前　言

网络空间成为国家安全新的疆域已经得到广泛认可，在信息化社会中，没有信息安全就没有国家安全，而保障信息安全依靠的核心要素是人。习近平总书记在 2016 年 4 月 19 日召开的网络安全和信息化工作座谈会中明确提出：“网络空间的竞争，归根结底是人才竞争。建设网络强国，没有一支优秀的人才队伍，没有人才创造力迸发、活力涌流，是难以成功的。”

《中华人民共和国网络安全法》实施以来，信息安全人才培养在不同的行业中都得到了高度的重视，企业纷纷通过组织或者参加各类 CTF 比赛、联合高校定向培养及内部培训等多种方式培养信息安全人才。尽管如此，信息安全人才短缺问题始终是目前各组织机构在信息安全工作中的痛点。中国信息安全测评中心主办的 2018 年度《中国信息安全从业人员现状调查》活动中，“职业教育”已经取代“自我学习”成为信息安全人才能力成长的首选方式。中国信息安全测评中心依据中央赋予的职能，从 2002 年起面向社会提供“注册信息安全专业人员”（CISP）培训服务，十多年来共培养了数万名信息安全专业人才，成为我国批量、快速培养高素质信息安全人才的主要方式之一，为我国党政军机关、职能部门以及金融、交通、能源等行业，国有大型企业及信息安全企业填补了信息安全专业人才队伍缺口。

中国信息安全测评中心在十多年信息安全职业教育的基础上，全面考察了国际知名信息安全职业教育知识体系，结合我国关键信息基础设施安全保障需求，汇聚国内著名信息安全专家及 CISP 培训讲师，编撰了本书，作为 CISP 培训体系中 CISE、CISO 两个培训证书的培训教材。本次教材改版是在原版本《信息安全保障》和《信息安全技术》两本书的基础上全面调整、修订而成，经过了一年的试用和多次完善。教材整体仍然以信息安全保障为核心，按照信息系统生命周期各阶段的工作，划分并重新构建了信息安全保障、网络安全监管、信息安全管理、业务连续性、安全工程与运营、信息安全评估、信息安全支撑技术、物理与网络通信安全、计算环境安全、软件安全开发十大知识域，基本覆盖了信息安全工作各个环节，通过学习可以有效地形成信息安全保障工作的体系化思路，较好地避免信息安全中“木桶效应”的出现。

本教材在编写的过程中得到了社会各界人士的关心与支持，许多信息安全专家、CISP 培训讲师参与了教材的编写和审核工作，特此感谢！

感谢中国信息安全测评中心李斌、徐长醒、张涛、戴忠华、王嘉捷、任望、姚轶崭给予的指导。感谢樊山、廖勇、雷敏、贺新朋、程晓峰、陈长松、张洪璇、干露、杜廷龙、廖宇力、杨天识、王星、张文祺、王厚魁、张水宁等 CISP 培训讲师为此付出的努力。

教材中不妥或错误之处恳请广大读者批评指正。

目　录

前言

第 1 章　知识域：信息安全保障 1

1.1　知识子域：信息安全保障基础 1
1.1.1　信息安全概念 1
1.1.2　信息安全属性 6
1.1.3　信息安全视角 8
1.1.4　信息安全发展阶段 13
1.1.5　信息安全保障新领域 17
1.2　知识子域：信息安全保障框架 25
1.2.1　基于时间的安全模型 25
1.2.2　信息安全保障技术框架 28
1.2.3　信息系统安全保障评估框架 31
1.2.4　企业安全架构 39

第 2 章　知识域：网络安全监管 43

2.1　知识子域：网络安全法律体系建设 43
2.1.1　计算机犯罪 43
2.1.2　我国立法体系 47
2.1.3　网络安全法 49
2.1.4　网络安全相关法规 53
2.2　知识子域：国家网络安全政策 59
2.2.1　国家网络空间安全战略 59
2.2.2　网络安全等级保护相关政策 60
2.3　知识子域：网络安全道德准则 62
2.3.1　道德约束 62
2.3.2　职业道德准则 63
2.4　知识子域：信息安全标准 65
2.4.1　信息安全标准基础 65
2.4.2　我国信息安全标准 70
2.4.3　网络安全等级保护标准族 75

第 3 章　知识域：信息安全管理 80

3.1　知识子域：信息安全管理基础 80
3.1.1　基本概念 80
3.1.2　信息安全管理的作用及对组织的价值 82
3.2　知识子域：信息安全风险管理 84
3.2.1　风险管理基本概念 84
3.2.2　常见风险管理模型 87
3.2.3　安全风险管理基本过程 89
3.3　知识子域：信息安全管理体系建设 93
3.3.1　信息安全管理体系成功因素 93
3.3.2　PDCA 过程 94

3.3.3 信息安全管理体系建设过程 96
3.3.4 文档化 99
3.4 知识子域：信息安全管理体系最佳实践 101
3.4.1 信息安全管理体系控制类型 101
3.4.2 信息安全管理体系控制措施结构 101
3.4.3 信息安全管理体系控制措施 103
3.5 知识子域：信息安全管理体系度量 129
3.5.1 基本概念 129
3.5.2 测量要求与实现 131

第 4 章 知识域：业务连续性 133

4.1 知识子域：业务连续性管理 ... 133
4.1.1 业务连续性管理基础 ... 133
4.1.2 业务连续性计划 135
4.2 知识子域：信息安全应急响应 145
4.2.1 信息安全事件与应急响应 145
4.2.2 网络安全应急响应预案 150
4.2.3 计算机取证与保全 151
4.2.4 信息安全应急响应管理过程 152
4.3 知识子域：灾难备份与恢复 ... 155
4.3.1 灾难备份与恢复基础 ... 155
4.3.2 灾难恢复相关技术 158
4.3.3 灾难恢复策略 163
4.3.4 灾难恢复管理过程 167

第 5 章 知识域：安全工程与运营 173

5.1 知识子域：系统安全工程 173
5.1.1 系统安全工程基础 173
5.1.2 系统安全工程理论基础 175
5.1.3 系统安全工程能力成熟度模型 179
5.1.4 SSE-CMM 的安全工程过程 182
5.1.5 SSE-CMM 的安全工程能力 203
5.2 知识子域：安全运营 207
5.2.1 安全运营概述 207
5.2.2 安全运营管理 207
5.3 知识子域：信息内容安全 212
5.3.1 内容安全基础 212
5.3.2 数字版权 214
5.3.3 信息保护 216
5.3.4 网络舆情 219
5.4 知识子域：社会工程学与培训教育 221
5.4.1 社会工程学 221
5.4.2 培训及教育 224

第 6 章 知识域：信息安全评估 226

6.1 知识子域：安全评估基础 226
6.1.1 安全评估概念 226
6.1.2 安全评估标准 228
6.2 知识子域：安全评估实施 239
6.2.1 风险评估相关要素 239
6.2.2 风险评估途径与方式方法 246
6.2.3 风险评估基本过程 250
6.2.4 风险评估文档 260
6.3 知识子域：信息系统审计 260
6.3.1 审计原则与方法 260
6.3.2 审计技术控制 264
6.3.3 审计管理控制 266
6.3.4 审计报告 267

第 7 章　知识域：信息安全支撑技术... 269

7.1　知识子域：密码学 269
7.1.1　密码学基本概念 269
7.1.2　对称密码算法 273
7.1.3　非对称密码算法 277
7.1.4　其他密码服务 282
7.1.5　公钥基础设施 286
7.2　知识子域：身份鉴别 293
7.2.1　身份鉴别的概念 293
7.2.2　基于实体所知的鉴别 294
7.2.3　基于实体所有的鉴别 297
7.2.4　基于实体特征的鉴别 298
7.2.5　Kerberos 体系 300
7.2.6　认证、授权和计费 303
7.3　知识子域：访问控制 304
7.3.1　访问控制模型的基本概念 305
7.3.2　自主访问控制模型 306
7.3.3　强制访问控制模型 308
7.3.4　基于角色的访问控制模型 312
7.3.5　特权管理基础设施 315

第 8 章　知识域：物理与网络通信安全 319

8.1　知识子域：物理安全 319
8.1.1　环境安全 319
8.1.2　设施安全 326
8.1.3　传输介质安全 327
8.2　知识子域：OSI 模型 329
8.2.1　OSI 模型 329
8.2.2　OSI 模型通信过程 330
8.2.3　OSI 七层模型安全体系 331
8.3　知识子域：TCP/IP 协议安全 334
8.3.1　协议结构及安全问题 334
8.3.2　安全解决方案 336
8.4　知识子域：无线通信安全 339
8.4.1　蓝牙安全 339
8.4.2　无线局域网安全 340
8.4.3　RFID 安全 345
8.5　知识子域：典型网络攻击及防范 346
8.5.1　欺骗攻击 346
8.5.2　拒绝服务攻击 349
8.6　知识子域：网络安全防护技术 350
8.6.1　边界防护 350
8.6.2　检测与审计 352
8.6.3　接入管理 354

第 9 章　知识域：计算环境安全 356

9.1　知识子域：操作系统安全 356
9.1.1　操作系统安全机制 356
9.1.2　操作系统安全配置要点 360
9.2　知识子域：信息收集与系统攻击 362
9.2.1　信息收集 362
9.2.2　缓冲区溢出攻击 365
9.3　知识子域：恶意代码防护 367
9.3.1　恶意代码预防 368
9.3.2　恶意代码检测与分析 370
9.3.3　恶意代码的清除 371
9.3.4　基于互联网的恶意代码防护 373
9.4　知识子域：应用安全 373
9.4.1　Web 应用安全 373
9.4.2　电子邮件安全 382
9.4.3　其他互联网应用 384
9.5　知识子域：数据安全 385
9.5.1　数据库安全 385
9.5.2　数据泄漏防护 386

第 10 章　知识域：软件安全开发 388

10.1　知识子域：软件安全开发生命周期 388
10.1.1　软件生命周期模型 388
10.1.2　软件危机与安全问题 ... 392
10.1.3　软件安全开发生命周期模型 396
10.2　知识子域：软件安全需求及设计 403
10.2.1　威胁建模 403
10.2.2　软件安全需求分析 406
10.2.3　软件安全设计 407
10.3　知识子域：软件安全实现 410
10.3.1　安全编码原则 410
10.3.2　软件安全编译 415
10.3.3　代码安全审核 415
10.4　知识子域：软件安全测试 416
10.4.1　软件测试 416
10.4.2　软件安全测试 420
10.5　知识子域：软件安全交付 424
10.5.1　软件供应链安全 424
10.5.2　软件安全验收 426
10.5.3　软件安全部署 426

英文缩略语 428

参考文献 436

第 1 章

知识域：信息安全保障

阅读提示 本知识域由信息安全保障基础和信息安全保障框架两个知识子域构成。信息安全保障基础知识子域介绍信息安全的基本概念及信息安全保障新领域的相关知识。信息安全保障框架知识子域介绍 PPDR、IATF、信息系统安全保障评估框架、舍伍德企业安全架构等信息安全保障模型。通过对这个知识域的学习，学员应理解信息安全问题产生的根源、信息安全的基本概念和发展阶段等相关知识，并了解典型的信息安全保障模型以指导信息安全保障工作。

1.1 知识子域：信息安全保障基础

1.1.1 信息安全概念

1. 信息安全定义

国际标准化组织（International Organization for Standardization，ISO）对信息安全的定义为：“为数据处理系统建立和采取技术、管理的安全保护，保护计算机硬件、软件、数据不因偶然的或恶意的原因而受到破坏、更改、泄露。”

美国法典第 3542 条给出的信息安全的定义为：“信息安全，是防止未经授权的访问、使用、披露、中断、修改、检查、记录或破坏信息的做法。它是一个可以用于任何形式数据（例如电子、物理）的通用术语。”

欧盟将信息安全定义为：“在既定的密级条件下，网络与信息系统抵御意外事件或恶意行为的能力，这些事件和行为将威胁所存储或传输的数据以及经由这些网络和系统所提供的服务的可用性、真实性、完整性和机密性。”

2. 信息安全问题

信息安全问题随着信息技术的发展而不断地蔓延发展，业务对于信息化的依赖性催生信息安全问题的复杂化，使得信息安全问题日益严峻。信息安全问题划分为狭义和广义两层概念。

（1）狭义的信息安全概念

对于狭义的信息安全而言，它是建立在IT技术基础上的安全范畴，是信息安全应用技术（最常见的是某种形式的计算机系统），有时也被称为计算机安全或网络安全。计算机不仅仅意味着家里的计算机终端，而是具有处理器和一些存储器的任何设备，这样的设备可以从简单的无须联网的独立的设备（如计算器）到诸如智能手机、平板电脑等联网移动计算设备等。由于数据的性质和价值，很多大型的组织机构都配置有信息安全专家，他们负责保护组织机构内的所有信息技术系统免受恶意网络攻击的威胁，这些攻击通常试图突破系统以获得关键的隐私信息或内部系统的控制权。

信息安全保障的目标是信息的保密性、完整性和可用性不被破坏。例如，确保在出现如自然灾害、计算机终端/服务器故障、盗窃等问题时数据不会丢失。这些信息安全保障工作通常由信息安全专家处理，对于上述例子中的问题，常见的处理方法是在问题发生前对数据进行异地备份。

（2）广义上的信息安全概念

广义的信息安全是一个跨学科领域的安全问题。

① 安全的根本目的是保证组织业务可持续性运行，保证利益相关者生命、财产安全的延续。构成业务可持续性问题的不仅仅是信息技术，还包括与业务相关联的生产、财务、人力资源、行政以及供应链等一系列的问题。在传统的意识中，不同的环节关注不同的元素，每个控制都只考虑本领域的控制问题，这使得安全本身被划分在不同的领域，如生产安全、财务安全、人员安全等，但其本质是相同的。安全应该被相互融合以构成立体化的安全保障。

② 信息安全应该建立在信息系统整个生命周期中所关联的人、事、物的基础上，综合考虑人、技术、管理和过程控制，使得信息安全不是一个局部，而是一个整体。随着信息安全事件的泛滥和扩大，组织越来越意识到信息安全问题既不是某个阶段的问题，更不是纯粹的技术问题。历史事件表明，单纯地从某个层次考虑安全问题往往会带来致命的损害。

③ 安全要考虑成本因素。财务成本是信息安全必须要考虑的问题，正如我们不会用价值数十万元的保险箱去保管面值10元的货币一样。安全的成本该如何考核呢？首要的问题应该是作为安全管理人员，必须清晰地了解组织的资产财务成本、价值以及组织利用信息技术带来的收益情况。随着互联网的普及和发展，信息技术已经开始为组织带来直接的经济收益，例如腾讯、百度、阿里巴巴等互联网公司，以及P2P、O2O、O2B等更多的依托互联网发展的产业。保护的成本必须和保护的资产价值形成有效的比率，这是财务风险中至关重要的一个环节。

④ 随着整个社会对信息化的依赖，信息系统所维系的不仅仅是业务的支撑和辅助，而且是业务的命脉。Web 2.0和互联网+的深入落实，整个业务被紧紧绑在信息系统之上，没有信息安全也就没有业务安全，业务流程本身的缺陷会直接导致信息安全问题的产生，而大量的业务绕行也为未授权的内部人员以及恶意外部人员所利用，因此，信息安全的管理者和操作者在实现安全的控制前提下，必须了解业务及流程，保障其最终所应该实现的业

务安全。

（3）信息安全问题的根源

造成信息安全问题的因素很多，技术故障、黑客攻击、病毒、漏洞等因素都可以造成信息系统安全问题。从根源来说，信息安全问题可以归因于内因和外因两个方面。

内因方面主要是信息系统复杂性导致漏洞的存在不可避免，换句话说，漏洞是一种客观存在。这些复杂性包括过程复杂性、结构复杂性和应用复杂性等方面。

外因主要包括环境因素和人为因素。从自然环境的角度看，雷击、地震、火灾、洪水等自然灾害和极端天气容易引发信息安全问题；从人为因素来看，员工的误操作及外部攻击（黑客、犯罪团伙、恐怖分子、竞争对手甚至网络战部队等）都是信息安全问题的外因。根据掌握的资源和具备的能力来看，针对信息系统的攻击由低到高分别是个人威胁、组织层面威胁（犯罪团伙、黑客团体、竞争对手等）和国家层面威胁（网络战部队）。

3．信息安全特征

（1）信息安全问题是复杂的问题，具有系统性

信息技术的发展以巨大的力量推动人类社会生存方式产生重大变革，这一变革使我们面对前所未有的复杂环境，这些环境包括以下方面。

① 一个无所不在、全球互联互通的国际化网络空间。

② 无数广域覆盖的、规模庞大而复杂的网络信息系统。

③ 品种多样的海量计算设备与信息处理终端。

在这个“人-机”“人-网”紧密结合的复杂系统中，某一分支或某一要害环节受到损害，均可能引发全局性的系统危机，从这个角度而言，我们不能孤立地从单一维度或单个安全因素来看待信息安全，将之视为单纯的技术问题或者管理问题，而是要系统地从技术、管理、工程和标准法规等各层面综合保障安全。

（2）信息安全是动态的安全，具有动态性

信息系统始于需求分析，终止于废弃或者退役，具有“生命周期”的概念。在整个生命周期中，信息安全需求和所面临的问题都是不一样的，因此，不能用固化的视角看待。风险是动态变化的，新的漏洞被发现，新的攻击手段出现，都会对系统的安全状况产生影响。新的信息技术不断出现，例如云计算、物联网、三网融合等新技术和新应用在带给人们便利的同时，也产生了各种新的安全风险和威胁。这都反映信息安全不能抱有一劳永逸的思想，而是要以风险管理的思想，根据风险的变化，在信息系统的整个生命周期中采取相应的安全措施来控制风险。

信息安全的动态特性决定了信息安全问题与实践密切相关。信息安全已经从病毒传播、黑客入侵、技术故障等局部性、个别性和偶发性的问题，逐步转变为网络犯罪、网络恐怖主义、网络战等全局性问题，成为攻守双方在高新技术领域内展开的一场激烈较量。

安全的动态性还需要关注组织业务的动态，组织的业务是在动态中发展，而由此产生的安全问题亦在改变。同时人的动态性也加剧了安全的复杂性，内部威胁带来的危害往往甚

于外部的攻击。“斯诺登事件”“维基解密”等都充分地暴露了组织内部威胁的重要影响。

（3）信息安全是无边界的安全，具有开放性和互通性

信息化的重要特点是开放性和互通性，信息关键基础设施都是广域覆盖的、大规模、复杂的信息系统，往往与互联网通过各种方式连接，例如金融、税务、电子政务系统等，同时各系统之间也日益互联互通，这使得信息安全威胁超越了现实地域的限制。

互联网具有传播速度快、覆盖面广、隐蔽性强和无国界等特点，违法犯罪活动逐步向互联网渗透，利用网络进行各种破坏活动，造成信息安全问题的跨边界特点，这对安全保障提出了更高的要求。

（4）信息安全是非传统的安全，与传统的安全相比显著不同

信息技术是20世纪最为重要的技术变革，其安全问题与军事安全、政治安全等传统安全相比，有显著不同。国家没有受到武力进攻，国家领土和主权是完整的，但人们却感受到不安全；没有明确的敌对国家，人们却感受到威胁的存在。传统的维护安全的军事和治安手段，无法应对信息安全这种新事物，必须采用新的信息安全保障手段来维护互联网安全。

4．威胁情报

情报的主要作用是为管理人员提供行动和制定决策的依据。威胁情报是建立在大量的数据搜集和处理的基础上，通过对搜集数据的分析和评估，形成相应的结论。与传统信息处理不同，威胁情报需要长时间关注各类与信息安全相关的数据，这些数据分散在不同的来源中，通过建立威胁模型对不同来源的数据进行分析，以识别出针对防护目标的特定威胁，并给出相应的对策建议，为管理者提供决策支持。以下案例较好地说明了威胁情报在信息安全保障中的作用。

案例：传统的安全信息处理中，安全服务商会从不同渠道收集威胁信息并通告给用户，同时给出相应的处理建议。例如安全服务商从不同的渠道收集到以下信息。

- 一个Java开发语言的0day漏洞被公开在一个安全邮件列表中。
- 某攻击者组织发布了一个利用此漏洞的攻击工具。

这些信息对用户是非常有用的信息，但这仅仅是威胁信息，威胁情报需要搜集和分析的数据更多。

- 根据安全厂商发布的数据，利用此漏洞的恶意软件在亚太地区感染率远高于美国。
- 被感染了恶意软件的计算机终端会被加入一个僵尸网络，并且会持续下载新的变种恶意代码。
- 某金融机构发布了一个新的政策，这个政策导致了大量的消费者不满，相关论坛上出现了大量针对该金融机构的抗议活动的讨论。
- 一个黑客组织发布了该僵尸网络的利用方法和相关软件。

这些信息汇总起来，就能分析出可能存在的安全风险：某金融机构很可能被攻击者利用这个僵尸网络进行分布式拒绝服务攻击，而亚太地区是感染率最高的地区，因此是攻击来源最多的区域。根据这个威胁情报，就能采取相应的技术措施，以降低可能带来的安全风险。

在信息安全保障中，威胁情报的重要性已经越来越高，甚至成为信息安全保障中的关键。

（1）威胁情报有助于应对安全威胁与防御的不平等

信息化的发展使得组织机构需要应对的安全威胁已经发生根本性的改变，很多攻击已经不仅仅是技术表面所展现出来的那么简单，而导致威胁的人员已经不仅仅局限于热衷网络攻击的个人或团体。网络战部队、专业化组织的攻击团队由于掌握资源丰富，具有很好的技术支持，也有足够的时间去寻找目标对象的信息系统漏洞，只需要找到一个可利用的薄弱点就能对组织机构产生极大的安全威胁。与之相对应的情况是，大量的组织机构只能投入有限的资源去构建防御体系，并且防御体系需要覆盖所有可能的攻击，这种不平等的状况使得组织机构更需要威胁情报，以有效应对各类安全威胁。

（2）威胁情报能降低组织机构信息安全投入

技术的发展使得信息安全威胁类型、数量不断增加，组织机构需要投入大量的资源进行应对，特别是极具威胁的定向攻击、0day 漏洞等。大多数组织机构并不具备评估和应对这些威胁的资源和知识技能。而威胁情报由经过训练、拥有专业工具并且理解现代攻击者思维模式、方法，有资历的威胁情报分析人员来进行实施。根据威胁情报的结论进行针对性的决策和处理，使得组织机构的安全保障工作更有序，也更有效率，从而降低整体安全投入。

（3）威胁情报能确保找到优先应对的安全问题

攻击数量的庞大以及持续性攻击的出现，使得传统的安全分析方式难以应对。传统的信息安全分析停留在处理过程的“数据”和“信息”阶段，这些虽然在一定程度上可用于抵御安全风险，但并不足以应对当前的安全环境，而威胁情报能更好地帮助管理者找到优先需要应对的安全威胁，从而使得工作更有序。

（4）威胁情报能帮助组织机构适应不断发展的技术和环境变化

信息技术的演化和扩展是威胁情报发展的一个重要驱动因素。信息技术的日益发展使得组织机构的信息化环境每隔几年都发生巨大的变化。例如移动互联网的发展，移动智能终端大量应用，使得远程办公成为常态。虚拟化、云计算等新技术的应用，使得组织机构中信息技术的应用范围和应用场景更加多样化。这些新技术很多时候并不是简单地替代原有的技术，通常是在原有技术上的叠加，这使得组织机构面临的威胁也在增加，而威胁情报能帮助组织机构更好地应对这种变化。

5. 态势感知

态势感知（Situational Awareness，SA）概念起源于 20 世纪 80 年代的美国空军，指分析空战环境信息，快速判断当前及未来形势并做出正确反应。随着网络空间安全上升到国家安全的高度，态势感知也逐渐在信息安全保障中得到应用。态势感知是一种基于环境的、动态、整体地洞悉安全风险的能力，是以安全大数据为基础，从全局视角提升对安全威胁的发现识别、理解分析、响应处置能力的一种方式，最终是为了决策与行动，是安全能力的落地。有效的态势感知不是某种单一技术，而是建立在威胁情报分析基础上，以大数据

和高性能计算为支撑，综合网络威胁相关的形式化及非形式化数据进行分析，并形成对未来网络威胁状态进行预判以便调整安全策略，实现“御敌于国门之外”的策略。

态势感知以简明、丰富、图形化和易于搜索的系统形式展现，并且按照优先级对威胁进行排序。通过态势感知，组织机构能建立安全预警机制，实现完善风险控制、应急响应和整体安全防护水平的提升。

1.1.2 信息安全属性

通常情况下，保密性、完整性和可用性（CIA）被称为信息安全基本属性，如图 1-1 所示。此外，还可以涉及其他属性，例如真实性、可问责性、不可否认性和可靠性（ISO/IEC 27000—2014《信息技术 信息安全 信息安全管理体系概述和词汇》）。

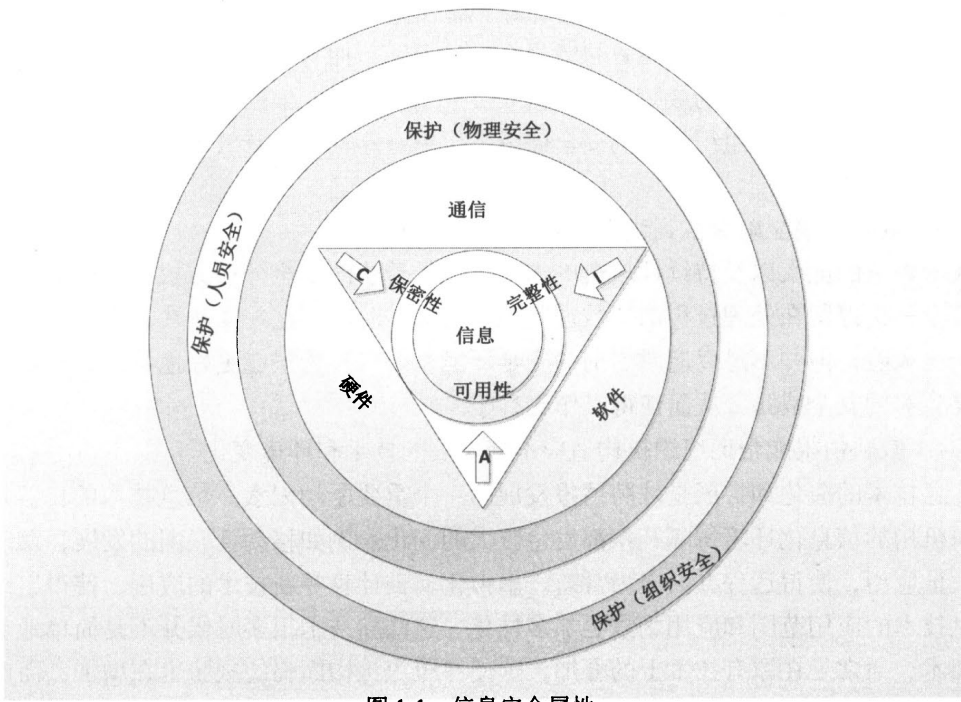

图 1-1 信息安全属性

1. 信息安全三元组

信息安全三元组（CIA）是一个著名的安全策略开发模型，用于识别信息安全领域的问题和提供必要的解决方案。

（1）保密性（Confidentiality）

保密性亦称机密性，是指对信息资源开放范围的控制，确保信息不被非授权的个人、组织和计算机程序访问。对于信息系统而言，保密性涉及的范畴非常广泛，可以是国家秘密，也可以是企业或研究机构的业务数据，还可以是个人的银行账号、身份证号等信息，因此，信息的保密性问题是人人都需要面对的。

保护机密性的工作包括为信息定义机密等级，实施适当的访问控制，对可能违反保密策略的行为进行控制的措施等。设置文件的访问控制权限、访问控制列表及文件加密等都是在信息系统中进行保密性控制的实际措施。

（2）完整性（Integrity）

完整性是保证信息系统中的数据处于完整的状态，确保信息没有遭受篡改和破坏。任何对系统信息、数据的未授权的插入、篡改、伪造都是破坏系统完整性的行为，这些行为可能导致严重的服务中断或其他问题。在合理的情况下，修改应该是可逆的。版本控制、系统及数据备份是确保完整性的常用措施之一，这些措施使得授权人员能方便地修改数据并且能很容易地撤销修改。

（3）可用性（Availability）

为了确保数据和系统随时可用，系统、访问通道和身份验证机制等都必须正常地工作，这就是可用性。也就是说，无论什么时候，只要得到授权的实体需要，信息系统必须是可用的，不能拒绝服务。增强的可用性要求还包括时效性及避免因自然灾害（火灾、洪水、雷击、地震等）和人为破坏导致的系统失效。

高可用（High Availability，HA）系统的架构就是针对特定的可用性需求进行设计，能有效地应对断电、硬件故障等问题对可用性的影响。而为网络使用多个接入链路以避免网络中断的风险，也能很好地应对拒绝服务攻击这类影响可用性的问题。

（4）模型的局限性

CIA 三元组关注的重心在信息，虽然这是大多数信息安全的核心要素，但对于信息系统安全而言，仅考虑 CIA 是不够的。信息安全的复杂性决定了还存在其他的重要因素。CIA 给出了一个信息系统整体安全模型框架，能帮助信息化工作人员在制定安全策略时形成思路，但这并不是所有需要考虑的策略。CIA 三元组可以作为规划、实施量化安全策略的基本原则，但是我们也应该认识到它的局限性。

2．其他信息安全属性

（1）真实性

真实是他所声称的属性，也可以理解为能对信息的来源进行判断，能对伪造来源的信息予以鉴别。

（2）可问责性

作为治理的一个方面，问责是承认和承担行动、产品、决策和政策的责任，包括在角色或就业岗位范围内的行政、治理和实施以及报告、解释并对所造成的后果负责。

在治理中，问责制已经超出了“解释一个人的行为”的基本定义。它经常被描述为账户之间的相互关系，例如“A 对 B 负责，A 必须通知 B 关于 A（过去或未来）的行动和决定并说明理由，并在最终的不当行为的情况下受到惩罚”。

（3）不可否认性

证明要求保护的事件或动作及其发起实体的行为。在法律上，不可否认意味着交易的

一方不能拒绝已经接收到的交易，另一方也不能拒绝已经发送的交易。虽然从技术校对来看，密码系统已经可以辅助实现不可否认，但不可否认这个概念是超越技术领域的法律概念。例如，发送者在发送消息时虽然已经利用私钥进行数字签名，理论上在传输过程中是不可被更改。但如果发送者可以证明数字签名算法存在漏洞或者缺陷，或者证明他自己用于签名的密钥已经被破坏，发送者即使存在抵赖，也很难证明与其关联的信息的真实性和完整性是否有效。

（4）可靠性

可靠性是信息系统能够在规定条件下、规定时间内完成规定功能的特性。

1.1.3 信息安全视角

1. 国家视角

2009 年，美国的《国家网络安全综合计划》（Comprehensive National Cybersecurity Initiative，CNCI）被披露出来，信息安全上升到国家安全高度的主张被全世界认可，网络战、关键基础设施保护在现代国防领域中凸显作用。近年来，工业控制系统（Industrial Control System，ICS）攻击使得网络攻击从虚拟世界走向了现实生活，而信息技术在军事、金融领域的广泛应用也使得相应的系统逐渐成为敌对国家和政治势力的攻击目标。

对于国家内部的社会公共秩序的稳定是传统的国家信息安全保护范畴，不管是“茉莉花革命”还是“颜色革命”都显示网络空间对整个社会巨大的影响力和穿透性，立法保护与标准化的推进构成国家安全的重要组成部分。

> 茉莉花革命是发生于 2010 年年末的北非突尼斯反政府示威导致政权倒台的事件，因茉莉花是其国花而得名。维基解密网站曝光的电文是突尼斯这次革命的催化剂。
>
> 颜色革命是指 20 世纪末期开始的一系列发生在中亚、东欧独联体国家的以颜色命名，以和平和非暴力方式进行的政权变更运动。

（1）网络战（Cyberwarfare）

一些政府已经将网络战当作其整体军事战略的一个组成部分，并且在网络战争能力方面做了大量的投入。例如，美国以战略方式实现防止关键基础设施受到网络攻击、降低国家应对网络攻击时的脆弱性、最小化网络攻击的损害和恢复时间。

① 美国

网络战争在美国是军事战略的一部分。2009 年，美国宣布数字基础设施成为“战略性国家资产”，2010 年 5 月，五角大楼成立了新的美国网络司令部，隶属美国国家安全局（National Security Agency，NSA），由国家安全局局长领导，捍卫美国军事网络和攻击其他国家的系统。2017 年 8 月 18 日，美国宣布将美军网络司令部升级为美军第十个联合作战司令部，地位与美国中央司令部等主要作战司令部持平。这意味着，网络空间正式与海洋、陆地、天空和太空并列成为美军的第五战场，令人担忧的是网络空间军事化趋势正进

一步加剧。

美国国防部认为使用计算机和互联网在网络空间进行战争是对国家安全的威胁，美国联合部队指挥部描述了其中一些特点。

- 网络空间技术正在社会中成为一种“权力工具”，并且越来越多地被一个国家的对手使用，他们可以利用它来攻击、降低和破坏通信及信息流动。
- 由于进入门槛低，加上网络空间活动的匿名性，网络空间安全面临的潜在攻击者类型广泛，数量众多。
- 全球范围的网络空间及其对国家边界的漠视将挑战法律制度，使一个国家阻止威胁和应对突发事件的能力复杂化。

② 俄罗斯

俄罗斯军队非常重视网络战，将“网络突击”视作等同火力突击的作战样式。20 世纪 90 年代初，俄罗斯就设立了专门负责网络信息安全的信息安全委员会，1995 年将信息安全纳入国家安全管理范畴。2002 年，信息安全委员会通过了《俄联邦信息安全学说》，提出了保障信息安全的指导原则。2011 年，俄罗斯倡议制定《保障国际信息安全》国际公约，规范网络空间行为。2013 年，俄罗斯组建网络安全部队并在一年后成立网络战司令部，网络战部队参与了多次局部战争并积累了丰富的网络实战经验。

对于网络战，俄罗斯意识到“信息资源和基础设施对政治和经济起决定性作用，对国家前途、利益和安全至关重要，必须做好准备应对信息威胁，提升对相关基础设施尤其是战略性设施的防护能力，信息战和网络战已被各国用于达成军事和政治目的，其威力甚至会大于常规武器”。

③ 德国

2013 年，德国透露了他们存在一个有 60 人规模的计算机网络操作单位。德国情报机构 BND 宣布它正在为一个新的“网络防御站点”单位招聘 130 名“黑客”。爱德华·斯诺登泄露美国国家安全局的网络监控系统的细节后，德国内政部长汉斯-彼得·弗里德里希宣布，将额外增加 1 亿欧元预算，将其在德国的网络监视能力从网络流量的 5%增加到总流量的 20%，这也是德国法律允许的最大量。

④ 英国

2013 年，英国宣布将陆军后备军培养成为网络安全专家以应对来自网络安全的威胁。随后不久，英国军方认识到网络空间的威胁和机会使得武装部队应该在思想和行动方面有所转变，网络安全能力被全面整合到军队的规划、指挥与控制中。

（2）国家关键基础设施保护

① 中国

2012 年，国务院下发了《关于大力推进信息化发展和切实保障信息安全的若干意见》的 23 号文，明确指出“大力推进信息化发展和切实保障信息安全，对调整经济结构、转变发展方式、保障和改善民生、维护国家安全具有重大意义”，要求“采取更加有力的政策措施，大力推进信息化发展，切实保障信息安全”。国务院 23 号文同时也指出我国目前还

存在“信息安全工作的战略统筹和综合协调不够，重要信息系统和基础信息网络防护能力不强”等问题。2013 年党的第十八届三中全会公报提出，要“设立国家安全委员会，完善国家安全体制和国家安全战略，确保国家安全”，关键基础设施必须与国民经济和社会发展相协调。

2016 年 11 月通过的《中华人民共和国网络安全法》（以下简称《网络安全法》）第三章第二节第三十一条定义了我国关键基础设施：“公共通信和信息服务、能源、交通、水利、金融、公共服务、电子政务等重要行业和领域，以及其他一旦遭到破坏、丧失功能或者数据泄露，可能严重危害国家安全、国计民生、公共利益的基础设施。”

2016 年 12 月，互联网信息办公室发布的《国家网络空间安全战略》指出，关键信息基础设施保护是政府、企业和全社会的共同责任，主管、运营单位或组织要按照法律法规、制度标准的要求，采取必要措施保障关键信息基础设施安全，逐步实现先评估后使用。国家关键信息基础设施建设要坚持技术和管理并重，保护和震慑并举，着眼识别、防护、检测、预警、响应、处置等环节，建立实施关键信息基础设施保护制度，从管理、技术、人才、资金等方面加大投入，依法综合施策，切实加强关键信息基础设施安全防护。

② 美国

美国政府早在 1996 年第 13010 号行政令中，建立了“总统关键基础设施保护委员会”，负责向总统汇报关键基础设施的脆弱点信息，应对加强基础设施保护提案所引发的法律问题等，并且定义关键基础设施主要包括电信、电力系统、天然气及石油的存储和运输、银行和金融、交通运输、供水系统、紧急服务（包括医疗、警察、消防和救援）、政府连续性 8 类。

1998 年第 63 号总统令，计划在联邦调查局建立“国家关键基础设施保护中心”，负责协调联邦政府应急响应、调查威胁和监督恢复等工作。新建立的“国家关键基础设施保护中心”将汇聚来自政府与私营企业的代表，开展信息共享尝试，同时鼓励政府与企业建立信息共享和分析中心。

2001 年第 13231 号行政令宣布成立“国家关键基础设施保护委员会”，委员会有权修改关键基础设施保护政策，须定期就其职能范围内的各种问题提出计划和建议。

2002 年，依据《国土安全法》组建了国土安全部，其所属的信息分析与基础设施保护局负责关键基础设施保护工作。《国土安全法》确立了关键基础设施信息的共享程序，要求各行业设立信息共享和分析组织，以集合、分析和披露关键基础设施信息，并对泄露信息的行为做了相应处罚规定。

2003 年 12 月，美国发布第 7 号国家安全总统令《关键基础设施的识别、优先级和防护》，该令确定了 17 类关键基础设施和重要资源（CI/KR）：化学制品、商业设施、通信、大坝、国防工业基地、应急服务、能源和电力、金融服务、食品和农业、政府设施、公共健康和医疗、信息技术、商用核反应堆及核材料与废弃物、运输、饮用水和废水处理系统、邮政和货运服务、国家纪念碑和象征性标志。

2008 年，国土安全部宣布挑选“关键制造业”作为第 18 类需要保护的国家基础设施

和关键资源。

2013 年第 21 号总统令强化了国土安全部的职责，并对其他部门在关键基础设施保护方面的角色和责任进行了详细界定。重新确定了 16 类关键基础设施部门：化学、商业设施、通信、关键制造、水利、国防工业基地、应急服务、能源、金融服务、食品和农业、政府设施、医疗保健和公共卫生、信息技术、核反应堆及核材料和废弃物、运输系统、水及污水处理系统，同时直接将促进政府部门之间以及与关键基础设施所有者和运营者之间的有效信息交换作为措施之一。

2017 年 1 月，美国国家标准与技术研究所发布的《改进关键基础设施的网络安全框架 1.1》将关键基础设施定义为“对美国至关重要的实物及虚拟系统和资产，因为这些系统和资产丧失能力或被破坏将对网络安全，国家经济安全，国家公共卫生、公共安全等事项的任何组合造成削弱性影响。”

（3）法律建设与标准化

法律是一国之根本，信息安全问题的特殊性和复杂性需要国家通过法律进行约束。信息安全立法活动必须在立法原则的指导下进行，才能把握信息安全发展的客观规律，更好地发挥法律调控功能。

由于互联网的开放、自由和共有的脆弱性，国家安全、社会公共利益以及个人权利在网络活动中面临着来自各方面的威胁，国家需要在技术允许的范围内保持适当的安全要求。这即美国联邦信息安全管理法所确认的“适度安全”。所谓适度安全是指安全保护的立法的范围要和应用的重要性相一致，不需要花费过多的成本，限制信息系统的可用性。

与传统安全一样，信息安全风险具有“不可逆”的特点，需要信息安全法律采取以预防为主的法律原则。由于信息安全威胁的全局性特点，其法律原则更应当采取积极主动的预防原则，从发现威胁、降低风险、控制风险的一切环节构建信息安全法律保障能力。

2．企业视角

企业是社会的根本，9·11 事件后，组织发现信息技术已经开始左右自己的生存命脉，世贸大厦的倒塌对于其中大量的组织机构而言，损失的不仅仅是人和有形的物理资产，更致命的是业务数据在瞬间灰飞烟灭；当组织需要重构业务时，失去了可依托的数据资产，使得大多数组织不得不面临破产、转型、重生等重大抉择。

国际信息安全立法在不断发展和完善，更多的组织在建立业务链的过程中所保留的用户信息、企业信息被国际相关法规明确规定了隐私保护、信息保护以及知识产权保护等权利和义务，使得组织一方面要考虑业务数据的可用性和完整性，另一方面还要关注它的保密性问题。

（1）业务连续性管理

业务连续性管理对组织机构至关重要，虽然盗窃、知识产权侵犯、无形资产损失等系列问题对组织机构的业务影响严重，但都无法与信息系统中断导致组织业务发生重大中断相比。对于目前大量的组织机构，信息系统已经成为业务支撑的关键因素，信息系统的中断对组织机构而言就是一场灾难。组织机构应针对性地做出许多准备，以应对信息系统面

临的诸多威胁，包括自然灾害，如洪水、飓风、龙卷风、地震等；人为灾害，如事故、人身暴力行为和恐怖主义行为等。

业务连续性管理（Business Continuity Manager，BCM）是一项应对上述问题的综合管理流程，它使企业认识到潜在的危机和相关影响，制订相应业务连续性的恢复计划，其总体目标是为了提高企业的风险防范能力，以有效地响应计划外的业务破坏并降低不良影响。这也是信息安全领域中一项重要的工作，需要得到广泛的重视和关注。

（2）资产保护

由于信息安全的复杂性，如何有效地实现安全保障是困扰组织机构的一个问题。对于组织机构而言，实施有效的安全保障的前提是明确需要保护的资产。组织机构应首先考虑以下问题。

① 组织机构有哪些资产？

② 这些资产对组织机构的价值在哪？

③ 是否需要对这些资产进行保护？

这些简单的问题对于每一个组织机构的管理者来说通常都很难得到准确的答案。尽管适度保护、实现可衡量的经济价值等概念都能得到理解，但在组织机构信息安全保障中却存在难以取舍的问题。没有绝对的安全，在一个合理的成本情况下，需要放弃什么成为考核一个组织机构应对业务连续性管理时的一个首要问题。

（3）合规性

合规性包括两个层面的问题：法律法规的符合，如知识产权侵犯，符合法律的网络监控行为和数据出口行为；标准的符合，如第三方支付卡业务所需要的 PCI-DSS，政府、国企所需要的信息安全等级保护等标准规范文件。组织的运行离不开合规性的保护和约束，所以组织必须选择适合自己的合规性规约。

合规性监管是组织机构通过行政手段对执行有关法律法规、制度和规章等情况进行监管，以确保组织机构遵守相关法律法规和政策，并明确组织机构希望实现的目标。随着法规数量的增加及对业务透明度的需求越来越多，组织机构也越来越多地关注合规性问题以确保满足所有必要的治理要求，避免造成不必要的重复工作和资源浪费。

国际标准化组织（ISO）制定国际标准，国际电工委员会（International Electrotechnical Commission，IEC）在电工技术领域制定国际标准，如 ISO/IEC 27002。一些本地或国际专业组织，如美国机械工程师协会（American Society of Mechanical Engineers，ASME）也制定标准和法规。此外，还有一些适用不同领域的其他法规，如 PCI-DSS、GLBA、FISMA 和 HIPAA。

3．个人视角

（1）隐私保护

“自从有了互联网，我们在虚拟世界中就开始了赤裸裸的生活”，也许用这个比喻来形容现代互联网下每个人所不得不面对的问题更为恰当。当我们无时无刻不使用互联网技术时，隐私保护和隐私信息的恶意使用成为全世界安全专家一个棘手的问题。从个人角度

而言，这不仅仅是一个技术问题，还是一个社会问题、法律问题以及道德问题。

美国是世界上最早提出并通过法规对隐私权予以保护的国家，1974 年通过《隐私法案》，1986 年颁布《电子通讯隐私法案》，1988 年又制定了《电脑匹配与隐私权法》及《网上儿童隐私权保护法》。

在我国法学界“人肉搜索”是一个存在广泛争议的问题，个人在互联网平台所发布的信息是否可以被无限制地引用本质上是一个法律问题，但是其具体的表现形式及暴露却是赤裸裸的信息技术的实现问题。2014 年我国在《最高人民法院关于审理利用信息网络侵害人身权益民事纠纷案件适用法律若干问题的规定》中，对有关“人肉搜索”行为做出司法约束，但并未对“人肉搜索”本身提供明确司法解释。

由于隐私问题在我国法律中没有明确定义，因此隐私侵犯在互联网中比比皆是，常见的问题如恶意发布他人身份信息、医疗健康信息和注册信息等，这些信息被泄露后常用作电信诈骗等。

（2）社会工程学

社会工程学的实质是一种通过对受害者心理弱点，如本能反应、好奇心、信任、贪婪等进行利用，实现对受害者进行欺骗以获取自身利益的方法。针对个人的社会工程学攻击如“我是你领导”、“你有一个包裹未领取”、中奖短信等。

导致这种攻击的原因是互联网用户在网上发布的信息，如朋友圈、微博、论坛、各种平台的注册信息等都形成了个人信息的暴露，这些信息被攻击者恶意利用就可能对用户带来很多的损失。为了避免不必要的损失和伤害，安全意识问题应受到广泛的重视。

（3）个人资产安全

随着互联网的不断发展，越来越多的互联网技术与个人生活息息相关。人们在不同的业务交互中与互联网紧密关联，如互联网社交、互联网支付、互联网政务平台以及智能家居等。互联网技术中如何识别用户身份是构成这些技术实现的基础，而身份本身的构成使得每一个依托互联网平台的人在大数据平台下暴露无遗。个人在网络空间需要关注的问题如下。

① 如何思考个人信息资产安全问题?

② 哪些信息资产被恶意利用后会形成人身的伤害。

③ 哪些信息资产被恶意利用后会形成财务的损失。

④ 哪些信息资产被恶意利用后会形成法律责任。

这些系列问题都是个人安全视角中的重要环节。

1.1.4　信息安全发展阶段

1．通信安全阶段

19 世纪中叶以后，随着电磁技术的发展，诞生了电报和电话，人类通信领域产生了根本性的飞跃，开始了人类通信新时代。

1837 年，美国人莫尔斯（Morse）发明了莫尔斯电码，可将信息转换成电脉冲传向目

的地，之后再转换为原来的信息，从而实现了长途电报通信。

1875 年，贝尔（Bell）发明了电话机，1878 年在相距 300 千米的波士顿和纽约之间进行了首次长途电话实验，获得了成功。

1906 年，美国物理学家费森登（Fessenden）成功地研究出无线电广播。法国人克拉维尔建立了英法第一条商用无线电线路，推动了无线电技术的进一步发展。

进入 20 世纪，尤其是在“二战”时期，军事和外交方面的巨大需求，使得无线通信技术得到飞速发展，被广泛用来传递军事情报、作战指令、外交政策等各种关键信息。21 世纪，通信技术突飞猛进的发展，移动通信和数字通信成为通信技术的主流，现代世界中，通信技术成为支撑整个社会的命脉和根本。各行各业都将业务与通信技术相结合，如电子政务、电子金融、互联网产业、物联网、移动互联网等。

在通信阶段，信息安全面临的主要威胁是攻击者对通信内容的窃取：有线通信容易被搭线窃听、无线通信由于电磁波在空间传播易被监听。保密成为通信安全阶段的核心安全需求。这阶段主要通过密码技术对通信的内容进行加密，保证数据的保密性和完整性，而破译成为攻击者对这种安全措施的反制。

随着技术的不断发展，影响现代通信安全的因素越来越多，如针对移动通信的伪基站，对通信链路的破坏、干扰等因素。

2．计算机安全阶段

20 世纪发明的计算机，极大改变了信息处理方式和效率，从此信息技术进入计算机阶段。1946 年，美国为了解决弹道分析和氢弹研究所需要的大量计算问题，研制出电子数字积分计算机（Electronic Numerical Integrator And Computer，ENIAC），这是世界上第一台通用计算机。ENIAC 重 30 吨，用了 18000 个电子管。

计算机经历了电子计算机、晶体管计算机、集成电路计算机等几个阶段。尤其是在进入 20 世纪 70 年代后，随着个人计算机的普及，各行各业都迅速采用计算机处理各种业务。计算机在处理、存储信息数据等方面的应用越来越广泛。美国国家标准局公布了《数据加密标准》（Data Encryption Standard，DES），标志着信息安全由通信保密阶段进入计算机安全阶段。这个时期，计算机网络尚未大规模普及，相对于电话电报，计算机对信息的处理和存储能力强大，但数据长距离、大容量的传输方式较单一，功能相对较弱（主要通过软盘等形式传输）。因此，计算机阶段主要威胁来自于非授权用户对计算资源的非法使用、对信息的修改和破坏。

技术的发展使得计算机越来越小型化，智能终端（智能手机、个人数字助理（PDA）、平板电脑等）出现并迅猛地占据移动终端市场，BYOD（Bring Your Own Device，携带你自己的设备）将计算机终端带入一个新的时代并有可能在未来取代计算机终端设备。智能终端多元化的网络接入模式、轻巧便捷的携带和高速处理能力将传统个人计算机的优势发挥得淋漓尽致。然而目前广泛使用的智能终端系统及平台架构的安全问题也越来越复杂并且多样化。不可预见的硬件安全问题，不断进步的智能终端恶意代码问题，即时处理终端和支付终端所引发的支付风险问题，被盗后引发的个人隐私安全问题等已经成为智能终端

应用的难题。

20 世纪 80 年代计算机安全的概念开始成熟。计算机安全的主要目的是采取措施和控制以确保信息系统资产（包括硬件、软件、固件和通信、存储和处理的信息）的保密性、完整性和可用性。典型代表措施是通过操作系统的访问控制手段来防止非授权用户的访问，主要标志是 1985 年美国国防部发布可信计算机系统评估准则（Trusted Computer System Evaluation Criteria，TCSEC），该标准将操作系统安全由低到高分为 4 类共 7 个级别（D、C1、C2、B1、B2、B3、A1），这就是著名的橙皮书。TCSEC 是世界上第一个有关信息技术安全评估的标准。随后美国国防部又发布了可信数据库解释（Trusted Data-Base Interpret，TDI）、可信网络解释（Trusted Network Interpret，TNI）等一系列相关的说明和指南，由于这些文档发行时封面均为不同的颜色，因此也被称为“彩虹系列”。

3．信息系统安全阶段

计算机网络尤其是互联网的出现是信息技术发展中一个里程碑事件。计算机网络将通信技术和计算机技术结合起来。信息在计算机上产生、处理，并在网络中传输。信息技术由此进入网络阶段，网络阶段利用通信技术将分布的计算机连接在一起，形成覆盖整个组织机构甚至整个世界的信息系统。信息系统安全是通信安全和计算机安全的综合，信息安全需求已经全面覆盖了信息资产的生成、处理、传输和存储等各阶段，确保信息系统的保密性、完整性和可用性。

信息系统安全也曾被称为网络安全，主要是保护信息在存储、处理和传输过程中免受非授权的访问，防止授权用户的拒绝服务，同时检测、记录和对抗此类威胁。为了抵御这些威胁，人们开始使用防火墙、防病毒、PKI、VPN 等安全产品。此阶段的主要标志是发布了《信息技术安全性评估通用准则》，此准则即通常所说的通用准则（Common Criteria，CC），后转变为国际标准 ISO/IEC 15408，我国等同采纳此国际标准为国家标准 GB/T 18336。

注：《网络安全法》中对“网络安全”进行了定义，与本阶段中“网络安全”两个概念并不完全等同。

4．信息安全保障阶段

随着信息化的不断深入，信息系统成为组织机构工作和生活不可或缺的一部分，信息安全威胁来源从个人上升到犯罪组织，甚至国家力量。在这个阶段，人们认识到信息安全保障不能仅仅依赖于技术措施，开始意识到管理的重要性和信息系统的动态发展性，信息安全保障的概念逐渐形成和成熟。

信息安全保障把信息系统安全从技术扩展到管理，从静态扩展到动态，通过各种安全保障技术和安全保障管理措施的综合融合至信息化中，形成对信息、信息系统乃至业务以及使命的保障。

1996 年，美国国防部第 5-3600.1 号指令（DoDD 5-3600.1）第一次提出了信息安全保障（也称信息保障）的概念。1998 年，《克林顿政府对关键基础设施保护的政策》和《新

世纪国家安全战略》两份文件均提出了对国家关键基础设施信息系统进行保护的构想。9·11 事件之后，《信息时代的关键基础设施保护》中宣布成立“总统关键基础设施保护委员会（PCIPB）”，代表政府全面负责国家的网络空间安全工作。

2008 年，《国家网络安全综合倡议》（CNCI）发布。CNCI 计划建立三道防线：第一道防线，减少漏洞和隐患，预防入侵；第二道防线，全面应对各类威胁，增强反应能力，加强供应链安全，抵御各种威胁；第三道防线，强化未来安全环境，增强研究、开发和教育，投资先进技术。同时，CNCI 还明确了 12 项任务，包括可信互联网连接（TIC）、网络入侵检测系统、网络入侵防护系统、科技研发、态势感知、网络反间、增强涉密安全、加强网络教育、“超越未来”技术研发、网络威慑战略、全球供应链风险管理机制和公私协作。

我国信息安全保障工作从 2001 年国家信息化领导小组重组，网络与信息安全协调小组成立开始正式启动。2003 年 7 月，国家信息化领导小组根据国家信息化发展的客观需求和网络与信息安全工作的现实需要，制定出台了《关于加强信息安全保障工作的意见》（中办发第 27 号文件）。文件明确了加强信息安全保障工作的总体要求，提出了加强信息安全保障工作的主要原则。

总体要求：坚持积极防御、综合防范的方针，全面提高信息安全防护能力，重点保障基础信息网和重要信息系统安全，创建安全健康的网络环境，保障和促进信息化的发展，保护公共利益，维护国家安全。提出了加强信息安全保障工作的主要原则：立足国情，以我为主，坚持管理与技术并重；正确处理安全与发展的关系，以安全保发展，在发展中求安全；统筹规划，突出重点，强化基础性工作；明确国家、企业、个人的责任和义务，充分发挥各方面的积极性，共同构筑国家信息安全保障体系。

围绕中办发第 27 号文件，我国信息安全保障工作取得了明显成效，建设了一批信息安全基础设施，加强了互联网信息内容安全管理，为维护国家安全与社会稳定，保障和促进信息化建设健康发展发挥了重要作用。目前，我国的信息安全保障工作正在稳健、扎实地步入高速发展的新阶段。

5．网络空间安全阶段

随着互联网的不断发展，越来越多的设备被接入并融合，技术的融合将传统的虚拟世界与物理世界相互连接，共同构成了一个新的 IT 世界。互联网成为个人生活、组织机构甚至国家运行不可或缺的一部分，网络空间随之诞生，信息化发展进入网络空间阶段。网络空间作为新兴的第五空间，已经成为新的国家竞争领域，威胁来源从个人上升到犯罪组织，甚至上升到国家力量的层面。

“网络空间（Cyberspace）”一词，由加拿大作家威廉·吉布森在其短篇科幻小说《燃烧的铬》中创造出来，原意指由计算机创建的虚拟信息空间，体现了 Cyberspace 不仅是信息的简单聚合体，也包含了信息对人类思想认知的影响。此后，随着信息技术的快速发展和互联网的广泛应用，Cyberspace 的概念不断丰富和演化。

2008 年，美国第 54 号总统令对 Cyberspace 进行了定义：Cyberspace 是信息环境中的一个整体域，它由独立且互相依存的信息基础设施和网络组成，包括互联网、电信网、计算机系统、嵌入式处理器和控制器系统。除了美国之外，还有许多国家对 Cyberspace 进行了定义和解释，但与美国的说法大同小异。

2009 年 5 月 29 日，美国发布《网络空间政策评估：确保信息和通信系统的可靠性和韧性》报告。云计算、虚拟化、物联网、移动互联网、大数据、人工智能等新技术的出现，使得网络空间安全的问题无比复杂。

2010 年 5 月，奥巴马政府提出了其执政之后的首个国家安全战略，即美国《国家安全战略（2010）》，此战略从国家安全的角度对网络空间的战略布局和网络信息安全提出了明确要求。

2011 年，美国先后颁布了《网络空间国际战略》和《网络空间行动战略》，这两份战略从外交和国防两个方面相互呼应。《网络空间国际战略》力图制定网络空间国际行为规范，从“树立自由的基础”“尊重财产”“保护隐私”“防止犯罪”“正当防卫”等方面提倡全世界共同来建设一个“开放、互动、安全、可靠”的未来网络空间。《网络空间行动战略》则将网络空间纳入美军的作战空间，对网络空间作战进行组织、训练和装备。

为实施国家安全战略，加快网络空间安全高层次人才培养，我国在 2015 年经专家论证，国务院学位委员会学科评议组评议，报国务院学位委员会批准，国务院学位委员会、教育部决定在“工学”门类下增设“网络空间安全”一级学科。

2016 年 12 月，我国发布了《国家网络空间安全战略》，明确了网络空间是国家安全的新疆域，已经成为与陆地、海洋、天空、太空同等重要的人类活动新领域，国家主权拓展延伸到网络空间，网络空间主权成为国家主权的重要组成部分。

1.1.5　信息安全保障新领域

1．工业控制系统安全

工业控制系统（Industrial Control System，ICS）是各式各样控制系统类型的总称，由各种自动化控制组件以及对实时数据进行采集、监测的过程控制组件，共同构成的确保工业基础设施自动化运行、过程控制与监控的业务流程管控系统。ICS 被广泛应用于核设施、钢铁、有色、化工、石油石化、电力、天然气、先进制造、水利枢纽、环境保护、铁路、城市轨道交通、民航以及其他与国计民生紧密相关的领域。

（1）工业控制系统的基本结构

工业控制系统涵盖了多种类型的控制系统，其中较常见又容易混淆的控制系统包括数据采集与监控系统（Supervisory Control And Data Acquisition，SCADA）、分布式控制系统（Distributed Control System，DCS）和可编程逻辑控制器（Programmable Logic Controller，PLC）。

①　数据采集与监控系统

SCADA 是一种大规模的分布式系统，用来控制和管理地理位置广域分布的资产，在工

业生产过程中，中央数据采集和集中控制对整个系统运行来说非常重要。SCADA 系统通常应用在类似供水工程、污水处理系统、石油和天然气管网、电力系统和轨道交通系统中。SCADA 控制中心集中监视和控制远距离通信网络中的野外现场节点设备，包括报警信息和过程状态数据等。中央控制中心依靠从远程站点获取的信息，生成自动化的或者过程驱动型的监视指令并发送至远程站点，以此来实现对远程装置的实时控制，这类远程装置就是工业领域的现场设备。现场设备操作类似阀门和断路器的开启/关闭，传感器数据采集和现场环境监视报警等本地作业。

② 分布式控制系统

分布式控制系统又称为集散控制系统，是由过程控制级和过程监控级组成，以通信网络为纽带的多级计算机系统。DCS 综合了计算机、通信、显示和控制等技术，其基本思想是分散控制、集中操作、分级管理、配置灵活以及组态方便。

DCS 系统采用集中监控的方式协调本地控制器以执行整个生产过程。通过模块化生产系统，DCS 减少了单个故障对整个系统的影响。在许多现代化系统中，DCS 系统与企业系统之间设置接口以便能够将生产过程体现在业务整体运作中。DCS 系统常用于炼油、污水处理、发电、化工和制药等工控领域。

③ 可编程逻辑控制器

PLC 是在传统的顺序控制器的基础上引入了微电子技术、计算机技术、自动控制技术和通信技术而形成的一代新型工业控制装置，目的是用来取代继电器、执行逻辑、计时、计数等顺序控制功能，建立柔性的程控系统。国际电工委员会（IEC）颁布了对 PLC 的规定：可编程控制器是一种数字运算操作的电子系统，专为在工业环境下应用而设计。它采用可编程序的存储器，用来在其内部存储执行逻辑运算、顺序控制、定时、计数和算术运算等操作的指令，并通过数字的、模拟的输入和输出，控制各种类型的机械或生产过程。可编程控制器及其有关设备，都应按易于与工业控制系统形成一个整体，易于扩充其功能的原则设计。PLC 广泛应用于几乎所有的工业生产过程，是 SCADA 系统或 DCS 控制系统中的一种关键组件。

（2）工业控制系统的主要安全威胁

随着信息化与工业化深度融合以及物联网的快速发展，ICS 产品越来越多地采用通用协议、硬件和软件，以各种方式与互联网等公共网络连接。这使得 ICS 已经不再是过去那种封闭的领域，因此面临的安全问题也日益突出。目前，我国工业控制系统普遍存在的安全问题主要表现在以下几个方面。

① 缺乏安全防护

工业控制系统作为与传统信息系统完全不同的生产控制系统，其设计、建设、管理和维护人员都是工业控制专业领域的技术人才，缺乏足够的信息安全知识，因此工业控制系统普遍存在对安全性考虑不足的问题。在工业控制系统设计场景与管理控制等多方面，优先确保系统的高可用性和业务连续性，而对于认证、加密、授权等方面缺乏足够措施。由于工业控制系统优先保证高可用性和业务连续性，考虑到软件补丁兼容性风险问题，系统

软件通常难以及时升级，设备使用周期也较长，这使得工业控制系统难以及时处理严重的安全漏洞。

② 系统安全可控性不高

工业控制设备生产厂商目前主要由国外厂商控制，相应的工业控制协议等核心技术都掌握在国外知名工业控制系统生产制造商手中。这些设备都可能存在安全漏洞和后门，极有可能造成非常严重的后果，而这些漏洞的修补都只能依赖于国外相应的生产厂商。

③ 缺乏安全管理标准和技术

工业控制系统由于运行在相对封闭的环境中，并且系统类型繁多，技术差异也较大，使得现有的信息安全产品无法直接应用在系统中，相应的管理体系、管理标准也不适用。而目前我国工业控制系统安全相关技术、标准、管理体系都不成熟，使得安全风险存在于工业控制系统的设计、开发、部署、运维的各个环节。

（3）工业控制系统安全防护

为保护工业控制系统安全性，达到可用性、完整性和保密性等目标，可从管理、操作和技术等 3 方面着手进行控制，设计具体的安全保护和应对措施。

① 管理控制

NIST SP 800-53 在管理控制类下定义了风险评价、规划、系统和服务采购及认证、认可和安全评价 4 个控制族。风险评价是通过判断发生概率、结果影响和减轻这些影响所需增加的安全控制确定操作、资产或人员面临的风险的过程；规划是制订维护计划，通过评价、规定和执行安全控制、划分安全等级和对事件做出响应来确保信息系统安全；系统和服务采购是调拨资源以便在信息系统整个生命周期保持系统安全，根据风险评价结果制定采购策略，其中包括要求、设计准则、测试规程和相关文件等；认证、认可和安全评价是确保规定的控制被正确实施，按意图运行，并产生预期结果。

② 操作控制

NIST SP 800-53 在操作控制类下定义了以下 9 个控制族。

- 人员安全：有关人员职位分类、筛选、调动、处罚和解雇的策略和规程，同时还涉及第三方人员安全。
- 物理和环境保护：有关物理、传输和显示器访问控制以及调节（如温度、湿度等）和应急供应（如关机、电源、照明、防火等）的策略。
- 意外防范计划：涉及保持或恢复业务运行的策略，其中，包括发生紧急情况、系统故障或灾害时计算机在可能的备用场地的运行。
- 配置管理：有关控制硬件、固件、软件和文档被人为改动的策略和规程，以确保信息系统在运行之前、期间和之后受到保护，不被不当改动。
- 维护：管理信息系统的所有方面维护工作的策略和规程。
- 系统和信息完整性：有关通过功能验证、数据完整性检查、入侵检测、恶意代码检测、安全预警和咨询控制来保护信息系统及其数据免受设计缺陷和数据篡改困扰的策略和规程。

- 媒体保护：确保安全处理媒体的策略和规程，控制涉及访问、标签、保存、传送、清洁、处置和销毁等多项内容。
- 事件响应：有关事件响应培训、检验、处理、监测、报告和支持服务的策略和规程。
- 意识和培训：确保所有信息系统用户都受过与其系统使用相关的适当安全培训，以及妥善保存准确培训记录的策略和规程。

③ 技术控制

技术控制主要由系统通过含在系统硬件、软件或固件成分中的机制实施和执行。NIST SP 800-53 在技术控制类内定义了 4 个控制族。

- 识别和认证：验证用户、进程或设备身份的过程，以此作为授予 IT 系统内资源访问权的先决条件。
- 访问控制：包括访问控制和规程、账户管理、访问执行、职责分离、最小特权及会话锁定、会话终止等管理。
- 审计和追责：对记录活动独立审核和检查，以评价系统控制的充分性，确保既定策略和操作规程得到遵守，就必要的控制、策略或规程改动提出建议。
- 系统和通信保护：保护系统和数据传输构件的机制。

2．云计算安全与虚拟化

云计算是一种共享 IT 基础架构的技术，利用云计算，可以将大量分散的 IT 资源连接在一起向用户提供服务。云计算的出现，使得组织机构和个人可以方便地按需访问计算资源（服务器、操作系统、网络、软件和存储设备等），相比传统的 IT 技术，云计算可以灵活、快速地提供服务并最小化管理成本。

（1）云计算所面临的风险

云计算作为一种新兴的计算资源利用方式，虽然为用户提供了新型的计算、网络和存储环境，但传统信息系统中的安全问题绝大部分在云计算环境中仍然存在。与此同时，云计算中的虚拟化、租户等技术特点又催生了新的安全问题和风险。这些安全风险需要云计算供应商和用户予以重视。云计算所面临的安全风险包括以下方面。

① 数据管理和访问失控的风险

云计算的技术特性决定了存储在云计算环境下的数据对用户存在失控的风险。主要原因在于数据的实际存储位置不受用户控制，云计算服务商对数据有更高的权限，而用户不能有效监管云服务商内部人员对数据的非授权访问和使用。

② 数据管理责任的风险

传统模式下“谁主管 谁负责、谁运营 谁负责”的原则使得信息安全责任较清晰，而在云计算环境下，用户对自己数据的访问、利用、管理可能还需要得到云服务商的授权，这使得数据的管理和运营主体与数据的安全责任主体不同，相互之间的责任难以界定。

③ 数据保护的风险

由于目前云计算缺乏统一的标准，不同云计算平台的数据存储格式不同，并且存储介

质由云服务提供商控制，用户对数据的操作都需要通过云服务商来进行，这使得用户无法真正有效掌控自己的数据。例如用户在退出云计算服务时，无法对云服务商是否真正实施了完全删除操作进行验证，由此可能造成数据残留风险。

（2）云计算安全框架

云计算安全是一个交叉领域，涵盖物理安全到应用安全。在云计算架构中安全不仅属于云提供者的范围，还关系到云用户和其他相关角色。除安全性外，云提供者还需保护云中的私人信息和个人身份信息的处理、使用、通信和合理的收集。根据 NIST 定义的云计算安全架构，按角色分为云用户、云提供者、云承载者、云审计者和云经纪人。

云计算安全服务体系是实现云用户安全目标的重要技术手段，根据其所属的层次不同，云安全服务可以分为安全云基础设施服务、云安全基础服务及云安全应用服务。

安全云基础设施服务是整个云计算体系安全的基石，为上层云应用提供安全的数据存在、计算等资源服务。安全云基础设施服务首先需要应对传统计算机系统面临的各种安全问题，同时也要向用户证明自己具备数据隐私保护能力。

云安全基础服务为各类云应用提供共性信息安全服务，是支撑云应用满足用户安全目标的重要手段。例如云用户的身份验证、云访问控制、云审计等。

云安全应用服务与用户的需求紧密结合，种类繁多。例如云网页过滤与杀毒应用、内容安全云服务、安全事件监控与预警云服务、云垃圾邮件过滤及防治等。

（3）虚拟化安全

虚拟化是云计算的支撑技术，通过把硬件资源虚拟化，构成一个资源池，实现隔离性、可扩展性、安全性、资源可充分利用等特点。通过虚拟化技术，云计算环境下每个应用部署和物理平台无关，通过虚拟平台进行管理、扩展、迁移、备份。在云计算中，资源以虚拟、租用的模式提供给用户，这些虚拟资源根据实际运行所需与物理资源绑定。由于在云计算中是多租户共享资源，多个虚拟资源很可能会被绑定到相同的物理资源上。如果云平台的虚拟化软件中存在安全漏洞，那么用户的数据就可能被其他用户访问。因此，如果云计算平台无法实现用户数据与其他企业用户数据的有效隔离，那么就无法保障用户的数据安全。

虚拟化安全是云计算中核心的安全问题，这方面研究包括对共享信息流的控制、对内存空间和内核的保护、对虚拟机行为的监控等，很多研究借助于硬件特性，包括传统的页保护机制和硬件虚拟化技术。使用虚拟化技术的云计算平台上的云架构提供者必须向其客户提供安全性和隔离保证。

3．物联网安全

物联网（Internet of things，IoT）是物物相连的互联网，核心和基础仍然是互联网，是将互联网延伸和扩展到任意的物品之间。物联网通过智能感知、识别技术与普适计算等通信感知技术，广泛应用于网络的融合中，也因此被称为继计算机、互联网之后世界信息产业发展的第三次浪潮。

2013 年，《物联网全球标准协议》（IoT-GSI）将物联网定义为“信息社会的基础设施”。物联网允许在现有网络基础设施上远程检测或控制对象，将物理世界更直接地整合到基于

计算机的系统中，并提高了效率、准确性和经济效益。

物联网的快速发展掀起了人类生活方式的新的改变，随着越来越多的智能设备应用在生产和生活领域，物联网所面临的安全威胁也日益增长。物联网涉及感知、控制、网络通信、微电子、计算机、软件、嵌入式系统、微机电等技术领域，因此物联网涵盖的关键技术非常多，其主要技术架构可分为感知层、传输层、支撑层和应用层 4 个层次，如图 1-2 所示。

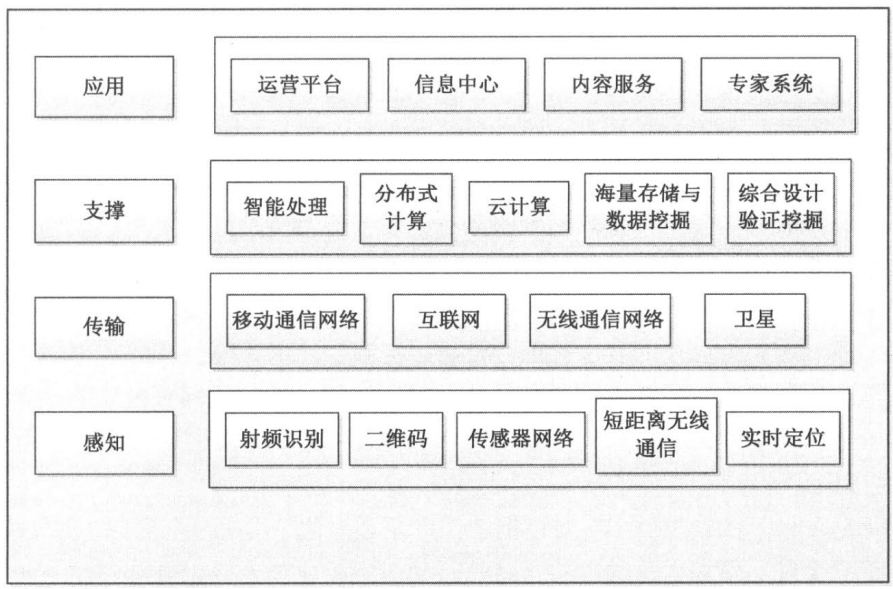

图 1-2　物联网技术体系模型

感知层的任务是全面感知外界信息，这一层的主要设备是各种信息收集器。感知信息要通过一个或多个与外界网络连接的传感节点，称为网关节点，所有与传感器内部节点的通信都要经过网关节点与外界联系。感知层的安全问题包括网关节点被控制、拒绝服务及接入的节点的标识、识别、认证和控制问题。

物联网的传输层主要用于把感知层收集到的信息安全可靠地传输到信息支撑层，然后根据不同的应用需求进行信息处理，即传输层主要是网络基础设施。物联网是依托互联网构建的应用，拒绝服务攻击、欺骗等安全问题都会直接影响物联网的传输安全。

支撑层的主要工作是对节点采集的信息的处理，对信息进行分析和过滤，需要判断接收到的信息是否真正有用，过滤掉垃圾甚至恶意信息。支撑层的安全问题包括来自终端的虚假数据识别和处理、可用性保护、人为干预等。

应用层是具体的应用业务，所涉及的安全问题与业务特性相关，例如隐私保护、知识产权保护、取证、数据销毁等方面。

4．大数据安全

大数据是指大小超出常规数据库软件工具收集、存储、管理和分析能力的数据集。美

国国家标准技术研究所的大数据工作组在《大数据：定义和分类》中指出：“大数据是指传统数据架构无法有效处理的新数据集。”

信息化的发展使得大量的数据产生，对这些数据的分析，在任何领域都能带来不可估量的价值。依托数据分析，能提供业务发展趋势，预测天气、预防疾病和打击犯罪等。大数据在为人们生活带来便利，为技术带来进步的同时，也带来了诸多的安全问题，因此数据安全保障成为大数据应用和发展中必须面临的重大挑战。大数据的安全保障应从数据应用安全及技术平台安全两个方面进行。

（1）数据应用安全

数据是有生命周期的，数据应用安全应从数据收集、数据存储、数据使用、数据分发、数据删除等生命周期阶段考虑其安全问题。

① 数据收集阶段：数据源鉴别及记录、数据合法收集、数据标准化管理、数据管理职责定义、数据分类分级以及数据留存合规识别等问题。

② 数据存储阶段：存储架构安全、逻辑存储安全、存储访问安全、数据副本安全、数据归档安全等。

③ 数据使用阶段：数据分布式处理安全、数据分析安全、数据加密处理、数据脱敏处理以及数据溯源等。

④ 数据分发阶段：数据传输安全、数据访问控制、数据脱敏处理等。

⑤ 数据删除阶段：删除元数据、原始数据及副本，断开与外部的实时数据流链接等。

（2）技术平台安全

伴随着大数据的不断发展，各种大数据技术层出不穷，新的技术架构、支撑平台和大数据软件不断涌现，使得大数据在技术平台层面面临着很多安全挑战，例如传统安全措施适配、平台安全机制、应用访问控制等问题。

① 由于大数据的多源、海量、异构、动态等特征导致其与传统的数据应用安全环境有很大区别，传统基于边界的安全保护措施不再有效。

② 大数据平台自身也会存在漏洞及恶意后门。

③ 由于大数据应用广泛，并且应用场景中存在大量未知的用户和数据，这使得传统的访问控制措施难以实施。

5．移动互联网安全

随着智能终端的普及及 4G 网络的全面铺开，移动互联网已经逐步渗透人们的生活，根据工信部发布的 2018 年 11 月通信业主要指标完成情况，国内移动互联网活跃用户数已经达到 13.86 亿。移动互联网自身脆弱的安全系统，使得越来越多的用户受到了伤害。移动互联网作为一个较新的领域，在管理层面上，相关法律法规不足，行业对安全风险的认识也存在一定的不足。移动互联网的迅猛发展使得厂商更多地关注应用，大量的移动互联网应用开发没有将安全列入软件生命周期中，对业务流程缺乏安全风险分析等，为移动互联网的发展留下了大量的隐患。

（1）移动互联网安全问题

智能手机是目前移动互联网主要的载体及媒介，而智能手机目前面临的安全问题包括以下方面。

① 系统安全问题

目前，智能手机的系统主要是苹果的 iOS 和安卓（Android），二者占据了智能手机操作系统绝大部分的份额，智能手机操作系统的安全性直接关系着移动互联网的安全问题。特别是开放的安卓系统，不同的开发商对系统的再开发产生了大量的衍生发行版，导致无法及时得到更新甚至没法更新，而有些系统虽然有更新，但更新质量也在一定程度上影响了手机系统自身的安全。这种操作系统碎片化问题是目前困扰安全的一个问题。

② 移动应用安全问题

伴随移动互联网的发展，各种移动应用也快速地发展起来。移动应用开发还是一个较新的领域，在管理层面上，移动智能相关法律法规滞后，行业对移动智能安全相关的风险认识不足，过分重视超前概念和业务而忽视基础安全设施；在技术层面，移动应用开发组织没有将信息安全列入软件全生命周期，复杂业务逻辑处理不当，对集成功能模块把关不严格，甚至个别开发者为某些商业利益故意收集信息等。这些应用本身的缺陷会给用户带来极大的安全风险，特别是移动支付等领域，由于使用广泛，使得安全问题成为移动互联网安全关注的重点。移动应用的安全问题主要包括移动应用本地数据存储和处理安全风险、移动应用数据传输安全风险、移动应用分发风险（重打包、山寨等）等。

③ 个人隐私泄漏问题

智能手机作为移动互联网接入终端设备，承载的职能越来越多，与最初的仅仅提供通信这一基本功能的手机相比，智能手机已经集上网终端、照相机、游戏机、音乐、视频娱乐终端为一体。这使得智能手机不可避免地产生大量的用户数据，从而成为隐私泄漏的主要途径之一。而手机号码作为身份验证的一种方式也被广泛采用。垃圾信息、诈骗信息等建立在隐私泄漏基础上的安全问题已经成为影响移动互联网应用的主要问题。

（2）移动互联网安全策略

移动互联网的蓬勃发展是一个不可避免的趋势，虽然网络安全问题仍然有很多，但通过不断改进和提高，移动互联网可以具备应对多样化的网络安全威胁的能力。移动互联网安全防护可从以下几个方面进行考虑。

① 政策规范和引导

由于智能手机操作系统、主要硬件等组件主要都由国外厂商生产，为了确保安全，应建立移动互联网行业安全引导相关政策，鼓励更多的厂商加大在移动互联网安全体系中的投入，对智能手机操作系统和应用安全进行深入研究，为构建安全的移动互联网体系打下坚实基础。

② APP 分发管控

由于安卓系统的开放性，使得目前国内存在大量的应用分发渠道，这些应用分发渠道

良莠不齐，为恶意应用和山寨应用提供了良好的生存空间。而对于应用的安全性审核，目前也缺乏权威的检测机构，通常都是由各应用分发渠道自行审查，这给应用发行方、用户带来了极大的不便。因此，对于 APP 应用的管控应采取有效措施，实现对 APP 供应链进行安全审查，建立 APP 审查机制，对可靠的应用（来源安全可信）进行数字签名并给予可靠标识，然后由各大应用分发市场统一分发。

③ 加强隐私保护要求

由于智能手机的特殊性，大量的用户信息都存储在智能手机中，而智能手机又更容易物理丢失，这对用户隐私及移动应用安全提出了更高的要求。虽然《网络安全法》将隐私数据保护纳入了法律的范畴，但侧重点还在对大数据量的用户信息保护，而对于智能终端的个人隐私数据保护，目前还缺乏相应的要求。

6．智慧的世界

智慧地球也称为智能地球，就是把感应器嵌入和装备到电网、铁路、桥梁、隧道、公路、建筑、供水系统、大坝、油气管道等各种物体中，并且被普遍连接，形成所谓“物联网”，然后将“物联网”与现有的互联网整合起来，实现人类社会与物理系统的整合。

智慧的世界在目前广泛被接受的概念是智慧城市，而构成“智慧”中所形成的综合技术问题（大数据、工业控制系统、云计算、移动互联网、基础 IT 设施问题）和管理问题（工程管理、人员管理、操作管理等）成为一个泛在的安全风险。

1.2　知识子域：信息安全保障框架

1.2.1　基于时间的安全模型

1．PDR 模型

保护-检测-响应（Protection-Detection-Response，PDR）模型是信息安全保障工作中常用的模型，其思想是承认信息系统中漏洞的存在，正视信息系统面临的威胁，通过采取适度防护、加强检测工作、落实对安全事件的响应、建立对威胁的防护来保障系统的安全，如图 1-3 所示。

图 1-3　PDR 模型图

该模型的出发点是基于这样的前提：任何安全防护措施都是基于时间的，超过该时间段，这种防护措施是可能被攻破的。该模型主要给出了信息系统的攻防时间表。攻击时间指的是在系统采取某种防守措施，通过不同的攻击手段来计算攻破该防守措施所需要的时间。防守时间指的是，对于某种固定攻击手法，通过采取不同的安全防护措施，来计算该防护措施所能坚守的时间。

PDR 模型直观、实用，建立了一个所谓的基于时间的可证明的安全模型，定义了防护时间 Pt（攻击者发起攻击时，保护系统不被攻破的时间）、检测时间 Dt（从发起攻击到检测到攻击的时间）和响应时间 Rt（从发现攻击到做出有效响应的时间）3 个概念，并给出了评定系统安全的计算方式，当 Pt>Dt+Rt 时，即认为系统是安全的，也就是说，如果在攻击者攻破系统之前发现并阻止了攻击的行为，那么系统就是安全的。

这个模型是一个理想模型，因为系统的 Pt、Dt、Rt 很难准确定义，面对不同攻击者和不同种类的攻击，这些时间都是变化的，其实还是不能有效证明一个系统是否安全。并且该模型对系统的安全隐患和安全措施采取相对固定的前提假设，难于适应网络安全环境的快速变化。

2．PPDR 模型

策略-保护-检测-响应模型（Policy-Protection-Detection-Response，PPDR）是在 PDR 模型的基础上发展出来的模型，也称为 P2DR 模型。模型的核心思想是所有的防护、检测、响应都是依据安全策略实施的，模型包括 4 个主要部分：Policy（策略）、Protection（保护）、Detection（检测）和 Response（响应），如图 1-4 所示。

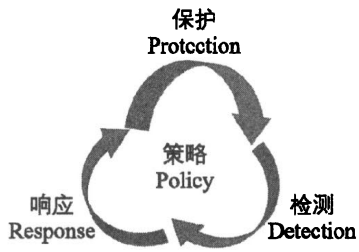

图 1-4　PPDR 模型图

- 策略：模型的核心，所有的防护、检测和响应都是依据安全策略实施的。安全策略一般由总体安全策略和具体安全策略两部分组成。
- 保护：保护是根据系统可能出现的安全问题而采取的预防措施，这些措施通过传统的静态安全技术实现。采用的防护技术通常包括数据加密、身份认证、访问控制、授权和虚拟专用网（VPN）技术、防火墙、安全扫描和数据备份等。
- 检测：当攻击者穿透防护系统时，检测功能就发挥作用，与防护系统形成互补。检测是动态响应的依据。
- 响应：系统一旦检测到入侵，响应系统就开始工作，进行事件处理。响应包括应

急响应和恢复处理，恢复处理又包括系统恢复和信息恢复。

PPDR 模型是在整体的安全策略的控制和指导下，在综合运用防护工具（如防火墙、操作系统身份认证、加密等）的同时，利用检测工具（如漏洞评估、入侵检测等）了解和评估系统的安全状态，通过适当的反应将系统调整到“最安全”和“风险最低”的状态。保护、检测和响应组成了一个完整的、动态的安全循环，在安全策略的指导下保证信息系统的安全。

该理论的最基本原理就是信息安全相关的所有活动，不管是攻击行为、防护行为、检测行为和响应行为等都要消耗时间，因此可以用时间来衡量一个体系的安全性和安全能力。

假设系统的防护、检测和反应时间分别是 Pt、Dt 和 Rt。系统被对手成功攻击后的时间为暴露时间（Et），那么 PPDR 模型就可以用典型的数学公式来表达安全的要求：如果 Pt>Dt+Rt，那么系统是安全的。

Pt 代表系统为了保护安全目标设置各种保护后的防护时间；或者理解为在这样的保护方式下，攻击者攻击安全目标所花费的时间。Dt 代表从入侵者发动攻击开始，系统能够检测到攻击行为所花费的时间。Rt 代表从发现攻击行为开始，系统能够做出足够的响应，将系统调整到正常状态的时间。那么，针对于需要保护的安全目标，如果上述数学公式满足防护时间大于检测时间加上响应时间，也就是在攻击者危害安全目标之前就能被检测到并及时处理。

如果 Pt<Dt+Rt，那么 Et=(Dt+Rt)-Pt，针对于需要保护的安全目标，Et 越小系统就越安全。

PPDR 给出了安全的全新定义：“及时的检测和响应就是安全”“及时的检测和恢复就是安全”。这样的定义给出了解决安全问题的明确方向：提高系统的防护时间 Pt，降低检测时间 Dt 和响应时间 Rt。

与 PDR 模型相比，PPDR 模型更强调控制和对抗，即强调系统安全的动态性，并且以安全检测、漏洞监测和自适应填充“安全间隙”为循环来提高网络安全。值得指出的是，在 PPDR 模型中，考虑了管理因素，它强调安全管理的持续性、安全策略的动态性，以实时监视网络活动、发现威胁和弱点来调整和填补网络漏洞。另外，该模型强调检测的重要性，通过经常对信息系统的评估把握系统风险点，及时弱化甚至消除系统的安全漏洞。但该模型忽略了内在的变化因素，如人员的流动、人员的素质和策略贯彻的不稳定性。系统本身安全能力的增强、系统和整个网络的优化，以及人员在系统中最重要角色的素质提升，都是该安全系统没有考虑到的问题。

不管是 PDR 还是 PPDR，总体来说还是局限于从技术上考虑信息安全问题。随着信息化的发展，人们越来越意识到信息安全涉及面非常广，除了技术，管理、制度、人员和法律等方面也是信息安全必须考虑的因素，就像一个由多块木块构成的“木桶”，木桶的容量由最短的那块板决定。在处理信息安全问题时，必须全面考虑各方面的因素，任何一个方面的遗漏都有可能形成“短板”。

1.2.2 信息安全保障技术框架

信息安全保障技术框架（Information Assurance Technical Framework，IATF）由美国国家安全局发布，为保障美国政府和工业的信息基础设施提供技术指南。

IATF 编制的目的是帮助定义和理解其技术需求并选择满足其需求的方案，其目标读者包括系统安全工程师、用户、科学家、研究者、产品和服务厂商、标准组织及相关联盟。

1. 核心思想

IATF 提出信息安全保障的核心思想是“纵深防御”，采用一个多层次的、纵深的安全措施来保障信息系统的安全。因为信息系统的安全不是仅仅依靠一两种技术或者简单的安全防御设施就能实现，必须在各个层次、不同技术框架区域中实施保障机制，才能最大程度地降低风险，应对攻击并保护信息系统的安全。如图 1-5 所示是 IATF 纵深防御的战略体系。

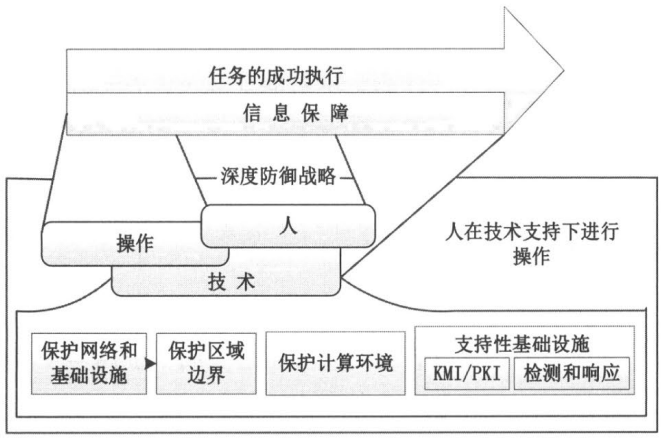

图 1-5 深度防御战略层面

2. 核心三要素

IATF 提出的深度防御战略 3 个核心要素为人、技术和操作。信息系统安全保障依赖于人、技术和操作来共同实现组织机构的职能，如表 1-1 所示。

表 1-1 深度防御—人、技术、操作

人	技 术	操 作
策略和流程 培训和意识 物理安全 人员安全 系统安全管理 设施措施	IA 体系框架区域 IA 准则（安全、互操作性和 PKI） 已评估产品的采购综合 系统风险评估	安全策略 认证和认可 准备性评估 安全管理 密钥管理 攻击传感和告警响应 恢复和重构

人（People）是信息系统中的主体，也是信息系统的拥有者、管理者和使用者，是信息安全保障的核心，也是信息安全保障的第一要素。

技术（Technology）是实现信息安全保障的重要手段，信息安全保障体系所需要的各项安全服务就是通过技术机制来实现的。

操作（Operation）也被称为运行，是信息系统安全保障的主动防御体系，与技术手段的被动防御不同，操作就是将各方面技术紧密结合在一起的主动的过程，包括风险评估、安全监控、安全审计、跟踪告警、入侵检测、响应恢复等内容。

3．4 个焦点领域

IATF 提供了一个通用的框架对信息系统进行解构和描述。从技术层面上，IATF 关注网络和基础设施、区域边界、计算环境、支撑性基础设施 4 个焦点领域。基于这 4 个焦点领域，结合 IATF 纵深防御的思想进行信息安全防御从而形成保障框架。

（1）保护网络和基础设施

网络和其他基础设施是信息系统及业务的支撑，是整个信息系统安全的基础。应采取措施确保网络和基础设施能稳定可靠运行，不会因故障和外界影响导致服务的中断或数据延迟，确保在网络中进行传输的公共的、私人的信息能正确地被接收者获取，不会导致未授权的访问、更改等。保护网络和基础设施防护措施包括但并不限于以下方式。

- 合理规划以确保骨干网可用性。
- 使用安全的技术架构，例如在使用无线网络时考虑安全的技术架构。
- 使用冗余设备提高可用性。
- 使用虚拟专网（VPN）保护通信。

（2）保护区域边界

信息系统根据业务、管理方式和安全等级的不同，通常可以划分为多个区域，这些区域或多或少都有与其他区域相连接的边界。保护区域边界关注的是如何对进出这些区域边界的数据流进行有效的控制与监视。要合理地将信息系统根据业务、管理方式和安全等级划分不同的安全区域，并明确定义不同网络区域间需要哪些数据传递。在此基础上采取措施对数据进行控制与监视。通常采取的措施包括但并不限于以下方式。

- 在区域边界设置身份认证和访问控制措施，例如部署防火墙对来访者进行身份认证。
- 在区域边界部署入侵检测系统以发现针对安全区域内的攻击行为。
- 在区域边界部署防病毒网关以发现并过滤数据中的恶意代码。
- 使用 VPN 设备以确保安全的接入。
- 部署抗拒绝服务攻击设备以应对拒绝服务攻击。
- 流量管理、行为管理等其他措施。

（3）保护计算环境

计算环境指信息系统中的服务器、客户机及其中安装的操作系统、应用软件等。保护计算环境通常采用身份鉴别、访问控制、加密等一系列技术以确保计算环境内的数据保密性、完整性、可用性、不可否认性等。保护计算环境的措施包括但并不限于以下方式。

- 安装并使用安全的操作系统和应用软件。
- 在服务器上部署主机入侵检测系统、防病毒软件及其他安全防护软件。
- 定期对系统进行漏洞扫描或者补丁加固，以避免系统脆弱性。
- 定期对系统进行安全配置检查，确保最优配置。
- 部署或配置对文件的完整性保护。
- 定期对系统和数据进行备份等。

（4）支撑性基础设施

支撑性基础设施是提供安全服务的基础设施及与之相关的一系列活动的综合体。IATF定义了两种类型的支撑性基础设施：密钥管理基础设施（KMI）/公钥基础设施（PKI）和检测与响应。

- KMI/PKI：提供支持密钥、授权和证书管理的密码基础设施并能实现使用网络服务人员确实的身份识别。
- 检测与响应：提供入侵检测、报告、分析、评估和响应基础设施，它能迅速检测和响应入侵、异常事件并提供运行状态的情况。

4．其他安全原则

除了纵深防御这个核心思想之外，IATF还提出了其他一些信息安全原则，这些原则对指导我们建立信息安全保障体系具有非常重大的意义。

（1）保护多个位置

保护多个位置包括保护网络和基础设施、区域边界、计算环境等，这一原则提醒我们，仅仅在信息系统的重要敏感区域设置一些保护装置是不够的，任意一个系统漏洞都有可能导致严重的攻击和破坏后果，所以在信息系统的各个方位布置全面的防御机制，才能将风险降至最低。

（2）分层防御

如果说保护多个位置原则是横向防御，那么这一原则就是纵向防御，这也是纵深防御思想的一个具体体现。分层防御即在攻击者和目标之间部署多层防御机制，每一个这样的机制必须对攻击者形成一道屏障。而且每一个这样的机制还应包括保护和检测措施，以使攻击者不得不面对被检测到的风险，迫使攻击者由于高昂的攻击代价而放弃攻击行为，如表1-2所示。

表1-2　分层防御示例

攻 击 类 型	第一层防线	第二层防线
被动攻击	链路与网络层加密和流量安全	安全的应用
主动攻击	保卫区域边界	保卫计算环境
内部	物理和人员安全	认证的访问控制、审计
接近攻击	物理和人员安全	技术监督措施
分发攻击	可信软件开发和分发	运行时完整性控制

（3）安全强健性

不同的信息对于组织有不同的价值，该信息丢失或破坏所产生的后果对组织也有不同的影响。所以对信息系统内每一个信息安全组件设置的安全强健性（即强度和保障），取决于被保护信息的价值以及所遭受的威胁程度。在设计信息安全保障体系时，必须要考虑到信息价值和安全管理成本的平衡。

5．特点

IATF 的 4 个技术焦点区域是一个逐层递进的关系，从而形成一种纵深防御系统。因此，以上 4 个方面的应用充分贯彻了纵深防御的思想，对整个信息系统的各个区域、各个层次，甚至在每一个层次内部都部署了信息安全设备和安全机制，保证访问者对每一个系统组件进行访问时都受到保障机制的监视和检测，以实现系统全方位的充分防御，将系统遭受攻击的风险降至最低，确保数据的安全和可靠。IATF 认为，信息安全并不是纯粹的技术问题，而是一项复杂的系统工程，表现为具体实施的一系列过程，这就是信息系统安全工程（ISSE）。通过完整实施的 ISSE 过程，组织应该能够建立起有效的信息安全体系。IATF 提出了 3 个主要核心要素：人、技术和操作。尽管 IATF 重点是讨论技术因素，但是它也提出了“人”这一要素的重要性，人即管理，管理在信息安全保障体系建设中同样起到了十分关键的作用，可以说技术是安全的基础，管理是安全的灵魂，所以在重视安全技术应用的同时，必须加强安全管理。

IATF 最大的缺陷在于缺乏流程化的管理要求和对业务相关性在信息安全管理体系中的体现。在体系中更注重技术消减策略。将管理局限于人的因素，难以有效体现业务与安全的平衡概念。

1.2.3　信息系统安全保障评估框架

1．相关概念和关系

信息系统是用于采集、处理、存储、传输、分发和部署信息的整个基础设施、组织结构、人员和组件的总和。随着当前社会信息化程度的不断提高，各类信息系统越来越成为其所从属的组织机构生存和发展的关键因素，信息系统的安全风险也成为组织风险的一部分。同时，信息系统受来自于组织内部与外部环境的约束，信息系统的安全保障除了要充分分析信息系统本身的技术、业务、管理等特性，还要考虑这些约束条件所产生的要求。为了保障组织机构完成使命，系统安全管理人员必须针对信息系统面临的各种各样的风险制定相应的策略。

信息系统安全风险是具体的风险，产生风险的因素主要有信息系统自身存在的漏洞和来自系统外部的威胁。信息系统运行环境存在特定威胁动机的威胁源，使用各种攻击方法，利用信息系统运行环境中的各种漏洞，对信息系统造成相应的风险，由此才会产生信息安

全事件和问题。

信息系统安全保障是在信息系统的整个生命周期中，通过对信息系统的风险分析，制定并执行相应的安全保障策略，从技术、管理、工程和人员等方面提出信息安全保障要求，确保信息系统的保密性、完整性和可用性，把安全风险降到可接受的程度，从而保障系统能够顺利实现组织机构的使命。

信息系统安全保障工作就是针对信息系统在运行环境中所面临的各种风险，制定信息安全保障策略体系，在策略指导下，设计并实现信息安全保障架构或模型，采取技术、管理等安全保障措施，将风险降至预定可接受的程度，从而保障其使命要求。策略体系是组织机构在对风险、资产和使命综合理解的基础上所做出的指导文件。策略体系的制定，反映了组织机构对信息系统安全保障及其目标的理解，它的制定和贯彻执行对组织机构信息系统安全保障起着纲领性的指导作用。

图 1-6 说明了信息系统安全保障中的这些高层概念的关系。

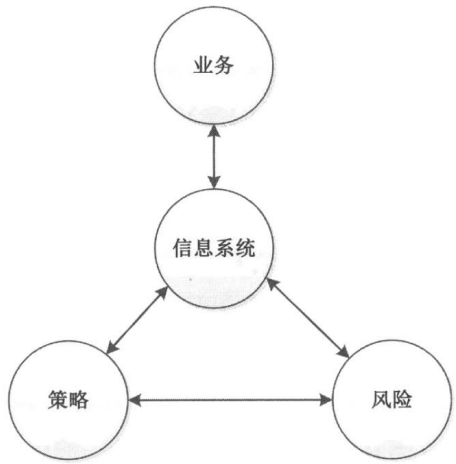

图 1-6　信息系统安全概念和关系

信息系统安全保障工作的基础和前提是风险管理。信息安全策略必须以风险管理为基础，针对可能存在的各种威胁和自身存在的弱点，采取有针对性的防范措施。信息安全不是追求绝对的安全，不强调面面俱到，但风险必须是能够管理的。

最适宜的信息安全策略就是最优的风险管理对策，这是一个在有限资源前提下的最优选择问题。防范不足会造成直接的损失；防范过多又会造成间接的损失。也就是说，信息安全保障的问题就是安全的效用问题，在解决或预防信息安全问题时，要从经济、技术、管理的可行性和有效性上做出权衡和取舍。

2．信息系统安全保障评估描述

信息系统安全保障评估，就是在信息系统所处的运行环境中对信息系统安全保障的具体工作和活动进行客观的评估。通过信息系统安全保障评估所搜集的客观证据，向信息系

统的所有相关方提供信息系统的安全保障工作能够实现其安全保障策略，能够将其所面临的风险降到其可接受程度的主观信心。信息系统安全保障评估的对象是信息系统，信息系统不仅包含信息技术系统，还包括与信息系统所处的运行环境相关的人和管理等领域。信息系统安全保障是一个动态持续的过程，涉及信息系统整个生命周期，因此信息系统安全保障的评估也应该提供一种动态持续的信心。

评估是信息系统安全保障的一个重要概念，系统所有者可以根据评估所得到的客观结果建立其主观的信心。图 1-7 描述了信息系统安全保障评估的概念和关系。

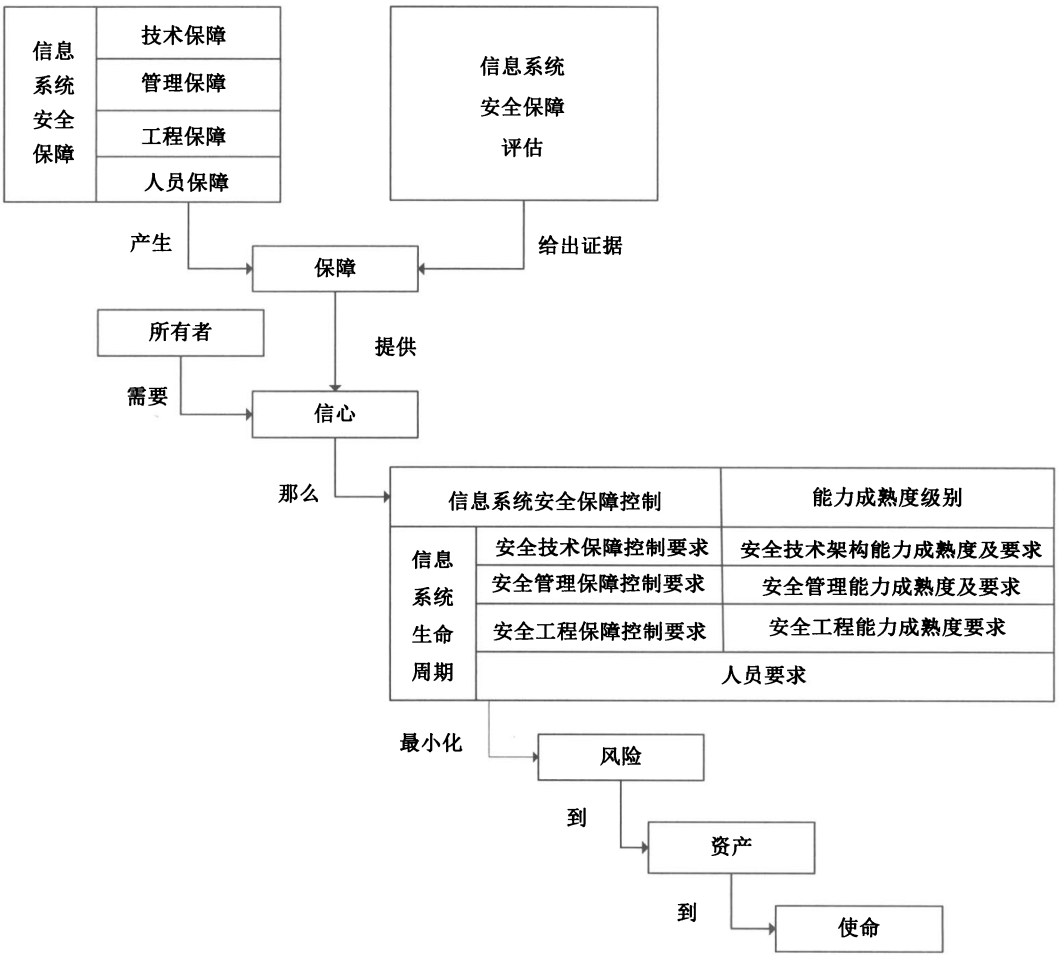

图 1-7　信息系统安全保障评估概念和关系

信息系统安全保障的评估，是从信息系统安全保障的概念出发，在信息系统的生命周期内，根据组织机构的要求，在信息系统的安全技术、安全管理和安全工程领域内对信息系统的安全技术控制措施和技术架构能力、安全管理控制和管理能力以及安全工程实施控制措施和工程实施能力进行评估综合，从而最终得出信息系统安全保障措施在其运行环境中满足其安全保障要求的符合性以及信息系统安全保障能力的评估。

图 1-8 给出了信息系统安全保障评估的描述。

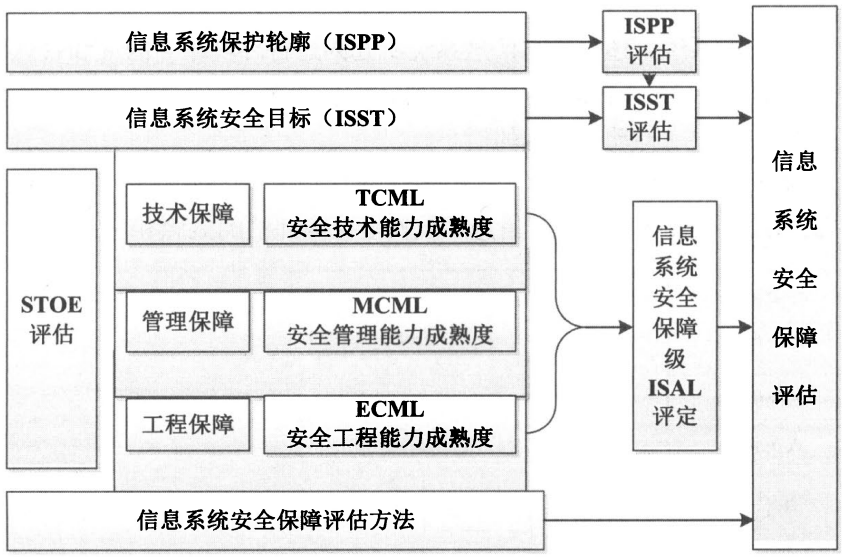

图 1-8　信息系统安全保障评估描述

信息系统安全保障评估主要包括以下两方面的评估。

（1）在信息系统运行环境中，其具体的安全保障控制相对于安全保障要求（目标）的符合性的评估

信息系统在其运行环境中的安全保障控制对安全保障要求的符合性（即信息系统的技术体系、管理控制和工程实施相对于信息系统在其运行环境下的符合性），是与信息系统保护轮廓（Information System Protect Profile，ISPP）和信息系统安全目标（Information System Security Target，ISST）相关的内容。信息系统保护轮廓是从信息系统的所有者角度来描述的信息系统安全保障的规范化需求描述。对信息系统保护轮廓的评估就是评估所编制的信息系统保护轮廓是否符合 ISPP 规范化描述的要求，以及评估它是否真正反映了信息系统所有者的真实的安全保障要求。信息系统安全目标是从信息系统安全保障的建设方角度来描述的信息系统安全保障方案。信息系统安全目标的评估就是评估所编制的信息系统安全目标是否符合 ISST 规范化描述的要求以及它是否能够真正解决和满足信息系统保护轮廓的信息系统安全保障要求。

（2）信息系统安全保障级的评估

信息系统安全保障级（Information Systems Assurance Level，ISAL）是信息系统所提供的各项安全技术保障、安全管理保障、安全工程保障的实施、正确性、质量和能力进行保障（或信心）的强度和程度的特征，是对信息系统安全保障持续改进的能力特征的描述。信息系统安全保障级（ISAL）是信息系统在其运行环境中，实施信息系统安全保障方案（即实施信息系统安全目标）的具体实施情况和实施能力的反应。

3．信息系统安全保障评估模型

在国家标准 GB/T 20274.1—2006《信息安全技术 信息系统安全保障评估框架第一部分：简介和一般模型》中，信息系统安全保障模型包含保障要素、生命周期和安全特征 3 方面，如图 1-9 所示。

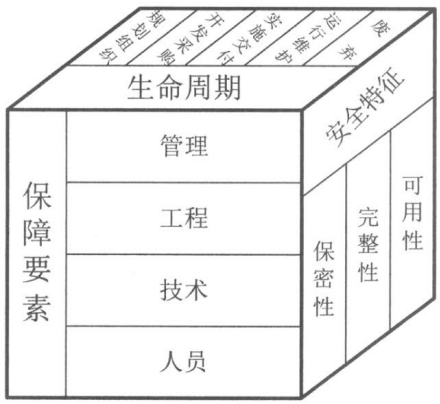

图 1-9　信息系统安全保障模型

信息安全保障模型的主要特点如下。

- 将风险和策略作为信息系统安全保障的基础和核心。
- 强调信息系统安全保障持续发展的动态安全模型，即强调信息系统安全保障应贯穿于整个信息系统生命周期的全过程。
- 强调综合保障的观念。信息系统的安全保障是通过综合技术、管理、工程和人员的安全保障要求来实施和实现信息系统的安全保障目标，通过对信息系统的技术、管理、工程和人员要求的评估，提供了对信息系统安全保障的信心。
- 通过以风险和策略为基础，在整个信息系统的生命周期中实施技术、管理、工程和人员保障要素。通过信息系统安全保障实现信息安全的安全特征：信息的保密性、完整性和可用性特征，从而达到保障组织机构执行其使命的根本目的。

在这个模型中，更强调信息系统所处的运行环境、信息系统的生命周期和信息系统安全保障的概念。信息系统生命周期有各种各样的模型，本书中的信息系统生命周期模型是基于这些模型的一个简单、抽象的概念性说明模型。它的主要用途在于对信息系统生命周期模型进行示例说明。在进行信息系统安全保障具体操作时可根据实际环境和要求，对信息系统生命周期进行改动和细化。信息系统生命周期的概念是如何在信息系统整个生命周期中通过对技术、管理、工程和人员建立的信息系统安全保障保证下的覆盖整个生命周期的动态持续性的长效安全。

（1）基于信息系统生命周期的信息安全保障

在信息系统安全保障模型中，信息系统的生命周期层面和保障要素层面不是相互孤立的，而是相互关联、密不可分的。图 1-10 描述了它们之间的关系。

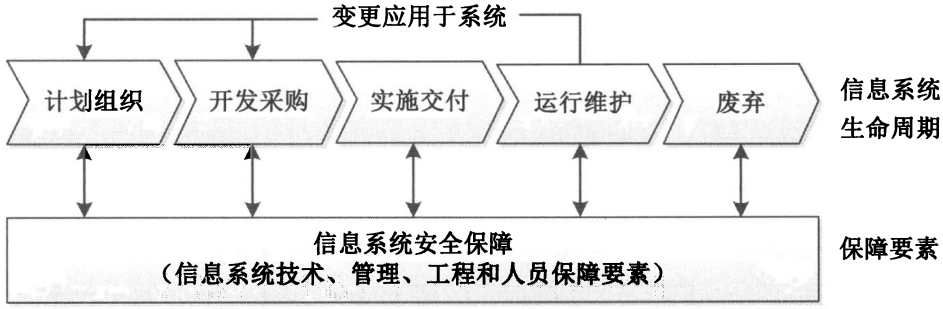

图 1-10　信息系统安全保障生命周期的安全保障要素

在信息系统生命周期模型中，将信息系统的整个生命周期抽象成计划组织、开发采购、实施交付、运行维护和废弃 5 个阶段，加上在运行维护阶段的变更产生的反馈，形成信息系统生命周期完整的闭环结构。在信息系统生命周期中的任何时间点上，都需要综合信息系统安全保障的技术、管理、工程和人员保障要素。

- 计划组织阶段：根据组织机构的业务要求、法律法规的要求、系统所存在的风险等因素，产生了信息系统安全保障需求。在此阶段，信息安全策略应加入信息系统建设和使用的决策中。从信息系统建设开始，就应该综合考虑系统的安全保障要求，确保信息系统建设和信息系统安全保障建设同步规划、同步实施。
- 开发采购阶段：此阶段是计划组织阶段的细化和具体体现。在此阶段中，进行系统安全需求分析、系统安全体系设计以及相关预算申请和项目准备等活动。在此阶段，应克服传统拘泥于具体技术的片面性，要综合考虑系统的风险和安全策略，将信息系统安全保障作为一个整体，进行系统地设计，建立信息系统安全保障整体规划和全局视野。组织机构可根据具体要求，对系统整体的技术、管理安全保障规划或设计进行评估，以保证对信息系统的整体规划满足组织机构的建设要求和相关国家与行业的要求。
- 实施交付阶段：在此阶段，组织机构可通过对承建方进行信息安全服务资格要求和人员专业资格要求以确保施工组织的服务能力；组织机构还可通过信息系统安全保障工程保障对实施施工过程进行监理和评估，最终确保所交付系统的安全性。
- 运行维护阶段：信息系统进入运行维护阶段后，对信息系统的管理、运行维护和使用人员的能力等方面进行综合保障，是信息系统得以安全正常运行的根本保证。
- 变更：信息系统投入运行后并不是一成不变的，它随着业务和需求的变更、外界环境的变更产生新的要求或增强原有的要求，重新进入信息系统组织计划阶段（即规划阶段）。
- 废弃阶段：当信息系统不再满足业务要求时，信息系统进入废弃阶段，在这个阶段，需要考虑信息安全销毁等要素。

这样，通过在信息系统生命周期所有阶段融入信息系统安全保障概念，确保了信息系统的持续动态安全保障。

（2）信息安全保障要素

① 信息安全技术

信息安全技术体系包括以下几个方面。

- 密码技术：密码技术及应用涵盖了数据处理过程的各个环节，如数据加密、密码分析、数字签名、身份识别、秘密分享等。通过以密码学为核心的信息安全理论与技术保证数据的机密性和完整性等要求。
- 访问控制技术：在为用户对系统资源提供最大限度共享的基础上，对用户的访问权进行管理，防止对信息的非授权篡改和滥用。访问控制对经过身份鉴别后的合法用户提供所需要的且经过授权的服务，拒绝用户越权的服务请求，保证用户在系统安全策略下有序工作。
- 审计和监控技术：审计是事后认定违反安全规则行为的分析技术，在检测违反安全规则方面、准确发现系统发生的事件以及对事件发生的事后分析方面，审计都发挥着巨大的作用。审计技术的发展，来源于对访问的跟踪，这些访问包括对保存在计算机系统中敏感及重要信息的访问和对计算机系统资源的访问。网络安全监控包括主动监控和被动监控。它依赖于在任何给定时间内网络组件和检测器记录下已经发生的事情，接收日志信息，并对它进行分析。
- 网络安全技术：这些技术包括网络协议安全、防火墙技术、入侵检测系统/入侵防御系统（Intrusion Detection System/Intrusion Prevention System，IDS/IPS）、安全管理平台（Security Operations Center，SOC）、统一威胁管理（Unified Threat Management，UTM）等。网络安全技术主要是保护网络的安全，防止入侵攻击行为的发生。防火墙是一个位于可信网络和不可信网络之间的边界防护系统。防病毒网关防止基于 HTTP/FTP/SMTP/POP3/HTTPS 等网络协议侵入网络内部的病毒进行过滤。入侵检测系统是一种对网络传输进行即时监视，在发现可疑传输时发出警报措施的网络安全设备。入侵防御系统是监视网络传输行为的安全技术，它能够即时地中断、调整或隔离一些异常或是具有伤害性的网络传输行为。
- 操作系统与数据库安全技术：操作系统安全技术主要包括身份鉴别、访问控制、文件系统安全、安全审计等方面。数据库安全技术包括数据库的安全特性和安全功能，数据库完整性要求和备份恢复，以及数据库安全防护、安全监控和安全审计等。
- 安全漏洞与恶意代码：包括安全漏洞的成因、分类、发掘方法，以及如何修复等；以及恶意代码的加载、隐藏和自我保护技术，恶意代码的检测原理及清除方法等。
- 软件安全开发：包括软件安全开发模型、软件安全开发关键阶段的安全控制措施等内容。

② 信息安全管理

信息安全管理体系的一部分，是组织在整体或特定范围内建立信息安全方针和目标，以及完成这些目标所用方法的体系。基于对业务风险的认识，ISMS 包括建立、实施、操作、

监视、复查、维护和改进信息安全等一系列的管理活动，并且表现为组织结构、策略方针、计划活动、目标与原则、人员与责任、过程与方法、资源等诸多要素的集合。

风险管理是指以风险为主线进行信息安全的管理，它的实施目标就是要依据安全标准和信息系统的安全需求，对信息、信息载体、信息环境进行安全管理，以达到安全目标。

风险管理贯穿于整个信息系统生命周期，包括对象确立、风险评估、风险控制、审核批准、监控与审查、沟通与咨询等 6 个方面的内容。其中，对象确立、风险评估、风险控制和审核批准是信息安全风险管理的 4 个基本步骤，监控与审查、沟通与咨询则贯穿于这 4 个基本步骤中。

③ 信息安全工程

信息安全工程涉及系统和应用的开发、集成、操作、管理、维护和进化以及产品的开发、交付和升级。

系统安全工程能力成熟模型（Systems Security Engineering Capability Maturity Model，SSE-CMM）描述了一个组织的系统安全工程过程必须包含的基本特征。这些特征是完善的安全工程保证，也是系统安全工程实施的度量标准，同时还是一个易于理解的评估系统安全工程实施的框架。

④ 信息安全人才

信息安全保障诸要素中，人是最关键也是最活跃的要素。网络攻防对抗，最终较量的是攻防两端的人，而不是设备。对组织机构来说，应建立一个完整的信息安全人才体系。信息安全人才体系应包括以下方面。

- 所有员工：需要进行信息安全保障意识教育，具体可以采用内部培训、在组织机构网站上发布相关信息等措施来增强所有员工的安全意识。
- 涉及信息系统的岗位和职责的员工：需要进行相应的信息安全保障的基本技能培训。
- 信息安全专业人员：应建立更全面、更专业的信息安全保障知识和经验。

（3）信息安全保障解决方案

信息安全保障解决方案是一个动态的风险管理过程，通过信息系统生命周期内的风险实施控制，来解决在运行环境中信息系统安全建设所面临的各种问题，从而有效保障业务系统及应用的持续发展。

信息安全保障方案是以安全需求为依据设计的。在设计安全方案时，需要考虑方案是否贴合实际，是否具有可实施性，包括可接受的成本、合理的进度、技术可实现性，以及组织管理和文化的可接受性。在工作中，可以根据信息系统安全目标（ISST）来规范制定安全方案。ISST 是根据信息系统保护轮廓（ISPP）编制、从信息系统安全保障的建设方（厂商）角度制定的信息系统安全保障方案。

根据信息系统安全目标要求，信息系统安全方案的标准格式应包括 8 个部分：引言、信息系统描述、信息系统安全环境、安全保障目的、安全保障要求、信息系统概要规范、ISPP 声明，以及符合性声明。

其中，引言、信息系统描述、信息系统安全环境、安全保障目的、安全保障要求部分

与 ISPP 一致。

信息系统概要规范包括信息系统安全功能满足哪一个特定的安全功能需求，其保证措施满足哪一个特定的安全保障要求，以及相应的解释、证明等支持材料。与 ISPP 类似，在编制这部分内容时，从国标 GB/T 20274《信息安全技术 信息系统安全保障评估框架》的第二部分选择技术组件，从该标准的第三部分选择具体管理组件，在该标准的第四部分选择具体的工程组件。

在具体实施信息安全保障方案时，须以方案为依据，覆盖方案所提出的建设目标和建设内容。另外，在实施过程中，需要注意以下几个方面：规范的实施过程；实施的质量、进度和成本必须受控；实施过程中出现的变更必须受控；充分考虑实施风险，如资源不足、组织文化的抵触情绪、对业务正常运行造成的影响、信息泄露或破坏等。

1.2.4　企业安全架构

企业安全架构是企业架构的一个子集，它定义了信息安全战略，包括分层级的解决方案、流程和规程，以及它们与整个企业的战略、战术和运营链接的方式。这是用全面的、严格的方法描述了组成完整的信息安全管理体系所有组件的结构和行为。开发企业安全架构的主要原因是确保安全工作以一个标准化的和节省成本的方式与业务实践相结合。架构在抽象层面工作，它提供了一个可供参考的框架。除了安全性之外，这种类型的架构让组织更好地实现互操作性、集成性、易用性、标准化和便于治理性。

1．舍伍德商业应用安全架构

舍伍德商业应用安全架构（Sherwood Applied Business Security Architecture，SABSA）是一个分层的模型，包括 6 个层级，如图 1-11 所示。第一层从安全的角度定义了业务需求，模型的每一层在抽象方面逐层减少，但是在细节方面则是逐层增加。SABSA 安全架构提供了一个包括战略、概念、设计、实施、度量和审计层次的安全链条，层级都是建立在其他层之上。

	资产（什么）	动机（为什么）	过程（如何）	人（谁）	地点（何地）	时间（何时）
背景层	业务	业务风险模型	业务过程模型	业务组织和关系	业务地理布局	业务时间依赖性
概念层	业务属性配置文件	控制目标	安全战略和架构分层	安全实体模型和信任框架	安全域模型	安全有效期和截止时间
逻辑层	业务信息模型	安全策略	安全服务	实体概要和特权配置文件	安全域定义和关系	安全过程循环
物理层	业务数据模型	安全规则、实践和规程	安全机制	用户、应用程序和用户接口	平台和网络基础设施	控制结构执行
组件层	数据结构细节	安全标准	安全产品和工具	标识、功能、行为和访问控制列表（ACL）	过程、节点、地址和协议	安全步骤计时和顺序
运营层	业务连续性保障	运营风险管理	安全服务管理和支持	应用程序和用户管理与支持	站点、网络和平台的安全	安全运营日程表

图 1-11　SABSA 架构框架

每一层代表着每一个不同参与者在指定、设计、施工和对建筑的使用中的观点。

（1）背景层（业务视图）

业务视图说明所有架构必须满足业务要求。了解该系统的业务需求驱动，选择合适的架构。比如，需要了解以下方面。

- 什么类型的系统?
- 什么时候使用?
- 为什么会用?
- 将如何使用?
- 谁将会使用它?
- 它会在哪里使用?
- 何时可以使用?

从收到答复的分析中，应该能够获得对安全系统业务需求的理解，从而合成系统架构和安全架构，以满足这些要求。

在 SABSA 模型，这个业务视图被称为背景环境的安全架构。这是安全系统必须设计、建造和经营的业务范围内的描述。

（2）概念层（架构视图）

架构是整体的概念，可满足企业的业务需求。因此，这层 SABSA 被称为概念性的安全架构。它定义在较低层次的抽象逻辑和物理元素的选择和组织上，确定指导原则和基本概念。该部分需要了解以下方面。

- 需要安全控制的目标在哪里？为什么要保护？控制的目标是直接来自企业的经营风险分析，是企业安全动机概念化。
- 如何来实现保护？在高层次技术和管理安全策略和过程映射框架中，保护业务流程。这种策略可能包括应用程序的安全策略、网络安全策略、公钥基础设施（PKI）的战略和基于角色的访问控制（RBAC）策略等。对于每一个内容安全架构中所确定的业务需求的主要领域，将支持它的安全策略（组策略）。
- 如何实现安全域框架概念化的保护？这里重要的概念是安全域（逻辑和物理）、域边界和安全组织。

（3）逻辑层（设计视图）

设计是架构的具体反映，设计过程通常被称为系统工程，它涉及整个系统的架构元素的识别和规范。逻辑的安全架构应该反映和代表所有概念性的安全架构中的主要安全战略。在这个逻辑层面上，一切从更高的层次转化为一系列的逻辑抽象。逻辑安全体系结构关注的是以下内容。

- 什么？即需要保护的商业信息，它是一个真正的业务逻辑表示。
- 为什么？指定的安全和风险管理政策要求，如确保商业信息的高层次的安全政策、登记管理机关的政策、核证机关的政策、物理域的政策、逻辑域政策等。
- 如何做？指定逻辑安全服务（实体验证、保密性、完整性保护、不可抵赖性和保

证系统等），以及如何将它们组合成一个复杂的安全系统，以满足整体业务需求的可重复使用的共同集合。还指定了流程图和功能规范，描述了所需的功能方面的安全服务的逻辑流。

- 谁？指定实体（用户、安全管理员和审计师等）及其相互间的关系、属性。
- 在哪里？指定的安全域和域间的关系（逻辑安全域、物理安全域和安全组织）。
- 什么时候？指定开始时间、期限和生命周期方面（如注册、认证、登录和会话管理等）与安全有关的日历和时间表。

（4）物理层（建设视图）

设计是产生一套描述了系统的逻辑抽象，这些都需要形成一个物理的安全体系结构模型，该模型应描述实际的技术模式和指定的各种系统组件的详细设计。如需要描述提供服务的服务器的物理安全机制和逻辑安全服务等。总体而言，物理安全体系结构关注的是以下内容。

- 什么？指定的业务数据模型和安全相关的数据结构（表、信息、指针、证书和签名等）。
- 为什么？指定驱动系统内的逻辑决策规则（条件、方式、程序和行动）。
- 如何？指定的安全机制（加密、访问控制、数字签名和病毒扫描等）和物理应用。
- 谁？指定访问控制系统的人机界面（屏幕格式和用户交互）的形式。
- 在哪里？主机平台和网络（硬件、软件和通信线路的物理布局）。
- 什么时候？指定的时间和顺序（序列、事件、寿命和时间间隔）。

（5）组件层（实施者视图）

这层的模型也被称为组件的安全架构。组件体系结构关注的是以下内容。

- 什么？信息和通信技术的组成部分，如信息和通信技术产品，包括数据仓库和处理器。
- 为什么？风险管理相关的工具和产品，如风险分析工具、风险寄存器、风险监测和报告工具。
- 如何？流程工具和标准（过程中传递-硬件和软件两方面的工具和协议）。
- 谁？人事管理工具和产品（身份、职务说明、角色、功能、操作和访问控制列表）。
- 在哪里？定位工具和标准（节点、地址以及其他定位器）。
- 什么时候？步骤计时和测序工具（时间安排、时钟、定时器和中断）。

（6）运营层（服务和管理视图）

当建设完成后，需要进行运维管理。主要是保持各项服务的正常运作，保持良好的工作秩序和监测，以及按要求执行。这样的框架被称为服务管理的安全架构。在这里，关注的焦点是安全性相关的部分。安全服务管理架构关注的是以下内容。

- 什么？服务交付管理（保证业务连续性、卓越的业务系统和信息处理，并保持业务的数据和信息的安全性）。
- 为什么？操作风险管理（风险评估、风险监测和报告、风险处理，以尽量减少操

作失误和干扰）。

- 如何？流程交付管理（系统、应用和服务的管理和支持，执行与安全有关的专门的业务，如用户系统的安全管理、数据备份、安全监控和应急响应程序等）。
- 谁？人事管理（账户设置和用户支持与安全有关的所有用户及其应用的需求，包括企业用户、运营商和系统管理员等管理）。
- 在哪里？环境管理（建筑物、遗址、平台和网络管理）。
- 什么时候？日程管理（管理与安全有关的日历和时间表）。

要成功开发和实现企业安全架构，必须理解并遵循下面的要点：战略一致性、过程强化、促进业务和安全有效性。

2．舍伍德商业架构模型生命周期

SABSA 是用于企业安全架构和服务管理的框架和方法论，由于它是一个框架，这就意味着它为构建架构提供了一种结构，也就意味着它提供了建立和维护架构要遵循的过程。SABSA 提供了一个生命周期模型，这样，随着时间的推移，可以对架构持续监控和改进。

从 SABSA 的发展过程可以看出整个 SABSA 在安全架构中的生命周期，如图 1-12 所示。在 SABSA 生命周期中，前两个阶段的过程被归类为所谓的“战略与规划”。其次是“设计”，它包含了建筑设计中的逻辑设计、物理设计、组件设计和服务管理设计。再者就是“实施”，紧随其后的则是“管理与衡量”。

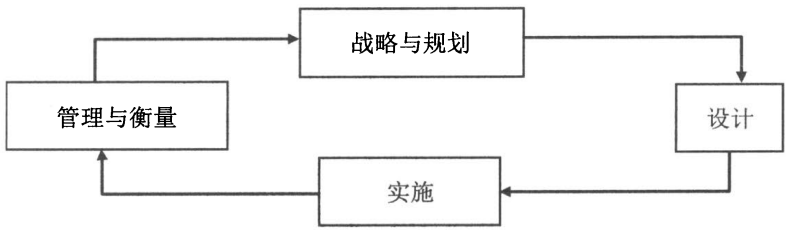

图 1-12　SABSA 的生命周期

“管理和衡量”这一活动的重要意义在于提早设定目标绩效指标。一旦该系统投入使用，必衡量目标的实际性能并管理任何一个被发现的偏差。

第 2 章

知识域：网络安全监管

阅读提示 本知识域是介绍我国信息安全法律法规及标准体系，学员通过学习，了解我国信息安全相关战略及政策要求，掌握如何通过法律法规为网络安全建设工作提供依据和合规性支撑，同时了解信息安全标准体系及我国信息安全相关标准。本知识域包括网络安全法律体系建设、国家网络安全政策、网络安全道德准则和信息安全标准 4 个知识子域。

2.1 知识子域：网络安全法律体系建设

网络空间作为继陆地、海洋、天空及外太空之外的第五空间，安全问题已经上升到国家安全的高度。网络攻击和防御能力已经从商业化发展到了军事化，通过网络空间获取巨大商业利益甚至影响政权变更已经在真实世界发生。立法作为网络空间安全治理的基础工作，是抑制黑色产业链必须采取的工作，也是网络安全产业发展和规范的支持，关键信息基础设施保障的依据。

经过十多年的发展，目前我国现行法律法规及规章中，与网络空间安全有关的已有近百部，它们涉及网络运行安全、信息系统安全、网络信息安全、网络安全产品、保密及密码管理、计算机病毒与恶意程序防治、通信、金融、能源、电子政务等特定领域的网络安全、各类网络安全犯罪制裁等多个领域，在文件形式上，有法律、有关法律问题的决定、司法解释及相关文件、行政法规、法规性文件、部门规章及相关文件、地方性法规与地方政府规章及相关文件多个层次，初步形成了我国信息安全的法律体系。随着《网络安全法》在 2017 年 6 月 1 日正式实施，我国网络安全法律法规体系一直以来基本法缺位的问题得到了彻底解决。我国初步构建了以《网络安全法》为基础的网络空间安全法律法规体系。

2.1.1 计算机犯罪

1. 计算机犯罪的概念

网络犯罪或计算机犯罪是涉及计算机和网络的犯罪。网络犯罪可定义为：“利用现代电信网络故意伤害受害者的声誉或间接地给受害者造成身心伤害或损失，如利用互联网（包

括但不限于聊天室、电子邮件、BBS 和网络群组等）和手机（蓝牙/短信/彩信）针对个人或团体进行的犯罪。”在国际上，政府和非国家行为体都参与网络犯罪，包括间谍活动、金融盗窃和其他跨境犯罪。跨越国际边界并涉及至少一个国家利益的活动有时被称为网络战。

注：法律健全的国家，网络间谍活动均有专门的法律支持，不属于计算机犯罪。

2．计算机犯罪的特征

计算机犯罪问题随着计算机技术的快速发展也日趋广泛。常见的计算机犯罪有 3 个特征：多样化、复杂化和国际化，成为计算机立法以及执法的难题。

（1）多样化

计算机犯罪的多样化主要体现在实施犯罪的工具、受侵害的对象以及作为存储犯罪证据的载体所形成的法律责任问题。犯罪所形成的损害包括有形损害（如导致组织提供支付服务中断、导致用户数据被恶意篡改或者国家关键基础设施被攻击后城市公共服务中断等）和无形损害（包括恶意网络诽谤、虚假新闻、公众因为服务中断或泄露对组织产生的不信任等）两大类型；对于受害者而言又分为直接导致损害（如拒绝服务攻击、篡改数据、泄露组织敏感信息等）和间接导致损害（如提供工具、种植木马或后门然后被他人利用）两种。传统计算机犯罪从国际通用的分类而言，可分为以下 3 种类型。

① 针对计算机系统的犯罪行为

该类行为通常指传统意义上的计算机犯罪，典型的行为如非法入侵、非法破坏等。

从法律上而言，该类型首先要确定受害对象是否为法律所定义的计算机信息系统或者网络系统；其次要根据相关法律描述其形成破坏的结果进行相应的司法追溯。例如，《中华人民共和国刑法》（以下简称《刑法》）第 285 条和第 286 条中针对对象分别定义为“国家国防建设、科技、公共事务服务”与“其他”两大类型。不同类型前者产生上述行为直接适用《刑法》，而后者需要构成损害的结果为“重大”和“特别重大”。

针对计算机系统的犯罪不仅局限于利用计算机实施的，还可能包括如物理破坏或损坏、社会工程学攻击等行为。

计算机系统构成损害的实体不仅包括计算机系统物理设施本身，现代犯罪更追求的是计算机系统作为载体所内在的数据、业务的破坏和损害，因此该类型有可能存在更广泛的涵义（如伪指令对人工智能所形成的错误执行、大数据所形成的人物画像导致的隐私泄露等）和影响需要法学界跨学科地进行长期的研究和应对。

② 利用计算机系统实施犯罪的行为

随着计算机系统的普及化使用，利用计算机系统实施犯罪越来越普遍，通过计算机系统实施的犯罪，对象不仅是计算机系统本身，还可能包含生产、生活及其他任何领域的安全问题。

合理利用计算机系统是社会繁荣的重要保证，但是计算机的使用越普遍，可能构成犯罪的利用途径就越广泛，因此，计算机立法问题不仅要突出计算机系统被入侵后的损害，

更要明确利用计算机系统所形成的后果，以进行法律约束。

③ 基于计算机提示性犯罪

计算机系统作为一种数据创建、管理、传播以及存储、处理的工具被广泛地使用，该类犯罪本质上与计算机犯罪相关法律并无直接关系，由于犯罪分子可能利用计算机系统记录犯罪行为，如走私账单、聊天记录、邮件等内容，这些内容是对犯罪分子犯罪行为的有效举证，因此，需要通过合法的取证手段进行提取和保存，以作为法证提交司法进行追溯。

随着计算机系统相关技术的发展，更多的时候云的应用增加了这类证据的提取难度，由于属地管理问题和跨国界问题，很多时候犯罪分子会通过加密、云存储以及碎片化存储技术，使得取证工作变得异常复杂。

（2）复杂化

计算机犯罪随着计算机技术的发展不断得到延伸，基于网络层的攻击从 IP 的单一化到 IP 伪造，再到跳板技术，使得对于攻击者的追踪变的异常复杂；大规模的僵尸网络掩盖了真实的攻击 IP，同时复合式攻击使得防御技术变得异常脆弱。

传统的犯罪具有时间、地点、动机三大要素，但计算机犯罪利用网络技术打破了传统犯罪的三原则。计算机时间的可更改性掩盖了犯罪分子拥有犯罪时间或者通过自动化攻击技术构造不在犯罪时间实施行为的能力；而计算机犯罪无须在受害人所在的场地实施攻击，有网络的地方就能实现攻击，攻击本身变得不可预测；“为什么要这么去做？”可能很多执法人员都会这样去盘问犯罪分子，但是很多时候这个原因很难用“为什么”来描述，比如基于技术的炫耀、被不良人员的利诱、基于经济原因或者政治原因，甚至可能就是一个无意识的操作或者好奇，都可能引发计算机犯罪问题的产生。

近年来崛起的 APT（Advanced Persistent Threat）攻击使得计算机犯罪从个体行为变成有组织犯罪。攻击不再是单纯通过计算机技术来实现，社会工程学、情报分析等使得犯罪更加专业化。尤其是国家势力的介入使得很多带有政治目的的计算机攻击行为被某些因素掩盖了攻击者的真实轨迹。

云计算的广泛使用使得犯罪分子可以通过云平台实施攻击；同样也可以在跨境云平台存储犯罪信息；计算机终端设备的多样化也使得攻击者不一定要坐在某个固定的场合去实施行为，一部手机、一个树莓派甚至是一块智能手表都可能成为一种攻击工具。可以说，“只要有机会，计算机犯罪可以利用一切电子设备实施攻击”。

注：树莓派是 Raspberry Pi 的中文名，简写为 RPi，是为学习计算机编程教育而设计的只有信用卡大小的微型电脑，其系统基于 Linux。

攻击工具的傻瓜化使得攻击不再需要更专业的技术，“脚本小子”利用网络中下载的各种工具为所欲为的时候，用户却在饱受煎熬。各种论坛中充斥着层出不穷的攻击手段和技术；利用社会工程学的通信诈骗手段日益更新，“道高一尺魔高一丈”，这个事实在计算机犯罪领域不断被验证。

（3）国际化

有了互联网，计算机系统就成为联通世界的重要工具。任何人都可以通过互联网在世界任一地方进行通信和传递，这也为国际计算机犯罪提供了契机。

不是每个国家都具有计算机犯罪立法，也不是每个国家都具有良好的计算机防护能力，因此，犯罪分子利用国家立法的漏洞或者国际化的跳板技术，通过这些国家计算机系统构建攻击通道，甚至有些犯罪分子集中在一些没有计算机犯罪立法的国家（如罗马尼亚）肆意实施犯罪行为。

网络是连通的，这也就意味着同样的攻击不仅可以在一个国家进行，随着高速网络的传输，它也可以在任何国家同步发起。2017 年 5 月在我国广泛传播的“永恒之蓝”就是一种典型的跨国犯罪行为。而“9·11 事件”中，恐怖分子利用邮件系统以及推特在美国同步展开的袭击事件，更加体现了计算机犯罪本身在国际化的影响下，变得更为猖狂。

3．计算机犯罪的趋势

计算机犯罪的本质是一种技术的不良利用所导致，技术本身是复杂的，但是技术的实现手段被工具化之后，计算机犯罪无论从成本而言还是从收益而言都变得越发具有诱惑性。从炫耀技术能力变成有组织、有目的的恶意行为，计算机犯罪已经成为一种专业的犯罪行为，随着这种行为构成日益庞大的利益链，计算机犯罪的形势也将变得更加严峻。

（1）从无意识犯罪到有组织犯罪

早期的计算机犯罪往往是某个具有高超技术能力的个体（俗称“黑客”）为了炫耀自己的技术能力所形成的一种表现，尤其是在美国的“朋克”年代，他们通常没有一种确切的诉求，往往是一种下意识的行为；因此，从本质上而言他们并不是刻意去破坏什么，但是最终的结果可能会导致计算机系统的使用者产生不可估量的后果和影响。

现代计算机犯罪已经具有了清晰的目的性，从黑色产业链分工而言，制作木马、传授技术、部署木马、获得数据后的销售以及利益的分配共同构成了一条完整的黑色产业链。在这条链条中不仅有计算机专业人员的参与，更多的还包括各行各业的一线工作人员以及能够支配数据的其他人员。

APT 攻击把这种有组织性变得更加完整，一个团队中拥有情报分析人员、高级的编程人员、漏洞挖掘人员、信息收集和分析人员甚至包括数据专家、锁匠（这并不是笑话，有时候需要通过撬锁来实现对特定人员的计算机相关设备安装特种木马）。

（2）从个体损害向国家威胁发展

传统的计算机犯罪主要是对个人的危害，比如窃取用户账号密码、传播病毒，受技术的限制，个人终端往往更容易被入侵和利用；随着计算机的普及，组织在大量使用计算机系统时，由于组织漠视信息化的安全问题，导致攻击重心从个人向组织偏移。在这里，攻击者能获得更多的利益和荣耀。

但是近年来，计算机犯罪不再是一种单纯的技术犯罪，针对国家的攻击行为逐步走到了前台，“震网事件”使得伊朗纳什尔核电站遭受实际物理损失，乌克兰火电站的大面积

瘫痪也说明了没有所谓的“物理隔离就是安全的”一说。国家关键信息基础设施的脆弱性在一夜之间必须面临计算机犯罪的挑战。

从军事信息化到工业信息化，从医疗信息化到金融信息化，计算机犯罪已无孔不入，未来针对国家关键信息基础设施的攻击将成为各国所关注的重点，也会成为未来计算机犯罪立法的关注重点。

（3）跨越计算机本身的实施能力

“不用计算机的计算机犯罪”，这句话听起来非常怪异，但是社会工程学这种利用人性弱点的攻击方法已经成为计算机犯罪利用的一种新技术，通过跨学科的社会工程学理论，欺诈、利用信任甚至是胁迫都成为获取信息或者获取系统控制权的重要手段。

美国计算机应急响应中心（CERT/CC）在 2014 年发布的《内部威胁：社会工程学攻击》一文中，从心理学、社会学、计算机科学等角度分析了最容易被社会工程学利用的人员年龄段、学历层次、社会角色等因素。

（4）低龄化成为法律制约的难题

低龄化的问题是困扰各国司法界的难题，在我国，未成年人犯罪的司法追溯能力尚不完善，而计算机技术的低龄化和工具的傻瓜化使得计算机犯罪人员的年龄逐年下降。一些别有用心的人员利用法律的漏洞和未成年人的好奇心，通过即时通讯工具，将攻击工具、使用方法传递给未成年人，引导或操纵未成年人实施他们想要的操作。对于司法而言，未成年人本身不具有民事能力，因此很难通过有效的司法程序追究其责任。

2.1.2 我国立法体系

1．立法与职能

计算机犯罪的不断发展使得国家需要通过有效的立法体系来控制和约束其不良行为。目前我国采用多级立法机制，如图 2-1 所示。《中华人民共和国宪法》（以下简称《宪法》）作为我国根本大法确立了我国的基本法制体系，根据我国《宪法》第六十二条规定，“全国人民代表大会行使下列职权：（一）修改宪法；（二）监督宪法的实施；（三）制定和修改刑事、民事、国家机构的和其他的基本法律；……”。同时，也明确了《宪法》的解释与监督执行由全国人民代表大会负责。2017 年 6 月 1 日，由全国人民代表大会审议通过并发布了我国第一部信息安全基本法《网络安全法》。

国务院根据宪法和法律，规定行政措施，制定行政法规，发布决定和命令，例如，为了保护计算机信息系统的安全，促进计算机的应用和发展，保障社会主义现代化建设的顺利进行，国务院于 1994 年发布了 147 号令《中华人民共和国计算机信息系统安全保护条例》（以下简称《计算机信息系统安全保护条例》），该条例根据 2011 年 1 月 8 日《国务院关于废止和修改部分行政法规的决定》重新做出修订；条例定义了计算机信息系统及保护的范围、意义，明确了公安部主管全国计算机信息系统安全保护工作。国家安全部、国家保密局和国务院其他有关部门，在国务院规定的职责范围内做好计算机信息系统安全保护的

有关工作；提出了安全保护制度及其公安机关的安全监督职能和要求。

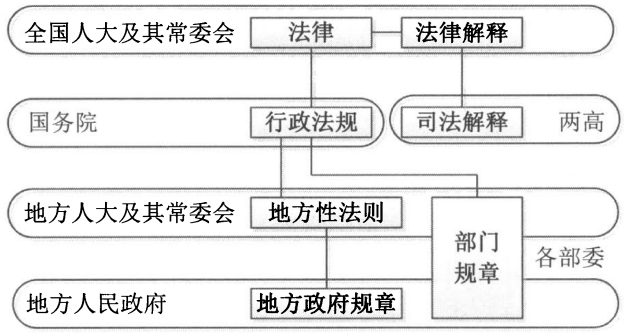

图 2-1　立法体系示意图

国务院各部、委员会、中国人民银行、审计署和具有行政管理职能的直属机构，可以根据法律和国务院的行政法规、决定、命令，在本部门的权限范围内，制定规章；如公安部在 1997 年 6 月颁布了《计算机信息系统安全专用产品检测和销售许可证管理办法》，该办法针对在我国境内销售的境内外计算机信息系统安全专用产品必须经过公安部有关机构进行检测，通过检测许可后，方可在我国境内销售使用。

省、直辖市的人民代表大会和它们的常务委员会，在不同宪法、法律、行政法规相抵触的前提下，可以制定地方性法规，报全国人民代表大会常务委员会备案。同时对设区的市人民代表大会和它们的常务委员会，在不同宪法、法律、行政法规和本省、自治区的地方性法规相抵触的前提下，可以依照法律规定制定地方性法规，报本省、自治区人民代表大会常务委员会批准后施行。

从立法体系而言，《宪法》具有最高的法律效力，一切法律、行政法规、地方性法规、自治条例和单行条例、规章都不得同《宪法》相抵触。法律的效力高于行政法规、地方性法规、规章。行政法规的效力高于地方性法规、规章。法律、行政法规、地方性法规如果有超越权限或下位法违反上位法规定的情形的，将依法予以改变或者撤销。法律的这些规定，就是要求下位法与上位法相衔接、相协调、相配套，从而构成法律体系的有机统一整体，有效地调整社会关系，保证社会生活的正常秩序。

人民法院依照法律规定独立行使审判权，除法律规定的特别情况外，一律公开进行。人民法院、人民检察院和公安机关办理刑事案件，分工负责，互相配合，互相制约，保证准确有效地执行法律。

2．立法分类

以《宪法》为根本依据，分为法律、行政法规、地方性法规 3 个层次；由宪法及宪法相关法、民法商法、行政法、经济法、社会法、刑法、诉讼与非诉讼程序法 7 个法律部分组成。

《宪法》作为我国根本大法，确立了公民通信自由和通信保密受到法律的保护。民法是调整作为平等主体的公民之间、法人之间、公民与法人之间的财产关系和人身关系的法

律；民法强调对公民权力如隐私权、肖像权、知识产权等受到侵害后所形成的法律责任，通常采取赔偿、道歉等形式进行惩戒；商法是调整作为平等主体之间的商事关系或商事行为的法律。

行政立法体制是指一个国家的行政立法主体的设置及其立法权限的划分，是一个国家整个立法体制的一部分。行政法，是指行政主体在行使行政职权和接受行政法制监督过程中而与行政相对人、行政法制监督主体之间发生的各种关系，以及行政主体内部发生的各种关系的法律规范的总称。常见的信息安全行政立法除了《计算机信息系统安全保护条例》，还包括其他若干法规。如1999年10月国务院令第273号《商用密码管理条例》，针对我国商用密码的科研、生产、销售和使用实行专控管理，并确立其主管部门国家密码管理委员会及其办公室。

2.1.3 网络安全法

1.《网络安全法》背景

《网络安全法》的出台是落实国家总体安全观的重要举措，是维护网络安全的客观需要，也是维护人民群众切身利益的迫切需要。《网络安全法》从制定到实施经历了3次审议和两次公开征求意见。

第一次审议（2015年6月26日）明确了网络空间主权原则；对关键基础设施安全实行重点保护；加强网络安全监测预警和应急制度建设。

第二次审议（2016年6月28日）明确了重要数据境内存储，建立数据跨境安全评估制度并鼓励关键信息基础设施以外的网络运营者自愿参加关键信息基础设施保护体系。

第三次审议（2016年10月31日）进一步界定关键信息基础设施范围；增加了惩治攻击破坏我国关键信息基础设施的境外组织和个人的规定以及惩治网络诈骗等新型网络违法犯罪活动的规定；同时强调加强网络安全人才培养、保护未成年人上网安全的相关问题。

2016年11月7日，《网络安全法》正式发布，2017年6月1日实施。《网络安全法》从我国的国情出发，坚持问题导向，总结实践经验，确定了各相关主体在网络安全保护中的义务和责任，网络信息安全各方面的基本制度，注重保护网络主体的合法权益，保障网络信息依法、有序、自由地流动，促进网络技术创新，最终实现以安全促发展，以发展来促安全。

2.《网络安全法》基本概念

《网络安全法》在附则部分对相关概念进行了明确定义。

（1）网络

由计算机或者其他信息终端及相关设备组成的按照一定的规则和程序对信息进行收集、存储、传输、交换、处理的系统。

《网络安全法》里的网络不仅仅是传统IT领域中狭义的仅包含网线、交换机等数据通信设备的计算机网络，还包含相关处理信息的服务器和各种其他软硬件，是广义的网络空

间，相当于国外的 Cyber Space 概念（中国香港、台湾等地也有翻译为赛博空间），不仅仅是 Network。网络空间已成为陆地、海洋、天空、太空之外的“第五空间”，成为国家主权延伸的新疆域，也是人类“第二类生存空间”。

（2）网络安全

通过采取必要措施，防范对网络的攻击、侵入、干扰、破坏和非法使用以及意外事故，使网络处于稳定可靠运行的状态，以及保障网络数据的完整性、保密性、可用性的能力。

《网络安全法》里的网络安全应对的不仅仅是对计算机网络本身的攻击，还包含对网络中处理的信息的保密性、完整性和可用性进行攻击。《网络安全法》中的第三章网络运行安全主要针对可用性进行保护，第四章网络信息安全主要针对保密性和完整性进行保护，可以理解为网络空间安全。

（3）网络运行安全

网络运行安全是指对网络运行环境的安全保障，主要包含传统网络安全中对于保障网络与信息系统正常运行的物理环境、网络环境、主机环境和应用环境的技术管理措施。

（4）网络信息安全

网络信息安全是指对网络数据和个人信息的安全保障，主要包含传统数据安全、内容安全的范畴。

（5）网络运营者

网络运营者是指网络的所有者、管理者和网络服务提供者。

《网络安全法》里的网络运营者不仅仅是网络的运维组织或人员，还包含网络的所有者和各种类型的网络服务提供者，例如提供信息搜索、网络聊天、电子商务、电子政务等网络服务的提供者，可以说涵盖了 ISP、ICP、IDC 等所有概念。

（6）关键信息基础设施

关键信息基础设施是指面向公众提供网络信息服务或支撑能源、通信、金融、交通、公用事业等重要行业运行的信息系统或工业控制系统。

（7）网络数据

网络数据是指通过网络收集、存储、传输、处理和产生的各种电子数据。

（8）个人信息

个人信息是指以电子或者其他方式记录的能够单独或者与其他信息结合识别自然人个人身份的各种信息，包括但不限于自然人的姓名、出生日期、身份证件号码、个人生物识别信息、住址、电话号码等。

3.《网络安全法》主要内容

《网络安全法》共计 7 章，79 条。主要内容包括网络空间主权原则、网络运行安全制度、关键信息基础设施保护制度、网络信息保护制度、应急和监测预警制度、网络安全等级保护制度、网络安全审查制度等。

（1）网络空间主权原则

作为我国网络安全治理的基本法，《网络安全法》在总则部分确立了网络主权原则，

明确了网络安全管理体制、分工及域外的适用效力。

（2）网络运行安全制度

明确网络运营者的安全义务，内部安全管理：制定内部安全管理制度和操作规程，确定网络安全负责人；安全技术措施：采取防范网络安全行为的技术措施；采取监测、记录网络运行状态、网络安全事件的技术措施，留存相关的网络日志不少于6个月；数据安全管理：采取数据分类、重要数据备份和加密等措施，防止网络数据泄露或者被窃取、篡改；网络身份管理：办理网络接入、域名注册服务，或固定电话、移动电话等入网手续，或为用户提供信息发布、即时通讯等服务，应要求用户提供真实身份信息；应急预案机制：制定网络安全事件应急预案，及时处置系统漏洞、计算机病毒、网络攻击、网络侵入等安全风险；在发生危害网络安全的事件时，立即启动应急预案，采取相应的补救措施，并向有关主管部门报告；安全协助义务：为公安机关、国家安全机关依法维护国家安全和侦查犯罪的活动提供技术支持和协助。

明确网络产品、服务提供者的安全义务。强制标准义务：网络产品、服务应当符合相关国家标准的强制性要求，不得设置恶意程序；网络关键设备和网络安全专用产品应当按照相关国家标准的强制性要求，由具备资格的机构安全认证合格或者安全检测符合要求后，方可销售或者提供；告知补救义务：网络产品、服务提供者发现其网络产品、服务存在安全缺陷、漏洞等风险时，应当立即采取补救措施，及时告知用户，向有关主管部门报告；安全维护义务：网络产品、服务提供者应为产品、服务持续提供安全维护，在规定或者当事人约定的期限内不得终止；个人信息保护：网络产品、服务具有收集用户信息功能的，网络产品、服务提供者应向用户明示并取得同意；涉及用户个人信息的，还应遵守相关法律、行政法规中有关个人信息保护的规定。

明确一般性安全保护义务，安全信息发布：开展网络安全认证、检测、风险评估等活动，向社会发布系统漏洞、计算机病毒、网络攻击、网络侵入等网络安全信息，应当遵守国家有关规定；禁止危害行为：任何个人和组织不得从事非法侵入他人网络、干扰他人网络正常功能、窃取网络数据等危害网络安全的活动；不得提供专门用于从事侵入网络、干扰网络正常功能及防护措施、窃取网络数据等危害网络安全活动的程序、工具；明知他人从事危害网络安全的活动的，不得为其提供技术支持、广告推广、支付结算等。

信息使用规则：网信部门和有关部门在履行网络安全保护职责中获取的信息，只能用于维护网络安全的需要，不得用于其他用途。

（3）关键信息基础设施保护制度

关键信息基础设施保护是指面向公众提供网络信息服务或支撑能源、通信、金融、交通、公用事业等重要行业运行的信息系统或工业控制系统，且这些系统一旦发生网络安全事故，会影响重要行业正常运行，对国家政治、经济、科技、社会、文化、国防、环境以及人民生命财产造成严重损失。

① 关键信息基础设施外延

关键信息基础设施的具体范围由国务院制定，鼓励关键信息基础设施以外的网络运营

者自愿参与关键信息基础设施保护体系。

② 关键信息基础设施管理机制

按照国务院规定的职责分工，负责关键信息基础设施安全保护工作的部门具体负责实施本行业、本领域的关键信息基础设施保护工作。国家网信部门统筹协调有关部门对关键信息基础设施采取安全保护措施。

③ 关键信息基础设施建设要求

国家关键信息基础设施应具有确保可支持业务稳定、可持续运行的性能。系统建设与安全技术措施遵循同步规划、同步建设、同步使用的原则。

④ 关键信息基础设施运营者安全保护义务

- 人员安全管理：设置专门安全管理机构和安全管理负责人；对负责人和关键岗位的人员进行安全背景审查；定期对从业人员进行网络安全教育、培训和考核。
- 数据境内留存：在我国境内运营中收集和产生的个人信息和重要数据应当在境内存储。确需向境外提供的，须进行安全评估；对重要系统和数据库进行容灾备份。
- 应急预案机制：制定网络安全事件应急预案，并定期进行演练。
- 安全采购措施：采购网络产品和服务可能影响国家安全的，应当通过国家安全审查。应与网络产品和服务提供者签订安全保密协议。
- 风险评估机制：自行或者委托网络安全服务机构对其网络的安全性和可能存在的风险每年至少进行一次检测评估，并将检测评估情况和改进措施报送相关部门。

（4）网络信息保护制度

网络信息保护吸收了国际通行准则中合法、正当、必要（《网络安全法》第四十一条）的原则。采用公开规则、获得同意（第四十一条）的透明规则。

《网络安全法》限制超范围收集、违法和违约收集行为，对于已收集的信息不得泄露毁损、建立预防措施防止信息保密性、完整性和可用性的破坏并建立补救措施，对产生上述行为的结果做出有效的处理。在第四十三条中对违法、违约信息进行删除、有误信息进行改正的主体责任做出约定。

2017 年 5 月 2 日国家互联网信息办公室正式发布《互联网新闻信息服务管理规定》（国信办 1 号令），于 2017 年 6 月 1 日同《网络安全法》一起实施。国信办 1 号令明确规范了在网络空间开展新闻信息服务的范围、条件、提供者的责任义务，积极响应国家网信部门对于开展服务进行监督检查的要求以及相关法律责任。该规定属于《网络安全法》下对网络信息安全中互联网新闻安全的部门规章制度。

同日国家互联网信息办公室一并发布《互联网信息内容管理行政执法程序规定》（国信办 2 号令），于 2017 年 6 月 1 日同《网络安全法》一起实施。国信办 2 号令明确规范了互联网信息内容管理部门行政执法依据、管辖范围、立案流程、调查取证过程、听证及约谈机制、处罚决定及执行办法。该规定正式授权网信部门对互联网信息内容进行管理的行政执法权力。

（5）网络安全等级保护制度

《网络安全法》第二十一条明确指出“国家实行网络安全等级保护制度”，即网络安

全等级保护制度是我国网络安全保护方面的基本制度。同时要求网络运营者应当按照网络安全等级保护制度的要求，履行网络安全保护义务，保障网络免受干扰、破坏或者未经授权的访问，防止网络数据泄露或者被窃取、篡改。

等级保护制度从原有的以公安部牵头的行业制度正式成为我国不涉及国家秘密信息系统的基本保护制度。

（6）网络安全审查制度

《网络安全法》第三十五条规定关键信息基础设施的运营者采购网络产品和服务，可能影响国家安全的，应当通过国家网信部门会同国务院有关部门组织的国家安全审查。2017 年 2 月 4 日由国家互联网信息办公室发布关于《网络产品和服务安全审查办法（征求意见稿）》公开征求意见的通知。其中审查的目的、需要审查的网络产品和服务的范围、网络安全审查的管理部门（网络安全审查委员会）、审查的机构（国家统一认定网络安全审查第三方机构）和对党政机关和重点行业的审查工作提出要求，于 2017 年 6 月 1 日同《网络安全法》一起实施。

2017 年 6 月 29 日，由国家互联网信息办公室等四部委联合发布的《网络关键设备和网络安全专用产品目录（第一批）》的公告中，规定除了传统的 11 类网络安全专用产品（防火墙、入侵检测系统等）外，还对 4 类网络关键设备高性能路由器、交换机、服务器和可编程逻辑控制器 PLC 要求采购使用应当按照相关国家标准的强制性要求，由具备资格的机构安全认证合格或者安全检测符合要求后，方可销售或者提供。该目录相对于过去由公安部发布的《计算机信息系统安全专用产品销售许可证目录》范围有所扩大。未来还将增加对各类网络安全服务的安全审查。

2.1.4　网络安全相关法规

1．行政法相关法规

行政违法行为是行政主体（自然人或法人）的违法行为，与民事违法和刑事违法不同，行政违法是行政主体在行政法上的违法行为。任何组织和个人只有当他们以行政法主体身份或以行政法主体名义出现时，他们的违法才能构成行政违法。即根据行政法规应履行某种行政行为或承担某种义务，如果不履行或不承担而产生的法律后果。

行政违法责任是指因为违反行政法或因行政法规定而应承担的法律责任，行政法律规范要求国家行政机关及其公务人员在行政活动中需要履行和承担的义务。例如，网信部门、公安部门等公务人员未尽职履行网络安全监管，网络运营商未承担应尽的网络安全义务所产生的责任。

（1）行政处罚的类型

- 警告。
- 罚款。
- 没收违法所得、没收非法财物。

- 责令停产停业。
- 暂扣或者吊销许可证、暂扣或者吊销执照。
- 行政拘留。
- 法律、行政法规规定的其他行政处罚。

行政违法一般较为轻微，不同于刑事违法，不可以采取有期徒刑、无期徒刑乃至死刑的处罚。刑事违法行为由《刑法》及其修正案规定。

（2）违反网络安全管理相关规定的行政处罚

情节较轻的：责令改正、警告等。

情节严重的：罚款、责令暂停相关业务、停业整顿、关闭网站、吊销相关业务许可证或者吊销营业执照等。

较严重的：没收违法所得、拘留等。

对于网络安全主管人员还面临记入信用档案并公示等处罚。

（3）常见行政处罚

① 对网络运营者

不履行网络安全保护义务的，由有关主管部门责令改正，给予警告；拒不改正或者导致危害网络安全等后果的，处一万元以上十万元以下罚款，对直接负责的主管人员处五千元以上五万元以下罚款。侵害个人信息依法得到保护的权利的，情节严重的，并可以责令暂停相关业务、停业整顿、关闭网站、吊销相关业务许可证或者吊销营业执照。

② 对关键信息基础设施的运营者

不履行网络安全保护义务的，由有关主管部门责令改正，给予警告；拒不改正或者导致危害网络安全等后果的，处十万元以上一百万元以下罚款，对直接负责的主管人员处一万元以上十万元以下罚款。

网络安全服务机构或个人违反规定，开展网络安全认证、检测、风险评估等活动，或者向社会发布系统漏洞、计算机病毒、网络攻击、网络侵入等网络安全信息的，由有关主管部门责令改正，给予警告；拒不改正或者情节严重的，处一万元以上十万元以下罚款，并可以由有关主管部门责令暂停相关业务、停业整顿、关闭网站、吊销相关业务许可证或者吊销营业执照，对直接负责的主管人员和其他直接责任人员处五千元以上五万元以下罚款。

③ 针对黑色产业链

从事危害网络安全的活动，或者提供专门用于从事危害网络安全活动的程序、工具，或者为他人从事危害网络安全的活动提供技术支持、广告推广、支付结算等帮助，尚不构成犯罪的，由公安机关没收违法所得，处五日以下拘留，可以并处五万元以上五十万元以下罚款；情节较重的，处五日以上十五日以下拘留，可以并处十万元以上一百万元以下罚款。单位有前款行为的，由公安机关没收违法所得，处十万元以上一百万元以下罚款，并对直接负责的主管人员和其他直接责任人员依照前款规定处罚。受到治安管理处罚的人员，五年内不得从事网络安全管理和网络运营关键岗位的工作；受到刑事处罚的人员，终身不

得从事网络安全管理和网络运营关键岗位的工作。

④ 对网信部门和有关部门

违反规定，将在履行网络安全保护职责中获取的信息用于其他用途的，对直接负责的主管人员和其他直接责任人员依法给予处分。网信部门和有关部门的工作人员玩忽职守、滥用职权、徇私舞弊，尚不构成犯罪的，依法给予处分。

⑤ 对境外的机构、组织、个人

从事攻击、侵入、干扰、破坏等危害中华人民共和国的关键信息基础设施的活动，造成严重后果的，依法追究法律责任；国务院公安部门和有关部门并可以决定对该机构、组织、个人采取冻结财产或者其他必要的制裁措施。

2．民法相关法规

（1）民事责任及其构成

民事侵权行为是行为人由于过错侵害人身、财产和其他合法权益，依法应承担民事责任的不法行为，以及依照法律特殊规定应当承担民事责任的其他侵害行为。侵权行为构成要件，主要集中在以下几个因素，即过错、行为不法、损害事实是否是侵权行为必要构成要件。

2017 年 3 月 15 日第十二届全国人民代表大会第五次会议表决通过了《中华人民共和国民法总则》（以下简称《民法总则》），国家主席习近平签署第 66 号主席令予以公布，《民法总则》于 2017 年 10 月 1 日起施行。《民法总则》是民法典的开篇之作，在民法典中起统领性作用。下一步将编纂民法典各分编，于 2018 年整体提请全国人民代表大会常务委员会审议，经全国人民代表大会常务委员会分阶段审议后，争取于 2020 年将民法典各分编一并提请全国人民代表大会会议审议通过，从而形成统一的民法典。其中将对网络安全相关的民事责任进行规定。

（2）常见民事责任风险

《网络安全法》第七十四条规定：“违反本法规定，给他人造成损害的，依法承担民事责任”。

一般民事违法行为以民事赔偿为主。责任主体一般涉及网络运营者、网络服务提供者，及对公民个人造成损害的。

根据 2017 年 3 月发布的《民法总则》，民事违法责任主要包括以下方面。

① 停止侵害。

② 排除妨碍。

③ 消除危险。

④ 返还财产。

⑤ 恢复原状。

⑥ 修理、重作、更换。

⑦ 继续履行。

⑧ 赔偿损失。

⑨ 支付违约金。

⑩ 消除影响、恢复名誉。

⑪ 赔礼道歉。

共计 11 项，其中涉及网络安全相关的民事责任主要包括①停止侵害、④返还财产、⑧赔偿损失、⑩消除影响、恢复名誉和⑪赔礼道歉等 5 项。

3．刑法相关法规

（1）刑事责任及其构成

刑事责任是依据国家刑事法律规定，对犯罪分子依照刑事法律的规定追究的法律责任。刑事责任与行政责任不同之处在于，一是追究的违法行为不同：追究行政责任的是一般违法行为，追究刑事责任的是犯罪行为；二是追究责任的机关不同：追究行政责任由国家特定的行政机关依照有关法律的规定决定，追究刑事责任只能由司法机关依照《刑法》的规定决定；三是承担法律责任的后果不同：追究刑事责任是最严厉的制裁，可以判处死刑，比追究行政责任严厉得多。刑事责任包括两类问题：一是犯罪；二是刑罚。

刑事责任比行政责任严重得多，根据《中华人民共和国立法法》要求在其他网络安全相关法律法规中不能规定涉及刑事责任的行为，《网络安全法》也不行。必须由《刑法》及其修正案规定。当前在《刑法》修正案中一般对网络安全犯罪采用有期徒刑和拘役等刑事处罚。

（2）常见网络安全犯罪

- 出售或者提供公民个人信息罪（《刑法》第二百五十三条）。
- 非法侵入计算机信息系统罪（《刑法》第二百八十五条）。
- 非法获取计算机信息系统数据罪（《刑法》第二百八十五条）。
- 非法控制计算机信息系统罪（《刑法》第二百八十五条）。
- 提供非法侵入或者控制计算机信息系统专用程序、工具罪（《刑法》第二百八十五条）。
- 破坏计算机信息系统罪（《刑法》第二百八十六条）。
- 网络服务渎职罪（《刑法》第二百八十六条）。
- 扰乱无线电通讯管理秩序罪（《刑法》第二百八十八条）。

以上犯罪情节严重的一般判处有期徒刑三年以下，情节特别严重的判处有期徒刑七年以下。

4．其他网络安全相关法规及条款

（1）国家安全法

2014 年 4 月 15 日中央国家安全委员会第一次会议召开，习近平同志首次提出“总体国家安全观”的概念，强调要走出一条中国特色国家安全道路要构建集政治安全、国土安全、军事安全、经济安全、文化安全、社会安全、科技安全、网络安全、生态安全、资源安全、核安全等于一体的国家安全体系。

《中华人民共和国国家安全法》（以下简称《国家安全法》）第二十五条规定国家建设网络与信息安全保障体系，提升网络与信息安全保护能力，加强网络和信息技术的创新研究和开发应用，实现网络和信息核心技术、关键基础设施和重要领域信息系统及数据的安全可控；加强网络管理，防范、制止和依法惩治网络攻击、网络入侵、网络窃密、散布违法有害信息等网络违法犯罪行为，维护国家网络空间主权、安全和发展利益。

《国家安全法》第五十九条规定国家建立国家安全审查和监管的制度和机制，对影响或者可能影响国家安全的外商投资、特定物项和关键技术、网络信息技术产品和服务、涉及国家安全事项的建设项目，以及其他重大事项和活动，进行国家安全审查，有效预防和化解国家安全风险。

（2）秘密法

《中华人民共和国保守国家秘密法》（以下简称《秘密法》）由中华人民共和国第十一届全国人民代表大会常务委员会第十四次会议于2010年4月29日修订通过，自2010年10月1日起施行。共计6章，53条。

《秘密法》第十条规定国家秘密的密级分为绝密、机密、秘密三级。

《秘密法》第十七条规定机关、单位对承载国家秘密的纸介质、光介质、电磁介质等载体（以下简称国家秘密载体）以及属于国家秘密的设备、产品，应当做出国家秘密标志。不属于国家秘密的，不应当做出国家秘密标志。

《秘密法》第二十三条规定存储、处理国家秘密的计算机信息系统（以下简称涉密信息系统）按照涉密程度实行分级保护。涉密信息系统应当按照国家保密标准配备保密设施、设备。保密设施、设备应当与涉密信息系统同步规划，同步建设，同步运行（三同步）。涉密信息系统应当按照规定，经检查合格后，方可投入使用。

《秘密法》第二十四条规定机关、单位应当加强对涉密信息系统的管理，任何组织和个人不得将涉密计算机、涉密存储设备接入互联网及其他公共信息网络。

《秘密法》第二十八条规定互联网及其他公共信息网络运营商、服务商应当配合公安机关、国家安全机关、检察机关对泄密案件进行调查；发现利用互联网及其他公共信息网络发布的信息涉及泄露国家秘密的，应当立即停止传输，保存有关记录，向公安机关、国家安全机关或者保密行政管理部门报告；应当根据公安机关、国家安全机关或者保密行政管理部门的要求，删除涉及泄露国家秘密的信息。

《秘密法》第三十四条规定从事国家秘密载体制作、复制、维修、销毁，涉密信息系统集成，或者武器装备科研生产等涉及国家秘密业务的企业事业单位，应当经过保密审查，具体办法由国务院规定。

（3）电子签名法

《中华人民共和国电子签名法》由中华人民共和国第十届全国人民代表大会常务委员会第十一次会议于2004年8月28日通过，自2005年4月1日起施行。共计五章，三十六条。主要内容是对电子签名的法律效力、适用范围和作为证据的真实性提出要求。其中电子签名需要第三方认证的，由依法设立的电子认证服务提供者提供认证服务；从事电子认

证服务，应当向国务院信息产业主管部门提出申请。当前为工业和信息化部。

（4）反恐怖主义法

《中华人民共和国反恐怖主义法》（以下简称《反恐法》）由中华人民共和国第十二届全国人民代表大会常务委员会第十八次会议于2015年12月27日通过，自2016年1月1日起施行。共计十章，九十七条。其中与网络信息安全相关的主要内容包括以下方面。

《反恐法》第十八条规定电信业务经营者、互联网服务提供者应当为公安机关、国家安全机关依法进行防范、调查恐怖活动提供技术接口和解密等技术支持和协助。第十九条规定电信业务经营者、互联网服务提供者应当依照法律、行政法规规定，落实网络安全、信息内容监督制度和安全技术防范措施，防止含有恐怖主义、极端主义内容的信息传播；发现含有恐怖主义、极端主义内容的信息的，应当立即停止传输，保存相关记录，删除相关信息，并向公安机关或者有关部门报告。

对互联网上跨境传输的含有恐怖主义、极端主义内容的信息，电信主管部门应当采取技术措施，阻断传播。

《反恐法》第六十一条规定恐怖事件发生后，负责应对处置的反恐怖主义工作领导机构可以决定由有关部门和单位采取下列一项或者多项应对处置措施：（四）在特定区域内实施互联网、无线电、通讯管制。

（5）密码法（草案）

2017年4月13日国家密码管理局发布《中华人民共和国密码法（草案征求意见稿）》公开征求意见。草案共计七章，四十三条。重点把握以下五项原则。

第一，坚持党管密码根本原则，全面贯彻中央精神。

第二，坚持依法管理，全面推进密码法治建设。

第三，坚持总体国家安全观，切实维护国家网络与信息安全。

第四，坚持构建良好环境，促进密码事业科学发展。

第五，坚持问题导向，着力解决密码工作面临的突出问题。

主要内容包括以下方面。

① 本法的立法宗旨和密码的定义：为了规范密码应用和管理，保障网络与信息安全，保护公民、法人和其他组织的合法权益，维护国家安全和利益，制定本法。本法所称密码，是指使用特定变换对数据等信息进行加密保护或者安全认证的物项和技术。

② 密码工作的基本原则和领导管理体制：坚持党对密码工作的领导，是密码工作必须毫不动摇坚持的基本原则。

③ 密码分类管理：国家将密码分为核心密码、普通密码、商用密码，实行分类管理并提出了密码分类保护要求：核心密码、普通密码可以用于保护国家秘密信息，商用密码用于保护不属于国家秘密的信息。

④ 密码应用：一是强调国家积极规范和促进密码应用；二是规定了商用密码产品、服务管理制度；三是规定了关键信息基础设施密码使用要求；四是规定了电子政务电子认证服务管理制度。

⑤ 密码安全：一是强调国家加强密码安全制度建设（第十五条）；二是规定了密码进出口管制制度（第十六条）；三是规定了密码检测认证管理制度（第十七条）；四是规定了密码应用安全性评估制度和密码安全审查制度（第十八条）；五是确立了密码安全协同联动机制（第十九条）；六是规定了电信业务经营者、互联网服务提供者的解密技术支持义务（第二十条）；七是规定了任何组织或者个人不得非法攻击他人的加密信息或者密码保障系统，不得利用密码从事违法犯罪活动（第二十一条）。

⑥ 密码发展促进：一是从支持科学技术研究、推动产业发展、鼓励学术研究和交流、依法保护知识产权等方面明确了促进密码科学技术进步和创新的有关制度措施（第二十二条）；二是规定了密码标准化制度（第二十三条）；三是规定了密码科学技术奖励制度（第二十四条）；四是从人才队伍、宣传教育等方面明确了密码发展促进的保障措施（第二十五条、第二十六条）。

⑦ 监督管理：一是明确了密码管理部门承担密码应用和密码安全监督检查和执法，以及密码失泄密案件调查职责（第二十七条）；二是规定了密码监督执法协作机制（第二十八条）；三是规定了密码监督管理权（第二十九条）；四是规定了密码鉴定制度（第三十条）。

2.2　知识子域：国家网络安全政策

2.2.1　国家网络空间安全战略

1．机遇和挑战

伴随信息革命的飞速发展，互联网、通信网、计算机系统、自动化控制系统、数字设备及其承载的应用、服务和数据等组成的网络空间，正在全面改变人们的生产生活方式，深刻影响人类社会历史发展进程。《国家网络空间安全战略》总结了网络空间带来的改变，分别是“信息传播的新渠道、生产生活的新空间、经济发展的新引擎、文化繁荣的新载体。社会治理的新平台、交流合作的新纽带、国家主权的新疆域”，这些改变就是机遇。

同时，也总结了网络空间面临的“网络渗透危害政治安全”“网络攻击威胁经济安全”“网络有害信息侵蚀文化安全”“网络恐怖和违法犯罪破坏社会安全”“网络空间的国际竞争方兴未艾”“网络空间机遇和挑战并存”这六大挑战。

2．目标

《国家网络空间安全战略》提出了在总体国家安全观指导下，贯彻落实创新、协调、绿色、开放、共享的发展理念，增强风险意识和危机意识，统筹国内国际两个大局，统筹发展安全两件大事，积极防御、有效应对，推进网络空间和平、安全、开放、合作、有序，维护国家主权、安全、发展利益，实现建设网络强国的战略目标。

- 和平：信息技术滥用得到有效遏制，网络空间军备竞赛等威胁国际和平的活动得到有效控制，网络空间冲突得到有效防范。

- 安全：网络安全风险得到有效控制，国家网络安全保障体系健全完善，核心技术装备安全可控，网络和信息系统运行稳定可靠。网络安全人才满足需求，全社会的网络安全意识、基本防护技能和利用网络的信心大幅提升。
- 开放：信息技术标准、政策和市场开放、透明，产品流通和信息传播更加顺畅，数字鸿沟日益弥合。不分大小、强弱、贫富，世界各国特别是发展中国家都能分享发展机遇、共享发展成果、公平参与网络空间治理。
- 合作：世界各国在技术交流、打击网络恐怖和网络犯罪等领域的合作更加密切，多边、民主、透明的国际互联网治理体系健全完善，以合作共赢为核心的网络空间命运共同体逐步形成。
- 有序：公众在网络空间的知情权、参与权、表达权、监督权等合法权益得到充分保障，网络空间个人隐私获得有效保护，人权受到充分尊重。网络空间的国内和国际法律体系、标准规范逐步建立，网络空间实现依法有效治理，网络环境诚信、文明、健康，信息自由流动与维护国家安全、公共利益实现有机统一。

3．原则

《国家网络空间安全战略》也给出构建网络空间和平与安全的四项基本原则，分别是“尊重维护网络空间主权、和平利用网络空间、依法治理网络空间、统筹网络安全与发展”。

4．任务

为了保障网络空间“五大战略目标”的实现，《国家网络空间安全战略》提出了基于和平利用与共同治理网络空间的“九大任务”。

- 坚定捍卫网络空间主权。
- 坚决维护国家安全。
- 保护关键信息基础设施。
- 加强网络文化建设。
- 打击网络恐怖和违法犯罪。
- 完善网络治理体系。
- 夯实网络安全基础。
- 提升网络空间防护能力。
- 强化网络空间国际合作。

2.2.2 网络安全等级保护相关政策

1．计算机系统安全保护等级划分思想提出（1994—1999）

1994 年国务院颁布的《计算机信息系统安全保护条例》规定：计算机信息系统实行安全等级保护，安全等级的划分标准和安全等级保护的具体办法，由公安部会同有关部门制定。

1999 年国家强制标准 GB 17859—1999《计算机信息系统安全保护等级划分准则》发布，

正式细化了对计算机系统采用划分等级进行保护的要求。

当时安全保护对象主要以计算机信息系统安全为主，划分了 5 个级别，从低到高分别为用户自主保护、系统审计保护、安全标记保护、结构化保护、访问验证保护。

2．等级保护工作试点（2002—2006）

2002 年 7 月 18 日，公安部在 GB 17859 的基础上，又发布实施了 5 个公安行业等级保护标准，分别是 GA/T 387—2002《计算机信息系统安全等级保护网络技术要求》、GA 388—2002《计算机信息系统安全等级保护操作系统技术要求》、GA/T 389—2002《计算机信息系统安全等级保护数据库管理系统技术要求》、GA/T 390—2002《计算机信息系统安全等级保护通用技术要求》、GA 391—2002《计算机信息系统安全等级保护管理要求》，形成了我国计算机信息系统安全等级保护系列标准的最初一部分。

在原国家计委《计算机信息系统安全保护等级评估认证体系》及《互联网络电子身份认证管理与安全保护平台试点》项目的支持下，公安部牵头从 2003 年 1 月开始在全国范围内开展了等级保护试点工作，逐步摸索计算机信息系统安全等级保护的法律体系、技术体系和评估、执法保障体系，并开展了一些关键技术和基础性研究工作。

3．等级保护相关政策文件颁布（2004—2009）

2004 年，公安部、保密局、密码委、信息办联合发文《关于信息安全等级保护工作的实施意见的通知》（公通字〔2004〕66 号），初步规定了信息安全等级保护工作的指导思想、原则、要求。该通知将信息和信息系统的安全保护等级划分为五级，即第一级：自主保护级；第二级：指导保护级；第三级：监督保护级；第四级：强制保护级；第五级：专控保护级。需要特别指出的是，66 号文中的分级主要是从信息和信息系统的业务重要性及遭受破坏后的影响出发的，是系统从应用需求出发必须纳入的安全业务等级，而不是 GB 17859 中定义的系统已具备的安全技术等级。

2007 年，公安部、保密局、密码委、信息办联合发文《信息安全等级保护管理办法》，更加系统地规定了信息安全等级保护制度，也正式规定了我国对于所有非涉密信息系统采用等级保护标准的要求。涉及国家秘密的信息系统也以不低于等级保护三级的标准进行设计和建设。

4．等级保护相关标准发布（2008—2014）

以 GB/T 22239—2008《信息安全技术 信息系统安全等级保护基本要求》和 GB/T 22240—2008《信息安全技术 信息系统安全等级保护定级指南》发布为标准，等级保护制度正式进入了标准体系建设的阶段。截至 2014 年已经发布了 80 余份相关的等级保护国家标准，还有更多的行业标准也在制定之中。

5．《网络安全法》明确我国实行网络安全等级保护制度（2016）

2016 年 11 月发布的《网络安全法》第二十一条明确指出“国家实行网络安全等级保护制度”。正式宣告在网络空间安全领域，我国将等级保护制度作为基本国策。同时也正

式将针对信息系统的等级保护标准变更为针对网络安全的等级保护标准。

2017 年 8 月，公安部评估中心根据网信办和安标委的意见将等级保护在编的 5 个基本要求分册标准进行了合并形成《网络安全等级保护基本要求》一个标准。

2.3 知识子域：网络安全道德准则

2.3.1 道德约束

1. 道德的概念

道德（Ethic）通常意义上是指一定社会或阶级用以调整人们之间利益关系的行为准则，也是评价人们行为善恶的标准。

希腊哲学家苏格拉底（公元前 469—399 年）提出，如果一个人想获得自我认识，就必须意识到与他的存在相关的每一个事实及其背景。他假设如果人们知道什么是正确的，自然会做出好的事情，邪恶行为是无知的结果。如果犯罪者真正意识到行为的后果，就不会承诺甚至不考虑去实施这些邪恶的行为。因此，道德本身会受到知识的影响，道德的遵循与自身的教育是密切相关的。

亚里士多德（公元前 384—323 年）提出了一个可称为“良性”的道德体系。在亚里士多德看来，当一个人按照美德行事时，这个人就会行善并且感到满足。基于此理论国际出现了“道德黑客”一词，要求做一个具有社会责任、行善、依据美德利用自己技术的黑客。

对于道德而言，在不同的时代、不同的地域有不同的观点，因此道德通常很难直接以“是或否”来判定。同样的行为在特定时间、特定区域可能是违反道德的，但是在另外时间或地点可能就是合理的行为。

2. 道德和法律

道德和法律之间往往是一线之隔，二者之间的差异通常表现在以下方面。

（1）尽管道德也可以按需分类，但不具有法律那样的严谨的结构体系，而法律是国家意志的统一体现，有严密的逻辑体系，有不同的等级和效力。

（2）道德的内容则主要存在于人们的道德意识中，表现于人们的言行上，不道德行为的后果，是自我谴责和舆论压力，是一种“软约束”。法律都是以文字形式表现出来，违法犯罪的后果有明确规定，是一种“硬约束”。通常意义而言，违反道德的行为不一定违法，但是违法行为往往会触犯道德的底线。

（3）道德是法律的基础，法律是道德的延伸；道德规范约束范围广，法律约束范围要小；道德规范具有人类共同的特性，法律具有国家地区特性；科学的法律和道德规范应保持一致。

3. 道德约束

信息安全（或者网络安全）领域的特殊性使得无论是国家、企业还是个人都考虑“道

德”问题。常见的与道德有关的网络行为包括：随意下载、使用、传播他人软件或资料的侵犯知识产权行为；传播淫秽等不良信息；滥发广告、垃圾邮件、虚假信息与新闻等；利用计算机技术非授权读取或者复制用户信息等。

近年来，我国陆续建立了一系列的网络安全相关法律法规。例如，在《中华人民共和国刑法修正案（九）》第二百五十三条之一中，明确了对公民信息泄露的刑事处罚原则“违反国家有关规定，向他人出售或者提供公民个人信息，情节严重的，处三年以下有期徒刑或者拘役，并处或者单处罚金；情节特别严重的，处三年以上七年以下有期徒刑，并处罚金。”

其次，具有惩戒性条款的管理制度是组织内部建立职业道德约束的有效手段之一。组织通过成熟的管理对违反职业道德准则的行为进行约束和限制，使员工能够规范自己的工作行为，降低违反道德的行动概率。当然，组织的管理制度可以通过有效的法律支撑来弥补行政处罚力度不足的缺陷，例如通过《中华人民共和国劳动合同法》中有关劳动合同中增加保密条款或者通过保密协议对员工、第三方人员及其他合作伙伴对获取组织及用户信息的保护责任和保护义务。

第三，教育与培训是一种不可或缺的增强员工道德意识的途径。“无知者无畏”，只有让每一个公民充分理解道德约束对社会和个人的价值和意义，才能使道德约束从被动到主动的演变。

2.3.2　职业道德准则

1．计算机职业道德准则

专业人员在为公众提供服务时如何使用自己掌握的知识被视为道德问题，也被称为职业道德。职业道德是涵盖了个人和企业行为的准则。职业道德最早的例子之一就是医生今天仍然坚持的希波克拉底誓言。

网络安全知识是把双刃剑，既可以维护信息系统的业务连续性，又可能会破坏计算机信息系统。从事网络安全工作的人员更需要遵守一种职业道德准则来规范如何使用已掌握的技术影响当前社会，并承担职业所赋予的责任和义务。这不仅是为了服务对象的利益，也是为了那些属于这个职业的人的利益。计算机道德的概念起源于 20 世纪 40 年代，麻省理工学院教授、美国数学家兼哲学家诺伯特·维纳（Norbert Wiener）在 1948 年的《控制论》一书中讨论了计算机这个新领域及其相关的道德问题，并在 1950 年出版的第二本书《The Human Use of Human Beings》深入探讨了围绕信息技术的道德问题，并奠定了计算机道德的基础。

各种国内、国际专业团体和组织制作了道德规范文件，为计算机专业人员和用户提供基本的行为准则。

（1）美国计算机学会（ACM）职业伦理守则

ACM 是世界上最早制定职业行为伦理守则的协会之一。1992 年，ACM 就公布了职业伦理守则《美国计算机协会职业行为伦理守则》，其后经过多次修订。伦理守则共分 4 个

部分，24 条内容构成。

（2）英国计算机学会（BCS）伦理守则

BCS 伦理守则共分 4 部分，17 项条款。第一部分关注社会公众利益，提出相关规定；第二部分说明对相关权利机构责任；第三部分是职业责任；第四部分是职业能力和责任。

（3）澳大利亚计算机学会伦理守则

共有 10 部分，46 条要求，分别是维护职业声誉与尊严、成员的职业行为、价值和理想、行为标准、优先权、能力、诚实、社会相关的责任、职业发展和信息技术职业。澳大利亚计算机学会伦理守则是一个十分详细的职业伦理守则，涵盖了职业道德规范的方方面面。

（4）计算机伦理十诫（摩西十诫）

① 你不应当用计算机去伤害他人。

② 你不应当干扰他人的计算机工作。

③ 你不应当偷窥他人的文件。

④ 你不应当用计算机进行偷盗。

⑤ 你不应当用计算机做伪证。

⑥ 你不应当使用或复制没有付过钱的软件。

⑦ 你不应当未经许可而使用他人的计算机资源。

⑧ 你不应当盗用别人的智力成果。

⑨ 你应当考虑你所编制的程序的社会后果。

⑩ 你应当用深思熟虑和审慎的态度来使用计算机。

2．CISP 职业道德准则

作为国家注册信息安全专业人员应该遵循其应有的道德准则，中国信息安全测评中心为 CISP 持证人员设定了职业道德准则。

（1）维护国家、社会和公众的信息安全

自觉维护国家信息安全，拒绝并抵制泄露国家秘密和破坏国家信息基础设施的行为。

自觉维护网络社会安全，拒绝并抵制通过计算机网络系统谋取非法利益和破坏社会和谐的行为。

自觉维护公众信息安全，拒绝并抵制通过计算机网络系统侵犯公众合法权益和泄露个人隐私的行为。

（2）诚实守信，遵纪守法

不通过计算机网络系统进行造谣、欺诈、诽谤、弄虚作假等违反诚信原则的行为。

不利用个人的信息安全技术能力实施或组织各种违法犯罪行为。

不在公众网络传播反动、暴力、黄色、低俗信息及非法软件。

（3）努力工作，尽职尽责

热爱信息安全工作岗位，充分认识信息安全专业工作的责任和使命。

为发现和消除本单位或雇主的信息系统安全风险做出应有的努力和贡献。

帮助和指导信息安全同行提升信息安全保障知识和能力，为有需要的人谨慎负责地提

出应对信息安全问题的建议和帮助。

（4）发展自身，维护荣誉

通过持续学习保持并提升自身的信息安全知识。

利用日常工作、学术交流等各种方式保持和提升信息安全实践能力。

以 CISP 身份为荣，积极参与各种证后活动，避免任何损害 CISP 声誉形象的行为。

2.4　知识子域：信息安全标准

2.4.1　信息安全标准基础

1．标准和标准化

（1）标准

标准是为了在一定范围内获得最佳秩序，经协商一致制定并由公认机构批准，共同使用的和重复使用的一种规范性文件。

国际标准是由国际标准化组织或国际标准组织通过并公开发布的标准。

国家标准是由国家标准机构通过并公开发布的标准。《中华人民共和国标准化法》（以下简称《标准化法》）（中华人民共和国主席令 1988 年第 11 号）的规定，对需要在全国范围内统一的技术要求，应当制定国家标准。国家标准由国务院标准化行政主管部门制定。

行业标准是针对没有国家标准而又需要在全国某个行业范围内统一的技术要求而制定的标准。根据《标准化法》的规定，由我国各主管部、委（局）批准发布，在该部门范围内统一使用的标准，称为行业标准。行业标准由国务院有关行政主管部门制定，并报国务院标准化行政主管部门备案，在公布国家标准之后，该项行业标准即行废止。

地方标准是针对没有国家标准和行业标准而又需要在省、自治区、直辖市范围内统一的工业产品的安全、卫生要求而制定的标准。地方标准由省、自治区、直辖市标准化行政主管部门制定，并报国务院标准化行政主管部门和国务院有关行政主管部门备案，在公布国家标准或者行业标准之后，该地方标准即应废止。

（2）标准化

标准化即为了在一定范围内获得最佳秩序，对现实问题或潜在问题制定共同使用和重复使用的条款的活动。标准化工作的任务是制定标准、组织实施标准和对标准的实施进行监督。标准化的主要作用在于为了其预期目的改进产品、过程或服务的适用性，防止贸易壁垒，并促进技术合作。

标准化具有的基本特点如下。

- 标准化是一项活动，是制定、发布和实施标准的系统过程，标准是标准化活动过程的核心要素。标准化对象不是孤立的一件事、一个事物，而是共同的、可重复的事物。

- 标准化的对象可以概括为“物”“事”“人”三方面，由于这些“物”“事”“人”的多次重复活动，产生了统一标准的客观需要和要求，从而分别形成了技术标准、管理标准和工作标准。
- 标准化是一个动态的概念，是随着科技的进步和社会的发展而不断变化发展的。标准没有最终成果，标准在深度上的持续深化和广度上的不断扩张正体现了标准化的动态特征。
- 标准化是一个相对的概念，表现在随着事物的发展，标准化与非标准化、共性和个性的相互不断转化的发展规律上。任何已经标准化的事物和概念，都可能随着社会的发展，环境的变化，突破已有的共同规定，成为非标准化。因此，这种事物和概念的标准化——非标准化——再标准化，共性——个性——共性的交替进化，符合否定之否定的辩证法，它推动标准化永无止境地发展。
- 标准化的经济和社会效益只有当标准在实践中得到应用以后才能体现出来，因此在标准化活动中，标准的应用是最重要、最具实践性的一个环节，没有标准的应用，标准化工作就失去根本意义。

标准化工作应该遵循以下原则。

- 简化：在一定范围内缩减对象的类型数目，使之在既定时间内足以满足一般需要的标准化形式。对象的多样性发展规模超出必要的范围时，消除多余的、可替换的、低功能的环节，保持其构成的精炼、合理，使总体功能最佳。
- 统一：把同类事物两种以上的表现形态归并为一种或限定在一个范围内的标准化形式。统一化的目的是消除由于不必要的多样化而造成的混乱，为人类的正常活动建立共同遵循的秩序。
- 协调：任何事物处于广泛联系之中，存在着相关性，其在系统中作为一个功能单元，既受约束，又影响整个功能的发挥，必须与其他功能单元进行协调，在连接点上找到一致性，使整体功能最佳。
- 优化：按照特定的目标，在一定的限制条件下，对标准系统的构成因素及其关系进行选择、设计或调整，使之达到最理想的效果。

2. 标准化组织

标准化组织一般分为国际化标准组织（如 ISO、IETF 等）、国家标准组织（如中国国家标准化管理委员会、美国国家标准化组织（ANSI）、英国标准协会（BSI）等）等类型。国际标准化组织（ISO）是指其成员资格向每个国家的有关国家机构开放的标准化组织。与之相对应的，国家标准机构是在国家层面上承认的，有资格成为相应的国际和区域标准组织的国家成员的标准机构。我国的国家标准机构是中国国家标准化管理委员会。

（1）国际信息安全标准化组织

国际上，信息安全标准化工作兴起于 20 世纪 70 年代中期，80 年代有了较快的发展，90 年代引起了世界各国的普遍关注。目前，世界上约有近 300 个国际和区域性组织负责制

定标准或技术规则，其中与信息安全标准化有关的主要组织有国际标准化组织（ISO）、国际电工委员会（IEC）、国际电信联盟（ITU）和 Internet 工程任务组（IETF）等。

国际标准化组织（ISO）于 1947 年 2 月 23 日正式开始工作，ISO/IEC JTC1（信息技术标准化委员会）所属 SC27（安全技术分委员会）前身是 SC20（数据加密分技术委员会），主要从事信息技术安全的一般方法和技术的标准化工作。ISO/IEC JTC1 SC27 是国际标准化组织（ISO）和国际电工委员会（IEC）的信息技术联合技术委员会（JTC1）下专门从事信息安全标准化的分技术委员（SC27），是信息安全领域中最具代表性的国际标准化组织。SC27 下设信息安全管理体系工作组（WG1）、密码与安全机制工作组（WG2）、安全评估准则工作组（WG3）、安全控制与服务工作组（WG4）和身份管理与隐私技术工作组（WG5）5 个工作组，工作范围广泛地涵盖了信息安全管理和技术领域，包括信息安全管理体系、密码学与安全机制、安全评价准则、安全控制与服务、身份管理与隐私保护技术。而 ISO/TC68 负责银行业务应用范围内有关信息安全标准的制定，它主要制定行业应用标准，在组织上和标准之间与 SC27 有着密切的联系。ISO/IEC JTC1 负责制定标准主要是开放系统互连、密钥管理、数字签名、安全的评估等方面的内容。

国际电工委员会（IEC）正式成立于 1906 年 10 月，是世界上成立最早的专门国际标准化机构。在信息安全标准化方面，除与 ISO 联合成立了 JTC1 下分委员会外，还在电信、电子系统、信息技术和电磁兼容等方面成立了技术委员会，如 TC56 可靠性、TC74 IT 设备安全和功效、TC77 电磁兼容、TC108 音频/视频、信息技术和通信技术电子设备的安全等，并制定相关国际标准，如信息技术设备安全（IEC 60950）等。

国际电信联盟（ITU）成立于 1865 年 5 月 17 日，所属的 SG17 组主要负责研究通信系统安全标准。SG17 组主要研究的有通信安全项目、安全架构和框架、计算安全、安全管理、用于安全的生物测定、安全通信服务。此外 SG16 和下一代网络核心组也在通信安全、H323 网络安全、下一代网络安全等标准方面进行了研究。目前，ITU-T 建议书中大约有 40 多个都是与通信安全有关的标准。

Internet 工程任务组（IETF）创建于 1986 年，其主要任务是负责互联网相关技术规范的研发和制定，目前 IETF 已成为全球互联网界最具权威的大型技术研究组织。IETF 标准制定的具体工作由各个工作组承担，工作组分成 8 个领域，分别是 Internet 路由、传输、应用领域等，著名的 IKE 和 IPsec 都在 RFC 系列之中，还有电子邮件、网络认证和密码标准，也包括了 TLS 标准和其他的安全协议标准。

（2）国家标准化组织

① 美国国家标准化协会（ANSI）

1918 年，美国材料试验协会（ASTM）、美国机械工程师协会（ASME）、美国矿业与冶金工程师协会（ASMME）、美国土木工程师协会（ASCE）、美国电气工程师协会（AIEE）等组织，共同成立了美国工程标准委员会（AESC）。美国政府的 3 个部（商务部、陆军部、海军部）也参与了该委员会的筹备工作。1928 年，AESC 改组为美国标准协会（ASA）。1966 年 8 月，又改组为美利坚合众国标准学会（USASI）。1969 年 10 月 6 日改成现名：

美国国家标准学会（ANSI）。

ANSI 于 20 世纪 80 年代初开始数据加密标准化工作，共制定了 3 项美国国家标准。ANSI 中技术委员会 NCITS（即 X3）负责信息技术，承担着 JTC1 秘书处的工作，其中，分技术委员会 T4 专门负责 IT 安全技术标准化工作，对口 JTC1 的 SC27。

② 美国国家标准与技术研究院（NIST）

美国国家标准与技术研究院（National Institute of Standards and Technology，NIST）直属美国商务部，从事物理、生物和工程方面的基础和应用研究，以及测量技术和测试方法方面的研究，提供标准、标准参考数据及有关服务，在国际上享有很高的声誉。

从 20 世纪 70 年代公布的数据加密标准（DES）开始，NIST 制定了一系列有关信息安全方面的联邦信息处理标准（Federal Information Processing Standards，FIPS）以及信息安全相关的专题出版物（NIST SP 800 系列和 NIST SP 500 系列）。

FIPS 由 NIST 在广泛搜集政府各部门及私人部门的意见的基础上写成。正式发布之前，将 FIPS 分送给每个政府机构，并在“联邦注册”上刊印出版。经再次征求意见之后，NIST 局长把标准连同 NIST 的建议一起呈送美国商务部，由商务部长签字同意或反对这个标准。FIPS 安全标准的一个著名实例就是数据加密标准（DES）。

③ 中国国家标准化管理委员会

中国国家标准化管理委员会（以下简称“国家标准委”）是我国最高级别的国家标准化机构，其下属全国信息安全标准化技术委员会（TC260）负责信息安全相关标准制定及管理。

2002 年 4 月，为加强信息安全标准的协调工作，国家标准委决定成立全国信息安全标准化技术委员会（以下简称“安标委”），由国家标准委直接领导，对口 ISO/IEC JTC1 SC27。国家标准化管理委员会高新函〔2004〕1 号文决定：自 2004 年 1 月起，各有关部门在申报信息安全国家标准计划项目时，必须经信息安全标委会提出工作意见，协调一致后由信息安全标委会组织申报；在国家标准制定过程中，标准工作组或主要起草单位要与安标委积极合作，并由安标委完成国家标准送审、报批工作。

全国信息安全标准化技术委员会设秘书处负责委员会的日常事务工作，秘书处是委员会的常设办事机构，负责委员会的日常事务工作；秘书处设在中国电子技术标准化研究所。安标委下设多个工作组（见图 2-2），其分工分别是：WG1-信息安全标准体系与协调工作组，研究信息安全标准体系、跟踪国际信息安全标准发展动态、研究、分析国内信息安全标准的应用需求、研究并提出新工作项目及工作建议；WG2-涉密信息系统安全保密标准工作组，研究提出涉密信息系统安全保密标准体系、制定和修订涉密信息系统安全保密标准，以保证我国涉密信息系统的安全；WG3-密码技术标准工作组，密码算法、密码模块，密钥管理标准的研究与制定；WG4-鉴别与授权标准工作组，国内外 PKI/PMI 标准的分析、研究和制定；WG5-信息安全评估标准工作组，调研国内外测评标准现状与发展趋势，研究提出测评标准项目和制订计划；WG6-通信安全标准工作组，调研通信安全标准现状与发展趋势，研究提出通信安全标准体系，制定和修订通信安全标准；WG7-信息安全管理标准工作

组，信息安全管理标准体系的研究，信息安全管理标准的制定工作；SWG-BDS-大数据安全特别工作组，负责大数据和云计算相关的安全标准化研制工作。具体职责包括调研急需标准化需求，研究提出标准研制路线图，明确年度标准研制方向，及时组织开展关键标准研制工作。秘书处负责委员会的日常事务工作。

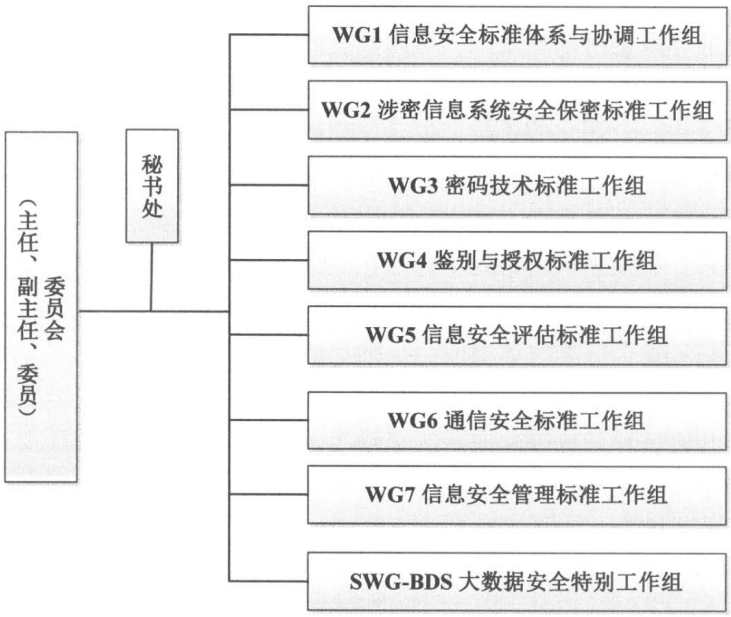

图 2-2　信息安全标准化技术委员会组织结构

3．我国标准分类

我国的国家标准分别有 GB 强制性国家标准、GB/T 推荐性国家标准和 GB/Z 国家标准化指导性技术文件。

- 强制性标准：强制性标准具有法律属性，一经颁布必须贯彻执行，违反则构成经济或法律方面的责任。强制性标准一般包括全国必须统一的基础标准、通用试验检验方法标准、对国计民生有重大影响的产品标准和工程建设标准、有关人身健康和生命安全与环境保护方面的标准等。
- 推荐性标准：推荐性标准是自愿采用的标准，但一经法律或法规引用，或各方商定同意纳入商品、经济合同之中，就成为共同遵守的技术依据，具有法律上的约束性，必须严格贯彻执行。
- 国家标准化指导性技术文件：制定国家标准化指导性技术文件是在对仍处于技术发展过程中（如变化快的高新技术领域），或者由于其他理由，将来而不是现在有可能就国家标准取得一致意见的国家标准化指导性技术文件项目。制定国家标准化指导性技术文件的理由及它与将来的国家标准的关系，应在前言中说明。

国家标准化指导性技术文件在实施后 3 年内必须进行复审。复审结果的可能是以下结果。

- 再延长 3 年。

- 转为国家标准。
- 撤销。

2.4.2 我国信息安全标准

信息安全标准体系是由信息安全领域内具有内在联系的标准组成的科学有机整体，是编制信息安全标准制订/修订计划的重要依据。信息安全标准体系是促进信息安全领域内的标准组成趋向科学化、合理化的手段，也是一幅现有、应有和预计制定的信息安全标准的蓝图，并随着科学技术的发展不断地完善和更新。

国家信息安全标准化的重要工作之一是建立国家信息安全标准体系。建立科学的国家信息安全标准体系，将众多的信息安全标准在此体系下协调一致，才能充分发挥信息安全标准系统的功能，获得良好的系统效应，取得预期的社会效益和经济效益。信息安全标准体系框架描述了信息安全标准整体组成，是整个信息安全标准化工作的指南。

本着“科学、合理、系统、适用”的原则，经过多年的研究，在借鉴和吸收国际先进的信息安全技术和方法及其标准化成果的基础上，我国初步形成了如图 2-3 所示的以信息安全基础标准和信息安全管理标准为支柱，以物理安全标准、系统与网络标准、应用与工程标准为支撑的信息安全标准体系框架。

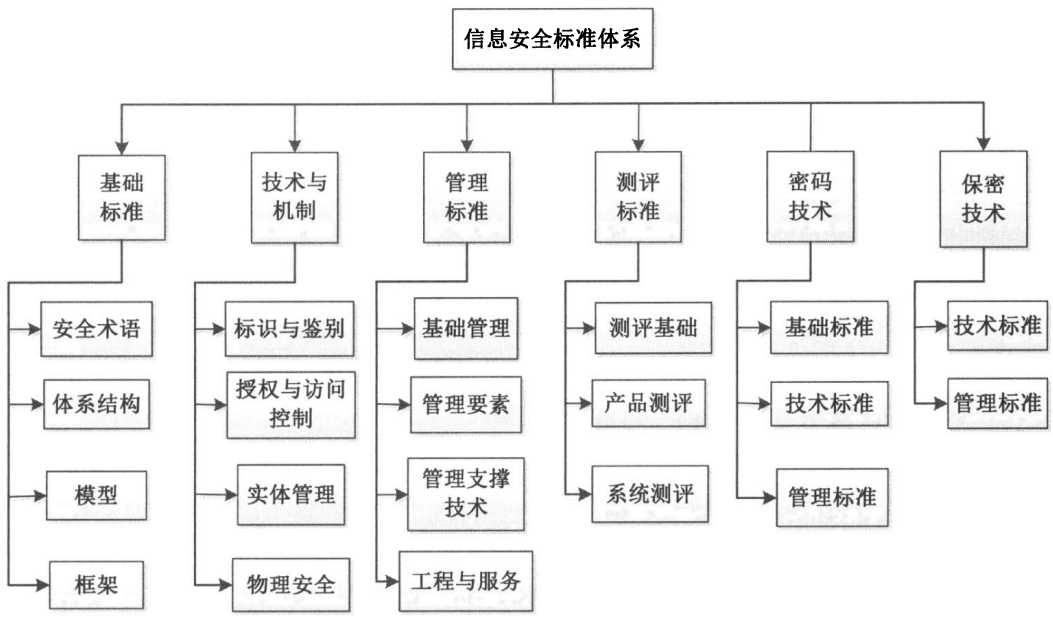

图 2-3 我国信息安全标准体系

1. 基础标准

基础标准在一定范围内可以直接应用，也可以作为其他标准的依据和基础，具有普遍的指导意义。一定范围是指特定领域，如企业、专业、国家等。也就是说，基础标准既存

在于国家标准、专业标准，也存在于企业标准中。在某领域中基础标准是覆盖面最大的标准。它是该领域中所有标准的共同基础。

常见的基础标准分为6类。

（1）安全术语类

如GB/T 5271.8—2001《信息技术 词汇 第8部分：安全》，标准给出了与信息技术安全相关概念的基本术语及其定义，并明确了这些条目之间的关系。本标准适用于信息和数据安全保护方面的有关标准及国内外交流。标准详细定义了有关密码技术、信息分类与信息访问控制、数据与信息的恢复和安全违规等数据与信息安全保护方面的术语及其定义，包括一般概念、信息分类、密码技术、访问控制、安全违规、敏感信息保护、数据恢复、复制保护。

（2）测评基础类

如GB 17859—1999《计算机信息系统安全保护等级划分准则》，标准规定了计算机信息系统安全保护能力的5个等级，标准适用于计算机信息系统安全保护技术能力等级的划分。计算机信息系统安全保护能力随着安全保护等级的增高，逐渐增强。

（3）管理基础类

如GB/T 22080—2016《信息技术 安全技术 信息安全管理体系 要求》，标准规定了在组织环境下建立、实现、维护和持续改进信息安全管理体系的要求。该标准还包括了根据组织需求所剪裁的信息安全风险评估和处置的要求。标准规定的要求是通用的，适用于各种类型、规模或性质的组织。当组织声称符合本标准时，不能排除第4章到第10章中所规定的任何要求。

（4）物理安全类

如GB/T 9361—2011《计算机场地安全要求》，标准规定了计算站场地的安全要求，适用于各类地面计算站，不建站的地面计算机机房，按该标准对计算机机房的有关要求执行，改建的计算机机房参照本标准执行，非地面计算机机房参照本标准执行。

（5）安全模型类

如GB/T 17965—2000《信息技术 开放系统互连高层安全模型》，标准定义一个体系结构模型，以此为基础开发开放系统互联（OSI）高层独立于应用的安全服务和协议。

（6）安全体系架构类

如GB/T 9387.2—1995《信息处理系统开放系统互连基本参考模型 第2部分：安全体系结构》，标准描述了安全服务、特定的普遍性的安全机制，以及安全服务与安全机制之间的关系。详细规定了安全服务和安全机制与OSI各层之间的关系；安全服务和安全机制的配置，并分别规定了物理层、数据链路层、网络层、运输层、会话层、表示层和应用层的服务和机制；安全管理，包括OSI安全管理的分类、特定的系统安全管理活动、安全机制的管理功能。

2．技术与机制

（1）密码技术

如 GB/T 15277—1994《信息处理 信息技术 安全技术 N 位块密码算法的操作方式》，标准描述了采用秘密密钥的任意一种 64bit 分组密码算法的 4 种工作方式。

（2）鉴别机制

如 GB/T 15843.1—2008《信息技术 安全技术 实体鉴别 第 1 部分：概述》，本部分规定了采用安全技术的实体鉴别机制的鉴别模型及一般要求和限制。

（3）授权机制

如 GB/T 25062—2010《信息安全技术 鉴别与授权 基于角色的访问控制模型与管理规范》，标准规定了基于角色的访问控制（RBAC）模型、RBAC 系统和管理功能规范。适用于信息系统中 RBAC 子系统的设计与实现，相关系统的测试和产品采购亦可参照使用。

（4）电子签名

如 GB 15851—1995《信息技术 安全技术 带消息恢复的数字签名方案》，标准规定了对有限长消息使用公开密钥体制的带消息恢复的数字签名方案。这种数字签名方案包含下列两个进程：一是签名进程，它使用秘密签名密钥和签名函数来对消息签名；二是验证进程，它使用公开验证密钥和验证函数来验证签名，同时恢复出消息。签名进程中，必要时，欲签名的消息须填充和扩展，然后加上与消息本身有关的人为的冗余，对消息中是否存在自然的冗余不做假定，人为的冗余将由验证进程揭示出来，把人为的冗余去掉便恢复出消息。本标准不规定密钥产生进程、签名函数和验证函数。

（5）公钥基础设施

如 GB/T 19714—2005《信息技术 安全技术 公钥基础设施 证书管理协议》，标准描述了公钥基础设施（PKI）中的证书管理协议，定义了与证书产生和管理相关的各方面所需要的协议消息，这些消息主要包括申请证书、撤销证书、密钥更新、密钥恢复、交叉认证等。本标准主要适用于在安全或不安全环境中实施 PKI 组件并实施管理，可作为 PKI 运营机构、PKI 组件开发者的参考指南。

（6）通信安全技术

GB/T 21643—2008《IP 认证头（AH）》，标准规定了 AH 协议的技术要求，包括 AH 协议头格式、AH 协议处理、一致性要求等。适用于支持 AH 协议的数据设备。

（7）涉密系统通用技术要求

如 BMB1—1994《电话机电磁泄漏发射限值和测试方法》，标准规定了电话机电磁泄漏辐射发射、传导发射的限值和测试方法。适用于党政专用电话网使用的有线电话机（不包括无绳电话机、数字电话机），适用于需要保密通信的电话机。

3．管理标准

（1）涉密服务

如 BMB8—2004《国家保密局电磁泄漏发射防护产品检测实验室认可要求》，标准规

定了“国家保密局电磁泄漏发射防护产品检测中心”及其分中心的检测实验室在组织管理、技术能力以及检测人员、检测场地、检测设备、设施配置等方面应达到的认可要求。标识适用于申请获得实验室资格认可的单位的检查和评审，供国家保密局认可实验室使用。

（2）安全控制与服务

如 GB/T 20984—2007《信息安全技术 信息安全风险评估规范》，标准提出了风险评估的基本概念、要素关系、分析原理、实施流程和评估方法，以及风险评估在信息系统生命周期不同阶段的实施要点和工作形式。本标准适用于规范组织开展的风险评估工作。

（3）网络安全管理

如 GB/T 17143.1—1997《信息技术 开放系统互连系统管理 第1部分：客体管理功能》定义客体管理功能由服务、功能单元和类属定义组成。详细规定了客体管理的模型；类属定义，包括事件类型、事件信息和事件应答；创建、删除、活动等9种服务定义；客体管理的各种功能单元；各种协议，包括规程元素、抽象语法和功能单元协商的协议；与其他功能的关系；一致性要求。

（4）行业/领域安全管理

如 GB/Z 24294—2009《信息安全技术 基于互联网电子政务信息安全实施指南》文件确立了基于互联网电子政务信息安全保障总体架构，为基于互联网电子政务所涉及的信息安全技术、信息安全管理、信息安全工程建设等方面安全要求的实施提供指导。文件主要对统一的安全政务网络平台、安全政务办公平台、可信公共服务平台和安全支撑平台的建设提出规范与要求。对于相关政务部门专有的业务系统，其安全防护根据明确责任、各负其责的原则，由主管部门采取适当的安全措施，本指导性技术文件适用于地市级（含以下）政府单位，基于互联网开展不涉及国家秘密的电子政务信息安全建设，为管理人员、工程技术人员、信息安全产品提供者进行信息安全建设提供管理和技术参考。

4．测评标准

（1）密码产品

如 GB/T 25056—2010《信息安全技术 证书认证系统密码及其相关安全技术规范》，标准规定了为公众服务的数字证书认证系统的设计、建设、检测、运行及管理规范。标准为实现数字证书认证系统的互联互通和交叉认证提供统一的依据，指导第三方证书认证机构的数字证书认证系统的建设和检测评估，规范数字证书认证系统中密码及相关安全技术的应用。适用于第三方证书认证机构的数字证书认证系统的设计、建设、检测、运行及管理。非第三方证书认证机构的数字证书认证系统的设计、建设、检测、运行及管理，可参照本标准。

（2）通用产品

如 GB/T 17900—1999《网络代理服务器的安全技术要求》，标准规定了网络代理服务器的安全技术要求，并作为网络代理服务器的安全技术检测依据。本标准详细规定了代理服务器的安全环境，包括安全条件假设、对安全的威胁；安全目标，包括信息技术和非信

息技术安全目标；信息技术安全要求，包括各种功能要求和各种保证要求；基本原理，包括信息技术安全目标、非信息技术安全目标、信息技术功能要求的基本原理。

（3）安全保密产品

如 BMB1—1994《电话机电磁泄漏发射限值和测试方法》，标准规定了电话机电磁泄漏辐射发射、传导发射的限值和测试方法。适用于党政专用电话网使用的有线电话机（不包括无绳电话机、数字电话机），适用于需要保密通信的电话机。

（4）通用系统

如 GB/T 20270—2006《信息安全技术 网络基础安全技术要求》，标准依据 GB 17859—1999《计算机信息系统安全保护等级划分准则》划分的 5 个安全保护等级，规定了各个安全等级的网络系统所需要的基础安全技术的要求。标准详细给出了网络安全的组成及它们的相互关系；网络安全功能的基本要求，包括身份鉴别、自主访问控制、标记、强制访问控制、数据流控制、安全审计、用户数据完整性、用户数据保密性、可信路径、抗抵赖、网络安全监控；网络安全功能分层分级要求；按 GB 17859—1999 的 5 个安全保护等级，对每一个安全保护等级的安全功能技术要求和安全保证技术要求做了详细描述。标准还以附录的形式给出了标准中各概念的说明。适用于按等级化要求进行的网络系统的设计和实现，对按等级化要求进行的网络系统安全的测试和管理可参照使用。

（5）涉密信息系统

如 BMB17—2006《涉及国家秘密的信息系统分级保护技术要求》，标准规定了涉密信息系统的等级划分准则和相应等级的安全保密技术要求。适用于涉密信息系统的设计单位、建设单位、使用单位对涉密信息系统的建设、使用和管理，也可用于保密工作部门对涉密信息系统的管理和审批。

（6）通信安全

如 GB/T 20275—2013《信息安全技术 网络入侵检测系统技术要求和测试评价方法》，标准规定了网络入侵检测系统的技术要求和测试评价方法，要求包括安全功能要求、自身安全功能要求、安全保证要求和测试评价方法，并提出了网络入侵检测系统的分级要求。标准适用于网络入侵检测系统的设计、开发、测试和评价。

（7）政府安全检查

GB/T 29245—2012《信息安全技术 政府部门信息安全管理基本要求》，标准规定了政府部门信息安全管理基本要求，用于指导各级政府部门的信息安全管理工作。本标准中涉及保密工作的，按照保密法规和标准执行；涉及密码工作的，按照国家密码管理规定执行。适用于各级政府部门，其他单位可以参考使用。

（8）安全能力评估

如 GB/T 30271—2013《信息安全技术 信息安全服务能力评估准则》，标准定义了服务过程模型和信息安全服务商的服务能力的评估准则。标准既可用于对信息安全服务提供商的能力进行评估，也可为服务提供商对于自身能力的改善提供指导。

2.4.3 网络安全等级保护标准族

《网络安全法》第二十一条提出“国家实行网络安全等级保护制度。网络运营者应当按照网络安全等级保护制度的要求，履行下列安全保护义务，保障网络免受干扰、破坏或者未经授权的访问，防止网络数据泄露或者被窃取、篡改”。网络安全等级保护也就是我们传统所说的信息系统安全等级保护。

信息安全等级保护制度是国家在国民经济和社会信息化的发展过程中，提高信息安全保障能力和水平，维护国家安全、社会稳定和公共利益，保障和促进信息化建设健康发展的一项基本制度。实行信息安全等级保护制度，能够充分调动国家、法人和其他组织及公民的积极性，发挥各方面的作用，达到有效保护的目的，增强安全保护的整体性、针对性和实效性，使信息系统安全建设更加突出重点、统一规范、科学合理，对促进我国信息安全的发展将起到重要推动作用。

1．等级保护标准体系

（1）安全等级类标准

主要包括 GB/T 22240—2008《信息安全技术 信息系统安全保护等级保护定级指南》和各类行业定级准则。

这些标准主要对如何进行信息系统定级做出指导。

（2）方法指导类标准

主要包括 GB/T 25058—2010《信息安全技术 信息系统安全等级保护实施指南》和 GB/T 25070—2010《信息系统等级保护安全设计技术要求》等。其中《等级保护实施指南》原以公安部政策文件方式发布，后经过修改以标准发布。

这些标准主要对如何开展等级保护工作做出了详细规定。

（3）状况分析类标准

主要包括 GB/T 28448—2012《信息安全技术 信息系统安全等级保护测评要求》和 GB/T 28449—2012《信息安全技术 信息系统安全等级保护测评过程指南》等。其中在等级保护试点工作期间还发布过《等级保护测评准则》等文件，后经过修改以《等级保护测评要求》发布。

这些标准主要对如何开展等级保护测评工作做出了详细规定。

（4）基线要求类标准

主要包括 GB/T 22239—2008《信息安全技术 信息系统安全等级保护基本要求》、GB/T 20271—2006《信息系统通用安全技术要求》、GB/T 21052—2007《信息系统物理安全技术要求》、GB/T 20269—2006《信息系统安全管理要求》、GB/T 20272—2006《操作系统安全技术要求》等数十份。其中，以《等级保护基本要求》为核心，在其下可以细分为技术类、管理类和产品类等标准，分别对某些专门技术、管理和产品进行要求。

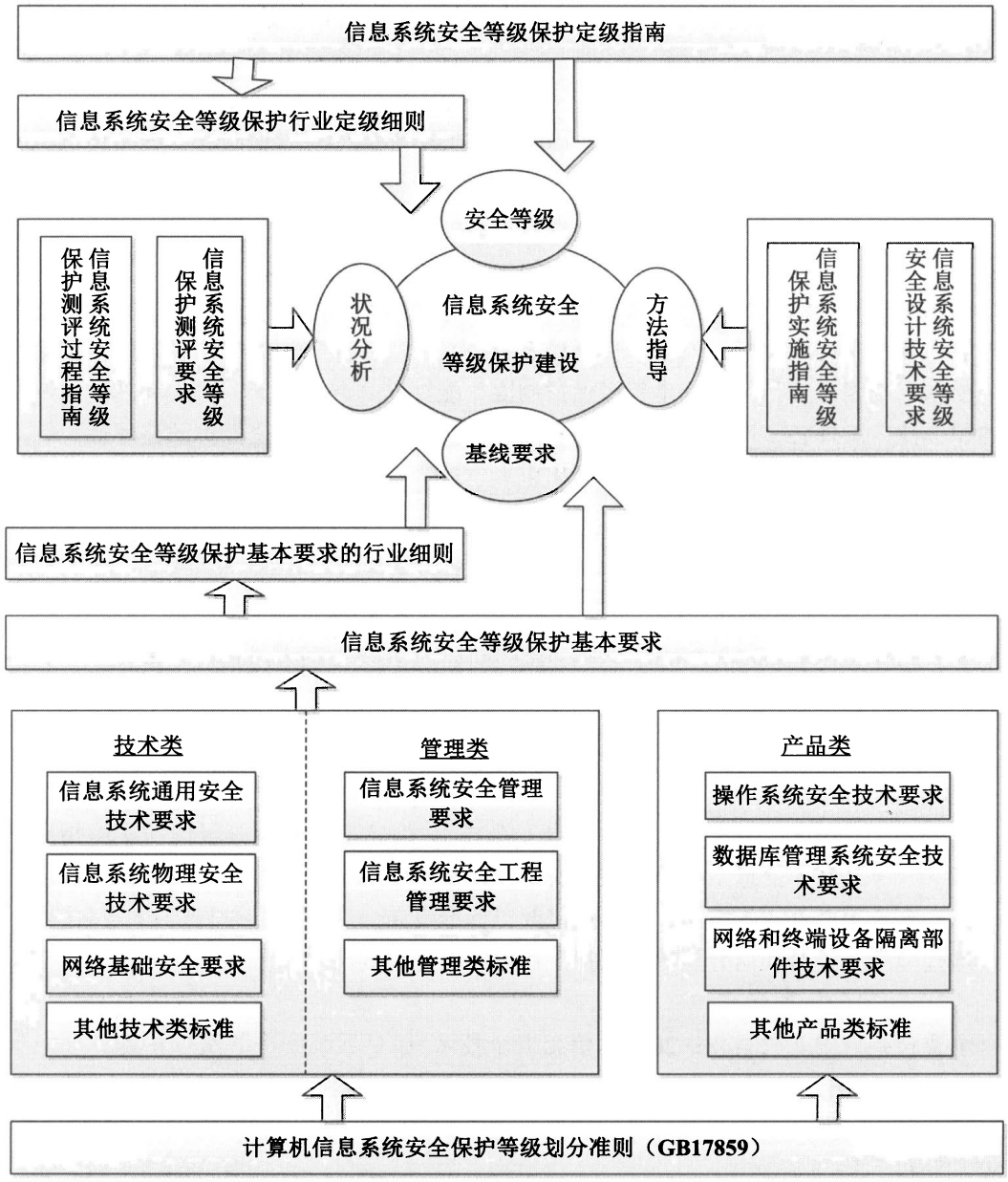

图 2-4　等级保护标准体系

2．等级保护实施流程

等级保护实施根据 GB/T 25058—2010《信息安全技术_信息系统安全等级保护实施指南》分为五大阶段：定级、总体规划、设计实施、运行维护和系统终止。但由于在开展等级保护试点工作时，大量信息系统已经建设完成，因此根据实际情况逐步形成了定级、备案、差距分析（也叫差距测评）、建设整改、验收测评、定期复查为流程的等级保护工作流程。这与《等级保护实施指南》中规定的针对信息系统生命周期的五大阶段略有差异。

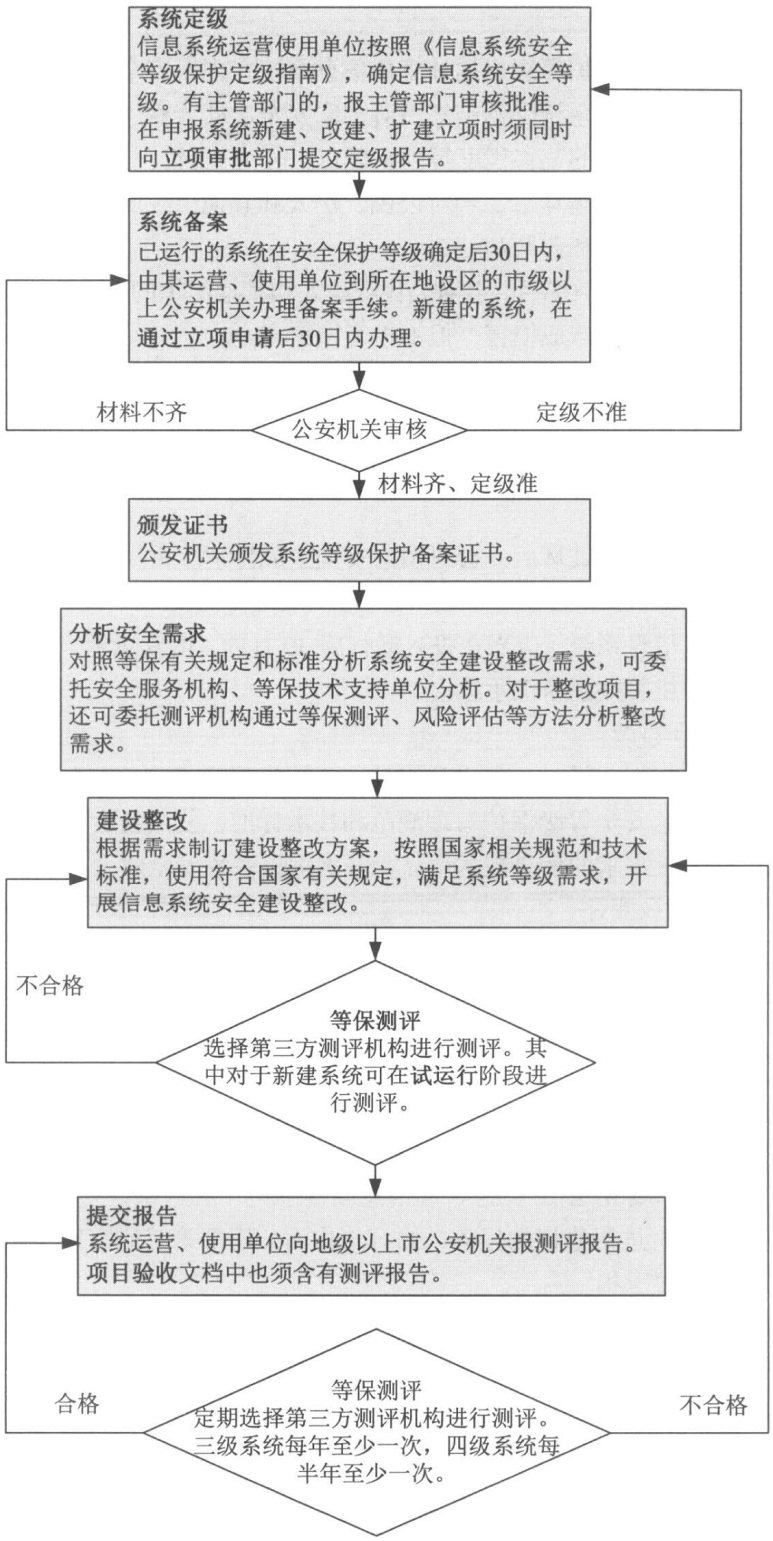

图 2-5　信息系统安全等级保护流程

（1）定级

计算机信息系统安全保护等级根据计算机信息系统在国家安全、经济建设、社会生活中的重要程度，计算机信息系统受到破坏后对国家安全、社会秩序、公共利益以及公民、法人和其他组织的合法权益的危害程度等因素确定，分为五级。

第一级，信息系统受到破坏后，会对公民、法人和其他组织的合法权益造成损害，但不损害国家安全、社会秩序和公共利益。

第二级，信息系统受到破坏后，会对公民、法人和其他组织的合法权益产生严重损害，或者对社会秩序和公共利益造成损害，但不损害国家安全。

第三级，信息系统受到破坏后，会对社会秩序和公共利益造成严重损害，或者对国家安全造成损害。

第四级，信息系统受到破坏后，会对社会秩序和公共利益造成特别严重损害，或者对国家安全造成严重损害。

第五级，信息系统受到破坏后，会对国家安全造成特别严重损害。

（2）备案

新建第二级以上信息系统，应当在投入运行后 30 日内，由其运营、使用单位到所在地设区的市级以上公安机关办理备案手续。

（3）安全建设和整改

计算机信息系统规划、设计、建设和维护应当同步落实相应的安全措施。运营、使用单位应当按照国家信息安全等级保护管理规范和技术标准，使用符合国家有关规定，满足信息系统安全保护等级需求的信息技术产品，开展信息系统安全建设或者改建工作。

（4）信息安全等级测评

信息系统建设完成后，二级以上的信息系统的运营使用单位应当选择符合国家规定的测评机构进行测评，合格方可投入使用。已投入运行信息系统在完成系统整改后也应当进行测评。经测评，信息系统安全状况未达到安全保护等级要求的，运营使用单位应当制订方案进行整改。

3．等级保护标准发展

2014 年全国安标委秘书处下达对《信息安全技术 信息系统等级保护基本要求》（GB/T 22239—2008）进行修订的任务，修订工作由公安部第三研究所（公安部信息安全等保护评估中心）主要承担。

2015 年 4 月第一次专家评审会、2015 年 12 月第二次专家评审会、2016 年 7 月第三次专家评审会、2016 年 9 月再次修订形成标准征求意见稿。先后征求了网信办、工信部、保密局、公安部、国家密码管理局、国家认监委、信息安全测评中心的意见，共收到 44 条意见，采纳 36 条。

2017 年 8 月，根据网信办和公安部的意见将 5 个分册进行整合形成一册送审稿，后收到 10 条修改意见并全部采纳。

将原来的信息系统安全等级保护相关标准名称更改为网络安全等级保护相关标准，与《网络安全法》保持一致。

基本要求的内容由一个基本要求变更为安全通用要求和安全扩展要求（含云计算、移动互联、物联网、工业控制）。

由原来的 10 个分类调整为 8 个分类，分别为技术部分（物理和环境安全、网络和通信安全、设备和计算安全、应用和数据安全）、管理部分（安全策略和管理制度、安全管理机构和人员、安全建设管理、安全运维管理）。

针对云计算环境安全扩展要求主要增加的内容包括“基础设施的位置”“虚拟化安全保护”“镜像和快照保护”“云服务商选择”“云计算环境管理”等。

对移动互联环境主要增加的内容包括“无线接入点的物理位置”“移动终端管控”“移动应用管控”“移动应用软件采购”“移动应用软件开发”等。

对物联网环境主要增加的内容包括“感知节点的物理防护”“感知节点设备安全”“感知网关节点设备安全”“感知节点的管理”“数据融合处理”等。

对工业控制系统主要增加的内容包括“室外控制设备防护”“工业控制系统网络架构安全”“拔号使用控制”“无线使用控制”“控制设备安全”。

增加了描述等级保护安全框架和关键技术、云计算应用场景、移动互联应用场景、物联网应用场景、工业控制系统应用场景。

为适应定级方法的变化，取消对控制点的“S”“A”“G”标注的使用，调整原标准附录 B，增加安全控制措施选择时，控制点的标注及使用说明。

第 3 章

知识域：信息安全管理

阅读提示 本知识域是介绍信息安全管理基本概念、信息安全风险管理、信息安全管理体系建设的过程方法、信息安全管理体系最佳实践及度量等知识，通过学习，学员能理解信息安全管理的重要性，了解信息安全管理体系建设的过程方法及信息安全管理控制措施及度量方法等概念。本知识域包含信息安全管理基础、信息安全风险管理、信息安全管理体系建设、信息安全管理体系最佳实践、信息安全管理体系度量 5 个知识子域。

3.1 知识子域：信息安全管理基础

网络空间是继海洋、陆地、天空和外太空之外的第五空间已经成为国际社会的共识。现今的社会，组织机构的正常运行已经高度依赖信息系统，信息系统所承载的信息和服务的安全性已经关系到组织机构的业务是否能正常运转，任何在保密性、完整性和可用性等方面的缺陷，都可能给组织机构带来重大的影响。信息安全技术是信息安全控制的重要手段，许多信息系统的安全保障都要依靠技术手段来实现，但光有安全技术还是不行，要让安全技术发挥应有的作用，必然要有适当的管理程序的支撑。如果说安全技术是信息安全体系的构筑材料，那么信息安全管理就是粘合剂和催化剂，只有将有效的安全管理从始至终地贯彻落实到信息系统建设的方方面面，信息安全的长期性和有效性才能有所保证。

3.1.1 基本概念

1. 信息

信息是一种资产，与其他重要的业务资产一样，对组织业务必不可少，因此需要得到适当的保护。信息的价值从企业视角、用户视角和攻击者视角 3 个层面来看待。

（1）企业视角

作为企业，首先关注的是信息对组织业务连续性产生的影响，但是随着全球立法机制的发展问题，更多的时候，企业收集的公民信息成为重要的保护难题，我国网络安全等级保护 2.0 在新的定级指南中调整了针对公民造成特别严重损害的信息系统的定级标准，从

二级上调为三级系统。

传统的企业信息保护中，知识产权保护与财务信息仍然是组织保护的重点，但由于互联网的快速发展，信息触发的舆情问题，使得组织越发开始关注针对组织无形资产受损所导致的直接经济损失和间接经济损失。企业内部管理的信息保护成为新的需求。

（2）用户视角

互联网的快速发展使得用户在各种信息系统的使用过程中形成大量的数据，组织管理不善（来自外部的入侵、内部的人员非法窃取）可能导致大量包含用户信息的数据被泄露，而大数据技术的应用也可能使得信息系统使用过程中产生的公开数据、残余数据被用于对用户进行画像，这些数据是社会工程学利用的重要来源，最终导致用户的自身利益（如肖像权、隐私权、知情权等）受损而产生损失。因此用户在选择服务时，安全性已经成为必不可少的考虑因素之一。

（3）攻击者视角

组织更强调的是针对于生产、经营所形成的信息安全问题，但是攻击者更关注的是如何利用和何种信息可以被利用的问题。组织机构可能不关注的信息，如拓扑图、内部的通讯录、学习材料等在攻击者眼里却是非常有价值的资料，可被用于获取更大的利益。

从攻击者角度而言，不起眼的信息可能具备极高的价值，这使得组织机构对信息的控制越来越困难。

2．信息安全管理

管理就是针对特定对象、遵循确定原则、按照规定程序、运用恰当方法、为了完成某项任务并实现既定目标而进行的计划、组织、指导、协调和控制等活动。对现代企业和组织来说，管理对其正常业务运行无疑起着举足轻重的作用。

管理体系使用资源框架来实现组织的目标。管理体系包括组织结构、政策、计划活动、责任、实践、程序、流程和资源。管理体系是建立在风险评估和合规性的基础上，组织不仅要考虑外部的法规，立法遵守，同时也要符合行业规定，使得组织的管理始终走在一条正确的道路上。

信息安全管理作为组织完成的管理体系中的一个重要环节，它构成了信息安全具有能动性的部分，是指导和控制组织的关于信息安全风险的相互协调的活动，其针对对象就是组织的信息资产。信息安全管理的前提是有效管理组织的信息资产，通过对资产的有效识别和授权使用促进对当前组织目标的持续改进和调整，并保持资产的保密性、完整性和可用性得到有效的保障。

- 体系化的管理通常是建立在组织业务战略之上，管理最终的目标是实现组织业务连续性的保障，因此，信息安全管理首先要满足客户和其他利益相关者的信息安全要求。
- 通过管理改进组织的计划和活动，使得组织能够在不断地管理活动的过程中通过检查和纠正使得组织的管理水平得到螺旋式上升。

- 组织的安全目标是信息安全管理要考虑的重要因素，不同的行业、相同的行业不同的组织甚至相同的行业相同的组织由于业务差异化，他们所形成的信息安全目标可能截然不同，因此在建立信息安全管理体系的过程中如何符合组织的信息安全目标是整个体系的关键所在。

3．信息安全管理体系

信息安全管理体系（Information Security Management System，ISMS）是组织整体管理体系的一个部分，是组织在整体或特定范围内建立信息安全方针和目标，以及完成这些目标所用方法的体系。

信息安全管理体系由组织共同管理的政策、程序、指导方针和相关资源与活动组成，旨在保护其信息资产。基于对业务风险的认识，ISMS 用一种系统化的方法，建立、实施、运营、监控、审查、维护和改进等一系列的管理活动使组织实现业务目标。它基于风险评估和组织的风险接受水平，旨在有效处理和管理风险。

通俗意义所讲的 ISMS 是指以 ISO/IEC 27001 为代表的一套成熟的标准族。经过各方对标准的不断改进、演化，从 BS 7799（10 个控制类，147 个控制点）开始，一直到现行的 ISO/IEC 27001:2013（14 个控制类，113 个控制点）。信息安全管理体系的本质就是风险管理，因此，信息安全管理体系首先要对风险进行客观的识别和评价。

2008 年我国 GB/T 2208:2008 等同采用（IDT）ISO/IEC 27001:2005，实现了我国的信息安全管理体系认证体系建设，2016 年，中国标准化管理委员会发布了等同采用 ISO/IEC 27001:2013 版的 GB/T 22080:2016，同步了国际信息安全管理体系标准。

3.1.2 信息安全管理的作用及对组织的价值

1．信息安全管理的作用

（1）信息安全管理是组织整体安全管理重要、固有组成部分

当前信息安全问题已经成为组织业务正常运营和持续发展的最大威胁。信息安全问题本质上是人的问题，单凭技术是无法实现从“最大威胁”到“最可靠防线”转变的。实现信息安全是一个多层面、多因素的过程，也取决于制定信息安全方针策略标准规范、建立有效的监督审计机制等多方面非技术性努力。如果组织想当然地制定一些控制措施和引入某些技术产品，难免存在挂一漏万、顾此失彼的问题，使信息安全这只“木桶”出现若干“短板”，从而无法真正提高信息安全水平。信息安全管理是组织完整的管理体系中一个重要的环节，它构成了信息安全具有能动性的部分。理解并重视管理对于信息安全的关键作用，制定适宜的、易于理解、方便操作的安全策略对实现信息安全目标、进而实现业务目标至关重要。组织建立一个管理框架，让好的安全策略在这个框架内实施，并不断得到修正，才可能为业务的正常持续运作提供可靠的信息安全保障。组织应该将信息安全管理与生产安全管理、财务安全管理、安全保卫管理等构成组织整体安全管理。

（2）信息安全管理是信息安全技术的融合剂，保障各项技术措施能够发挥作用

解决信息安全问题，成败通常取决于两个因素：一个是技术；另一个是管理。安全技术是信息安全控制的重要手段，但光有安全技术还不行，要让安全技术发挥应有的作用，必然要有适当的管理程序，否则，安全技术只能趋于僵化和失败。如果说安全技术是信息安全的构筑材料，信息安全管理就是粘合剂和催化剂。技术和产品是基础，管理才是关键。产品和技术，要通过管理的组织职能才能发挥最佳作用。技术不高但管理良好的系统远比技术高超但管理混乱的系统安全。只有将有效的安全管理从始至终贯彻落实于安全建设的方方面面，信息安全的长期性和稳定性才能有所保证。根本上说，信息安全是个管理过程，而不是技术过程。人们常说，三分技术，七分管理，可见管理对信息安全的重要性。

强调信息安全管理，并不是要削弱信息安全技术的作用，开展信息安全管理要处理好管理和技术的关系，应该强调“技管并重”。“坚持管理与技术并重”是我国加强信息安全保障工作的主要原则之一。

（3）信息安全管理能预防、阻止或减少信息安全事件的发生

统计结果显示，在所有信息安全事故中，只有 20%～30%是由于攻击者入侵或其他外部原因造成的，70%～80%是由于内部员工的疏忽或有意泄密造成的。统计结果表明，现实世界里大多数安全事件的发生和安全隐患的存在，与其说是技术原因，不如说是管理不善造成的。因此，防止发生信息安全事件不应仅从技术着手，同时更应加强信息安全管理。安全不是产品的简单堆积，也不是一次性的静态过程，它是人员、技术、操作三者紧密结合的系统工程，是不断演进、循环发展的动态过程。

2．对组织机构的价值

（1）对组织内信息安全管理的价值

① 能够保护关键信息资产和知识产权，维持竞争优势。

② 在系统受侵袭时，确保业务持续开展并将损失降到最低程度。

③ 建立起信息安全审计框架，实施监督检查。

④ 建立起文档化的信息安全管理规范，实现有“法”可依，有章可循，有据可查。

强化员工的信息安全意识，建立良好的安全作业习惯，培育组织的信息安全企业文化。

按照风险管理的思想建立起自我持续改进和发展的信息安全管理机制，用最低的成本，达到可接受的信息安全水平，从根本上保证业务的持续性。

（2）对组织外信息安全管理的价值

① 能够使各利益相关方对组织充满信心。

② 能够帮助界定外包时双方的信息安全责任。

③ 可以使组织更好地满足客户或其他组织的审计要求。

④ 可以使组织更好地符合法律法规的要求。

⑤ 若通过了 ISO 27001 认证，能够提高组织的公信度。

⑥ 可以明确要求供应商提高信息安全水平，保证数据交换中的信息安全。

3.2 知识子域：信息安全风险管理

3.2.1 风险管理基本概念

风险管理的目的是确保不确定性不会使企业的业务目标发生变化。风险管理是风险的识别、评估和优化（ISO 31000 定义为不确定性对目标的影响），然后协调和经济地应用资源，以最小化监测和控制不良事件的可能性及影响，最大限度地实现业务。

在信息时代，信息已经成为第一战略资源，信息对组织使命的完成、组织目标的实现起着至关重要的作用，因此信息资产的安全是关系到该组织能否完成其使命的重大因素。资产与风险是一对矛盾共同体，资产价值越高，面临的风险就越大。而对于目前的组织机构而言，由于组织的业务运营越来越依赖于信息资产，信息安全相关风险在组织整体风险中所占的比例也越来越高。信息安全风险管理的目的就是将风险控制到可接受的程度，保护信息及其相关资产，最终保障组织能够完成其使命，实现其目标。

信息安全风险管理是基于风险的信息安全管理，也就是始终以风险为主线进行信息安全的管理。应根据实际信息系统的不同来理解信息安全风险管理的侧重点，即风险管理选择的范围和对象重点应有所不同。

1．风险与风险管理

风险在 GB/T 22081 中定义为事态的概率及其结果的组合。风险的目标可能有很多不同的方面，如财务目标、健康和人身安全目标、信息安全目标和环境目标等；目标也可能有不同的级别，如战略目标、组织目标、项目目标、产品目标和过程目标等。风险经常通过引用潜在事态和后果或这些的组合来描述。影响，是对一个预期的偏离，正面的或负面的偏离。

风险是客观存在的，与不确定性紧密相连，但又不能完全等同。风险带来的影响，通常都是负面的（正面的影响通常不被称为风险）。风险强调的是损害的潜在可能性，而不是事实上的损害。风险不能消除殆尽，包括人为因素带来的风险，也一样不能消除殆尽。衡量风险的两个基本要素就是事件的概率和影响。

威胁利用脆弱性作用于资产产生影响，威胁增加了组织资产的风险，脆弱点能够暴露资产，脆弱性本身不会构成对资产的损害，但是脆弱性被威胁利用就会增加组织资产的风险。组织应该根据风险建立相应的保护要求，通过构建防护措施降低风险对组织产生的影响。

在 GB/T 22080 中，风险管理被定义为指导和控制一个组织相关风险的协调活动。风险管理由风险评估、风险减缓以及基于风险的决策 3 个部分组成。风险评估过程将全面评估信息系统的资产、威胁、脆弱性以及现有的安全措施，分析安全事件发生的可能性以及可能的损失，从而确定信息系统的风险，并判断风险的优先级，建议处理风险的措施。基于风险评估的结果，风险处理过程将考察信息安全措施的成本，选择合适的方法处理风险，将风险控制到可接受的程度。基于风险的决策是风险管理的最后过程，旨在由信息系统的

主管者或运营者判断残余风险是否处在可接受的水平之内。根据判断，主管者或运营者将做出决策，决定是否允许信息系统运行。

2．风险管理的价值

风险管理可使信息系统的主管者和运营者在安全措施的成本与资产价值之间寻求平衡，并最终通过对支持其使命的信息系统及数据进行保护而提高其实现使命的能力。

一个单位的领导必须确保本单位具备完成其使命所需的能力。信息安全措施是有成本的，因此对信息安全的成本必须像其他管理决策一样进行全面检查。一套合理的风险管理方法，可以帮助信息系统的主管者和运营者最大程度地提高其信息安全保障能力，以有效实现其使命。

为了使风险管理有效，一个组织应在所有层面上符合以下原则。

（1）**风险管理创造和保护价值：**风险管理致力于人员健康和人身安全、其他安全、法律法规符合性、公众认可、环境保护、产品质量、项目管理、运营效率、治理和名誉等方面的目标达成和绩效提升。

（2）**风险管理是所有组织过程不可分割的一个部分：**风险管理不是从组织的主要活动和过程中分离出来的一个孤立活动。风险管理是管理职责的一部分，是组织过程的有机组成部分，包括战略规划、所有项目和变更管理过程。

（3）**风险管理是决策的一部分：**风险管理帮助决策者做出明智选择、确定优先行动和辨别措施的可选过程。

（4）**风险管理明确地应对不确定性：**风险管理特别考虑不确定性、不确定性的本质，以及如何应对它。

（5）**风险管理是体系化的、结构化的过程：**一个体系化的、结构化的风险管理方法有助于提高效率，以及获得可持续的、可比较的和可靠的结果。

（6）**风险管理是基于最好的可获得的信息：**风险管理过程的输入是基于诸如历史数据、经验、股东反馈、观察报告、预报和专家判断这样的信息来源。然而，风险管理的关键还在于决策者应该考虑如何使用这些数据。

（7）**风险管理是可裁剪的：**风险管理作用于组织应可根据组织的业务、技术、管理文化等诸多方面进行裁剪，以适应组织实际风险，进行合理管理。

（8）**风险管理考虑人员和文化因素：**风险管理承认外部和内部人员的能力、感觉、意图，这些因素能促进或阻碍组织目标的达成。

（9）**风险管理是透明的，参与人员包含广泛：**特别是所有级别的决策者适当和适时的参与，确保风险管理保持与当前组织机构业务问题是相关的且不断更新。这种参与也允许有适当的股东代表，并且在确定风险准则时考虑到他们的观点。

（10）**风险管理是动态的、反复的、响应变化的：**风险管理持续感知和响应变化。当外部和内部事件发生进行风险的监视和评审。背景和知识改变，新的风险浮现了，一些风险改变了，其他风险消失了。

（11）**风险管理促进组织的持续改进：**组织应开发和实施战略，在改进其风险管理成

熟度的同时，改进组织其他方面的管理成熟度。

（12）**不断或定期重新评估**：风险是动态的，动态的风险评估可以为组织的持续改进提供重要的依据。组织应该定期执行风险评估，例如，每年至少一次全面的风险评估；组织也可以在发生变更后对变更点进行评估。

3．风险管理角色和责任

风险管理是一项综合的过程，该过程中的参与角色一般分为国家信息安全主管机关、业务主管机关、信息系统拥有者/运营者、信息系统承建者、信息系统安全服务机构、信息系统的关联者（即因信息系统互联、信息交换和共享、系统采购等行为与该系统发生关联的机构），如表 3-1 所示。

表 3-1　风险管理工作的角色和职责

角　色	责　任
国家信息安全主管机关	制定信息安全的政策、法规和标准 督促、检查和指导各单位的风险管理工作
业务主管机关	提出、组织制定并批准本单位的信息安全风险管理策略 领导和组织本单位的信息系统安全评估工作 基于本部门内风险评估的结果，判断信息系统的残余风险是否可接受，并决定是否批准信息系统投入运行 检查信息系统运行中产生的安全状态报告 定期或不定期地开展新的风险评估工作
信息系统拥有者/运营者	制订风险管理策略和安全计划，报上级审批 组织实施信息系统自评估工作 配合检查评估或委托评估工作，并提供必要的文档等资源 向主管机关提出新一轮风险评估的建议 改善信息安全措施，处理信息安全风险
信息系统承建者	将信息系统建设方案提交给有关方面进行风险分析，根据风险分析的结果修正建设方案，使方案成本合理且积极有效，在方案中有效地控制风险 规范建设，减少在建设阶段引入新风险
信息安全服务/集成机构	提供独立的风险评估，并在评估后提出调整建议以减少或根除信息系统中的脆弱性，有效对抗安全威胁，处理风险。保护评估中的敏感信息，防止被无关人员和单位获得 使用经过测评认证的安全产品 协助制订风险管理策略和安全计划 根据系统拥有者/运营者的需求，对风险进行处理
信息系统的关联机构	遵守安全策略、法规、合同等涉及信息系统交互行为的安全要求，减少信息安全风险 协助风险管理工作确定安全边界 在风险评估中提供必要的资源和资料

3.2.2 常见风险管理模型

1．内部控制整合框架（COSO 报告）

《内部控制整合框架》也称为“COSO 报告”，由美国反虚假财务报告委员会下属的发起人委员会（The Committee of Sponsoring Organizations of the Treadway Commission，COSO）于 1992 年提出。COSO 建立了一个共同的内部控制模式，公司和组织可以对其进行评估。COSO 企业风险管理的定义：企业风险管理是一个过程，受企业董事会、管理层和其他员工的影响，包括内部控制及其在战略和整个公司的应用，旨在为实现经营的效率和效果、财务报告的可靠性以及法规的遵循提供合理保证。

COSO 的内部控制定义为：由一个企业的董事会、管理层和其他人员实现的过程，旨在为下列目标提供合理保证：（1）财务报告的可靠性；（2）经营的效果和效率；（3）符合适用的法律和法规。《内部控制整合框架》把内部控制划分为 5 个相互关联的要素，分别是：（1）内制环境；（2）风险评估；（3）控制活动；（4）信息与沟通；（5）监控。每个要素均承载 3 个目标：（1）经营目标；（2）财务报告目标；（3）合规性目标。

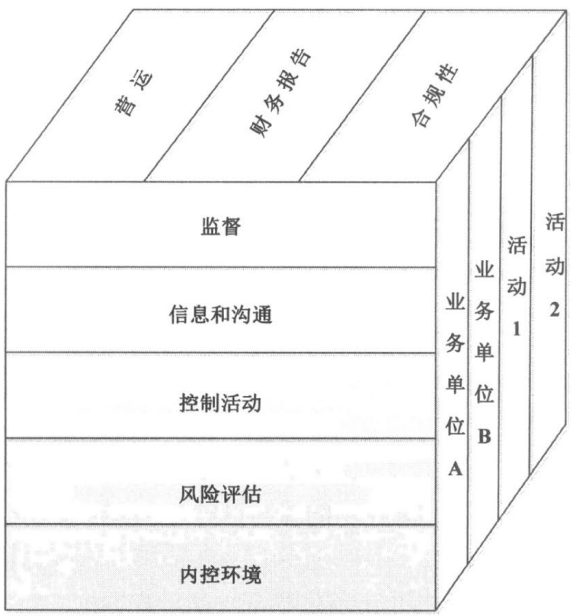

图 3-1 COSO 风险管理模型

2．ISO 31000 风险管理 原则与实施指南

ISO 31000:2009《风险管理 原则与实施指南》是由国际标准化组织编纂的与风险管理相关的一系列标准，目的是提供风险管理的原则和通用指南。ISO 31000 旨在为从业人员和公司提供普遍公认的范例。采用风险管理流程来取代各种行业、主体和地区不同的现有标准、方法和范例。

目前，ISO 31000 系列预计将包括以下方面。

- ISO 31000:2009-实施原则和准则。
- ISO/IEC 31010:2009-风险管理-风险评估技术。
- ISO 指南 73:2009-风险管理-词汇。

ISO 还制定了 ISO 21500 项目管理指南标准，以符合 ISO 31000:2009，ISO 31000:2009 的目标是适用于“任何公共、私人或社区企业、协会、团体或个人”，因此，作为风险管理标准家族的 ISO 31000 的总体范围并不是针对特定的行业组织、管理体系或业务领域开发的，而是为所有与风险管理相关的操作提供最佳实践结构和指导。它于 2015 年 5 月 13 日开始了第一次修订。2017 年 2 月 17 日发布了征求公众意见的国际标准草案（DIS）。

ISO 31000:2009 为整个组织的风险管理流程的设计、实施和维护提供了通用准则。这种形式化风险管理实践的方法将促进需要企业风险管理标准的企业更广泛地采用，该标准适应多个“以企业为中心”的管理体系。

这种风险管理方法的范围是使整个项目、职能和流程中组织的所有战略、管理和运营任务与一套通用的风险管理目标保持一致。因此，ISO 31000:2009 是针对广泛的利益相关者群体的，其中包括以下方面。

- 高层管理人员。
- 企业风险管理小组的任命人员。
- 风险分析师和管理人员。
- 直线经理和项目经理。
- 合规和内部审计师。
- 独立从业者。

3. COBIT

COBIT（信息和相关技术的控制目标）是国际专业协会 ISACA 为 IT 管理和 IT 治理创建的良好实践框架。COBIT 提供了一套可实施的“信息技术控制，并围绕 IT 相关流程和推动因素的逻辑框架进行组织。”

COBIT 最初是“信息与相关技术的控制目标”，在框架发布之前，人们将“COBIT”称为“IT 控制目标”或“信息及相关技术的控制目标”。该框架定义了一套管理 IT 的通用流程，确定了每个过程与过程输入和输出、关键流程活动、流程目标、绩效评估和初级成熟度模型。COBIT 还为信息系统和技术的治理和控制过程提供了一套推荐的最佳实践，其实质是使 IT 与业务相一致。COBIT 5 将 COBIT 4.1、Val IT 和风险 IT 整合为一个单一的框架，作为与其他框架和标准相一致和可互操作的企业框架，如图 3-2 所示。

COBIT 组件包括以下方面。

- 框架：通过 IT 领域和流程组织 IT 治理目标和良好做法，并将其与业务需求联系起来。
- 流程描述：组织中每个人的参考流程模型和通用语言。过程映射到计划、构建、

运行和监视的责任领域。

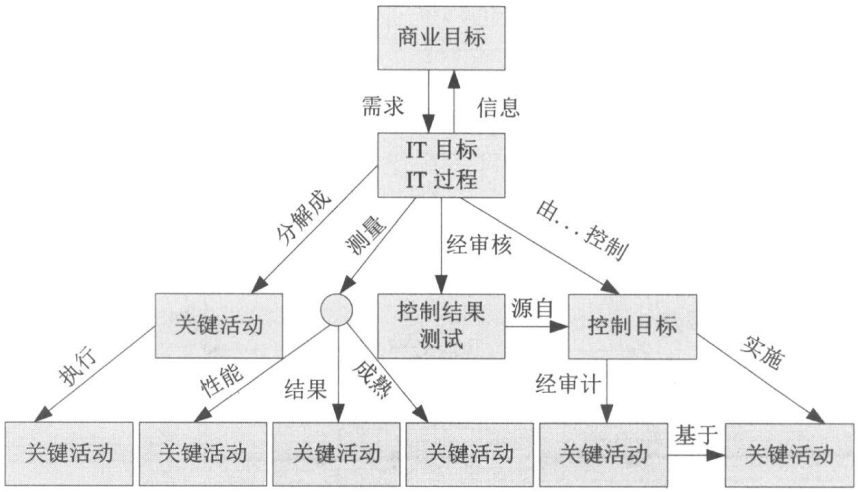

图 3-2 COBIT 模型

- 控制目标：提供管理层要考虑的一套完整的高级要求，以有效控制每个 IT 流程。
- 管理指南：帮助分配责任，达成目标，衡量绩效，并说明与其他流程的相互关系。
- 成熟度模型：评估每个过程的成熟度和能力，并帮助解决差距。

4. ISMS

ISMS 通常是指以 ISO/IEC 27000 标准族为代表的信息安全管理体系。通过信息安全控制措施来管理信息系统安全，其设计类似于质量保证管理体系（ISO 9000 系列）、环保（ISO 14000 系列）等管理系统。

ISMS 涉及隐私、保密性和 IT、技术、网络安全问题，适用于不同类型、不同规模的组织。鼓励所有组织评估其信息风险，然后在相关的指导和建议的基础上，根据需要采取信息安全控制措施。由于信息安全的动态性，ISMS 包含持续的反馈和改进活动，以应对事件的威胁、漏洞或影响的变化。

3.2.3 安全风险管理基本过程

信息安全风险管理包括背景建立、风险评估、风险处理、批准监督、监控审查和沟通咨询 6 个方面的内容。背景建立、风险评估、风险处理和批准监督是信息安全风险管理的 4 个基本步骤，监控审查和沟通咨询则贯穿于这 4 个基本步骤中，如图 3-3 所示。

1. 背景建立

背景建立是信息安全风险管理的第一步骤，确定风险管理的对象和范围，确立实施风险管理的准备，进行相关信息的调查和分析。背景建立是为了明确信息安全风险管理的范围和对象，以及对象的特性和安全要求，对信息安全风险管理项目进行规划和准备，保障

后续的风险管理活动顺利进行。背景是建立在业务需求的基础上，通过有效的风险评估和国家、地区、行业相关法律法规及标准的约束下获得背景依据。

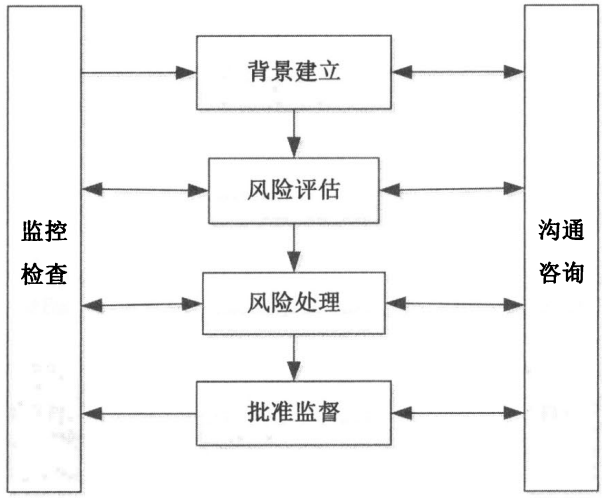

图 3-3　信息安全风险管理过程

背景建立的过程包括风险管理准备、信息系统调查、信息系统分析和信息安全分析 4 个阶段。在信息安全风险管理过程中，对象确立过程是一次信息安全风险管理主循环的起始，为风险评估提供输入，而监控审查和沟通咨询贯穿其 4 个阶段。

2．风险评估

风险评估确定信息资产的价值、识别适用的威胁和（存在或可能存在的）脆弱点、识别现有控制措施及其对已识别风险的影响，确定潜在后果，对风险进行最终的优先级排序，并按照风险范畴中设定的风险评价准则进行排名。

风险评估的目的是通过风险评估的结果，来获得信息安全需求，信息安全风险管理要依靠风险评估的结果来确定随后的风险处理和批准监督活动。风险评估使得组织能够准确定位风险管理的策略、实践和工具，能够将安全活动的重点放在重要的问题上，能够选择有合理成本效益的和适用的安全对策。基于风险评估的风险管理方法被实践证明是有效的和实用的，已被广泛应用于各个领域。

风险评估的过程包括风险评估准备、风险要素识别、风险分析和风险结果判定 4 个阶段。在信息安全风险管理过程中，风险评估活动接受背景建立阶段的输出，形成本阶段的最终输出《风险评估报告》，此文档为风险处理活动提供输入。监控审查和沟通咨询贯穿风险评估的 4 个阶段。

3．风险处理

风险处理是依据风险评估的结果，选择和实施合适的安全措施。风险处理的目的是为了将风险始终控制在可接受的范围内。风险处理的方式主要有降低、规避、转移和接受 4 种方式。

- 降低方式：组织首先应该选择降低风险，通常通过对面临风险的资产采取保护措施来降低风险。保护措施可以从构成风险的 5 个方面（即威胁源、威胁行为、脆弱性、资产和影响）来降低风险。比如，采用法律的手段制裁计算机犯罪（包括窃取机密信息，攻击关键的信息系统基础设施，传播病毒、不健康信息和垃圾邮件等），发挥法律的威慑作用，从而有效遏制威胁源的动机；采取身份认证措施，从而抵制身份假冒这种威胁行为的能力；及时给系统打补丁（特别是针对安全漏洞的补丁），关闭无用的网络服务端口，从而减少系统的脆弱性，降低被利用的可能性；采用各种防护措施，建立资产的安全域，从而保证资产不受侵犯，其价值得到保持；采取容灾备份、应急响应和业务连续计划等措施，从而减少安全事件造成的影响程度。
- 规避方式：当风险不能被降低时，通过不使用面临风险的资产来避免风险。比如，在没有足够安全保障的信息系统中，不处理特别敏感的信息，从而防止敏感信息的泄漏。再如，对于只处理内部业务的信息系统，不使用互联网，从而避免外部的有害入侵和不良攻击。
- 转移方式：只有在风险既不能被降低，又不能被规避时，通过将面临风险的资产或其价值转移到更安全的地方来避免或降低风险。比如，在本机构不具备足够的安全保障的技术能力时，将信息系统的技术体系（即信息载体部分）外包给满足安全保障要求的第三方机构，从而避免技术风险。再如，通过给昂贵的设备上保险，将设备损失的风险转移给保险公司，从而降低资产价值的损失。
- 接受方式：是选择对风险不采取进一步的处理措施，接受风险可能带来的结果。接受风险的前提是确定了风险的等级，评估了风险发生的可能性以及带来的潜在破坏，分析了使用每种处理措施的可行性，并进行了较全面的成本效益分析，认定某些功能、服务、信息或资产不需要进一步保护。

风险处理的过程包括现存风险判断、处理目标确立、处理措施选择和处理措施实施 4 个阶段。

实施风险处理措施，需要依据《风险处理实施计划书》《入选风险处理方式说明报告》《入选风险处理措施说明报告》，实施风险处理措施，并记录实施的过程和结果，形成《风险处理实施记录》。

4．批准监督

批准监督包括批准和持续监督两部分。

批准，是指机构的决策层依据风险评估和风险处理的结果是否满足信息系统的安全要求，做出是否认可风险管理活动的决定。批准应由机构内部或更高层的主管机构的决策层来执行。

持续监督，是指检查机构及其信息系统以及信息安全相关的环境有无变化，监督变化因素是否有可能引入新的安全隐患并影响到信息系统的安全保障级别。监督通常由机构内

部管理层和执行层完成，必要时也可以委托支持层的外部专业机构提供支持，这主要取决于信息系统的性质和机构自身的专业能力。

对风险评估和风险处理的结果的批准和持续监督，不能仅依据相关标准进行僵化的对比，而是需要紧紧围绕信息系统所承载的业务，通过对业务的重要性和业务遭受损失后所带来的影响来开展相关工作。批准通过的依据（原则）有两个：一是信息系统的残余风险是可接受的；二是安全措施能够满足信息系统当前业务的安全需求。

5. 监控审查

监控审查对信息安全风险管理的 4 个步骤进行监控和审查。监控，是监视和控制，一是监视和控制风险管理过程，即过程质量管理，以保证过程的有效性；二是分析和平衡成本效益，即成本效益管理，以保证成本的有效性。审查是跟踪受保护系统自身或所处环境的变化，以保证结果的有效性和符合性。

信息安全风险管理活动本身也会存在风险。监控与审查可以及时发现已经出现或即将出现的变化、偏差和延误等问题，并采取适当的措施进行控制和纠正，从而减少因此造成的损失，保证信息安全风险管理主循环的有效性。

具体来说，监控审查包括 3 方面的内容。

- 监控过程有效性，要求对过程是否完整和有效地被执行进行监控；对输出文档是否齐全和内容完备进行监控。
- 监控成本有效性，要求对执行成本与所得效果相比是否合理进行监控。
- 审查结果有效性和符合性，要求对输出结果是否符合信息系统的安全要求进行审查；对输出结果是否因信息系统自身或环境的变化而过时进行审查。

6. 沟通咨询

沟通咨询为信息安全风险管理 4 个步骤相关人员提供支撑。沟通的目的是为直接参与风险管理的人员提供交流途径，以保持参与人员之间的协调一致，共同实现安全目标。咨询是为所有相关人员提供学习途径，以提高风险意识、知识和技能，配合实现安全目标。因此，作为一个安全管理人员，首先应该具备的是沟通能力。

沟通咨询过程应实现两方面的目标。

- 面向参与人员的沟通：与决策层沟通，得到其理解和批准；与管理层和执行层沟通，得到其理解和协作；与支持层沟通，使其了解并得到其支持；与用户层沟通，使其了解并得到其配合。
- 面向相关人员的咨询：为所有层面的相关人员提供咨询和培训，提高其安全意识、知识和技能。

沟通咨询涉及各层面的人员，当沟通咨询的双方角色不同，所采取的方式亦应有所不同。沟通咨询的各种方式如下。

- 指导和检查：机构上级对下级工作的指导和检查，用以保证工作质量和效率，适用于决策层对管理层、决策层对执行层和管理层对执行层。

- 表态：机构高层支持信息安全风险管理的对外表态，用以得到外界认同和支持，适用于决策层对支持层和决策层对用户层。
- 汇报：机构下级对上级做工作汇报，用以得到上级认可，适用于管理层对决策层、执行层对决策层和执行层对管理层。
- 宣传和介绍：机构的信息系统和信息安全风险管理的对外宣传和介绍，用以得到外界支持和配合，适用于管理层对支持层、管理层对用户层和执行层对支持层。
- 培训和咨询：专业人员对信息安全风险管理相关人员的培训和咨询，用以提高人员的安全意识、知识和技能，适用于执行层对用户层、支持层对决策层、支持层对管理层和支持层对执行层。
- 反馈：机构信息系统使用者对机构信息安全风险管理的意见反馈，用以了解实施效果和用户需求，适用于用户层对决策层、用户层对管理层、用户层对执行层和用户层对支持层。
- 交流：同级或同行之间的对等交流，用以共享信息和协调工作，适用于决策层对决策层、管理层对管理层、执行层对执行层、支持层对支持层和用户层对用户层。

3.3　知识子域：信息安全管理体系建设

信息安全问题从信息系统攻击和防护角度来看严重不对称。从攻击角度来看，只要攻其一点，相对来说攻击成功很容易。但是从防御角度来看，成功防护所有攻击在技术领域和经济领域均是不可能实现的。信息安全保障特征说明，信息安全是动态的、无边界的，不可能存在一种或多种安全技术组合能够成功防御各种攻击。同时针对某些特定攻击，从需要投入的资源（人、财、物）衡量要实现防护是不可接受的。

根据木桶原理：一个木桶能装多少水取决于最短的木板。组织机构的信息安全管理的水平取决于管理中最薄弱的环节，而以体系化的方式实施信息安全管理能有效地避免出现管理的短板。

3.3.1　信息安全管理体系成功因素

信息安全管理体系是一个自上而下的管理过程，GB/T 29246—2017（ISO/IEC 27000:2016）中描述了信息安全管理体系成功的主要因素。

- 信息安全策略、目标和与目标一致的活动。
- 与组织文化一致的，信息安全设计、实施、监视、保持和改进的方法与框架。
- 来自所有管理层级、特别是最高管理者的可见支持和承诺。
- 对应用信息安全风险管理（见 ISO/IEC 27005）实现信息资产保护的理解。
- 有效的信息安全意识、培训和教育计划，已使所有员工和其他相关方知悉在信息安全策略、标准等当中他们的信息安全义务，并激励他们做出相应的行动。

- 有效的信息安全事件管理过程。
- 有效的业务连续性管理方法。
- 评价信息安全管理性能的测量系统和反馈的改进建议。

组织首先必须能够认识到信息安全对组织所形成的必要性，信息安全关联着组织的业务命脉，在现代高度依赖信息化发展的产业链中，没有信息安全就没有成功的企业，知识产权盗窃、用户敏感信息泄露、组织信息系统遭到勒索或拒绝服务攻击，无一不对组织业务产生致命影响，因此，认识信息安全的必要性成为信息安全管理体系的首要工作。

信息安全不是一个部门的工作，也不是某个人的职责，信息安全应该贯穿于整个组织，每个成员都需要承担相关的义务和责任，通过组织的工作职能有机的分配安全责任，形成有效的问责机制，成为信息安全管理体系成功的另一因素。

高层承诺是指组织的最高领导应该成为信息安全工作的第一责任人，通过提供适当的人力、物力、财力支持信息安全管理体系的建设，并签署发布顶层管理文件，委任管理者代表具体实施有关信息安全在组织中的相关决策。通过独立的审计向利益相关方陈述有关信息安全管理体系的推动为组织带来的价值和意义。

信息安全不仅能够预防事件的发生，更能提高组织在开展业务中带来的信任。随着互联网产业的不断发展，组织所面临的安全问题也日益严重。如何通过信息安全工作提升组织的无形资产的价值，满足日益增强的全球信息安全管控要求成为组织的一个新的课题。

信息安全管理就是风险管理，因此，信息安全控制措施的本质就是风险处置。组织通过从客观的风险评估中所发现的不可接受风险中建立相应的控制措施，结合预防性、检测性、纠正性 3 种预防技术的有机结合形成组织的整体信息安全控制。

信息系统与安全的“同步规划、同步建设、同步使用”已经被立法约束。信息安全已经成为组织的信息化发展的基本要素。预防和及时响应事件成为组织的当务之急。暴露时间越短，对于组织所形成的影响越小，通过有效的管理和技术的结合，尽可能地降低检测时间和响应时间，成为组织降低安全隐患所带来损失的重要举措。

安全不是一劳永逸的，持续的风险评估是构成持续的安全保障的重要机制。在动态的安全下，通过风险再评估来不断推动信息安全管理体系的螺旋式上升。

3.3.2 PDCA 过程

组织需要识别和管理许多活动，以便有效和高效地运作。任何使用资源的活动都需要进行管理，以便使用一系列相互关联或相互作用的活动将输入转换为输出，这也称为一个过程。一个过程的输出可以直接形成另一个过程的输入，通常这种转换是在计划和控制的条件下进行的。组织内部流程系统的应用以及这些流程的识别和交互及其管理可以称为“过程方法”。

信息安全管理体系采用通用的 PDCA（plan-do-check-act 或者 plan-do-check-adjust）过程方法，PDCA 过程方法也被称为戴明环，由美国质量管理专家戴明博士首先提出。PDCA

是管理学中常用的一个过程模型，该模型在应用时，按照 P-D-C-A 的顺序依次进行，一次完整的 P-D-C-A 可以看成组织在管理上的一个周期，每经过一次 P-D-C-A 循环，组织的管理体系都会得到一定程度的完善，同时进入下一个更高级的管理周期，通过连续不断的 P-D-C-A 循环，组织的管理体系能够得到持续的改进，管理水平将随之不断提升，如图 3-4 所示。

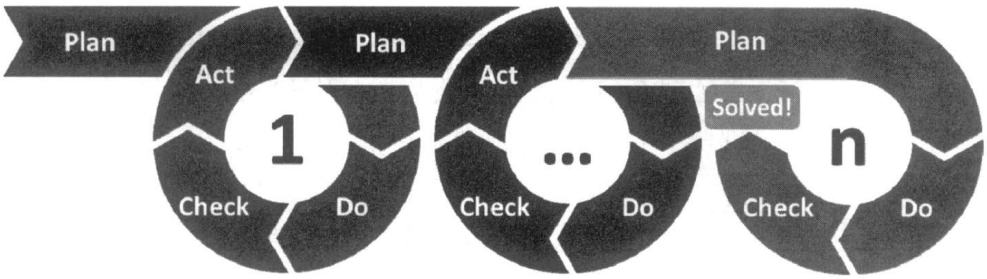

图 3-4　PDCA 动态性

各级质量管理都有一个 PDCA 循环，形成一个大环套小环，一环扣一环，互相制约，互为补充的有机整体。在 PDCA 循环中，一般来说，上一级的循环是下一级循环的依据，下一级的循环是上一级循环的落实和具体化。

每个 PDCA 循环，都不是在原地周而复始地运转，而是像爬楼梯那样，每一循环都有新的目标和内容，这意味着质量管理，经过一次循环，解决了一批问题，质量水平有了新的提高，如图 3-5 所示。

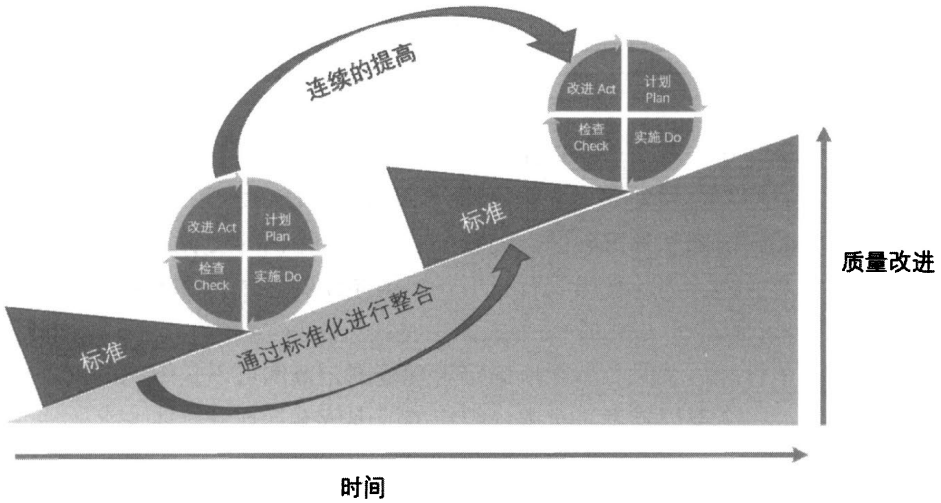

图 3-5　PDCA 模型

PDCA 循环的 4 个阶段，“策划—实施—检查—改进”循环的管理模式，体现着科学认识论的一种具体管理手段和一套科学的工作程序。PDCA 管理模式的应用对我们提高日常工作的效率有很大益处，它不仅在质量管理工作中可以运用，同样也适合于其他各项管理工作。

在 ISO/IEC 27001:2013《信息安全管理体系要求》中定义了 PDCA 过程方法的 4 个阶段主要工作，如图 3-6 所示。

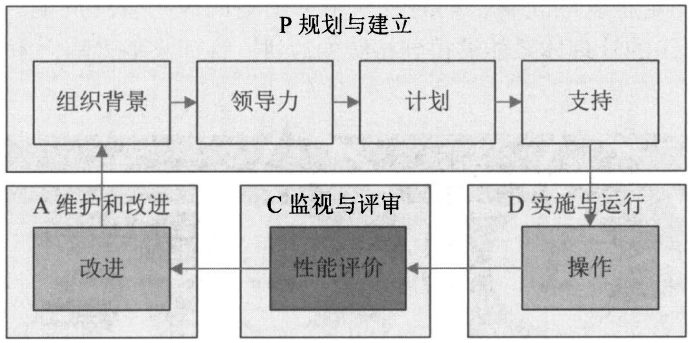

图 3-6　PDCA 结构图

3.3.3　信息安全管理体系建设过程

1．规划与建立

组织在规划与建立阶段确立总体战略和业务目标，规模和地域分布范围，通过对信息资产及其价值的确定、信息处理，存储和通信的业务需求以及法律，监管和合同要求等方面理解来识别信息安全要求。

对组织的信息资产实施风险评估，评估资产面临的威胁、实施威胁的可能性和概率以及任何信息安全事件对信息资产的潜在影响，选择相关控制措施并预计相关控制支出与风险实现对预期业务影响是否相称。

（1）组织背景

建立组织背景是建立信息安全管理体系的基础，首先应该了解组织有关信息安全的内部（人员、管理、流程等）和外部（合作伙伴、供应商、外包商等）问题，以及影响组织建立体系时需要解决的内部和外部问题。随着全球经济一体化的发展，任何企业都很难独立完成完整的一个产业链，因此在组织背景中，组织同样要遵循利益相关方的信息安全需求和合规性要求。

在建立信息安全管理体系时，组织应确定管理范围，范围可以是组织的全部，也可以是组织的一个系统、一个部门或者一个人，组织的范围依据管理的具体要求所涉及的人、事、物来建立。

建立、实施、运行、保持和持续改进符合国际标准要求的 ISMS。

（2）领导力

管理承诺是建立信息安全管理体系的关键成功因素之一，组织管理者首先应该能够充分理解和认识组织所面临的风险，在保障业务的基础上将组织战略与信息安全方针相互结合，并确保足够的人力、物力、财力的支持。

信息安全工作是建立在组织的整体管理基础上，需要组织每个部门都应该参与其中，

而没有高层的参与协调，这项工作将很难得到有效落实。

组织的高层方针由组织最高领导或者董事会来制定，信息安全方针通过文件的形式描述组织的宏观目标，并描述组织在业务框架下的信息安全策略要求。在信息安全方针中明确描述组织的角色、职责和权限。常见的角色遵循最小授权、知必所需、岗位轮换等原则。

（3）计划

计划的建立是在风险评估基础之上，只有在组织风险不可接受时才需要建立控制计划。风险评估是客观的，只有客观的风险评估才能为组织安全战略提供最具费效比的控制。组织通过选择风险评估方法、确定风险评估范围、实施风险评估，并选择恰当的风险评估控制措施。控制措施可以是管理性，也可以是技术性或者物理性。通过有效风险评估建立一种适度安全，并将控制措施写入适用性声明（SoA）。

组织的计划必须符合组织的安全目标，层次化的计划通过层次化的文件体系反映在不同层级的组织机构中执行。安全目标与方针应可以度量并持续改进，通过持续改进实现组织信息安全的螺旋式上升。

（4）支持

组织在建立信息安全管理体系中需要获得资源以建立、实施、保持和持续改进 ISMS。

资源的使用需要提供一定的权限，并对员工及相关外包人员进行适当的培训和教育，而信息安全方针作为组织信息安全指导性文件应向全员进行宣贯。组织还需要建立组织内部和外部的沟通，在信息安全管理工作中通过有效的文件推动体系的执行，并在执行过程中建立客观的记录作为审计的依据。

2．实施与运行

通过风险评估确定所识别信息资产的信息安全风险以及处理信息安全风险的决策，形成信息安全要求。选择和实施控制措施以降低风险。控制措施需要确保风险降至可接受的水平，同时考虑到国家、国际立法和条例的要求和限制、组织的安全目标、组织对操作的要求和限制。

信息安全是建立在费效比的适度安全基础之上，需要考虑降低风险方面的实施和运营成本，并保持与组织的要求和限制成正比；通过实施这些措施来监测、评估和提高信息安全控制的效率和有效性，以支持组织的目标。控制的选择和实施应在适用性声明中形成文件，以协助达标要求。控制措施的实施和运行方面的投资与信息安全事件可能导致的损失之间需要取得平衡。

在系统和项目需求规格和设计阶段考虑信息安全控制。如果不这样做可能会导致额外的成本和较低效的解决方案，并且可能在最坏的情况下无法实现足够的安全性。有必要认识到，一些控制措施可能不适用于每个信息系统或环境，并且可能不适用于所有组织。

有时候需要时间来实施一套选定的控制措施，在此期间，风险水平可能高于长期可以承受的水平。风险标准应该在控制措施实施的同时涵盖短期风险承受能力。应当随着控制措施的逐步实施，了解在不同时间点评价或预期的风险水平。

3．监视和评审

组织需要通过根据组织政策和目标，监控和评估绩效来维护和改进 ISMS，并将结果报告给管理层进行审核。ISMS 审核将检查 ISMS 是否包含适用于在 ISMS 范围内处理风险的特定控制。此外，根据这些监测区域的记录，提供验证证据，以及纠正、预防和改进措施的可追溯性。

（1）监测、测量、分析和评价

在评价信息安全性能和 ISMS 的有效性时，应该确定需要监测和测量的对象，包括信息安全过程和控制措施；选择适用的监测、测量、分析和评价方法以确保有效的结果。确定何时、何人执行监测和测量以及对结果的分析。测量过程需要保留适当的记录信息作为监测和测量结果的证据，并形成文件。

（2）内部审核

内部审核是在计划的时间间隔进行，目的是提供信息确定 ISMS 是否符合组织自身对 ISMS 的要求和对本国际标准的要求。是否对信息安全管理体系定期进行有效的实施和维护。在此基础上组织需要计划、建立、实施和维持审计项目，包括审计频率、方法、责任、计划要求和报告。审计过程应考虑到相关过程的重要性和以前的审计结果；正确定义审计标准和每个审计的范围；选择审核员和审核的实施，确保审核过程的客观性和公正性；审核结束后要确保审计结果报告至相关管理者并保留记录信息作为审计项目和审计结果的证据。

（3）管理评审

组织的管理者按计划的时间间隔评审组织的 ISMS，确保其持续的适宜性、充分性和有效性。在管理评审中需要包括以往管理评审行为的状态；ISMS 相关的外部和内部事件的变化；信息安全性能的反馈，包括不符合和纠正措施、监测和测量结果、审计结果和信息安全目标的实现。

评审要重视利益相关方的反馈，通过风险评估的结果和风险处置计划的状态提供持续改进的机会。

管理评审的输出应包括持续改进机会相关的决定和任何 ISMS 需要的变化。

4．维护和改进

持续改进信息安全管理系统的目的是提高实现保护信息机密性、可用性和完整性目标的可能性。持续改进的重点在于寻求改进的机会，而不是假设现有的管理活动足够好或尽可能好。

改进行动包括不符合和纠正措施以及持续改进两个环节。

（1）不符合和纠正措施

组织应该分析和评估现有情况，找出需要改进的地方；当不符合时，组织需要重现不符合，如适用采取行动控制，修正其事项并处理事项的后果；评估消除不符合原因需要的行为，通过评审不符合项、确定不符合的原因并确认有相似的不符合存在或者潜在的不符合发生的情况以促使其不复发或不在其他地方发生。

在建立纠正措施之后，需要对改进的地方进行评审，以确定纠正行为的有效性。如果有必要，应该改变 ISMS 的政策。修正措施应该与所遇不符合效果适当，并且在纠正过程中形成文件以保留记录信息作为以下证据。

（2）持续改进

必要时对结果进行审查以确定进一步的改进机会。以这种方式，改进是持续的活动，即动作频繁重复。客户和其他利益相关方的反馈，信息安全管理体系的审计和审查也可以用来确定改进的机会。组织需要持续改进 ISMS 的适宜性、充分性和有效性，定期的改进有助于组织形成信息安全管理水平的螺旋式上升。

3.3.4 文档化

1. 体系文件分类

信息安全管理体系是建立在文档化基础之上，信息安全管理体系文件的建立和管理遵从质量管理体系文件规范和要求。体系文件的分类如图 3-7 所示。

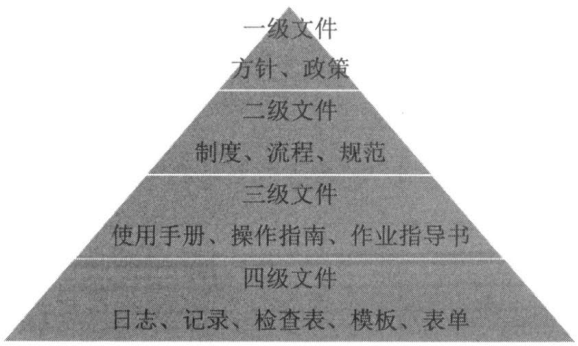

图 3-7 体系化文件结构

管理体系的文档化分为文件和记录两部分。文件是管理体系审核的依据，记录是管理体系审核的证据。因此，两者都需要得到妥善的使用和保存。文档和记录可以是任何形式或任何介质。层次化的文件结构是构成管理体系的重要内容之一，通常文件分为 4 个层级。

- 一级文件：由高级管理层发布，适用于整个组织所有成员及外部相关的第三方机构与人员，组织成员只有充分理解组织的宏观信息安全管理战略，才能更好地遵循下一级文件的执行。
- 二级文件：由组织管理者代表签署发布，该文件针对组织宏观战略提出的目标建立组织内部的“法”。组织成员必须遵守该级别文件，通过文件来约束员工的行为，以确保组织战略得到有效的贯彻和落实。二级文件发布范围通常在组织内部。
- 三级文件：该级别文件包括员工具体执行所需的手册、指南和作业指导书，因此，该级别文件应针对具体的岗位、角色建立发布和落实。文件要求每一个成员都能

依据文件来建立使用，并在执行过程中形成充分的记录。

- 四级文件：为了有效支撑文件的执行，文件必须包含记录，四级文件是对整个组织所形成的检查列表、表单、日志等记录性文件建立归类，每个文件理论上都应该形成相应的记录，因此四级文件也是我们通常所说的审核证据。由于四级文件中可能记录组织敏感信息，因此对四级文件的调阅需要遵循组织的相关制度，限制对文件的随意访问。

2．文件控制

（1）文件的建立

文件的建立是在风险评估过程中针对组织不可接受风险而创建的管理约束，只有在有风险的地方才需要建立文件，通过文件控制风险的蔓延和影响。随着组织的不同，文件的范围也不相同，同样的文件很难在不同的组织中得到有效的应用，而文件需要依据组织的大小、业务活动的类型及被管理系统及安全需求复杂性和范围而建立。

文件应包括管理层决策的记录，确保措施可以追溯到管理层决策和策略，确保记录结果是可重复；重要的是能够证明所选择的控制措施与风险评估和风险处理过程的结果之间的关系，以及追溯到信息安全管理策略和目标。

（2）文件的批准与发布

文件的批准和发布是随着文件的层级不同而不同，高层领导负责签署并发布组织宏观战略文件，通过领导力强制在组织内部执行体系的推动和策略。文件的发布必须得到批准，以确保文件的充分性。

（3）文件的评审与更新

文件必须获得持续的更新，在动态的安全风险中，组织随着管理的变更、业务的变更、技术的变更等一系列的变更，需要对文件体系进行评审和更新。更新应该是定期的（通常每年一次），也可以在组织认为出现重大变更后执行更新。文件的更新需要通过信息安全相关领导组织进行评审，只有通过评审的文件才能被再次执行，并废弃旧的文件。

（4）文件保存

文件的保存根据文件的层级不同而不同，确保需要文档的人可以获得有效文档，根据他们的分类进行传输、存储和最终的销毁，并且确保在使用处可获得适用文件的有关版本。文件需要保持清晰、易于识别以及在发放过程中得到控制，防止不当的发布导致组织敏感信息的泄露。

（5）文件作废

防止作废文件的非预期使用；文件在更新后应该销毁旧版本文件，如果因为其他因素需要保留时，需要对这些文件进行适当的标识。

3．记录管理

（1）记录的作用

记录作为提供符合要求和信息安全管理体系的有效运行的证据需要保护和控制。记录

不仅是审核信息安全管理体系执行力的证据，同样也是组织建立有效的问责和事件跟踪的重要证据。

（2）记录的管理

信息安全管理体系应该考虑任何有关的法律、法规和合同责任的要求。记录需要保持清晰、易于识别和检索。记录的标识、储存、保护、检索、保存期限和处置所需的控制应文件化并实施。

应保留过程执行记录和所有与信息安全管理体系有关的安全事故发生的记录。记录的例子如访问者的签名簿、审核记录和完整的授权访问记录。

3.4 知识子域：信息安全管理体系最佳实践

3.4.1 信息安全管理体系控制类型

控制措施是指企业根据风险评估结果，结合风险应对策略，确保内部控制目标得以实现的方法和手段。控制措施的目的是改变流程、政策、设备、实践或其他行动的风险。控制可以是预防性、检测性或纠正性。

1. 预防性控制

预防性控制是为了避免产生错误或尽量减少今后的更正性活动，是为了防止资金、时间或其他资源的损耗而采取的一种预防保证措施。预防性控制可防止不良事件的发生。例如，要求访问系统的用户 ID 和密码。它阻止未经授权的人访问系统。从理论的角度来看，出于显而易见的原因，首先选择预防性控制。

2. 检测性控制

建立检测性控制的目的是发现流程中可能发生的安全问题。被审计单位通过检测性控制，监督其流程和相应的预防性控制能否有效地发挥作用。检测性控制通常是管理层用来监督实现流程目标的控制，可以由人工执行，也可以由信息系统自动执行。例如，记录系统上执行的所有活动将允许您查看日志以在事件发生后查找不适当的活动。

3. 纠正性控制

纠正性控制措施无法阻止安全事件的发生，但提供了一种系统的方式来检测何时发生了安全事件并对安全事件带来的影响进行纠正。例如，对信息系统中的数据进行备份，当发生系统故障或硬盘故障后，通过备份可以避免这些问题导致的数据丢失。

3.4.2 信息安全管理体系控制措施结构

在 ISO/IEC 27002 中，标准定义了控制措施的分类，每一个主要安全类别包含：一个

控制目标，声明要实现什么；可被用于实现该控制目标的一个或多个控制措施。控制措施的描述结构如下。

- **控制措施**：定义满足控制目标的特定的控制措施的陈述。
- **实施指南**：为支持控制措施的实施和满足控制目标，提供更详细的信息。本指南的某些内容可能不适用于所有情况，可能无法满足组织的具体控制要求。
- **其他信息**：提供需要考虑的进一步的信息，例如法律方面的考虑和对其他标准的引用。如无其他信息，本项即被省略。

控制措施示例如下。

控制类：

信息安全方针-信息安全管理指导。

控制目标：

依据业务要求和相关法律法规提供管理指导并支持信息安全。

控制措施：

信息安全方针

信息安全方针应由管理者批准、发布并传达给所有员工和外部相关方。

实施指南：

组织应在最高层次定义“信息安全方针”，该方针应获得管理层批准并阐述组织管理信息安全目标的方法。

……

其他信息：

组织内部信息安全方针的需要各不相同。内部方针在大型和复杂型组织中尤其有用，在这些组织中，控制措施的预期水平的定义和批准部门与控制措施的执行部门或地点相互分离。信息安全政策可以作为单一的“信息安全策略”文件或一组相关的文件。

如果信息安全方针在组织外进行分发，宜注意不要泄露敏感信息。

一些组织使用短语诸如“标准”“指导”或是“规则”。

ISO/IEC 27002 中规定的控制措施被认为是适用于大多数组织的最佳实践，并很容易适应各种规模和复杂性的组织。ISMS 系列标准中的其他标准为信息安全管理体系的 ISO/IEC 27002 控制的选择和应用提供指导。

组织可以根据 ISMS 所提供的控制措施进行裁剪，并且在适用性声明（SoA）中阐述选择的措施以及未选择措施的原因。在 ISO/IEC 27002:2013 中，将控制措施划分为 14 个安全控制章节、35 个主要的安全类别和 113 个控制措施，如图 3-8 所示。

信息安全通过包括方针、过程、规程、组织结构和软硬件功能在内的一系列适当的控制措施实现。在必要时，控制措施需要建立、实施、监视、审查和改进以确保其满足组织特性的安全和业务目标。

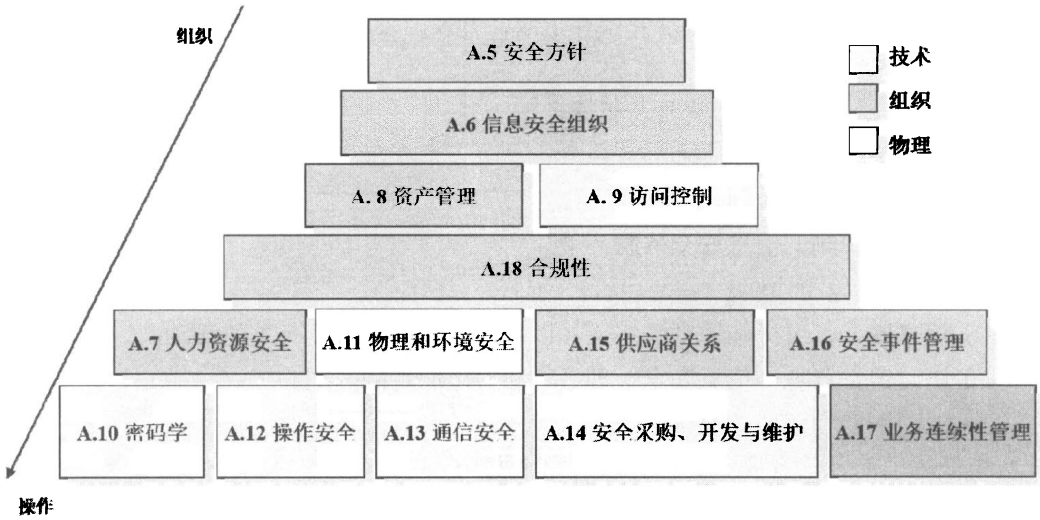

图 3-8　信息安全管理控制措施

控制措施可以来自于 ISO/IEC 27002:2013 标准或其他控制集合，或适当时针对特殊的要求设计新的控制措施。

控制措施的选择取决于组织决策，该决策的建立基于风险接受标准、风险处置方案、组织应用的通用风险管理方法；控制措施的选择也必须遵守所有相关的国家相关法律法规。同时控制措施的选择也取决于控制措施之间相互作用以提供纵深防御的方式。

3.4.3　信息安全管理体系控制措施

1. 信息安全方针

信息安全方针包含 1 个控制目标 2 个控制措施。

5 信息安全方针		
5.1 信息安全管理指导		
目标：依据业务要求和相关法律法规提供管理指导并支持信息安全。		
5.1.1	信息安全方针	控制措施 信息安全方针应由管理者批准、发布并传达给所有员工和外部相关方。
5.1.2	信息安全方针的评审	控制措施 宜按计划的时间间隔或当重大变化发生时进行信息安全方针评审，以确保它持续的适宜性、充分性和有效性。

组织应在最高管理层（例如由董事会或局长办公会）定义“信息安全方针”并形成正式文件。方针主要阐述组织管理信息安全目标的方法。该方针应获得管理层批准签字。需要组织通过正式公告、宣传培训等方式对全体员工和外部相关方发布组织的“信息安全方针”，必要时可以留存宣传培训记录。一般在每次管理评审后，信息安全方针可能会被修

订，修订结果也应获得管理层批准并留存记录，并及时发布传达。同时将旧的信息安全方针宣传材料及时处理。

信息安全方针应与以下相关要求相符合。

（1）业务策略。

（2）法律、法规和合同。

（3）当前和预测的信息安全威胁环境。

方针建议包括以下声明。

（1）信息安全，目标和原则的定义，以指导所有信息安全有关的活动。

（2）用以定义角色的信息安全管理一般和特定职责的分配。

（3）处理偏差和意外的流程。

在稍低的层面，信息安全方针应由特定主题的方针支持，例如网络安全方针、移动办公安全方针、外部第三方合作伙伴安全方针等。这些特定的主题强制实施信息安全控制措施，通常解决组织内某些目标群体的需求或覆盖某些主题。

每一条特定方针应该有一个责任人，由其负责并对该方针的制定、审查和评估负有管理责任。安全方针的审查应包括评估改进组织方针的时机和响应组织环境、业务环境、法律条件或技术环境变更的信息安全管理方法。信息安全方针的评审应考虑到每次管理评审的结果。

2．信息安全组织

信息安全组织包含 2 个控制目标 7 个控制措施。

<table>
<tr><td colspan="3">6 信息安全组织</td></tr>
<tr><td colspan="3">6.1 内部组织</td></tr>
<tr><td colspan="3">目标：建立一个管理框架，用以启动和控制的组织内信息安全的实施和运行。</td></tr>
<tr><td>6.1.1</td><td>信息安全的角色和职责</td><td>控制措施
所有的信息安全职责应予以定义和分配。</td></tr>
<tr><td>6.1.2</td><td>职责分离</td><td>控制措施
应分离冲突的职责和责任范围以减少公司资产未经授权、无意的修改或误用的机会。</td></tr>
<tr><td>6.1.3</td><td>与政府部门的联系</td><td>控制措施
应保持与政府相关部门的适当联系。</td></tr>
<tr><td>6.1.4</td><td>与相关利益方的联系</td><td>控制措施
应保持与相关利益方、其他安全专家组和专业协会的适当联系。</td></tr>
<tr><td>6.1.5</td><td>项目管理中的信息安全</td><td>控制措施
无论什么项目类型，都应在项目管理中解决信息安全问题。</td></tr>
</table>

组织应该将与信息安全方针相一致的信息安全职责进行分配，例如资产保护的职责、执行特定安全过程（例如防病毒系统升级、风险评估、漏洞扫描、安全监测等）的职责、

风险管理行为的职责。分配有安全职责的人员可以将安全任务委托给其他人员，但他们仍然负有责任，并且能够确定任何被委托的任务是否已被正确地执行。在许多组织中，会任命一名信息安全管理人员全面负责各项安全技术的开发应用和各项安全管理措施实施，并支持控制措施的识别。然而，提供控制措施资源并实施这些控制措施的职责通常归于各个系统管理人员。一种通常的做法是为每一项资产指定一名责任人负责该项资产的日常保护。

要做好职责分离，确保不会有人能在非授权和不被监测的情况下访问、修改和使用资产。一般建议将系统管理员、安全管理员、日志审计员 3 种角色进行分离，由不同人员担任，并要求不能兼任。在设计控制时还应考虑相互串通的可能。对于小型组织而言，职责分离也许难以实现，但是应该尽可能和尽可行地考虑职责分离。当职责难以分离时，应考虑其他控制措施如监控活动、审计跟踪和管理监督等。

组织要有规程指明什么时候与哪个部门（如执法部门、供电局、消防部门、监管部门）联系，以及怀疑已识别的信息安全事件可能触犯了法律时，要如何及时报告。例如，受到来自互联网的攻击时，组织可能需要执法部门采取对攻击源行动；与制定信息安全法律法规部门的联系有助于预先知道组织必须遵循的法律法规方面预期的变化；与其他部门的联系包括公共设施、紧急服务和健康安全部门，例如供电局（与业务连续性有关）、消防部门（与业务连续性有关）、电信服务提供商（与路由和可用性有关）、供水部门（与设备的冷却设施有关）。

组织要和相关利益方（客户或供应商）、其他安全专家组和专业协会保持适当的联系，以便：

（1）增进对最佳实践和最新相关安全信息的了解。

（2）确保全面了解当前的信息安全环境。

（3）尽早收到关于攻击和脆弱性的预警、建议和补丁。

（4）获得信息安全专家的建议。

（5）分享和交换关于新的技术、产品、威胁或脆弱性的信息。

（6）提供处理信息安全事件时适当的联络点。

组织应将信息安全整合进项目管理方法中，以确保信息安全风险作为项目风险的一部分被识别和解决。这一般要求适用于任何性质的项目，如项目核心业务流程、IT、设施管理和其他配套工艺。项目管理方法应要求：

（1）项目目标包含信息安全目标。

（2）项目的早期阶段应进行信息安全风险评估以识别需要的控制措施。

（3）应用的项目方法的所有阶段都应将信息安全作为其一部分。

在所有项目中应定期解决和审查信息安全问题，应按照项目管理方法中的定义将信息安全责任定义和分派到指定角色。

6.2 移动设备和远程办公		
目标：确保远程办公和使用移动设备时的安全性。		
6.2.1	移动设备方针	控制措施 应采用方针和配套保障措施以管理使用移动设备时带来的风险。
6.2.2	远程工作	控制措施 应实施方针和配套保障措施以保护远程工作地点的信息访问、处理和存储。

当使用移动设备（包括笔记本电脑、平板电脑、智能手机）或远程工作（从家庭或出差地远程访问公司内部网络）时，应特别注意确保业务信息不外泄。移动设备方针应考虑与非受保护环境移动设备同时工作时的风险。当在公共场所、会议室和其他不受保护的区域使用移动计算设施时，要加以小心。应采取保护措施以避免这些设备存储和处理的信息未授权的访问或泄露，如使用加密技术、强制使用秘钥身份验证信息、移动设备本身支持的各种安全技术（不允许安装未知来源的 APP、启用多因素身份鉴别、移动设备丢失后的远程锁定和敏感数据清除等）。

要对移动计算设施进行物理保护，以防被偷窃或因为疏忽遗失，例如，遗留在汽车和其他形式的交通工具上、旅馆房间、会议中心和会议室。要为移动计算设施的被窃或丢失等情况建立一个符合法律、保险和组织的其他安全要求的特定规程。携带重要、敏感或关键业务信息的移动设备不宜无人值守，若有可能，要以物理的方式锁起来，或使用专用锁来保护设备。

对于使用移动计算设施的人员要安排培训，以提高他们对这种工作方式导致的附加风险的意识，并且要根据风险评估结果实施相应的控制措施。

在允许远程工作时，组织要制定相应的安全方针，定义远程工作的条件和限制。安全方针要包括物理、通信、网络、软件、数据、使用人员、安全技术等方面的要求。这里的远程工作包括了办公室以外的所有形式的工作，以及非传统工作环境比如那些被称为“远程办公”“弹性工作场所”“远程工作”“虚拟工作”环境。

3．人力资源安全

人力资源安全包含 3 个控制目标 6 个控制措施。

7 人力资源安全		
7.1 任用之前		
目标：确保雇员、承包方理解其职责，对其考虑的角色是适合的。		
7.1.1	审查	控制措施 关于所有任用的候选者与承包商的背景验证核查应按照相关法律法规、道德规范和对应的业务要求、被访问信息的类别和察觉的风险来执行。
7.1.2	任用条款及条件	控制措施 应在雇员和承包商的合约协议中声明他们与组织的信息安全责任。

在相关的隐私、个人数据保护及与任用相关的法律允许下，要对所有任用的候选者与承包商委派的人员的背景进行核验，包括个人资料、个人履历、学术和专业资质、个人身份核查，以及其他如信用卡核查或犯罪记录核查。未能通过审查或未能提供相关证明资料的人员不能够使用组织信息系统。

对于特定的信息安全岗位（例如系统管理员、安全管理员、日志审计员等），还要确定该候选人具备执行该安全角色所必需的能力，并且担当该角色时是可被信任的，尤其该角色对组织而言至关重要时。必要时可以开展针对性的任前考核，必须在考核通过后才能够担任相关岗位。不应由承包商委派人员担任以上岗位。

在任用前与候选者或承包商委派人员签订的合同协议中应该有专门的条款和条件要反映组织的安全方针，包括关于保密性、数据保护、道德规范、组织设备和设施的适当使用以及组织期望的信誉良好的实践等。对于拟担任特定信息安全岗位的候选人在任用之前，要和候选人交流信息安全角色和职责相关信息并留存取得一致认识的正式文件，例如承诺书、任务书等。

7.2 任用中		
目标：确保雇员、承包方意识并履行其信息安全职责。		
7.2.1	管理职责	控制措施 管理者应要求所有雇员和承包商按照组织已建立的方针策略和规程对安全尽心尽力。
7.2.2	信息安全意识、教育和培训	控制措施 适当时，组织的相关雇员和承包商应受到与其工作职能相关的适当的意识培训和组织方针策略及规程的定期更新培训。
7.2.3	纪律处理过程	控制措施 对于安全违规的雇员，应有一个正式的纪律处理过程。

管理者应该表现对信息安全政策、程序和控制措施的支持，并以身作则。管理职责要确保雇员和承包商委派人员都了解其应遵守的信息安全政策、程序和控制措施，并遵守相应的条款和条件。

组织委托人力资源管理部门或信息安全管理部门建立信息安全意识教育培训计划，并定期组织信息安全宣传、教育和培训。信息安全教育和培训应涵盖以下方面。

（1）说明管理层对整个组织的信息安全的承诺。

（2）各类信息安全方针、标准、法律法规、合同和协议中定义的要求和遵守适用的信息安全规则和义务的需要。

（3）对个人作为和不作为的问责制度，以及保护组织和外部各方信息安全的一般责任。

（4）基本信息安全规程（如信息安全事件报告）和底线控制措施（如密钥安全性、恶意代码控制和清除桌面等）。

（5）外部办公地点和其他信息资源的信息安全问题的建议，包括信息安全的进一步教

育和培训的素材。

组织要建立正式的信息安全违规纪律处理制度和处置流程，确保正确和公平地对待被怀疑安全违规的雇员。纪律处理过程要规定分级的响应处置规程，根据违规的性质、重要性及对于业务的影响等因素决定处罚的方式和程度，严重的可能需要追究其相关法律责任、终止业务合同等。

7.3 任用的终止和变化		
目标：将聘用的变更或终止作为组织过程的一部分以保护组织的利益。		
7.3.1	雇佣责任的改变和终结	控制措施 应与雇员和承包商交流并强化定义的在雇佣改变或终止时仍有效的信息安全责任和义务。

在雇员离职或调岗、承包商委派人员完成工作离场时，应由组织安全管理人员与其就任用终止或变化后的信息安全职责和义务取得一致并留存正式文件，例如《离职信息安全保密协议》，其中应包括组织的安全要求和法律职责。适当时，还包括保密协议规定的职责。在雇员、承包方人员的合同中也应该有相应条款，并且确保在职责或任用变更后仍然受到必要的信息管理。

4．资产管理

资产管理包含 3 个控制目标 10 个控制措施。

8 资产管理		
8.1 对资产负责		
目标：标识组织资产并确定适当的保护责任。		
8.1.1	资产清单	控制措施 应标识与信息和信息处理设施相关的资产，制定并保留资产清单。
8.1.2	资产责任人	控制措施 应确定资产清单中的资产责任人。
8.1.3	资产的可接受使用	控制措施 应确定、记录并实施与信息处理设施有关的信息和资产可接受使用规则。
8.1.4	资产归还	控制措施 所有的雇员和外方用户在终止任用、合同或协议时，应归还他们使用的所有组织资产。

组织要根据相关法律法规、业务目标相关性识别信息生命周期中相关的重要资产并形成一份统一的信息资产清单，并确定每一项重要资产的责任人和信息分类。信息生命周期包括信息的创建、处理、存储、传输、删除和销毁。资产管理文件应使用适当的专有文件或现有清单并予以维持，资产清单要准确，实时更新并与其他清单保持一致。

组织应确定信息和资产安全管理制度、记录并实施与信息处理设施有关的信息和资产

可接受使用规则。使用或拥有资产访问权的雇员和承包方人员要意识到他们使用信息处理设施相关的信息和资产以及资源时的限制条件。他们要对其使用信息处理资源以及在他们职责下的不当使用造成的结果负责，例如违规外带存储敏感数据的笔记本导致丢失。

所有的雇员和外方用户在终止任用、合同或协议时，应归还他们使用的所有组织资产（包括计算机、U-key、智能手机等）。当雇员或外部人员购买了组织淘汰的设备或临时使用他们自己的设备处理组织业务时，要遵循规程确保所有组织相关的信息已转移给组织，并且已从设备中安全地删除。在终止过程中，组织要通过雇员和承包商控制未授权的相关信息备份（如设计图、技术方案、知识产权）。

8.2 信息分类		
目标：确保信息按照其对组织的重要程度受到适当级别的保护。		
8.2.1	信息分类	控制措施 信息应按照其法律要求、价值，对泄露或篡改的敏感性和关键性予以分类。
8.2.2	信息的标记	控制措施 应按照组织所采纳的分类机制建立和实施一组合适的信息标记规程。
8.2.3	资产的处理	控制措施 应按照组织所采纳的分类机制建立和实施一组合适的资产处理规程。

组织应制定信息安全管理制度，组织信息应按照其法律要求、价值，对泄露或篡改的敏感性和关键性予以分类（例如定义为可对外公开、内部公开、内部某部门公开、内部特定人员公开等类别）。信息资产的所有者应对其分类负责。分类的结果表明了该资产的价值，该价值取决于其对组织业务目标的敏感性和关键性，如保密性、完整性和有效性。

信息要进行标记并体现其分类，标记的规程需要涵盖物理和电子格式的信息资产。分类信息的标记和安全处理是信息共享的一个关键要求。物理标签和元数据标签是常见的形式。标记应易于辨认且不易篡改，规程应对标记附着的位置和方式给出指导，并考虑到信息被访问的方式和介质类型的处理方式。

组织要建立与信息分类一致的资产处理、加工、存储和交换规程。

8.3 介质处置		
目的：防止介质存储信息的未授权泄露、修改、移动或销毁。		
8.3.1	可移动介质的管理	控制措施 应根据组织所采用的分类方案实施适当的可移动介质的管理规程。
8.3.2	介质的处置	控制措施 对于不再需要的介质，应使用正式的规程可靠并安全地处置。
8.3.3	物理介质传输	控制措施 应保护包含信息的介质以防未经授权的访问、滥用或在运输过程中的毁坏。

对于可移动介质，应建立与信息分类方案相对应的管理规程。根据相应规程确定可移动介质可以存储哪类信息。

对于不再需要的介质，要建立安全处置介质的正式规程，以使敏感信息泄露给未授权人员的风险减至最小。安全处置包含敏感信息介质的规程宜与信息的敏感性相一致。组织还要注意，当处置堆积的介质时要考虑集合效应，它可能使大量不敏感信息变成敏感信息。所有介质的处置应该留存处置记录。

存储信息的介质在物理传输期间易受未授权访问、不当使用或破坏。组织要保护包含信息的介质在传输中的安全，这里的介质包括纸质文档和电子信息。当介质的保密信息未加密时，宜考虑额外的物理防护，例如保密文件箱。

5．访问控制

访问控制包含 4 个控制目标 14 个控制措施。

9 访问控制		
9.1 访问控制的业务要求		
目标：限制对信息和信息处理设施的访问。		
9.1.1	访问控制方针	控制措施 应建立访问控制策略并形成文件，并基于业务和访问的安全要求进行评审。
9.1.2	网络和网络服务的访问	访问控制 用户应仅能访问已获专门授权使用的网络和网络服务。

组织应建立统一的访问控制策略并形成正式文件。资产责任人应决定访问其资产的指定用户的适当的访问控制规程、访问权利和限制，访问控制策略须有适量的细节和严格的控制措施，以反映相关的信息安全风险。访问控制包括逻辑的和物理的，它们要一起考虑。要给用户和服务提供商提供一份清晰的满足业务要求的说明。在规定访问控制规则时，建议在“未经明确允许，则一律禁止”的前提下，而不是“未经明确禁止，一律允许”的弱规则的基础上建立规则。访问控制策略须适用于物理环境、网络、服务器、终端、应用系统和信息等多类对象，并分别留存不同用户的访问控制授权记录。

组织要制定关于使用网络和网络服务的策略。网络服务使用策略要与业务访问控制策略相一致，并留存网络日志。

9.2 用户访问管理		
目的：确保授权用户访问系统和服务，并防止未授权的访问。		
9.2.1	用户注册和注销	控制措施 应实施正式的用户注册及注销规程以启用访问权限分配。
9.2.2	用户访问配置	控制措施 应对所有系统和服务的所有类型用户实施正式的用户访问配置过程以指定或撤销访问权限。
9.2.3	特殊权限管理	控制措施 应限制和控制特殊权限的分配及使用。

9.2.4	用户的秘密验证信息管理	控制措施 应通过正式的管理过程控制秘密验证信息的分配。
9.2.5	用户访问权的复查	控制措施 管理者应定期对用户的访问权进行复查。
9.2.6	访问权限的移除或调整	控制措施 所有的雇员和外方用户在终止任用、合同或协议时，应终止并移除其访问权限。

组织应建立正式的用户注册及注销规程。用户 ID 管理过程应该包括以下方面。

（1）使用唯一用户 ID，使得用户与其行为链接起来，并对其行为负责；只有在进行必要的业务或操作时才允许使用组 ID，应经过批准并形成文件。

（2）立即关闭或移除离开组织的用户 ID，将其作为雇员离职或承包商验收的一个必须环节。

（3）定期核查系统，取消或停用多余的、长期未使用的用户 ID 和账号。

（4）确保多余的用户 ID 不会发给其他用户。

组织要对用户 ID 分配或吊销访问权限，宜考虑基于业务要求建立不同的用户访问角色，将一部分访问权赋予典型的用户访问角色中。

特殊访问权限的分配应通过符合相关控制方针的正式授权过程加以控制。

秘密验证信息，通常是密码或者加密密钥和存储在硬件令牌的生成验证码的其他数据（如智能卡），要建立正式的管理过程进行控制。

管理者应定期对用户的访问权进行复查。包括要定期和在任何重大变更之后对用户的访问权进行复查，包括提升、降级或雇用终止，以及变换岗位时。对于特定的特殊权限的访问权的授权要在更频繁的时间间隔内进行复查；要定期核查特殊权限的分配访问控制表，以确保不能获得未授权的特殊权限。

所有的雇员和承包商委派人员在终止任用、合同或协议时，应终止并移除其访问权限。任用终止时，个人对与信息处理设备系统和服务有关的信息和资产的访问权宜清除或暂停。宜删除或改变的访问权包括物理和逻辑访问。对于组 ID，离开的人员要从组访问列表中删除，还要建议所有相关的其他雇员和外部人员不宜再与已离开的人员共享信息。

9.3 用户职责		
目的：使用户负责维护其授权信息。		
9.3.1	秘密验证信息的使用	控制措施 应要求用户遵循组织在使用秘密验证信息时的习惯。

用户应遵循组织在使用秘密验证信息时的习惯，保密秘密验证信息，确保其不被泄露至包括授权人员在内的任何人。避免保留秘密验证信息的记录（例如在纸上、软件文件中或手持设备中），当使用口令作为秘密验证信息时，建议选择尽可能长的容易记忆的密码。个人用户的秘密验证信息不允许共享；当使用口令作为秘密验证信息时，在自动登录过程中确保口令得到保护；要求雇员和承包商委派人员工作中和生活中使用不同的秘密验证信息。

9.4 系统和应用访问控制		
目的：防止对系统和应用的未授权访问。		
9.4.1	信息访问限制	控制措施 应依照已确定的访问控制策略限制对信息和应用系统功能的访问。
9.4.2	安全登录规程	控制措施 当访问控制方针要求时，应通过安全登录规程控制对系统和应用的访问。
9.4.3	口令管理系统	控制措施 口令管理系统应是交互式的，并应确保优质的口令。
9.4.4	特权实用程序的使用	控制措施 对于可能对系统和应用控制措施造成致命影响的实用工具和程序的使用应加以限制并严格控制。
9.4.5	程序源代码的访问控制	控制措施 应限制对程序源代码的访问。

组织应依照已确定的访问控制策略限制对信息和应用系统功能的访问。对访问的限制要基于各个业务应用要求，各信息和应用系统的访问控制策略还要与组织统一的访问策略一致。

应建立安全登录规程控制实现对系统和应用的访问。宜选择合适的身份验证技术以验证用户身份。在需要强认证和身份验证时，宜使用如加密技术、智能卡、令牌或生物识别手段等替代口令的身份验证方法。

应建立交互式的口令管理系统，并确保使用优质的口令，一般要求口令长度 8 个字符以上，且易于记忆。

对于可能对系统和应用控制措施造成致命影响的工具或程序（例如格式化工具、数据备份恢复软件、大负荷扫描工具）的使用，应加以限制并严格控制，并编制相应规程，授权使用前应制定应急预案，使用中应实时监测，使用后应进行验证。

对程序源代码和相关事项（例如设计、说明书、验证计划和确认计划）的访问宜严格控制，以防引入非授权功能、避免无意识的变更和泄密维持有价值的知识产权。对于程序源代码的保存，可以通过中央存储控制系统来实现，或者放在源程序库中。

6．密码学

密码学包含 1 个控制目标 2 个控制措施。

10 加密		
10.1 加密控制		
目标：通过加密方法保护信息的保密性、真实性或完整性。		
10.1.1	使用加密控制的策略	控制措施 应开发和实施使用加密控制措施来保护信息的策略。
10.1.2	密钥管理	控制措施 应开发和实施在密钥生命周期中使用和保护密钥的方针。

组织应制定并实施使用加密控制措施来保护不同类别信息的策略，基于风险评估，宜确定需要的保护级别，并考虑采用的加密算法的类型、密钥长度和其他相关参数。当实施组织的密码策略时，宜考虑我国应用密码技术使用的规定和限制，以及加密信息跨越国界时的问题。

组织应制定和实施在密钥生命周期中使用和保护密钥的方针。方针应包括密钥在其全部生命周期中的管理要求，包括密钥的生成、存储、归档、检索、分配、删除和销毁。宜根据最好的实际效果选择加密算法、密钥长度和其他相关参数。适合的密钥管理要求密钥在生成、存储、归档、检索、分配、删除和销毁过程中的安全。宜保护所有的密钥免遭修改和丢失。另外，对称加密算法中使用的秘钥和非对称加密算法中使用的私有密钥需要防范非授权的泄露，用来生成、存储和归档密钥的设备（例如密码芯片、加密机等）应进行物理保护。

7．物理与环境安全

物理与环境安全包含 2 个控制目标 15 个控制措施。

11 物理和环境安全		
11.1 安全区域		
目的：防止对组织场所和信息过程设备的未授权物理访问、损坏和干扰。		
11.1.1	物理安全周边	控制措施 应定义和使用安全周边来保护包含敏感或关键信息和信息处理设施的区域。
11.1.2	物理入口控制	控制措施 安全区域应由适合的入口控制所保护，以确保只有授权的人员才允许访问。
11.1.3	办公室、房间和设施的安全保护	控制措施 应为办公室、房间和设施设计并采取物理安全措施。
11.1.4	外部和环境威胁的安全防护	控制措施 应设计和应用物理保护以防自然灾害、恶意攻击和意外。
11.1.5	在安全区域工作	控制措施 应设计和应用安全区域工作规程。
11.1.6	送货和装卸区	控制措施 访问点如送货和装卸区和未授权人员可进入办公场所的其他点应加以控制，如果可能，应与信息处理设施隔离，以避免未授权访问。

组织应定义安全边界范围并制定正式文件来保护包含敏感或关键信息和信息处理设施的区域。一个安全区域可以是一个可上锁的办公室，或是被连续的内部物理安全屏障包围的几个房间。在安全边界内具有不同安全要求的区域之间需要部署控制物理访问的附加屏障和围栏。

安全区域应由适合的入口控制所保护，例如门禁系统、专人值守等，以确保只有授权的人员才允许访问。

应为办公室、房间和设施设计并采取物理安全措施，例如门锁、带锁的文件柜、保险柜等，防止未授权人员进入或访问敏感信息。

应制定规程设计和应用物理保护措施以应对各种自然灾害、恶意攻击和意外，例如在机房设置气体消防灭火器避免火灾引起的破坏，类似的还有洪水、地震、爆炸、社会动荡和其他形式的自然灾难或人为灾难的破坏。

应制定和应用安全区域工作规程。要求雇员和承包商委派人员在安全区域内进行工作，以及对其他发生在安全区域的所有活动控制。

访问点如送货和装卸区和未授权人员可进入办公场所的其他点应加以控制，如果可能，应与信息处理设施隔离，以避免未授权访问。

11.2 设备安全		
目标：防止资产的丢失、损坏、失窃或危及资产安全以及组织活动的中断。		
11.2.1	设备安置和保护	控制措施 应安置或保护设备，以减少由环境威胁和危险所造成的各种风险以及未授权访问的机会。
11.2.2	支持性设施	控制措施 应保护设备使其免于由支持性设施的失效而引起的电源故障和其他中断。
11.2.3	布缆安全	控制措施 应保证传输数据或支持信息服务的电源布缆和通信布缆免受窃听或损坏。
11.2.4	设备维护	控制措施 设备应予以正确地维护，以确保其持续的可用性和完整性。
11.2.5	资产的移动	控制措施 设备、信息或软件在授权之前不应带出组织场所。
11.2.6	组织场所外的设备安全	控制措施 应对组织场所的设备采取安全措施，要考虑工作在组织场所以外的不同风险。
11.2.7	设备的安全处置或再利用	控制措施 包含储存介质的设备的所有项目应进行核查，以确保在处置之前，任何敏感信息和注册软件已被删除或安全地写覆盖。
11.2.8	无人值守的用户设备	控制措施 用户应确保无人值守的用户设备有适当的保护。
11.2.9	清空桌面和屏幕方针	控制措施 应采取清空桌面上文件、可移动存储介质的策略和清空信息处理设施屏幕的策略。

应安置或保护设备，以减少由环境威胁和危险所造成的各种风险以及未授权访问的机会。例如，将设备安置在特点工作区域，以尽量减少其他无关人员对该工作区域的访问；把处理敏感数据的信息处理设施放在适当的位置，以减少在其使用期间信息被无授权人员窥视的风险；保护存储设施以防止未授权访问；对于有特殊保护的设施、设备予以单独隔离，避免因为其导致其他设备设施必须采用较高的总体保护等级。

要保护设备的支持性设施安全（如电力、电信、供水、燃气、排污、通风和空调），避免由于支持性设施的失效而引起的电源故障和其他中断。可以设计网络连接的冗余设备，并尽可能选择多家设备提供商提供设备或服务。

应保证传输数据或支持信息服务的电源布缆和通信布缆免受窃听或损坏。进入信息处理设施的电源和通信线路宜在地下或墙体中。若可能，尽量提供足够的可替换的保护，例如同时部署多条线缆以便冗余；为了防止干扰，电源电缆要与通信电缆分开；对于敏感的或关键的系统，还要考虑采用屏蔽机柜或建设屏蔽机房，避免电磁干扰等更进一步的控制措施。

设备应予以正确地维护，以确保其持续的可用性和完整性，包括要按照供应商推荐的检修服务时间间隔和规范对设备进行维护，如果需要承包商委派人员定期修理和维护要进行规范的授权管理和控制。

设备、信息或软件在授权之前不应带出组织限定的安全边界或场所。如果根据实际工作需要必须外带设备，要设置设备移动的时间限制，并在返还时执行符合性核查；设备外带和返回时需要做相应记录以备核查。

应对组织场所的设备采取安全措施，要考虑工作在组织场所以外的不同风险，例如失窃风险。组织外使用信息存储和处理设备须得到管理者的审批授权。这适用于该组织所拥有的设备，也同样适用于为了组织利益使用的私人设备。

设备处置或再利用前，应实施验证以确保是否包含存储介质，例如服务器中的硬盘、打印机中的缓存。如果包含敏感信息的设备再利用前，其中的存储介质应该在物理上予以摧毁，或者采用使原始信息不可获取的技术破坏、删除或多次写覆盖，而不能采用标准的删除或格式化功能。

对于无人值守的用户设备，应确保有适当的保护，例如视频监控、自动故障告警。所有用户应了解保护无人值守的设备的安全要求和规程，以及他们对实现这种保护所负有的职责。

制定保持办公桌面没有无关纸质资料和清空计算机屏幕上“桌面”文件策略能降低正常工作时间之中和之外对组织敏感信息的未授权访问、丢失、破坏的风险。应制定采取清空桌面上文件、可移动存储介质和锁定信息处理设施屏幕的策略，并由专门人员进行检查。清空桌面、锁定屏幕策略宜考虑信息分类、法律和合同要求、相应的风险和组织的文化方面。

8. 操作安全

操作安全包含 7 个控制目标 14 个控制措施。

12 操作安全		
12.1 操作规程和职责		
目标：确保正确、安全的操作信息处理设施。		
12.1.1	文件化的操作规程	控制措施 操作规程应形成文件、保持并对所需用户可用。
12.1.2	变更管理	控制措施 应控制对信息安全有影响的组织、业务流程、信息处理设施和系统变化。
12.1.3	容量管理	控制措施 应对资源的使用进行监控、调整和预测未来的容量需求，以确保所需的系统性能。
12.1.4	开发、测试和运行环境分离	控制措施 开发、测试和运行环境应分离，以减少未授权访问或改变运行系统的风险。

与信息处理和通信设施相关的系统活动应具备文件化的操作规程，例如计算机启动和关机规程、备份、设备维护、介质处理、计算机机房检查、邮件处置管理和安全规程等。操作规程要详细规定执行每项工作的说明和步骤。操作规程要形成正式的文件，其变更由管理者授权，并随时可供所需用户查阅。

对信息处理设施和系统的变更缺乏控制是系统故障或安全失效的常见原因。应制定对信息安全有影响的组织、业务流程、信息处理设施、系统变更制度和变更流程，并留存所有变更记录。在组织、业务流程、信息处理设施和系统有较大变更时及时开展风险评估，识别安全风险变化。

组织应根据组织业务发展的需求，考虑未来一定时间段内（一般是 3～5 年）相关系统业务能力容量要求（例如并发用户量、日新增数据容量、所需网络带宽），应对这些资源的使用进行监控，调整和定期预测未来的容量需求，以确保信息系统具备所需的系统性能。对未来容量要求的推测应综合考虑新业务、系统要求以及组织信息处理能力的当前和预计的趋势。

为防止组织业务生产系统故障，应将业务生产系统和其开发测试环境相隔离，并在开发测试环境和生产环境间采用访问控制措施减少未授权的访问或改变运行系统的风险。

12.2 恶意代码保护		
目标：保护信息和信息处理设施以防恶意代码。		
12.2.1	恶意代码的控制	控制措施 应在结合适当用户意识的基础上实施恶意代码的检测、预防和恢复控制。

防范恶意代码应基于恶意代码检测和修复软件、雇员安全意识、适当的系统访问和变更管理控制措施，并形成正式制度，规定组织对于恶意代码的处置措施。在信息处理环境中使用来自不同防恶意代码供应商的两个或多个软件产品，能改进恶意代码防护的有效性。还可以在网络边界使用防恶意代码网关或开启具有防恶意代码功能的防火墙设备。宜注意防止在实施维护和应急响应期间引入恶意代码，因为它们可能绕过正常的恶意代码防护的控制措施。

12.3 备份		
目标：防止数据丢失。		
12.3.1	信息备份	控制措施 应按照已设的备份策略，定期备份和测试信息、软件和系统镜像的备份副本。

组织要建立备份管理制度以确定组织各类信息、软件和系统的备份要求，并提供足够的备份设备以确保所有的基本信息和软件能在灾难或介质故障后恢复。组织还要监控备份的执行，解决预定备份在执行过程中可能遇到故障告警，以确保基于备份策略备份的完整性。各个系统和服务的备份介质应安排定期恢复测试以确保它们满足业务连续性计划的要求，在恢复测试时须注意恢复到测试环境，以免由于误操作对生产系统造成影响。

12.4 日记记录和监视		
目的：记录事件并生成证据。		
12.4.1	事件日志	控制措施 应产生、保持并定期评审记录用户活动、异常、错误和信息安全事态的事件日志。
12.4.2	日志信息的保护	控制措施 记录日志的设施和日志信息应加以保护，以防止篡改和未授权的访问。
12.4.3	管理员和操作员日志	控制措施 应记录系统管理员和系统操作员活动并定期审查。
12.4.4	时钟同步	控制措施 一个组织或安全域内的所有相关信息处理设施的时钟应与单一的参考源进行同步。

事件日志是安全监测的基础，能够对系统安全状态生成综合报告和警报。组织应该制定安全事件日志管理制度，对产生的事件日志进行保存和定期评审，并留存评审记录。记录中应该包括用户操作、异常告警、错误告警和信息安全事件记录。事件日志可能包含入侵和保密人员的数据，应采取适当的隐私保护措施，一般仅允许日志审计员对事件日志进行操作。日志系统不应该允许系统管理员或安全管理员删除他们自己活动的日志。

组织应该采取控制措施以防止日志设施被未授权访问或更改，可以采用哈希函数等工

具对日志数据进行保护。一般设备由于缓存容量有限，无法保存较长时间的事件日志（根据《网络安全法》要求为 6 个月）可能需要被存档或转存到日志服务器，以作为记录保持策略的一部分和保留证据的要求。

特权用户的账户持有人的操作必须在其直接控制下的信息处理设施留存操作日志。日志审计员有必要保护和审查日志以维持特权用户的可核查性。还可以部署入侵检测系统对在系统和安全管理员控制之外是否有人管理系统或网络进行检测。

审计日志如果要用于调查或作为法律、纪律处理的证据，必须要正确设置各种设备的时钟。时间不准确的审计日志可能妨碍调查，并损害这种证据的可信性。因此，一个组织或安全域内的所有相关信息处理设施的时钟应与单一的参考源进行同步。可以将时间管理服务器链接到国家原子钟无线电广播时间的时钟用于记录系统的主时钟，并启用网络时间协议保持所有服务器与主时钟同步。

12.5 操作软件控制		
目标：确保操作系统的完整性。		
12.5.1	操作系统软件的安装	控制措施 应实施操作系统软件安装控制规程。

对操作系统软件安装方面应制定安装控制规程，一般包括最小安装原则（不安装非必须操作系统组件）、最小授权原则（不启用操作系统默认用户账户），操作系统要仅安装经过批准的正式版可执行代码，不安装开发版代码和编译程序。对于应用和操作系统软件的补丁更新要在一定范围的成功的测试之后才能实施。而且只能由受过培训的管理员，根据合适的管理授权，进行运行软件、应用和程序库的更新；必要时在管理者批准的情况下，仅限于为了软件更好地支持业务，才授予供应商物理或逻辑访问权，并且要委派专人监督供应商的活动。

12.6 技术漏洞管理		
目标：防止对技术漏洞的利用。		
12.6.1	技术脆弱性管理	控制措施 应及时获取正在使用的信息系统的技术脆弱性信息，组织评估这些漏洞并采取适当的措施来解决相关的风险。
12.6.2	软件安装限制	控制措施 应建立并实施管理用户安装软件的规则。

要建立有效的技术脆弱性管理过程，采取适当的、及时的措施以响应潜在的技术脆弱性。组织应建立并定期维护信息系统的特定信息清单，包括软件供应商、版本号、部署的当前状态（例如，哪台服务器上装了什么操作系统，安装什么应用软件），应该由组织内负责软件维护的人员定期更新该清单并负责定期查询国家信息漏洞库 CNNVD 了解是否发

现新的安全漏洞对组织信息系统造成威胁。技术脆弱性管理可被看作是一项变更管理，因此可以利用变更管理的过程和规程。供应商的补丁可能不足以解决该问题，并且可能存在负作用；而且，在某些情况下，一旦补丁被安装后，很难被卸载。应该首先在测试环境中对补丁的安全性（不会导致死机或故障）进行验证。如果不能对补丁进行充分的测试，如由于成本或资源缺乏，那么可以考虑推迟打补丁，以便基于其他用户报告的经验来评价相关的风险。

对于用户能安装何种类型的软件，组织应制定强制执行的严格的软件安全方针，宜使用最小特权方针，即不授予用户操作系统的管理员权限或超级用户权限不允许用户自行安装软件。不受控制的计算机设备上的软件安装可能导致脆弱性，进而导致信息泄露、整体性损失或其他信息安全事件或违反知识产权。

12.7 信息系统审计的考虑		
目标：极小化审计行为对业务系统带来的影响。		
12.7.1	信息系统审计控制	控制措施 应精心计划涉及业务系统验证的审计要求和活动以实现对业务流程的干扰达到最小化。

对于涉及业务系统验证的审计应精心计划其要求和活动，以减小对业务流程的干扰。必要时应将可能对系统造成影响的审计工作安排在非业务高峰时间进行，并提前制定好应急预案。

9．通信安全

通信安全包含 2 个控制目标 7 个控制措施。

13 通信管理		
13.1 网络安全管理		
目标：确保网络中信息的安全性并保护支持性的基础设施。		
13.1.1	网络控制	控制措施 应管理和控制网络以保护系统和应用中的信息。
13.1.2	网络服务安全	控制措施 安全特性、服务级别以及所有网络服务的管理要求应予以确定并包括在所有网络服务协议中，无论这些服务是由内部提供的还是外包的。
13.1.3	网络隔离	控制措施 应从网络中隔离信息服务、用户和信息系统组。

网络管理员应根据统一的访问控制策略实施网络访问控制，以确保网络信息安全、防止人员未授权访问系统。

网络服务包括网络接入服务、私有网络协议、增值网络和受控的网络安全解决方案等，

例如通过部署防火墙和入侵检测系统对网络进行有效保护。这些服务既包括简单的未受控的带宽，也包括复杂的高级功能。组织应识别特殊服务的安全安排，例如 VPN、安全特性、服务级别和管理要求。网络服务提供商以安全方式管理商定服务的能力应该予以正式文件的约定（例如 Service Level Agreement 服务级别协议）并定期监视，还应和网络服务提供商商定审核的权利。组织应确保网络服务提供商实施了这些特殊的安全服务措施。

控制大型网络的安全的一种方法是将该网络分成独立的网络域，组织以正式文件的形式明确界定组织内各个网络域的边界。域之间的隔离可以使用不同的物理隔离或者使用不同的逻辑隔离（如 VPN）。对于不同网络域之间的访问，应该根据网络访问策略进行判断，但该访问必须在边界处使用网关（如防火墙、带安全功能的三层交换机或路由器）进行控制。由于无线网络的边界难以定义，因此需要专门对待，有必要专门制定无线网络接入组织内网的相关制度。对敏感信息系统而言，应将所有无线网络视为外部连接，并将其与内部网络访问隔离直至其按照网络控制方针通过网关进行接入。

13.2 信息交换		
目标：保持组织内以及与组织外信息交换的安全。		
13.2.1	信息交换策略和规程	控制措施 应有正式的交换策略、规程和控制措施，以保护通过使用各种类型通信设施的信息交换。
13.2.2	信息交换协议	控制措施 应建立组织与外部方交换信息和软件的协议。
13.2.3	电子消息	控制措施 应当保护包含在电子消息发送中的信息。
13.2.4	保密或不披露协议	控制措施 应确定反映组织信息保护要求的保密或保密协议，定期审查并形成文档。

组织应制定文件化的信息交换策略、规程和控制措施，以保护通过使用各种类型通信设施的信息交换。可能通过使用多种不同类型的通信设施进行信息交换，例如电子邮件、声音、传真和视频；可能通过多种不同类型的介质进行软件交换，包括从互联网下载和从出售现货的供应商处获得。应考虑与电子数据交换、电子商务、电子通信和控制要求相关的业务、法律和安全含义。应提醒工作人员，不要在公共场所、开放办公室会场及使用不安全的通信（例如咖啡店的 WIFI）进行保密会谈。

应建立组织与外部方交换信息和软件的协议。组织应制定信息传输外发策略、规程和标准，以保护传输中的信息和物理介质，并应在信息交换协议中进行引用。

应当规定保护包含在电子消息发送中的信息，包括电子邮件、电子数据交换、社交网络等，应该建议使用加密技术来保护电子邮件等信息发送渠道。

保密或保密协议应该基于依法强制执行的机密信息保护条款的要求，它适用于外部人员或组织雇员。保密性和保密协议的要求应进行周期性评审，当发生影响这些要求的变更时（例如人员离职、法规变化），也应进行评审。

10. 信息获取、开发和维护

信息获取、开发和维护包含3个控制目标13个控制措施。

14 信息系统获取、开发和维护		
14.1 信息系统的安全要求		
目标：确保信息安全是信息系统生命周期中的一个有机组成部分。这同样包含了在公共网络上提供服务的信息系统的要求。		
14.1.1	安全要求分析和说明	控制措施 在新的信息系统或增强已有信息系统的业务要求陈述中，应规定对安全控制措施的要求。
14.1.2	公共网络上的安全应用服务	控制措施 应保护在公共网络上的应用服务以防止欺诈行为、合同纠纷以及未经授权的披露和篡改。
14.1.3	应用服务交换的保护	控制措施 应保护涉及应用服务交换的信息以防不完整的传输、路由错误、未经授权的改变、擅自披露、未经授权的复制或重放攻击。

在新的信息系统或增强已有信息系统的业务要求陈述中，应包括信息安全相关要求。信息安全要求与实施安全的过程应在信息系统建设项目的早期阶段（一般是规划设计阶段）被纳入项目需求，根据实践经验在早期如设计阶段引入安全控制措施将更高效和节省成本。如果购买安全产品，则宜遵循一个正式的测试和获取过程，并根据国家或本地区法律法规选择经过权威部门检测检验的信息安全产品。对于组织重要的信息系统的安全产品的采购必须验证其是否需要经过我国的安全审查。

通过公共网络访问的应用易受到许多网络威胁，如欺诈活动、合同纠纷和信息的泄露或篡改。因此要进行详细的风险评估并进行适当的控制，包括验证和保护数据传输的加密方法等，保护在公共网络上的应用服务以防止欺诈行为、合同纠纷以及未经授权的披露和篡改。

应保护涉及信息系统中应用服务交换的信息以防不完整的传输、路由错误、未经授权的改变、擅自披露、未经授权的复制或重放攻击。

14.2 开发和支持过程中的安全性		
目标：确保信息系统开发的生命周期中设计和实施的信息安全。		
14.2.1	安全开发策略	控制措施 应建立和实施组织内的软件和系统的开发规则。

14.2.2	系统变更控制规程	控制措施 应使用正式的变更控制规程控制系统开发周期内的变更。
14.2.3	操作系统变更后应用的技术评审	控制措施 当操作系统发生变更时，应对业务的关键应用进行评审和测试，以确保对组织的运行和安全没有负面影响。
14.2.4	软件包变更的限制	控制措施 除必要的变更外，应对软件包的修改进行劝阻，且对所有的变更加以严格控制。
14.2.5	安全系统工程原理	控制措施 应在任何信息系统的实施过程中建立安全系统工程原理，建立文档并维护。
14.2.6	开发环境的安全	控制措施 组织应建立和适当保护在整个系统开发的生命周期中开发和整合的环境安全。
14.2.7	外包软件开发	控制措施 组织应管理和监视外包软件的开发。
14.2.8	系统安全测试	控制措施 应在开发过程中开展安全功能测试。
14.2.9	系统验收测试	控制措施 应对新的信息系统、信息系统的升级和新版本的信息系统建立验收测试程序和相关标准。

安全开发是建立安全服务、架构、软件和以满足系统的安全要求，组织应建立和实施组织内的软件和系统的开发规则。应使用安全编码技术，考虑安全编码的相关标准、模型和有关规定使用。组织应定期组织内部开发人员针对标准的使用和测试进行培训，并审核代码以确保其应用。对于由承包商外派人员从事的开发工作应该由专人对其能力进行考核验证。

系统开发周期内的变更应该使用正式的变更控制规程控制，将变更流程文件化并强制实施，以确保从最初设计至后续维护中系统、应用和产品的整体性。如果引入新系统和对已有系统进行大的变更应按照从文件、规范、测试、质量控制到实施管理这个正式的过程进行。这个过程应该包括风险评估、变更影响分析和所需的安全控制措施规范。

当操作系统（包括数据库和中间件平台）发生变更时，应对业务的关键应用进行风险评审和测试，以确保对组织的运行和安全没有负面影响。如果评审结果认定存在负面影响，则需要选择适当的控制措施来加以弥补。例如由于选用了 Windows 操作系统导致存在安全隐患，则可以选择使用 Windows 操作系统加固软件来进行加固。

尽可能使用厂商提供的软件包，不要对软件自行修改。如果由于业务的确需要对软件

包进行修改时，应对所有的变更加以严格控制，考虑软件包内置安全控制措施和完整性保护过程被损害的风险。对软件包的修改还应获得软件开发厂商的同意，当软件可以更新时，组织应向厂商了解更新的必要性信息，组织要负责进一步维护此软件，考虑变更的影响以及与其他在用软件的兼容性等。

组织应建立基于安全工程原理的安全信息系统工程规程，形成文档并在内部信息系统的工程活动中使用。在平衡信息安全需求和访问需求的基础上，组织所有架构层（业务、数据、应用和技术）均应考虑安全设计。如果工程中将采用新技术（例如云计算、大数据、移动互联网），还需要对其进行安全风险评估，并针对已知的攻击模式予以评审。

安全的开发环境包括与系统开发和整合相关的人员、过程和技术。组织应评估与各个系统开发相关的风险，并为特定系统的开发搭建安全的开发环境。开发环境应该和实际生产环境隔离。

在系统开发外包时，组织应管理和监视外包软件的开发。包括安排项目联系人参与到外包软件开发团队中，持续了解外包软件开发是否符合软件安全开发的标准。

新系统和升级的系统在开发测试环境中需要彻底地测试和验证，禁止在生产环境中测试。对于内部开发，应由开发团队进行此类测试。所有新系统开发和旧系统升级均需要进行独立的验收测试（无论内部和外包开发）以确保系统能按期望工作。

组织应对新的信息系统、旧信息系统的升级和新版本的信息系统建立验收测试程序和相关标准。系统验收测试应包括信息安全要求测试和遵守安全系统开发实践测试。该测试也应在接收软件组件和集成系统时进行。组织可以使用自动工具如代码分析工具或漏洞扫描器，如果发现安全漏洞，在内部开发人员或外包商整改后应验证与安全的修复。应在模拟的测试环境中进行测试以确保系统不会引入脆弱性至组织生产环境，确保测试的可靠性。

14.3 测试数据		
目标：确保用于测试的数据得到保护。		
14.3.1	测试数据的保护	控制措施 应仔细选择、保护和控制测试数据。

系统和验收测试常常要求相当多的尽可能接近运行数据的测试数据。宜避免使用包含个人信息或其他敏感信息的运行数据库用于测试。如果测试使用了个人或其他敏感信息，那么在使用之前应该去除或修改所有的敏感细节和内容，常见的方法是使用脱敏处理技术对真实数据进行处理。对于外包开发商，要求其签署对测试数据的保密协议，确保在测试结束后销毁所有测试数据。

11．供应商关系

供应商关系包含2个控制目标5个控制措施。

15 供应商关系		
15.1 供应商关系中的信息安全		
目标：确保供应商可访问的组织资产受到保护。		
15.1.1	供应商关系的信息安全方针	控制措施 为减轻供应商进入组织的资产相关的风险，应与供应商商定信息安全要求并形成文档。
15.1.2	供应商协议中表述安全	控制措施 对所有可能进入、存储、通信组织信息或提供 IT 基础设施组件的供应商建立相关的信息安全要求，并与供应商协商。
15.1.3	信息和通信技术的供应链	控制措施 供应商协议应包括解决与信息和通信技术、产品供应链相关信息安全风险的要求。

组织应制定专门的方针来识别供应商访问组织信息的要求，并建立相应的信息安全控制措施。该控制措施应基于组织的访问控制策略和组织要求供应商实施的过程和规程。

应该签署供应商安全协议，以确保组织和供应商双方在关于履行相关信息安全要求的义务之间不存在误解。

供应商安全协议应包括信息和通信技术解决方案、产品供应链相关信息安全风险的要求。例如，在信息和通信技术供应链中包含云计算服务可能面临的安全风险和其防范要求。

15.2 供应商服务交付管理		
目标：根据供应协议，维持信息安全和服务交付在协定的等级。		
15.2.1	监控和审查供应商服务	控制措施 组织应定期监控、审查、审计供应商服务交付。
15.2.2	供应商服务变更管理	控制措施 当供应商提供的服务，包括对信息安全方针、规程和控制措施的维持和改进等发生变更时，应在考虑到其对业务信息、系统、过程的重要性和重新评估风险的基础上管理。

组织应定期监控、审查、审计供应商服务，确保协议中的信息安全条款和条件被遵守，监测发现的信息安全事件和问题得到妥善管理。应将管理供应商关系的责任分配给指定的个人或项目管理团队。另外，组织应确保落实供应商符合性审查和相关协议要求强制执行的责任。应保持足够的技术技能和资源的可用性以监视协议要求尤其是信息安全要求的实现。当发现服务交付的不足时，宜采取合适的措施。

当供应商提供的服务，包括对信息安全方针、规程和控制措施的维持和改进等发生变更时，应在考虑到其对业务信息、系统、过程的重要性和重新评估风险的基础上修改监控、审查和审计的方法、范围、频率等。

12. 信息安全事件管理

信息安全事件管理包含 1 个控制目标 7 个控制措施。

16 信息安全事件管理		
16.1 信息安全事件的管理和改进		
目标：确保采用一致和有效的方法对信息安全事件进行管理，包括通信安全事件和弱点。		
16.1.1	职责和规程	控制措施 应建立管理职责和规程，以确保快速、有效和有序地响应信息安全事件。
16.1.2	信息安全事态报告	控制措施 应通过适当的管理渠道尽快地报告信息安全事态。
16.1.3	信息安全弱点报告	控制措施 应要求使用组织信息系统和服务的雇员和承包商注意并报告任何观察到或可疑的系统或服务中的信息安全弱点。
16.1.4	信息安全事态的评估和决策	控制措施 应评估信息安全事态并决定其是否属于信息安全事件。
16.1.5	信息安全事件的响应	控制措施 应按照既定规程响应信息安全事件。
16.1.6	从信息安全事件中学习	控制措施 应使用分析和解决信息安全事件中得到的经验来减少未来相似事件带来的影响。
16.1.7	证据的收集	控制措施 对于可以作为证据的信息，组织应定义和使用可以标识、收集、获取和保存该信息的规程。

组织应建立信息安全事件管理制度，明确信息安全事件的职责和处理规程，以确保快速、有效和有序地响应信息安全事件。应与管理人员商定信息安全事件管理的目标，应确保信息安全事件管理责任人理解处理组织信息安全事件时的优先级。

所有雇员、承包方人员和第三方人员都应该知道他们有责任尽可能快地报告任何信息安全事态。他们还应该知道报告信息安全事态的流程、联系人员及联系方式。

为了预防信息安全事件，所有雇员和承包商应注意并报告任何观察到或可疑的系统或服务中的信息安全弱点，尽可能快地将这些事情报告给组织制定的安全管理者，或者直接报告给服务提供者。报告机制应尽可能容易、可访问和可利用。雇员、承包商不要试图去证明被怀疑的安全弱点。需要告知雇员和承包商自行测试弱点可能被看作是潜在的系统误用，还可能导致信息系统或服务的损害，并引起测试人员的法律责任。

组织应使用商定的信息安全事件和事故分类规范评估每个信息安全事态以确定该事态是否该归于信息安全事件。事件的分类和优先级可以帮助标识事件的影响和范围。当组织中有信息安全响应团队（ISIRT）时，评估和决策应被转发至该团队确认和再评估。应详细

记录评估和决策的结果，供日后参考和验证。

所有信息安全事件应按照既定规程应急响应预案件，通过任命的联络人、组织内相关人员和外部团体对信息安全事件予以响应。

组织应该安排专职人员统计监测信息安全事件的类型、数量和造成的损失。应使用分析和解决信息安全事件中得到的经验来减少未来相似事件带来的影响。

对于可以作为电子证据的信息，组织应定义和使用可以标识、收集、获取和保存该信息的规程。通常，电子证据手机规程应根据不同介质、设备及其状态（如开机或关机）提供鉴定、收集、采集和保存证据的过程。如果可以，应寻找执法机关人员和具有电子证据取证工具的资格认证或其他相关手段，以加强保存证据的价值。证据可以超越组织或管辖区域的边界。在这样的情况下，应确保组织有资格去收集要求的信息作为证据。还应考虑不同国家和地区对于取证的要求，以使证据跨越相关管辖区域被允许进入的机会最大化。

13. 业务连续性管理

信息安全方面的业务连续性管理包含 2 个控制目标 4 个控制措施。

17 信息安全方面的业务连续性管理		
17.1 信息安全的连续性		
目标：应将信息安全连续性嵌入组织业务连续性管理之中。		
17.1.1	信息安全连续性的计划	控制措施 组织应确定在不利情况如危机和灾难时信息安全和信息安全管理连续性方面的要求。
17.1.2	信息安全连续性的实施	控制措施 组织应建立、记录、实施并维持过程、规程和控制措施以确保在不利情况时信息安全连续性处于要求级别。
17.1.3	信息安全连续性的确认、审查和评估	控制措施 组织应定期审核已建立和实施的信息安全连续性控制措施以确保这些措施在不利情况下的有效性。

组织应定期审核在业务连续性管理过程或灾难恢复管理过程中是否包含了信息安全连续性要求。应在设计业务连续性和灾难恢复要求时包含信息安全要求。

组织应建立、记录、实施并维持文件化的信息安全连续性过程、规程和控制措施以确保在发生自然灾害或其他意外事件时信息安全连续性满足要求级别，即不会因为自然灾害导致防火墙、日志审计系统等中断或无法恢复。在业务连续性或灾难恢复过程中，可能已定义特定的过程和规程。组织应保护这些信息安全连续性过程和规程，并支持它们的特性，即保护信息系统中处理的信息。在发生自然灾害或其他意外事件时，已实施的信息安全控制措施应继续实行，即发生火灾时不会导致应用服务器恢复而防火墙无法恢复运行。如果安全控制措施不能保持信息安全水平，应建立、实施和维持其他控制措施以保持信息安全在可接受的水平，例如发生火灾时防火墙无法恢复但可以通过启用三层交换机上的安全功

能实现网络访问控制。

发生组织结构、技术、规程和过程变化都会导致信息安全连续性要求的变化。在这些情况下，组织应针对这些变化审查信息安全连续性的过程、规程和控制措施是否有效。如果失效则应该建立实施新的信息安全连续性措施。

17.2 冗余		
目标：确保信息过程设施的可用性。		
17.2.1	信息过程设施的可用性	控制措施 应实施足够的信息过程设施冗余以确保可用性要求。

组织应以文件形式明确信息系统可用性的业务要求。当使用现有系统体系结构不能保证可用性时，宜考虑对网络或核心服务器部署冗余组件或架构。若可行，应定期测试冗余信息系统以确保故障按预期从一个组件转移到另一个组件。

14. 符合性

符合性包含 2 个控制目标 8 个控制措施。

18 符合性		
18.1 符合法律和合同规定		
目标：避免违反任何法律、法令、法规或合同义务以及任何安全要求。		
18.1.1	可用的法律和合同要求的识别	控制措施 对每一个信息系统和组织而言，所有相关的法令、法规和合同要求，以及为满足这些要求组织所采用的方法，应加以明确地定义、形成文件并保持更新。
18.1.2	知识产权	控制措施 应实施适当的规程，以确保在使用具有知识产权的材料和具有所有权的软件产品时，符合法律、法规和合同的要求。
18.1.3	记录的保护	控制措施 应防止重要的记录遗失、毁坏和伪造，以满足法令、法规、合同和业务的要求。
18.1.4	个人身份信息的隐私和保护	控制措施 应依照相关的法律、法规和合同条款的要求，确保个人身份信息的隐私和保护。
18.1.5	加密控制的监管	控制措施 加密控制措施的使用应遵从相关的协议、法律和法规。

对每一个信息系统和组织而言，所在国家行业的所有相关信息安全法令、法规和合同要求，以及为满足这些要求组织所采用的方法，均应以文件加以明确地定义，形成正式文

件由管理层审批签署并保持更新。安全管理人员应明确所有适用于其组织的法律以满足业务类型的需求。若组织在其他国家执行业务，安全管理人员应考虑与相关国家的符合性。

组织应实施合规性审查流程，以确保在使用具有知识产权的材料和具有所有权的软件产品时，符合法律、法规和合同的要求。知识产权包括软件或文件的版权、设计权、商标、专利权和源代码许可证。

组织应对合规性审查记录进行保护，防止重要的记录遗失、毁坏和伪造，以满足法律、法规或合同的要求，以及支持必要的业务活动。举例来说，可以要求这些记录作为组织在法令或法规规则下运行的证据，以确保充分防御潜在的民事或刑事诉讼，或者和股份持有者、外部方和审核员确认组织的财务状况。可以根据所在国家行业的法律或规章来设置信息保存的时间和数据内容，一般情况下要求长期保存。

许多国家已经具有控制公民个人信息（一般是指可以从该信息确定生命个体的信息）收集、处理和传输的法律。应依照相关的法律、法规和合同条款的要求，确保个人身份信息的隐私和保护。

组织对于其使用的加密技术应遵从相关的协议、法律和法规，包括以下方面。

（1）限制执行加密功能的计算机硬件和软件的入口或出口。

（2）限制被设计用以增加加密功能的计算机硬件和软件的入口或出口。

（3）限制加密技术的使用。

（4）利用国家对硬件或软件加密的信息的授权的强制或任意的访问方法提供内容的保密性。

18.2 信息安全审查		
目标：确保信息安全依据组织方针和规程实施和操作。		
18.2.1	信息安全的独立审查	控制措施 在规定的时间间隔或重大变化发生时，组织的信息安全管理和实施方法（如信息安全的控制目标、控制措施、方针、过程和规程）应独立审查。
18.2.2	符合安全策略和标准	控制措施 管理者应定期审查其职责范围内信息过程和规程与适当的安全方针、标准和任何安全要求的符合性。
18.2.3	技术符合性核查	控制措施 信息系统应被定期核查是否符合组织的信息安全方针和标准。

组织在规定的时间间隔（一般是一年）或重大变化发生时，组织的信息安全管理和实施方法（如信息安全的控制目标、控制措施、方针、过程和规程）应独立审查。独立评审宜由管理者启动，由独立于被评审范围的人员执行，例如交叉审核（审核员 A 审查 B 的信息安全管理工作）、内部审核部门、独立的管理人员或专门进行这种评审的第三方组织。从事这些评审的人员宜具备适当的技能和经验。内部审查的结果应该形成正式文件并长期

留存。

管理人员宜对自己职责范围内的信息处理是否符合合适的安全策略、标准和任何其他安全要求进行定期评审（一般是一年一次）。为了日常评审的效率，可以考虑使用自动测量和报告工具。评审结果和管理人员采取的纠正措施应该被记录，形成管理评审报告，并对这些记录进行维护。如果在管理评审中发现重大不符合项，则必须启动纠正改进措施。

信息系统应被定期核查（一般为半年一次或一年一次）是否符合组织的信息安全方针和标准。技术符合性核查宜由有经验的系统工程师手动地（如必要，由适当的软件工具支持）和在自动化工具辅助下实施，以产生供技术专家进行后续解释的技术报告。如果使用渗透测试或脆弱性评估，则宜格外小心，需要提前制定应急预案和做好应急准备，因为这些活动可能导致系统安全的损害。这样的测试宜预先计划，形成文件，且可重复执行。任何技术符合性核查应由有能力的、已授权的人员来实施或在他们的监督下完成。

3.5 知识子域：信息安全管理体系度量

3.5.1 基本概念

1. 测量

测量是一个过程，包括信息安全管理体系和用以实现控制目标的控制措施的有效性，以及信息安全管理体系各过程相关信息的获取，测量方法、测量函数、测量模型及测量准则的使用等。

测量识别现有管理体系的充分性，包括策略、风险管理、控制目标、控制措施、过程和规程，并支持组织进行过程的修订，在信息安全管理体系的测量活动中，还需要决定哪些 ISMS 过程或控制措施应该变更和改进。

ISO/IEC 27004 要求管理层“定义怎样测量所选择的一个或一组控制措施的有效性，并指明这些测度是怎样被用来评估控制措施有效性，以产生可比较和可再现的结果。”

根据多种因素，包括风险暴露、规模、资源可用性、能力、行为和部门需求的不同，被组织采用来测量控制措施有效性的方法也有所不同。

仔细地选择和证明所使用的方法非常重要，这可以保证不会因为过多的资源被投入信息安全管理体系的某个领域从而损害到其他领域。

2. 测量的目的

信息安全测量项目能够帮助管理层识别和评价不符合和无效的控制措施，并对这些控制措施改进和变更等相关行动的优先次序进行排列。测量项目也能帮助组织展示与组织信息安全管理体系的符合程度，并能产生管理评审过程的输入。

信息安全测量项目的实施，优先保证向利益相关方提供关于各种最严重（或是最高优先级别）风险及其处置/控制措施状态的可靠信息。

一个有效的信息安全测量项目能改进利益相关方对可提供状态信息的各种测量的信心，并使利益相关方能使用这些测量有效、持续改进信息安全和信息安全管理体系。

3．ISO/IEC 27004 的测量模型

信息安全测量模型是将信息相关测量对象及其属性关联的结构。测量对象可包括已计划的或已实施的过程、规程、项目和资源。

信息安全测量模型描述如何将相关属性进行量化并转换为指标，以提供决策依据。图 3-9 给出了信息安全测量模型。

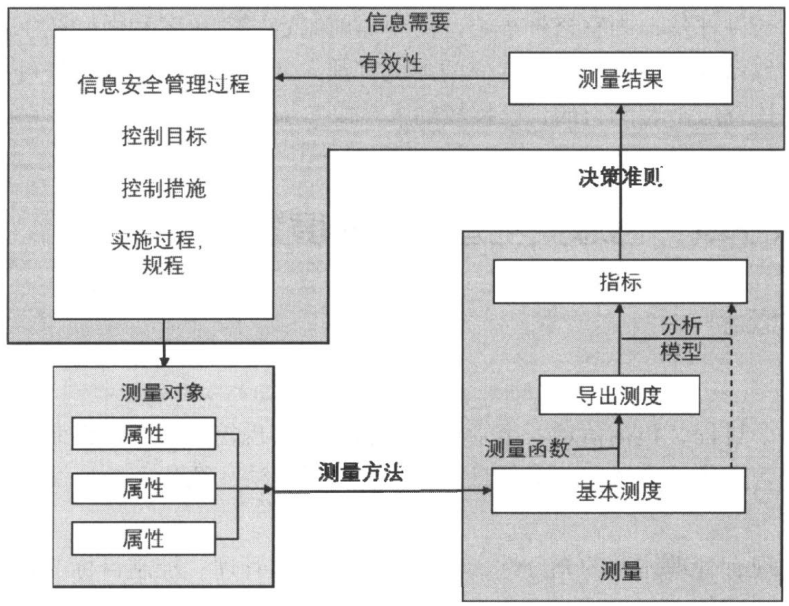

图 3-9　信息安全测量模型

基本测度是可获得的最简单的测度。基本测度是通过对一个测量对象所选择的属性应用一个测量方法而产生的。一个测量对象可能有许多属性，但只有部分属性可提供赋予基本测度的有用值。对于不同的基本测度，可使用一个给定的属性。

对每个基本测度应识别其测量方法。测量方法是一种逻辑操作序列，将属性转换为基本测度。测量方法被用来量化测量对象，其操作可能涉及例如统计出现次数或观测时间推移之类的活动。

一个测量方法能应用于一个测量对象的多个属性。例如，测量对象可以是 ISMS 中已实施的控制措施的执行情况；受控制措施保护的信息资产的状况；ISMS 中已实施的过程的执行情况；已实施的 ISMS 责任人的行为；信息安全责任部门的活动；感兴趣方的满意程度等内容。

一个测量方法可以使用来自不同源测量和属性的测量对象，例如，风险分析和风险评估结果；问卷调查和人员访谈；内部和（或）外部审核报告；事件记录，如日志、报告统计和审计轨迹；事件报告，特别是那些产生影响的事件的报告；测试结果，如来自渗透试

验、社会工程、符合性测试工具和安全审计等工具的结果；与规程和方案相关的组织信息安全记录，如信息安全意识培训结果。

3.5.2　测量要求与实现

1．管理职责

信息安全管理体系的测量需要管理者负责建立信息安全测量方案、吸纳利益相关者参与测量活动、接受测量结果作为管理评审的输入以及在 ISMS 改进活动中使用测量结果。

确保测量就 ISMS 有效性和已实施的 ISMS 的改进需求为利益相关者提供充足的信息，包括 ISMS 的范围、策略、目标、控制措施、过程和规程；控制措施或控制措施组的有效性和改进已实施的控制措施的需求为利益相关者提供充足的信息。通过分配适当的测量角色和职责，管理者通过职责分离来实现测量结果不受拥有信息的主体的影响，也可以借助能够进行独立检查的详细文件来实现。

为了支持测量必需的资源管理活动，例如数据收集、分析、存储、报告和发布，需要管理者分配和提供相应的资源。包括负责信息安全测量方案的各个方面的人员支持；适当的资金支持；适当的基础设施支持，例如用于执行测量过程的物理基础设施和工具。

对实施的信息安全测量方案，管理者应确保利益相关者在实现其角色和职责方面得到充分的培训，并且有能力执行其角色和职责；包括为改进所实施的信息安全测量方案提出建议的责任。

2．测度和测量开发

为了评估已实施的 ISMS 和控制措施或控制措施组的有效性，并识别组织特定的测量构造集合，需要建立编制测度和测量所需的活动，并应建立相应的文件。活动包括：定义测量范围；识别信息需要；选择测量对象及其属性；制定测量构造；应用测量构造；确定数据收集和分析过程及报告；确定测量实施途径和相应的文件。在建立这些活动时，需要考虑资金、人力和基础设施（物理的和工具）资源。

3．测量运行

测量运行包括收集、存储和验证被用来创建信息安全测度的数据。为了确保已产生的测量结果能为已实施的 ISMS、控制措施或一组控制措施的有效性提供准确的信息，信息安全测量的运行涉及将测量规程整合到整个 ISMS 的运行中；收集、存储并验证数据及规程的整合等必不可少的活动。

信息安全测量方案需要完全整合到 ISMS 中，并由 ISMS 所使用。测量规程与 ISMS 运行相协调，针对信息安全测量的制定、实施和维护，定义角色、授权和职责，并建立相应的文件；收集数据，并在必要时，为了配合数据的产生和收集活动，修改当前 ISMS 的运行；与利益相关者沟通数据收集活动中的变更；保持信息收集人能力，及其对已需要的数据类型、数据收集工具和数据收集规程的理解；有关定义测量在组织内的使用、测量信息

的发布、信息安全测量方案的审核和评审，制定方针策略和规程；把数据分析和报告与相关过程进行整合，以便确保它们的正常执行；监视、评审和评价测量结果；为了确保测度和组织一起发展，建立逐步淘汰测度和增加新测度的过程；为了进行趋势分析，建立一个确定历史数据使用寿命的过程。

4．测量分析和报告

为了产生测量结果，需要对已收集的数据进行分析，并通报已产生的测量结果。包括分析数据并产生测量结果和与利益相关者沟通测量结果。

使用决策准则分析和解释已收集的数据。在分析之前，数据可被整合、转换或重新记录。在分析数据期间，为了产生指标，宜对数据进行相应的处理。可应用到许多分析技术。宜根据数据特点和信息需要，确定分析的深度。

对于沟通测量结果而言，确定如何沟通信息安全测量结果，例如，确定哪些测量结果要向内部和向外部报告；测度列表要与单个利益相关者或相关方对应；提供特定测量结果，根据各组需要裁剪表述类型；为了评价测量结果的有用性和信息安全测量方案的有效性，获取利益相关者反馈信息的方式。

5．测量评价和改进

为了确保已实施的信息安全测量方案能够以有效的方式产生测量结果，还需要定期执行对测量体系有效性以及评价已产生的测量结果有用性的评估。

对测量体系进行评估需要考虑以下方面。

- 组织的业务目标产生变更。
- 信息安全相关的法律法规、政策与合同要求变更。
- 组织的信息安全要求变更。
- 组织的信息安全风险变更。
- 增加有效或适用的测量数据及测量方法。
- 测量对象、测量属性的变化。

对于测量结果的评估需要考虑以下方面。

- 测量结果是否易懂、提交是否及时，客观、可比较和可重现。
- 测量结果产生过程是否完善定义，操作难度以及是否严格遵循已定义流程实施。
- 测量结果是否对改进 ISMS 有价值。
- 测量结果是否与相应的需求相对应。

对测量体系的有效性进行评估后，对于不适用的进行修改或取消，并重新分配相关的资源。测量体系的有效性评估也需要组织高层管理者的支持、相关方的反馈以确保该体系有效运行。

第 4 章

知识域：业务连续性

阅读提示 本知识域包括业务连续性管理、信息安全应急响应和灾难备份与恢复 3 个知识子域。通过学习，理解业务连续性管理的基本概念，制订业务连续性计划的相关工作，同时理解信息安全应急响应、灾难备份、灾难恢复等相关知识。

4.1 知识子域：业务连续性管理

灾难的发生事先是无法预料的。无论是飓风或地震那样的自然灾害，还是建筑火灾、水管爆裂或因黑客攻击而导致系统中断那样的人为灾难，对缺乏业务连续性规划的企业可能都是致命的。组织机构在受到灾难袭击之后非常脆弱，而业务连续性计划和灾难恢复计划能确保组织机构持续地发展，帮助它们降低灾难对业务持续运营的影响以及快速恢复正常的业务运营。

4.1.1 业务连续性管理基础

1．业务连续性与业务连续性管理

业务连续性（Business Continuity，BC）是组织针对事故可能导致的业务中断进行规划，通过建立组织策略和响应能力，使业务在预先定义的级别上持续运行。它主要为长期停产和灾难事件提供解决办法和程序。比如，当灾难发生时，将关键系统转移到异地，在各个工作岗位上安排合理的人员，在恢复正常秩序之前改变业务运作模式，以及通过各种渠道处理与客户、合作伙伴和股东的关系，直到一切恢复正常。

业务连续性管理（Business Continuity Management，BCM）是找出对组织有潜在影响的威胁及其对组织业务运行的影响，通过有效的响应措施保护组织的利益、信誉、品牌和创造价值的活动，并为组织建设提供恢复能力的整体框架的管理过程。它是一项综合管理流程，使企业认识到潜在的危机和相关影响，制订相应业务连续性的恢复计划，其总体目标是为了提高企业的风险防范能力，以有效地响应非计划的业务破坏并降低不良影响。它包括组织在面临灾难时对业务活动的恢复和连续性的管理，以及为保证业务连续性所进行

的培训、演练和评审。

BCM 是一个由业务驱动，建立符合预定战略目标和框架的操作过程，主要包括以下方面。

（1）预先提高组织抵御业务中断风险的能力，以帮助企业达成其关键目标。

（2）预先确定组织机构恢复提供关键产品或服务的能力所要求的时间，然后建立相应的预演方法，确保组织机构在事故发生后能按这个时间要求提供关键产品或服务。

（3）交付经过证明的应对业务中断的管理能力，以保护组织的信誉和品牌。

2．BCM 与组织机构

BCM 可能根据组织的规模、结构、职责不同而有所不同，但不论是公共或私有组织，无论是非营利组织、政府还是企业，无论它的规模、范围和复杂程度，BCM 的基本原则还是一致的。

任何组织都具有其自己的业务战略目标，通常会通过设定短期、中期和长期目标促使组织机构全体成员共同努力。组织最高层需要对 BCM 深入理解，以保证业务不会因意外中断而危及组织的战略目标。

对于不同的组织，由业务中断而引起的事故后果可能会有很大的不同。这些后果可能是人员伤亡，资产或收入的损失，声誉及信誉的丧失，甚至是无力提供企业生存所依赖的产品和服务等。因此，在考虑 BCM 时，必须认识到已知利益相关方对策略的重要性。另外，作为业务中断的后果，一些新的利益相关方会浮现，并且可能会给损害的最终范围带来直接的影响。例如，媒体会在组织面对业务中断时，施加压力。

BCM 是组织机构风险管理框架的补充，用于理解组织运行和业务上的风险及其后果。通过风险管理过程，组织能够识别关键资产在业务运行过程中所面临的相关风险；在 BCM 中，主要集中考虑业务中断的影响，同时识别组织赖以生存的产品和服务，进而满足组织持续运行的要求。

3．BCM 的生命周期

BCM 生命周期中的管理流程能够对潜在的灾难加以辨别分析，帮助组织机构计算并确定灾难的冲击对组织机构运营可能的威胁，并提供一个有效的管理机制来阻止或抵消威胁，减少损失。同时 BCM 提供了一个弹性的组织框架和有效的响应能力来保护组织机构的利益，为组织机构应对业务中断、实施业务恢复提供了一个战略和操作层面的框架。

BCM 范畴较广，涵盖危机管理、风险管理、灾难恢复、设施管理、供应链管理、质量管理、安全管理、知识管理、应急管理、沟通和公关、人力资源管理、环境管理等内容。因此，BCM 不是一项单一的技术，而是由业务自身驱动的集技术、管理于一体的动态管理流程。其生命周期有以下 6 个阶段。

（1）BCM 需求、组织和管理程序的确定：确定业务连续管理过程的需求，建立相应的组织和管理体制（如 BCM 指导委员会和危机管理小组），制定 BCM 程序管理的有关规定、标准和指导方针，从而对项目有效评估、控制和审计。

（2）熟悉和理解业务，确定关键业务流程和关键因素：明确业务目标，进行风险分析

（RA）和业务冲击分析（BIA），识别关键业务以及业务的优先级、关键业务流程以及业务流程得以实现的关键因素，进而识别业务中断造成的直接和间接后果，确定可以接受的损失范围、关键业务恢复的优先顺序以及恢复时间目标（RTO）。

（3）制定业务连续策略：确定业务恢复运行策略，以便按照关键性和优先级有序地恢复业务和信息技术，维持机构的关键功能；为保证策略的有效及成本的合理，必须综合分析恢复目标、所需资源、技术手段、投资成本、管理方式等，形成组织 BCM 策略、过程层面 BCM 策略、资源恢复 BCM 策略 3 个层次的业务连续策略。

（4）开发并执行业务连续计划：识别和定义主要计划组件、建立计划分发和控制规程，设计、制订和实施一系列的业务连续性相关计划，包括业务连续性计划（BCP）、危机管理计划（CMP）、资源恢复计划（RRP）、灾难恢复计划（DRP）、业务恢复计划（BRP）、危机通信计划（CTP）、场地撤离计划（FEP）、应急反应计划（ERP）、人力资源计划（HRP）等，有效地保障业务持续运行。

（5）BCM 意识培养和建立：制订针对管理层、关键岗位、员工意识培养计划，将 BCM 教育培训融入常态工作管理，以使业务连续性计划能够得到制订、实施、维护和执行。

（6）BCM 计划演练、维护和审计：有计划地进行 BCM 计划演练，并进行记录、评估和不断改进，确保计划的有效性及实用性，并符合业务的要求。

4.1.2　业务连续性计划

业务连续性计划（Business Continuity Planning，BCP）是一套基于业务运行规律的管理要求和规章流程，能够使一个组织在突发事件面前迅速做出反应，以确保关键业务功能可以持续，不造成业务中断或业务流程本质的改变。

部分组织机构在实施业务连续性计划时，仅仅考虑数据备份和硬件冗余。数据备份和硬件冗余毫无疑问非常重要，但这些措施仅仅是组织整体业务连续性计划的一部分。硬件需要人员进行配置和操作，数据备份虽然能确保数据不会丢失，但在业务运行中，可能还需要能被用户或其他系统进行访问。因此，业务连续性计划需要考虑的是如何使组织机构的各个业务连续性协同进行，这是一个需要统筹规划的事情。

BCP 建立在对组织机构各种过程的风险评估之上，制订各种策略、计划和措施使得风险发生对组织的影响降到最小程度。BCP 关注点是基础设施功能和资源受限或减少的情况下如何维持业务操作，以确保组织执行关键工作任务的能力得以持续。如果连续性受到破坏，组织的业务过程停止，那么组织将执行灾难恢复计划（Disaster Recovery Planning，DLP）。

BCP 应成为组织管理文化的一部分。在组织制订 BCP 之后，要确保该计划的切实可行，时刻满足组织的业务战略。BCP 涉及的相关环境、资源、人员、流程发生改变，计划也应该及时进行更新。例如组织的业务模式发生变化或是业务过程进行了重新设计调整，或者业务连续性计划中涉及的关键人员已经离职等。

BCP 的整体目标是在紧急情况下提供及时有效的响应，从而增强组织从事故中尽快恢

复过来的能力。BCP 过程包括 BCP 的组织管理、业务影响分析、BCP 的制订及批准实施和 BCP 的评估及维护 4 个主要步骤。

1．组织管理

BCP 的组织管理是 BCP 过程的核心。组织应该确保 BCP 与组织的性质、规模、复杂程度、地理位置及其业务活动的危险程度相符，并反映组织的文化、业务关联性和运行环境。BCP 定义过程要求，以确保业务连续性安排满足组织遭受事故时的需要。同时 BCP 应该整合到组织的变更管理活动中，以保证 BCP 随着组织业务活动的变化而得到及时的更新。BCP 的组织管理应考虑理解业务组织、建立 BCP 团队、评估 BCP 资源、BCP 的合规性要求 4 个因素。

（1）理解业务组织

对 BCP 管理者来说，构建业务连续性计划首先要做的是充分了解组织的体系结构及其组成部分，清晰地掌握每个业务流程及相互依赖关系。这是 BCP 团队人员选择的基础，也是后续进行业务影响分析的重要基础。

组织的体系结构是一个综合体，它由许多类型的设备、人员、任务、部门通信机制和外部接口构成。BCP 面临的最大问题就是需要充分理解这些错综复杂的因素以及它们之间的相互关系。团队可以制订各种计划，实现数据的备份还原、冗余的数据处理设备、冗余的电源、线路，培训员工手动完成自动化任务等，但如果这些措施不能相互协调以生产出有质量保证的产品，那么这些工作最终都是毫无意义，因此，应当充分理解组织业务、定义必不可少的业务功能和支持部门，确定这些功能和部门之间的相互依赖关系。

业务流程和组织的体系结构的获取可以通过调查、访谈或讨论的方式，在获取过程中，非常重要的是了解组织机构内各种任务（不限于流程、事务处理或服务）的完成方式以及所有的相互依赖关系，最后的输出可能是流程图或者是体系架构图。当然，在具体实践中，这一部分内容在刚开始进行阶段可能会不完善，会忽略某些重要的业务功能，因此，当 BCP 团队建成后，其首先要做的就是彻底审查这部分内容，进行修正和补充，否则会因业务功能不完整而使整个 BCP 过程受到负面影响，并导致所制订的计划不能完整说明组织如何在紧急状况下成为一个整体并做出响应。

（2）建立 BCP 团队

组织需要指定或任命一名具有适当资历和权限的人员负责 BCP 的制订和实施过程，同时建立 BCP 团队。在选择 BCP 团队成员时，根据组织的规模、范围及复杂程度来进行全面考虑，既要考虑 IT 和安全部门的人员，还要考虑负责日常业务运作的人员，一定要摒弃只由 IT 部门的人员独立开发 BCP 的问题，这种情况会降低操作要素与计划条款保持一致并有效实施的可能性。通常 BCP 团队的人员应来源于下面这些领域。

- 负责为用户提供核心服务业务的运营部门。
- 重要的支持服务部门，如 IT 部门、设备维护部门和其他负责对支持运营部门的系统进行检修的团队。

- 高层行政管理人员和对于组织继续生存来说非常重要的关键个人，如法律顾问。

来源于以上不同领域的人员对 BCP 过程会有不同的视角，例如，来自每个运营部门的人员通常会认为他们的部门对于组织的持续生存来说是最重要的。虽然这些见解最初看来会引起分歧，但在 BCP 过程中应该接受它们并以有效的方式进行管理。如果管理得当，这些分歧会在最终的 BCP 中达到某种程度的平衡。当然，BCP 团队需要一位优秀的管理者，能够对这些分歧进行有效的管控，否则这些分歧可能转变为具有破坏性的争斗，对组织产生不利的影响。因此，尽可能建立一支人才多样化并仍然保持关系和谐的团队。

（3）评估 BCP 资源

当团队建设后，就应当转向 BCP 工作中所要求的资源评估，一个有效的 BCP 需要耗费公司大量的资源，资源的范围从购买和部署冗余的计算设施直至团队成员拟制计划所需的办公用品。然而，BCP 过程中消耗的最重要的资源之一是人力。比如 BCP 的开发、测试、培训和维护过程，即使在 BCP 实施过程中，BCP 团队正确并果断地使用其 BCP 实现能力也是很重要的，而这些都需要管理层的充分支持。

（4）BCP 的合规性要求

许多企业可能会发现它们要受到所在地区法律、法规以及所属行业的行业规定的限制，这些限制要求它们实现不同程度的 BCP。比如 2003 年，中共中央办公厅颁布的《国家信息化领导小组关于加强信息安全保障工作的意见》中首次提出“基础网络和重要信息系统的建设要充分考虑抗毁性和灾难恢复，应制定和不断完善信息安全应急处置预案。”其后，我国重点行业（尤其是银行、电力、铁路、民航、证券、保险、海关、税务八大行业）都有对信息系统业务连续性的行业标准要求。比如在《商业银行操作风险管理指引》第十九条中规定：“商业银行应当制定与其业务规模和复杂性相适应的应急和业务连续方案，建立恢复服务和保证业务连续运行的备用机制，并应当定期检查、测试其灾难恢复和业务连续机制，确保在出现灾难和业务严重中断时这些方案和机制的正常执行。”此规定涉及了业务连续和灾难恢复相关的内容，明确了银行业应制订适当的业务连续性规划。从这些例子可以看出，涉及公共服务、国计民生、公共安全的领域在行使业务职能时，会受到政府和行业相关规定的严格控制，这些规定帮助它们持续运作和确保国家经济的生命力。如果由于它们的原因导致无法可靠地实现 BCP，那么会造成生命和/或财产的损失并降低政府在群众心中的威信。比如，当药品生产商必须在发生灾难之后在非最佳环境中生产药品时，它们会被要求必须向政府管理者证明药品的纯度。因此，当出现紧急情况、公共安全受到威胁时，紧急情况服务变得越来越重要。

即使不受到国家或行业任何一项规定的约束，也要对用户负责以实施有效的BCP措施，如果合同中包括某种服务级别协议（SLA），那么就会在发生事故导致用户服务中断时，发现自己违反了这些合同条款。许多用户可能会表示理解并希望继续使用你的产品或服务，但是他们自己的业务要求可能会迫使他们终止合同，从而去寻找新的供应商。

另一方面，发展完善的、文档化的 BCP 能够帮助组织从现有的客户那里赢得更多的新用户。如果能够向用户展示出在发生灾难事件时，公司具有恰当的完善措施来保证用户服

务的持续发展，那么他们就会对你的公司充满信心并且很可能首选你成为供应商。

因此，请组织的法律顾问全程参与 BCP 过程是非常重要的。他非常熟悉应用于组织的各种法律、法规和合同要求，在保证组织持续生存从而给包括员工、股东、供应商和用户在内的各方带来利益的同时，他能够帮助 BCP 团队实现满足这些要求的计划。

2．业务影响分析

BCP 主要是处理不确定性和偶然性。它的关键在于尝试考虑可能发生的灾难，通过评估潜在的破坏和损失，对可能发生的灾难进行分类和排定优先次序，并制定可行的解决方法，以减少损失，保障关键性业务可持续运行。通过业务影响分析（Business Impact Assessment，BIA），可以确定组织持续运行的关键资产，以及对这些资产的威胁，同时评估每种威胁实际出现的可能性以及出现的威胁对业务的影响。BIA 的结果还可以提供一些用于量化的度量，这些度量有助于组织确定在面对各种本地、区域和全球风险时投入业务连续性资源的优先顺序。

（1）确定业务优先级

BIA 首先要做的就是确定业务优先级。基于前面分析所获取的组织业务架构，可以得到组织业务的具体范围，然后对它们进行分析，比如哪些流程、设备或操作活动是关键的，哪些是非关键的，以确定业务优先级。对于关键的业务，在出现灾难的时候，需要优先恢复。优先级确认或关键性优先级涉及创建业务流程的综合列表，并且按照重要性排序。

在确定业务功能之后，BCP 团队有必要查明这些业务功能实际运转需要哪些资源。这些资源不仅限于计算机系统，还包括支撑其运转所需要的人员、资源（通信、共享的物理设施、设备以及软硬件）和服务（IT 部门、运输及配送服务、后台操作，包括财务、交易处理、客户服务、采购等，第三方供应商）。如果其中一项或几项支持机制失效，那么业务功能可能会因此而中断。所以对组织来讲，理解业务功能所需资源之间的相互关系和对外部组织或他方的依赖是非常重要的。

对每项业务功能及其所依赖的资源，组织应该：

评估如果业务中断，随时间推移对组织所造成的影响；通过识别以下内容，为每项业务建立最大允许中断时间（Maximum Tolerable Downtime，MTD）。

- 自中断开始，业务需要被恢复的最大期限。
- 业务需要恢复到的最低水平。
- 恢复到正常水平的时间跨度。

识别任何相互依赖的活动、资产、用于支持的基础设施和资源，这些也需要得到持续的维护或随时间进行的恢复。

MTD 指的是某个业务功能出现故障但是不会对业务产生无法弥补的损害所允许的最大时间长度。在评估影响时，组织应该考虑业务目的、目标和相关利益方等方面。可以通过参考以下指标进行考虑。

- 运行中断和生产力。

- 财务因素。
- 法律责任。
- 声誉。

“运行中断和生产力”主要从如果某项业务功能运行发生中断对组织整个生产力的影响程度上考虑，如产品或服务质量的降低，基础设施、技术或信息损害或丧失所造成的影响等。

在进行 BCP 制订时，MTD 是需要重点考虑的。比如某个组织可能会用到以下 MTD 估计。

- 无关紧要的业务：30 天。
- 正常的业务：7 天。
- 重要的业务：72 小时。
- 紧急的业务：24 小时。
- 危急的业务：几分钟到几小时。

每个业务功能和资产都应当根据组织缺少它能够生存的时间来分配上述一个 MTD 类别。这些估计有助于组织决定需要使用何种备份解决方案来确保资源的可用性。

与之有关的还有另一个度量标准，即恢复时间目标（Recovery Time Objective，RTO），它指的是当中断事件发生时，可以实际恢复功能的时间量。一旦定义了恢复目标，就可以设计必要的步骤去完成任务。BCP 过程的目标是确保 RTO 小于 MTD，即要求一个业务功能必须在最大容忍中断时间内恢复。

将确定优先级过程的工作交给 BCP 团队每个成员，要求他们都创建一个优先级列表，这个列表涉及该成员所负责部门的业务功能。当整个 BCP 团队开会讨论时，团队成员会使用这些优先级列表为整个组织创建一个优先级主列表。整个分析过程可以采用定性和定量两种分析方法实施。

（2）风险分析

接下来要做的是识别并分析组织所面临的重大风险。这里的重大风险主要指的是容易引起组织业务不可持续的风险。应充分理解风险的级别，特别是有关组织关键业务及导致关键业务中断的风险。关键业务需要资源的支持，如人员、设施、技术、信息、供给和利益相关方。组织应理解对这些资源的威胁，每一资源的脆弱性，以及当威胁转化为事故并导致业务中断的影响。

① 风险要素识别

有关于组织业务所依赖的资产识别，在第一阶段已经完成，这部分的主要工作是要识别组织所面临的威胁，通常有两种威胁：一种是自然威胁；一种是人为威胁。自然威胁主要包括洪水、地震、泥石流等，人为威胁主要包括恐怖活动、战争、罢工，还包括盗窃、毁坏、火灾/爆炸、长时间断电、建筑物倒塌、设备故障、通信运输中断等。

这里仅标识了可能的一些威胁，并不完整，比如可能还包括关键人员缺失、关键产品供应商或关键服务提供商倒闭、关键数据丢失等。要完整地列出组织所面临的威胁，需要

BCP 团队所有成员共同参与，其中应包括威胁利用资产的脆弱性而产生的各种事件（脆弱性识别隐含其中，脆弱性可能表现为资源的漏洞，并在某些条件下被威胁所利用，如单点失效、不充分的消防防护、电子设备健壮度、人员配备水平、IT 安全和 IT 健壮度）。另外，在识别威胁这个阶段，不必关心每种威胁实际发生的可能性，也不必关心发生风险对业务继续运作的影响破坏程度。这种分析的结果有助于后续做定性和定量分析。

② 可能性分析

威胁识别完后，应有一个威胁列表，其中列出了威胁组织的各种事件。可以发现，组织所在的不同地域或组织中不同的业务，同一种威胁发生的可能性以及影响程度可能都是不同的，所以由某种威胁所产生的风险发生的可能性应该根据不同的业务或不同的地域特征单独进行分析。

考虑到计算的一致性，可能性评估通常采用年发生比率（ARO）表示，ARO 反映了业务预期每年遭受特定灾难的可能性。

③ 影响分析

影响分析阶段需要确定如果每种风险发生会对业务产生什么影响。这些影响可能会包括以下方面。

- 生产力的损失。
- 收入的损失。
- 收入延迟成本。
- 运作费用的增加。
- 竞争优势的损失。
- 法规责任。
- 违反合同协议所造成的损失。
- 声誉的损失。

这些影响可能直接存在，也可能间接体现，但都必须以合适的方式进行分析。可以通过定性或定量的方式进行。如果是用定量的分析方法，可借鉴第 6 章所介绍的方法，比如 BIA 所涉及的 3 个特定的度量：暴露因子、单一预期损失和年度预期损失。这些度量中的每一个值都是针对 BIA 前几个阶段中评估的每种特定风险/资产组合计算的。

（3）资产优先级划分

资产优先级划分主要是划分针对各种不同风险所分配的业务连续性资源的优先级。这些资源可能包括以下方面。

- 人力资源，包括人的数量、技能和知识。
- 必要的工作场所和设施。
- 用于支持的技术、厂房和设备。
- 以前工作或当前工作进展有关信息的提供，并确保信息的即时更新和精确，以保证业务在要求的水平上有效持续运行。
- 外部服务和供给。

组织在确定资源水平时，应考虑相关利益方的需求。

重大风险已在 BIA 前面的任务中进行了确定和分析。这里需要注意的是，在前面分析的过程中，使用了定性和定量两种方法，这样就生成了两个不同的应当解决的风险优先级列表，这需要 BCP 团队和管理层一起，将这两个列表合并成一个优先级列表，从而确定各种威胁对组织的全面影响，这一分析过程应包括组织业务的 MTD 要素，它影响着管理者确定哪些业务功能是恢复最高优先级，并为这些关键业务建立恢复目标。

BIA 分析完成后，应文档化所有的流程，内容包括：关键业务流程及其依赖的关键性系统和支撑性系统的识别，重大风险识别及分析和应当解决的风险优先级等。

3．BCP 的制订及批准实施

BCP 过程的前两个阶段主要确定 BCP 过程如何工作并确定需要防止出现中断的业务资产的优先顺序。这个阶段主要专注于连续性策略的开发和实现，以达到降低中断的可能性、缩短中断期限、限制因中断对组织关键业务的影响等目的。

（1）BCP 的制订

BCP 团队必须根据 BIA 所得到的应当解决的风险优先级列表，确定业务连续性计划会处理哪些风险。信息安全风险的处置方式有 4 种，分别是风险降低、风险转移、风险规避和风险接受。基于这 4 种风险处置方式，BCP 团队应当根据 BIA 前期建立的 MTD 评估时间，并且确定哪些风险被认为是可接受的，哪些必须采取 BCP 连续性措施加以缓解。

① 风险降低

风险降低可采用预防性策略和反应性策略两种方案，采用预防性策略解决风险问题是整个业务连续性方案的重要部分，采用适当的、低成本的预防性措施应当优于反应性策略。在这个部分中，BCP 团队应设计具体的过程和机制，缓解被认为不可接受的风险。在 BCP 中，需要重点保护的 3 个对象是人力资源、IT 基础设施和辅助性设施/场所。

- **人力资源**：人是最常被忽略的资源之一，组织可以恢复它的网络和关键系统，使业务功能恢复运作，但这时才发现没人操作。所以人是 BCP 的关键组成部分，应把对人的保护整合到 BCP 中。BCP 务必确保员工、客户、供应商和其他可能受到影响的个人在重大事件发生前、发生期间和发生后都是安全的。对于实施 BCP 的人员，应为他们提供完成所分配任务而需要的所有资源，包括为他们安排住宿和食品。所以 BCP 中应该包括对 BCP 团队在面对灾难事件时的详细指导，如关键活动运行方式的文档，以及为支持团队长久地提供足够多的预备储备的相关策略，比如储备应该放在易接近的地方、定期轮换这些储备，以防损坏。

除此之外还应有关键人员的冗余计划，以防止关键人员在灾难中丧生或者突然离职。计划可能会包括关键岗位设置 AB 角，或者实施关键岗位轮换策略，对员工进行多种技能的培训，有些计划还规定，负责同一重要业务的人员不能同时面临某个特定的风险，比如不能同乘一架飞机。

- **IT 基础设施**：IT 基础设施主要包括信息系统所涉及的主要部分，如计算机硬件、

软件、支撑环境等。BCP 必须说明如何保护这些系统，从而抵御所确定的风险。提供保护的方法主要有两种：一是通过引入保护性措施来为系统抵御风险，这些措施包括购买 UPS 和发电机，使用火灾探测设备和灭火系统或者使用介质保护防范措施。另外，可以引入冗余性措施使 IT 基础设施受到保护，比如使用冗余服务器和通信链接，冗余供应商支持以及增加关键设备的存货等。在引入冗余性措施时，BCP 团队应该仔细标识关键设备，并估计平均故障间隔时间（Mean Time Between Failure， MTBF）和平均修复时间（Mean Time To Repair，MTTR），从而在处理和更换设备时提供必要的统计数据。

应制定信息防护策略，保证对组织运行至关重要的信息受到保护，使其保密性、完整性、可用性达到应有的水平。

这些相同的原则应用于任何基础设施组件，从而为关键性业务处理提供服务。

- **辅助性设施/场所**：许多业务为了完成其功能，要求使用专门的设备，如制造车间、操作中心、仓库、配送或物流中心，以及维修或维护站等。BCP 应该说明具体的保护方式，具体也有两种方式：一种是采取强化机制和过程用于保护现有的设施能够抵御已定义的风险，如设施建筑材料的强化、安装防火墙等；另一种是在不可能强化设施抵御风险时，BCP 应该确定业务活动可以立即恢复的预备场所，如热站、温站、冷站。不同类型的事故或威胁可能需要实施不同或多个场所的选项。正确的策略是基于组织的规模、行业、活动的范围，基于利益相关方，基于地理位置进行考虑。这部分在“灾难恢复计划”中介绍。

② 风险转移

对于某些风险，最好的响应方式可能是转移风险。这可通过常规的保险或合同安排来实现风险转移，或通过向第三方支付费用以其他方式处理风险。该选项对于降低财务风险或资产的风险尤为合适。风险是可被转移的，之所以组织可通过风险转移来减少风险，是因为另一个组织可能更能够有效地管理风险。需要注意的是，某些风险不能（或不能全部）转移，例如不能转移信誉风险，即使服务交付是外包的，产生安全问题影响的仍然是组织信誉。

购买保险可能构成风险处理的一部分，购买保险可能给部分损失带来一定的财务补偿。网络保险是一种新型的保险项目，它为由拒绝服务攻击、恶意软件破坏、黑客、电子盗窃、与隐私有关的法律诉讼以及其他事件造成的损失提供保险。组织根据它的安全计划（如是否拥有防火墙、IDS、防病毒软件和其他安全措施）来决定网络保险的保险费。

组织还可以购买一种业务中断保险，购买这种保险后，如果组织业务中断一段时间，那么保险公司将赔付指定的开支和损失的收入。也可以购买应收账款购买保险，如果组织因某种原因无法收回应收账款，那么这种保险将赔付部分或全部损失与成本。

但是并非所有的损失都是可以保险的，如不确定的事故、品牌或信誉的损失、市场份额的降低或人身安全等。

单独的财务处置方法很难如相关利益人所期望的全面保护组织。必要的保险安排通常

与一个或多个其他策略相配套。

③ 风险规避

在某些情形下，变更、延缓或停止某种服务或业务功能，可能是合适的方法。该方式应只在与组织目标、法律法规符合性以及利益相关方的期望不发生冲突时考虑。

④ 风险接受

风险可不采取任何进一步的活动，而被接受。即使是不可接受风险，但对某些风险能够采取措施的能力有限，或者采取措施的潜在收益与成本不成比例。如果组织高层管理者认为风险是可以接受的，那么响应措施是接受现有的风险水平。

在组织的风险偏好内，如果高层管理人员认为风险是可能接受的，在这些情况下，响应措施可能是忍受现有的风险水平。在某些情形下，风险的影响可能超出了组织的风险偏好，但风险发生的可能性较低或风险控制成本不经济，最高管理层可接受风险。对风险发生的影响处置计划可作为风险接受的补充。

（2）BCP 文档化

文档化是 BCP 过程中的关键步骤，其文档中应包含如下内容。

① BCP 的目标

文档中应当描述 BCP 团队和高级管理层提出的 BCP 的目标，它有助于指导 BCP 资源和任务的合理分配，为 BCP 的实际制订过程提供指导，以及对计划和程序的整体经济性做出合理判断。这些目标应当在第一次 BCP 团队会议上或会议之前决定，并且很可能在 BCP 的生命周期内保持不变。

BCP 最初的目标可能会很简单，比如目标可能是“确保在灾难事件发生时保证业务的连续性运行”。这样的目标可能不太明确和具体，缺乏实用性，所以为了满足组织的需求，有可能会细化目标，或者会定义量化指标。例如，要求关键性业务不能中断超过 30 分钟，一年不能中断两次，或者备份服务器能够每小时处理全速工作 75%的处理负载。

② 职责声明

文档中还应该明确职责。每个参与 BCP 的人都应当将他们的职责以书面形式列出，以便在混乱时能够明确自己的职责。组织职责声明重申了组织对 BCP 的承诺，并且通知组织的员工、供应商和分支机构，要求他们每个人都做他们能够协助 BCP 过程的所有工作。每项工作都应当被分配给最适合的人员，他们必须了解自己的职责，可能通过培训、演习和文档来培养意识。

③ 优先级声明

了解哪些是关键业务，哪些是次要业务极为重要，不同部门为一个组织机构提供不同的功能，必须了解首先恢复哪部分，然后恢复哪个部分，即为组织、系统、信息设立优先级，比如在恢复文件服务器之前，有必要保证数据库能够正常运行。这样才能以一种最实用、最高效、最集中的方式完成。

优先级声明是 BIA 的优先级确定阶段的直接产物，但它仅仅涉及按优先次序列出的被认为对连续业务操作具有关键作用的功能。当列出这些优先级后，还应当包括一个声明，

指出它们是 BCP 过程的一部分，并且反映这些功能在灾难事件中对连续性业务操作的重要性，否则这个优先级的列表可能形同虚设，并且导致竞争组织之间的争斗，进而对业务连续性计划造成破坏。在优先级声明中应该包括各业务恢复的紧急程度和时限的声明表。

④ 风险评估

BCP 文档的风险评估部分实质上重述了 BIA 中进行的决策制定过程。它应该包括对 BIA 过程中所有风险的讨论以及评估这些风险时执行的定性和定量分析。另外，由于风险在持续变化，风险评估内容必须进行定期更新。

⑤ BCP 策略

BCP 策略应该覆盖风险分析时确定的所有风险的处置，包括可接受的风险和不可接受的风险。对于那些被认为可接受的风险，应当阐述风险被认为可接受的原因，以及未来可能导致值得重新考虑这个决定的事件。对于那些被认为不可接受的风险，应当阐述风险缓解的预备措施和用来减少威胁组织持续生存能力的风险过程。

⑥ 关键业务记录计划

BCP 文档还应当概述组织的关键业务记录计划。这份文档应阐述关键业务记录将要存放的地方和这些记录建立及备份的过程。执行关键业务记录计划最大的问题是关键业务记录的识别，有些组织对自己的业务记录存放在哪些位置并不十分清楚。所以需要重建组织的关键业务流程，从而产生一份有关组织的关键业务记录清单，清单中不仅包括流程本身，还包括每个流程所需的角色和资源。与关键业务流程相关的内容如下。

- 需要的角色。
- 需要的资源。
- 输入和输出机制。
- 工作流程步骤。
- 需要的完成时间。
- 与其他流程的接口。

关键业务记录计划将有助于 BCP 团队标识威胁和控制，以确保将流程中断造成的影响降至最低。

⑦ 应急响应的指导原则

指导原则文档概述了组织和个人对于紧急事件立即响应的职责。文档为首先发现紧急事件的员工提供了响应步骤，这些指导原则应当包括下列内容。

- 立即响应规程。例如，安全性规程、防火规程、通知该事件的紧急处理机构（消防、网警等）。
- 按事件通知清单进行通知。例如，负责该事件的主管、BCP 团队成员或应急响应团队等。
- 等待 BCP 团队或应急响应团队实施二级响应规程。

该指导原则应该被所有人了解并接受，当灾难事件来临时，最宝贵的是时间，如果第一发现人能够及时有效地执行响应规程，可大大降低业务因事件而造成的损失。

⑧ 测试与演习

BCP 文档还应当阐述一个正式的测试计划，以确保计划是最新的，并且所有人员都接受了充分培训，从而在实际的灾难事件发生时能够履行他们的职责。测试过程实际上与用于灾难恢复的计划非常类似。

（3）BCP 的批准与实施

完成 BCP 文档后，需要向高级管理层汇报，并获取计划的批准。汇报的过程中需要对计划目标和具体控制措施进行详细的说明。高级管理层批准后，BCP 团队就应当推动并开始实现计划。

培训和教育是 BCP 实现中的一项重要内容。计划中涉及的所有人都应接受整个计划中与个人职责相关的培训。对 BCP 有直接责任的员工更需要进行足够的培训，并对其在 BCP 中具体负责的任务进行评估以确保在灾难发生时他们能够有效地完成安排的任务。

4．BCP 的评估及维护

BCP 文档和计划本身必须是实际使用中的文档。每个组织都会遇到几乎持续的变化，这种动态特性也确保了业务连续性要求随之发生变化。BCP 团队应当定期讨论计划、复审计划测试的结果，以确保能够继续满足组织的要求。在更新 BCP 时，需要进行版本控制，所有旧的 BCP 版本都应该进行物理销毁。

4.2　知识子域：信息安全应急响应

4.2.1　信息安全事件与应急响应

1．基本概念

信息安全事件是指由于自然或人为以及软、硬件本身缺陷或故障的原因，对信息系统造成危害，或者在信息系统内发生对社会造成负面影响的事件。至今，尚没有任何一种信息安全策略或防护措施，能够对信息及信息系统提供绝对的保护，这就使得信息安全事件的发生是可能的。因此，对信息安全事件进行有效管理和响应，最小化事件所造成的损失和负面影响，是组织信息安全战略的一部分。

应急响应是信息安全事件管理的重要内容。应急响应是指组织为了应对突发/重大信息安全事件的发生所做的准备，以及在事件发生后所采取的措施。应急响应工作与其他信息安全管理工作相比有其鲜明的特点：具有高技术复杂性与专业性、强突发性、对知识经验的高依赖性，以及需要广泛的协调与合作。

应急响应工作列为我国信息安全保障工作的重点之一。《关于加强信息安全保障工作的意见》（中办发〔2003〕27 号文）指出：“信息安全保障工作的要点在于，实行信息安全等级保护制度，建设基于密码技术的网络信任体系，建设信息安全监控体系，重视信息安全应急处理工作，推动信息安全技术研发与产业发展，建设信息安全法制与标准。”《网

络安全法》在“第五章 监测预警与应急处置”中，对我国的应急响应工作从法律上做了规定。

为了做好信息安全事件管理和应急响应工作，我国已经发布了一系列国家标准和相关文件，所涉及的标准有 GB/T 24364—2009《信息安全技术 信息安全应急响应计划规范》、GB/Z 20985—2007《信息技术 安全技术 信息安全事件管理指南》、GB/Z 20986—2007《信息安全技术 信息安全事件分类分级指南》和 GB/T 20988—2007《信息安全技术 信息系统灾难恢复规范》。2017 年 1 月，中央网信委印发了《国家网络安全事件应急预案》，同年 5 月，工信部印发了《工业控制系统信息安全事件应急管理工作指南》，同年 11 月，工信部印发了《公共互联网网络安全突发事件应急预案》。

2．信息安全事件分类与分级

信息安全事件的种类很多，严重程度也不尽相同，其响应和处理方式也应各不相同。对信息安全事件进行分类和分级管理，是有效防范和响应信息安全事件的基础，能够使事前准备、事中应对和事后处理的各项相关工作更具针对性和有效性。

（1）信息安全事件分类

信息安全事件的分类方法有多种。依据 GB/Z 20986—2007《信息安全技术 信息安全事件分类分级指南》，信息安全事件分为有害程序事件、网络攻击事件、信息破坏事件、信息内容安全事件、设备设施故障、灾害性事件和其他信息安全事件 7 个基本类别，每个基本分类分别包括若干个子类。例如，网络攻击事件，是指通过网络或其他技术手段，利用信息系统的配置缺陷、协议缺陷、程序缺陷或使用暴力攻击对信息系统实施攻击，并造成信息系统异常或对信息系统当前运行造成潜在危害的信息安全事件。网络攻击事件包括拒绝服务攻击事件、后门攻击事件、漏洞攻击事件、网络扫描窃听事件、网络钓鱼事件、干扰事件和其他网络攻击事件 7 个子类。

（2）信息安全事件分级

依据 GB/Z 20986—2007《信息安全技术 信息安全事件分类分级指南》，对信息安全事件的分级参考下列 3 个要素：信息系统的重要程度、系统损失和社会影响。信息系统的重要程度主要是基于信息系统所承载的业务对国家安全、经济建设、社会生活的重要性，以及业务对信息系统的依赖程度的考虑，划分为特别重要信息系统、重要信息系统和一般信息系统三级。系统损失是指由于信息安全事件对信息系统的软硬件、功能及数据的破坏，导致系统业务中断，从而给事发组织和国家所带来的损失，其大小主要考虑恢复系统正常运行和消除安全事件负面影响所需付出的代价，划分为特别严重的系统损失、严重的系统损失、较大的系统损失和较小的系统损失 4 个级别。社会影响是指信息安全事件对社会所造成影响的范围和程度，其大小主要考虑国家安全、社会秩序、经济建设和公众利益等方面的影响，划分为特别重大的社会影响、重大的社会影响、较大的社会影响和一般的社会影响 4 个级别。

根据信息安全事件的分级参考要素，可将信息安全事件划分为 4 个级别：特别重大事

件（I 级）、重大事件（II 级）、较大事件（III 级）和一般事件（IV 级）。例如，特别重大事件（I 级），是指能够导致特别严重影响或破坏的信息安全事件，包括以下情况：会使特别重要信息系统遭受特别重大的系统损失，如造成系统大面积瘫痪，使其丧失业务处理能力，或系统关键数据的保密性、完整性和可用性遭到严重破坏，恢复系统正常运行和消除安全事件负面影响所需付出的代价十分巨大，对于事发组织是不可承受的；产生特别重大的社会影响，如产生的社会影响会波及一个或多个省市的大部分地区，极大威胁国家安全，引起社会动荡，对经济建设有极其恶劣的负面影响，或者严重损害公众利益。其他 II 级、III 级和 IV 级事件，造成的系统损失和社会影响依次减弱，具体说明可参见 GB/Z 20986—2007 文件，如表 4-1 所示。

表 4-1　安全事件定级

特别重大事件（I 级）	特别重大事件是指能够导致特别严重影响或破坏的信息安全事件，包括以下情况： ① 会使特别重要的信息系统遭受特别严重的系统损失 ② 产生特别重大的社会影响
重大事件（II 级）	重大事件是指能够导致严重影响或破坏的信息安全事件，包括以下情况： ① 会使特别重要的信息系统遭受严重的系统损失，或使重要的信息系统遭受特别严重的系统损失 ② 产生重大的社会影响
较大事件（III 级）	较大事件是指能够导致较严重影响或破坏的信息安全事件，包括以下情况： ① 会使特别重要的信息系统遭受较大的系统损失，或使重要的信息系统遭受严重的系统损失、一般信息系统遭受特别严重的系统损失 ② 产生较大的社会影响
一般事件（IV 级）	一般事件是指不满足以上条件的信息安全事件，包括以下情况： ① 会使特别重要的信息系统遭受较小的系统损失，或使重要的信息系统遭受较大的系统损失、一般信息系统遭受严重或严重以下级别的系统损失 ② 产生一般的社会影响

中央网信委印发的《国家网络安全事件应急预案》中，把网络安全事件分为特别重大网络安全事件、重大网络安全事件、较大网络安全事件、一般网络安全事件。特别重大网络安全事件指的是重要网络和信息系统遭受特别严重的系统损失，造成系统大面积瘫痪，丧失业务处理能力；或国家秘密信息、重要敏感信息和关键数据丢失或被窃取、篡改、假冒，对国家安全和社会稳定构成特别严重威胁；或其他对国家安全、社会秩序、经济建设和公众利益构成特别严重威胁、造成特别严重影响的网络安全事件。其他级别的事件，造成的损失和影响依次减弱。

工信部印发的《公共互联网网络安全突发事件应急预案》中，参照了《国家网络安全事件应急预案》，根据社会影响范围和危害程度，把公共互联网网络安全突发事件分为特

别重大事件、重大事件、较大事件、一般事件。特别重大事件指的是以下方面。

① 全国范围大量互联网用户无法正常上网。

② .CN 国家顶级域名系统解析效率大幅下降。

③ 1 亿以上互联网用户信息泄露。

④ 网络病毒在全国范围大面积爆发。

⑤ 其他造成或可能造成特别重大危害或影响的网络安全事件。

⑥ 其他级别的事件，造成的损失和影响依次减弱。

3. 信息安全应急响应组织

应急响应组织是专门处理安全事件的组织，常用的名字是计算机网络安全事件应急组（Computer Network Security Emergency Response Team，CNSERT）、计算机安全事件响应组（Computer Security Incident Response Team，CSIRT）、信息安全事件响应组（Information Security Incident Response Team，ISIRT）或事件响应组（Incident Response Team，IRT）。

（1）国际应急响应组织

世界上第一个信息安全应急响应组织的成立归因于 1988 年 11 月发生的“莫里斯蠕虫病毒”事件。基于该事件以及对安全应急响应的认识的逐渐深入，卡内基梅隆大学的软件工程学院向美国国防部高级研究项目处申请资金，成立了计算机应急响应协调中心（Computer Emergency Response Team/Coordination Center，CERT/CC），协调处理整个互联网的信息安全应急响应。目前，CERT/CC 是美国国防部资助下的抗毁性网络系统计划的一部分，下设事件处理、安全漏洞处理和计算机安全事件响应组 3 个部门。CERT/CC 成立后，随着互联网的迅速发展，美国以及世界各地的学术研究机构、政府部门以及商业领域纷纷成立了与自身业务相关的应急响应机构。在这种情况下，NIST 联合 CERT/CC、亚洲相互协作与信任措施会议（Conference on Interaction and Confidence-Building Measures in Asia，CICA）、美国航空航天局（National Aeronautics and Space Administration，NASA）以及其他 IRT 组织，成立了事件响应与安全组论坛（Forum of Incident Response and Security Teams，FIRST）。FIRST 通过促进多个 IRT 组织及厂商间的合作来提高信息技术的安全性，并为 IRT 组织和其他的安全研究机构提供一个研讨信息安全缺陷的论坛。此外，还有亚太地区计算机应急响应组（Asia Pacific Computer Emergency Response Team，APCERT）和欧洲计算机网络研究教育协会（Trans-European Research and Education Networking Association，TERENA）等区域性应急响应组织。

（2）国内应急响应组织

我国早期的计算机安全事件的应急响应工作主要包括计算机病毒防范和“千年虫”问题的解决，但是关于网络安全应急响应的起步较晚。1995 年 5 月，清华大学信息网络工程研究中心成立了中国第一个专门从事网络安全应急响应的组织，即中国教育和科研计算机网应急响应组。1999 年 10 月，东南大学网络中心成立了中国教育网华东（北）地区网络安全应急响应组。此外，中国电信成立了 ChinaNet 安全小组，中国人民解放军、公安部以

及一些商业网络安全服务公司也先后成立其 IRT。在这种发展趋势下，需要一个组织来为各行业、部门以及公司的应急响应协调和交流提供便利条件，同时为政府提供应急响应服务，因而国家计算机网络与信息安全管理中心的国家计算机网络应急技术处理协调中心（National Computer Network Emergency Response Technical Team/Coordination Center of China，CNCERT/CC）应运而生。在 CNCERT/CC 运作协调下，国内应急响应组织之间不但开展了一些国内的交流活动，而且也开始参与国际的交流。此外，我国还有国家计算机病毒应急处理中心、国家计算机网络入侵防范中心、国家 863 计划反计算机入侵和防病毒研究中心等应急响应组织。

4．应急响应组织架构

由于信息安全事件的不可预测性及后果的严重性，在组织内部，有必要建立信息安全应急响应组织，全力应对信息安全事件。信息安全应急响应组织通常由管理、业务、技术和行政后勤等人员组成，常见的角色有应急响应领导小组、应急响应技术保障小组、应急响应专家小组、应急响应实施小组和应急响应日常运行小组 5 个功能小组，如图 4-1 所示。

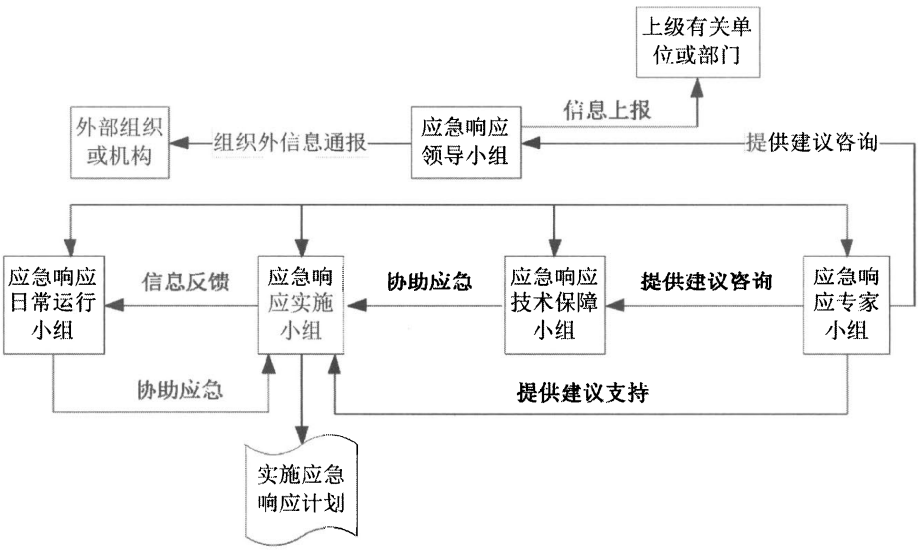

图 4-1　应急响应组织的一般构成

（1）应急响应领导小组的主要职责

领导和决策信息安全应急响应的重大事宜。

（2）应急响应技术保障小组的主要职责

① 制定信息安全事件技术对应表。

② 制定具体的角色和职责分工细则。

③ 制定应急响应协同调度方案等。

（3）应急响应专家小组的主要职责

① 对重大信息安全事件进行评估，提出启动应急响应的建议。

② 研究分析信息安全事件的相关情况及发展趋势，为应急响应提供咨询或提出建议等。

（4）应急响应实施小组的主要职责

① 分析应急响应需求，如风险评估、业务影响分析等。

② 确定应急响应策略和等级。

③ 实现应急响应策略。

④ 编制应急响应计划文档。

⑤ 组织应急响应计划的测试、培训和演练。

⑥ 合理部署和使用应急响应资源等。

（5）应急响应日常运行小组的主要职责

① 协助灾难恢复系统的实施。

② 备份中心的日常管理。

③ 备份系统的运行与维护。

④ 应急监控系统的运作与维护。

⑤ 落实基础物质的保障工作。

⑥ 维护和管理应急响应计划文档等。

组织建立的内部应急响应组织应与外部的国内外应急响应组织、相关管理部门、设备设施及服务提供商（如电力供应、通信服务等）、利益相关方和新闻媒体等保持联系和协作，以确保在发生信息安全事件时能及时通报准确情况，并获得支持。

4.2.2 网络安全应急响应预案

《礼记·中庸》中记载“凡事预则立，不预则废”，鉴于应急响应在信息安全事件（含灾难性事件）中的重要性，为减小各类事件导致的系列影响，同时确保在期望的时间内恢复信息系统，良好的应急预案实施与合理部署可谓重中之重。

网络安全应急预案是在分析网络与信息系统突发事件后果和应急能力的基础上，针对可能发生的重大网络与信息系统突发事件，预先制订的行动计划或应急对策。应急响应预案应建立在综合防灾规划之上，明确关键业务系统信息安全应急响应指挥体系和工作机制，提高应对网络和信息系统突发事件能力，减少突发事件造成的损失和危害，保障信息系统运行平稳、安全、有序、高效。

应急响应预案应当描述支持应急操作的技术能力，并适应组织要求。应急响应预案需要在详细程度和灵活程度之间取得平衡。因此预案的编制应根据实际情况，如事先进行业务影响分析和风险评估，确定应急响应策略，然后对应急响应的内容进行适当的调整、充实和本地化，以更好地满足组织特定系统、操作和机构需求。应急响应预案应能为信息安全事件中不熟悉计划的人员提供快捷明确的指导。

应急响应预案并没有必须遵守的标准格式，一般情况下应急预案应当包括总则、角色及职责、预防和预警机制、应急响应流程、应急响应保障措施和附件 6 个部分。可参考中

央网信委印发的《国家网络安全事件应急预案》。

为检验应急响应预案的有效性、应急准备的完善性、应急响应能力的适应性和应急人员的协同性，应针对应急响应预案进行演练。演练和演习的主要方式为桌面演练、模拟演练、实战演练等，根据演练和演习的深度，可分为数据级演练、应用级演练、业务级演练等；根据演练和演习的准备情况，可分为计划内的演练和演习、计划外的演练和演习等。

在网络安全应急演练之前，需要理解和熟悉应急响应预案的背景或相关信息，组织专门队伍，明确定位，同时还需对接单位既有的预防监控制度。同时应急响应小组中的相关人员要定期检查网络日志，加强对网络安全防护和应急准备工作的监督检查，保障网络或系统的安全畅通，随时准备发现网络安全问题、启动网络安全应急响应。

4.2.3　计算机取证与保全

计算机取证是使用先进的技术和工具，按照标准规程全面地检查计算机系统，以提取和保护有关计算机犯罪的相关证据的活动。取证的目的包括通过证据查找肇事者、通过证据推断犯罪过程、通过证据判断受害者损失程度及收集证据提供法律支持。电子证据是计算机系统运行过程中产生的各种信息记录及存储的电子化资料及物品。对于电子证据，取证工作主要围绕两方面进行：证据的获取和证据的分析。计算机取证的过程可以分为准备、保护、提取、分析和提交 5 个步骤。

1．准备阶段

准备阶段是计算机取证中必不可少的基础工作，包括以下 5 项工作。

（1）**获取授权**：取证工作获得明确的授权（授权书），该授权可由事件发生组织（受害方）或第三方执法机构（公安部门或其他执法机构）给出。

（2）**明确目标**：对取证的目标情况进行了解，确定取证的目标资料及信息，并对取证的目的有清晰的认识，明确取证要达到什么样的目标。

（3）**准备工具**：根据对取证环境的了解，准备需要的工具。

（4）**准备软件**：对取证的软件进行有效的验证，确保软件在取证环境下能有效地运行。

（5）**准备介质**：准备符合取证环境需要的干净的介质，确保有符合要求的足够容量的干净的介质用于取证。

2．保护阶段

主要目的是对目标环境进行保护，避免取证导致证据彻底丢失和数据进一步破坏。保护工作应确保以下几点。

（1）**保证数据安全性**：明确哪些取证操作可能导致证据或数据彻底丢失，避免使用这些类型的操作，如不要拔下电源线或关机。

（2）**保证数据完整性**：明确哪些取证操作能确保完整性，取证中不使用可能破坏完整性的操作，例如应该制作磁盘映像，尽量不在原始磁盘上操作；确保目标系统、服务和网

络在取证过程中受到保护，防止其变得不可用、被改变或受到其他危害；同时确保对正常运行的影响最小或没有。

3．提取阶段

从受到侵害的计算机上获取信息，供随后的分析和处理。具体的操作过程是查看计算机的状态，复制磁盘上存储的数据，并将可疑数据复制到可信任的设备上。

4．分析阶段

对提取的数据进行详细的分析，从中发现被攻击的痕迹或相关线索。

5．提交阶段

对从分析中获取的证据或线索进行规范整理，总结事件发生的原因及在其演变过程以及每一阶段采取的行动，并将取证过程详细地记录下来，形成文件，一起提交。若需要，为内部惩罚或法律诉讼行动提供专家支持。

4.2.4 信息安全应急响应管理过程

基于应急响应工作的特点和事件的不规则性，事先制定出事件应急响应方法和过程，有助于一个组织在事件发生时阻止混乱的发生或是在混乱状态中迅速恢复控制，将损失和负面影响降至最低。应急响应方法和过程并不是唯一的。一种被广为接受的应急响应方法是将应急响应管理过程分为准备、检测、遏制、根除、恢复和跟踪总结 6 个阶段。

1．准备

作为应急响应工作的第一个阶段，准备阶段需要达到以下目标。

首先，应确定重要资产和风险，实施针对风险的防护措施。

其次，编制和管理应急响应计划，为了应对突发/重大信息安全事件而编制对包括信息系统运行在内的业务运行进行维持或恢复的策略和规程（应急响应计划），是信息安全应急响应规划过程中的关键步骤。应急响应计划的编制和管理分为 3 个阶段：应急响应计划的编制准备，编制应急响应计划，应急响应计划的测试、培训演练和维护。

另外，需要建立和训练应急响应组织和准备相关的资源。除了人力资源（应急响应组织）以外，应急响应还需要的基本资源包括财力资源、物质资源、技术资源和社会关系资源等。事先确定对这些资源的需求并准备就绪，是能够有效进行应急响应的基础。

2．检测

检测的目的是先确认事件是否真的发生，在肯定有安全事件发生后判定问题所发生的领域，其当前造成的危害和影响范围有多大，以及发展的速度与进一步的威胁是什么。在检测阶段，需要依次进行以下几方面的工作。

首先，进行监测、报告及信息收集。通过已经建立的信息安全事态/事件监测及报告制

度，收集并报告一切异常和可疑信息，以检测信息安全事件的发生。应急响应组织在接到报告或在察觉到有异常现象后，应立即开始行动，从多方面进一步收集有价值的信息来开展检测工作。

其次，确定事件类别和级别。

再次，初步动作和响应。

应急响应组织在接到报告或在察觉到有异常现象后，可以先进行以下初步响应工作：激活和增强审计功能、迅速备份完整系统、记录所发生的事件。然后评估事件的影响范围。最后，进行事件通告，包括信息通报、信息上报和信息披露3方面。

3．遏制

遏制的目的是限制事件影响的范围，同时也限制了潜在的损失和破坏，避免事件升级。在遏制阶段，通常要进行以下活动。

首先，启动应急响应计划。

其次，确定适当的响应方式。IRT 在掌握相关的信息后，应当就此事件来选择最适当的响应方式。这些选择包括恢复运行、在线响应与离线响应、识别攻击者、起诉和惩戒等。

再次，实施遏制行动。遏制措施可能会因事件的类别和级别不同而完全不同。常见的可选遏制措施如下。

（1）关闭相关系统。

（2）拔掉网线。

（3）修改所有防火墙和路由器的过滤规则，拒绝来自发起攻击的嫌疑主机的所有流量；封锁或删除被攻破的登录账号。

（4）提高系统、服务和网络行为的监控级别。

（5）设置诱饵服务器作为陷阱；关闭服务。

（6）反击攻击者的系统等。

应急响应组织应根据组织业务特点、事件性质来合理选择并实施遏制/封锁/隔离措施，以使损失最小化，同时确保遏制/封锁/隔离措施对各业务的影响最小。实施遏制措施后，应汇总相关数据，估计损失和遏制效果。

最后，须考虑用户在遏制工作中的角色。遏制工作应该由专业的 IRT 来完成。在应急响应策略文件中，建议一般用户遇到异常情况时，遵守以下行为规范。

（1）在没有向专家咨询之前不要关闭系统或者从网络上断开。

（2）按照组织的报告程序要求报告任何可疑的/异常的现象。

（3）继续监控并记录可疑的现象，直到处理该类安全事件的人员到达。

（4）不要修改系统或应用软件。

（5）除非得到管理层同意，不要告诉媒体任何信息。

4．根除

在根除阶段必须依据响应计划实施根除措施，有可能还需要制定计划以外的其他根除

措施。常见的根除措施有消除或阻断攻击源、找到并消除系统的脆弱性/漏洞、修改安全策略、加强防范措施、格式化被感染恶意程序的介质等。特别需要注意，如果受害者使用的是专用的系统，则根除操作必须遵循专门的操作规定；对机密的环境来说，低级格式化则更加彻底一些。

5．恢复

恢复的目标是把所有被破坏的系统和网络设备彻底地还原到它们原来正常的任务状态。恢复阶段的行动集中在建立临时业务处理能力、修复原系统的损害、在原系统或新设施中恢复运行业务能力、重建信息系统等恢复措施。应按应急响应计划中事先制定的业务恢复优先顺序和恢复步骤，顺次恢复相关的系统，恢复的优先顺序应依据 BIA 分析的结果来确定。每种系统的恢复步骤应在应急响应计划中详尽描述。通常，如下事务性行动步骤和技术性恢复操作应写入应急响应计划的恢复步骤中。

（1）恢复工作相关人员获得访问备用设施和地理区域的授权；通知相关系统的内部和外部业务伙伴。

（2）获得所需的办公用品和工作空间。

（3）获得所需的硬件部件。

（4）获得备份介质。

（5）恢复关键操作系统和应用软件（需要详细描述操作步骤）。

（6）恢复系统数据（需要详细描述操作步骤）。

（7）启用备份系统。

（8）获得访问受损设施和地理区域的授权。

（9）重建主系统。

（10）通知重要用户系统已经恢复；在适当的时候解除封锁措施等。

6．跟踪总结

跟踪总结的目标是跟踪系统恢复后的安全状况，回顾并汇总所发生事件的相关信息。这一阶段对于圆满完成响应任务、提供有助于法律行动的信息以及完善响应者的知识、经验体系与响应能力是相当重要的。在此阶段，通常构造一个事件的时间线，包括事件本身的发展以及响应运作的内容；还应该做一份关于损失的报告并重新进行风险评估以及提出新的安全建议；并基于此次响应的经验和教训重新评估和修改应急响应策略和应急响应计划，这既包括技术上的，也包括程序上的和涉及人的相互影响的因素。最终，需要编写并提交一份条理清晰的、完整的应急响应过程记录与应急响应报告。

需要注意的是，真实的事件应急响应过程是不可能以这种纯粹串行的方式发生的，这里只是描述了一个理想的应急响应过程。应急响应过程中各阶段任务的协调以及响应中人的关系的协调永远是应急响应工作中两个同等重要的课题。同时，这 6 个阶段的响应方法也不能确保事件处理的成功，事件处理的成功涉及事件的性质、应急响应组织的能力和应急响应保障措施的落实等众多因素，但这种有序的响应过程确实是提高应急响应成功率的

基础。因此在应急处置的过程中须结合“谁主管谁保障，谁保障谁处置，谁处置谁报告”的原则，实现统一指挥、协调联动、专业处置、沟通顺畅、反应灵敏、运转高效的信息安全应急响应。

4.3 知识子域：灾难备份与恢复

BCP 关注于在基础设施功能和资源减少或受限的情况下维持业务操作。只要维持组织执行关键工作任务的能力的连续性，BCP 就能够被用于管理和还原系统环境。如果这种连续性受到破坏，那么业务过程就会停止，则组织进入灾难模式，组织需要制订灾难恢复计划（Disaster Recovery Planning，DRP）帮助组织恢复运营。因此，DRP 在 BCP 中止时开始。当灾难发生且 BCP 无法防止业务中断时，DRP 开始生效，并且指导紧急事件响应人员的工作，在预定的灾难恢复目标内恢复信息系统支持的关键业务功能。

BCP 和 DRP 处理过程之间会有很多重叠的地方，也有很多组织都只有单个团队和计划，同时涉及业务连续性和灾难恢复所关注的内容。

4.3.1 灾难备份与恢复基础

1. 灾备概念

灾难备份简称灾备，是指为了保证关键业务和应用在经历各种灾难后，仍然能够最大限度地提供正常服务所进行的一系列系统计划及建设行为，其目的就是确保关键业务持续运行以及减少非计划宕机时间。灾备包括灾难备份和灾难恢复两层含义。为了灾难恢复而对数据、数据处理系统、网络系统、基础设施、技术支持能力和运行管理能力进行备份的过程称为灾难备份。灾难备份是灾难恢复的基础，是围绕着灾难恢复所进行的各类备份工作。灾难恢复不应只关注信息系统恢复，更应该考虑的是业务的恢复。

灾备可以大幅提高业务计算机系统抵御突发性灾难的能力，有效地保护重要数据，使重要业务数据可以在设定的时间内恢复，从而实现业务的持续运行，进而增强客户及潜在客户的信心，让企业在信息行业的竞争中取得优势。

灾难恢复计划是定义信息系统灾难恢复过程中所需的任务、行动、数据和资源的文件，用于指导相关人员在预定的灾难恢复目标内恢复信息系统支持的关键业务功能。灾难恢复能力（Disaster Recovery Capability，DRC），是在灾难发生后利用灾难恢复资源和灾难恢复预案及时恢复和继续运作的能力。

2. 灾备指标

灾备指标是用于衡量组织机构容灾性能的重要参考指标，在这些指标中，恢复时间目标（Recovery Time Objective，RTO）和恢复点目标（Recovery Point Objective，RPO）是其中两个非常重要的指标，能很好地反映出容灾性能如何。因此在灾备体系建设过程中，一

定要重点关注这两个指标。

RPO 是指在业务恢复后的数据与最新数据之间的差异程度，这个程度使用时间作为衡量指标。这个差异主要与数据的备份频次有关，备份频次越高，当业务发生故障时，丢失的数据就越少。例如一周进行一次备份，那么系统发生故障时，丢失的数据最多可能会达到一周，而数据一天一备的情况下，最多丢失一天的数据。RPO 的值越小，灾备的性能越好，如果 RPO=0，说明数据是实时备份，不会出现数据丢失的情况。

RTO 是系统发生故障到恢复业务所需要的时间，也就是容许服务中断的时间。RTO 值越小，系统从故障中恢复的时间就越短，说明系统从灾难中恢复能力就越强，如果 RTO=0，那么服务就不会中断。

RPO 和 RTO 两个指标从不同的角度来反映灾难备份和恢复的能力，RTO 和 RTO 都为 0 是最完美的解决方案，因为在两个值都为 0 的情况下，意味着系统永不中断服务，而且完全没有数据丢失。当然，要达到这样的目标，系统建设投入会非常巨大。

在实际的容灾备份系统的建设中，必须根据实际业务系统的使用情况，综合考虑网络条件、投资规模、业务系统长远发展规划等各种因素，平衡 RPO、RTO 指标和成本投入的关系，才能制定合理的、可行的容灾系统设计指标。

3．灾难恢复组织

灾难恢复组织应由管理、业务、技术和行政后勤等人员组成，通常会分为灾难恢复领导小组、灾难恢复实施组和灾难恢复日常运行组等角色。其中，实施组的人员在实施任务完成后可成为日常运行组的成员。组织可聘请外部专家协助灾难恢复规划工作，也可委托外部机构承担实施组和运行组的部分或全部工作。

常见的灾难恢复组织结构如图 4-2 所示。

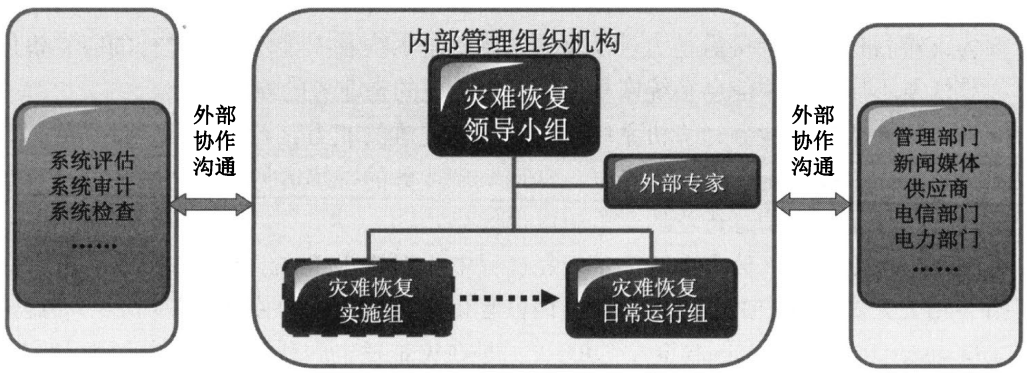

图 4-2　灾难恢复组织结构

灾难恢复领导小组，是实施灾难恢复规划工作的组织领导机构，组长应由单位高层领导担任，负责领导和决策灾难恢复规划重大事宜，其一般职责包括审核并批准经费预算、审核并批准灾难恢复策略、审核并批准灾难恢复预案、组织灾难恢复预案的测试和演练、批准灾难恢复预案的执行等。

灾难恢复实施组的一般职责包括灾难恢复的需求分析、提出灾难恢复策略和等级、灾难恢复策略的实现、制定灾难恢复预案等。灾难恢复日常运行组的一般职责包括灾难备份中心日常管理、灾难备份系统的运行和维护、灾难恢复的技术支持、灾难恢复预案的教育及培训和演练、维护和管理灾难恢复预案、突发事件发生时的损失控制和损害评估、灾难发生后信息系统和业务功能的恢复、灾难发生后的外部协作等。

4．国家灾备相关政策标准

国家对信息系统灾备建设高度重视，在政策支持方面逐级加深，颁布了一系列灾备行业相关的法律和法规，建立了适合我国信息化系统的灾备标准体系，为国家信息化建设提供信息安全保障。

（1）国家政策及相关标准

2003年，中共中央办公厅颁布的《国家信息化领导小组关于加强信息安全保障工作的意见》中首次提到灾备的概念，提出基础网络和重要信息系统的建设要充分考虑抗毁性和灾难恢复，制定和不断完善信息安全应急处置预案。

2004年，国务院信息化工作办公室发布的《关于做好重要信息系统灾难备份工作的通知》，提出需要提高抵御灾难和重大事故的能力，确保重要信息系统的数据安全和作业连续性。

2005年，国务院信息化工作办公室发布的《关于印发“重要信息系统灾难恢复指南”的通知》，指明了灾难恢复工作的流程、等级划分和预案的制定框架。

2007年，国务院信息化工作办公室发布的GB/T 20988—2007《信息系统灾难恢复规范》，规定了灾难恢复工作的流程，灾难恢复等级，以及灾难恢复方案设计、预案、演练等框架。该标准是灾备行业目前唯一的一套国家标准，对国内重点行业及相关行业的灾难备份与恢复工作的开展与实施有积极指导意义。

2013年，全国信息安全标准化技术委员会发布的《灾难恢复中心建设与运维管理规范》，指出了灾备中心建设的全生命周期、灾备中心的运维工作等。

（2）行业规定

在国家积极制定灾难备份国家标准的同时，灾难备份相关重点行业（尤其是银行、电力、铁路、民航、证券、保险、海关、税务八大行业）也纷纷加快了对信息系统灾难备份行业标准的制定。其中，银行业、证券业和保险业在灾备相关标准制定过程中进展较为迅速。

① 银行业相关法规条款

《商业银行操作风险管理指引》第十九条中规定“商业银行应当制定与其业务规模和复杂性相适应的应急和业务连续方案，建立恢复服务和保证业务连续运行的备用机制，并应当定期检查、测试其灾难恢复和业务连续机制，确保在出现灾难和业务严重中断时这些方案和机制的正常执行。” 此规定涉及了业务连续和灾难恢复相关的内容，明确了银行业应制定适当的业务连续性规划。

《银行业金融机构信息系统风险管理指引》第二十九条中规定“银行业金融机构应制定信息系统应急预案，并定期演练、评审和修订。省域以下数据中心至少实现数据备份异地保存，省域数据中心至少实现异地数据实时备份，全国性数据中心实现异地灾备。”此规定明确了银行业金融机构的数据备份要求。

② 证券业相关法规条款

在《证券期货业信息系统安全等级保护基本要求》中在应用安全和数据安全方面对灾备提出了明确的要求。《证券公司集中交易安全管理技术指引》明确了灾难备份 BCP（业务连续性计划）的 3 个具体指标，该指引提出“RPO（恢复点目标）、RTO（恢复时间目标）、DOO（运行性能降低预期）是衡量灾难恢复性能好坏的关键指标，应分别达到：RPO<16 分钟，RTO<1 小时，DOO<50%。”《证券公司集中交易安全管理技术指引》第四十七条规定“应定期组织灾难备份应急预案和应急计划的演练，至少每年两次，并根据演练的结果和发现的问题进行总结，对系统和应急方案进行优化及完善。”明确了灾备预案演练周期。

③ 保险业相关法规条款

保监会下发的《关于做好重要信息系统灾难备份工作的通知》，要求保险企业需要确定本单位的灾难恢复目标和建设模式，制订完善的灾难恢复计划。保监会发布了《保险业信息系统灾难恢复管理指引》，对保险机构信息系统灾备建设进度和灾难恢复能力进行了明确要求，“保险机构应统筹规划信息系统灾难恢复工作，自本指引生效起五年内至少达到本指引规定的最低灾难恢复能力等级要求。”

4.3.2 灾难恢复相关技术

灾难恢复管理是一门综合学科，涉及很多基础技术，如存储技术、备份技术、冗余磁盘阵列磁盘高可用性技术，以及各种备用场所。

1. 存储技术

依据网络存储结构，计算机数据存储技术主要分为直接附加存储（Direct Attached Storage，DAS）、存储区域网络（Storage Area Network，SAN）和网络附加存储（Network Attached Storage，NAS）3 种。

（1）直接附加存储

直接附加存储也称为服务器附加存储（Server Attached Storage，SAS），是通过服务器、客户机的 I/O 接口进行数据传输的存储设备。DAS 是硬件的堆叠，本身不带任何的操作系统，是计算机系统的扩展。DAS 是计算机系统中最常用的数据存储方法，很容易实现大容量存储，存取性能较高，实施也非常简单。由于 DAS 依赖于计算机系统，因此需要占用主机性能，并且当连接的主机发生故障时，存储的数据就无法读取，并且还存在扩展性差、资源利用率低、可管理性差等问题。

（2）存储区域网络

SAN 使用网状通道（Fibre Channel，FC）技术，服务器和存储阵列通过 FC 交换机进行连接，建立专用于数据存储的区域网络。SAN 通过同一物理通道支持广泛使用的 SCSI 和 IP 协议，这使得 SAN 允许任何类型的服务器连接到任意的存储阵列中，扩展性也很强，增加存储空间或增加存储空间的服务器都非常方便。由于使用了光纤交换，性能非常高，存取速度很快。SAN 技术经过多年发展，已经非常成熟，但由于各个厂商的光纤交换技术不完全相同，其服务器和 SAN 存储有兼容性的要求。

SAN 应用的主要局限是成本高，实施复杂，特别是服务器物理位置分散时，实施难度较大。

（3）网络附加存储

NAS 不再通过 I/O 总线将存储设备附属于某个特定的计算机，而是一种直接通过网络接口将存储设备与网络进行连接，用户通过网络进行访问。NAS 本身就是一台独立的计算机，有自身的操作系统，因此用户可通过网络访问和管理数据。NAS 的优点是易于安装、部署和管理，并且不占用服务器资源，可跨平台使用等。

NAS 本身能够支持多种协议（如 NFS、CIFS、FTP、HTTP 等），而且能够支持各种操作系统。通过任何一台工作站，采用 IE 或其他浏览器就可以对 NAS 设备进行直观方便的管理。因此 NAS 是真正即插即用的设备，并且部署也非常灵活简单。

NAS 的不足在于性能相对较差，因为数据传输使用网络，可能影响网络流量，甚至可能产生数据泄漏等安全问题。并且对数据的访问通过 NAS 操作系统进行，在某种情况下严重影响了效率，例如像大型数据库等对数据操作要求较高的系统就不宜采用 NAS 进行存储。

2．备份技术

备份技术不仅仅是灾难管理工作的需要，当数据资源由于灾难、病毒、黑客攻击、误操作、硬件故障等遭到损失、破坏、毁坏时，备份是最后也是唯一的办法。备份的重要性及相关技术和操作，在信息安全领域中怎么强调都不过分。

（1）备份方式

在备份技术中，主要包含全部备份、增量备份和差分备份 3 种备份方式。全部备份是对整个系统所有文件进行完全备份，包括所有系统和数据；增量备份是每次备份的数据相当于上一次备份后增加和修改过的数据；差分备份是每次备份的数据相对于上一次全部备份之后新增加和修改过的数据。这 3 种备份方式各有优缺点，在实际工作中，需要根据组织各自的备份需求，结合所使用的备份软硬件的实际情况，综合 3 种备份方式，制定自己特定的备份策略。通常，要对数据进行大量修改时，应该先做一次全备份。增量备份最适合用来对经常发生变更的数据进行备份。差分备份可以把文件恢复过程简单化。全部备份与增量或差分备份合用可以做到使用最少的介质来保存需要长期保存的数据。表 4-2 列举了 3 种备份方式的优势与劣势。

表 4-2　不同备份方式比较

备份方式	优　势	劣　势
全部备份	当前系统备份中包含所有的文件，只需要一份存储介质就可以进行恢复工作	如果文件没有经常变更，备份容易造成相当大的冗余，全部备份相当耗时
增量备份	数据存储所需的空间很小，耗时短	文件存储在多个介质中，因此，难以找到所需要的介质
差分备份	数据恢复时只需最后一次的标准备份与差分备份，耗时比标准备份短	如果备份文件存储在单一介质上，恢复时间将会很长，如果每天都有大量数据变化，备份工作非常费时

（2）备份介质

有多种多样的存储介质可以用来存放数据，如磁带和磁盘。数据也可以复制到逻辑驱动器、可拆除磁盘、磁盘库或网络共享上。理想的存储设备应该有足够的容量来备份数据，并应该有错误检测和纠正机制。技术总是在不断进步，备份技术也不例外。因此，实时跟踪市场中最新的存储设备发展情况非常重要，特别是在决定采购合适设备之前。最常用的存储介质是磁带。备份中最常用的磁带类型有四分之一英寸卡带、数字音频带、8 毫米磁带和数字线性磁带，也可以使用光盘/高密度盘片（Compact Disk，CD）、DVD 等光盘，随着硬盘容量的增加，硬盘备份也成为存储备份的一个潮流。

也可以考虑远程存储。单一的介质驱动器可以通过网络共享，这样可以把数据复制到远程计算机中。远程存储可以看作是加强系统可用性的一种机制，保证文件服务器可以有充裕的空闲磁盘空间。对不经常使用的数据进行分离也可以减少备份程序的工作量。

3．冗余磁盘阵列

在计算机中添加容错和系统恢复组件的常见方法是增加冗余磁盘阵列（RAID）。冗余磁盘阵列包括两个或两个以上的磁盘，即使其中一个磁盘损坏，通过 RAID 配置，可保证磁盘继续运行。常见配置如下。

（1）RAID-O，又称为条带：它使用两个或两个以上磁盘，提高了磁盘子系统的性能，但不提供容错能力。

（2）RAID-1，又称为镜像：它使用两个磁盘，两个磁盘有相同的数据信息。如果一个磁盘损坏，另一个磁盘仍含有数据，系统仍能继续运行。

（3）RAID-5，又称为奇偶校验：它使用 3 个或 3 个以上磁盘，相当于一个磁盘，其中包含奇偶校验信息。如果单一磁盘损坏，磁盘阵列将继续运行，但速度会变慢。

（4）RAID-10，又称为 RAID 1+0 或条带镜像：是在条带 RAID-O 配置上再配置两个或两个以上镜像 RAID-l。它使用至少 4 个磁盘，但可以支持更多个磁盘，磁盘可添加数应为偶数。即使多个磁盘损坏，只要在每个镜像中至少有一个驱动器继续运行，它就能继续运行。然而，如果在任何镜像集中两个驱动器都损坏了，整个阵列将无法继续运行。

RAID 可基于软件，也可基于硬件。基于软件的系统需要操作系统来管理阵列中的磁

盘，而且这会降低系统的整体性能。它们相对便宜，因为不需要除额外磁盘以外的任何其他硬件。基于硬件的磁盘阵列系统通常更有效、更可靠。虽然基于硬件的磁盘阵列更昂贵，但当使用这种阵列以增加其各关键组件的可用性时，益处大于成本。

4．备用场所

备用场所/备用站点，有时也称为灾难备份中心，是指用于灾难发生时接替生产系统运行进行数据处理和支持关键业务功能运作的场所，包括备用数据处理中心、备用的工作环境、备用生活设施和技术支持及运行管理人员。在灾难恢复中，灾难通常导致信息系统需要切换到备用场所运行。基于备用场所具有的功能、备战性程度，备用场所可分为冷站、温站、热站、移动站和镜像站等类别。

冷站通常包含用于支持 IT 系统的足够空间和基础设施（电力、电信连接和环境控制）。此空间应有抬升地板和其他适用 IT 运行操作的设施。此类站点不包含 IT 设备并且通常不包含办公自动化设备，例如，电话、传真机或复印机。使用冷站时，组织要负责提供和安装必要的设备和通信能力。

温站是包含部分或所有系统硬件、软件、电信和电源资源装备的办公空间。温站维持于一个运行维护状态以接受重定位的系统。此类站点可能需要在接收系统和恢复人员前进行一些准备。在很多情况下，温站可以作为其他系统或功能正常运营的设施，当连续性计划启动的事件发生后，其正常活动将临时替换以容纳被中断的系统。

热站是有足够空间大小以支持系统要求和配备了必要的系统硬件、支持基础设施和支持人员的办公空间。热站通常配备了 1 周 7 天、每天 24 小时（7×24）的人员。一旦接到连续性计划启动通知后，热站人员将立即开始准备系统的运行。

移动站是带有满足系统需求的特定电信和 IT 设备的，为客户量身定做的自包含、可移动的站点。它们可以通过商业厂商租用。此设施通常包含在拖车尾部并可以开往和设置于所需的后备地点。在绝大多数情况下，要制订一个可行的恢复方案，在进行移动站的设计前应预先同厂商联系，双方签订一个服务水平协议（SLA）。这是必要的，因为配置移动站所需的时间可能较长，如果没有预先的协调，将移动站送达的时间可能会超过系统允许的中断时间。

镜像站是包含全部、实时信息镜像的冗余设施。镜像站点同主站点在技术方面是完全相同的。因为数据的处理和存储在主站和后备站同时进行，这种站点提供了最高级别的可用性，站点通常是由组织机构自己设计、建设、操作维护和维持。

表 4-3 总结了用于确定何种备用场所类型以适合组织机构需求的准则。组织机构应进一步基于业务影响分析中定义的特定需求对站点进行分析。在评估站点时，灾难恢复实施组应确保系统的安全、管理、运行操作和技术控制（如防火墙和物理访问控制）同预期站点相兼容。此类控制可以包含防火墙和物理访问控制、数据维护控制和站点及支持此站点的人员安全许可级别。

表 4-3　备用场所选择准则

站　点	费　用	硬件设备	电　信	设置时间	位　置
冷站	低	无	无	长	固定
温站	中	部分	部分/完全	中	固定
热站	中/高	完全	完全	短	固定
移动站	高	视相关情况而定	视相关情况而定	随相关情况而定	不固定
镜像站	高	完全	完全	无	固定

若基于建设和管理方式，备用场所又可分为 3 种类型：由组织拥有或运行维护的专用站点、同内部或外部实体通过签署互惠协议而确定的备用站点、向专业商业组织租用的备用站点。

由组织拥有或运行维护的专用站点，是完全由组织出资建设、使用、维护和管理，其可以是冷战、温站、热站、镜像站或移动站。

同内部或外部实体通过签署互惠协议而确定的备用站点，是由两个或更多有相似或相同 IT 配置和备份技术的组织，签订一个正式合同以相互作为备用场所或与同一个备用场所签订一个联合合同。这种类型的站点通过互惠协议建立。在签订互惠协议时必须仔细，因为每个站点在灾难事件发生后，除了本身的工作负荷外还必须支持其他站点。这种类型的协议需要从联合的角度出发，将两个组织的应用的恢复顺序排好优先级。应在合作伙伴站点进行测试，对恢复战略功能外附加的处理阈值、系统兼容性、备份配置、电信连接是否足够等安全措施进行评估。

向专业商业组织租用的备用站点，需要事先与专业商业组织签订商业合同，必须在合同中协商并清晰地说明足够的测试时间、工作空间、安全要求、硬件要求、电信要求、支持服务和恢复时间（在恢复期间，组织机构可以占用空间多久）。客户应意识到可能有多个组织与同一个厂商为相同的备用场所签订合同，因此，灾难同时影响这些用户时，此站点可能不能同时满足所有客户要求。因此，应确定厂商处理这种情况的策略并确定这种情况下的优先级。

当通过签署互惠协议或向专业商业组织租用而获得备用站点时，组织与合作伙伴应开发关于备用场所的理解备忘录、协议备忘录或服务级别协议。每一方的法律部门应审核和批准此协议。通常，协议至少应解决下面的所有相关内容：合同/协议持续时间；灾难宣布和占用（日常使用）、管理、维护、测试、每年费用的增加、交通支持费用（如果使用，接收和返回后备站数据/供应）的费用结构，成本/费用分配（如果使用）、账单和付费时间安排；灾难宣布（例如，构成灾难的情况，通知流程）；站点/设施访问和/或使用优先级；站点可用性；站点保证；在可行的情况下，定购相同服务和站点的其他客户，以及站点定购的总数；合同/协议变更或修改过程；合同/协议终止条件；协调服务扩展的过程；兼容性的保证；用于硬件、软件和任何特殊系统要求（硬件和软件）的 IT 系统要求（包括数据和

电信要求）；所需要的变更管理和通告，包括硬件、软件和基础设施；安全要求，包括特殊的安全要求；提供/不提供的人员支持；提供/不提供的设施服务（使用现场办公设备、饮水等）；测试，包括时间安排、可用性、测试持续时长，以及需要时的其他测试；记录管理（现场和非现场），包括电子介质和硬备份；服务级别管理（所提供的 IT 服务的质量的管理和性能测量）；工作场地要求（如椅子、桌子、电话和 PC）；所提供/不提供的其他内容；其他地方没有覆盖的费用；其他可适用的合同问题；其他可适用的技术要求等。

不管选择哪种备用场所，相应设施必须能够满足在灾难恢复预案中定义的系统运行需求。

4.3.3　灾难恢复策略

灾难恢复策略可供选择的范围很大，但所有的恢复策略都必须考虑的因素包括恢复时间、实施与维护恢复策略所需的投入等。恢复策略可依据国际标准来制定，以 SHARE78 最具有代表性；也可依据国家标准制定，如 GB/T 20988—2007《信息系统灾难恢复规范》；有些行业对恢复策略有具体的要求，也可以依据各行业的标准制定。

1．国际标准 SHARE78

国际标准 SHARE78 根据备份/恢复的范围、灾难恢复计划的状态、应用站点与灾难备份站点之间的距离、应用站点与灾难备份站点之间的连接方式、数据如何在两个站点之间传送、允许丢失数据量、如何确保需要更新的数据在备份站点更新、备份站点开始灾难备份工作的能力 8 个方面，对灾难备份的能力由低到高划分了 0～6 共 7 个层级，每一层级都在上一层级的基础上有所改进或提高。

（1）0 级：无异地备份

0 级的容灾仅在本地进行数据备份，并且没有制订灾难恢复计划，这种方式成本最低，仅能解决由于误操作或系统错误导致的数据丢失，但如果本地系统发生灾难性故障，例如硬盘故障，本地备份数据也会随之丢失，无法恢复。

（2）1 级：简单异地备份

将关键数据备份到其他介质上，然后将备份介质保存在异地。异地没有任何备份系统、包括服务器、网络通信等，并且未制订灾难恢复计划。相比 0 级，这种方式在本地系统发生毁灭性灾难后，可以将介质从异地运送过来进行数据恢复和业务恢复。这种实施方案成本较低，但管理压力较大，并且不适用数据量较大或需要快速恢复业务的系统。

（3）2 级：热备中心备份

将关键数据进行备份并存储在异地的热备份站点中，并且制订了相应的灾难恢复计划。在灾难发生时，可利用热备份站点中的数据进行恢复。由于热备站点的存在，使得在灾难发生时进行灾难恢复的效率更高，但也相应地增加了用户投入，包括热备站点设备成本、

管理人员成本等。

（4）3 级：电子传输备份

3 级灾备是在 2 级灾备的基础上，通过网络将关键数据传输到异地的灾备中心进行备份。由于使用网络传输代替了传统的数据传输方式，极大地提高了灾难备份和灾难恢复的速度。一旦灾难发生，关键数据可从异地的灾难备份中心通过网络迅速回复，或者通过网络切换，将关键应用恢复时间降低到小时级。3 级灾备需要备份站点持续运行，并且传输数据对带宽有较高的要求，因此成本相对有所增加。

（5）4 级：自动定时备份

在 2 级灾备的基础上，利用备份软件定时自动对关键数据进行备份并传输到异地，一旦灾难发生，备份中心的资源及数据可迅速恢复关键业务，不至于长时间中断。相比 3 级灾备，这一级别的备份数据采用自动化备份管理软件进行备份，因此效率更高，对备份管理软件和网络设备的要求也更高，投入成本也会增加。

（6）5 级：实时数据备份

需要保证生产系统中心和灾难备份中心的数据的一致性。灾难备份中心与生产系统同等规模建设，基本是业务系统的镜像。业务系统运行时，业务系统的数据变更采用远程异步提交方式来实现同步，应用站点和备份站点的数据都被更新。这种异步提交的方式使得在灾难发生时，仅有少量的数据丢失，恢复时间降低到分钟级或秒级。相应的对存储系统和数据同步软件要求较高，成本也大幅增加。

（7）6 级：数据零丢失

为了实现数据零丢失，生产系统和灾难备份中心的数据是同时更新的。所有的数据都通过专用的存储网络在本地和异地（灾备中心）同步提交，本地和异地都进行确认后才能生效。由于数据是同步写入本地和异地（灾备中心）的存储系统中，因此在灾难发生时灾备中心有全部的数据，数据不会丢失。通常情况下，这两个系统可以实现应用的自动接管，实现业务零中断。这种灾备方式在实际应用中存在对存储系统和存储专用网络要求高、成本投入巨大的问题，并且由于数据同步写入，也会影响生产系统的运行效率。

2．我国灾难恢复等级

在《重要信息系统灾难恢复指南》中，根据支持灾难恢复各个等级所需的资源，即数据备份系统、备用数据处理系统、备用网络系统、备用基础设施、技术支持能力、运行维护管理能力和灾难恢复预案这 7 个要素划分了 6 个灾难恢复等级。

各个灾难恢复能力级别对灾难恢复资源具备的程度要求如下。

（1）第 1 级：基本支持

若要具备第 1 级基本支持级别的灾难恢复能力，组织应每周至少做一次完全数据备份，将备份介质在场外存放；同时还需要有符合介质存放的场地；要制定介质存放、验证和转储的管理制度，并按介质特性对备份数据进行定期的有效性验证；需要制定经过完整测试和演练的灾难恢复预案。

（2）第 2 级：备用场地支持

若要具备第 2 级备用场地支持级别的灾难恢复能力，组织应在第 1 级的基础上，增加对备用数据处理系统、备用网络系统两个恢复要素的要求；备用基础设施增加了需要有备用的场地，其能满足信息系统和关键功能恢复运行的要求；对于组织的运行维护管理能力，也增加了具有备份场地管理制度和签署符合灾难恢复时间要求的紧急供货协议等要求。

（3）第 3 级：电子传输和部分设备支持

若要具备第 3 级电子传输和部分设备支持级别的灾难恢复能力，组织应在第 2 级的基础上，增强要求配置部分数据处理设备、部分通信线路和网络设备；要求每天实现多次的数据电子传输；对于专业技术支持能力，要求在备用场地配置专职的运行管理人员；对于运行维护管理能力，要求具备备用计算机机房管理制度和电子传输备份系统运行管理制度等。

（4）第 4 级：电子传输及完整设备支持

若要具备第 4 级电子传输及完整设备支持级别的灾难恢复能力，组织应在第 3 级的基础上，增强对备用数据处理系统、备用网络系统、备用基础设施、专业技术支持能力和运行维护管理能力等灾难恢复要素的要求，例如，要求配置灾难恢复所需要的全部数据处理设备、通信线路和网络设备，并处于就绪状态；备用场地也提出了 7×24 小时运行的要求等。

（5）第 5 级：实时数据传输及完整设备支持

若要具备第 5 级实时数据传输及完整设备支持级别的灾难恢复能力，组织应在第 4 级的基础上，增强对数据备份系统、备用网络系统、备用基础设施、专业技术支持能力、运行维护管理能力等灾难恢复要素的要求，例如，要求采用远程数据复制技术，利用网络将关键数据实时复制到备用场地；备用网络应具备自动或集中切换能力；备用场地有 7×24 小时专职数据备份、硬件和网络技术支持人员，具备较严格的运行管理制度等。

（6）第 6 级：数据零丢失和远程集群支持

若要具备第 6 级数据零丢失和远程集群支持级别的灾难恢复能力，组织应在第 5 级的基础上满足对灾难恢复要素的更为严格的要求，例如，要求实现远程数据实时备份，实现零丢失；备用数据处理系统具备与生产数据处理系统一致的处理能力并完全兼容，应用软件是集群的，可以实现实时无缝切换，并具备远程集群系统的实施监控和自动切换能力；对于备用网络系统的要求也加强，要求最终用户可通过网络同时接入主、备中心；备用场地还要有 7×24 小时专职操作系统、数据库和应用软件的技术支持人员，具备完善、严格的运行管理制度。

各个灾难恢复能力级别对灾难恢复要素的具体要求参见 GB/T 20988—2007《信息系统灾难恢复规范》。

3．组织常用的灾难恢复策略

组织在进行灾备策略选择时，通常根据对灾难的抵抗程度，把灾难恢复分为数据容灾、

系统容灾和应用容灾 3 个级别。

（1）数据容灾

数据容灾技术，是建立一个异地的容灾中心，该中心是本地关键应用数据的一个可用复制，数据同步或异步复制到此中心。在本地数据及整个应用系统出现灾难时，系统至少在异地保存有一份可用的关键业务的数据。该数据可以是本地生产数据的完全实时复制，也可以比本地数据略微落后，但一定是可用的。

（2）系统容灾

系统容灾技术可保护业务数据、系统数据，保证网络通信系统的可用性，避免计划外停机。系统容灾技术包括冗余技术、集群技术、网络恢复技术等。其中，冗余技术主要对磁盘系统（RAID）、电源系统和网络进行备份，在系统的主部件发生故障时冗余部件能代替主部件继续工作，避免系统停机。集群技术可以利用分散的主机保证操作系统的高可用性。网络恢复技术可以在交换机网络层实现动态网络路由重选，在不中断用户操作的情况下转入灾备中心。

（3）应用容灾

应用容灾技术在数据容灾技术的基础上，异地建立一套完整的与本地生产系统相当的备份应用系统（可以是互为备份）。完整的应用容灾，既要包含本地系统的安全机制、远程的数据复制机制，还应具有广域网范围的远程故障切换能力和故障诊断能力。一旦故障发生，系统要有强大的故障诊断和切换策略制定机制，确保快速的反应和迅速的业务接管，从而保护整个业务流程。建立这样一个系统是相对比较复杂的，不仅需要一份可用的数据复制，还要有包括网络、主机、应用，甚至 IP 等资源，以及各资源之间的良好协调。

应用容灾的实现技术要求高，通过负载均衡、应用集中和隔离、自动化监控等手段实现业务应用的连续性和高可用性。其中，使用负载均衡技术不但可以保证业务负载分发，还能实现故障的隔离与计划内停机维护；应用的集中和隔离可以方便用户对 IT 系统进行管理，减少出现故障的可能性，同时，在部分应用发生故障时，可通过应用隔离减少故障带来的影响；自动化监控手段可以有效减少人工错误操作带来的故障，同时也能及时有效地发现故障。

数据级容灾是前提，只有保证数据能及时、完整地复制到灾备中心，才能在灾难发生时及时恢复受灾业务；系统级容灾是实现灾难恢复的基础，要求信息系统本身具有容灾抗毁能力；应用级容灾是实现信息系统保持业务连续性、不间断服务的关键。

4．确定灾难恢复能力级别

组织所应具有的灾难恢复能力级别，应依据灾难恢复需要分析的结果来确定，其中，主要是依据业务影响分析而得出的各项业务/信息系统的 RTO、RPO 两个指标来确定。通常，可参照表 4-4，来确定组织所需要的灾难恢复能力级别。

表 4-4　RTO/RPO 与所需灾难恢复能力级别的关系

RTO	RPO	所需的恢复能力级别（参照国家标准）
48 小时以上	1～7 天	1
24～48 小时	1～7 天	2
12～24 小时	数小时～1 天	3
2～12 小时	数小时～1 天	4
30 分钟～2 小时	0～30 分钟	5
小于 30 分钟	0	6

4.3.4　灾难恢复管理过程

灾难恢复工作不仅包括灾难恢复规划和灾难备份中心的日常运行，还包括灾难发生后的应急响应、关键业务功能在灾难备份中心的恢复和重续运行，以及生产系统的灾后重建和回退工作，还涉及突发事件的应急响应。

灾难恢复规划是灾难恢复管理工作中最重要的一项工作，是其他灾难恢复工作的基础。组织应对灾难恢复规划这项工作本身有适当的管理，如应评估灾难恢复规划过程本身的风险、筹备所需资源、确定详细任务及时间表、监督和管理规划活动、跟踪和报告任务进展及对问题和变更进行管理。

灾难恢复的外部协作，也是确保信息系统能够及时有效恢复的因素之一。组织应与相关管理部门、设备及服务提供商、电信、电力和新闻媒体等保持联络和协作，以确保在灾难发生时能及时通报准确情况和获得适当支持。

组织灾难恢复的等级评定、灾难恢复预案的制定，应按有关规定进行审计和备案。灾难恢复规划是一个周而复始、持续改进的过程，包含以下 4 个阶段：灾难恢复需求分析、灾难恢复策略制定、灾难恢复策略实现和灾难恢复预案制定和管理，如图 4-3 所示。

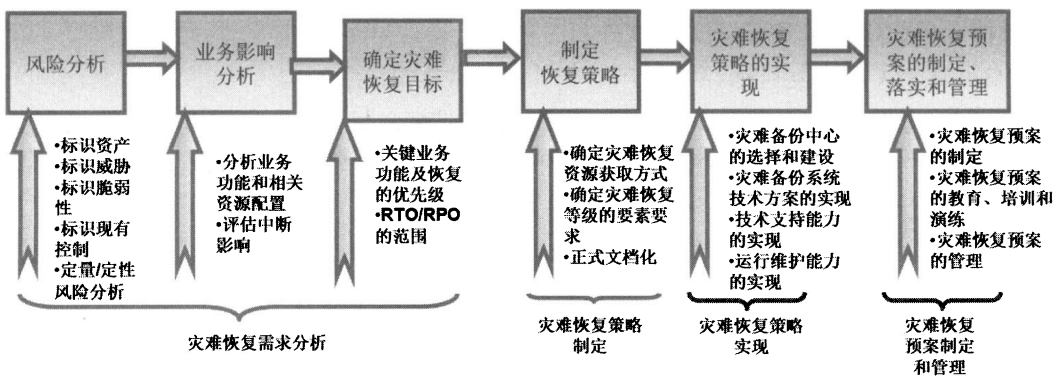

图 4-3　灾难恢复规划管理过程

1．灾难恢复需求分析

灾难恢复需求分析主要包括风险分析、业务影响分析和确定灾难恢复目标 3 个子步骤。

（1）风险分析

标识信息系统的资产价值，识别信息系统面临的自然的和人为的威胁，识别信息系统的漏洞，分析各种威胁发生的可能性，并定量或定性描述可能造成的损失。通过技术或管理手段，防范或控制信息系统的风险。依据防范或控制风险的可行性和残余风险的可接受程度，确定对风险的防范和控制措施。

（2）业务影响分析

业务影响分析包括分析业务功能和相关资源配置，以及评估中断影响，如图 4-4 所示。

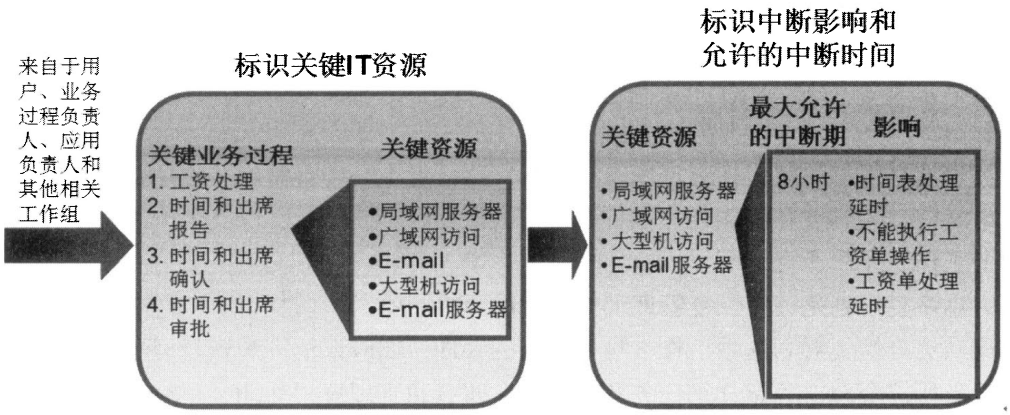

图 4-4　业务影响分析示例

① **分析业务功能和相关资源配置**：分析单位的各项业务功能及各项业务之间的相关性，确定支持各种业务功能的相应信息系统资源及其他资源，明确相关信息的保密性、完整性和可用性要求。

② **评估中断影响**：应采用定量和/或定性的方法，对各种业务功能的中断造成的影响进行评估。定量分析是以量化方法，评估业务功能的中断可能给单位带来的直接经济损失和间接经济损失；定性分析是以非量化方法，评估业务功能的中断可能对国家的政治、社会、法律及单位内部事务等造成的影响。

（3）确定灾难恢复目标

根据风险分析和业务影响分析的结果，确定灾难恢复目标，包括关键业务功能及恢复的优先顺序；灾难恢复时间范围，即 RTO 和 RPO 的范围，如图 4-5 所示。

2. 灾难恢复策略制定

制定灾难恢复策略，即要明确需要哪些灾难恢复资源、各项灾难恢复资源的获取方式，以及对各项灾难恢复资源的具体要求（即需要具备的灾难恢复能力等级）。

组织应根据灾难恢复需求/目标，按照灾难恢复资源的成本与风险可能造成的损失之间取得平衡的原则，即“成本风险平衡原则”，确定每项关键业务功能的灾难恢复策略，不同的业务功能可采用不同的灾难恢复策略。首先，要明确所需的灾难恢复资源。组织应根据灾难恢复需求/目标确定需要哪些灾难恢复资源。通常，将灾难恢复资源分为 7 大类（7

个要素）：数据备份系统、备用数据处理系统、备用网络系统、备用基础设施、专业技术支持能力、运行维护管理能力和灾难恢复预案。其次，要明确灾难恢复资源的获取方式；最后，明确对灾难恢复资源的具体要求。

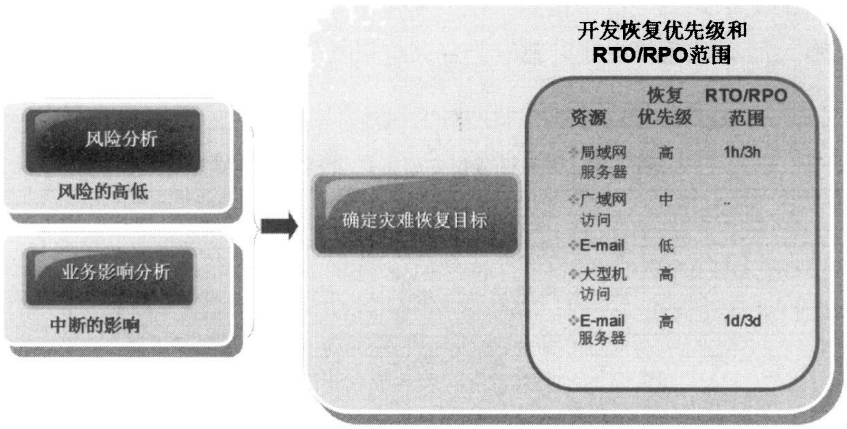

图 4-5　灾难恢复需求分析-确定灾难恢复目标

3．灾难恢复策略实现

在制定灾难恢复策略以后，就要实现灾难恢复策略。灾难恢复策略实现通常包括选择和建设灾难备份中心、实现灾备系统技术方案、实现专业技术支持能力和实现运行维护管理能力 4 个步骤。

（1）选择和建设灾难备份中心

选择或建设灾难备份中心，应遵循一般的选址原则。

选择或建设灾难备份中心时，应根据风险评估的结果，避免灾难备份中心与生产中心同时遭受同类风险。根据规避灾难风险影响范围的不同，灾难备份中心分同城和异地两种类型，二者的对比如表 4-5 所示。

表 4-5　同城和异地灾难备份中心的对比

	同　城	异　地
含义	指灾难备份中心与生产中心处于同一区域性风险威胁的地点，但又有一定距离，例如在数十千米以内	灾难备份中心不会同时遭受与生产中心同一区域性风险威胁的地点，例如距离生产中心数百千米以上
优点	技术上可以支持同步的数据实时备份方式，便于运营管理和灾难演练	对地震、地区停电、战争等大规模灾难防范能力较强
缺点	抵御灾难能力方面有局限性，对地震、地区停电、战争等大规模灾难防范能力较弱	技术上只能支持异步或定点复制的数据方式，运营管理和灾难演练的成本较高

灾难备份中心应具有数据备份和灾难恢复所需的通信、电力等资源，以及方便灾难恢复人员和设备到达的交通条件。

灾难备份中心应根据统筹规划、资源共享、平战结合的原则，合理布局。

在选择或建设灾备中心时，应满足对基础设施的基本要求。

在新建或选用灾难备份中心的基础设施时，计算机机房应符合国家相关标准的要求，如 GB/T 2887—2011《计算机场地通用规范》、GB 50174—2008《电子信息系统机房设计规范》、GB 50462—2008《电子信息系统机房施工及验收规范》等的要求。

工作设施、辅助设施和生活设施应符合灾难恢复目标的要求，主要包括表 4-6 中说明的几个方面。

表 4-6　对灾难备份中心基础设施的基本要求

设施类型	设施名称	说　明
工作设施	信息系统工作设施	位于灾难备份中心的核心区域的信息系统设备及相关配套设备，主要包括计算机机房、主操作室、通信机房、介质机房和信息系统设备测试维修机房等
	保障系统工作设施	位于灾难备份中心的保障设备区域，用来保障灾难备份中心 7×24 小时运行的设施，主要包括供配电设施、空调暖通设施、给排水设施、消防设施、监控设施和货运设施等
辅助设施	灾难备份中心辅助设施	用于灾难备份中心运行所需的配套设施，主要包括灾难备份中心办公室、会议室、资料室、值班室、仓库、客户接待室、客户休息室、客户活动区域、停车场和货物装卸区等
	灾难恢复辅助设施	灾难备份中心提供灾难恢复用途的设施，主要包括灾难恢复指挥中心、灾难恢复座席区、办公区、新闻发布中心（多媒体室）、会议室和打印传真室等
	灾难恢复培训设施	灾难备份中心提供用于灾难恢复或业务连续性培训的设施，主要包括培训教室、模拟演练室和培训人员办公室等
生活设施	保障人员生活设施	提供给灾难备份中心 7×24 小时运行而配备的人员生活所必需的设施，主要包括宿舍、食堂、健身房和阅览室等生活设施
	灾难恢复人员生活设施	提供给灾难恢复或灾难恢复培训人员所需要的生活设施，主要包括客房和食堂等生活设施

（2）实现灾备系统技术方案

主要经过 3 个步骤：技术方案的设计，技术方案的验证、确认和系统开发，系统安装和测试。

（3）实现专业技术支持能力

组织应根据灾难恢复策略的要求，获取对灾难备份系统的技术支持能力。灾难备份中心应建立相应的技术支持组织，定期对技术支持人员进行技能的教育和培训。

（4）实现运行维护管理能力

为了实现灾难恢复目标，灾难备份中心应建立各种操作规程和管理制度，用以保证数据备份的及时性和有效性；备用数据处理系统和备用网络系统处于正常状态，并与生产系统的参数保持一致；有效的应急响应、处理能力。

4．灾难恢复预案制定和管理

灾难恢复预案制定和管理是灾难恢复规划的重要内容，主要包括四方面的工作。

（1）制定灾难恢复预案

灾难恢复计划的制订是一项复杂的工作，需要经历多次修改，以满足业务要求，计划中要考虑灾难恢复预算对资源、时间和费用的限制，以及可以获得的人力资源。

灾难恢复计划中应当包含重要人员在识别出灾难或灾难即将来临时应立即遵守的、简单但内容全面的指令。根据灾难的性质、对事件做出响应的人员种类，以及在需要撤离设施和/或关闭设备之前可用的时间，这些指令千差万别。因此，灾难恢复计划的制订有别于其他计划，应遵守以下原则。

- 完整性：恢复计划应包含灾难恢复的整个过程，以及灾难恢复所需的尽可能全面的数据和资料。
- 易用性：恢复计划应运用易于理解的语言和图表，并适合在紧急情况下使用。
- 明确性：恢复计划应采用清晰的结构，对资源进行清楚的描述，工作内容和步骤应具体，每项工作应有明确的责任人。
- 有效性：恢复计划应尽可能满足灾难发生时进行恢复的实际需要，并保持与实际系统和人员组织同步更新。
- 兼容性：恢复计划应与其他应急体系有机结合。

恢复计划应按照风险分析和业务影响分析所确定的灾难恢复内容，根据灾难恢复等级的要求，结合组织其他相关的应急计划，撰写恢复计划。完成后，组织应对灾难恢复计划进行严格评审，评审应依据前面所确定的原则来进行。编制者根据评审结果进行修订。

灾难恢复计划应经过测试。测试之前应预先制订测试计划，测试应包含基本单元测试、关联测试和整体测试。测试的整个过程应有详细记录，并形成测试报告。

（2）灾难恢复计划的教育与培训

为了使灾难恢复参与人员了解信息系统灾难恢复的目标和流程，熟悉灾难恢复的操作规程，组织应进行灾难恢复计划的教育、培训和演练。

与业务连续性计划一样，对所有涉及灾难恢复工作的人员进行培训是十分重要的。在灾难恢复工作初期就应该开始灾难恢复观念的宣传教育工作。灾难恢复计划培训所要求的程度根据个人在公司中的职位和工作角色而有所不同。应预先对培训需求进行评估，设计培训计划时应该考虑下面的要素。

- 对全体新员工进行定向培训。
- 对第一次担任新的灾难恢复角色的员工进行基本培训。
- 对灾难恢复团队的成员进行详细的重复性培训。
- 对所有的其他员工进行简要的重复性培训。

应事先确定培训的频次和范围，事后保留培训的记录。

（3）灾难恢复计划演习

应预先制订演习计划，编写演习脚本，演习的整个过程应有详细的记录，并形成报告，

灾难恢复演习应保证至少每年一次。演习通常分为桌面演练、模拟演练和实战演练。

- 桌面演练：灾难恢复团队成员聚集在一间大会议室中，不同的人在灾难发生时扮演不同角色。通常，确切的灾难情景只有主考官知道，他在会议上向团队成员描述具体的情况。然后，团队成员通过参考他们的灾难恢复计划对特定的灾难类型进行讨论，进而得出适当的响应办法。
- 模拟演练：为灾难恢复团队成员呈现情景并要求他们产生出适当的响应措施。与前面讨论的桌面演练不同，其中某些响应措施随后会被触发。这种演练可能涉及中断非关键的业务活动并使用某些操作人员。
- 实战演练：将实际人员部署到备用场所和实现场所启用措施。被部署到该场所的员工，以灾难实际发生时的方式执行他们的灾难恢复职责。实战演练有业务非中断演练和业务中断演练两种方式。

（4）灾难恢复预案的保存与分发

正式的灾难恢复计划应由专人负责保存与分发，并形成多份备份在不同地点保存。每次修订后所有备份应统一更新，并保留一套，以备查阅，原分发的旧版本应销毁。

应该为不同的人员准备适合其岗位职责的相关文档，在灾难发生或即将来临时，使用特别定制的文档很重要，它能帮助人们保持头脑清醒来实施他们的计划。例如，管理者手里应该有一份文档，它对整个灾难恢复计划进行了高度概括，这样就不用听灾难恢复团队成员解释，通过这份文档的内容就能大致了解当前的灾难恢复工作是如何协调在一起的。IT 人员应有一份技术指南，以帮助他们建立和启用替代场所。灾难恢复团队的重要成员也应该有一份清单，这份清单在混乱的灾难环境中能够指导他们的行为。

灾难恢复计划应定期评审和修订。

第 5 章

知识域：安全工程与运营

阅读提示 本知识域包括系统安全工程、安全运营、信息内容安全、社会工程学与培训教育 4 个知识子域。系统安全工程知识子域介绍系统安全工程能力成熟度模型 SSE-CMM，了解 SSE-CMM 的体系及工程域维的风险过程、工程过程和保证过程，能力维 6 个级别。安全运营知识子域介绍了安全运营的概念和管理方法，而信息内容安全知识子域介绍了内容管理和舆情的相关知识。社会工程学介绍了利用人性弱点的安全领域相关知识。学员通过学习能了解信息系统工程过程和运营过程中可能涉及的安全知识。

5.1 知识子域：系统安全工程

安全工程是一个专门的工程领域，专注于信息系统的安全性，需要能够处理来自自然灾害及人类行为可能破坏来源的健壮性。它类似于其他系统工程活动，其主要的处理方式是支持包含预定义的功能和用户要求的工程解决方案的交付，但增加的维度可防止滥用和恶意行为。这些约束和限制通常被称为安全策略。

安全工程包括社会科学、心理学（如设计一个“失败”系统，而不是试图消除所有错误来源）、经济学以及物理学、化学、数学、建筑和园林绿化工程。同时，也涉及这些学科所使用的一些技术，如故障树分析等。

5.1.1 系统安全工程基础

1. 系统安全工程概念

随着社会对信息信赖程度的增长，信息的保护变得越来越重要。信息的维护与保护需要许多产品、系统和服务的结合。系统安全工程采用工程的概念、原理、技术和方法，来研究、开发、实施与维护信息系统安全的过程。它的主要目标如下。

- 获得对组织安全风险的理解。
- 根据已识别的安全风险建立一组平衡的安全需求。
- 将安全需求转换成安全的指导原则，这些安全指导原则将被综合到项目实施中的

其他科目活动和系统配置或运行的定义中。

- 通过正确有效的安全机制建立信心和保证。
- 判断系统本身和系统运行时残留的安全风险对运行的影响是否可接受。
- 将所有科目和专业活动集成为一个系统安全可信性的共同理解。

系统安全工程是多种科目和协同工作的工程组织中的一个关键部分。安全工程应用到系统和应用软件的开发、集成、操作、管理、维护和进化以及产品的开发、交付和升级中。在企业和业务过程中的定义、管理和重建中必须强调安全因素，这样安全工程就能够在产品、系统或服务中得到体现。

系统安全工程是信息化建设活动中与加强系统安全性相关活动的集合，所以信息安全工程活动必须要与其他相关实体进行协调，各种不同类型的组织都会涉及安全工程活动。例如在判断系统建设中和系统运行时残留的安全风险对运行的影响是否可容忍并做出可接受性保证时，必须由开发商、集成商、用户、采购方、独立评估方和其他组织共同决定。

由于系统工程整个生命周期都存在安全工程活动，因此安全工程活动与许多其他工程都存在着某种关系，如系统工程、软件工程、人力资源工程、通信工程、硬件工程、测试工程、系统管理等。它们之间都存在着关系接口，而这些接口又遍布各种组织且具有相互影响，所以安全工程与其他工程相比就更加复杂。

良好的安全工程要求将 4 个方面集中在一起，如图 5-1 所示。第一是策略，用于指明计划要达到的目标；第二是机制，密码、访问控制、硬件防篡改以及为了实现方针而组装的其他机制；第三是保证，也就是每种特定机制的可靠程度；最后是动机，也就是系统保护与维护人员正确履行职责的动力，也包括攻击者为突破安全策略必须付出的努力。

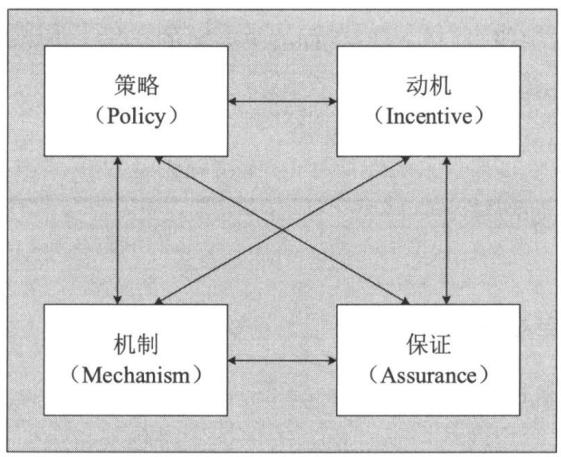

图 5-1　良好安全工程的 4 个方面

2．系统安全工程的必要性

系统安全工程是信息安全保障的重要组成部分，不可或缺。但是长期以来，人们在信息化建设过程中，信息安全建设却被广泛忽视。“重功能、轻安全”“先建设、后安全”的现象一直存在。没有实施安全建设的信息系统是在“走钢丝”，一旦出现问题，后果非

常严重。

国家对信息安全建设非常重视，如国家信息化领导小组在《关于加强信息安全保障工作的意见》中明确要求，“信息安全建设是信息化的有机组成部分，必须与信息化同步规划、同步建设。各地区各部门在信息化建设中，要同步考虑信息安全建设，保证信息安全设施的运行维护费用。”国家发展改革委所下发的《关于加强国家电子政务工程建设项目信息安全风险评估工作的通知》要求：“电子政务工程建设项目必须同步考虑安全问题，提供安全专项资金，信息安全风险评估结论是项目验收的重要依据。”在我国 2017 年正式发布的《网络安全法》中规定：“建设关键信息基础设施应当确保其具有支持业务稳定、持续运行的性能，并保证安全技术措施同步规划、同步建设、同步使用。”信息安全工程就是要解决信息系统生命周期的“过程安全”问题。

5.1.2　系统安全工程理论基础

1．系统工程思想

系统工程（Systems Engineering，SE）是 20 世纪中期兴起的一门新兴的交叉学科，它主要是应用定性分析和定量分析相结合的方法，通过建立实际对象的数学模型，应用合适的优化算法对模型进行求解，从而解决实际问题。

系统工程的目的是实现总体效果最优，即从复杂问题的总体入手，认为总体大于各部分之和，各部分虽然存在不足，但总体可以优化。如电话网络，不能只研究个别电话的质量问题，必须从总体网络入手。因此，系统工程技术通常被应用于复杂工程，从太空飞船到芯片设计，从机器人技术到大型软件产品。第一次应用并提出这个名词是在 1940 年，美国贝尔实验室研制电话通信网络时，将研制工作分为规划、研究、开发、应用和通用工程等 5 个阶段，提出了排队论原理。1940 年，美国研制原子弹的曼哈顿计划应用了系统工程原理进行协调。自觉应用系统工程方法而取得重大成果的两个例子是美国的登月火箭阿波罗计划和北欧跨国电网协调方案。

从学科体系上讲，系统工程不属于基本理论，也不属于技术基础，它所研究的重点是方法论。系统工程方法论是在综合应用运筹学、控制论、信息论、管理科学、心理学、经济学以及计算机科学等有关学科的理论和方法的基础上形成的科学思想和方法。它是在系统工程的实践中不断形成和发展起来的。早在 1957 年，美国学者 H.H.古德和 R.E.麦克霍尔在《系统工程》一书中就对工作步骤、工具和技术等方面做过较为系统的描述。到了 20 世纪 60 年代，许多系统工程学者根据实践经验，总结出了系统工程方法论的许多有关步骤、内容和方法，虽然这些工作成果在形式上不尽相同，但基本思想还是一致的，其中以霍尔的方法论最具代表性。美国系统工程专家霍尔（A.D.Hall）在 1969 年利用结构分析法提出著名的霍尔三维结构，使系统工程的工作阶段和步骤更为清晰明了。

霍尔三维结构是将系统工程整个活动过程分为前后紧密衔接的 7 个阶段和 7 个步骤，同时还考虑了为完成这些阶段和步骤所需要的各种专业知识和技能。这样，就形成了由时

间维、逻辑维和知识维所组成的三维空间结构，如图 5-2 所示。其中，时间维表示系统工程活动从开始到结束按时间顺序排列的全过程，分为规划、拟订方案、研制、生产、安装、运行、更新 7 个时间阶段。逻辑维是指时间维的每一个阶段内所要进行的工作内容和应该遵循的思维程序，包括明确问题、确定目标、系统综合、系统分析、优化、决策、实施 7 个逻辑步骤。知识维列举需要运用包括工程、医学、建筑、商业、法律、管理、社会科学、艺术等各种知识和技能。三维结构体系形象地描述了系统工程研究的框架，对其中任一阶段和每一个步骤，又可进一步展开，形成了分层次的树状体系。

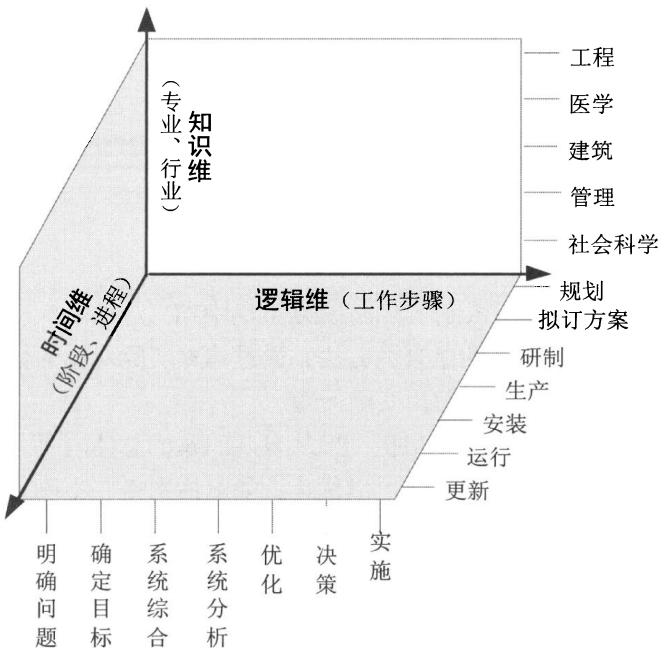

图 5-2　霍尔三维结构图

2．项目管理方法

项目是创造独特产品、服务或其他成果的一次性工作任务。这个工作任务用有限的资源、有限的时间为特定客户完成特定目标，因此项目需要有一个明确的目标或目的，必须在特定的时间、预算、资源限定内，依据规范完成。

项目管理（Project Management，PM）就是项目的管理者在有限的资源约束下，运用系统的观点、方法和理论，对项目涉及的全部工作进行有效地管理。即从项目的投资决策开始到项目结束的全过程进行计划、组织、指挥、协调、控制和评价，以实现项目的目标。

项目管理技术是在 20 世纪 50 年代出现的关键路径法（Critical Path Method，CPM）和计划评估和审查技术（Program Evaluation and Review Technique，PERT）的基础上发展起来的。它融合了后来发展起来的工作分解结构（Work Breakdown Structure，WBS）、蒙特卡罗（Monte Carlo）方法（也称模拟统计法）和挣值（Earned Value，EV）分析法，形成了一门关于项目资金、时间、人力等资源控制的管理科学，涉及项目范围、时间、成本、

质量、人力资源、沟通、风险、采购、集成九大知识领域。

项目管理所使用的技术其实都来源于系统工程的最优化思想，只不过这些技术是应用在项目的各个方面，以保证项目的最优化运行。因此可以说，项目管理是系统工程思想针对具体项目的实践应用。

在项目管理中，强调了项目的过程管理，主要包括项目的启动、计划、执行、控制和收尾这 5 个过程，贯穿于项目的整个生命周期。这些过程的应用能够大大提高项目取得成功的可能性。

3．质量管理体系

质量指产品或服务满足规定或需要的特征。质量包括了产品的适用性和符合性的全部内涵，既包括有形产品也包括无形产品，既包括产品内在的特性，也包括产品外在的特性。

质量控制（Quality Control，QC）是对生产的全部过程加以控制，是面的控制，不是点的控制。为保证产品过程或服务质量，必须采取一系列的作业、技术、组织、管理等有关活动，这些都属于质量控制的范畴。

质量管理（Quality Management，QM）是指为了实现质量目标，而进行的所有管理性质的活动。在质量方面的指挥和控制活动，通常包括制定质量方针和质量目标以及质量策划、质量控制、质量保证和质量改进。实现质量管理的方针目标，有效地开展各项质量管理活动，必须建立相应的管理体系，这个体系就叫质量管理体系。

质量管理体系是组织内部建立的、为实现质量目标所必需的系统性质量管理模式，是组织的一项战略决策。它将资源与过程结合，以过程管理方法进行的系统管理，根据企业特点选用若干体系要素加以组合，一般由与管理活动、资源提供、产品实现以及测量、分析与改进活动相关的过程组成，可以理解为涵盖了从确定顾客需求、设计研制、生产、检验、销售、交付之前全过程的策划、实施、监控、纠正与改进活动的要求，一般以文件化的方式，成为组织内部质量管理工作的要求。

国际标准化组织的质量管理和质量保证技术委员会制定了 ISO9000 族系列标准，以适用于不同类型、产品、规模与性质的组织。ISO9000 族标准并不是产品的技术标准，而是针对组织的管理结构、人员、技术能力、各项规章制度、技术文件和内部监督机制等一系列体现组织保证产品及服务质量的管理措施的标准。

ISO9000 族标准在以下 4 个方面规范质量管理。

（1）机构：标准明确规定了为保证产品质量而必须建立的管理机构及职责权限。

（2）程序：组织的产品生产必须制定规章制度、技术标准、质量手册、质量体系、操作检查程序，并使之文件化。

（3）过程：ISO9000 要求对生产的全过程都必须进行控制。从根据市场调研确定产品、设计产品、采购原材料，到生产、检验、包装和储运等，其全过程按程序要求控制质量，并要求过程具有标识性、监督性、可追溯性。

（4）总结：不断地总结、评价质量管理体系，不断地改进质量管理体系，使质量管理

呈螺旋式上升。

4．能力成熟度模型

能力成熟度模型（Capability Maturity Model，CMM）是一种衡量工程实施能力的方法，是一种面向工程过程的方法。CMM 是建立在统计过程控制理论基础上的，它基于这样一个假设，即“生产过程的高质量和在过程中组织实施的成熟性可以低成本地生产出高质量产品”。这种思想不关注结果，而是强调了过程的控制，过程中如果是高质量的，结果通常会是高质量的。事实也是这样，据统计，所有成功企业的共同特点是都具有一组严格定义、管理完善、可测可控从而高度有效的业务过程。

能力成熟度（Capability Maturity，CM）是指一个具体的工程过程被明确地定义、管理、评价、控制和产生实效的程度。所谓成熟度包含着能力的一种增长潜力，同时也表明了组织实施工程过程的实际水平。随着组织工程过程成熟度能力的不断提高，组织内部通过对过程的规范化和对成员的技术培训，工程过程也将会被它的使用者关注和不断修改完善，从而使工程质量、生产率和生产周期得到改善。CMM 模型就是抽取了这样一组好的工程实践并定义了过程的“能力”。CMM 有助于组织建立一个有规律的、成熟的过程。改进的过程将会生产出质量更好的产品，避免产品项目的时间和费用超支。

注意：过程的改善不可能在一夜之间完成，CMM 是以增量方式逐步引入变化的。

CMM 明确地定义了 5 个不同的“成熟度”等级。一个组织可按一系列小的改进向更高的成熟度等级前进。CMM 为工程的过程能力提供了一个阶梯式的改进框架，它基于以往工程的经验教训，提供了一个基于过程改进的框架图，它指出一个组织在开发方面需要哪些主要工作，这些工作之间的关系，以及开展工作的先后顺序，一步一步地做好这些工作而使组织走向成熟，如图 5-3 所示。

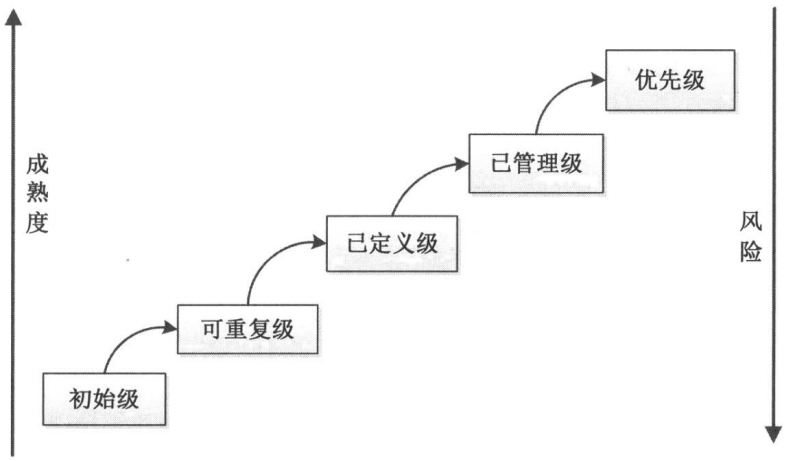

图 5-3　CMM“成熟度”等级

CMM 的思想来源于已有多年历史的项目管理和质量管理，自产生以来几经修订，成

为具有广泛影响的模型。尽管已有个人或团体提出了各种各样的成熟度模型，但还没有一个像 CMM 那样在业界确立了权威标准的地位。CMM 已经被广泛应用于各领域的工程过程改进，如软件工程领域有软件能力成熟度模型（SW-CMM），传统制造业领域有系统工程能力成熟度模型（SE-CMM），安全工程领域有系统安全工程能力成熟度模型（SSE-CMM）和系统安全工程能力成熟性模型评估方法（SSAM）等。

5.1.3　系统安全工程能力成熟度模型

1．SSE-CMM 基本概念

系统安全工程能力成熟度模型（Systems Security Engineering Capability Maturity Model，SSE-CMM）是一种衡量系统安全工程实施能力的方法，主要用于指导系统安全工程的完善和改进，使系统安全工程成为一个清晰定义的、成熟的、可管理的、可控制的、有效的和可度量的学科。

现代统计过程控制理论表明，通过强调生产过程的高质量和在过程中组织实施的成熟性可以低成本地生产出高质量产品。对于安全系统和可信产品的开发，如果增加所需的成本和时间，就可以保证更有效的过程。安全系统的运行与维护也依赖于人和技术过程，通过强调所使用过程的质量和过程中组织实施的成熟性，可以降低管理成本。

CMM 是一个框架，它用于将一个工程组织从一个特定的，组织不善、效率不高的状态，进化成高度结构化的且高效的状态。SSE-CMM 的开发基于这样的期望，即在安全工程中使用统计过程控制概念以促进在预期的成本、进度及质量范围内开发出安全系统和可信产品。

SSE-CMM 模型描述了一个组织的系统安全工程过程必须包含的本质特征，或者叫基本安全实施。这些特征是完善的安全工程保证，也是系统安全工程实施的度量标准，同时还是一个易于理解的评估系统安全工程实施的框架。

作为安全工程实施的度量标准，SSE-CMM 拥有系统安全工程的所有特征，如它覆盖整个组织的活动，包括管理、组织和工程活动等，而不仅仅是系统安全的工程活动；它与其他组织的相互作用，涉及开发者、产品供应商、集成商、采购者、安全评估组织、资质评估认证组织、咨询服务商等；同时 SSE-CMM 不是孤立的工程，而是与其他工程并行且相互作用，包括企业工程、软件工程、硬件工程、基建工程、人力资源工程、通信工程、测试工程、系统管理等。另外，SSE-CMM 可应用于所有类型和大小的安全工程机构，如业务机构、政府机构和学术机构。

SSE-CMM 可以使安全工程成为一个确定的、成熟的和可度量的科目。它可以带来如下益处。

（1）对于获取组织（包括从内部/外部获取系统、产品和服务的组织以及最终用户）

- 使用可重用的评定方法。
- 降低选择不合格投标者的风险（性能，成本，工期风险）。

- 基于工业标准的统一评估以减少争议。
- 在产品生产或提供服务过程中建立可预测和可重复级的可信度。

（2）对于工程实施组织（包括系统集成商、应用开发者、产品厂商和服务供应商）

- 通过可重复和可预测的过程和实施来减少返工、提高质量、降低成本，改进安全工程实施能力。
- 获得公众对其真正工程实施能力的认可，特别在资源选择方面。
- 关注于提升组织的资质（成熟度）和改进能力。

（3）对于评估组织（包括认证机构、系统授权机构、产品评估机构和产品评价机构）

- 过程评估结果具有可重复性，与系统或产品的改变无关。
- 在安全工程以及与其他工程集成中获得信任度。
- 基于可见的对能力的信任，可以减少安全评估工作量。

2．SSE-CMM 的体系结构

SSE-CMM 体系结构被设计用于在整个安全工程过程中判断安全工程组织的成熟性。这个体系结构的目标是从管理和制度化特征中分离出安全工程清晰的基本特征。SSE-CMM 模型是一个两维的模型，分别称为“域维”和“能力维”。“域维”由所有安全工程定义的过程区域（Process Area，PA）构成，“能力维”代表组织能力，它由过程管理和制度化能力构成。通过设置这两个相互依赖的维，SSE-CMM 为整个安全工程活动范围定义各自的能力级别。

例如，在图 5-4 中，“评估脆弱性”过程区域显示在横坐标中。这个过程区域代表了所有涉及安全脆弱性评估的实施活动，这些实施活动是安全风险过程的一部分。“跟踪执行”公共特征显示在纵坐标上，它代表了一组涉及测量的实施活动。这些测量相对于可用计划的过程实施活动。因此，过程区域和公共特征的交叉点表示组织跟踪执行脆弱性评估过程的能力。图 5-4 中每一个方框表示一个组织执行一些安全工程过程的能力。通过这种方式收集安全组织的信息，可以建立执行安全工程能力的能力轮廓。

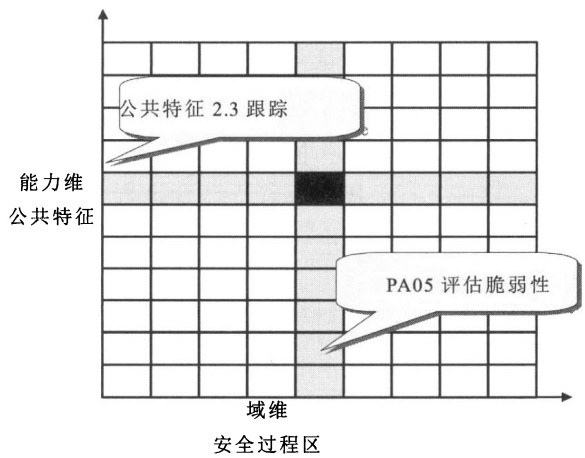

图 5-4　安全工程能力

（1）域维

域维由所有安全工程定义的过程活动构成，这些实施活动称为“过程区域”。但需要注意的是，这个模型并不要求一个组织完成所有的信息安全工程的任何过程，也不要求用最新的或者是最好的技术或方法，但它所规定的措施必须做到。这些特征是完善的安全工程保证，也是系统安全工程实施的度量标准，同时还是一个易于理解的评估系统安全工程实施的框架。然而，这个模型要求是一个组织机构要有一个适当的过程，这个过程应包括这个模型中所描述的基本安全实施，即域维所包含的内容。组织机构以任何方式随意创建符合他们业务目标的过程以及组织结构。因此，一个过程区有如下特点。

- 汇集一个域中的相关活动。
- 可应用于整个组织生命周期。
- 能在多个组织和多个产品范围内实现。
- 能作为一个独立过程进行改进。

每个过程区域包括一组表示组织成功执行过程区域的目标。每个过程区域也包括一组集成的基本实施（Base Practice，BP）。基本实施定义了获得过程区域目标的必要步骤，它具有如下特性。

- 应用于整个组织生命周期。
- 和其他 BP 互不覆盖。
- 代表安全业界“最好的实施”。
- 在业务环境下不指定特定的方法或工具。

SSE-CMM 域维涉及 3 个过程类，即工程过程类、组织过程类和项目过程类。工程过程类中包含 11 个过程区域，描述了系统安全工程中实施的与安全直接相关的活动，也是 CISP 培训及考试的内容。组织和项目过程类中包含了另外 11 个过程区域，这些过程区域是从 SE-CMM 修改过来，并不直接同系统安全相关，但常与工程过程的 11 个过程区域一起用来度量系统安全队伍的过程能力成熟度。

SSE-CMM 整个域维的结构如图 5-5 所示。

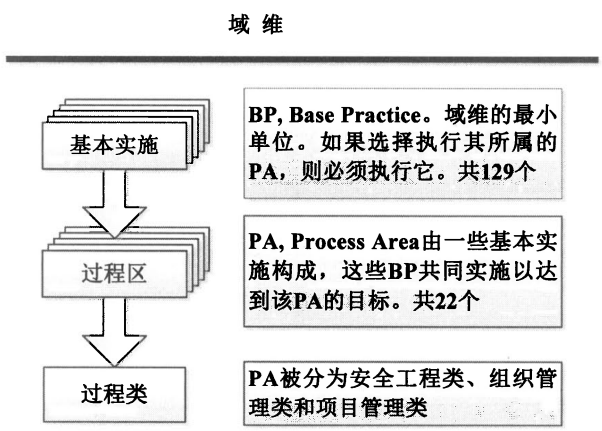

图 5-5　SSE-CMM 域维结构图

（2）能力维

能力维按实施成熟性排序，共分为 5 个级别，依次表示不断增强的组织能力。组织能力由被称之为“公共特征”的逻辑域组成，每一个公共特征包括一个或多个通用实施。

能力维结构如图 5-6 所示。

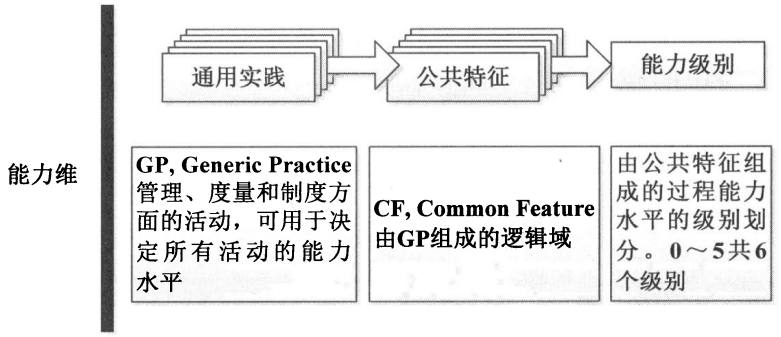

图 5-6　能力维结构图

注意：一个组织机构可随意以他们所选择的方式和次序来计划、跟踪、定义、控制和改进他们的过程。然而，由于一些较高级别的通用实施依赖于较低级别的通用实施，因此，组织机构在试图达到较高级别之前，应首先实现较低级别通用实施。

通过设置这两个相互依赖的维，SSE-CMM 在各个能力级别上覆盖了整个安全活动范围。给每个 PA 赋予一个能力级别评分，所得到的两维图形便形象地反映一个工程组织整体上的系统安全工程能力成熟度，也间接地反映其工作结果的质量及其安全上的可信度。图 5-7 所示为某个组织的能力轮廓。图中纵坐标为能力的 5 个级别，横坐标中包含了 5 个过程区域。这个能力轮廓说明了这个组织的能力并不成熟，它有一个过程区域能力级只有 1 级。

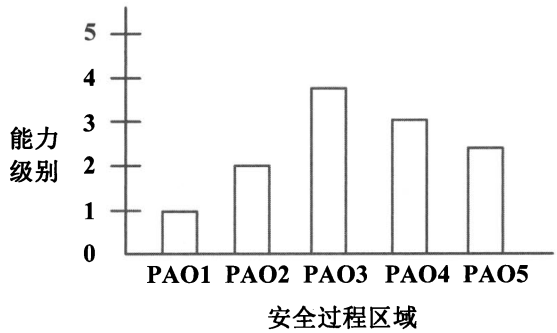

图 5-7　能力轮廓图

5.1.4　SSE-CMM 的安全工程过程

SSE-CMM 将域维中的工程过程类的 11 个过程区域划分为 3 个基本过程领域，分别是

风险过程、工程过程、保证过程。它们相互独立，但又有机联系，如图 5-8 所示。风险过程识别出所开发的产品或系统的风险，并对这些风险进行优先级排序。针对风险所面临的安全问题，工程过程要与其他工程一起来确定和实施解决方案。最后，由安全保证过程建立起解决方案的可信性并向用户转达这种安全可信性。这 3 个过程共同实现了安全工程过程结果所要达到的安全目标。

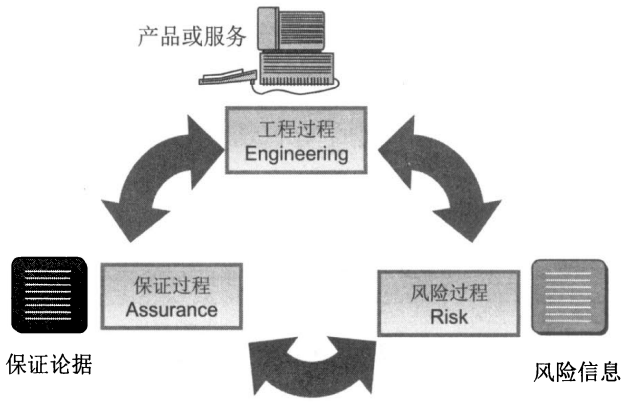

图 5-8　系统安全工程过程区域的组成

1．风险过程

系统安全工程的主要目标就是降低风险到可接受范围。安全工程中的风险三要素是影响、威胁和脆弱性。如果不存在脆弱性和威胁，则不存在有害事件，也就不存在风险。风险评估是调查和量化风险的过程。它是安全管理的一个重要部分。图 5-9 显示的是风险过程包括的过程区域。

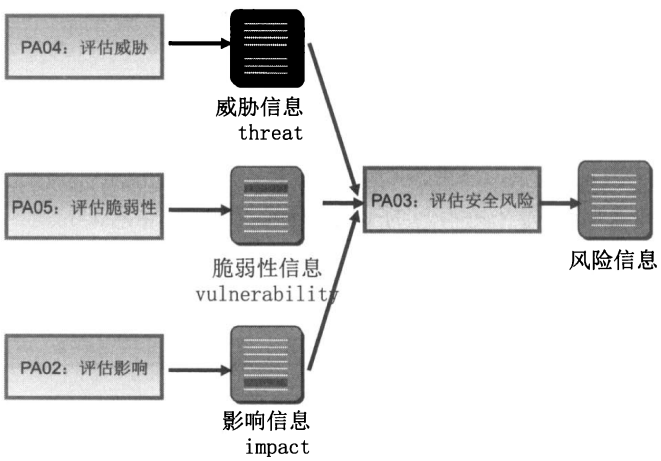

图 5-9　风险过程

注意：通常风险管理中的风险三要素是资产、威胁和脆弱性。与安全工程中的风险三要素并不矛盾，“影响”即指对“资产”安全的影响，资产越有价值，影响也就越大。

安全措施的实施可以控制风险，但不可能消除所有威胁或根除某个具体威胁，必须接受残留的风险。由于风险度量不精确的本质特征，因此对风险的度量也存在很大的不确定性，通常情况下，风险过程中常常会出现纠结于在何种程度上接受风险是最恰当的情况。

（1）PA04 评估威胁

评估威胁过程区域的目的在于识别安全威胁及其性质和特征。由于威胁可能发生变化，因此必须定期地对其进行监视，以保证由本过程区域所产生的安全理解始终得到维持。

本过程区域基本实施有 6 项。

- BP.04.01 识别由自然因素所引起的有关威胁。
- BP.04.02 识别由人为因素所引起的有关威胁。
- BP.04.03 制定评判威胁的测度单位。
- BP.04.04 评估威胁源的动机和能力。
- BP.04.05 评估威胁事件出现的可能性。
- BP.04.06 监控威胁的变化。

这里需要注意的是 BP.04.03 项，即需要确定用什么指标来衡量威胁的高低。自然和人为威胁都有与之相关的测度单位，应根据具体情况，对可能在特定位置中出现的事件，建立测度范围。比如说，“未授权访问”是个威胁，那么它威胁的范围，可以根据具体情况设定为一台主机、一个 VPN 域，或一个业务区等作为它威胁的范围测度单位，或者比如我们常说的十年一遇的冰灾，百年一遇的洪水，十年、百年也可作为威胁的范围测度单位。如果某一特定威胁不存在标准的测度单位，可以自己设立一个标准测度单位，并对标准单位进行描述。

在 BP.04.04 项中，我们主要根据攻击者对系统有多大兴趣，攻击者拥有的知识、技能、工具和其他资源来评估威胁源的动力和能力。比如在 IATF 模型中，威胁被划定了 7 个等级，第 1 级定义为“无意的或意外的事件”；第 7 级定义为“占有丰富程度资源的熟练的对手，愿意冒较大的风险。”

（2）PA05 评估脆弱性

本过程区域包括分析系统资产、定义特殊的脆弱性以及对整个系统脆弱性的评估。评估活动在系统生命期内任何时间都可进行，以支持在已知环境中对系统的开发、维护和运行做出决策。由于脆弱性会发生变化，所以必须定期监控。

本过程区域基本实施有 5 项。

- BP.05.01 选择用于识别和描述系统脆弱性的方法、技术和标准。
- BP.05.02 识别系统存在的脆弱性。
- BP.05.03 收集与脆弱性特征有关的数据。
- BP.05.04 对脆弱性进行综合分析，评判脆弱性或脆弱性组合可能带来的危害。
- BP.05.05 监控脆弱性的变化。

在 BP.05.01 项中，脆弱性分析方法可以是现有的、经裁剪的或者专门针对系统中特定运行方面和确定环境而制定的。它可以是定量的、定性的或者是定量定性综合方法。需要注意的是，在整个评估期间，所选用的分析方法要求要统一，因为不同的分析方法，所产

生的分析结果可能是不一致的，这样会让我们无法判别各个脆弱性之间的层次关系。

在 BP.05.03 项中，收集与脆弱性特征有关的数据，包括该脆弱性如果被威胁利用给资产带来的危害；该脆弱性有没有已经发布的补丁或者解决方案，如果有，可以在哪里能够安全得到，如果没有，是否还有相关的解决措施或者避免方式等。

（3）PA02 评估影响

评估影响的目的是识别对该系统有关的影响，并对发生影响的可能性进行评估。评估影响要遵循成本和效益的平衡原则。另外必须考虑意外事件发生的频度。特别重要的是，即使每一次影响引起的损失并不大，但长期积累的众多意外事件的影响总和则可造成严重损失。对影响的评估是评估风险和选择安全措施的要素。

由于影响要经历变化，必须定期进行监视。

本过程区域基本实施有 6 项。

- BP.02.01　对运行、业务或任务指令进行识别、分析和优先级排列。
- BP.02.02　识别系统资产。
- BP.02.03　选择用于评估影响的度量标准。
- BP.02.04　标识度量标准以及（若需要）度量标准转换因子之间的关系。
- BP.02.05　识别影响。
- BP02.06　监控影响的变化。

在 BP.02.01 项中，对运行、业务或任务指令进行识别、分析和优先级排列，也需要考虑对业务战略的影响，因为这些因素会增加和降低组织可能遭受的影响。同时，它们也可能会影响在其他基本实施和过程区域中对风险的顺序。因此，当在测试潜在影响时要对这些影响因素加以考虑和分解。例如，在对资产价值进行评估时，资产的价值不能仅根据自身的价格来进行评判，对于具有相同价格的路由器，处在骨干路由或关键节点位置和处在局域网内部的某个位置，它们的价值是不同的，这里就加入了路由器所处位置对业务影响的因素。通常情况下，价值与资产运行的作用、密级、敏感性或与系统利用和计划运行有关。

在 BP.02.03 项中，许多度量标准可用来测量事件的影响。例如，预算财务成本；依靠专家经验划分严重程度等级，如从 1 到 10；从预定义清单中有选择地使用形容词，例如低、中、高等。针对不同的系统，需要预先确定哪种度量标准适合于此系统。

在 BP.02.04 项中，需要注意的是，不同度量标准之间的关系需要建立起来，以保证在整个影响评估中对所有风险均保持一致性方法。在某些情况下，需要把各种度量标准方法组合起来，产生单一的统一结果。举例说，若某风险是陨石推毁一栋房屋，那么潜在的影响便是要花费 800000 元重建这栋房屋。另一种影响可能是 6 个月后再重建房屋。如果每月预算 2000 元的租房费用，那么这两种影响可以组合起来。其总影响便是 812000 元。

（4）PA03 评估安全风险

评估安全风险的目标是获得对在一个给定环境中运行该系统相关的安全风险的理解，并按照给定的方法论优先考虑风险问题。由于风险环境要经历变化，因此必须对其进行定期监视。本过程区域基本实施有 6 项。

- BP.03.01　选择评估风险所依据的方法、技术和准则。
- BP.03.02　识别威胁/脆弱性/影响三者之间的组合（暴露）。
- BP.03.03　评估与每个暴露有关的风险。
- BP.03.04　评估与风险相关的总体不确定性。
- BP.03.05　按优先级对风险进行排列。
- BP.03.06　监控风险的变化。

在 BP.03.01 项中，所选择的方法可以是现有方法，也可以是一个经过裁剪的方法，或者是针对系统运行方面和给定环境的特定方法。用于该风险评估的方法论应与所选的评估威胁、脆弱性和影响评估的方法论相衔接。

在 BP.03.02 项中，暴露是可能对系统造成伤害的威胁、脆弱性和影响的组合。识别暴露的目的在于认识这些威胁和脆弱性的利害关系，进而识别出威胁和脆弱性造成的影响。这些暴露将是在选择系统保护措施中必须予以考虑的。

在 BP.03.03 项中，标识出每一个暴露的可能性，特定的情况或常见的情况下的影响力度，严重后果发生的可能性都必须作为考虑因素。最终工作成果是计算出暴露列表，并且对计算出的暴露进行优先级排序。

在 BP.03.04 项中，总体风险不确定性是在 BP.04.05“评估出现威胁事件的可能性”、BP.05.03“收集与脆弱性特征有关的数据”和 BP.02.05“识别影响”中已被标识的威胁、脆弱性和影响及其特征不确定性的累积。

在 BP.03.05 项中，已经被识别的风险应以组织的优先级、风险出现的可能性、资金等这些因素为依据进行排序。

2. 工程过程

系统安全工程与其他工程活动一样，是一个包括概念、设计、实现、测试、部署、运行、维护、退出的完整过程。在这个过程中，系统安全工程的实施必须紧密地与其他的系统工程组进行合作。SSE-CMM 强调系统安全工程师是一个大项目队伍中的组成部分，需要与其他科目工程师的活动相互协调。这将有助于保证安全成为一个大项目过程中一部分，而不是一个独立部分。工程过程包括的过程区域如图 5-10 所示。

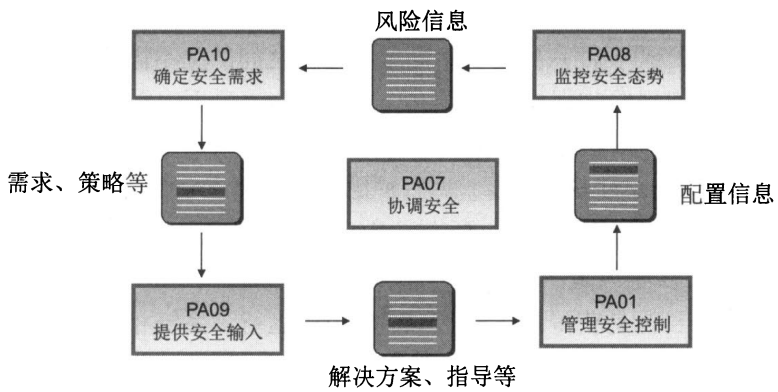

图 5-10　工程过程

1）PA10 确定安全需求

该过程区域的主要工作是明确地识别出与安全相关的需求，它要求包括用户在内的所有各方达成对安全需求的共同认识。确定安全需求首先要定义系统安全的基本原则、系统安全目标，并经批准后发布为系统的安全基线，满足与安全相关的所有法律法规、政策、策略和组织的安全要求。这些需求可以根据某些情况进行适当裁剪，例如组织当前的安全策略和系统环境，一系列已经被定义的安全目标等。

该过程区域包括定义整个信息系统中所有安全方面（例如物理的、功能的、程序的）的活动。其基本实施提出了安全需求如何被识别，并被提炼为与安全要求相关的、连贯的基线，以用于系统设计、开发、检验、运行和维护。在大多数的情况下，有必要考虑现有环境和与安全需求相关的因素。通过这一过程区域所获得和产生的信息在整个项目中被收集、提炼、使用和更新（详见“提供安全输入”（PA09）），以此保证涵盖了用户需求。

本过程区域基本实施有7项。

（1）BP.10.01 理解用户的安全需求

本基本实施的目的是收集所有必要的信息用于全面理解用户安全需求。这些需求受安全风险的严重程度以及系统将来运行的目标环境的影响。

工作产品示例：《用户安全需求访谈记录》或《用户安全需求说明书》等文件，这些文件是对用户安全需求的高层描述。

（2）BP.10.02 识别适用的法律、策略、标准、外部影响和约束

本基本实施的目的是收集所有对系统安全产生影响的外部因素。系统安全工程过程中应识别出系统目标环境的法律、法规、政策和业务标准并确保做出的策略能适应。同时，还需要考虑全局和局部策略的先后顺序。另外，由系统用户对系统提出的安全需求必须被标识并标注出安全含义。

工作产品示例：

① 安全约束——影响系统安全的法律、策略、规则和其他约束条件。

② 安全轮廓——安全环境（威胁、组织策略）；安全目标（例如，需要对抗的威胁）；安全功能和保证需求，说明为满足这些需求所开发的系统。

这里需要注意的是，当系统要跨越多个物理域时需要进行特殊考虑。不同的国家和不同类型的业务活动中的法律和规则可能会发生冲突。作为标识过程的一部分，冲突应按最小化原则加以识别，并在可能条件下予以解决。

（3）BP.10.03 识别系统用途，以确定其安全关联性

本基本实施的目的是识别并理解系统（例如电子政务、电子商务、医疗和金融等）的用途，深入理解系统之间的关系是如何影响安全，从而理解系统各要素和外部因素对安全的影响。例如系统遭受的安全威胁或可能的威胁，评估性能和功能需求对安全可能产生的影响。系统运行的约束条件也需要进行考虑。

组织的许多外部因素也影响组织安全需求的变化程度。这些因素包括政策上的倾向性和政策重点的改变、技术开发、经济影响、全局性事件以及信息战。由于这些因素没有一

个是静态的，它们需要监视和定期地评估这些变化潜在的影响。

工作产品示例：

① 预期的威胁环境——对系统资产的已知或假定的威胁；包括威胁作用力（专门技术、可用资源、动机），攻击（方法、可开发的脆弱性、机会），资产。

② 评估目标——描述被评估的系统或产品的安全特性（类型、预期的应用、通用特性、使用限制）。

系统的安全边界不必与系统边界等同。例如，安全边界可以包括系统驻留的设备和运行该系统的人，而系统边界则可能定在人机界面处。可以认为，就访问控制而言，这一扩展的安全边界可使物理方法成为除了纯技术方面以外的有效安全措施。

（4）BP.10.04　描绘系统运行的安全视图

该基本实施的目的是开发一个高层、面向安全的规划视图，包括任务、角色、职责、信息流、资产、资源、人员保护以及物理保护等要素。

与系统开发环境有关的需求也要在这一阶段进行识别和描述。

工作产品示例：

① 运行安全概念——系统高层的、面向安全的视图（任务、职责、资产、信息流、过程）。

② 概念性安全体系结构——一个安全体系结构的概念性视图。

（5）BP.10.05　定义高层的安全目标

本基本实施的目的是，识别出在运行环境中怎样提供足够的安全才能使该系统满足其安全目标。PA06“建立保证论据”中确定的系统保证目标可能对安全目标产生影响。

工作产品示例：

① 运行环境的安全策略——资产怎样在一个组织的内部和外部进行管理，如何进行保护和发布的规则、指令和实施。

② 系统安全策略——资产怎样被系统或产品进行管理，保护和发布的规则、指令和实施。

本基本实施的目标应该不依赖于任何特殊的具体实现。如果因为现有环境存在特殊的约束条件，为了做出有科学依据的选择而要决定安全约束条件和需要考虑的问题时，应该在“PA09 提供安全输入”中被提出来。安全目标至少应提出系统和信息的可用性、机密性、完整性、可核查性、真实性和可靠性的要求。

（6）BP.10.06　定义安全相关需求

本基本实施的目的是定义与系统安全相关的需求。该实施应确保全面识别并定义系统的安全需求，这些需求应与可适用的政策、法律、标准、安全要求以及系统的约束条件相一致。通常有必要定义或确定目标的逻辑或物理边界，以确保所有的需求都被识别。这些需求应与系统目标建立映射关系或发生关联。

与安全相关的需求应被清楚地、简明地陈述，而且彼此不应发生矛盾。无论何时，安全都应将系统功能和性能的任何影响降到最小。与安全相关的需求应在目标环境中为系统

安全的评价提供一个基础。

工作产品示例：

① 与安全相关的需求——直接影响系统的安全运行，或强加在某一特殊安全策略的一致性需求。

② 可跟踪模型——将安全需求映射成为必需条件、解决方法（例如，体系结构、设计、实现）、测试和测试结果。

这里需要注意的是，许多需求应用于多种科目，所以几乎没有什么需求是安全所专有的。因此，这一过程区域需要同其他的科目进行大量的协调，正确地产生出系统真正所需的结果。与这些相互作用相关的活动在 PA07“安全协调”中有描述。

（7）BP.10.07　达成安全协议

该基本实施的目的是系统的安全需求与相关方达成一致，并获得用户的认可。

工作产品示例：

① 审核确定的安全目标——陈述需对抗的已识别的威胁，遵从已识别的安全策略（已被顾客认可）的计划。

② 与安全相关的需求基线——与安全相关的最低要求（基线）得到所有的相关方（特别是顾客）的认可。

2）PA09 提供安全输入

系统的安全性不是一组安全专业人员就可以全部解决的，它需要所有项目组成员共同来完成，而这首先需要所有项目组成员都要理解安全问题，以使他们各司其职。“提供安全输入”的意思是为系统的规划者、设计者、实施者和用户提供他们所需的安全信息（包括安全架构、安全设计、实施方法和安全指南等），即告诉“其他人”怎么做才能保证系统的安全。然后对所有具有安全意义的系统问题都进行检查，并按照安全目标的要求找出解决的方法，解决方法反映出所提供的安全输入。

本过程区域提供支持系统设计和实施活动的安全输入。焦点是关于安全如何成为系统开发的一个完整部分，而且是无止境的。每项基本实施都使用来自整个工程组织的输入，产生出特定的安全结果，再把那些结果传回给整个工程组织。这些识别出的过程适用于新设施的开发或对现有设施的运行和维护。

本过程区域包括适用于开发（设计者和实现者）和运行（用户和管理员）的安全输入。另外，通过把设计和实现安全活动结合为单个过程区域，强调这些活动虽然非常近似，但处于不同的抽象层。可选择的解决办法涉及的范围是从整个系统的体系结构到单个组成部分。安全要求的某些方面会对系统的开发环境而不是系统本身产生影响。

本过程区域中所有的基本实施都可重复进行，并且都发生在整个系统生命期中的多个点。

本过程区域基本实施有 6 项。

（1）BP.09.01　理解安全输入需求

安全工程与其他工程相协调，才能有助于确定哪些工程的安全输入的类型。安全输入包括任何种类的、应被其他工程所考虑的、与安全相关的指南、设计、文档或思想。输入

可以为多种形式，包括文档、备忘录、电子邮件、培训和咨询。

这样的输入基于 PA10“确定安全需求”中确定的需求为基础。例如，一套安全规则可能需要由软件工程师来开发。同系统相比，某些输入与环境则更有关系。

工作产品示例：

① 安全工程和其他工程间的协议——定义安全工程将如何把输入提供给其他科目（例如，文档、备忘录、培训、咨询）。

② 所需输入描述——对提供安全输入的每种机制的标准化定义。

（2）BP.09.02　确定安全约束和需要考虑的问题

安全工程组通过分析以确定在需求、设计、实现、配置和文档方面的任何安全限制及所要考虑的问题。约束可在系统生命期内的所有时间段进行标识，也可在不同的抽象层上进行标识。注意，这些约束只有肯定（总是如此）和否定（绝不如此）两种选择。

工作产品示例：

① 安全设计标准——对整个系统或产品设计做决定时所需的安全约束和考虑。

② 安全实施原则——用于系统或产品实现（例如，使用特定机制、编码标准）的安全限制和考虑。

③ 文档要求——对支持安全要求所需的特定文档（例如，管理员手册、用户手册、特定设计文件）的标识。

（3）BP.09.03　识别安全解决方案

识别出与安全相关的工程问题的解决方案，这一过程需要反复进行，并且要把与安全相关的需求转化到实现中。这些解决方案以多种形式表现，如体系结构、模型和原型。该基本实施涉及对与安全相关的需求进行分解、分析和重组，直到识别出有效的具有比较性的解决方案。

工作产品示例：

① 系统体系结构的安全视图——以能满足安全要求的方式，从理论层次上描述系统体系结构中各关键元素间的关系。

② 安全设计文档——包括系统资产和信息流的细节，以及具有强制性安全或与安全相关的系统功能的描述。

③ 安全模型——对系统强制性安全策略的一个形式上的说明文档，必须识别控制一个系统如何管理、保护和发布信息的一套规则和实施。

④ 安全体系结构——集中于系统体系结构的安全方面，描述与系统安全有关的规则、基本概念、功能和服务。

⑤ 信任分析（防护关系和依赖性）——描述安全服务和机制间如何相互关联，并如何相互协调，以产生对整个系统行之有效的安全保证；确定补充防护措施所需的区域。

可选解决方案包括体系结构、设计和实现方法。在确定安全约束和考虑后（BP.09.02），这些安全选项应与所标识的约束和考虑协调一致（BP.09.02）。这些可选方案也是折衷比较的一部分（BP.09.04）。这一活动是与提供安全工程指南（BP.09.05）相关的，一旦择优

选定了方案，其指导原则对其他工程科目也是需要的。

（4）BP.09.04　分析工程可选方案的安全性

当决定安全约束和考虑后（BP.09.02），利用识别的安全约束和考虑，设计组可以评估每个工程可选方案并提出对工程组的建议。安全工程组同样应考虑其他工程组的工程指南。

这些工程可选方案不受 BP.09.03 所标识的安全方案的限制，且可以包括来自其他工程科目的可选方案。

工作产品示例：

① 折中研究结果和建议——包括考虑了对 BP.09.02 中提供的安全约束和须考虑的问题的所有工程可选方案的分析。

② 端对端折中研究结果——整个产品、系统或过程的生命期中各种决策结果，都把注意力集中于为满足其他目标（如成本、功能性）的需求而已将安全需求降低的工作区上。

（5）BP.09.05　提供安全工程指南

开发出与安全相关的指南，并把它提供给其他工程组。安全工程指南被工程组用于做出有关体系结构、设计和实现选择的决定。

工作产品示例：

① 体系结构建议——包括能支持可满足安全要求的系统体系结构的约束和开发规则。

② 设计建议——包括指导系统设计的规则或约束。

③ 实现建议——包括指导系统实现的规则或约束。

④ 安全体系结构建议——包括定义系统安全特性的规则或约束。

⑤ 保护原理——对如何强化安全，包括自动的、物理的、个人的以及管理机制的高层次描述。

⑥ 设计标准、原理、规则——关于系统如何设计的约束（例如，最少的特权、隔离安全控制）。

⑦ 编码标准——关于系统如何实现的约束。

这里需要注意的是，所需指南的数量和具体内容取决于安全知识、经验和对其他工程科目的熟悉程度。在很多情况下，大量的指南都与开发环境而不是与开发中的系统有关。

（6）BP.09.06　提供运行安全指南

为运行系统的用户和管理员提供与安全相关的指南。该运行指南告诉用户和管理员在以安全模式进行安装、配置、运行和淘汰系统时需要做些什么。安全指南的开发需要在生命期内提早开始。

工作产品示例：

① 管理员手册——描述系统管理员以安全模式安装、配置、运行和淘汰系统的功能和特权。

② 用户手册——描述用户使用的指南以及系统提供的安全机制。

③ 安全轮廓——安全环境（威胁、组织策略）；安全目标（例如，被对抗的威胁）；

安全功能和保证需求。

④ 系统配置指令——确保运行能满足安全目标的系统配置指令。

3）PA01 管理安全控制

该项主要是确定集成到系统中的安全控制措施确实在系统运行过程中发挥预计的安全功能。这里包括在工程建设前，建立安全控制措施的责任，落实有关责任人；在工程建设中对系统安全控制的配置进行管理；在工程建成后对系统用户和管理员进行安全意识教育和技能培训；在系统运维期间对安全服务和控制机制进行定期维护，避免损伤和故障等。

管理安全控制是在工程实施过程中要着重把握的环节，解决工程实施完整性问题。因此管理安全控制措施在工程部署各个环节中均要落实到位。

本过程区域基本实施有 4 项。

（1）BP.01.01 建立安全职责

建立安全控制的职责和责任并通知到组织中的每一个人。安全的某些方面能够在常规的管理结构中进行管理，然而另外一些方面则需要更专业的管理。

本过程应该保证负有责任的那些人是负责的，并是经过授权的，同时也应该保证采用的所有安全控制是明确的，并具有一致性。此外他们应该保证被采纳的安全机制，不但通知结构内的那些人，也应通知整个组织。

工作产品示例：

① 组织的安全机构图表——识别与安全有关的组织成员及其角色。

② 文档化安全角色——描述每个与安全有关的组织角色及其职责。

③ 文档化安全职责——详细描述每个安全职责，包括希望输出哪些信息以及怎样评审与使用它们。

④ 文档化安全责任——描述对于有关问题的安全负责的人，确保有人对所有的风险负责。

⑤ 文档化安全授权——识别一个组织的每个成员允许做的事情。

（2）BP.01.02 管理安全配置

所有设备的安全配置需要管理。该基本实施认为，系统安全很大程度上依赖于许多相关组件（硬件、软件与程序），而常规配置管理实施则不必关心安全系统所需的相互关联性。

工作产品示例：

① 所有软件更新的记录——记录系统的所有软件与软件更新的许可证、序列号和回执，包括日期、个人责任和修改描述。

② 所有发布问题的记录——包括对软件发布期间所遇到的任何问题以及怎样解决它的描述。

③ 系统安全配置——描述系统硬件、软件及通信的当前状态的数据库，包括硬件位置、软件发布和相关的信息。

④ 系统安全配置的修改——描述对系统安全配置的任何修改，包括修改人的名字、修

改的描述、修改的理由以及修改的时间。

⑤ 所有确认的软件更新记录——一个跟踪软件更新的数据库，包括修改的描述、修改人的名字以及修改的时间。

⑥ 可信软件发布的定期综述——描述最近的可信软件发布活动，注意到出现的任何困难和作用情况。

⑦ 安全需求修改——跟踪对系统要求所做的任何修改，修改的原因可能是基于安全理由或对安全有影响。这样有助于保证修改及其作用是合乎安全策略的。

⑧ 对设计文档进行安全修改——跟踪对系统设计文档所做的任何修改，修改的原因可能是基于安全理由或对安全有影响。这样有助于保证修改及其作用是合乎安全策略的。

⑨ 控制的实现——描述系统中安全控制的实现，包括配置的详细情况。

⑩ 安全审核——描述相对于所希望控制实现的系统安全控制的当前状态。

⑪ 控制处置——描述删除或取消安全控制的程序，包括过度控制计划。

维护任何系统中安全控制配置的当前状态是一项复杂的任务，特别是对于大型的分布式系统更是如此。配置本身的某些方面对于保护安全是至关重要的。有效的安全需要记录一些特定信息，这些特定信息是与组成该系统的安全控制机制有关的，并且通常不用于其他科目。同样，必须对现有系统提出的修改进行评估，以便确定这些修改对整个系统安全状态的影响。

特别是在分布式环境中，需要有相应的程序来保证软件或应用的特定模块的所有备份都是相同的合适版本。此外，特别是当该软件通过网络本身进行发布时，保证该软件在发布过程中不被损伤是至关重要的。这些要求适用于所用软件。

该基本实施应该保证该软件只执行那些希望的功能；维持一个密封的标准版本；该软件的所有备份是相同的；更新需要进行确认；安全控制配置是已知的和可维护的。

（3）BP.01.03　管理安全意识、培训和教育

所有员工的安全意识、培训和教育都需要管理，其管理方式与其需要管理的意识、培训和教育管理方式相同。

工作产品示例：

① 安全培训材料的用户审核——描述安全意识和培训材料的有效性、可用性和相关性。

② 所有意识、培训、教育日志和培训结果——跟踪用户对组织和系统安全的理解。

③ 用户团体关于安全的知识、意识和培训水平的定期再评估——对安全的有组织的理解进行复查并标识出将来关注的可能区域。

④ 培训、意识及教育材料的记录——收集可以在整个组织中重复使用的有关安全的培训材料，可以将它们与其他组织的培训材料综合起来。

在此环境中，“用户”这个术语不仅包括那些直接与系统一起工作的个体，而且也包括所有从这个系统直接或间接接收信息的个体，以及所有的经营和管理人员。

用户意识到安全处于适当位置的理由，以及采用特殊安全机制或控制的理由是至关重

要的。另外，用户理解怎样正确地使用该机制或控制是非常重要的。因此，当引入新机制和控制时，用户需要原始的、周期性重新理解的和修改的教程。所有用户都要求具有安全意识，某些用户在使用安全机制方面需要培训，少数用户需要更多深入的安全知识，是安全教育的主要对象。

（4）BP.01.04　安全服务及控制机制的管理

安全服务及机制的一般管理类似于其他服务及机制的管理，这包括保护它们避免损伤、偶然事故和人为故障，并根据法律和政策要求进行归档。

工作产品示例：

① 维护和管理日志——根据系统安全机制对维护、完整性检查和运行检查进行记录。

② 定期的维护和管理检查——对最近的系统安全管理及维护工作的分析。

③ 管理和维护失效——跟踪记录系统维护方面的问题以便标识需要额外关注的地方。

④ 管理和维护例外——包括对正常管理及维护程序的例外情况的描述，其中包括该例外情况出现的原因和持续的时间。

⑤ 敏感信息清单——描述系统中各种类型的信息和这些信息应怎样得到保护。

⑥ 敏感介质清单——描述系统中存储信息所用的各种类型的介质和每种介质应怎样得到保护。

⑦ 净化、降级和撤销——描述一些保证在信息敏感性降低或者介质被净化或处置后，不出现不必要风险的程序。信息资产被定义为属于一个组织的硬件、软件和数据。某些信息资产可能需要删除敏感部分以便余下部分能用于较低敏感的目的。净化措施能保证信息发布给需要知道的个体。这可以通过降低信息的级别或对特定敏感信息的选择性删除来达到。

4）PA08 监控安全态势

安全态势表明系统及其环境已准备好处理目前的威胁、脆弱性和对系统及其资源的任何影响。监控安全态势的目的就是，在整个工程过程及时发现安全措施状态变化及安全事件，并进行适当的处置，如识别出并报告所有的安全违规、已尝试过的违规或能够潜在地导出安全违规的错误。

监视外部和内部环境可能影响系统安全的所有因素。对内部及外部环境收集的数据进行分析的方法是：根据上下文联系和它们与其他数据的相关性进行分析，这里的其他数据可能是有问题的事件出现以前、同时或之后导出的另外的数据。本过程区域提出了系统准备的目标环境和开发系统的环境。任何特殊的系统必须与影响整体安全的现有系统一起工作，因此这些现有系统应该包括在监视之中。

本过程区域基本实施有 7 项。

（1）BP.08.01　分析事件记录

检测并分析安全相关性信息的历史和事件记录（包括日志记录），以确定一个事件的原因，它怎样发展以及将来可能的事件。通过多条记录中的相关事件所用元素，应该能识

别出感兴趣的事件。多条事件记录可以融和为一条事件记录。

工作产品示例：

① 描述每个事件——识别出每个探测到的事件的来源、影响和重要性。

② 建立日志记录和来源——从各种来源生成安全相关事件的记录。

③ 事件标识参数——描述事件是否由系统的各个部分进行收集。

④ 列出所有目前的单个日志记录报警状态——标识根据单个日志记录采取行动的所有要求。

⑤ 列出所有目前的单个事件报警状态——找出根据事件采取行动的所有要求，这些事件由多个日志记录形成。

⑥ 定期报告已出现的所有报警状态——将从多个系统得到的报警列表进行综合处理并做初步分析。

⑦ 日志分析和归纳——对最近出现的报警进行分析归纳。

这里需要注意以下方面。

① 许多审计记录可能包含与单个事件有关的信息。在分布式网络化环境中尤其如此。一个事件在跨越网络多个位置时常常留下踪迹。为了保证单独的记录对于完整地理解事件及其行为是有价值和有贡献的，单独的日志记录需要进行组合或融和为单个的事件记录。

② 可以对单个记录和多个记录进行分析。对相同类型的多个记录分析经常使用统计或趋势分析技术。虽然通常是对相同类型事件进行多事件记录，但也可以根据日志记录和事件（融和）记录对不同类型的多个记录进行分析。

③ 报警，即基于单个事件的偶然行动需求，应该根据日志记录和融和的事件记录来确定。分析也包括来自于开发环境的日志和事件记录。

（2）BP.08.02　监视变化

从威胁、脆弱性、影响、风险和环境等方面查找并监视可能影响当前安全状态有效性的任何变化，不管这种影响是正面的还是负面的。

任何系统实现的安全应该与威胁、脆弱性、影响和风险相关联，因为它们与系统的内部和外部环境有关。这些因素没有一个是静态的，而变化既影响有效性，也影响适应性。必须监视所有因素的变化，并分析这些变化以评估它们对安全有效性的意义。

工作产品示例：

① 变化报告——识别出任何可能影响系统安全状态的内部或外部变化。

② 对变化的意义进行定期评估——对安全状态的变化进行分析，确定它们的影响和做出响应的激励因素。

（3）BP.08.03　识别安全突发事件

确定是否发生了一个有关安全的突发事件，识别出事件详细情况并且必要时提出报告。安全突发事件可通过历史事件的数据、系统配置数据、完整性工具和其他系统信息诊断出来。由于某些突发事件会经过一个长周期时间后才出现，因此这种分析可能涉及与以前系统状态进行比较。

工作产品示例：

① 突发事件清单和定义——识别出共同的安全突发事件并进行易于识别的描述。

② 突发事件响应指南——描述对出现安全突发事件的恰当响应。

③ 突发事件报告——描述出现了什么突发事件及其全部的相关详细情况，包括突发事件的来源、任何形式的危险、应采取的响应和需要进一步采取的行动。

④ 与探测到的每个入侵事件有关的报告——描述探测到的每个入侵事件并提供全部相关详细情况，包括突发事件的来源、任何形式的危险、采取的响应和需要进一步采取的行动。

⑤ 周期性突发事件综述——提供最近的安全突发事件的概述，指出趋势，要求更为安全的区域以及降低安全可能节约的经费。

安全突发事件在开发和运行环境中都可能发生。这些突发事件能够以不同方式影响正在开发或运行的系统。对付黑客或恶意代码（病毒、蠕虫等）采用预谋的技术攻击，需要一种不同于对抗随机事件的方法。这要求对系统配置和状态进行分析才能检测出这类攻击，应该准备、测试和使用恰当的响应计划。许多技术攻击要求快速的、预先规定好的响应以将损失减至最小。在许多情况中，错误的响应可能使情况变得更坏。在需要时，应该识别和定义响应计划（BP.08.06）。

（4）BP.08.04　监控安全防护措施的有效性

检测安全防护措施的执行情况，以便识别出安全防护措施执行中的变化。应该对安全防护措施保护开发和运行环境的情况进行监视。许多安全防护措施在使用后处于不恰当的或无效的状态。许多安全防护措施提供它们当前状态、有效性和维护要求的指示。所有的这 3 个方面都需要定期地进行复查。

工作产品示例：

① 定期安全防护状态——描述现有安全防护措施的状态，目的在于探测出可能的错误配置或其他问题。

② 定期安全防护措施状态综述——提供一份现有安全防护措施的状态综述，指出趋势、需要改进的地方和降低安全可能节约的经费。

（5）BP.08.05　审核安全态势

一个系统的安全态势要经受基于威胁环境、运行要求和系统配置出现的变化。本实施是审核实施安全的理由，以及将安全植入其他科目的理由。

安全态势的审核应该根据当前运行环境和已经出现的变化情况进行。如果出现其他事件，比如情况变化，没有完整的安全审核，那么就应该根据上次审核以来经历的时间长短，启动新的审核。启动审核的时间间隔应该遵从恰当的策略和规则。审核应该基于安全评估的组织方法，可以参考 PA03“评估安全风险”。以同样的方式审核运行环境，创建的系统开发环境也应该定期地进行审核。事实上，开发环境也可以认为是系统开发的运行环境。

工作产品示例：

① 安全审核——包括描述当前安全风险环境、现有的安全态势和对这两者是否兼容进

行的分析。

② 风险容忍审核——由适当的正式授权机构提供报告，以表明运行该系统有关的风险是可以接受的。

（6）BP.08.06 管理对安全突发事件的响应

在许多情况中，系统的连续可用性是非常关键的。由于许多事件不能预防，因而对破坏的响应能力是至关重要的。应急计划要求识别出系统失效的最长时间，识别出系统正常工作的基本元素，识别并开发一个可恢复策略和计划，测试并维护这个计划。

在某些情况中，应急措施可能包括对突发事件的响应和与敌方势力（如病毒、黑客等）的对抗。

工作产品示例：

① 系统恢复优先级清单——包括对系统功能在突发事件引起失效时的保护和恢复顺序的描述。

② 测试时间表——包括系统周期性测试的日期，以保证与安全有关的功能和过程是可运行的和成熟的。

③ 测试结果——描述周期性测试的结果以及为保持系统安全应采取的行动。

④ 维护时间表——包括对所有系统维护（指更新和预防）的日期，典型情况是与测试时间表结合起来。

⑤ 突发事件报告——描述出现了什么样的突发事件及其全部的相关详细情况，包括突发事件的来源、任何形式的危害防护措施、采取的响应和进一步要求的行动。

⑥ 定期检查——描述系统安全的定期检查期间执行的过程，包括谁参与了检查、做了什么检查和包含什么结果。

⑦ 应急计划——标识系统失效的最长可接受时间、系统运行的基本元素、系统恢复的策略及计划、重新开始的业务、状态的管理以及计划的测试及维护过程。

（7）BP.08.07 保护安全监视的记录数据

如果监视活动的成果不可信任，那么监视活动就没有价值，因此需要保证与安全监视有关的记录数据得到适当的保护。监视活动包括封存和归档相关的日志、审计报告和相关分析结果。

包括审计在内的大多数监视活动都产生结果数据，这种结果数据可以直接发挥作用，或者记录在案供以后分析和进一步采取行动。日志的内容应该设计成有助于理解在突发事件期间出现了什么，并探测出趋势和可能发生的变化。输出日志应该按与所用的策略和规则相一致的原则进行管理。日志必须是可靠的和受到保护的，能抗篡改或偶然破坏。当日志存储区被填满时，它必须换一个新日志存储区或者将它清空。当日志改变时，任何不需要的记录都应被删除并执行其他需要的删减动作。日志应该封存以阻止不可探测的任何修改，还应该在法律保护期间内归档。

工作产品示例：

① 列出全部归档的日志和相应的保存周期——标识出与安全监视有关的活动应该存

储，以及什么时候进行处理。

② 应提交归档的日志的定期现场检查结果——描述任何损失的报告并标识出恰当的响应。

③ 归档日志的使用——识别归档日志的使用者，包括访问时间、目的及任何注解。

④ 定期检查随机选择的归档日志的有效性和可利用性结果——分析随机选取的日志并确定它们是否完整、正确和有用，以保证对系统安全的充分监视。

5）PA07 协调安全

安全工程不能独立地取得成功，要保证所有部门都有一种参与安全工程的意识，这样才能充分发挥他们的作用，并且，有关安全的决定和建议是相互沟通和协调才能达成一致。

这种协调性涉及保持安全组织、其他工程组织和外部组织之间的开放交流。多种机制可以用于在这些部门之间协调和沟通安全工程的决定和建议，包括备忘录、文档、电子邮件、会议和工作组。

本过程区域保证了安全是整个工程项目的一个完整部分。安全工程师应该是所有主要设计队伍和工作组的一份子，在做出关键设计决定后的工程生命期早期就建立起安全工程与其他工程队伍间的联系是特别重要的。

本过程区域基本实施有 4 项。

（1）BP.07.01　定义协调目标

许多其他的组织也需要有一种参与安全工程的意识，所以需要建立与其他组织之间的联系和义务关系。成功的联系可有许多形式，但必须被全体参与的部门所接受。与这些组织共享信息的目标是通过检查项目结构、信息需求和项目要求来决定的。

协调目标及关系应该在项目中定义得越早越好，以便保证充分地建立通信线路。其他工程组应该为安全工程师规定每天的工作任务（例如，坐下来检查/参加培训、检查设计）。如果这一点没有做到，那么会增加安全关键方面的损失风险。

工作产品示例：

① 信息共享协议——描述组织间共享信息的过程，标识参与部门、介质、格式、期望值和频率。

② 工作组的成员关系和日程表——描述本组织的工作组，包括他们的隶属关系、成员的作用、目的、议程和后勤。

③ 组织标准——描述各工作组之间及用户之间沟通安全相关信息的过程和程序。

（2）BP.07.02　识别协调机制

有多种方法可以与其他组织共享安全工程的决定和建议。本过程区域的目的就是识别在项目中协调安全的不同方法。

在同样一个项目上有多个安全组是常见的。这些情况下，所有的工作组都应该为了一个共同的目标而工作，接口标识、安全机制选择、培训及开发工作都需要以某种方式进行，以保证每个安全组件放置在运行系统中时都能如愿工作。另外，安全工程的作用必须得到所有其他工程组和工程机构的理解，以便使安全能完好地集成到系统中去。用户也必须清

楚有关安全的事情和工作，以便保证恰当地识别和提出要求。

工作产品示例：

① 沟通计划——包括用于工作组成员之间以及与其他团体之间需要共享的信息、会议日期、过程和程序。

② 通信基础设施的要求——标识工作组成员之间以及与其他团体之间共享信息需要的基础设施和标准。

③ 会议报告、报文、备忘录的模板——描述各种文档的格式，保证标准化和有效的工作。

（3）BP.07.03　促进协调

成功的关系依赖于完善的促进。在具有不同优先级的不同组织之间进行沟通有可能会发生一些冲突。本基本实施确保争端以合适的富有成果的方式得到解决。

工作产品示例：

① 冲突解决的程序——识别出有效解决组织中实体之间和实体内部冲突的方法。

② 会议议程、目标、行动条目——描述会议中讨论的议题、强调需要阐述的目标和行动条目。

③ 行动条目的跟踪——识别工作和项目分解的计划，包括职责、时间表和优先级。

（4）BP.07.04　协调安全决定和建议

本基本实施的目的在于在各种安全工程组织、其他工程组织、外部实体及其他合适的部门中沟通安全决定和建议。

工作产品示例：

① 决定——通过会议报告、备忘录、工作组会议纪要、电子邮件、安全指南或公告牌将有关安全的决定告诉有关工作组。

② 建议——通过会议报告、备忘录、工作组会议纪要、电子邮件、安全指南或公告牌将有关安全的建议通报给有关工作组。

3．保证过程

保证是指安全需求得到满足的可信程度。它是系统安全工程非常重要的产品。SSE-CMM 的可信程度来自于系统安全工程过程可重复性的结果质量。这种可信性的基础是工程组织的成熟性，成熟的组织比不成熟的组织更可能产生重复的结果。

安全保证并不能增加任何额外的对安全相关风险的抗拒能力，但它能为减少预期安全风险提供信心。安全保证也可看作是安全措施按照需求运行的信心。这种信心来自于措施及其部署的正确性和有效性。正确性保证了安全措施按设计实现了需求，有效性则保证了提供的安全措施可充分地满足用户的安全需求。

保证过程包括的过程区域如图 5-11 所示。安全保证通常以安全论据的形式出现。安全论据包括一系列具有系统特性的需求。这些需求都要有证据来支持。证据在系统安全工程活动的正常过程期间获得，并被记录在文档中。SSE-CMM 活动自身就产生了与安全相关的证据，如过程文件能够表示开发是遵循一个充分定义的成熟度工程过程，这个过程须加

以持续改进。

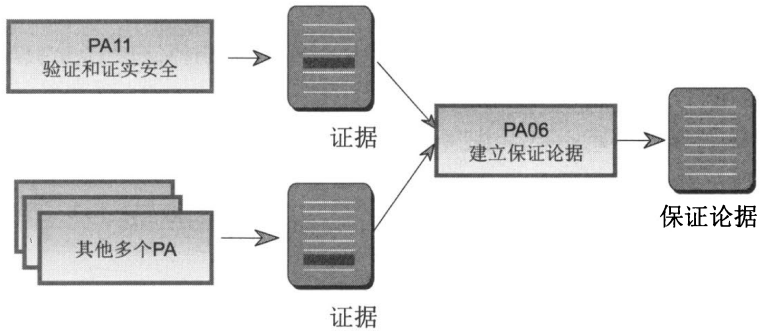

图 5-11　保证过程

1）PA11 验证和证实安全

通过观察、论证、分析和测试来验证和证实解决方案满足安全需求；验证证据正确性，证实证据有效性。解决方案要依照安全需求、体系结构和设计得到确认，还要依照用户的运行安全需求被证实。

本过程区域是系统验证和证实的重要部分，可在所有的抽象层上进行。解决方案包括从运行概念到体系结构再到实现的所有方面，并跨越包括环境和过程的整个信息系统。

为了获得有价值的目标结果，验证和证实工作组应不同于工程组，不过，这个组可以和工程组并行工作。验证和证实的结果可在解决方案的生命期内的任何时间反馈给整个工程组。验证和证实有时也与正确性和有效性的概念关联。

本过程区域基本实施有 5 项。

（1）BP.11.01　识别验证和证实的目标

本基本实施的目的是分别地识别出验证和证实的目标。验证证明了解决方案被正确地实施，而证实则证明了解决方案是有效的。它也涉及与整个生命期内所有工程组的协调。

许多工作产品的验证和证实牵涉广泛的抽象和复杂性。这些包括需求、设计、体系结构、实现、硬件、软件和测试计划。与系统的运行和维护相关的工作产品同样可被验证和证实，包括系统配置、用户文档、培训资料和突发事件响应计划等。

工作产品示例：验证和证实计划——验证和证实工作的定义（包括资源、时间表、验证和证实的工作产品）。

（2）BP.11.02　定义验证和证实方法

本基本实施的目的是，定义验证和证实每种解决方案的方法和严密等级。识别这种方法涉及选择每个需求如何得到验证和证实。严密等级应指示出验证和证实的审查到底有多严格，而且要受到 PA06“建立保证论据”中保证策略输出的影响。例如，某些项目只对一致性需求进行简单地审核，而另一些则可能要求非常严密的审核。

这一方法论还应包括一种可跟踪保持从用户的运行安全需求到安全需求，到解决办法，到验证和证实结果的方法。验证和证实的方法应与整个系统的验证和证实方法兼容。这就

要求有效的协调和交互。与协调相关的活动在PA07“协调安全”中进行描述。

工作产品示例：

① 测试、分析、演示和观察计划——被使用的验证和证实方法（例如，测试、分析）和严密等级（例如，非正规或正规的方法）的定义。

② 测试过程——定义测试每种解决办法时所采取的步骤。

③ 跟踪方法——描述被跟踪的是什么样的验证和证实结果才能满足顾客的安全需求和需要。

（3）BP.11.03 执行验证

本基本实施的目的是，通过显示解决方案，实现了与上一抽象层相关的要求，包括作为PA06“建立保证论据”所识别的保证需要，从而验证解决办法是正确的。有许多验证需求的方法，包括测试、分析、观察和演示等，所用的方法在BP.11.02中标识。单个需求和整个系统都要受到检测。

工作产品示例：

① 来自测试、分析、演示和观察得出的原始数据——验证解决办法满足要求的过程中所采取的任何方法所得出的结果。

② 问题报告——在验证解决办法满足要求过程中发现的矛盾。

（4）BP.11.04 执行证实

通过显示能满足与上一抽象层相关的需求，最终满足用户的运行安全需求，实现对解决方案的证实。证实表明解决方案有效地满足了这些需求。有许多种方法可以用来证实这些需求已被满足，包括在一个运行着的，或有代表性的测试环境中测试解决方案。所使用的方法在BP.11.02中被标识。

工作产品示例：

① 问题报告——在证实解决方案满足安全需求的过程中发现的矛盾。

② 矛盾——解决方案不能满足安全需求的区域。

③ 无效的解决方案——不能满足用户安全需求的解决方案。

（5）BP.11.05 提供验证和证实的结果

本基本实施的目的是，收集并提供验证和证实的结果。验证和证实的结果应以某种易被理解和使用的方式所提供。所有结果应被跟踪，以使从需求到解决方案，到测试结果的可跟踪性不被丢失。

工作产品示例：

① 测试结果——测试结论文档。

② 可跟踪模型——将安全需求映射到解决方案（例如，体系结构、设计、实现），到测试和测试结果。

2）PA06 建立保证论据

通过证据的收集，建立保证论据，该论据应清楚地说明用户的安全需求已经得到满足，通过一系列证据建立了对系统安全的信心。本过程包括对与需求有关的保证进行识别和定

义；证据的产生和分别活动；支持保证需求所需的附加证据。此外，对这些活动所生成的证据进行收集、打包并准备随时递交。

本过程区域基本实施有 5 项。

（1）BP.06.01　识别保证目标

由用户确定的保证目标，标识了在该系统中所需的可信度等级。系统安全保证目标指定了强制性的系统安全策略的可信度等级。该目标的充分性由开发者、集成者、用户和签名授权者确定。

新的和经修改的安全保证目标的标识，要保持与所有内部和外部工程组织（例如，客户、系统安全认证者、签名授权者、用户）的安全相关性团体协调一致。

为反映变化，安全保证目标应及时更新。在安全保证目标中需要进行修改的例子包括客户、系统安全认证者、签名授权和用户的可接受风险程度变化，或需求的变化以及对需求解释的变化。

安全保证目标必须清晰地沟通，如有必要应包含适当的解释。在无特别声明的情况下，如果保证目标能够被阐明或与特定安全保证声明相关联，是有帮助的，这将有助于减少误解。

工作产品示例：安全保证目标的陈述——对系统安全特性中用户所需的可信度等级进行识别。

（2）BP.06.02　定义保证策略

安全保证策略的目的是，规划并确保正确地强制性地实现安全目标。通过实现安全保证策略所产生的证据应（向系统签名授权者）提供一个可接受的可信度等级，此等级系统安全措施足以管理安全风险。通过开发并颁布安全保证策略，获得对保证的相关活动进行有效管理。与需求相关的早期识别和定义，对于产生必要的支持证据是必要的。通过不断的外部协调，对用户保证需求的满意程度进行理解和监视，确保高质量组合保证要求。

工作产品示例：产品化保证策略——对满足用户安全保证目标的规划进行描述并标识应负责的责任方。

（3）BP.06.03　控制保证证据

安全保证证据通过与所有安全工程过程区域相互配合进行收集，以便识别出不同抽象层面的证据。该证据受到控制，以确保与现有工作产品的通用性和与安全保证目标的关联性。

保证工作产品可以从系统、体系结构、设计、实现、工程进程、物理开发环境和物理运行环境中开发出来。

工作产品示例：安全保证证据仓库（例如，数据、工程笔记本、测试结果、证据日志记录）——存储开发、测试和使用期间产生的所有证据，可以采用数据库、工程笔记、测试结果或证据日志记录的形式。

（4）BP.06.04　分析证据

引入保证证据分析，是为收集起来的满足安全目标进而满足用户安全需求的证据提供可信性。保证证据的分析决定了系统安全工程和安全验证过程是否充分和足够完善，以便

做出安全特性和安全机制是否令人满意地实现的结论。此外，对保证证据的分析，保证了工程产品相对于基线系统是完善和正确的。当保证证据不充分或不足够的情况下，本分析可能导致对支持安全目标的系统、安全工作产品和过程进行必要的修订。

工作产品示例：保证证据分析结果——识别和概述论据仓库中证据的强弱程度。

需要注意的是，某些保证证据只能从合并其他系统工程产品的联合体中产生出来或其他保证的联合体中推导出来。

（5）BP.06.05　提供保证论据

开发出一个完整的被证明与安全目标一致的安全保证目标，并使其提供给顾客。保证论据是一系列陈述性保证目标，而这些陈述性目标是从多层抽象中获得的保证论据的组合所支持的。为了满足安全目标，必须对提交证据中的缺陷和安全保证目标中的缺陷进行审核。

高层次的安全保证论据可以是满足相关标准的保证目标。保证论据的其他可能部分说明了对系统资产已进行了怎样的威胁。每个保证目标都得到相关的足够证据的支持，以满足适当的可以证明的标准。本论据可被客户、系统安全认证者、签名授权者和用户所使用。

工作产品示例：具有支持证据的保证论据——由各种保证论据支持的一系列结构化的保证目标。

5.1.5　SSE-CMM 的安全工程能力

1．能力级别

安全工程能力级别是 SSE-CMM 模型中最重要的一个维度，它表示了过程的成熟性，即组织的过程管理和制度化能力的强弱。能力级别根据“公共特性”分级，公共特性由通用实施（Generic Practices，GP）组成，这些通用实施可在过程评估中用于确定任何过程的能力，还可以帮助确定项目管理好坏的程度并可将每一个过程区域作为一个整体加以改进。

一个能力级别低的组织，其成本高、生产力低、工程进度慢并且质量不稳定。即使其偶然能做出一个好产品、好项目，但它是不可重复的。因此当它做出项目计划，确定了成本、进度和质量后，执行的结果往往与计划预期差之甚远，至少不相符合。但能力级别高的组织执行的结果基本会达到预期。

2．SSE-CMM 的能力级别

SSE-CMM 包含了 5 个级别，能力级别整体结构如图 5-12 所示。

（1）1 级：“非正规执行级”

这个级别着重于一个组织或项目执行了包含基本实施的过程。这个级别的特点可以描述为“你必须首先做它，然后你才能管理它”。

在这一级别，过程区域的基本实施通常被执行。但基本实施的执行可能未经严格的计划和跟踪，而是基于个人的知识和努力。此过程区域的工作产品可证实基本实施的执行。组织内的个人可识别出一个行动应被执行，并同意这个行动会在需要时执行。此过程的工

作产品是可识别的。

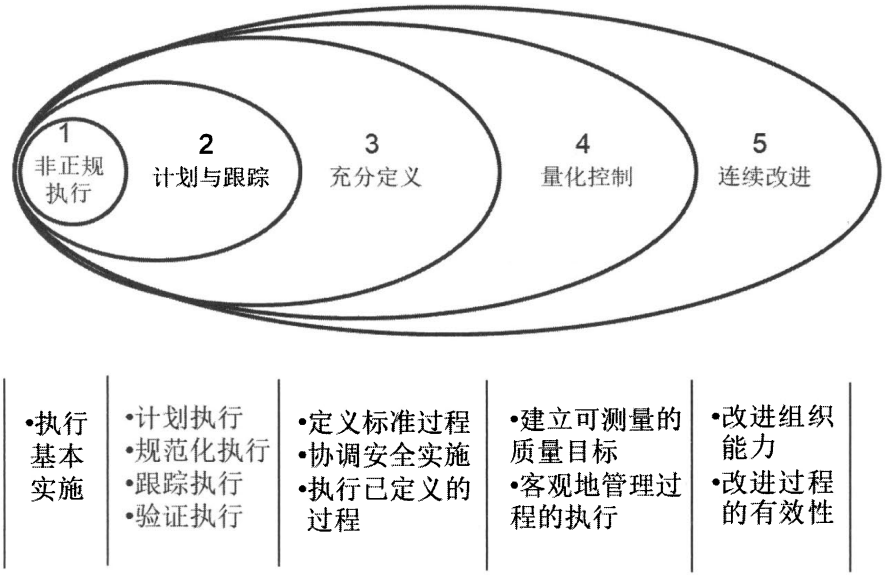

图 5-12　能力级别代表安全工程组织的成熟级别

该过程的公共特征是“执行基本实施”，此公共特征的通用实施只是保证过程区域的基本实施以某种方式执行。然而，工作产品的一致性、性能和质量会因缺乏适当控制而存在极大的差异。

（2）2 级：“计划与跟踪级”

这个级别着重于项目层面的定义、计划和执行问题。这个级别的特点可描述为“在定义组织层面的过程之前，先要弄清楚项目相关的事项”。

在这一级别上，过程区域基本实施的执行是经计划并被跟踪的。依据特定步骤的执行被验证。工作产品符合指定的标准和需求。测量被用于跟踪过程区域的执行情况，因此，使组织能够基于实际实施活动进行管理。与非正式实施级别间的主要区别是过程实施被计划和管理。

2 级的公共特征有 4 项。

① “规划执行”。该公共特征的基本实施集中在过程区域以及相关的基本实施执行的规划方面。因而涉及过程文档的编制，适当执行过程工具的提供、过程实施的计划、过程执行中的培训、过程资源的分配以及过程执行的责任分配。这些通用实施为规范化的过程执行提供了最根本的基础。

② “规范化执行”。该公共特征的通用实施注重于对过程实施的控制程度。因此列出了过程执行计划的使用、基于标准和程序的过程执行、配置管理下依过程产生的工作产品。这些通用实施构成了验证过程执行的重要基础。

③ “验证执行”。该公共特征的通用实施注重于确认过程按预定的方式执行。因此这个通用实施涉及验证执行过程与可应用的标准和程序是一致的以及对工作产品的审计。这

些通用实施构成了跟踪过程实施能力的重要基础。

④ “跟踪执行”。该公共特征的通用实施注重于控制项目进展的能力。因此，该过程通过可测量的计划跟踪过程执行，当过程实施与计划产生重大偏离时采取修正行动。这些通用实施形成了达到充分定义过程能力的根本基础。

（3）3级：“充分定义级”

这个级别着重于规范化地裁剪组织层面的过程定义。这个级别的特点可描述为“用项目中学到的最好的东西来定义组织层面的过程”。

在这一级别，基本实施按照充分定义的过程执行。充分定义的过程是依据对文档化的标准过程进行裁剪并经批准的过程版本。这一过程与计划和跟踪级的主要区别在于利用组织范围内的过程标准来管理和规划。

3级的公共特征有3项。

① “定义标准过程”。该公共特征的通用实施注重于组织标准过程的制度化。制度化过程的起因和基础可能是一个或多个相似过程在特定项目中的成功应用。一个组织机构的标准过程可能需要裁剪以适合特定环境的使用，所以如何进行裁剪也应考虑。因此，为组织提出了标准过程的文档和为满足特定用途对标准过程进行裁剪。这些通用过程形成了执行已定义过程必要的基础。

② “执行已定义的过程”。该公共特征注重于充分定义过程的可重复执行。因此提出了制度化过程的使用，针对缺陷的过程结果和工作产品的审阅，过程执行及其结果数据的使用。该通用实施构成了协调安全实施的重要基础。

③ “协调安全实施”。此公共特征注重于项目和组织活动的协调。许多重大活动都是由项目中的不同组和代表项目的组织服务组完成的。缺乏协调将会导致延误和不可比的结果。因此应确定组内、组间、组外活动的协调。这些通用实施是获得定量控制过程能力的必要基础。

（4）4级：“量化控制级”

这个级别着重于测量。测量是与组织业务目标紧密联系在一起的。尽管以前级别数据收集和使用项目测量是基本的活动，但只有到达高级别时，数据才能在组织层面上应用。这个级别的特点可以描述为“只有你知道它是什么，你才能测量它”和“当你测量的对象正确时，基于测量的管理才有意义”。

收集、分析执行详细测量，获得对过程能力和改进能力的量化理解以预测执行情况。这个级执行的管理是客观的，工作产品的质量是量化的。这一级与充分定义级的主要区别在于定义的过程是定量的理解和控制。

4级的公共特征有两项。

① “建立可测的质量目标”。该公共特征的通用实施注重于就组织过程开发的工作产品而言建立可测量目标。因此这个公共特征提出了质量目标的建立。这些通用实施为客观地执行管理提供了必需的基础。

② “客观地管理执行”。该公共特征的通用实施注重于确定过程能力的量化测量并使

用量化测量来管理这一过程。这个公共特征提出了确定量化过程能力和以量化测量作为修正行动的基础。这些通用实施构成了获得连续改进能力的必要基础。

（5）5级：“连续改进级”

这个级别从前面各级的所有管理活动中获得发展的力量，并通过加强组织文化，来保持这个力量。这个方法强调文化的转变，这种转变又将使方法更有效。这个级别的特点可以描述为“一个连续改进的文化需要以完备的管理实施、已定义的过程和可测量的目标作为基础”。

在这个级别上，基于组织的业务目标并针对过程有效性和效率建立量化执行目标。通过执行已定义过程和有创建的新概念、新技术的量化反馈来保证对这些目标进行连续过程改进。这一级与定量控制级的主要区别在于已定义的过程和标准过程基于对这些过程变化效果的量化理解，进行连续调整和改进。

5级的公共特征有两项。

① “改进组织能力”。该公共特征的通用实施注重于在整个组织范围内标准过程的使用进行比较和在这些不同使用之间进行比较。当这些过程被使用时，寻找改进标准过程的机会，分析产生的缺陷以识别对标准过程的其他可能改进。因此，这个公共特征对过程的有效性建立了目标、标识对标准过程的改进以及分析对标准过程的可能变更。这些通用实施构成了改进过程有效性的必要基础。

② “改进过程有效性”。该公共特征的通用实施注重于制定处于连续受控改进状态下的标准过程。因此这个公共特征提出消除标准过程产生缺陷的原因和连续改进的标准过程。

几点说明：

在评估一个组织过程能力和改进组织过程能力时，公共特征和能力级别都是重要的。当评估一个组织能力时，如果这个组织只执行了一个特定级别的一个特定过程的部分公共特征时，则这个组织对这个过程而言，处于这个级别的底层。例如，在 2 级能力上，如果缺乏跟踪执行公共特征的经验和能力，那么，跟踪项目的执行将会很困难。如果高级别的公共特征在一个组织中实施，但其低级别的公共特征未能实施，则这个组织不能获得该级别的所有好处。评估队伍在评估一个组织的个别过程能力时，应对这种情况加以考虑。

当一个组织希望改进某个特定过程能力时，组织为能力级别的实施活动可为改进组织机构提供一个“能力改进路线图”。也是由于这个原因，SSE-CMM 的实施按公共特征进行组织，并按级别进行排序。

对每一个过程区域的能力级别确定，均需执行一次评估过程。这意味着不同的过程区域能够或可能存在于不同的能力级别上。组织可利用这个面向过程的评估结果作为侧重于这些过程改进的参考。组织机构改进过程活动的顺序和优先级应在业务目标中加以考虑。组织的业务目标是使用 SSE-CMM 的主要驱动力。

5.2　知识子域：安全运营

5.2.1　安全运营概述

在组织机构信息系统建设时，安全工作主要是对信息系统面临的安全风险进行分析，根据安全风险形成安全需求，然后通过合理的规划、采购并部署安全设备等工作，构建完备的信息系统防御体系。随着组织机构业务的不断发展，业务也越来越多样，安全环境也越来越复杂，组织机构面临的安全问题也在不断地增加，这些问题不是安全技术、安全管理、安全开发等工作能解决的，需要建立机制对信息系统运行状况进行监控，对运行中的问题进行分析，发现问题的根源并协调资源进行解决以实现安全目标。信息安全运营更多的是面向组织机构的业务，与传统的 IT 运营相辅相成、互为依托、共享资源与信息。

安全运营可以参考 COBIT、ITIL、ISO 27000 等最佳实践与标准。其中 COBIT 重点在于 IT 控制和 IT 度量评价；ITIL 重点在于 IT 过程管理，强调 IT 支持和 IT 交付；ISO 27000 重点在于 IT 安全控制。

5.2.2　安全运营管理

1．漏洞管理

（1）漏洞的概念

漏洞（Vulnerability）也被称为脆弱性，1947 年冯·诺依曼建立计算机系统结构理论时认为，计算机系统也有天生的类似基因的缺陷，也可能在使用和发展过程中产生意想不到的问题。20 世纪七八十年代，早期黑客的出现和第一个计算机病毒的产生，软件漏洞逐渐引起人们的关注。1970 年中期，美国启动的 PA 计划（Protection Analysis Project）和 RISOS（Research in Secured Operating Systems）计划开启了信息安全漏洞研究工作的序幕。

在各种产品、主机、网络和复杂信息系统中，安全漏洞以不同形式存在，而且数量逐年增加，利用漏洞造成的各类安全事件层出不穷。攻击行为或网络安全事件的发生正越来越多地受到利益驱动的影响，这种“黑色产业链”的兴起，导致越来越多的网络终端受害，大量机密信息被窃取，敏感数据信息在互联网上传播，并在黑市中待价而沽。工业控制领域以及新技术新应用的安全漏洞，特别是基础核心系统的安全漏洞已经成为危害国家经济和发展安全的重要因素。

在三十多年的研究过程中，学术界、产业界以及政策制定者对漏洞给出了很多定义，漏洞本身也随着信息技术的发展而具有不同的含义与范畴，从最初的基于访问控制的定义逐步发展到涉及系统安全流程、设计、实施、内部控制等全过程的定义。

1982 年，Dennin 从系统状态、访问控制策略的角度给出了漏洞定义。他认为，系统中主体对对象的访问是通过访问控制矩阵实现的，这个访问控制矩阵就是安全策略的具体实

现，应该明确描述系统中的每一个主体可以执行什么操作、不可以执行什么操作。当系统的操作和安全策略之间相冲突时，就产生了安全漏洞。因此，信息安全漏洞就是指导致访问控制矩阵所定义的安全策略和系统操作之间冲突的所有因素。

Bishop 和 Baily 在 1996 年对信息安全漏洞给出了基于状态空间的定义，认为信息系统是由若干描述实体配置的当前状态所组成的，系统通过应用程序的状态转变来改变系统的状态，通过系列授权和非授权的状态转变，所有的状态都可以从给定的初始状态到达。易受攻击状态是指通过授权的状态转变，从非授权状态可以到达的授权状态，受损状态是指已完成这种转变的状态。攻击就是指到达受损状态的状态转变过程。从状态空间角度来讲，漏洞就是指区别于所有非受损状态的容易受攻击的状态特征。通常地讲，漏洞可以刻画许多容易受攻击的状态。

给定一个系统，安全策略规定了其用户哪些操作是允许的，哪些操作是不允许的。其形式化的定义为：给定状态空间 S=（M，T），安全策略是状态对 P=（A，D），其中，$A \subseteq M$ 是系统允许的状态集合，D=M-A 是系统不允许的状态集合。那么基于安全策略的漏洞定义为：漏洞是一个二元组 V=（N，P），其中 N 是一个非空的条件集合，满足这些条件可导致违背某个系统 x 的安全策略 P。因此，对应于不同安全策略的违背，就形成了不同类型的漏洞。

由美国 MITRE 公司（一个由美国联邦政府支持的非盈利性研究机构）提出了漏洞与披露的标准命名字典（CVE）。CVE 对漏洞给出的定义也是基于安全策略的，即一个错误（mistake）如果可以被攻击者用于违反目标系统的一个合理的安全策略，那么它就是一个漏洞。一个漏洞可以使目标系统（或者目标系统的集合）处于下列危险状态之一：允许攻击者以他人身份运行命令；允许攻击者违反访问控制策略去访问数据；允许攻击者伪装成另一个实体；允许攻击者发起拒绝服务攻击。

1990 年，Longstaff 等人认为漏洞是指系统中存在的任何不足或缺陷。在计算机安全中，漏洞可以从以下两个方面来理解：一方面，漏洞是指自动化系统安全过程、管理控制以及内部控制等过程中的缺陷，它能够被威胁利用，从而获得对信息的非授权访问或者破坏关键数据处理；另一方面，漏洞是指在物理层、组织管理、软件程序或人员管理等方面的缺陷，它能够被利用而导致对系统的损害。

1999 年，ISO/IEC 15408 对漏洞给出的定义是：漏洞是存在于评估对象（TOE）中的，在一定的环境条件下可能违反安全功能要求的弱点。2003 年美国发布的信息系统安全词汇表（NSTISSI No.4009）给出的定义认为漏洞是指可被利用的信息系统、系统安全流程、内部控制或实施中存在的弱点。2006 年，美国国家标准与技术研究院发布的《关键信息安全术语词汇表》（NIST IR 7298）定义漏洞是指威胁源可以攻击或触发的信息系统、系统安全流程、内部控制或实施中的弱点。同年出版的《信息安全字典》中给出的定义，漏洞是系统安全流程、系统设计、实施、内部控制等过程中的弱点，这些弱点可以被攻击以违反系统安全策略；攻击或对威胁暴露的可能性特定于给定的平台。2009 年 ISO/IEC SC 27 发布的国际标准《SD6：IT 安全术语词汇表》中给出的定义是，漏洞是一个或多个威胁可以

利用的一个或一组资产的弱点；是违反某些环境中安全功能要求的评估对象（TOE）中的弱点；是在信息系统（包括其安全控制）或其环境的设计及实施中的缺陷、弱点或特性。

综上所述，信息安全漏洞可以这样理解，从生命周期的角度出发，信息技术、信息产品和信息系统在需求、设计、实现、配置、维护和使用等过程中，有意或无意产生的缺陷，这些缺陷一旦被恶意主体所利用，就会造成对信息产品或系统的安全损害，从而影响构建于信息产品或系统之上正常服务的运行，危害信息产品或系统及信息的安全属性。

有时漏洞也被称作错误（Error）、缺陷（Fault）、弱点（Weakness）或是故障（Failure）等，这些术语很容易引起混淆。在许多情况下，人们习惯于将错误、缺陷、弱点都简单地称为漏洞。需要指出的是，严格地说，错误、缺陷、弱点和故障并不等于漏洞。错误、缺陷和弱点是产生漏洞的条件，漏洞被利用后必然会破坏安全属性，但不一定能引起产品或系统故障。

（2）检测并评估漏洞

漏洞是信息系统中必然存在的安全问题，因此在信息系统运营过程中对漏洞进行管理是保障信息系统安全的重要工作。漏洞管理是指定期检测漏洞，评估并采取相应措施来减少相关风险。漏洞与风险一样，不可能彻底地消除，然而，有效的漏洞管理程序能够帮助组织机构及时地发现系统中存在的漏洞并进行修补。

漏洞扫描是信息系统风险评估中的常用技术措施，定期的漏洞扫描有助于组织机构发现系统中存在的安全漏洞。漏洞扫描软件是实施漏洞扫描的工具，用于测试网络、操作系统、数据库及应用软件是否存在漏洞。绝大部分漏洞扫描软件都有一个已知安全漏洞特征数据库，采取类似防病毒软件的特征匹配方式来进行漏洞检测，漏洞扫描软件的供应商会定期更新这个数据库。因此，对于安全运维人员来说，定期更新这个数据库是基本要求，因为如果不定期更新，就无法及时发现系统中存在的新的安全漏洞。这类似于如果防病毒软件不知道最新型的病毒，就不能检测到该病毒。

漏洞评估概念要大于漏洞扫描，涵盖更多的东西。漏洞评估不仅分析目前系统的扫描结果，还要分析之前的漏洞扫描报告，以确定组织机构是否已经执行了漏洞修复工作，如果漏洞扫描报告上存在之前已经发现但未修补的漏洞，安全运营人员就需要关注此漏洞未被修补的原因。是否由于工作落实问题导致补丁安装工作未被落实，如果是这种情况，安全运营人员须上报高层并关注落实情况。而如果是其他原因，例如由于系统兼容性问题，此漏洞补丁无法安装，那么安全运营人员需要评估漏洞存在的安全风险并给出进一步的防护措施，包括其他技术措施或管理措施。

漏洞评估还需要检测其他领域，以确定风险。例如，漏洞评估通过检测敏感信息在整个生命周期中如何被标记、处理、存储和销毁，来解决潜在风险。

2. 补丁管理

补丁有时被称为更新、快速修复或热修复，是能够纠正错误、修复漏洞，或提高现有软件的性能的操作系统或应用软件代码。在软件的整个生命过程中，软件都可能因为添加

新的功能、调整现有算法、优化模块性能、适应新的环境、修补代码缺陷、重构代码风格等各种原因而被更新。专门用于修复漏洞的软件补丁一般称为安全补丁。

如果漏洞信息发布后没有安全补丁，就只能采取一些规避措施，例如关闭某些控件、服务或调整相关配置等方法来尽量避免危险或者缩减可能的危害范围。但这些临时措施并没有从根本上解决漏洞带来的安全问题，而且其使用范围和作用也受到各种条件和环境的限制。因此，漏洞的修复最终还是依赖于软件厂商发布的补丁修复程序或升级软件来完成。数据显示，只要用户及时为信息系统安装恰当的补丁即可避免大约 95%的信息安全问题。因此，针对安全漏洞，安装相应的补丁是最有效、也是最经济的防范措施，而补丁安装也是信息系统安全运营过程中非常重要的工作。

补丁安装部署之前需要经过必要的测试。补丁的安装可能会给信息系统引入稳定性、性能等方面的隐患，甚至直接影响应用系统的正常运行。因此，在应用于信息系统之前，每个补丁都应该经过测试，确保能够正常运行，不会和系统中已有的应用程序相冲突。在某些情况下，用户需要重新配置系统或为某些应用程序重新编码，才能使补丁正常运行，不致引发新问题。

补丁的获取没有标准过程，有些厂商的补丁可以在厂商网站上获取，有的却不可以，用户需要从可靠来源不断获取最新补丁信息。

补丁安装部署时可能需要重启系统以使补丁生效，如果需要安装补丁的信息系统是生产环境中的关键系统，关闭时可能会带来损失，因此在关键生产系统中，尽量避免使用自动安装补丁的功能，并且，信息系统安装补丁时需要做好备份和相应的应急措施。

有效的补丁管理程序能够确保系统安装当前最新的补丁。下面是有效补丁管理程序中共同的步骤。

（1）评估补丁：当供应商发布补丁后，管理员会进行评估，以确定补丁适用于他们的系统。例如，如果 Windows 系统中的某个功能没有安装，则用于修补该功能的补丁可能就不需要了。

（2）测试补丁：管理员应在测试环境中对系统补丁进行部署测试，以确保该补丁的安装不会带来其他问题，特别是针对关键信息系统的补丁程序，如果未经测试就安装，由此引起系统的无法启动或其他故障，后果可能是灾难性的。测试补丁应在与生产环境一致的测试环境中实施。

（3）批准补丁：管理员测试补丁并确定其安全性后，就会批准补丁的部署，批准程序中常用到变更管理过程。

（4）部署补丁：经过测试和批准，管理员部署补丁。许多组织使用自动化的方法部署补丁，自动化方法可以是第三方产品或由软件供应商提供。

（5）确认补丁已部署：部署补丁后，管理员定期测试和审计系统，以确保系统补丁仍然有效。许多部署工具都有审计系统的功能。此外，许多漏洞评估工具也具有检查系统的功能，以确保随时有合适的补丁。

3．变更管理

任何一个项目，从开始就处于不停地变化之中，如用户需求发生变化，对应需要调整计划或者设计等。测试发现了问题需要对错误的代码进行修正，也会引发变更。甚至人员流失了，也需要对项目进行一定的调整以适应这种情况。Bug 管理、需求管理、风险控制等本质上都是变更管理的一种方式，它们都是为了保证项目在变化过程中始终处于可控状态，并随时可跟踪回溯到某个历史状态。所有的变更都必须遵循一个正式的变更管理过程。

（1）提交变更申请

项目团队中任何成员都可以提交变更申请，但需要完成以下工作。

① 变更申请人识别项目中任何方面的变更需求（如范围、可交付成果、时限、组织）。

② 变更申请人完成变更申请表（CRF），并将其呈交项目管理委员会（CCB）。变更申请表中需要对变更的需求进行概括性描述，包括变更描述、变更原因（包括商业驱动）、变更利益、变更成本、变更带来的影响及支持性文件等。

（2）审核变更申请

项目管理委员会（CCB）对变更申请进行审核，以决定是否需要一份充分的可行性研究报告以评估变更可能带来的全部影响。

（3）批准变更申请

本阶段涉及项目管理委员会对变更申请的正式审核。CCB 可能做出以下结论：拒绝变更请求、要求与变更相关的更多信息、批准变更申请、在特定条件下批准变更。

（4）实施变更

本阶段开始对变更进行实施，包括更新文档、代码等，并进行相应的测试，以确保变更被正确实施。

（5）报告组织领导层

对变更进行详细的记录，并将结果报告给组织的领导层。

4．配置管理

配置管理是 IT 服务中的重要管理流程，其目标是定义和控制服务与基础设施的部件，并保持准确的配置信息。在信息系统的安全运营过程中，配置管理有助于确保系统处于一致安全的状态，并在其整个生命周期中维护这种状态。随着信息系统的日益复杂化和用户需求及软件更新的频繁化，配置管理和变更管理流程在安全运营过程中至关重要，它能确保信息系统保持安全基线，避免由于业务的不断发展带来的混乱情况。

5．事件管理

事件管理针对在某一服务中不属于标准操作，可能引起这个服务中断或服务质量下降的任何事件进行管理的流程，其目的是减少或消除事件（包括 IT 事件和安全事件）对信息系统运行带来的干扰，以确保组织机构的业务连续性。事件管理也是安全运营中很关键的流程，它为组织提供首先检测事件然后准确确定正确的支持资源以便尽快解决事件的能力。

该流程还为管理层提供关于影响组织的事件的准确信息，以便他们能够确定必需的支持资源，并为支持资源的供给做好计划。事件管理流程涉及运营的整个生命周期。

5.3 知识子域：信息内容安全

5.3.1 内容安全基础

1. 内容概念及重要性

数字资源是文献信息的表现形式之一，是将计算机技术、通信技术及多媒体技术相互融合而形成的以数字形式发布、存取、利用的信息资源总和。随着信息技术的发展，数字资源的内涵日益丰富，主要包括数字音像、科学出版、远程教育、动漫游戏、金融信息、政府公告、网络博客、网络论坛等，涉及教育、科学、金融、文化、娱乐、商业、通信等各个领域。信息化技术的发展不仅使大量的数据被数字化，同时也不断生产出更多的数字内容。这些数字资源的快速传播为人们生活带来极大便利的同时，也带来了数字资源盗版、信息泄露、非法内容等诸多安全问题。

> 根据 IDC 和 EMC 发布的“2020 年的数字宇宙”报告，预计到 2020 年，数字内容的总容量将达到 40 万亿 GB（也就是说，2020 年每个男人、女人和孩子可以均摊到 5200GB 以上）

- 数字资源盗版：也就是数字内容版权被侵犯。数字资源（包括动画、游戏、影视、数字出版、数字创作、数字馆藏、数字广告、互联网、信息服务、咨询、移动内容、数字化教育、内容软件等）的版权和应得的利益被侵犯。
- 信息泄露：随着大量数字资源在网络上快速传播，企业及个人的敏感及隐私信息泄露。
- 非法内容：网络空间的特性为反动言论、色情暴力、谣言等非法及有害言论提供生存空间，对社会和谐构成威胁。

数字资源的内容安全是信息安全在政治、法律、道德层次上的要求，即信息内容在政治上是健康的，而且信息内容必须符合国家法律法规，同时还需要符合中华民族优良的道德规范。除此之外，广义的内容安全还包括信息内容保密、知识产权保护、信息隐藏和隐私保护等诸多方面。国家制定了多条法律法规来保障数字内容的安全性。

《网络安全法》第十二条指出：“国家保护公民、法人和其他组织依法使用网络的权利，促进网络接入普及，提升网络服务水平，为社会提供安全、便利的网络服务，保障网络信息依法有序自由流动。任何个人和组织使用网络应当遵守宪法法律，遵守公共秩序，尊重社会公德，不得危害网络安全，不得利用网络从事危害国家安全、荣誉和利益，煽动颠覆国家政权、推翻社会主义制度，煽动分裂国家、破坏国家统一，宣扬恐怖主义、极端

主义，宣扬民族仇恨、民族歧视，传播暴力、淫秽色情信息，编造、传播虚假信息扰乱经济秩序和社会秩序，以及侵害他人名誉、隐私、知识产权和其他合法权益等活动。”

《网络安全法》第四章第四十条规定：“网络运营者应当对其收集的用户信息严格保密，并建立健全用户信息保护制度。”第四十二条规定：“网络运营者不得泄露、篡改、毁损其收集的个人信息；未经被收集者同意，不得向他人提供个人信息。但是，经过处理无法识别特定个人且不能复原的除外。网络运营者应当采取技术措施和其他必要措施，确保其收集的个人信息安全，防止信息泄露、毁损、丢失。在发生或者可能发生个人信息泄露、毁损、丢失的情况时，应当立即采取补救措施，按照规定及时告知用户并向有关主管部门报告”等。

国家还颁布了《国务院关于授权国家互联网信息办公室负责互联网信息内容管理工作的通知》，通知指出为促进互联网信息服务健康的有序发展，保护公民、法人和其他组织的合法权益，维护国家安全和公共利益，授权重新组建的国家互联网信息办公室负责全国互联网信息内容管理工作，并负责监督管理执法。

由此可见，互联网数字内容监管在法律和政策中的地位日益凸显。

2．内容安全需求

内容安全需求主要包括来源可靠、敏感信息泄露控制以及不良信息传播控制3个方面。

（1）内容来源可靠

数字内容来源的可靠性可以通过数字版权来保证。数字版权即各类出版物、信息资料的网络出版权，及可以通过新兴的数字媒体传播内容的权利，包括制作和发行各类电子书、电子杂志、手机出版物等的版权。

数字版权管理（Digital Rights Management，DRM）指的是出版者用来控制被保护对象的使用权的一些技术，这些技术保护的有数字化内容（例如软件、音乐、电影）以及硬件、处理数字化产品的某个实例的使用限制。

（2）敏感信息泄露控制

随着信息化的发展，信息技术强大的开放性和互通性为企业提供了便利，但同时各种泄密事件和个人隐私信息泄露事件频发。敏感信息的泄漏大致分为个人隐私信息泄漏和企业信息泄漏两大类。例如，各类企业利用信息化技术打破地域阻碍的同时会产生大量的关乎企业核心竞争力的商业机密资料，如客户资料、营销方案、财务报表、研发数据等，这些商业机密信息的泄露给企事业单位带来巨大损失。因此，敏感信息泄漏控制逐渐成为企业关注的焦点。个人隐私信息的泄漏方式主要集中于网络社交工具泄漏与票据信息泄漏等。个人隐私信息泄露也会给个人造成巨大困扰，为防治个人隐私信息泄密，应当加强法治监管，培养个人信息安全意识。对于企业而言，需要从技术防范和信息安全管理两个角度来防止企业敏感信息泄露。同时组织人员进行保密培训，提高员工的信息安全防范意识。

（3）不良信息传播控制

互联网是一个虚拟空间，互联网的匿名性使得它成为了传播不良信息的便利场所。在互联网上，各种色情、诈骗、暴力、谩骂、攻击、诽谤信息比比皆是。网上不良信息的传播范围广，而且传播速度快，因此网上不良信息的危害性极大，如果不采取适当有效的措施，互联网不良信息会给社会和民众造成极大威胁，因此监控不良信息传播具有重要意义。

不良内容的传播者包括不良信息的初始传播者和再传播者，传播者中既有个人，也有组织。需要从法律、行政监管、群众监管和行业自律等多个方面构建互联网不良信息的传播者控制机制。此外，需要建立完善的网络舆情监控机制，随时关注互联网上的舆情动向，及时对不良内容进行处理。

5.3.2 数字版权

1．著作权与版权

版权一词来源于英美法系中的单词“copyright”，从单词原意可以看出，版权（copyright）最初的意思就是“复制权”。也就是说对作品是否有复制的权力，如果未经许可是不能复制作品的，因为未经许可的复制损害了作品权利人的相关权益。我国法律体系中通常使用的词是“著作权”，著作权从学术角度来看，更为注重保护作品创作者的人身权利。根据《中华人民共和国著作权法》（以下简称《著作权法》）中对著作权的定义，在我国著作权与版权是同义词（《著作权法》第五十七条：本法所称的著作权即版权）。在日常使用中，两个词基本没有区别，例如我国相关法律称为“著作权法”，但是管理机构名称是“国家版权局”。中文最早使用“著作权”始于中国第一部著作权法律《大清著作权律》。清政府解释为：“有法律不称为版权律而名之曰著作权律者，盖版权多于特许，且所保护者在出版，而不及于出版物创作人；又多指书籍图画，而不是以赅刻模型等美术物，故自以著作权名之适当也。”（注：来自百度百科）我国之后就沿用著作权的称呼。

根据《著作权法》，在中华人民共和国境内，凡是中国公民、法人或者非法人单位的作品，不论是否发表都享有著作权；外国人的作品首先在中国境内发表的，也依《著作权法》享有著作权；外国人在中国境外发表的作品，根据其所属国与中国签订的协议或者共同参加的国际条约享有著作权。

2．数字版权管理

信息技术的快速发展使得大量的作品使用了二进制数字编码表达的形式，很多传统的文字、图片、美术、摄影、音乐、动画、电影电视等作品也都转换成二进制数字编码的形式。由于数字化后的作品具有复制和传播的便利性，因此大量的数字作品的网络传播权保护就成为数字化时代必须要解决的问题。数字版权管理（Digital Rights Management，DRM）就是数字化时代用于保护数字作品的版权的一种方式，从技术上防止数字媒体的非法复制和非法使用，确保最终用户在得到授权后才能使用数字媒体。一般具有以下六大功能。

- 数字媒体加密：打包加密原始数字媒体，以便于进行安全可靠的网络传输。
- 阻止非法内容注册：防止非法数字媒体获得合法注册从而进入网络流通领域。
- 用户环境检测：检测用户主机硬件信息等行为环境，从而进入用户合法性认证。
- 用户行为监控：对用户的操作行为进行实时跟踪监控，防止非法操作。
- 认证机制：对合法用户的鉴别并授权对数字媒体的行为权限。
- 付费机制和存储管理：包括数字媒体本身及打包文件、元数据（密钥、许可证）和其他数据信息（例如数字水印和指纹信息）的存储管理。

DRM 系统的核心是数字媒体授权中心（Rights Issuer，RI），数字媒体授权中心负责对数字作品进行加密保护，并在加密的数字媒体头部存放着 KeyID 和节目授权中心的 URL。用户在使用数字媒体资源时，根据数字媒体头部的 KeyID 和 URL 连接到数字媒体授权中心进行验证，验证通过后获得解密的密钥，使用密钥解密数字媒体后即可使用。由于数字作品是经过加密的，即使在传输过程中被截获或者非法复制，因为没有数字媒体授权中心的验证授权，所以无法打开，从而很好地保护数字作品的版权。DRM 机制从技术角度来看能为数字作品的版权提供良好的安全保障，但由于体系结构复杂，并且要求用户只能在特定的设备上使用数字作品，因此在便利性和易用性上都存在较多问题。例如网络不稳定、DRM 系统故障等问题都可能导致合法用户得不到应有的服务。

2007 年 2 月 6 日，乔布斯向外界发出了一封公开信，宣布苹果公司完全废止 DRM 技术，因为使用 DRM 保护不能保证歌曲不被盗版，但是却给用户带来巨大的使用障碍，同时，使用 DRM 技术用户也容易发生隐私信息泄露。随后，微软、索尼、华纳音乐等多家公司都退出了 DRM 的阵营，向用户提供无数字版权保护的音乐。

3．使用数字版权保护信息

目前，在版权保护方面国内外使用较为广泛的是数字对象标识符（Digital Object Identifier，DOI）系统，它是由非赢利性组织国际 DOI 基金会（International DOI Foundation，IDF）研究设计的，在数字环境下标识知识产权对象的一种开放性系统。在 DOI 系统中，出版商将数字作品的 DOI 命名、元数据及 URL 信息提交至 DOI 注册机构进行审核，审核通过的数字作品将存入元数据库和 DOI 目录库，完成 DOI 注册。个人用户在网络上检索数字作品时，单击 DOI 链接，通过 DOI 注册机构的解析服务得到数字作品的 URL，登录到数字作品拥有者的服务器、版权在线购买服务器或其他版权解决机制的服务器，从而实现数字作品的版权保护。

DOI 系统已经发展得比较成熟，但是采用 DOI 标准，就要加入它的解析系统之中，这不仅要将数字作品基本数据提交给外方，每年还要交纳巨额费用，形成国内作品信息集中于外方手中的局面，影响国家文化安全。更重要的是，这种参与和加入 DOI 系统的方式不能有效解决我国网络环境下的数字版权权属问题，更难以达到保护的目的。为此，中国版权保护中心在对国际国内互联网版权保护模式研究与探索的基础上，结合我国国情，提出数字版权唯一标识符（Digital Copyright Identifier，DCI）体系，以有效应对互联网版权保

护面临的挑战。DCI 体系主要由 3 个基础平台构成，分别是数字作品版权登记平台、数字版权费用结算平台和数字版权检测取证平台。通过登记、结算、检测平台并结合 DCI 相关技术，提供我国数字版权公共服务的新模式。DCI 体系现在正处于研究与建设之中。

DCI 体系的核心内容是 DCI 码，它是数字作品权属的唯一标识，可以分配给任何形式的数字作品（包括软件、音频、视频、文本等）。数字作品在登记机构进行登记，登记成功后由专门机构来分配 DCI 码。通过 DCI 码对数字作品版权信息进行标识，可以逐步建立一个国家级的、统一的数字作品版权元数据库，从而使社会各相关方容易检索到数字作品的权利人和权属状态。当权利人的利益受到侵害或者发生版权纠纷时，能够通过对版权元数据库的查询确定数字作品的权属。通过 DCI 码对数字作品权利人和权属状态进行标识的方式，能够有效解决我国网络环境下数字作品版权权属的问题，达到数字作品版权保护的目的。

5.3.3 信息保护

1. 信息的价值

信息泛指人类社会传播的一切内容。人通过获得、识别自然界和社会的不同信息来区别不同事物，得以认识和改造世界。在一切通信和控制系统中，信息是一种普遍联系的形式。科学家香农在题为《通信的数学理论》的论文中指出：“信息是用来消除随机不定性的东西。”

而隐私信息是一种与公共利益、群体利益无关，当事人不愿他人知道或他人不便知道的个人信息。从法理意义上讲，隐私信息应当定义为：已经发生了的正当且符合道德规范但不能或不愿示人的事、物或情感活动等信息。隐私权是指自然人享有的私人生活安宁与私人信息秘密依法受到保护，不被他人非法侵扰、知悉、收集、利用和公开的一种人格权。并且权利主体对他人在何种程度上可以介入自己的私生活，对自己的隐私是否向他人公开以及公开的人群范围和程度等具有决定权。隐私权是一种基本人格权利。

任何的信息，特别是隐私信息都具有价值。马克思主义的价值观认为价值是客体满足主体需要的一种属性，而价值量的大小则是客体满足主体需要的满足程度。因而，信息的价值在于它具有满足信息用户的信息需求的属性。同时，马克思主义政治经济学中阐述了商品具有使用价值和价值这两重属性，商品的价值量是由社会必要劳动时间决定的。信息一旦用于交换，便成为了商品，这使信息具备了与其他商品形态一样的价值属性，即信息具有了使用价值和价值。

综上所述，信息的价值是凝结在信息服务组织或个人信息服务过程中的一般（抽象）劳动，体现的是信息生产者与信息用户之间的一种经济利益关系。信息的使用价值则在于信息的有用性：信息本身包含用户所需的大量知识、应用技术等为用户所需的竞争性、前瞻性情报，因而具备有用性。对于隐私信息来说，其包含的情报等比普通信息更多，因此具有更重要的价值。

2．信息的泄漏途径

（1）个人隐私信息泄漏

互联网时代，各种新技术、新应用层出不穷，为人们生活提供了极大便利，也给网络犯罪提供了更多机会。我国上网用户比例年年增长，其中用户遇到的最大问题就是个人信息泄露，据统计，超过四分之三的网民个人身份信息都被泄露过，包括姓名、住址、身份证号、工作单位、电话等。信息泄露给个人生活带来巨大危害，严重影响家庭财产安全。

其中，信息泄漏的方式多种多样，对于个人来说，隐私泄露的途径包括通过微博、微信等社交网络的信息发布、网站注册时信息泄露等多种方式。微博是一种受到广大网友关注和欢迎的信息交流形式，其社交化特点和字符限制，使发布内容大多局限在与自身密切相关的信息，如日常生活、朋友聚会、情绪心情，以及家庭情况、行程定位、自拍图片等。这些个人隐私信息的大量公开，不仅将个人形象立体地呈现给别人，同时也将私人活动和私人领域暴露在了网络上。相比微博，微信的朋友圈具有更好的私密性，但正是因为这一特性，用户可能会将自己更加隐私的信息发布到朋友圈中，若这些信息被攻击者看到，可能会造成严重后果。

另外，人们在网上填写的注册信息往往也包含个人隐私信息，例如姓名、电话、地址等信息。有些不良网站会收集人们的个人信息进行贩卖，从而导致隐私信息大量泄漏。除了上述网络中的信息泄露方式，在人们的日常生活中还存在多种信息泄漏的可能，下面列举几种常见的泄漏途径。

① 各类单据信息泄漏：日常生活中，人们的快递单、车票以及购物小票等票据上都存有大量个人隐私信息，若随意丢弃很可能被不法分子利用。

② 身份证复印件泄漏：银行、电信运营商营业厅、各类考试报名等，很多地方都需要留存身份证复印件，甚至一些打字店、复印店利用便利，将暂存在复印店的客户信息资料存档留底。

③ 网络调查：上网时经常会碰到各种填写调查问卷、玩测试小游戏、购物抽奖，或申请免费邮寄资料、申请会员卡等活动，会要求填写详细联系方式和家庭住址等个人信息。

④ 公共 Wi-Fi：平常人们在上网时，总喜欢连接免费的公共 Wi-Fi 来节省流量，然而这些公共 Wi-Fi 可能并不安全，黑客可能利用相关技术手段获取连接到 Wi-Fi 的手机上网信息。此外，生活中还有许多细节都可能造成隐私信息的泄漏。

（2）组织机构的敏感信息泄漏

对于企业或公司来说，信息泄露途径主要有信息公示过于细致、缺乏敏感信息标记两种方式。在各公司或政府学校的网站上，经常会有各式各样的公示信息，过于详细的公示信息会造成企业及其员工的隐私信息泄露。

此外，企业敏感信息泄漏的原因还可能是因为缺乏敏感信息标记及定义。为此在管理信息时，若内容中包含敏感信息，则必须对敏感信息进行适当标记（或加上标签）并加以保护。敏感性和机密性分为不同的“程度”，每个程度基于信息在非授权披露时可能造成的损害来决定。程度范围包括从微小到严重（包括丧失生命）。潜在危害的程度越高，就

越需要采取更多的措施来保护信息。对于不同的敏感类型，通过 5 种敏感性标记来指示：商业机密、只可查阅、政府/外部资源、私人、重要。所有的工作人员都有责任遵守指南来为敏感性信息加上标签，并保护它们。

3．个人隐私信息保护

（1）个人隐私信息保护相关规定

我国作为民事立法之基石的《宪法》对隐私权相关保护的规定有两条。其中第三十九条规定："中华人民共和国公民的住宅不受侵犯。禁止非法搜查或者非法侵入公民的住宅。"《宪法》的这一条规定是对隐私权的直接确认与保护，明确禁止了非法搜查或者非法侵入公民的住宅。《宪法》第四十条规定："中华人民共和国公民的通信自由和通信秘密受法律的保护，除因国家安全或者追究刑事犯罪的需要，由公安机关或者检察机关依照法律规定的程序对通信进行检查外，任何组织或者个人不得以任何理由侵犯公民的通信自由和通信秘密。"该条款保护了公民通信的自由与私密性。

最高人民法院《关于贯彻执行中华人民共和国民法通则的若干问题的意见》第一条规定："以书面、口头等形式宣扬他人的隐私，或者捏造事实公然丑化他人人格，以及用侮辱、诽谤等方式损害他人名誉，造成一定影响的，应当认定为侵害公民名誉行为。"最高人民法院在《关于审理名誉案件若干问题的解答》中再次强调指出："对未经他人同意，擅自公布他人的隐私材料或以书面、口头形式宣扬他人隐私，致人名誉受到损害的，应按照侵害他人名誉权处理。""文中有披露隐私的内容，致使名誉受到损害的，应认定为侵害他人名誉权。"这一司法解释在总体上与前述司法解释相仿。

（2）个人的隐私信息保护措施

在生活中，应该加强个人隐私保护意识，重要证件（身份证、军官证）等不随身携带，银行卡、U 盾等应及时升级和更新，在 ATM 机取款时要观察周边环境，遮挡用户密码，不相信周边围贴的通知等。手机要安装杀毒软件并及时更新，定期扫描，不安装来历不明的应用程序，不轻易点击不明链接，网上交易时使用第三方支付平台。电脑用户也必须安装杀毒软件并及时更新，不使用盗版软件，不访问不正规网站，不在公共机房、网吧使用个人信息，公共电脑使用完毕要用安全软件及时清理上网记录和痕迹。

4．组织机构敏感信息保护

组织机构的敏感信息泄露防护应从技术及管理两个方面采取措施，以降低信息泄露的安全风险。

（1）技术措施

敏感信息泄露防护措施包括数据加密、信息拦截、访问控制等具体实现。

数据加密采用密码技术对数据进行加密，然后通过密钥管理和密钥的分发实现对数据解密的授权，只有被授权的人才能解密和使用数据。信息拦截是在网络出口和主机上部署安全产品，对进出网络主机的数据进行过滤，发现数据被违规转移时，进行拦截和警报。而访问控制受限于操作系统机制，可能被绕过。因此在实际应用中需要综合利用各类防护

技术的优点才能更好地保护隐私信息的安全性。

（2）管理措施

加强信息安全泄露防护不仅仅通过技术实现，还应结合各类管理措施并落实相关安全工程，才能有效提高企业的敏感信息泄露防护能力。组织机构信息安全管理措施相关内容参考安全管理知识域的相关章节。

5.3.4 网络舆情

1. 网络舆情的概念

随着互联网的快速发展，网络媒体作为一种新的信息传播形式，已深入人们的日常生活。以互联网为基础的 QQ、微信、微博等即时通讯软件，为人们发表观点提供了一个公共的平台，网络日益成为大众反映民意、诉说民情的新途径。网友言论活跃已达到前所未有的程度，不论是国内还是国际重大事件，都能马上形成网上舆论，通过这种网络来表达观点、传播思想，进而产生巨大的舆论压力，达到任何部门、机构都无法忽视的地步。可以说，互联网已成为思想文化信息的集散地和社会舆论的放大器。

网络舆情是随着技术的发展而形成和发展起来的，是大众以网络作为媒介所发表的各种观点的集合，是在一定的社会空间内，网民通过网络围绕某一社会现象或事件的发生和发展及变化，对人们关心的若干社会现象所产生和持有的自我意识表示、态度和价值观。它归属于社会舆情的大范畴之中，是对特定事件的发生情况进行有效的判断之后，通过与网民的互动实现自发的分类筛选，最终形成对该问题属性各种倾向性判断的集合。

在网民相互交流的过程中，各自的观点、意见与态度交相辉映，人们根据自身头脑中长期形成的思维意识、价值观、知识结构及道德观念等对收到的信息进行进一步的分类、筛选和组织，当某个特定的问题引起大家的广泛关注甚至于是共鸣的时候，网络传播的迅捷性和放大效应便会吸引更多的群体参与跟帖、交流以及讨论。随着意见和讨论的深入与扩展，人们的关注点便会深入到某一个焦点，从而形成具有一定规模且较为明确的网络舆情。

2. 网络舆情管理

对于网络舆情的管理大致有以下几个措施。

（1）确立政府主导地位，发挥媒体监督功能。

网络空间文化冲突的必然性要求网络舆情管理必须以政府主导，构建和谐网络。政府主导将会以社会主义先进文化为代表，以其权威性有效拨正网络文化发展的不良倾向，使互联网真正成为传播社会主义先进文化的新途径、公共文化服务的新平台、人们健康精神文化生活的新空间。

（2）夯实网络舆情理论研究，积极开发网络舆情监测软件。

网络舆情理论研究是网络舆情管理的基础，只有深入开展网络舆情理论的研究，才能

为网络舆情管理奠定坚实的基础，才能有效保证网络舆情的监控，才能摸清网络文化发展的现状，才能明确网络文化发展的问题，才能促进网络文化朝社会主义先进文化方向发展。

（3）把握网络舆情管理的原则，建立和完善网络舆情管理机制。

针对目前网络舆情管理的现状，网络舆情管理的原则应该从 3 个方面加以把握。一是坚持以法管网，只有以法管网，依法治网，才能保证网络经济的健康发展，才能有效保障人民的财产免遭网络侵害，才能有效打击遏制网络犯罪。二是要坚持以网管网，网络是平等自由的，但不是没有限制的自由，网民通过网络畅所欲言、自由发表言论是网络本质的体现，但当这种自由带着特定的目的，危害国家网络文化安全，突破社会主义道德底线时，就要受到谴责、警告甚至处罚。建立权威舆情网站，就是要反对文化垃圾，保证国家网络文化的安全，反对“网络恶搞”“网络暴力”等不良网络行为，提倡和谐网络文化，宣传网络文明，维护中华民族传统美德的承传。三是坚持行业自律、道德自律，坚持以人为本，大力宣扬社会主义先进文化，大力宣传互联网络荣辱观，从自我做起，文明上网，绿色上网。

3．网络舆情监控技术

“网络舆情监测系统”是针对在一定的社会空间内，围绕中介性社会事件的发生、发展和变化，民众对社会管理者产生和持有的社会政治态度于网络上表达出来意愿集合而进行的计算机监测的系统统称。

网络舆情监控系统能够利用搜索引擎技术和网络信息挖掘技术，通过网页内容的自动采集处理、敏感词过滤、智能聚类分类、主题检测、专题聚焦、统计分析，实现各单位对自己相关网络舆情监督管理的需要，最终形成舆情简报、舆情专报、分析报告、移动快报，为决策层全面掌握舆情动态，做出正确舆论引导，提供分析依据。

网络舆情监控系统架构一般包括 3 个层面。

（1）采集层：该层包含了要素采集、关键词抽取、全文索引、自动去重和区分存储及数据库，可以对微博、论坛、博客、贴吧、新闻及评论、搜索引擎、图像和视频等数据信息进行采集。

（2）分析层：该层可以对采集的数据信息实行自动分类、自动聚类、自动摘要、名称识别、正负性质预判和中文分词操作，保证分析的全面性。

（3）呈现层：系统对采集分析的数据可以通过负面舆情、分类舆情、最新舆情、专题跟踪、舆情简报、分类评价、图表统计和短信通知等形式推送给用户。

舆情监控系统对热点问题和重点领域比较集中的网站信息，如网页、论坛、BBS 等，进行 24 小时监控，随时下载最新的消息和意见。下载后完成对数据格式的转换及元数据的标引，对下载本地的信息，进行初步的过滤和预处理。对热点问题和重要领域实施监控，前提是必须通过人际关系的交互建立舆情监控的知识库来指导智能分析的过程。对热点问题的智能分析，首先在传统基于向量空间的特征分析技术上，对抓取的内容做分类、聚类和摘要分析，对信息完成初步的再组织。然后在监控知识库的指导下进行基于舆情的语义

分析，使管理者看到的民情民意更有效，更符合现实。最后将监控的结果，分别推送到不同的职能部门，供制定对策使用。

5.4 知识子域：社会工程学与培训教育

5.4.1 社会工程学

1. 社会工程学概念

社会工程学是一种特殊的攻击方式，与其他利用系统漏洞等网络攻击和入侵不同，社会工程学充分利用了人性中的“弱点”，包括本能反应、好奇心、信任、贪婪等，通过伪装、欺骗、恐吓、威逼等种种方式以达到目的。信息系统的管理者和使用者都是人，无论信息系统部署了多少安全产品，采取了多少有效的安全技术，如果系统的管理者或者使用者被利用，这些防护技术和措施都将成为摆设。人的因素才是系统的软肋，可以毫不夸张地说，人是信息系统安全防护体系中最不稳定也是最脆弱的环节。社会工程学攻击是一种复杂的攻击，不能等同于一般的欺骗方法，很多即使是自认为非常警惕及小心的人，一样会被高明的社会工程学攻击所攻破。在网络安全领域中，社会工程学很早就被应用在各种网络攻击方式中（例如在进行口令破解时，针对用户的习惯去设置密码字典，能极大地提高破解的效率），而随着网络攻击技术的不断发展，社会工程学逐渐成为一种主要的攻击方式，使用社会工程学为主的攻击方式突破系统安全防护体系的事件在最近数年呈现上升甚至泛滥的趋势。

信息安全从业者和组织机构的信息化管理人员需要建立一个概念，尽管我们非常重视信息安全，投入大量的资金并选择先进的技术来保护我们的信息系统和数据，但是社会工程学工程师仍然可能通过人性的“弱点”利用内部人员绕过所有技术的保护达到非法的目的。凯文·米特尼克在他所著的关于社会工程学书籍《欺骗的艺术》中这样形容社会工程师：**一个无所顾忌的魔术师，用他的左手吸引你的注意，右手窃取你的秘密。他通常十分友善，很会说话，并会让人感到遇上他是件荣幸的事情。**

社会工程学攻击是建立在人性“弱点”利用基础上的攻击，大部分的社会工程学攻击都是经过精心策划才能实施成功的。即使是最简单的“直接攻击”也需要进行前期的准备。如果希望受害者接受攻击者所伪装的身份，攻击者就必须具备这个身份所需要的一些特征。攻击者在实施攻击之前，需要尽量收集伪装身份所需要的信息，这些信息是攻击者伪装成功的基础。例如攻击者要伪装成某个大型集团公司总部的系统管理员，那么他需要了解这个大型集团公司所处行业的一些行规或者内部约定、公司规章制度、组织架构等信息，甚至包括集团公司中相关人员的绰号等，想象一下，如果攻击者伪装成集团公司的网络管理人员，在跟某个用户沟通交流时，不仅能准确地使用行业术语，还能随口说出公司内部所熟知的人员的绰号，想让受害者相信你是公司内部人员几乎是非常容易的。

2．社会工程学利用的人性“弱点”

社会工程学是网络安全与心理学结合的学科，准确来说，它不是一门科学，因为它不能总是重复和成功，并且在信息充分多的情况下它会失效。基于系统、体系、协议等技术体系缺陷的攻击方式，随着时间流逝最终都会失效，因为系统的漏洞可以弥补，体系的缺陷可能随着技术的发展完善或替代而消失。社会工程学利用的是人性的“弱点”，而人性是永恒存在的，这使得它几乎可以说是永远有效的攻击方式。

社会工程学本质上是一种心理操纵，攻击者通过种种方式来引导受攻击者的思维向攻击者期望的方向发展。克里斯托弗·海德纳吉有《社会工程-安全体系中的人性漏洞》，罗伯特·B·西奥迪尼（Robert B Cialdini）在科学美国人（2001 年 2 月）杂志中总结对心理操纵的研究，介绍了 6 种“人类天性基本倾向”，这些基本倾向都是社会工程学工程师在攻击中所依赖的（有意识或者无意识的）。

（1）权威

基于对权威的信任，当一个请求或命令来自一个“权威”人士时，这个请求就可能被毫不怀疑地执行。在电信诈骗中，攻击者伪装成“公安部门”人员，要求受害者转账到所谓“安全账户”就是利用了受害者对权威的信任。在网络攻击中，攻击者可能伪装成监管部门、信息系统管理人员等身份，去要求受害者执行操作，例如伪装成系统管理员，告诉用户请求配合进行一次系统测试，要求更改密码等。

（2）爱好

当两个人被发现存在共同点时，相互之间的好感、信任度就会提升，这时一方对另一方提出的请求往往倾向于顺从。这些共同点包括共同的兴趣爱好、共同的生活经历（一个城市、地区、一个学校）、共同的信仰等。攻击者通过信息收集渠道获得了受害者的资料，了解其兴趣和爱好，然后声称具有相同的兴趣和爱好，双方交流非常融洽，使得攻击者放松警惕，从而满足攻击者的要求。例如攻击者在了解了目标喜欢玩某款游戏后，也声称自己是这款游戏的爱好者，如果双方交流愉快，然后给对方发一个伪装的游戏视频或资源（实际上是一个携带木马的视频或网页），受害者打开这个伪装的资源的可能性就非常大了。

（3）报答

当人们被赠予（或者许诺）获得一些有价值的东西，出于报答的目的，会倾向于满足提供者要求的一些回报。因为绝大部分人都是善良的，对于获得好处都有或多或少的负疚感，因此倾向于给予报答以平衡心态，因此攻击者在希望受害者顺从自己要求的有效方法就是先给予受害者一定的好处（通常是虚假的或难以兑现的），以形成受害者的负疚感。电信诈骗中声称受害者中奖，然后要求受害者支付一定的税金等费用就是利用这样的心理。

（4）守信

出于对自身信用的保护等原因，人们对自己公开承诺或者认可的事情，会倾向坚持或维护，因此当攻击者以此来提出一些要求时，受害者出于避免违反自己的承诺或者众所周知的事情时，会倾向于顺从。例如攻击者打电话给系统管理员，在咨询一些系统使用问题后，声称自己系统密码忘记，要求系统管理员按自己要求密码类型帮忙进行重置，系统管

理员出于遵守更好服务用户的工作目标，可能会按照攻击者的要求重置用户账号。

（5）社会认可

人是社会性动物，因此人有趋众的特性，当绝大部分人都是按某种方式来做的时候，人们就会认为这些行为是正确的。攻击者通过引导受害者让受害者认为所做的事是大家都这么做过的，被攻击者就倾向于顺应攻击者的要求。例如攻击者在要求用户提供敏感信息前，说这是一次安全调查，之前某部门、某用户等都已经参与过这样的调查，引导受害者相信提供敏感数据是正确的，从而达到获得信息的目的。

（6）短缺

人性中对获取稀缺物品的渴望也是社会工程学经常利用的天性，当攻击者声称说提供的资源有限，仅有少部分用户能获取，如果想获取这样的资源，必须执行某种操作，受害者倾向于顺从以获取稀缺的资源。例如攻击者发送邮件给受害者，前 500 名在网站上进行某银行信用卡绑定和验证的账户，用户可以以极低的价格购买最新的 iPhone，从而诱骗用户注册并提供信用卡信息。

3. 社会工程学攻击防御

社会工程学攻击是一种非常危险的攻击，除了常规的建设完善的信息安全防护技术体系、实施良好的信息安全管理制度等措施外，还应该从以下几个方面考虑。

（1）注重信息保护

信息收集是社会工程学攻击实施的基础，因此攻击者在实施前会对目标进行信息收集，了解目标所有相关的资料和信息。这些资料和信息对很多组织机构来说都是公开或者看似无用的，然而对攻击者来说，这些信息都是非常有价值的，这些信息收集得越多，离他们成功的实现身份伪装就越近。如果认为信息没有价值或者价值非常低，组织机构通常不会采取措施进行保护，这正是社会工程学攻击者所希望的。任何信息都是有价值的，组织机构应充分了解信息的价值并在工作中应用这样的理念。在组织机构日常的工作中，对信息的发布和公开应遵循“不是必须公开的信息都是敏感信息”原则，尽量避免信息泄露，这对防御社会工程学攻击能起到良好的作用。另外，对于使用过的资料和数据，应及时进行销毁，例如打印机打印错误的纸张、快递单、取款凭证等。

（2）学习并了解社会工程学攻击

了解社会工程学攻击是应对和防御社会工程学攻击的关键，对于信息系统的管理人员和用户，都应该了解社会工程学攻击的概念和攻击的原理。组织机构可采取对相关人员实施社会工程学培训来帮助员工了解什么是社会工程学攻击，如何判断是否存在社会工程学攻击，这样才能更好地保护信息系统和个人数据。因为如果对攻击方式有所了解，那么就越容易识破攻击者的伪装。因此组织机构应持续不断地向员工提供安全意识的培训和教育，向员工灌输安全意识，从而降低社会工程学攻击的风险。

（3）建立并遵循信息安全管理制度

建立并完善信息安全管理体系是有效应对社会工程学攻击的方法，通过安全管理制度

的建立，使得信息系统用户需要遵循规范来实现某些操作，从而在一定程度上降低社会工程学的影响。例如对于用户密码的修改，由于相应管理制度的要求，网络管理员需要对用户身份进行电话回拨确认才能执行，那么来自外部的攻击者就可能很难伪装成为内部工作人员来进行社会工程学攻击，因为他还需要想办法拥有一个组织机构内部电话才能实施。

5.4.2 培训及教育

近年来，随着我国经济社会信息化的深入发展，信息网络安全案件、事件时有发生，信息网络安全保障工作的重要性日益凸显。加强信息网络安全人才队伍建设，提高信息网络管理和企业安全管理、技术防范水平，是做好我国信息网络安全保障工作、推动经济社会发展的一项重要措施。

国外对网络攻击防范方面有很多研究，提出了很多防范措施及安全解决方案，它们在防范技术和防范手段上有着共性，其中包括对人进行教育培训。因为安全解决方案如果要成功实现，需要改变用户的行为方式。这些变化包括从改变常规的工作方式一直到遵守安全策略中规定的标准、指南和程序。行为的改变包括用户需要一定程度的学习。

另外，“人”是在整个网络安全体系中最薄弱的一个环节，按照木桶理论，网络安全的水平是由最低的木块决定的。我国从事专业安全的技术人员不多，很多小型企业的网管等都是半途出家，对安全方面的知识本身懂的不多，加之安全教育以及安全防范措施都需要成本，对于国内企业来讲，往往注重网络技术技能的培训，而轻于网络安全方面的培训，只有在接受严重的损失以后，才会意识到网络安全的重要性。

安全培训首先要做的是意识培训。安全意识关注于与安全有关的重要或基础的问题，如所有人员应充分认识到他们的安全责任和义务，知道什么该做，什么不该做。

用户还需要知道的问题包括防止欺骗和未经授权的活动。组织的全体成员，从资深的管理者到临时的实习人员，都需要同等程度的安全意识。组织的安全意识培养过程应该与其安全策略、事件处理计划和灾难恢复措施紧密相关联。构建安全意识的过程要做到有效，必须有创新并经常更新。意识的构建过程还应当涉及理解公司文化如何影响针对个人的安全性以及整个组织机构的安全性。如果员工没有看到安全策略和标准的实施，尤其是没有意识到这种情况，那么他们可能不会觉得遵守安全策略和标准是自己的义务。

许多工具都可以被用于培养安全意识，例如海报、通知、即时通讯、屏幕保护程序、领导讲话、告示、备忘录以及传统的培训课程。

培训是教导员工执行工作任务和遵守安全策略的活动，通常由组织执行。所有的新员工都需要进行某种程度的培训，从而使他们能够遵守安全策略中规定的所有标准、指导方针和步骤。新用户需要知道如何使用 IT 基础设施、数据存储的位置以及如何和为什么要对资源进行分类等。

培训也应该是持续进行的活动，每位员工在工作期间都必须持续接受培训。组织应根据自身的实际情况，建立一套适合组织的安全培训计划，并通过反馈，不断调整和完善。

安全教育对象不仅仅包含网络管理员，还应包含用户、管理者、工程实施人员、研发人员、运维人员等。

培训内容包含法规教育、安全技术教育（包含加密技术、防火墙技术、入侵检测技术、漏洞扫描技术、备份技术、计算机病毒防御技术和反垃圾邮件技术、风险防范措施和技术等）、安全意识教育（包含了解组织安全目标、安全规定与规则、安全相关法律法规等）和安全管理培训。

教育培训是一项更细致更深入的工作，需要学习比完成工作任务实际所需知识多得多的知识。教育培训最常与用户参加认证考试或寻求职务晋升关联。

第 6 章

知识域：信息安全评估

阅读提示 本知识域包括安全评估基础、安全评估实施及信息系统审计 3 个知识子域。学员通过学习能了解风险评估的相关概念，掌握风险评估实施流程及方法，并了解安全评估相关标准，同时也了解信息系统安全审计的方法。

6.1 知识子域：安全评估基础

6.1.1 安全评估概念

1. 安全评估基本概念

安全评估也称作安全风险评估（以下简称风险评估），是针对资产潜在影响正常执行其职能的行为产生干扰或者破坏的因素进行识别、评价的过程。可将其分为狭义和广义两种。狭义的风险评估指对一个具有特定功能的工作系统中固有的或潜在的威胁及其严重程度所进行的分析与评估，并以既定指数、等级或概率值做出定量的表示，最后根据定量值的大小确定优先级并决定采取预防或防护对策。广义的风险评估指利用系统工程原理和方法对拟建或已有的信息系统可能存在的威胁及其可能产生的后果进行综合评价和预测，并根据可能导致的损失的大小，提出相应的安全措施，以达到工程和系统安全的过程。

信息化技术日益快速的发展使得各种平台、应用相互关联，并且不断在变更，而组织机构对于信息安全投入有限，如何为系统采取必要措施保护组织的资产是组织机构不可避免要面对的问题。环境越复杂，就越需要这种措施和控制来保证组织业务的连续性。

风险评估是组织确定信息安全需求的一个重要途径，属于组织安全管理策划的过程。风险评估工作包括以下方面。

- 确定保护的对象（保护资产）是什么？它们的直接和间接价值是什么？
- 资产面临哪些威胁？威胁类型及存在原因？可能性有多大？
- 资产中存在哪些弱点（包含系统漏洞、管理疏忽等）可能会被威胁所利用？利用的难易程度如何？
- 一旦威胁事件发生，组织会遭受怎样的损失或者面临怎样的负面影响？

- 组织应该采取怎样的安全措施才能将风险带来的损失降到最低程度。

2. 安全评估的价值

（1）信息安全风险评估是信息安全建设的起点和基础

信息安全风险评估是科学分析信息和信息系统在保密性、完整性、可用性等方面所面临的风险，从而揭示一个组织机构的风险状况并提出改进风险状况的建议的工作。信息安全建设和管理，只有在正确、全面认识风险后，才能在规避风险、减少风险、转移风险、接受风险之间做出正确的判断，才能决定调动多少资源、以什么样的代价、采取什么样的应对措施去化解、减少风险；否则就只能盲目行事，要么不能保障安全，要么就是浪费资源、妨碍工作。因此，所有信息安全建设和管理都应该是基于信息安全风险评估的结果。只有这样，信息安全建设才能做到从实际出发，才能坚持需求主导、突出重点，才能以最小的代价实现最大程度地保障信息安全。

（2）信息安全风险评估是信息安全建设和管理的科学方法

信息系统的安全性取决于系统的资产、脆弱性、威胁、已有措施等多种安全要素，取决于这些要素之间的关系以及与系统环境的关系。而资产又包括设备、软件、数据以及人员等，脆弱性包括系统自身在结构上、管理上、技术上的弱点和不足，威胁可分为自然威胁与人为威胁、内部威胁与外部威胁等，包括病毒传播、黑客攻击、网络窃密等。要对这么多要素进行认识，对它们间的相互关系进行分析，没有一个科学的方法是难以做到的。风险评估提供了这样一种科学的方法，它是将系统的风险理论应用于某一组织的具体生产运营环境，是一种理论与实践相结合的工作方法，使组织的管理层和决策层得以了解组织信息安全客观现状的全貌，然后基于对现状的了解，才能做出后续信息安全相关建设的正确决策。

（3）风险评估实际上是在倡导一种适度安全

从理论上讲，不存在绝对的安全，风险总是客观存在的。风险评估并不追求零风险、不计成本的绝对安全，或者试图完全消灭风险或避免风险。信息安全风险评估要求在认清风险的基础上，决定哪些风险是必须要避免的，哪些风险是可以容忍的。也就是说，信息安全风险评估要求组织的管理者在风险与建设和成本之间寻求一个最佳平衡点。这体现了信息安全的一个基本原则，就是坚持从实际出发，坚持有针对性地进行信息安全建设和管理。这也就是适度安全。

（4）保护网络空间安全的核心要素和重要手段

作为风险评估先驱者的美国等信息化发达国家越来越重视信息系统风险评估工作。2006 年 6 月，美国国土安全部正式发布了《国土基础设施保护计划（NIPP）》，NIPP 是美国国土安全框架的一个关键要素，它是建立于一系列不断发展的国家策略（包括 2002 年 7 月发布的《国土安全战略》、2003 年 2 月发布的《关键基础设施和重要资产物理保护的国家战略》、2003 年 2 月发布的《安全保护计算机空间国家战略》、2003 年 12 月发布的第 7 号国土安全总统令）之上，使用风险管理框架为人和关键基础设施建立一个环境更安

全的国家战略。从 NIPP 和这一系列美国国家战略中可以看到，以风险管理框架为基础、大力开展风险评估工作已经成为美国等西方发达国家保障关键基础设施和重要资源，从而保护国土安全的一个核心要素和重要手段。发达国家的这些经验值得学习和借鉴。

3．安全评估工具

安全评估工具是安全评估的辅助手段，是保证风险评估结果可信度的一个重要因素。安全评估工具的使用不但在一定程度上解决了手工评估的局限性，最主要的是它能够将专家知识进行集中，使专家的经验知识被广泛地应用。根据在风险评估过程中的主要任务和作用原理的不同，风险评估的工具可以分成风险评估与管理工具、系统基础平台风险评估工具、风险评估辅助工具 3 类。

（1）风险评估与管理工具

风险评估与管理工具是一套集成了风险评估各类知识和判据的管理信息系统，以规范风险的过程和操作方法；或者是用于收集评估所需要的数据和资料，基于专家经验对输入输出进行模型分析。

根据实现方法的不同，风险评估与管理工具可以分为 3 类：基于信息安全标准的风险评估与管理工具、基于知识的风险评估与管理工具和基于模型的风险评估与管理工具。

（2）系统基础平台风险评估工具

系统基础平台风险评估工具主要用于对信息系统的主要部件（如操作系统、数据库系统、网络设备等）的脆弱性（弱点）进行分析，或实施基于脆弱性的攻击。此类工具包括脆弱性扫描工具和渗透性测试工具。

常见的脆弱性扫描工具有以下几种类型：基于网络的扫描器、基于主机的扫描器、分布式网络扫描器和数据库脆弱性扫描器。渗透性测试工具是根据脆弱性扫描工具扫描的结果进行模拟攻击测试，判断被非法访问者利用的可能性。这类工具通常包括黑客工具、脚本文件等。

（3）风险评估辅助工具

风险评估辅助工具则实现对数据的采集、现状分析和趋势分析等单项功能，为风险评估各要素的赋值、定级提供依据。

常见的这类工具包括检查列表、入侵检测系统、安全审计工具、拓扑发现工具和资产信息收集系统等。

6.1.2 安全评估标准

1．安全评估标准的发展

早在 20 世纪 50 年代以美国为首的西方发达国家和苏联及其盟国即着手开发用于政府和军队的安全的信息技术产品。随着信息技术产品的不断研发，相关安全评估标准的制定也相应地开展起来并不断改进。

1985 年，美国国防部率先推出了《可信计算机系统评估准则》（TCSEC），该标准事实上成了美国国家信息安全评估标准，对世界各国也产生了广泛影响。在 1990 年前后，英国、德国、加拿大等国也先后制定了立足于本国情况的信息安全评估标准，如加拿大的《可信计算机产品评估准则》（CTCPEC）等。在欧洲影响下，美国 1991 年制定了一个《联邦（最低安全要求）评估准则》（FC），但由于其不完备性，未能推行。

由于信息安全评估技术的复杂性和信息技术产品国际市场的逐渐形成，单靠一个国家自行制定并实行自己的评估标准已不能满足国际交流的要求，于是多国共同制定统一的信息安全评估标准被提了出来。

1991 年，欧洲的英国、法国、德国、荷兰四国国防部门信息安全机构率先联合制定了《信息技术安全评估准则》（ITSEC），并在事实上成为欧盟各国使用的共同评估标准。这为多国共同制定信息安全标准开了先河。为了紧紧把握信息安全技术与市场的主导权，美国在欧洲四国出台 ITSEC 之后，立即倡议欧美六国七方（即英国、法国、德国、荷兰、加拿大五国国防信息安全机构，加上美国国防部国家安全局（NSA）和美国商务部国家标准与技术局（NIST））共同制定一个供欧美各国通用的信息安全评估标准。1993—1996 年，经过四、五年的研究开发，产生了《信息技术安全通用评估准则》，简称 CC 标准。

信息安全技术评估标准发展如图 6-1 所示。

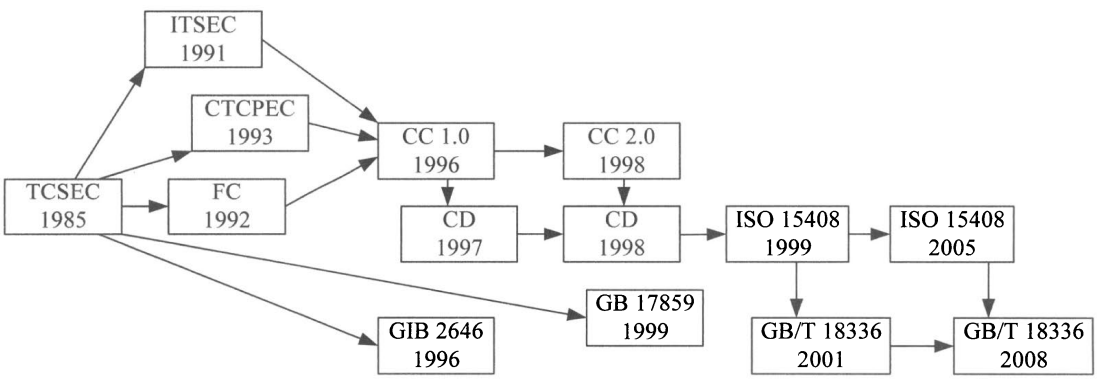

图 6-1　技术评估标准发展

2．可信计算机系统评估标准（TCSEC）

可信计算机系统评估标准（Trusted Computer System Evaluation Criteria，TCSEC）是美国政府国防部（Department of Defense，DoD）标准，为评估计算机系统内置的计算机安全功能的有效性设定了基本要求。TCSEC 用于评估、分类和选择用于处理、存储和检索敏感信息的计算机系统。作为国防部彩虹系列出版物的核心，TCSEC 经常被称为橙皮书。最初由国家安全局的国家计算机安全中心（National Computer Security Center，NCSC）于 1983 年发布，1985 年更新。TCSEC 已被 2005 年最初公布的国际标准《通用准则（CC）》所取代。

（1）基本目标和要求

TESEC 基本目标和要求包括策略、问责、保证和文档。

① **策略：**安全策略必须由计算机系统显式、明确地定义和执行。有 3 种基本的安全

策略。

- **强制性安全政策**：强制执行访问控制规则，直接根据个体的信息授权以及正在寻求的信息的机密级别。其他间接因素是物理和环境。这项政策还必须准确地遵循法律、一般政策和其他有关规则的指导。
- **标记**：旨在强制执行强制性安全策略的系统必须存储和保留访问控制标签的完整性，并在导出对象时保留标签。
- **自由安全策略**：根据确定需要知道信息的已识别个人，实施一套一致的控制和限制访问的规则。

② **问责**：不论策略如何执行个人问责。

必须存在一种安全手段，以确保获得对授权的准许代理机构的访问，在合理的时间内，不受任何约束对问责制信息进行评估。责任追究目标有 3 项要求。

- 识别：用于识别用户的过程。
- 验证：验证用户对特定类别信息的授权。
- 审核：审核信息必须有选择性地保护，以便对影响安全性的操作可追溯到相关人员。

③ **保证**：计算机系统必须包含可以被独立评估的硬件/软件机制，以提供系统实施上述要求的充分保证。

通过扩展，保证必须包括确保系统的受信任部分仅按预期工作，为了实现这些目标，需要有 3 种类型的保证，其各自的要素如下。

- 操作保证：系统架构，系统完整性，隐蔽通道分析，可信设备管理和可信恢复。
- 生命周期保证：安全测试，设计规范和验证，配置管理和可信系统分发。
- 持续保护：必须持续保护执行这些基本要求的信任机制，防止篡改和/或未经授权的更改。

④ **文档**：在每个类中，还有一些额外的文档集，用于处理系统的开发、部署和管理。文档包括安全功能用户指南、可信设施手册、测试文档和设计文档。

（2）分级

TCSEC 通过分级的方式建立评价指标，其定义了 4 个级别：D（最小保护）、C（选择保护）、B（强制保护）和 A（验证保护），其中 A 级具有最高的安全性。 每个级别代表个人或组织可以对评估系统进行信任的重大差异。在 C、B 和 A 级别中又建立了一系列细分，称为类别 C1、C2、B1、B2、B3 和 A1。

① D：最小保护。保留给那些已经被评估但不能满足更高要求的系统。

② C：选择保护。

③ C1：自主安全保护。

- 鉴别和认证。
- 分离用户和数据。
- 能够独立执行访问限制的自由访问控制（DAC）。

- 所需的系统文档和用户手册。

④ C2：受控访问保护。

- 更细粒度的 DAC。
- 通过登录程序的问责。
- 审计跟踪。
- 对象重用。
- 资源隔离。

⑤ B：强制保护。

⑥ B1：标签安全防护。

- 安全政策模型的非正式声明。
- 数据敏感度标签。
- 针对主体和客体的强制访问控制（MAC）。
- 标签导出功能。
- 一些发现的缺陷必须被删除或以其他方式缓解。
- 设计规格和验证。

⑦ B2：结构化保护。

- 安全政策模式明确界定并正式记录。
- DAC 和 MAC 执行扩展到所有主题和对象。
- 分析隐藏存储信道的发生和带宽。
- 结构化成关键保护和非保护关键因素。
- 设计和实施能够进行更全面的测试和审查。
- 验证机制得到加强。
- 受信任的设施管理提供管理员和操作员隔离。
- 严格的配置管理控制。
- 操作员和管理员角色分开。

⑧ B3：安全域。

- 满足参考监视器的要求。
- 结构化排除不是安全策略执行所必需的代码。
- 重要的系统工程旨在尽量减少复杂性。
- 安全管理员角色定义。
- 审计安全相关事件。
- 在发生安全相关事件时自动通知和响应。
- 可信系统恢复程序。
- 分析隐蔽定时信道的发生和带宽。

⑨ A：验证保护。

⑩ A1：验证设计。

- 功能上与 B3 相同。
- 正式的设计和验证技术，包括正式的顶级规范。
- 正式管理和分配程序。

⑪ 超越 A1。

系统架构证明，可信计算基础（TCB）中已经实现了参考监视器的自我保护和完整性要求。

安全测试从正式的顶级规范或正式的较低级别规范自动生成测试用例。

正式规范和验证是 TCB 被验证到源代码级别的地方，在可行的情况下使用形式验证方法。

可信赖的设计环境是 TCB 在受信任的设施中设计的，只有信任（已清除的）人员。

3. 信息技术安全评估标准（ITSEC）

信息技术安全评估标准（Information Technology Security Evaluation Criteria，ITSEC）是评估产品和系统中计算机安全性的一套结构化的标准。ITSEC 于 1990 年 5 月首先在法国、德国、荷兰和英国出版，基于其各自国家的现有情况。经过广泛的国际审查，1.2 版随后于 1991 年 6 月由欧洲共同体委员会在评估和认证计划中运作使用。自 1990 年 ITSEC 发布以来，其他一些欧洲国家同意认可 ITSEC 评估的有效性。

ITSEC 以超越 TCSEC 为目的，将安全概念分为功能与功能评估两部分。ITSEC 提出评估对象（TOE）的概念，评估对象分产品和系统两大类。

功能准则在测定上分 F1～F10 共 10 类。1～5 类对应于 TCSEC 的 D 到 A。6～10 类增加了以下概念。

- F6：数据和程序的完整性。
- F7：系统可用性。
- F8：数据通信完整性。
- F9：数据通信保密性。
- F10：包括机密性和完整性的网络安全。

评估准则分为 6 级：E1～E6。

- E1：测试。
- E2：配置控制和可控的分配。
- E3：能访问详细设计和源码。
- E4：详细的脆弱性分析。
- E5：设计与源码明显对应。
- E6：设计与源码在形式上一致。

4. 信息技术安全评估通用标准（CC）

信息技术安全评估通用标准（Common Criteria for Information Technology Security Evaluation）简称通用标准或 CC，是计算机安全认证的国际标准（ISO/IEC 15408）。为了

适应经济全球化的形势要求，在 CC 标准制定出不久，六国七方即推动国际标准化组织（ISO）将 CC 标准纳入国际标准体系。经过多年协商和磋切，国际标准化组织于 1999 年批准 CC 标准以“ISO/IEC 15408-1999”编号正式列入国际标准系列，标准名称为 Information technology - Security techniques - Evaluation criteria for IT security。2005 年，ISO 对 CC 进行了改版，发布了 ISO/IEC 15408：2005。其后又不断修订，最新版本为 ISO 15408-1：2009、ISO 15408-2：2008 和 ISO 15408-3：2008。

CC 的主要思想和框架取自 ITSEC 和 FC，并充分突出了“保护轮廓”这一概念，将评估过程分“功能”和“保证”两部分。CC 基于风险管理理论，对安全模型、安全概念和安全功能进行了全面系统地描绘，强化了评估保证，是目前最全面的评价准则。CC 是对已有安全准则的总结和兼容，有通用的表达方式，便于理解；有灵活的架构，用户可以定义自己的要求以扩展 CC 的要求。CC 有自己配套的评估方法即通用测试方法（CEM）。CC 的意义在于：通过评估有助于增强用户对于 IT 产品的安全信心、促进 IT 产品和系统的安全性、消除重复的评估。

在使用中，CC 标准也存在一定的局限性。

- CC 标准采用半形式化语言，比较难以理解。
- CC 不包括那些与 IT 安全措施没有直接关联的、属于行政性管理安全措施的评估准则，即该标准并不关注于组织、人员、环境、设备、网络等方面的具体的安全措施。
- CC 重点关注人为的威胁，对于其他威胁源并没有考虑。
- CC 并不针对 IT 安全性的物理方面的评估（如电磁干扰）。
- CC 并不涉及评估方法学。
- CC 不包括密码算法固有质量的评估。

5．信息技术安全性评估准则（CC）

《信息技术安全性评估准则》是我国在 2008 年等同采用《ISO/IEC 15408：2005 信息技术-安全技术-信息技术安全评估标准》形成的国家标准，标准编号为 GB/T 18336。标准定义了作为评估信息技术产品和系统安全特性的基础准则，由于历史和连续性的原因，仍叫通用准则（Common Criteria，CC）。通过建立这样的通用准则库，使信息技术安全评估的结果能被更多人理解。针对在安全性评估过程中信息技术产品和系统的安全功能及相应的保证措施，CC 提供了一组通用要求，使各种独立的安全评估结果具有可比性。评估过程为满足这些要求的产品和系统的安全功能以及相应的保证措施确定一个可信级别。评估结果可以帮助用户确定信息技术产品和系统对他们的应用而言是否足够安全，以及在使用中隐藏的安全风险是否可以容忍。

（1）通用准则的结构

《信息技术安全性评估准则》由一系列不同但又相互关联的部分组成，总共分为 3 部分，如表 6-1 所示。

表 6-1　通用准则结构表

对应标准号	名　　称	简　　述
GB/T 18336.1—2008	简介和一般模型	定义了 IT 安全性评估的一般概念和原理，并提出了评估的一般模型。此部分也提出了若干结构，这些结构可用于表达信息安全目标，用于选择和定义 IT 安全要求，以及用于书写产品和系统的高层规范。另外，针对各种目标，描述标准的每一部分的有效性
GB/T 18336.2—2008	安全功能要求	规定了一系列功能组件，作为表达 TOE 功能要求的标准方法。此部分列出了一系列功能组件、族和类
GB/T 18336.3—2008	安全保证要求	规定了一系列保证组件，作为表达 TOE 保证要求的标准方法。此部分列出了一系列保证组件、族和类。此部分也定义了 PP 和 ST 的评估准则，并提出了一些评估保证级别，这些级别定义了划分 TOE 保证等级的预定义的评估尺度，通常称为评估保证级（EAL）

（2）目标读者

有 3 类最关心 IT 产品和系统安全性评估的人员，分别是 TOE 客户、TOE 开发者和 TOE 评估者（见表 6-2）。此标准在文本组织上已充分考虑了这 3 类人员的需求，认为他们都是 CC 的主要用户，这 3 类人员都能从标准中受益。

表 6-2　通用准则使用指南

	用　　户	开　发　者	评　估　者
第一部分	用于了解背景信息和参考。PP 的指导性结构	用于了解背景信息，开发安全要求和形成 TOE 的安全规范的参考	用于了解背景信息和参考。PP 和 ST 的指导性结构
第二部分	在阐明安全功能要求的描述时用作指导和参考	用于解释功能要求和生成 TOE 功能规范的参考	当确定 TOE 是否有效地符合已声明的安全功能时，用作评估准则的强制性描述
第三部分	用于指导保证需求级别的确定	当解释保证要求描述和确定 TOE 的保证措施时，用作参考	当确定 TOE 的保证和评估 PP 和 ST 时，用作评估准则的强制描述

虽然 CC 主要是为了规范和评估 TOE 的 IT 安全特性，但它也可以供对 IT 安全有兴趣或有责任的所有各方参考。其他能够从 CC 所包含的信息中获益的群体有系统管理员和系统安全管理员、内部和外部审计员、安全架构师和设计师、审批者、评估发起者、评估管理机构。

（3）关键概念

① 评估对象（TOE）

评估对象（Target of Evaluation，TOE）是作为评估主体的 IT 产品或系统以及相关的指导性文档。如各种产品、系统、子系统及相关文件。

② 保护轮廓（PP）

保护轮廓（Protection Profile，PP）是满足特定用户需求的、一类 TOE 的、一组与实现无关的安全要求。

保护轮廓（PP）包含一套或来自 GB/T 18336 或明确阐述的安全要求，它应包括一个评估保证级（EAL）（可能通过添加额外的保证组件来增强）。PP 可以对一组 TOE 的安全要求做与实现无关的描述，这些要求是同安全目的一致。PP 可反复使用，可用来定义那些公认有用的且有效的满足既定安全目的的 TOE 功能和保证要求。PP 还包括安全目的和安全要求的基本原理。PP 可以由用户团体、IT 产品开发者或其他对定义这样一系列通用要求有兴趣的相关方负责开发。PP 为客户提供了一套方法以提出一组特定的安全需求，并且有助于将来依据这些需求进行评估。

③ 安全目标（ST）

安全目标（Security Target，ST）是作为一个既定 TOE 的评估基础使用的一组安全要求和规范。

安全目标（ST）包含一组安全要求，这些要求可以引用自 PP，可以直接引用 GB/T 18336 的功能或保证组件，也可以是明确阐述的。ST 可以对一个特定 TOE 的安全要求进行描述，通过评估，可以证明这些要求是有用的且有效地满足了既定安全目的。ST 包含 TOE 的概要规范，同时还包含安全要求和安全目的，以及它们的基本原理。ST 是所有的相关各方对 TOE 提供什么样的安全性达成一致的基础。

④ 功能

功能（Function）是规范 IT 产品和系统的安全行为，应做的事。CC 是以类、族、组件作为组织结构，来描述功能要求内容和保证要求内容的。

类（Class）是具有共同目的的族的集合。术语“类”用于安全要求的最高层次。一个类中所有成员关注同一个安全焦点，但覆盖的安全目的范围不同，类的成员被称为族。

族（Family）是一组具有共同安全目的、但侧重点或严格程度可能不同的组件的集合，也称子类。族是若干组安全要求的组合，这些要求共享同样的安全目的，但在侧重点和严格性上有所区别，族的成员被称为组件。

组件（Component）是包含在 PP、ST 或一个包中的最小可选元素集。一个组件描述一组特定的安全要求，它是 GB/T 18336 结构中安全要求的最小可选集合。一个族中的组件集合，可以按安全要求强度或能力递增的顺序进行描述，这些安全要求具有相同用途；在部分族也可以不区分层次的方式来描述。在某种情况下，一个族只有一个组件，因而不需要排序。

组件由多个元素组成。元素是安全要求的最低层次表达，并且是能被评估验证的不可再分的安全要求。

⑤ 保证

保证（Assurance）是实体达到其安全性目的的信任基础。保证是对功能产生信心的方法。

⑥ 包

包（Package）是为满足一组确定的安全目的而组合在一起的，一组可重用的功能或保证组件。组件的一个中间组合称作包。包可以描述一组功能或保证要求，这些要求满足部分指定的安全目的。包可重复使用，可用来定义那些公认有用的且有效的满足既定安全目的的要求。一个包可用于构造更大的包、PP 和 ST。

⑦ 评估保证级（EAL）

评估保证级（Evaluation Assurance Level，EAL）是由 GB/T 18336.3 中保证组件构成的包，该包代表了 GB/T 18336 预先定义的保证尺度上的某个位置。

评估保证级（EAL）就是 GB/T 18336.3 中预先定义的一些保证包。一个 EAL 是评估保证要求的一个基线集合。每个 EAL 定义了一套相容的保证要求。合起来，这些 EAL 构成一个有次序的集合，是 GB/T 18336 预定义的保证度量尺度，如表 6-3 所示。

表 6-3　评估保证级（EAL）列表

EAL1	功能测试（functionally tested）
EAL2	结构测试（structurally tested）
EAL3	系统地测试和检查（methodically tested and checked）
EAL4	系统地设计、测试和复查（methodically designed，tested，and reviewed）
EAL5	半形式化设计和测试（semiformally designed and tested）
EAL6	半形式化验证的设计和测试（semiformally verified design and tested
EAL7	形式化验证的设计和测试（formally verified design and tested）

（4）使用 CC 进行评估的基本过程

① 评估相关要素

为了使评估结果具有更好的可比性，评估宜在一个权威的评估体制框架内执行，该体制框架负责设定标准、监控评估质量、掌管评估机构和评估者必须遵守的规章制度。

CC 不对监管框架提出要求。但是，要达到评估结果相互认可的目标，不同评估管理机构的监管框架必须是一致的。图 6-2 描述了构成评估相关要素的主要因素。

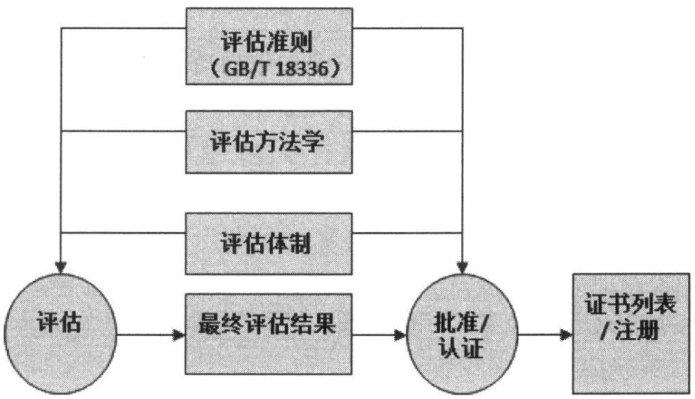

图 6-2　评估相关要素的主要因素

使用通用的评估方法学主要是确保评估结果的可重复性和客观性，但仅靠方法学本身不够充分。许多评估准则需要使用专家判断和一定的背景知识，而这些更难达到一致。为了提高评估意见的一致性，最终的评估结果应提交给一个认证过程。该认证过程是对评估结果的独立审查，并产生最终的证书或正式批文。该证书通常是公开的。认证过程是使得 IT 安全准则应用得到更好一致性的一种手段。

评估体制、评估方法学和认证过程由运行评估体制的评估管理机构负责，不属于 CC 的范围。

② 评估流程

评估分 PP 评估、ST 评估和 TOE 评估。

PP 评估是依照 GB/T 18336.3 中的 PP 评估准则进行的。此类评估的目的是为了证明该 PP 是完备的、一致的、技术合理的且适合用来作为一个可评估 TOE 的要求陈述。PP 的评估结果为“通过”或“不通过”。评估结果为“通过”的 PP 应当列入 PP 注册表中。

针对 TOE 的 ST 评估是依照 GB/T 18336.3 中的 ST 评估准则进行的。此类评估具有双重目的：首先是为了证明该 ST 是完备的、一致的、技术合理的，因而适合用来作为相应 TOE 评估的基础；其次，当某个 ST 宣称与一个 PP 一致时，证明该 ST 完全满足该 PP 的要求。ST 评估将产生在 TOE 评估框架中使用的中间结果。

TOE 评估是以一个充分完善的 ST 作为基础，依照 GB/T 18336.3 中的评估准则进行的。一个充分完善的 ST 是指所有的子条款都已被完善到评估方案接受的程度，且预知没有重大的评估障碍，该 ST 可降低在随后的评估过程中可能存在的风险。评估一个 TOE 的结果是证明该 TOE 满足包含在已评估的 ST 中的安全要求。TOE 的评估结果为“通过”或“不通过”。评估结果为“通过”的 TOE 应当列入一个注册表中。

评估流程如图 6-3 所示。

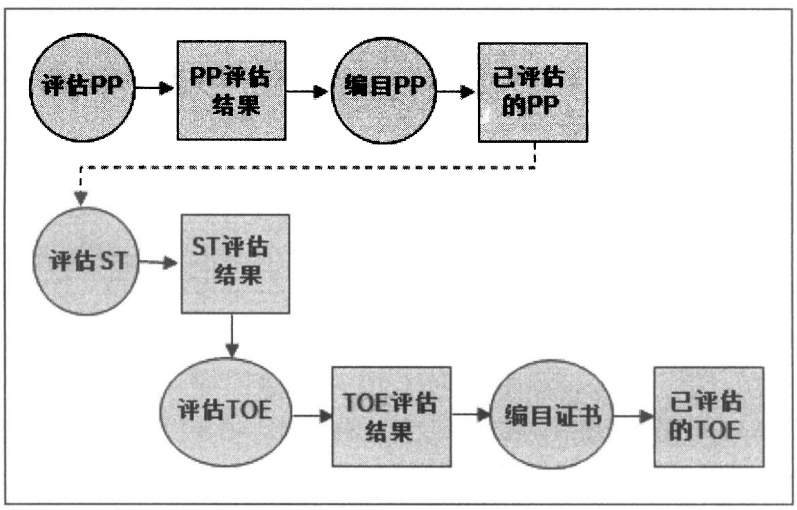

图 6-3　评估流程

（5）通用评估方法（CEM）

CEM 是 CC 标准出版后，为了在评估中应用 CC 而提供的一种通用方法。是与 CC 配套的文档。

CEM 分为两部分，第一部分主要包括 CEM 简介、CC 评估中的通用原则和假设以及评估的一般模型；第二部分主要讲述评估的一般任务、PP 评估、ST 评估以及 EAL1-EAL4 级的评估。CEM 没有提供 EAL4 级以上的评估方法。

CEM 的评估过程主要分为 3 个阶段：准备阶段、实施阶段和总结阶段。准备阶段主要是准备各种评估证据，包括人员的培训。发起者向评估者提供 PP 或 ST，评估者对其做可行性分析，并向发起者要求相关信息。发起者向评估者提供一系列评估证据。评估者复审 PP 或 ST 并建议发起者做出修改以便建立良好的评估基础。如果达到评估框架要求，则进入下一阶段。这一阶段产生的输出结果包括评估证据清单、评估活动和评估信息清单，所有参与者都必须对鉴定和保护专有信息负责，输出结果必须得到所有人的认同。执行阶段是评估的主要部分，评估者复审评估证据，并按照保证要求执行所规定的评估行为。这一过程中，评估者可以利用评估观察报告要求验证者澄清某个被要求的应用，而验证者应对之做出解释。评估者也可利用观察报告指出潜在的弱点或缺陷，并从发起者或开发者组要求更多信息。执行阶段的输出是评估技术报告（ETR）。结论阶段，评估者向验证者递交 ETR，不同的评估机制规定了对持有 ETR 的限制，可能包括递交给发起者或开发者，ETR 可能包括一些敏感或私有信息，在递交给发起者之前要进行处理。验证者复审并分析 ETR 以确保与 CC、CEM 及评估机制的要求一致，并对 ETR 中的最终评判做出同意或不同意的决定。验证者可以以 ETR 为主要参考准备一份评估总结报告（ESR）并递交给评估权威机构。发起者、评估者有权复核 ESR。

6．信息系统安全等级保护测评标准

信息系统安全等级测评是我国信息安全等级保护过程中必不可缺的环节，是验证信息系统是否满足相应安全保护等级的评估过程。信息安全等级保护要求不同安全等级的信息系统应具有不同的安全保护能力。

依据《信息安全等级保护管理办法》（公通字〔2007〕43 号），信息系统运营、使用单位在进行信息系统备案后，都应当选择测评机构进行等级测评。等级测评是测评机构依据《信息系统安全等级保护测评要求》（GB/T28448—2012）等管理规范和技术标准，检测评估信息系统安全等级保护状况是否达到相应等级基本要求的过程，是落实信息安全等级保护制度的重要环节。

等级测评由单元测评和整体测评两部分构成。单元测评是针对等级保护基本要求中各项控制点的测评。测评分为安全管理和安全技术两部分，根据信息系统定级中确定的安全等级，每一个具体测评实施项都与安全控制点的要求项相对应。整体测评是在单元测评的基础上，通过进一步分析信息系统安全保护功能的整体相关性，对信息系统实施的综合安全测评。整体测评主要包括控制点间、层面间和区域间相互作用的安全测评。

6.2　知识子域：安全评估实施

6.2.1　风险评估相关要素

1．资产

构成风险评估的资产是建立对组织具有价值的信息或资源，是安全策略保护的对象。

首先应该对资产进行分类，资产的分类是根据信息安全三元组保密性、完整性和可用性进行评价。风险评估中资产的价值不是以资产的经济价值来衡量，而是由资产在这 3 个安全属性上的达成程度或者其安全属性未达成时所造成的影响程度来决定的。安全属性达成程度的不同将使资产具有不同的价值，而资产面临的威胁、存在的脆弱性以及已采用的安全措施都将对资产安全属性的达成程度产生影响。为此，应对组织中的资产进行识别。

（1）资产类型

有形资产是具有实物形态的资产，包括固定资产和流动资产。如存货、对外投资、货币资产、应收账款等。有形资产有狭义的概念和广义的概念之分。总的来说，有形资产就是有一定实物形态的资产，以具体物质产品形态存在的资产，包括生产有形资产和非生产有形资产。这些资产根据资产的原始成本减去折旧进行估值，在部分组织中，出于财务的目的，有些有形资产可能折旧为零，信息安全专业人员需要了解原始成本以及相关项目的重置成本以更好地进行风险评估。此外，如果供应少于需求，原本折旧的资产可能会获得价值。某些资产也可能已经过时，可能需要新的资产来替代它们所提供的功能。确定有形资产价值的方法包括：

- 原价减去折旧。
- 通过市场调研实际市场价值。
- 参考在其他可实际购买资产的在线网站上标识的价值。
- 联系厂商，并获得更新的报价。
- 切换竞争资产所带来的成本和能力。

无形资产是指企业拥有或者控制的没有实物形态的可辨认非货币性资产。无形资产具有广义和狭义之分，广义的无形资产包括货币资金、应收账款、金融资产、长期股权投资、专利权、商标权等，因为它们没有物质实体，而是表现为某种法定权利或技术。但是，会计上通常将无形资产做狭义的理解，即将专利权、商标权等称为无形资产。

无形资产无具体形态。无形财产的例子包括但不限于：

- 商标。
- 专利。
- 版权。
- 业务流程。

- 品牌识别。
- 知识产权。

无形资产还可以进一步分类为有限期性或无限期性。

有限期无形资产是具有确定期限的无形资产。确定无形资产的一个例子是专利。该专利只有在可执行的情况下才具有价值。一旦专利到期，它不再具有价值。

无限期无形资产为无形资产无限期到期。一个例子就是组织的品牌。该品牌预计将在可预见的未来保持和保留。

无形资产可能难以确定价值。“CISP®”商标的价值是多少？对于持有证书的成员来说，这是有价值的，它对拥有该商标的中国信息安全测评中心具有价值。但商标的总价值是多少？对于某人来估计无形资产的价值，下面的方法被认为是普遍可接受的。

- 成本：创建和替换资产的成本。这种做法必须谨慎使用，因为无形资产的价值很少只等于创造或者获取成本。
- 历史利润资本化：如果获得专利，创造品牌或开发新流程直接导致利润增加，这些利润可以被视为资产总值的一部分。

试图确定资产的无形资产时，安全专业人员应寻求财务的协助。这些是组织中最复杂和最有价值的资产，需要进行全面的估价工作。

（2）资产分类

在一个组织中，资产有多种表现形式；同样的两个资产也因属于不同的信息系统而重要性不同，而且对于提供多种业务的组织，其支持业务持续运行的系统数量可能更多。这时首先需要将信息系统及相关的资产进行恰当的分类，以此为基础进行下一步的风险评估。在实际工作中，具体的资产分类方法可以根据具体的评估对象和要求，由评估者灵活把握。根据资产的表现形式，可将资产分为数据、软件、硬件、服务、人员等类型，如表 6-4 所示。

表 6-4　GB/T 20984：2007 一种基于表现形式的资产分类方法

分　类	示　例
数据	保存在信息媒介上的各种数据资料，包括源代码、数据库数据、系统文档、运行管理规程、计划、报告、用户手册、各类纸质的文档等
软件	❑ 系统软件：操作系统、数据库管理系统、语句包、开发系统等 ❑ 应用软件：办公软件、数据库软件、各类工具软件等 ❑ 源程序：各种共享源代码、自行或合作开发的各种代码等
硬件	❑ 网络设备：路由器、网关、交换机等 ❑ 计算机设备：大型机、小型机、服务器、工作站、台式计算机、便携计算机等 ❑ 存储设备：磁带机、磁盘阵列、磁带、光盘、软盘、移动硬盘等 ❑ 传输线路：光纤、双绞线等 ❑ 保障设备：UPS、变电设备、空调、保险柜、文件柜、门禁、消防设施等 ❑ 安全设备：防火墙、入侵检测系统、身份鉴别等 ❑ 其他：打印机、复印机、扫描仪、传真机等

续表

分　类	示　例
服务	❑ 信息服务：对外依赖该系统开展的各类服务 ❑ 网络服务：各种网络设备、设施提供的网络连接服务 ❑ 办公服务：为提高效率而开发的管理信息系统，包括各种内部配置管理、文件流转管理等服务
人员	掌握重要信息和核心业务的人员，如主机维护主管、网络维护主管及应用项目经理等
其他	企业形象、客户关系等

说明：表 6-4 仅作为一种资产分类的模式，不同的标准可能采用的资产分类不同，因此，组织应该合理采用符合本单位实际情况和所依循的标准所建立的资产分类模型。

2．威胁

可能导致对系统或组织危害事故的潜在起因。

威胁可以通过威胁主体、资源、动机、途径等多种属性来描述。造成威胁的因素可分为人为因素和环境因素。根据威胁的动机，人为因素又可分为恶意和非恶意两种。环境因素包括自然界不可抗的因素和其他物理因素。威胁作用形式可以是对信息系统直接或间接的攻击，在保密性、完整性和可用性等方面造成损害；也可能是偶发的或蓄意的事件。

构成威胁的评价指标一般是通过频率的高低来反映，表 6-5 列出了 GB/T 20984：2007《信息安全风险评估规范》中常见威胁的类型。

表 6-5　一种基于表现形式的威胁分类表

编　号	种　类	描　述	子　类
T01	软硬件故障	对业务实施或系统运行产生影响的设备硬件故障、通信链路中断、系统本身或软件缺陷等问题	设备硬件故障
T02			传输设备故障
T03			存储媒体故障
T04			系统软件故障
T05			应用软件故障
T06			数据库软件故障
T07			开发环境故障
T08	物理环境影响	对信息系统正常运行造成影响的物理环境问题和自然灾害	断电
T09			静电
T10			灰尘
T11			潮湿
T12			温度
T13			鼠蚁虫害
T14			电磁干扰
T15			洪灾
T16			火灾
T17			地震

续表

编　号	种　类	描　述	子　类
T18	无作为或操作失误	应该执行而没有执行相应的操作，或无意执行了错误的操作	维护错误
T19			操作失误
T20	管理不到位	安全管理无法落实或不到位，从而破坏信息系统正常有序运行	管理制度和策略不完善
T21			管理规程缺失
T22			职责不明确
T23			监督控管机制不健全
T24	恶意代码	故意在计算机系统上执行恶意任务的程序代码	病毒
T25			特洛伊木马
T26			蠕虫
T27			陷门
T28			间谍软件
T29			窃听软件
T30	越权或滥用	通过采用一些措施，超越自己的权限访问了本来无权访问的资源，或者滥用自己的权限，做出破坏信息系统的行为	非授权访问网络资源
T31			非授权访问系统资源
T32			滥用权限非正常修改系统配置或数据
T33			滥用权限泄露秘密信息
T34	网络攻击	利用工具和技术通过网络对信息系统进行攻击和入侵	网络探测和信息采集
T35			嗅探（账号、口令、权限等）
T36			用户身份伪造和欺骗
T37			用户或业务数据的窃取和破坏
T38			系统运行的控制和破坏
T39	物理攻击	通过物理的接触造成对软件、硬件、数据的破坏	物理接触
T40			物理破坏
T41			盗窃
T42	泄密	信息泄露给不应了解的他人	内部信息泄露
T43			外部信息泄露
T44	篡改	非法修改信息，破坏信息的完整性使系统的安全性降低或信息不可用	篡改网络配置信息
T45			篡改系统配置信息
T46			篡改安全配置信息
T47			篡改用户身份信息
T48			篡改业务数据信息
T49	抵赖	不承认收到的信息和所作的操作和交易	原发抵赖
T50			接收抵赖
T51			第三方抵赖

3．脆弱性

可能被威胁所利用的资产或若干资产的薄弱环节。

脆弱性是资产本身存在的，如果没有被相应的威胁利用，单纯的脆弱性本身不会对资产造成损害。而且如果系统足够强健，严重的威胁也不会导致安全事件发生，并造成损失。即威胁总是要利用资产的脆弱性才可能造成危害。

资产的脆弱性具有隐蔽性，有些脆弱性只有在一定条件和环境下才能显现，这是脆弱性识别中最为困难的部分。不正确的、起不到应有作用的或没有正确实施的安全措施本身就可能是一个脆弱性。

脆弱性识别是风险评估中最重要的一个环节。脆弱性识别可以以资产为核心，针对每一项需要保护的资产，识别可能被威胁利用的弱点，并对脆弱性的严重程度进行评估。也可以从物理、网络、系统、应用等层次进行识别，然后与资产、威胁对应起来。脆弱性识别的依据可以是国际或国家安全标准，也可以是行业规范、应用流程的安全要求。对应用在不同环境中的相同的弱点，其脆弱性严重程度是不同的，评估者应从组织安全策略的角度考虑、判断资产的脆弱性及其严重程度。信息系统所采用的协议、应用流程的完备与否、与其他网络的互联等也应考虑在内。

脆弱性识别时的数据应来自于资产的所有者、使用者，以及相关业务领域和软硬件方面的专业人员等。脆弱性识别所采用的方法主要有问卷调查、工具检测、人工核查、文档查阅、渗透性测试等。

脆弱性识别主要从技术和管理两个方面进行，技术脆弱性涉及物理层、网络层、系统层、应用层等各个层面的安全问题。管理脆弱性又可分为技术管理脆弱性和组织管理脆弱性两方面，前者与具体技术活动相关，后者与管理环境相关，如表 6-6 所示。

表 6-6　脆弱性识别内容表

编　　号	类　　型	识 别 对 象	识 别 内 容
V01	技术脆弱性	物理环境	机房场地
V02			机房防火
V03			机房供配电
V04			机房防静电
V05			机房接地与防雷
V06			电磁防护
V07			通信线路的保护
V08			机房区域防护
V09			机房设备管理
V10		网络结构	网络结构设计
V11			边界保护
V12			外部访问控制策略
V13			内部访问控制策略
V14			网络设备安全配置

续表

编　号	类　型	识别对象	识别内容
V15	技术脆弱性	系统软件	补丁安装
V16			物理保护
V17			用户账号
V18			口令策略
V19			资源共享
V20			事件审计
V21			访问控制
V22			新系统配置
V23			注册表加固
V24			网络安全
V25			系统管理
V26		应用中间件	协议安全
V27			交易完整性
V28			数据完整性
V29		应用系统	审计机制
V30			审计存储
V31			访问控制策略
V32			数据完整性
V33			通信
V34			鉴别机制
V35			密码保护
V36	管理脆弱性	技术管理	物理和环境安全
V37			通信与操作管理
V38			访问控制
V39			系统开发与维护
V40			业务连续性
V41		组织管理	安全策略
V42			组织安全
V43			资产分类与控制
V44			人员安全
V45			符合性

对不同的识别对象，其脆弱性识别的具体要求应参照相应的技术或管理标准实施。例如，对物理环境的脆弱性识别应按 GB/T 9361—2000 中的技术指标实施；对操作系统、数据库应按 GB 17859—1999 中的技术指标实施；对网络、系统、应用等信息技术安全

性的脆弱性识别应按 GB/T 18336—2001 中的技术指标实施；对管理脆弱性识别方面按 GB/T 19716—2005 的要求对安全管理制度及其执行情况进行检查，发现管理脆弱性和不足。

4．信息安全风险

人为或自然的威胁利用信息系统及其管理体系中存在的脆弱性导致安全事件的发生及其对组织造成的影响。

5．安全措施

保护资产、抵御威胁、减少脆弱性、降低安全事件的影响，以及打击信息犯罪而实施的各种实践、规程和机制。常见的安全措施有预防性、检测性和纠正性 3 类。

6．残余风险

采取了安全措施后，信息系统仍然可能存在的风险。

如果残余风险没有降低到可接受的级别，则必须重复风险管理过程，以找出一个将残余风险降低到可接受级别的方法。在进行了充分的风险评估后，得出如下结论：

（1）没有必要采用所有的安全保护措施。因为这些措施要解决的风险可能并不存在，或者可以容忍和接受这些风险。

（2）没有必要防范和加固所有的安全弱点。这些弱点可能因为成本、知识、文化及法律等方面的因素，而没有人能利用它们。

（3）我们没有必要无限制地提高安全保护措施的强度。只需要将相应的风险降低到可接受的程度即可。对安全保护措施的选择还要考虑到成本和技术等因素的限制。

7．风险评估各要素的关系

风险评估各要素之间的关系如图 6-4 所示。

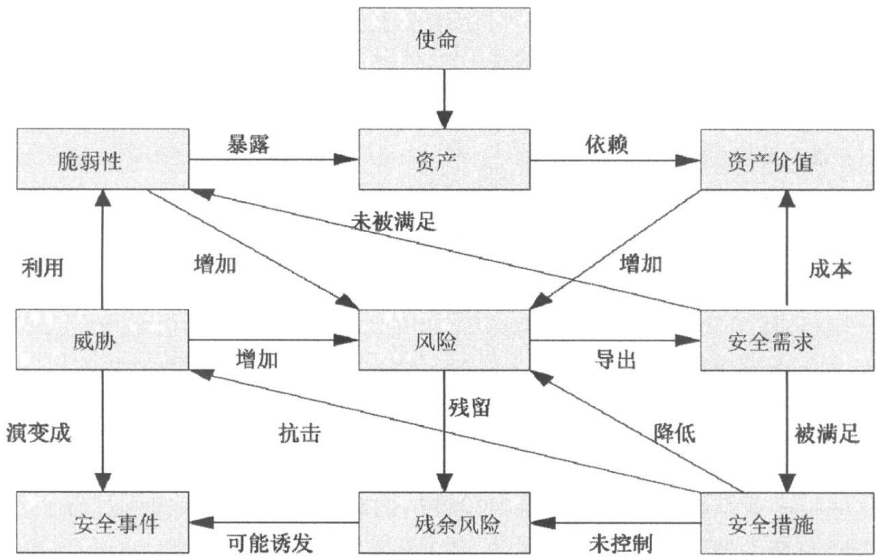

图 6-4　风险评估要素关系图

使命依赖于资产去完成，资产拥有价值。信息化的程度越高，单位的使命越重要，对资产的依赖度越高，资产的价值则就越大。资产的价值越大则风险越大。风险是由威胁引发，威胁越大则风险越大，并可能演变成事件。威胁要利用脆弱性实现，脆弱性越容易被利用则风险越大。脆弱性使资产暴露，是未被满足的安全需求，威胁要通过利用脆弱性来危害资产，从而形成风险。资产的重要性和对风险的意识会导出安全需求；安全需求要通过安全措施来得以满足，且是有成本的。安全措施可以抗击威胁，降低风险，减弱事件的影响。风险不可能削减为零，在实施了安全措施后还会有残留的风险。部分残余风险来自于安全措施可能不当或无效，在以后需要继续控制这部分风险，另一部分残余风险则是在综合考虑了安全措施的成本与资产价值后，有意未去控制的风险，这部分风险是可以被接受的。残余风险应受到密切监视，因为它可能会在将来诱发新的事件。

6.2.2 风险评估途径与方式方法

1. 风险评估途径

（1）基线评估（Baseline Risk Assessment，BRA）

安全基线是诸多标准规范中规定的一组安全控制措施或者惯例，这些措施和惯例适用于特定环境下的所有系统，可以满足基本的安全需求，使系统能达到一定的安全防护水平。

可选的安全基线包括：国际标准和国家标准，例如 ISO 27001、信息安全等级保护；行业标准或推荐，例如德国联邦安全局 IT 基线保护手册；来自其他有类似商务目标和规模的组织的惯例等。

适用范围：组织的商业运作不是很复杂，对信息处理和网络的依赖性不是很高，或者组织信息系统多采用普遍且标准化的模式。

评估策略：根据组织实际的情况，对信息系统进行基线检查（用现有的安全措施与安全基线规定的措施进行比较，找出差距），得出基本的安全需求。通过选择并实施标准的安全措施来消减风险和控制风险。

（2）详细评估

对资产进行详细识别和评价，对可能引起风险的威胁和脆弱性水平进行评估，根据风险评估的结果来识别和选择安全措施，即识别资产的风险并将风险降到可接受的水平，以此证明管理者所采用的安全措施是恰当的。

（3）组合评估

采用基于基线评估与详细评估两者之间的评估方式。

方法是组织应先对所有系统进行一次初步的高级风险评估。着眼于信息系统的商务价值和可能面临的风险，识别出组织内具有高风险或对其商务运作极为关键的信息资产（或系统），这些资产或系统应划分在详细风险评估的范围，而其他系统则可以通过基线风险评估直接选择安全措施。

风险评估途径如表 6-7 所示。

表 6-7 风险评估途径

风险评估途径	优 点	缺 点
基线评估	需要的资源少，周期短，操作简单，对于环境相似且安全需求相当的诸多组织，基线评估是最经济有效的风险评估途径	基线的高低水平难以设定，过高可能导致资源浪费限制过度；过低又会造成难以达到充分的安全。 在管理安全相关的变化方面，基线评估比较困难
详细评估	组织对信息安全风险有一个精确的认识，并且准确定义出组织目前的安全水平和安全需求。 详细评估的结果可以用来管理安全变化	可能是非常耗费资源的过程，包括时间、精力和技术，因此，组织应该仔细设定待评估的信息系统范围，明确商务环境、操作和信息资产的边界
组合评估	节省详细评估所耗费的资源，又能确保获得一个全面系统的评估结果，而且组织的资源和资金能够应用到最能发挥作用的地方，具有高风险的信息系统能够被预先关注	如果初步的高级风险评估不够准确，某些本来需要详细评估的系统也许会被忽略，最终导致结果失准

2．风险评估方式

（1）自评估

由组织自身发起，依据国家有关法规与标准，对信息系统及其管理进行的风险评估活动。自评估应参考相应标准，依据制定的评估方案、评估准则，结合系统特定的安全要求进行实施。周期性进行的自评估可以在评估流程上适当简化，重点针对自上次评估后系统发生变化后引入的新威胁，以及系统脆弱性的完整识别，以便于两次评估结果的对比。但系统发生重大变更时，应进行完整的评估。

自评估可由发起方实施或委托风险评估服务技术支持方实施。由发起方实施的评估可以降低实施的费用、提高信息系统相关人员的安全意识，但可能由于缺乏风险评估的专业技能，其结果不够深入准确。同时，受到组织内部各种因素的影响，其评估结果的客观性易受影响。委托风险评估服务技术支持方实施的评估，过程比较规范、评估结果的客观性比较好，可信程度较高，但由于受到行业知识技能及业务了解的限制，对被评估系统的了解，尤其是在业务方面的特殊要求存在一定的局限。由于引入第三方本身就是一个风险因素，因此，对其背景与资质、评估过程与结果的保密要求等方面应进行控制。

此外，为保证风险评估的实施，与系统相连的相关方也应配合，以防止给其他方的使用带来困难或引入新的风险。

（2）检查评估

由被评估组织的上级主管机关或业务主管机关发起的，依据国家有关法规与标准，对信息系统及其管理进行的具有强制性的检查活动。

检查评估可依据相关标准的要求，实施完整的风险评估过程。检查评估也可在自评估实施的基础上，对关键环节或重点内容实施抽样评估，包括以下内容（但不仅限于）：自

评估队伍及技术人员审查、自评估方法的检查、自评估过程控制与文档记录检查、自评估资产列表审查、自评估威胁列表审查、自评估脆弱性列表审查、现有安全措施有效性检查、自评估结果审查与采取相应措施的跟踪检查、自评估技术技能限制未完成项目的检查评估、上级关注或要求的关键环节和重点内容的检查评估、软硬件维护制度及实施管理的检查及突发事件应对措施的检查。

检查评估也可委托风险评估服务技术支持方实施，但评估结果仅对检查评估的发起单位负责。由于检查评估代表了主管机关，涉及评估对象也往往较多，因此，要对实施检查评估机构的资质进行严格管理。

3．风险评估方法

（1）基于知识的分析方法

基于知识的分析方法，组织不需要付出很多精力、时间和资源，只要通过多种途径采集相关的信息，识别组织的风险所在和当前的安全措施，与特定的标准或最佳惯例进行比较，从中找出不符合的地方，并按照标准或最佳惯例的推荐安全措施，最终达到消减和控制风险的目的。基于知识的分析方法，最重要的还在于评估信息的采集，信息源包括：

- 会议讨论。
- 对当前的信息安全策略和相关文档进行复查。
- 制作问卷，进行调查。
- 对相关人员进行访谈。
- 进行实地考察。

（2）定量分析

对构成风险的各个要素和潜在损失的水平赋予数值或货币金额，当实体风险的所有要素（资产价值、威胁频率、弱点利用程度、安全措施的效率和成本等）都被赋予数值，风险评估的整个过程和结果都可以被量化。在实施定量分析时，首先识别资产并为资产赋值，然后通过威胁和弱点评估，评价特定威胁作用于特定资产所造成的影响，即 EF（取值为0%～100%）。

定量分析的一些概念。

- 暴露因子（Exposure Factor，EF）：特定威胁对特定资产靠损失的百分比，或者说损失的程度。
- 单一预期损失（Single Loss Expectancy，SLE）：也称作单一事件成本（Single Occurrence Costs，SOC），即特定威胁一次可能造成的潜在损失总量。单一预期损失的计算方法：单一损失预期（SLE）=暴露因子（EF）×资产价值。
- 年度预期损失（Annualized Loss Expectancy，ALE）：或者称作预期年度费用（Estimated Annual Cost，EAC），表示特定资产在一年内遭受损失的预期值。年度预期损失（ALE）=SLE×年度发生率（ARO）。

例如，我们需要计算由于人员疏忽或设备老化对一个计算机机房所造成火灾的风险。

在这个示例中，我们假设这个计算机机房的资产价值为 1000000 元人民币；由于这些威胁所产生的火灾资产总值将损失至资产价值的 25%（EF=25%），也就是说这种火灾过后资产总值将为 250000 元人民币（SLE=资产价值 × EF=1000000 × 0.25=250000 元）；这种火灾发生的可能性为 10 年发生一次（ARO=0.1）；因此我们所计算出来的这种威胁的年度损失预期值为 25000 元人民币（ALE=SLE × ARO=250000 × 0.1=25000 元）。

ALE 提供了一个可能的年度损失价值，组织可以使用它来确定一年需要多少成本来建立一种控制或安全措施以阻止此类损害并提供足够级别的保护。为了知道需要花费多少钱来避免威胁的潜在后果，使用量化风险的实际可能性和威胁造成的损失（以货币尺度计量）是非常重要的。

（3）定性分析

定性风险评估在风险评价时，往往需要凭借分析者的经验和直觉，或者业界的标准和惯例，为风险诸要素（资产价值、威胁频率、脆弱性利用的可能性、安全措施的效率和成本等）的大小或高低程度定性分级，定性风险评估更具主观性，更依赖于专家、专业知识和组织机构对其所面临的风险的理解和判断。定性风险评估通常用于数字化数据不充分或不可用的情况下。定性风险评估也用于当资源有限（例如，人员、人员专业知识或预算）以及时间进度不允许更量化的评估。在定性风险评估中，可以获取和报告定量信息，但风险级别是主观确定的。

正如在所有风险评估中一样，定性评估开始于对风险因素的信息搜集。当信息搜集和分析完后，风险就可以主观评估。在这种评估中，使用例如“可接受风险”或“不可接受风险”或其他类似术语。另外，风险级别也可以分类为低、中或高。

定性风险评估与定量风险评估的区别在于在前一方法中不用向资产分配难以确定的财务价值、预期损失和控制成本。取而代之的是计算相对值。通常通过调查表和合作研讨会的组合形式进行风险分析，涉及来自组织内各个部门的人员，例如信息安全专家、信息技术经理和员工、企业资产所有者和用户以及高级经理。如果使用，调查表通常在第一次研讨会之前几天或几周内发放。调查表专为发现已经部署了什么资产和控制措施而制定，收集的信息在随后举行的研讨会期间非常有用。在研讨会中，参与者确定资产并评估资产的相对价值。接下来，参与者尝试指出各个资产可能面临的威胁，然后尝试描述这些威胁在将来可能利用的漏洞类型。信息安全专家和系统管理员通常准备好缓解风险的控制措施参加会议，以便各部门考虑并估计各个控制措施的成本。最后，结果被交给管理层以便在成本效益分析期间进行考虑。

定性分析的流程非常类似于定量方法，区别在于细节。一个资产和另一个资产的价值之间的比较是相对的，参与者不会用大量的时间来尝试为资产评估计算精确的财务数字。计算转变为现实的风险的可能影响以及实施控制所需的成本也同样如此。

定性方法的优点是克服了为资产价值、控制成本等计算精确数字的挑战，流程对员工没有太高的要求。定性风险管理项目通常在几周内即可开始显示重要的结果，然而选择定

量方法的大多数组织历时数月甚至数年也看不到好处。定性方法的缺点是得出的数字是含糊的；某些业务决策者，特别是具有财务或会计背景的决策者，可能会对在定性风险评估项目中确定的相对值感到不适。

定性风险分析常用到的分析矩阵如表 6-8 所示。

表 6-8　定性风险分析矩阵表

可　能　性	影　　响				
	可以忽略 1	较小 2	中等 3	较大 4	灾难性 5
A（几乎肯定）	H	H	E	E	E
B（很可能）	M	H	H	E	E
C（可能）	L	M	H	E	E
D（不太可能）	L	L	M	H	E
E（罕见）	L	L	M	H	H

（4）定性与定量分析的区别

定性与定量分析的区别如表 6-9 所示。

表 6-9　定性评估与定量评估对比表

评 估 方 法	优　　点	缺　　点
定量分析	按财务影响确定风险优先级；按财务价值确定资产优先级。 结果通过安全投资收益推动风险管理。 结果可用因管理而异的术语来表达（例如货币值和表达为具体百分比的可能性）。 随着组织建立数据的历史记录并获得经验，其精确度将随时间的推移而提高	分配给风险的影响值以参与者的主观意见为基础。 达成可靠结果和一致意见的流程非常耗时。 计算可能会非常复杂且耗时。 结果只用财务术语来表达，对非技术性人员而言可能难以解释。 流程要求专业技术，因此参与者无法轻松通过流程获得指导
定性分析	使可见性和了解风险优先级成为可能。 更容易达成一致意见。 无须量化威胁频率。 无须确定资产的财务价值。 更便于非安全或计算机专家的人员参与	在重要的风险之间没有足够的区别。 因为没有为成本效益分析提供基础，因此难以证明投资控制措施实施是否正确。 结果取决于建立的风险管理小组的素质

6.2.3　风险评估基本过程

风险评估是组织确定信息安全需求的过程，包括资产识别与评价、威胁和弱点评估、控制措施评估、风险认定在内的一系列活动。根据国家标准 GB/T 20984—2007《信息安全风险评估规范》，将风险评估定义为如下过程（见图 6-5）。

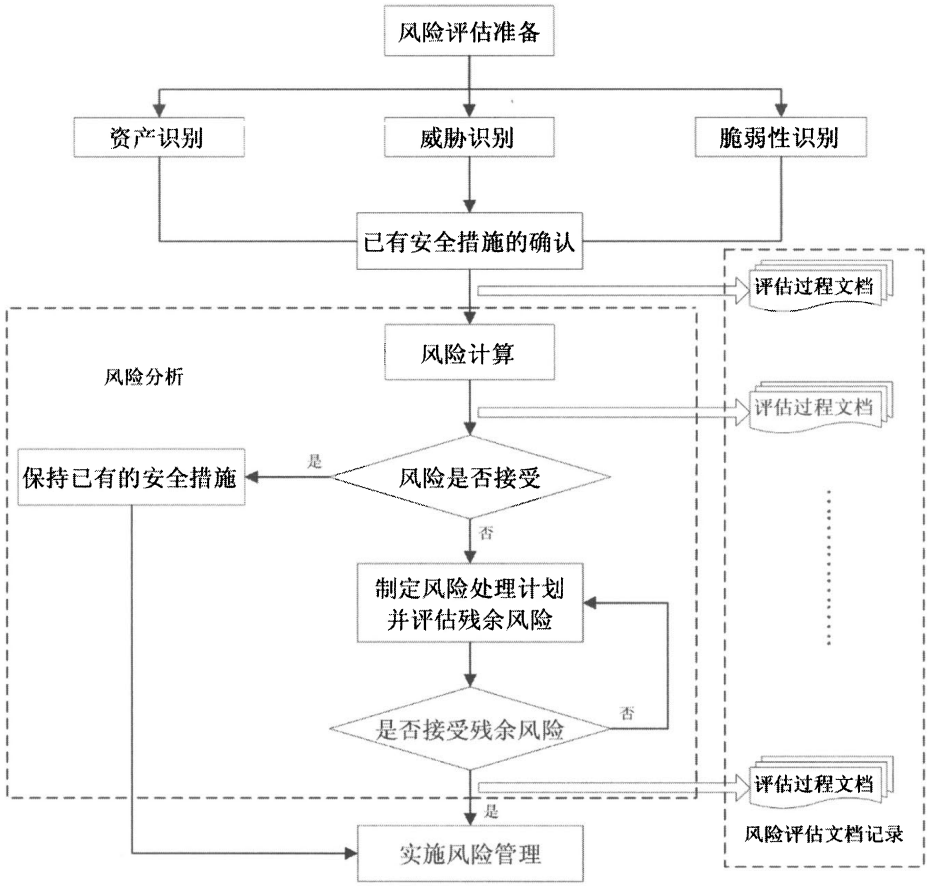

图 6-5　风险评估实施流程

1．风险评估准备

风险评估准备是整个风险评估过程有效性的保证。组织实施风险评估是一种战略性的考虑，其结果将受到组织的业务战略、业务流程、安全需求、系统规模和结构等方面的影响。因此，在风险评估实施前需要做以下工作。

（1）确定风险评估的目标

根据满足组织业务持续发展在安全方面的需要、法律法规的规定等内容，识别现有信息系统及管理上的不足，以及可能造成的风险大小。

（2）确定风险评估的范围

风险评估范围可能是组织全部的信息及与信息处理相关的各类资产、管理机构，也可能是某个独立的信息系统、关键业务流程以及与客户知识产权相关的系统或部门等。

（3）组建适当的评估管理与实施团队

风险评估实施团队是由管理层、相关业务骨干、IT 技术等人员组成风险评估小组，必要时，可组建由评估方、被评估方领导和相关部门负责人参加的风险评估领导小组，聘请相关专业的技术专家和技术骨干组成专家小组。

评估实施团队应做好评估前的表格、文档、检测工具等各项准备工作，进行风险评估技术培训和保密教育，制定风险评估过程管理相关规定。可根据被评估方要求，双方签署保密合同，酌情签署个人保密协议。

（4）进行系统调研

系统调研是确定被评估对象的过程，风险评估小组应进行充分的系统调研，为选择风险评估依据和方法、实施评估内容奠定基础。调研内容至少应包括以下方面。

- 业务战略及管理制度。
- 主要的业务功能和要求。
- 网络结构与网络环境，包括内部连接和外部连接。
- 系统边界。
- 主要的硬件、软件。
- 数据和信息。
- 系统和数据的敏感性。
- 支持和使用系统的人员。
- 其他。

系统调研可以采取问卷调查与现场面谈相结合的方式进行。调查问卷是提供一套关于管理或操作控制的问题表格，供系统技术或管理人员填写；现场面谈则是由评估人员到现场观察并收集系统在物理、环境和操作方面的信息。

（5）确定评估依据和方法

根据系统调研结果，确定评估依据和评估方法。评估依据包括但不限于以下方面。

- 现有国际标准、国家标准、行业标准。
- 行业主管机关的业务系统的要求和制度。
- 系统安全保护等级要求。
- 系统互联单位的安全要求。
- 系统本身的实时性或性能要求等。

根据组织机构自身的业务特点、信息系统特点，选择适当的风险分析方法并加以明确，如定性风险分析、定量风险分析，或是半定量风险分析。

根据评估依据应考虑评估的目的、范围、时间、效果、人员素质等因素来选择具体的风险计算方法，并依据业务实施对系统安全运行的需求，确定相关的判断依据，使之能够与组织环境和安全要求相适应。

（6）制订风险评估方案

风险评估方案的目的是为后面的风险评估实施活动提供一个总体计划，用于指导实施方开展后续工作。风险评估方案的内容一般包括但不限于以下方面。

- 团队组织：包括评估团队成员、组织结构、角色、责任等内容。
- 工作计划：风险评估各阶段的工作计划，包括工作内容、工作形式、工作成果等内容。

- 时间进度安排：项目实施的时间进度安排。

（7）获得最高管理者对风险评估工作的支持

上述所有内容确定后，应形成较为完整的风险评估实施方案，得到组织最高管理者的支持和批准。

对管理层和技术人员进行传达，在组织范围就风险评估相关内容进行培训，以明确有关人员在风险评估中的任务。

2. 风险识别

（1）资产识别

资产识别包括对组织机构资产分类、分级、形态及资产价值的评估，由专门的机构或专门评估人员，遵循法定或公允的标准和程序，运用科学的方法，以货币作为计算权益的统一尺度，对在一定时点上的资产进行评定估算的行为。信息资产是组织信息安全评估的对象，资产既是安全评估的起点，也是安全评估的终点。

① 资产分类与登记

在信息安全风险评估前，首先要进行的工作是资产分类与分级，资产清单作为资产登记的重要输出物。识别资产的有效手段是资产清单，通过资产清单记录组织资产的所有权关系以及资产的分类、分级及资产变更描述，资产清单在风险评估中具有重要价值，应准确地描述资产的相关信息和特征。资产清单也是安全评估的重要依据。

随着信息技术的发展，传统的信息资产也在不断发生变化，例如，云技术的广泛应用，使得云资产的登记与分类成为新的问题。图 6-6 所示为云资产登记表的一个实例。

编号	虚拟池名	地理位置	物理上机列表	型号	物理设施资源			操作系统	版本	虚拟软件	版本	等保定级	运行业务	业务等级	操作系统	支撑平台	虚拟化配额			变更说明	备注
					CPU	内存	外存										CPU	内存	外存		

图 6-6　云资产登记表实例

② 资产赋值

传统风险评估中，资产的价值并不是通过资产的财务价值建立赋值机制，在通行的定性评估中，资产通过其承载组织业务的信息安全三元组保密性、完整性和可用性受到侵害后的影响程度来建立赋值关系。

- **保密性赋值**：根据资产对保密性的不同要求，应将其分为不同的等级，分别对应资产在保密性上应达成的不同程度或者保密性缺失时对整个组织的影响。表 6-10 提供了一种保密性级别定义、赋值的参考。组织机构可参考表 6-10，制定自己的资产保密性分级准则。

表 6-10　资产保密性级别定义及赋值

赋　值	级　别	定　义
5	很高	包含组织最重要的秘密，关系未来发展的前途命运，对组织根本利益有着决定性的影响，如果泄露会造成灾难性的损害
4	高	包含组织的重要秘密，其泄露会使组织的安全和利益遭受严重损害
3	中	组织的一般性秘密，其泄露会使组织的安全和利益受到损害
2	低	仅能在组织内部或在组织某一部门内部公开的信息，向外扩散有可能对组织的利益造成轻微损害
1	公开	可对社会公开的信息，公用的信息处理设备和系统资源等

- **完整性赋值**：根据资产对完整性的不同要求，应将其分为不同的等级，分别对应资产在完整性缺失时对整个组织的影响。表 6-11 提供了一种完整性级别定义、赋值的参考。组织机构可参考表 6-11，制定自己的资产完整性分级准则。

表 6-11　资产完整性级别定义及赋值

赋　值	级　别	定　义
5	很高	完整性价值非常关键，未经授权的修改或破坏会对组织造成重大的或无法接受的影响，对业务冲击重大，并可能造成严重的业务中断，难以弥补
4	高	完整性价值较高，未经授权的修改或破坏会对组织造成重大影响，对业务冲击严重，较难弥补
3	中	完整性价值中等，未经授权的修改或破坏会对组织造成影响，对业务冲击明显，但可以弥补
2	低	完整性价值较低，未经授权的修改或破坏会对组织造成轻微影响，对业务冲击轻微，容易弥补
1	很低	完整性价值非常低，未经授权的修改或破坏对组织造成的影响可以忽略，对业务冲击可以忽略

- **可用性赋值**：根据资产对可用性的不同要求，应将其分为不同的等级，分别对应资产在可用性上应达成的不同程度。表 6-12 提供了一种可用性级别定义、赋值的参考。组织机构可参考表 6-12，制定自己的资产可用性分级准则。

表 6-12　资产可用性级别定义及赋值

赋　值	级　别	定　义
5	很高	可用性价值非常高，合法使用者对信息及信息系统的可用度达到年度99.9%以上，或系统不允许中断
4	高	可用性价值较高，合法使用者对信息及信息系统的可用度达到每天90%以上，或系统允许中断时间小于 10 分钟

续表

赋　值	级　别	定　义
3	中	可用性价值中等，合法使用者对信息及信息系统的可用度在正常工作时间达到 70%以上，或系统允许中断时间小于 30 分钟
2	低	可用性价值较低，合法使用者对信息及信息系统的可用度在正常工作时间达到 25%以上，或系统允许中断时间小于 60 分钟
1	很低	可用性价值可以忽略，合法使用者对信息及信息系统的可用度在正常工作时间低于 25%

- **重要性赋值**：应依据资产价值大小对资产的重要性划分不同的等级。资产价值应依据资产在保密性、完整性和可用性上的赋值等级，经过综合评定得出。综合评定方法可以根据自身的特点，选择对资产保密性、完整性和可用性最为重要的一个属性的赋值等级作为资产的最终赋值结果；也可以根据资产保密性、完整性和可用性的不同等级对其赋值进行加权计算得到资产的最终赋值结果。加权方法可根据组织的业务特点确定。表 6-13 给出了资产重要性等级划分的定义及赋值的示例，表明了不同等级的重要性的综合描述。组织机构可参考表 6-13，制定自己的资产重要性分级准则。

表 6-13　资产重要性等级定义及赋值

赋　值	重要性等级	定　义
5	很高	非常重要，其安全属性破坏后可能对组织造成非常严重的损失
4	高	重要，其安全属性破坏后可能对组织造成比较严重的损失
3	中	比较重要，其安全属性破坏后可能对组织造成中等程度的损失
2	低	不太重要，其安全属性破坏后可能对组织造成较低的损失
1	很低	不重要，其安全属性破坏后对组织造成很小的损失，甚至忽略不计

③ 资产评估原则

资产评估原则是调节资产评估委托者、评估业务承担者以及资产业务有关权益各方在资产评估中的相互关系，规范评估行为和业务的准则。

资产评估的工作原则是指评估机构和评估人员在执业过程中应遵循的基本原则，主要包括独立性原则、客观公正性原则和科学性原则。

- 独立性原则：评估机构应始终坚持第三者立场，不为资产业务当事人的利益所影响。评估机构应是独立的社会公正性机构，不能为资产业务中任何一方所拥有，也不能隶属于任何一方。遵循这一原则可以从组织上保证评估工作不受有关利益方的干扰和委托者意图的影响。
- 客观公正性原则：要求评估结果应以充分的事实为依据。这就要求评估者在评估过程中以公正、客观的态度收集有关数据与资料，并要求评估过程中的预测、推

算等主观判断建立在市场与现实的基础之上。此外，为了保证评估的公正、客观性，按照国际惯例，资产评估机构收取的劳务费用应该只与工作量相关，不与被评估资产的价值挂钩。

- 科学性原则：在资产评估过程中，必须根据特定目的，选择适用的价值类型和科学的方法，制订科学的评估方案，使资产评估结果准确合理。在整个评估工作中必须把主观评价与客观测算、静态分析与动态分析、定性分析与定量分析相结合，使评估工作做到科学合理、真实可信。

（2）威胁识别

判断威胁出现的频率是威胁赋值的重要内容，应对威胁出现的频率进行等级化处理，不同等级分别代表威胁出现的频率的高低。表 6-14 提供了威胁出现频率级别定义、赋值的一种参考。组织机构可参考表 6-14，制定自己的威胁出现频率分级准则。

表 6-14　威胁出现频率级别定义及赋值

赋　值	威胁出现频率级别	定　义
5	很高	出现的频率很高（或≥1 次/周）；或在大多数情况下几乎不可避免；或可以证实经常发生过
4	高	出现的频率较高（或≥1 次/月）；或在大多数情况下很有可能会发生；或可以证实多次发生过
3	中	出现的频率中等（或>1 次/半年）；或在某种情况下可能会发生；或被证实曾经发生过
2	低	出现的频率较小；或一般不太可能发生；或没有被证实发生过
1	很低	威胁几乎不可能发生；仅可能在非常罕见和例外的情况下发生

（3）脆弱性识别

应对脆弱性严重程度进行等级化处理，不同的等级分别代表资产脆弱性严重程度的高低。表 6-15 提供了脆弱性严重程度等级定义、赋值的一种参考。组织机构可参考表 6-15，制定自己的脆弱性严重程度分级准则。

表 6-15　脆弱性严重程度等级定义及赋值

赋　值	脆弱性严重程度级别	定　义
5	很高	如果被威胁利用，将对资产造成完全损害
4	高	如果被威胁利用，将对资产造成重大损害
3	中	如果被威胁利用，将对资产造成一般损害
2	低	如果被威胁利用，将对资产造成较小损害
1	很低	如果被威胁利用，将对资产造成的损害可以忽略

（4）确认已有的控制措施

确认已有的安全措施，需要依据背景建立阶段输出的 3 个报告，即《信息系统的描述

报告》《信息系统的分析报告》《信息系统的安全要求报告》来确认已有的安全措施，包括技术层面（物理平台、系统平台、网络平台和应用平台）的安全功能、组织层面（组织结构、岗位和人员）的安全控制和管理层面（策略、规章和制度）的安全对策，形成《已有安全措施列表》。

在识别脆弱性的同时，评估人员应对已采取的安全措施的有效性进行确认。安全措施的确认应评估其有效性，即是否真正地降低了系统的脆弱性，抵御了威胁。对有效的安全措施继续保持，以避免不必要的工作和费用，防止安全措施的重复实施。对确认为不适当的安全措施应核实是否应被取消或对其进行修正，或用更合适的安全措施替代。

已有安全措施确认与脆弱性识别存在一定的联系。一般来说，安全措施的使用将减少系统技术或管理上的脆弱性，但安全措施确认并不需要和脆弱性识别过程那样具体到每个资产、组件的脆弱性，而是一类具体措施的集合，为风险处理计划的制订提供依据和参考。

3．风险分析

在完成了资产识别、威胁识别、脆弱性识别、已有安全措施确认以及确定风险分析方法后，将采用已确定的风险分析方法与工具，来分析威胁利用脆弱性导致安全事件发生的可能性，并综合安全事件所作用的资产价值及脆弱性的严重程度，分析安全事件造成的损失对组织的影响，即安全风险。风险计算原理可以用下面的范式形式化地加以说明：

$$\text{风险值}=R(A, T, V) = R(L(T, V), F(Ia, Va))$$

其中，R 表示安全风险计算函数；A 表示资产；T 表示威胁；V 表示脆弱性；Ia 表示安全事件所作用的资产价值；Va 表示脆弱性严重程度；L 表示威胁利用资产的脆弱性导致安全事件的可能性；F 表示安全事件发生后造成的损失。

（1）计算安全事件发生的可能性

根据威胁出现频率及脆弱性的状况，计算威胁利用脆弱性导致安全事件发生的可能性，即：

$$\text{安全事件的可能性}=L(\text{威胁出现频率, 脆弱性}) = L(T, V)$$

在具体评估中，应综合攻击者技术能力（专业技术程度、攻击设备等）、脆弱性被利用的难易程度（可访问时间、设计和操作知识公开程度等）、资产吸引力等因素来判断安全事件发生的可能性。

（2）计算安全事件发生后造成的损失

根据资产价值及脆弱性严重程度，计算安全事件一旦发生后造成的损失，即：

$$\text{安全事件造成的损失}=F(\text{资产价值, 脆弱性严重程度}) = F(Ia, Va)$$

部分安全事件的发生造成的损失不仅仅是针对该资产本身，还可能影响业务的连续性；不同安全事件的发生对组织的影响也是不一样的。在计算某个安全事件的损失时，应将对组织的影响也考虑在内。

部分安全事件造成的损失的判断还应参照安全事件发生可能性的结果，对发生可能性极小的安全事件，如处于非地震带的地震威胁、在采取完备供电措施状况下的电力故障威胁等，可以不计算其损失。

（3）计算风险值

根据计算出的安全事件的可能性以及安全事件造成的损失，计算风险值，即：

风险值=R(安全事件的可能性，安全事件造成的损失) = R(L(T, V), F(Ia, Va))

评估者可根据自身情况选择相应的风险计算方法计算风险值，如矩阵法或相乘法。矩阵法通过构造一个二维矩阵，形成安全事件的可能性与安全事件造成的损失之间的二维关系；相乘法通过构造经验函数，将安全事件的可能性与安全事件造成的损失进行运算得到风险值。

在实际的风险评估活动中，具体的风险计算方法，应该是对以上风险相关要素的某种具体运算。目前，常用的风险计算方法是矩阵法和相乘法。在实际应用中，可以将矩阵法和相乘法结合使用。

- 矩阵法：主要适用于由两个要素值确定一个要素值的情形。首先需要确定二维计算矩阵，矩阵内各个要素的值根据具体情况和函数递增情况采用数学方法确定，然后将两个元素的值在矩阵中进行比对，行列交叉处即为所确定的计算结果。
- 相乘法：主要用于两个或多个要素值确定一个要素值的情形。即 z = f(x, y)，函数 f 的值 z 可以采用相乘法取得。

4．风险结果判定

风险结果判定阶段包括评估风险的等级和综合评估风险状况两个工作过程。

（1）评估风险的等级

评估风险的等级，需要依据《风险计算报告》，根据已经制定的风险分级准则，对所有风险计算结果进行等级处理，形成《风险程度等级列表》。

风险等级处理的目的是在风险管理过程中对不同风险的直观比较以确定组织安全策略。组织应当综合考虑风险控制成本与风险造成的影响，提出一个可接受的风险范围。对某些资产的风险，如果风险计算值在可接受的范围内，则该风险是可接受的，应保持已有的安全措施；如果风险评估值在可接受的范围外，即风险计算值高于可接受范围的上限值，则该风险是不可接受的，需要采取安全措施以降低、控制风险。另一种确定不可接受的风险的办法是根据等级化处理的结果，不设定可接受风险值的基准，对达到相应等级的风险都进行处理。

基于确定的风险等级定义及赋值准则，可以将所有的风险可能值进行等级化处理，如表 6-16 所示。

表 6-16　风险等级定义及赋值

等　级	取值范围	名　称	描　述
H	25，20	高风险	最高等级的风险，需要立即采取应对措施。不可接受
S	12，15，16	严重风险	需要高级管理层注意。不可接受
M	6，8，9，10	中等风险	必须规定管理责任。通常需要综合考虑取舍
L	1，2，3，4，5	低风险	可以通过例行程序来处理。可接受

（2）综合评估风险状况

综合评估风险状况，需要汇总各项输出文档和《风险程度等级列表》，综合评价风险状况，形成《风险评估报告》。

《风险评估报告》是对整个风险评估过程和结果进行的总结，应详细说明被评估对象、风险评估方法、资产、威胁、脆弱性的识别结果、风险分析、风险统计和结论等内容。

《风险评估报告》是组织机构确定信息安全需求的依据，为风险处理活动提供输入，是后续信息安全建设工作的基础。

5．风险处理计划

对不可接受的风险应根据导致该风险的脆弱性制订风险处理计划。风险处理计划中应明确采取弥补脆弱性的安全措施、预期效果、实施条件、进度安排、责任部门等。安全措施的选择应参照信息安全的相关标准，从管理与技术两个方面考虑。

风险处理计划工作过程如图 6-7 所示。

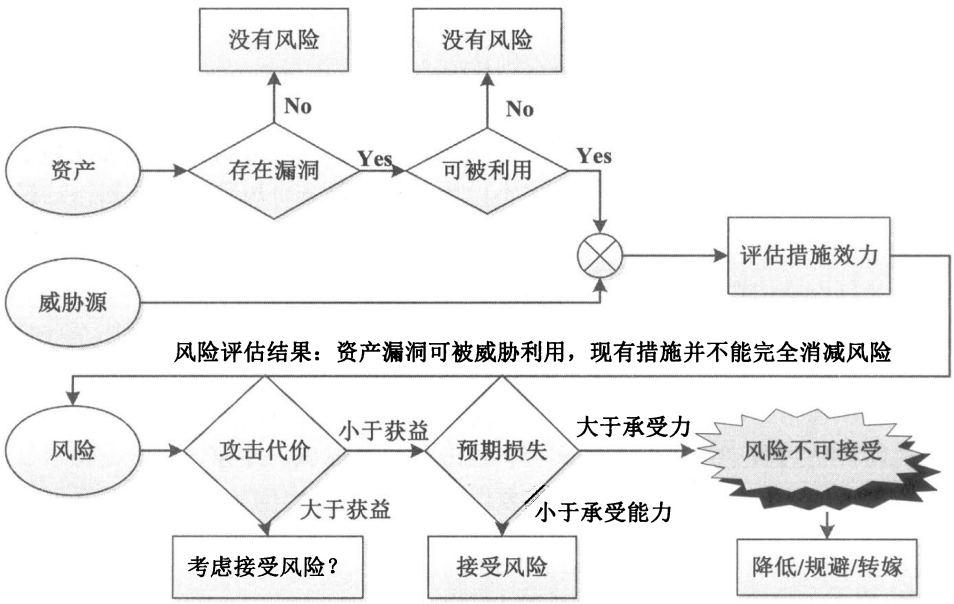

图 6-7　风险处理计划工作过程

6．残余风险评估

在对于不可接受的风险选择适当安全措施后，为确保安全措施的有效性，可进行再评估，以判断实施安全措施后的残余风险是否已经降到可接受的水平。残余风险的评估可以依据相关标准提出的风险评估流程实施，也可做适当裁剪。一般来说，安全措施的实施是以减少脆弱性或降低安全事件发生可能性为目标的，因此，残余风险的评估可以从脆弱性评估开始，在对照安全措施实施前后的脆弱性状况后，再次计算风险值的大小。

某些风险可能在选择了适当的安全措施后，残余风险的结果仍处于不可接受的风险范

围内，应考虑是否接受此风险或进一步增加相应的安全措施。

6.2.4 风险评估文档

风险评估文档是指在整个风险评估过程中产生的评估过程文档和评估结果文档，包括但不仅限于阐述风险评估的目标、范围、人员、评估方法、评估结果的形式和实施进度等的《风险评估方案》。明确评估的目的、职责、过程、相关的文档要求，以及实施本次评估所需要的各种资产、威胁、脆弱性识别和判断依据《风险评估程序》。根据组织在风险评估程序文档中所确定的资产分类方法进行资产识别，形成资产识别清单，明确资产的责任人。

常见的过程文档还包括描述资产识别和赋值的结果，形成重要资产列表，包括重要资产名称、描述、类型、重要程度、责任人/部门等的《重要资产清单》。根据威胁识别和赋值的结果，形成威胁列表，包括威胁名称、种类、来源、动机及出现的频率等的《威胁列表》以及根据脆弱性识别和赋值的结果，形成包括具体脆弱性的名称、描述、类型及严重程度的《脆弱性列表》和《已有安全措施确认表》。

风险评估的主体文档主要包括描述整个风险评估过程和总结的结果，详细说明被评估对象、风险评估方法、资产、威胁、脆弱性的识别结果、风险分析、风险统计和结论等内容的《风险评估报告》；描述评估结果中不可接受的风险制订风险处理计划，选择适当的控制目标及安全措施，明确责任、进度、资源，并通过对残余风险的评价以确定所选择安全措施的有效性的《风险处理计划》。

确保文档发布前是得到批准的并且标识出更改和现行修订状态。文档在分发过程中应得到适当的控制并确保在使用时可获得有关版本的适用文档，防止作废文档的非预期使用，若因任何目的须保留作废文档时，应对这些文档进行适当的标识。

对于风险评估过程中形成的相关文档，还应规定其标识、储存、保护、检索、保存期限以及处置所需的控制。相关文档是否需要以及详略程度由组织的管理者来决定。

6.3 知识子域：信息系统审计

6.3.1 审计原则与方法

1. 审计职能

信息系统审计初期是对财务信息系统的安全性、有效性进行检查，属于财务审计的一部分。但随着信息系统审计理论和实践的发展，逐步扩展到对组织重要信息系统进行单独的审计，一般会涵盖组织的所有重要信息系统。

国家审计署定义：“信息系统审计是指国家审计机关依法对被审计单位信息系统的真实性、合法性、效益性和安全性进行检查监督的活动。信息系统审计的主要目标是通过检

查和评价被审计单位信息系统的安全性、可靠性和经济性，揭示信息系统存在的问题，提出完善信息系统控制的审计意见和建议，促进被审计单位信息系统实现组织目标；同时，通过检查和评价信息系统产生数据的真实性、完整性和正确性，防范和控制审计风险。”

国际信息系统和控制协会（ISACA）将信息系统审计定义为：“是一个获取并评价证据以判断计算机系统是否能够保证资产的安全、数据的完整以及有效率地利用组织的资源并有效果地实现组织目标的过程。”

信息系统的安全性已经成为业务生产安全的重要组成部分，并成为信息系统所有者及其用户最为关心的问题，信息系统的安全控制是信息系统内部控制的主要内容之一，因此在信息系统审计中，系统安全性也是重要审计内容之一。信息安全审计是一个获取并评价证据，以判断组织的信息安全控制活动是否充分、有效、适宜，有力支撑组织的信息系统和业务目标的过程。

信息安全审计的主要目标是通过检查和评价被审计单位信息安全控制措施的充分性、有效性和适宜性，揭示信息安全工作存在的问题，提出完善信息安全控制措施的审计意见和建议，促进被审计单位信息安全控制措施实现组织的目标。

（1）充分性

为达到组织的信息安全目标、法律法规要求及合同责任等，组织的信息安全工作必须充分全面，这种充分全面性应考虑两个方面的内容。规划设计实施信息安全工作机制时是否考虑全面，是否有遗漏的环节；实施条件发生变化时，各种持续改进可能会发现原有的信息安全工作在过程方面可能存在不充分的情况。

（2）有效性

各项信息安全控制措施达到所策划的结果的程度。有效性的评价可通过对信息安全目标的实现程度、员工的反馈及满意程度、过程执行的效果、法规的符合性等方面进行评价而实现。

（3）适宜性

当组织信息安全内外部环境发生变化时，如国家或行业发布新的信息安全管理文件，先进技术的出现，新漏洞的发现，组织业务的变化，组织资源状况的变化等，要对其进行调整或改进以适应这种变化。

从审计目标看，信息系统审计主要是检查和促进被审计单位信息系统及其内部控制的真实性、正确性、完整性、安全性、可靠性和经济性等各类目标要素。从审计内容看，信息系统审计中的一般控制审计包括信息安全技术控制审计和信息安全管理控制审计。无论是从信息系统审计目标，还是从信息系统审计内容来看，信息系统审计中的大部分工作将围绕着信息安全控制展开，只有对信息安全控制实施了充分有效的测试和评估，才能有效达成信息系统审计的总体目标。

2．审计流程

审计工作流程如图 6-8 所示。

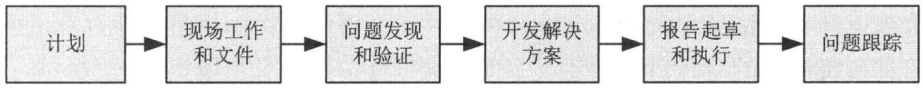

图 6-8　审计工作流程

（1）计划

计划过程的目标是确定审计的目标和范围。需要确定正在尝试通过审查完成什么，作为此过程的一部分，需要制定一系列要执行的步骤，以完成审计的目标。

如果审计过程包含在审计计划中，审计经理应该向审计组转达导致审计计划改变的信息，包括管理层的意见和该领域的已知问题。导致审计计划改变的因素需要纳入审计计划。此外，审计经理应该能够向审计团队提供审计的关键联系人。

审计小组应在每次审计之前花一些时间对审计的区域进行初步调查，以了解审计工作的内容，包括与审计客户的访谈和审查任何可能的文件，了解正在审查的系统或流程的功能，从而获得对待审查区域基本背景的理解。如果有需要，也可以对该区域的风险进行初步评估。

为了实现对待审计区域基本背景的理解，应让被审计的客户在其中发挥其对待审计区域所有权的优势，尽可能获得客户的意见并将其纳入审计计划。审计小组应向客户询问，了解他们认为应该审查哪些领域，以及哪些领域与之相关，这些信息应该与审计小组客户风险评估结果进行对照以确定审计范围。

审计部门可能有一套自己的公司标准和流程，可复用的审核清单可以为很多审核项目提供较好的开始。这些审核清单应根据每个项目具体的情况进行评估和修改，以更好地符合项目的实际需要。使用标准的审核清单不能取代每次审核前进行风险评估的要求。

可以通过互联网、相关书籍和培训材料等资料获取被审核领域的更多信息。

（2）现场工作和文件

大部分审计发生在此阶段，创建审计步骤由审计小组执行。团队收集数据并进行访谈，帮助团队成员分析潜在的风险，并确定哪些风险没有得到适当的缓解。

审计师应尽可能寻找方法独立验证所提供的信息和控制环境的有效性。审计师应该始终考虑创造性的方式来进行测试。例如，如果审计客户描述了批准新用户重新获得账户的过程，则审核员应尝试提取最近添加的用户的样本，看看他们确实获得了正确的批准。

文件也是实地工作的重要组成部分。审计人员必须做好充分的工作记录，足够详细的记录工作可以使相关合理知情人对审计所做的工作理解并得出相同的结论。

文档过程首先需要符合专业的标准。其次，由于以后执行审计工作的审计师可能不再是原来进行审计的机构或人员，此次审计过程中发现的风险有可能在以后的审计中受到质疑，因此需要有详细的文件解释审计过程并证实结论。第三，如果将来再次进行审核，那么保留详细的文档将使下一个审计团队能够从以前的审计团队的经验中学习，从而实现持续改进和提高效率。

在计划阶段需要制定审核期间审查内容的检查清单，在现场审核时，需要确保这些审

核清单不会影响审核小组成员的判断。在审计过程中，审核团队需要根据项目实际情况重新调整，找到在规划阶段被忽视的相关信息。这个工作应作为实现目标的指导原则，每个审核员都需要不断保持创造性以确保真正找到被调查区域的风险。

（3）问题发现和验证

在执行实地工作时，审计人员需要制定一个包含潜在需要关注的问题清单。这是审计中非常重要的阶段之一，审计人员必须注意针对清单中的问题进行逐条处理，确保清单中的问题与本次审计相关。审计师应注重与客户的合作，尽快与客户讨论潜在问题，除了客观地证实问题清单中所列举的是否为事实，还需要验证该问题所提出的风险是否非常重要，值得报告和解决。

虽然审计师对于系统是否遵守公司内部安全政策进行审查是很重要的工作，但仍应以风险为依据。有时系统在技术上违反了政策，但由于缓解控制或者系统特定的性质，这种违规行为并没有真正的安全风险。审核组不是策略合规审核团队，不能仅仅审核是否合规，还应考虑政策以及所有其他相关因素来评估正在审查的环境的真实风险。

（4）开发解决方案

在确定了正在审核的领域中的潜在问题，并确定事实和风险后，需要与客户合作制订解决每个问题的行动计划。

（5）报告起草和执行

审计工作中发现被审计环境中的问题，需要与客户进行验证，然后制订解决方案并起草审核报告。审核报告是记录审计结果的工具。它有以下两个主要功能。

① 对于审核方和审核客户，报告作为审计记录，是审核的结果和解决方案的行动计划。

② 对于高级管理层和审计委员会，作为审计区域的“报告”，审计报告格式的基本要素包括以下方面。

- 审计范围声明。
- 执行摘要。
- 问题清单，以及解决问题的行动计划。

起草报告后，应该让客户在发布报告之前对其进行审核并对其进行评论。只要不改变审核人员的描述，可以做一些小的修改。目标应该是与报告中的内容一致。

（6）问题跟踪

一旦审计报告发布，审计部门必须制定一个过程，其成员能够跟踪问题直到解决，包括维护一个包含所有审计点及其到期日的数据库，以及将其标记为关闭、逾期等机制。

首先，它允许审核员在做出决定时咨询客户。其次，如果正在实施的解决方案不符合预期，则可以提前告知审核员。以这种方式，审核员可以尝试在事情确定之前重定向活动。第三，如果问题没有得到解决，审计部门可以尝试在过期之前解决这个问题。

3. 内部控制

内部控制是确保内部流程正常运行的机制。公司内的每个系统和流程都存在一些特定

的业务目标。审计师必须寻找这些业务存在的风险，然后确保内部控制措施到位以减轻风险。

内部控制类型可以是预防性、检测性或纠正性，它们可以具有管理、技术和物理实现。管理手段的例子包括政策和流程，技术实现诸如在逻辑上执行控制（如密码）的工具和软件，物理实施包括安全人员和锁门等控制。

4．审计标准

审计公司在开展审计过程中，应遵循行业的相关标准。这些标准包括国际内部审计专业实务标准或国家内部审计标准。这些标准应该被审查并纳入审核过程。此外，在同一网站上，可以找到审计专业的道德守则，其中说明了对审计行为的完整性、客观性、保密性和能力的要求。

6.3.2 审计技术控制

1．脆弱性测试

无论是手动测试、自动化测试还是两者结合，脆弱性测试都要求具有深度安全背景和最高级别的可信赖员工或顾问来执行。即使是最好的自动化漏洞扫描工具也会产生误报，有些漏洞本身并不重要，但将多个类似的漏洞结合在一起可能会形成一个至关重要的可被利用脆弱性，同时，漏洞本身也要结合环境来判定其可被利用的可能性及容易程度。脆弱性测试的评估目标如下。

- 评估环境的真实安全状态。
- 确定尽可能多的漏洞，并对其进行真实的评估和优先级排序。
- 测试系统如何对某些情况和攻击做出反应，不仅可以了解已知漏洞（例如当前版本的操作系统、数据库存在的漏洞、弱口令的用户账号等），而且还可以了解针对环境可能被滥用的独特元素（SQL 注入攻击、缓冲区溢出以及可被社会工程学攻击利用的流程设计缺陷等）。
- 在用户同意测试并决定测试范围之前，测试人员必须说明测试可能产生的后果。生产系统可能会受到测试的影响，对系统负载带来压力，部分易受攻击的系统可以进行脱机测试。

管理层必须明白，测试结果只是一个“时间的快照”，随着环境的变化，新的漏洞可能会出现。

2．渗透测试

渗透测试是一种模拟真实攻击的测试行为。渗透测试工程师使用一套过程和工具测试是否存在可能绕过系统安全控制的情况。通过渗透测试，能发现系统中存在的脆弱性并衡量系统组织抵抗攻击的能力。渗透测试根据系统所有者、高级管理层的要求，在授权的前提下进行的模拟攻击，它可能是针对虚拟环境，也可能是在真实的生产环境中。

3. 战争驾驶

战争驾驶是通过软件和硬件打造的侦察平台，利用步行或相应的交通工具（自行车、汽车甚至无人机等）在各个物理环境中寻找不设防无线接入点的一种方式。战争驾驶是新时代的战争拨号。对于战争驾驶来说，有时的目的不只是为了找出不设防无线接入点这么简单，战争驾驶者还会通过使用 GPS 设备定位每个开放的无线接入点的经纬度，然后通过 GPS 地图软件将这些找到的开放 AP 按具体的经纬度在 GPS 地图中标识出来。

通过战争驾驶可以有效识别组织内部的不安全无线设备的使用和无线网络缺陷，在现代审计技术中这成为一种重要的审计技术手段。

4. 其他漏洞类型

脆弱性测试中发现潜在的漏洞后需要进行穿透测试，识别在运行环境中实际可以利用并造成损害的漏洞。常见的利用漏洞包括内核缺陷、符号链接、竞争条件等。

5. 日志

日志审查是检查系统日志文件以发现安全事件或验证安全控制有效性的审计技术。日志在系统运行过程中不断记录，这个过程会产生大量的信息，为了使日志提供有意义的信息，需要获取非常具体并且大量基于行业最佳实践和组织风险管理流程的信息，然后根据不断变化的威胁形态进行调整。

为组织设置有效的日志评估的另一个关键因素是确保所有联网设备的时间标准化。如果一个事件影响 3 个设备，并且设备时间并不同步，那么就难以确定事件的顺序，不利于了解攻击的整体流程。

6. 合成交易

一个用户从某个特定网页发起了一个电汇的请求，将自己账户上的资金转到另外一个银行账户上，这个事务无论由多少个服务器来处理，都被认为是一个真正的交易。但现在如果这个事务不是由一个人来生成，而是一个脚本，这就是一个合成交易。

合成交易在审计中的作用是系统的测试关键业务的行为和性能。脚本可能会在页面关闭或无法访问时立即提醒用户，允许用户在其他方式注意到之前进行调查。这可能是用户 Web 服务器被攻击者入侵或者处于分布式拒绝服务（DDoS）攻击的早期指标。

合成交易可以做的不仅仅是告诉服务是开启还是关闭。它们可以测量响应时间等性能参数，从而可以提醒网络拥塞或服务器过度利用。还可以通过模仿典型的最终用户行为来帮助测试新服务，以确保系统的运行。这是从外部测试软件的有效方式。

7. 滥用用例测试

用例通常被用于描述信息系统中所需功能的结构化场景，也被视为外部行为人（例如用户）希望在系统上完成给定目标的过程。用例描述了行为人和系统之间的为了达到所需结果的交互过程。用例测试对于分析系统正常或预期行为的要求非常有帮助，在系统安全评估方面，用例测试能帮助威胁行为人在系统上执行希望的任务，而滥用的用例测试对系

统就是一种安全威胁。

在信息系统审计中，需要关注滥用用例测试的可能，威胁行为人滥用用例从而威胁到系统特定部分合法使用情况，例如抢票软件对于购票网站来说就是典型的滥用用例测试。系统开发人员和安全人员可以针对这些滥用用例测试采取相对应的控制措施。

8. 代码审查

系统地检查构成软件的编码，代码审查工作可以是内部团队、外包开发商或商业供应商。代码审查的初步步骤是确保开发人员遵循团队的风格指南或标准。除了有助于提高软件的可维护性之外，此步骤还为代码审查人员了解未来的工作规模。

检查代码的结构和格式后，审计师将查找不必要或不需要的功能或过程。“代码膨胀”导致应用程序更难维护和保护，出于同样的原因，审计师会查找过于复杂的模块。

不必要和危险程序的一个极端例子是开发人员经常在其开发软件中包含的代码存根和测试例程。

9. 接口测试

接口测试是测试系统组件间接口的一种测试。接口测试主要用于检测外部系统与系统之间以及内部各个子系统之间的交互点。测试的重点是要检查数据的交换，传递和控制管理过程，以及系统间的相互逻辑依赖关系等。

6.3.3 审计管理控制

1. 账户管理

攻击者获取系统权限的首选方式是掌握系统中“正常”的特权用户，实现这一目的主要有 3 种方式：利用现有的特权账户、创建新的特权账户或提升已有用户账户的权限。

对于新建账户，应有一个明确的过程进行引导以确保用户不仅了解他们的职责和责任，还要确定被分配的资产，并且这些资产被正确地配置和保护。

而对于系统中已有的账户，审核员不仅应关注具有管理特权的账户，还需要关注是否存在自定义权限集合使账户权限接近管理员级别。

另外，对于暂时不需要的账户，是否存在相应的机制以确保账户被暂停。组织机构中人员已经离开仍然拥有权限的情况并不少见。无论什么原因，必须确保不存在使用人的账户被暂停，直到该人返回或符合保留政策的期限。

2. 备份验证

组织机构对信息系统的依赖使得大量数据产生，这些数据对组织机构而言非常重要，需要受到足够的保护。备份是组织机构数据保护的主要手段，无论如何备份数据，定期进行测试都是必不可少的。没有经过测试的备份，可能会在面临事件或灾难后，需要从备份中恢复数据时发现备份丢失、损坏或过时。

3．灾难恢复和业务连续性

组织机构的业务连续性管理是避免由于各种原因对业务带来的影响，业务连续性计划应定期进行评估以确保随时有效。而由于环境的不断变化，业务连续性计划应进行定期测试，并且在测试中不断改进。

4．安全培训和安全意识培训

安全培训是教授技能或知识的过程，使人们能够更好地执行具体的功能。安全意识是培训人们如何应对安全问题的过程，使他们能够认识到这些问题，并更好地做出回应。安全培训通常提供给安保/技术人员，同时应向组织的每个成员提供安全意识培训。

评估安全培训计划的有效性是非常简单的，因为培训与特定的安全功能相关。因此为了测试培训计划的有效性，所要做的就是测试个人在培训前后的表现。如果性能提高，那么训练可能是有效的。随着时间的推移，技能萎缩，所以培训的有效性应在其结束后立即予以衡量。

安全意识培训有效性的一个关键指标是人们改变行为的程度。

5．关键绩效和风险指标

行业的安全指标并不缺乏，但是应重点关注两个最重要的指标类别：关键绩效指标（KPI）和主要风险指标（KRIs）。

（1）关键绩效指标

尝试在没有适当指标的情况下运行信息安全管理体系（ISMS）可能比不管理安全性更危险。使用错误的指标可能会导致组织走错路径，从而使得结果比不运行 ISMS 更糟糕。国际标准化组织发布的 ISO/IEC 27004《信息安全度量实施》可用于衡量安全管理的有效性。

（2）主要风险指标

主要风险指标（KRIs）可用于衡量一个活动的风险程度，以便领导对这一活动做出明智的决策，并且考虑到潜在的资源损失。KPIs 的选择会对组织中高层领导的决定产生影响，这意味着 KPIs 影响组织的多个方面。

6.3.4 审计报告

审计报告的撰写是审计中非常关键的工作，评估人员如何描述审计中所做的工作及对组织机构的意义能真正体现审计人员的专业水平。专业的审计人员不仅了解在很多业务环境中信息系统安全的作用，还能将信息准确地传达给技术和非技术人员。审计报告常见的标准包括 SAS 70 和 SOC。

1．SAS 70

SAS 70 是由美国注册会计师协会（AICPA）制定的用于处理服务机构的审计标准。它提供了一套基于服务组织（如提供 IT 服务的服务组织）并且可用于展示内部控制有效性的

标准。根据标准，服务机构可以聘请经认证的独立服务审核员来形成 SAS 70 审核并发布报告。该报告可以反过来提交给任何需要证明服务机构内部控制有效性的客户。

自从 2002 年实施“萨班斯法案”404 条款以来，SAS 70 报告变得尤为重要，因为公司可以将其作为内部控制有效性的证明。

SAS 70 服务审核员报告有两种类型：类型 1 和类型 2。两种类型都包括对服务组织的内部控制在某个时间点的设计的描述和意见。但是只有第 2 类报告包含服务审计人员在本报告所述期间控制是否有效运行的结果，以确保实现控制目标。作为审计师，通常希望服务提供商提供类型 2 报告，因为类型 1 报告不提供控制措施有效运行的证据。

2．SOC

过去，SAS 70 报告旨在协助服务机构的用户及其审计人员进行财务报表审计。现在，已经定义了 3 种类型的 SOC 报告，以取代 SAS 70 并解决更广泛的特定用户需求，例如解决安全性、隐私和可用性问题。此外，服务组织正在寻找更好的方式来提供对其控制环境的保证。

SOC 报告最常见地涵盖了 12 个月的活动设计和有效性，每年持续的覆盖率从财务报告或治理的角度来满足用户需求。在某些情况下，如果系统/服务没有运行一整年，或年度报告不足以满足用户需求，SOC 报告可能会缩短时间，例如 6 个月。SOC 报告还可能仅涵盖新系统和服务的特定时间点的控制设计或系统、服务的初始检查（审核）。

第 7 章

知识域：信息安全支撑技术

阅读提示 本知识域主要介绍身份鉴别、访问控制及密码学等信息安全基础技术，通过学习，学员需要了解身份鉴别的作用、主要的身份鉴别方式，了解访问控制对信息安全的重要性及典型的访问控制模型，同时了解密码学对信息安全的支撑作用及典型的密码学应用等知识。本知识域包括密码学、身份鉴别和访问控制 3 个知识子域。

7.1 知识子域：密码学

7.1.1 密码学基本概念

密码学（Cryptology）是一门古老又现代的学科。几千年前，它作为神秘性和艺术性的字谜呈现，而现代密码学，作为数学、计算机、电子、通信、网络等领域的一门交叉学科，广泛应用于军事、商业和现代社会人们生产、生活的方方面面。随着密码学的不断发展，密码学逐步从艺术走向科学，并成为构建安全信息系统的核心。

1．密码学的发展历史

第一阶段：古典密码阶段。这一阶段是从古代到 19 世纪末，人类有众多的密码实践。例如两千多年前，罗马国王凯撒（Julius Caesar）就开始使用被称为“凯撒密码”的密码系统。此阶段的密码学还不能称为一门科学，因为此时的密码学是多半具有艺术特征的字谜，这一时期的密码专家常常靠直觉、猜测和信念来设计、分析密码，而不是凭借推理和证明。密码算法的基本手段是针对字符的替代和置换。

到 20 世纪 20 年代，随着机械和机电技术的成熟，电报和无线电安全需求引发了密码设备的一场革命，转轮密码机（简称转轮机）诞生了。转轮机的出现是古典密码学发展成熟的重要标志之一。尽管转轮机的出现对密码学应用带来了巨大的变化，但是密码算法的安全性仍然取决于密码算法本身的保密。

第二阶段：近代密码阶段。这一阶段是 1949—1975 年。计算机和通信系统的普及，带动了对数字信息的保护需求。1949 年，香农（Shannon）发表了划时代论文——《保密系统的通信理论》（*The Communication Theory of Secret Systems*），该文首先将信息论引入了

密码，从而把已有数千年历史的密码学推向了科学的轨道，奠定了密码学的理论基础，密码学开始成为一门科学。

第三阶段：现代密码阶段。该阶段自 1976 年开始一直延续到现在。由于受历史的局限，20 世纪 70 年代中期以前的密码学研究基本上都是秘密进行，而且主要应用于军事和政府部门。20 世纪从 70 年代中期开始，随着密码学的应用逐渐广泛，密码学真正地蓬勃发展起来。W.Diffie 和 M.E.Hellman 在 1976 年公布了一种密钥一致性算法（Diffie-Hellman 算法，简称 DH 算法），该算法不是加密算法，而是一种密钥建立的算法。DH 算法开启了密码学的新方向，具有里程碑式的意义，引发了密码学历史上一次革命性的变革，标志着密码学进入公钥密码学的时代。

信息化的发展使得密码学得到了广泛应用，密码标准化工作和实际应用得到了各国政府、学术界和产业界的空前关注，密码标准化大大推动了密码学的研究与应用。

2．基本保密通信模型

密码学包括密码编码学和密码分析学两部分。密码编码学主要研究信息的编码，构建各种安全有效的密码算法和协议，用于消息的加密、认证等方面。密码分析学是研究破译密码获得消息，或对消息进行伪造。

这里需要指出的是，传统的密码学主要用于保密通信，其基本目的是使得两个在不安全信道中通信的实体，以一种使他们的敌手不能明白和理解通信内容的方式进行通信。而现代密码技术及应用已经涵盖数据处理过程的各个环节，如数据加密、密码分析、数字签名、身份识别、零知识证明、秘密分享等。通过以密码学为核心的理论与技术保证数据的机密性、完整性、可用性等安全属性。

基本的保密通信模型如图 7-1 所示，通信的参与者包括消息发送方、消息接收方，潜在的密码分析者是在双方通信中既非发送方又非接收方的实体，它试图攻击保证发送方和接收方信息安全的服务。发送方要传递消息（明文）给接收方，他使用事先和接收方约定好的方法，用加密密钥加密消息。当接收方接收到加过密的消息（密文）后，即使用解密密钥将密文解密成明文。

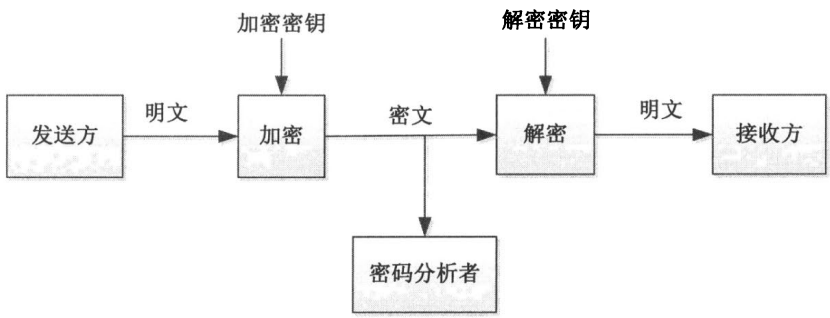

图 7-1　基本保密通信模型图

基本保密通信模型中的相关概念如下。

- 明文（Plain text）：不需要任何解密工具就可以读懂内容的原始消息称为明文。
- 密文（Cipher text）：明文变换成一种在通常情况下无法读懂的内容，这种隐蔽后的信息称为密文。
- 加密（Encryption）：由明文到密文的变换过程称作加密。
- 解密（Decryption）：从密文到明文的变换过程称为解密。
- 加/解密算法：对明文进行加密时采取的一组规则称作加密算法，密文的接收方对密文进行解密时采取的一组规则称为解密算法。
- 密钥（Key）：密钥在明文转换为密文或将密文转换为明文的算法中输入的参数。

3．密码系统的安全性

影响密码系统安全性的基本因素包括密码算法复杂度、密钥机密性和密钥长度等。所使用密码算法本身的复杂程度或保密强度取决于密码设计水平、破译技术等，它是密码系统安全性的保证。

对于密码系统的安全性，特别是密钥的机密性，早在1883年科克霍夫（Kerckhoff）在其著作《军事密码学》中就提出了下述原则：密码系统中的算法即使被密码分析员所知，也应该无助于用来推导出明文或密钥。这一原则已被后人广泛接受，称为科克霍夫原则（假设），并成为密码系统设计的重要原则之一。换言之，科克霍夫原则（假设）是指在评定一个密码体制的安全性时，假定攻击方知道所有目前已使用的密码学方法。系统的保密性不依赖于对加密体制或算法的保密，而依赖于密钥。这是因为攻击者可能通过逆向工程分析的方法最终获得密码算法；攻击者通过收集大量的明文/密文对来分析、破解密码算法；在密码算法实际使用过程中也不能排除多少了解一些算法内部机理的人有意或无意泄漏算法原理。

由于现代密码技术都依赖于密钥，因此密钥的安全管理是密码技术应用中非常重要的环节。只有密钥安全，不容易被敌手得到或破获，才能保障实际通信或加密数据的安全。密钥管理主要研究如何在不安全的环境中，为用户分发密钥信息，使得密钥能够安全并有效地使用，在安全策略的指导下处理密钥自产生到最终销毁的整个过程，包括密钥的产生、存储、备份/恢复、装入、分配、保护、更新、泄漏、撤销、销毁等。密钥管理本身是一个很复杂的问题，而且是保证密码安全的关键。密钥管理方法因所使用的密码体制而异。

密码算法的复杂性是保证算法安全的一个基本条件。如果一个密码系统使用的密码算法不够复杂，或者看起来似乎很复杂，但实际存在体制上的弱点，那么就容易被攻击者利用，在不需要尝试所有密钥的情况下能轻松地破解得到明文。单表代换密码是最容易攻破的密码算法之一，在这种密码体制中，尽管可能达到的密钥数量是 $26! \approx 4 \times 10^{26}$，但是密码专家已经可以在几分钟内破解该算法。

除了密码算法的复杂性外，密钥长度也是保证密码系统安全性的基本因素。最简单的破解密钥的方式就是尝试各种可能的密钥，看哪一个是实际使用的密钥。在这种攻击中，要尝试的密钥数量和将要检索的整个密钥空间紧密相关，也就是与密钥的长度紧密相关。

如果密钥是 16 位长，那么就有 2^{16}=65536 个可能的密钥，而在 DES 算法中密钥长 56 位，就有 $2^{56} \approx 7.2 \times 10^{16}$ 个可能的密钥。1977 年，Whitfield Diffie 和 Martin Hellman 假设了一种专门用于破译 DES 的机器，如果每秒能尝试一百万个密钥，需要花费约 2285 年时间才能尝试完 56 位的所有密钥。而如果某种算法使用了 64 位长的密钥，这种机器需要 585000 年来尝试所有的密钥。

评估密码系统安全性主要有 3 种方法。

（1）无条件安全性。这种评价方法考虑的是假定攻击者拥有无限的计算资源，但仍然无法破译该密码系统。

（2）计算安全性。这种方法是指如果使用目前最好的方法攻破它所需要的计算资源远远超出攻击者拥有的计算资源，则可以认为这个密码系统是安全的。

（3）可证明安全性。这种方法是将密码系统的安全性归结为某个经过深入研究的困难问题（如大整数素因子分解、计算离散对数等）。这种评估方法存在的问题是它只说明了这个密码方法的安全性与某个困难问题相关，没有完全证明问题本身的安全性，并给出它们的等价性证明。

对于实际使用的密码系统而言，由于至少存在一种破译方法，即暴力攻击法，因此都不能满足无条件安全性，只能达到计算安全性。密码系统要达到实际安全，就要满足以下准则。

（1）破译该密码系统的实际计算量（包括计算时间或费用）巨大，以至于在实际中是无法实现的。

（2）破译该密码系统所需要的计算时间超过被加密信息的生命周期。例如，战争中发起战斗攻击的作战命令只需要在战斗打响前保密。

（3）破译该密码系统的费用超过被加密信息本身的价值。

如果一个密码系统能够满足以上准则之一，就可以认为是实际安全的。

4．密码算法的分类

密码算法本身的复杂程度或保密强度取决于密码体系设计水平、破译技术等，它是密码系统安全性的保证。

（1）受限制的算法与基于密钥的算法

如果算法的保密性是基于保持加/解密算法的秘密，这种算法称为受限制的算法；而如果算法可以公开，即算法的安全性不是基于算法的保密，而是基于密钥的安全性，也即基于科克霍夫原则，则这种算法称为基于密钥的算法。现代密码学的一个显著特点是将算法的安全性基于密钥进行设计，而且其算法细节可以公开。这种算法可以抵御公众的分析和破解企图。

（2）对称密码与非对称密码

根据加密密钥与解密密钥的关系，密码体制可分为对称密码算法（Symmetric Cryptosystem）和非对称密码算法（Asymmetric Cryptosystem）。

对称密码算法也称单钥或秘密密钥算法，其加密密钥和解密密钥相同，或实质上等同，即从一个易于推出另一个。在大多数对称算法中，加密、解密密钥是相同的。它要求发送者和接收者在安全通信之前，商定一个密钥。对称算法的安全性依赖于密钥，泄漏密钥就意味着任何人都能对消息进行加密和解密。只要通信需要保密，密钥就必须保密。

非对称密码体制又称双钥或公钥密码体制，其加密密钥和解密密钥不同，从一个很难推出另一个。非对称密码体系的密钥由公开密钥（public key）和私有密钥（private key）组成。公开密钥与私有密钥是成对使用，如果用公开密钥对数据进行加密，只有用对应的私有密钥才能解密；如果用私有密钥对数据进行加密，那么只有用对应的公开密钥才能解密。因为加密和解密使用的是两个不同的密钥，所以这种算法叫作非对称加密算法。

（3）分组密码与流密码

按对明文的处理方式，可将对称密码体制分为分组密码（Block cipher）和流密码（Stream cipher）。

分组密码是将明文分成固定长度的组，用同一密钥和算法对每一块加密，对每个输入块产生一个输出块，输出也是固定长度的密文。典型的分组密码算法有 DES、AES 等。

流密码也称序列密码，是将明文消息按字符逐位地加密，连续地处理输入明文，并随着该加密的进行，一次产生一个密文的输出，即一次加密一个比特或一个字节。典型的例子如一次一密（One-time padding）。

7.1.2　对称密码算法

对称密码算法也称为传统密码算法、秘密密钥算法或单密钥算法，其加密密钥能够从解密密钥中推算出来，反过来也成立。

1．算法特点

对称加密算法的优点是算法简单、计算量小、加密速度快、加密效率高，适合加密大量数据，明文长度与密文长度相等。它也存在一些缺点。

（1）通信双方要进行加密通信，需要通过秘密的安全信道协商加密密钥，而这种安全信道可能很难实现。

（2）在有多个用户的网络中，任何两个用户之间都需要有共享的密钥。若每两个用户分别采用不同的对称密钥，则 n 个用户需要 $C(n,2)=n(n-1)/2$ 个密钥。当网络中的用户 n 很大时，需要管理的密钥数目非常大。例如 $n=100$ 时，$C(100,2)=4995$；$n=5000$ 时，$C(5000,2)=12497500$。可见随着网络规模的增大，密钥管理成为难点。

（3）无法解决对消息的篡改、否认等问题。例如当主体 A 收到主体 B 的电子文档（电子数据）时，无法向第三方证明此电子文档确实来源于 B。

对称密码算法常分为分组密码算法和流密码算法，分组密码和流密码的区别在于其输出的每一位数字不是只与相对应（时刻）的输入明文数字有关，而是与长度为 IV 的一组明

文数字有关。

分组密码是将明文消息编码表示后的数字（简称明文数字）序列，划分成长度为 IV 的组（可看成长度为 IV 的矢量），每组分别在密钥的控制下变换成等长的输出数字（简称密文数字）序列。分组对称密码是对称密码算法中重要的一类算法，典型的分组对称密码算法包括 DES、IDEA、AES、RC5、Twofish、CAST-256、MARS 等。

2. DES 和 3DES

数据加密标准（Data Encryption Standard，DES）是 1977 年美国联邦信息处理标准（FIPS）中所采用的一种对称密码（FIPS 46-3），是迄今为止世界上使用最为广泛的一种密码算法，它对分析、掌握分组密码的基本理论和设计原理有着重要的意义。

（1）DES 选定过程

美国国家标准局为了能使政府部门进行信息处理时保证数据的安全，自 1971 年开始研究数据密码的标准化，并于 1973 年 5 月 15 日的联邦记录（RF1973）中征求在传输和存储数据中保存计算机数据的密码算法，并提出一系列的密码算法要求。这些算法的要求包括以下方面。

- 算法必须提供高度的安全性。
- 算法必须有详细的说明，并易于理解。
- 算法的安全性取决于密钥，不依赖于算法。
- 算法适用于所有用户。
- 算法适用于不同应用场合。
- 算法必须高效、经济。
- 算法必须能被证实有效。
- 算法必须是可出口的。

征集的结果是美国国家标准局采用了 IBM 公司提交的 Luciffer 算法的改进版本，1977 年被采纳为联邦标准（FIPS PUB 46），即数据加密标准，并授权在非密级政府通信中使用。

DES 设计中使用了分组密码设计的两个基本原则：混淆和扩散原则，目的是抗击敌手对密码系统的统计分析。混淆是使密文的统计特性与密钥的取值之间的关系尽可能复杂化，以使密钥和明文以及密文之间的依赖性对密码分析者来说是无法利用的。扩散的作用就是将每一位明文的影响尽可能迅速地作用到较多的输出密文位中，以便在大量的密文中消除明文的统计结构；并且也使每一位密钥的影响尽可能迅速地扩展到较多的密文位中，以防止对密钥进行逐段破译。

（2）DES 算法过程

DES 算法把 64 位的明文输入块变为 64 位的密文输出块，它所使用的密钥也是 64 位（有效密钥为 56 位，第 8、16、24、32、40、48、56、64 位是校验位，使得每个密钥都有奇数个 1）。

DES 是一种分组对称加密算法，它以 64 位的分组长度对数据进行加密，每个明文分组在 64 比特的密钥控制下进行加密变化，输出结果为同样 64 比特长度的密文。由于 64 比

特长的密钥中包含了 8 比特位的奇偶校验比特，所以实际密钥长度为 56 比特。DES 算法每个分组加密和解密的过程如图 7-2 所示。

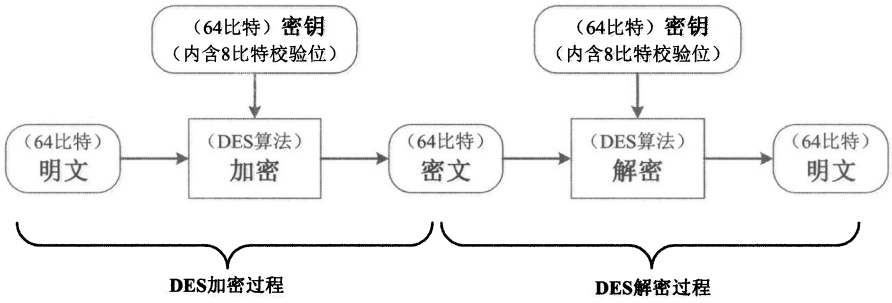

图 7-2　DES 算法过程

（3）DES 与 3DES

随着硬件技术和 Internet 的发展，DES 破解的可能性越来越大，而且，所需要的时间越来越少。为了克服 DES 密钥空间小的缺陷，人们又提出了三重 DES 的变形方式。3DES（即 Triple DES）是 DES 向 AES 过渡的加密算法，它使用两个 56 位的密钥对数据进行三次加密，是 DES 的一个更安全的变形。它以 DES 为基本模块，通过组合分组方法设计出分组加密算法。比起最初的 DES，3DES 更为安全。

该方法使用两个密钥，执行 3 次 DES 算法，加密的过程是加密-解密-加密，解密的过程是解密-加密-解密。

采用两个密钥进行三重加密的好处如下。

① 两个密钥合起来有效密钥长度有 112 比特，可以满足商业应用的需要，若采用总长为 168 比特的 3 个密钥，会产生不必要的开销。

② 加密时采用加密-解密-加密，而不是加密-加密-加密的形式，这样有效地实现了与现有 DES 系统的向后兼容问题。因为当秘钥 K1=K2 时，三重 DES 的效果就和原来的 DES 一样，有助于逐渐推广三重 DES。

3．AES

高级加密标准（Advanced Encryption Standard，AES），在密码学中又称 Rijndael 加密法，是美国联邦政府采用的一种加密标准。这个标准用来替代原先的 DES，已经被多方分析且广为全世界所使用。

（1）AES 选定过程

1997 年，美国国家标准技术研究所（National Institute of Standards and Technology，NIST）发起征集高级加密标准算法的活动，目的是为了确定一个非保密的、公开披露的、全球免费使用的分组密码算法，用于保护 21 世纪政府的敏感信息。AES 的基本要求是比三重 DES 快而且至少和三重 DES 一样安全，分组长度为 128 比特，密钥长度为 128/192/256 比特。

1998 年 8 月 20 日，NIST 召开了第一次 AES 候选会议，并公布了满足候选要求的 15 个 AES 候选算法。1999 年 3 月 22 日，召开了第二次 AES 候选会议，公开了第一阶段的分析与测试结果，从 15 个算法中选出了 5 个 AES 候选算法，分别是 Mars、RC6、Rijndael、Serpent 和 Twofish。2000 年 10 月 2 日，NIST 正式宣布 Rijndael 将作为 AES，理由是 Rijndael 更为安全，其能抵抗当前已知的攻击，对其最有效的攻击是穷举攻击；易于软、硬件实现，速度快；密钥建立时间短，灵敏性良好；内存要求低。

Rijndael 是具有可变分组长度和可变密钥长度的迭代分组密码。其分组长度和密钥长度均可独立地设定为 32 比特的任意倍数，最小值为 128 比特，最大值为 256 比特。为满足 AES 的要求，限定分组长度 128 比特，密钥长度为 128/192/256 比特，对应的轮数 r 分别为 10/12/14。

（2）AES 算法过程

设分组长度为 128 比特，密钥长度为 128 比特，输出 128 比特的密文。在这种情况下，128 比特的消息（明文或密文）分组被分成 16 个字节（一个字节是 8 比特）记为：

$$\text{输入分组}=m_0,m_1,\cdots,m_{15}$$

密钥分组也是这样，计为输入密钥$=k_0,k_1,\cdots,k_{15}$。

内部数据结构的表示是一个 4×4 矩阵。

$$\text{输入分组}=\begin{pmatrix} m_0 & m_4 & m_8 & m_{12} \\ m_1 & m_5 & m_9 & m_{13} \\ m_2 & m_6 & m_{10} & m_{14} \\ m_3 & m_7 & m_{11} & m_{15} \end{pmatrix}$$

$$\text{输入密钥}=\begin{pmatrix} k_0 & k_4 & k_8 & k_{12} \\ k_1 & k_5 & k_9 & k_{13} \\ k_2 & k_6 & k_{10} & k_{14} \\ k_3 & k_7 & k_{11} & k_{15} \end{pmatrix}$$

同 DES 一样，AES 算法也是由基本的变换单位——“轮”多次迭代而成。在消息分组长度和密钥分组均为 128 比特的最小情况下，轮数是 10。AES 中的轮变换记为 Round(State, RoundKey)，这里 State 是轮消息矩阵，既被看作是输入，也被看作是输出；RoundKey 是轮密钥矩阵，它是由输入密钥通过密钥表导出的。AES 算法结构可以使用图 7-3 表示。

除了最后一轮，每轮变换由 4 个内部函数组成，即字节替换、行位移变换、列混合变换以及轮密钥加，最后一轮中不使用列混合变换函数。这 4 个函数的主要功能如下。

① 字节替换函数：记为 SubBytes(State)，对 State 的每个字节做非线性代换。

② 行位移变换函数：记为 ShiftRows(State)，对 State 的行做置换，实际上重排了元素的位置而不改变元素本身。

③ 列混合变换函数：记为 MixColumns(State)，对 State 的列做运算，用 State 字节列的值进行数学域加和域乘的结果代替每个字节。

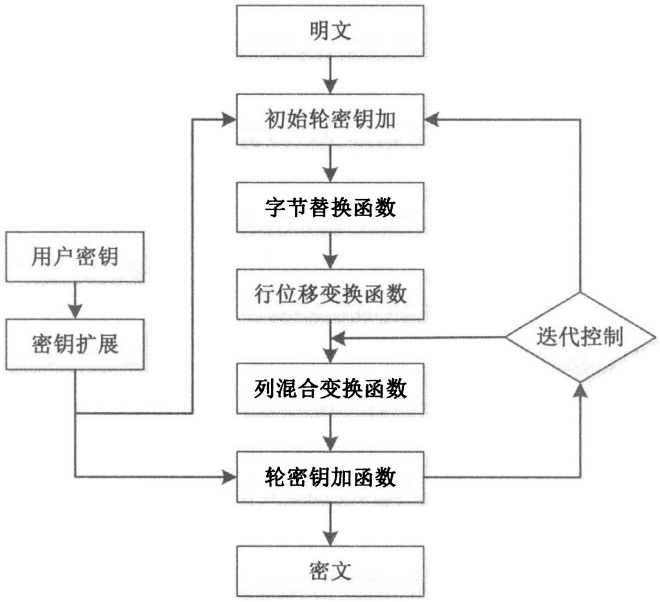

图 7-3　算法过程

④ 轮密钥加函数：记为 AddRoundKey(State,RoundKey)，逐字节、逐比特地将 RoundKey 中的元素与 State 中的元素相加。

4 个内部函数都是可逆的，因此解密仅仅是在相反的方向反演加密，也就是说，运行 AddRoundKey-1(State,RoundKey)、MixColumns-1(State)、ShiftRows-1(State)和 SubBytes-1 (State)。

4．其他算法

（1）RC4 算法

算法不对明文进行分组处理，而是字节流的方式依次加密明文中的每一个字节，解密的时候也是依次对密文中的每一个字节进行解密。算法密钥长度是可变的。

（2）BlowFish 算法

算法是一个 64 位分组及可变密钥长度的对称密钥分组密码算法，可用来加密 64 比特长度的字符串。该算法是非专利的。

（3）IDEA 算法

国际数据加密算法（International Data Encryption Algorithm，IDEA），使用 128 位的密钥和 8 个循环，它采用软件实现，和采用硬件实现同样快速。

7.1.3　非对称密码算法

非对称密码算法也称为公钥密码算法。针对传统对称密码体制存在的诸如密钥分配、密钥管理和没有签名功能等局限性，1976 年，W. Diffie 和 M.E. Hellman 提出了非对称密码

（公钥密码）的新思想。

1．算法特点

与对称密码体制不同，公钥密码体制是建立在数学函数的基础上，而不是基于替代和置换操作。在公钥密码系统中，加密密钥和解密密钥不同，由加密密钥推导出相应的解密密钥在计算上是不可行的。系统的加密算法和加密密钥可以公开，只有解密密钥保密。用户和其他 N 个人通信，只需要获得公开的 N 个加密密钥（公钥），每个通信方保管好自己的解密密钥（私钥），大大简化了密钥管理。同时，公钥密码体制既可用于加密，也可用于数字签名。

迄今为止，人们已经设计出许多公钥密码体制，如基于背包问题的 Merkle-Hellman 背包公钥密码体制、基于整数因子分解问题的 RSA 和 Rabin 公钥密码体制、基于有限域中离散对数问题的 ElGamal 公钥密码体制、基于椭圆曲线上离散对数问题的椭圆曲线公钥密码体制等。

公钥密码算法克服了对称密码算法的缺点，解决了密钥传递的问题，大大减少了密钥持有量，并且提供了对称密码技术无法或很难提供的认证服务（如数字签名），其缺点是计算复杂、耗用资源大，并且会导致密文变长。

关于公钥密码，有几种常见的误解。

（1）公钥密码更安全。任何一种现代密码算法的安全性都依赖于密钥长度、破译密码的工作量，从抗密码分析角度评估，没有一方更优越。

（2）公钥密码算法使得对称密码算法成为过时技术。公钥密码算法计算速度较慢，加密数据的速率较低，通常用于密钥管理和数字签名。实际应用中，人们通常将对称密码和公钥密码结合起来使用，对称密码算法将长期存在。

（3）使用公钥密码实现密钥分配非常简单。使用公钥密码也需要某种形式的协议，通常包含一个可信中心，其处理过程并不比传统密码的密钥分配过程更简单。

2．RSA 算法

RSA 公钥密码算法是以发明者 R.Rivest、A.Shamir 和 L.Adleman 的名字命名的，它的安全性是基于整数因子分解问题的困难性。RSA 算法是第一个能同时用于加密和数字签名的算法，易于理解和操作；是被研究得最广泛的公钥算法，经历了各种攻击的考验，逐渐为人们接受；也被普遍认为是目前最优秀、应用最广泛的公钥算法之一。

（1）RSA 算法描述

选取两个大素数 p 和 q，计算其乘积：$n=pq$ 和欧拉函数 $\phi(n)=(p-1)(q-1)$。然后随机选取加密密钥 e，$1<e<\phi(n)$，满足 e 和 $(p-1)(q-1)$ 互素。最后用欧几里得扩展算法计算解密密钥 d，以满足 $ed=1(\mathrm{mod}(p-1)(q-1))$，即

$$d=e-1\mathrm{mod}((p-1)(q-1))$$

其中，e 和 n 是公钥，d 和 n 是私钥。

RSA 算法对明文以分组为单位进行加密，每个分组的二进制均小于 n。即分组的大小

必须小于或等于 $\log_2(n)$ 位；在实际应用中，分组的大小是 k 位，其中 $2^k < n \leqslant 2^{k+1}$。对明文分组 M，加密过程如下：$C = M^e \bmod n$。对密文分组 C，解密过程如下：$M = C^d \bmod n$。

（2）RSA 算法举例

下面通过一个例子说明 RSA 算法加密和解密的过程。

① 选择两个素数，$p = 47$ 和 $q = 61$。

② 计算 $n = pq = 47 \times 61 = 2867$。

③ 计算 $\phi(n) = (p-1)(q-1) = 46 \times 60 = 2760$。

④ 选择 e 使其与 $\phi(n) = 2760$ 互素且小于 $\phi(n)$，这里选择 $e = 1223$。

⑤ 确定 d 使得 $de = 1 \bmod 2760$，$d = 167$。

通过以上计算可以得到 RSA 的公钥为 $\{e,n\} = \{1223,2867\}$，私钥 $\{d,n\} = \{167,2867\}$。

假设输入明文“RSA ALGORITHM”，把明文用两位二进制数字表示，空格=00，A=01，B=02，…，Z=26，把明文表示成一串十进制数的数据块，每块的值不超过 n-1，得到：1819 0100　0112　0715　1809　2008　1300。

利用加密变换，对每一数据块进行加密产生相应的密文块，例如：

$$
\begin{aligned}
C &= 1819^{1223} \bmod 2867 \\
&= 1819^{1024} \cdot 1819^{128} \cdot 1819^{64} \cdot 1819^{4} \cdot 1819^{2} \cdot 1819^{1} \cdot \bmod 2867 \\
&= 2756
\end{aligned}
$$

类似的，经过加密变换后可以得到整个密文：

2756　2001　0542　0669　2347　0408　1815

解密过程对每一密文块计算 $M = C^d \bmod n$，此处不再赘述。

（3）RSA 的安全性

密码分析者攻击 RSA 算法的关键点在于如何分解 n。若分解成功使 $n = pq$，则可以算出 $\phi(n) = (p-1)(q-1)$，然后由公开的 e，解出秘密的 d。攻破 RSA 与分解 n 是多项式等价的。因此产生密钥时，需要考虑两个大素数 p、q 的选取，以及 e 的选取和 d 的计算。

$n = pq$ 在体制中是公开的，因此为了防止敌手通过穷举搜索发现 p、q，这两个素数是在一个足够大的整数集合中选取的大数。寻找大素数时一般是先随机选取一个大的奇数，然后用素性检验算法检验这一奇数是否为素数，如果不是则选取另一个大奇数，重复这一过程，直到找到素数为止。RSA 算法从提出后，密码分析学家对其进行了大量抗攻击性分析。其中：

20 世纪 80 年代末，Rivest、Shamir 和 Adleman 找到了一个 129 位数（428bits）的两个素数的乘积，称为 RSA-129，设计了一套密钥向世界挑战。

1994 年 3 月，由 Lenstra 领导的一组数学家及世界各地 600 多个爱好者使用了 1600 台机器，花费了 8 个月的时间，分解出了这个数的两个素数因子，其中一个长 64 位，另一个长 65 位。

1999 年，阿姆斯特丹的国家数学与计算机科学研究所（CWI）属下的一个国际密码研究小组宣布，他们在破译 RSA 公钥密码系统使用的 155 位 RSA 密钥的竞赛中荣获冠军，

他们使用了一台克雷 900-16 超级计算机、300 台个人计算机以及专门设计的软件。2009 年 12 月，RSA-768 被分解（232 位的密钥）。

3．SM2 算法

SM2 是我国密码管理局于 2010 年 12 月 17 日发布（第 21 号）的国家密码标准，是基于 ECC（椭圆曲线密码算法）的公钥密码算法。

2017 年 10 月，我国 SM2 与 SM9 数字签名算法在第 55 次 ISO/IEC 信息安全分技术委员会（SC27）会议一致通过为国际标准，正式进入标准发布阶段。这两个数字签名机制为 ISO/IEC 14888-3/AMD1 标准研制项目的主体部分，是我国商用密码标准首次正式进入 ISO/IEC 标准，极大地提升了我国在网络空间安全领域的国际标准化水平。

由于 1024 位 RSA 算法面临严重的安全威胁及其他问题，我国密码管理部门决定采用 SM2 椭圆曲线算法替换 RSA 算法。SM2 算法在安全性、性能上都具有优势。

（1）SM2 算法原理

SM2 算法是由我国自主研发，其计算上比国际上公布的 ECC 算法复杂。SM2 算法采用的椭圆曲线方程为 $y^2 = x^3 + ax + b$。在 SM2 算法标准中，通过指定 a、b 系数，确定了唯一的标准曲线。同时，为了将曲线映射为加密算法，SM2 标准中还确定了其他参数，供算法程序使用。

这里不深入探讨椭圆曲线的数学理论，仅通过图示展示算法原理（见图 7-4）。选 a=−1，b=0，则椭圆曲线方程为 $y^2 = x^3 - x$。

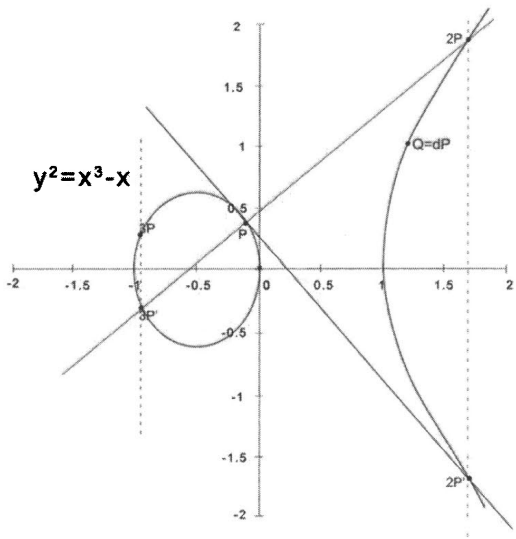

图 7-4　SM2 算法原理

① P 点为基点。

② 通过 P 点做切线，交于 $2P'$点，在 $2P'$点做垂线，交于 $2P$ 点，$2P$ 点即为 P 点的 2 倍点。

③ 进一步，在 P 点和 $2P$ 点之间做直线，交于 $3P'$点，在 $3P'$点做垂线，交于 $3P$ 点，$3P$ 点即为 P 点的 3 倍点。

④ 同理，可以计算出 P 点的 4、5、6、…、d 倍点。

⑤ 如果给定图上 Q 点是 P 的一个倍点，请问 Q 是 P 的几倍点呢?

⑥ 直观上理解，正向计算一个倍点是容易的，反向计算一个点是 P 的几倍点则困难得多。

在椭圆曲线算法中，将倍数 d 作为私钥，将 Q 作为公钥。当然，椭圆曲线算法还有更严格的计算过程，相对图示要复杂得多。

（2）SM2 算法应用

为保障重要经济系统密码应用安全，国家密码管理局于 2011 年发布了《关于做好公钥密码算法升级工作的通知》，要求：自 2011 年 3 月 1 日，在建和拟建公钥密码基础设施电子认证系统和密钥管理系统应使用 SM2 算法。自 2011 年 7 月 1 日起，投入运行并使用公钥密码的信息系统，应使用 SM2 算法。

SM2 算法是公钥算法，可以完成签名、密钥交换以及加密应用。目前在一些金融系统（如银行）得到广泛的应用。

（3）其他 SM 算法

为了保障商用密码安全，国家密码管理局还制定了一系列密码标准，包括 SM1、SM3、SM4、SM7、SM9 等。

- SM1：是对称算法。分组长度和密钥长度都为 128 位比特。采用该算法已经研制了智能 IC 卡、智能密码钥匙、加密卡等安全产品，广泛应用于电子政务、电子商务及国民经济的各个应用领域。
- SM3：是哈希算法。功能与 MD5、SHA-1 相同，产生 256 位的哈希值。该算法是不可逆的算法，适用于商用密码应用中的数字签名和验证，消息认证码的生成与验证以及随机数的生成，可满足多种密码应用的安全需求。
- SM4：是对称算法。分组长度和密钥长度都为 128 位比特，主要用于无线局域网产品。
- SM7：是对称算法。分组长度和密钥长度都为 128 位比特。该算法适用于身份识别类应用（如门禁卡、工作证、参赛证），票务类应用（如大型赛事门票、展会门票），支付一卡通类应用（如公交“一卡通”）等。
- SM9：是非对称算法。与 SM2 类似，实现数字签名、密钥交换协议以及密钥封装机制和公钥加解密。不同于传统意义上的 SM2 算法，可以实现基于身份的密码体制，也就是公钥与用户的身份信息即标识相关，省去了证书管理等。

4．其他公钥算法

（1）ElGamal 公钥密码算法

由 ElGamal 在 1985 年提出，其安全性基于求解离散对数困难问题，其修正形式已被美国国家标准技术研究所作为数字签名标准（Digital Signature Standard，DSS）。

（2）ECC 公钥密码算法

椭圆曲线密码算法，其安全性基于椭圆曲线点群上离散对数问题的难解性。ECC 是 RSA 强有力的竞争者。与 RSA 相比，有安全性能更高、计算量小、处理速度快、存储空间占用小和带宽要求低等优点。二者性能比较如表 7-1 所示。

表 7-1　ECC 和 RSA 性能比较

ECC 密钥长度（位比特）	RSA 密钥长度（位比特）	MIPS（年）
106	512	10^4
132	768	10^8
160	1024	10^{12}
211	2048	10^{20}
320	5120	10^{36}
600	21000	10^{78}
1200	120000	10^{168}

注：MIPS 表示用每秒完成 100 万条指令的计算机所需工作的年数。

7.1.4　其他密码服务

前面介绍的对称密码和非对称密码算法，主要是针对窃听、业务流分析等形式的威胁，解决消息的机密性问题。而实际的系统和网络还可能受到消息篡改、冒充和抵赖等形式的威胁，如何抵抗这些威胁，确保消息的完整性、真实性和不可否认性，就需要依靠其他的密码技术来实现。

1．哈希函数

哈希（Hash）函数也称单向散列函数，其主要用途是消息完整性检测和数字签名。使用哈希函数，可以获取消息的“指纹”，通过对比“指纹”，能够知道两条消息是否一致，就可以检查消息的完整性，判断消息是否被篡改。

哈希函数接受一个消息作为输入，产生一个称为哈希值的输出，也可称之为散列值、消息摘要（message digest）。更准确地说，哈希函数是将任意有限长度比特串映射为固定长度的串，形式如下：

$$h = H(M)$$

其中，M 是变长的报文，h 是定长的散列值。设 x、x' 是两个不同的消息，如果 $h(x) = h(x')$，则称 x 和 x' 是哈希函数 h 的一个（对）碰撞（collision）。对于任意给定的 x，$H(x)$的计算相对简单（易于软硬件实现）。安全的哈希函数需要满足以下性质。

- 单向性：对任意给定的码 h，寻求 x 使得 $h(x) = h$ 在计算上是不可行的。
- 弱抗碰撞性：任意给定分组 x，寻求不等于 x 的 y，使得 $H(y) = H(x)$ 在计算上不可行。

- 强抗碰撞性：寻求任何的(x, y)对，使得$H(x)=H(y)$在计算上不可行。

目前，常用的哈希函数有 MD5 和 SHA-1。

- MD5 算法：消息摘要算法（RFC1321），由 Ron Rivest 提出。该算法以一个任意长的消息作为输入，输出 128 位的消息摘要。
- SHA-1 算法：安全 Hash 算法（Secure Hash Algorithm，SHA），由美国标准与技术研究所设计并于 1993 年作为联邦信息处理标准（FIPS 180）发布，修改版于 1995 年发布（FIPS 180-1），通常称之为 SHA-1。SHA-1 算法的输入是长度小于2^{64}的任意消息x，输出 160 位的散列值。

2．消息认证码

在网络通信中，存在一些针对消息内容的攻击方法，如伪造消息、篡改消息内容、改变消息顺序、消息重放或者延迟。为防止这类攻击，可采用消息认证技术。消息认证是证实一个收到的消息来自可信的源点，且未被篡改、重放或延迟等的过程（完整性、真实性）。除哈希函数之外，消息认证码和数字签名都是常用的消息认证技术。

（1）基本特点

消息认证码也称消息鉴别码（Message Authentication Code，MAC），它利用密钥来生成一个固定长度的短数据块，并将该数据块附加在消息之后。在这种方法中假定通信双方，比如 A 和 B 共享密钥 K。若 A 向 B 发送消息，则 A 计算 MAC，它是消息和密钥的函数，即$\mathrm{MAC}=C_K(M)$。其中，M是输入的消息，C是 MAC 函数，K是共享密钥，MAC 表示消息认证码。消息和 MAC 一起被发送给接收方。接收方对收到的消息用相同的密钥K进行相同的计算得出新的 MAC，并将接收到的 MAC 与其计算出的 MAC 进行比较，如图 7-5 所示。

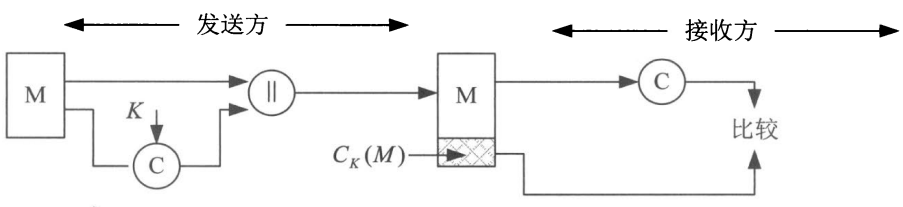

图 7-5　消息认证码工作流程

如果假定只有收发双方知道该密钥，那么若接收到的 MAC 与计算的 MAC 相等，则有：

- 接收方可以相信消息未被修改。即使攻击者改变了消息，也无法改变相应的 MAC，所以接收方计算出的 MAC 不等于接收到的 MAC。因为已经假定攻击者不知道密钥，所以他不知道应该如何改变 MAC 才能使其与修改后的消息相一致。
- 接收方可以相信消息来自真正的发送方。因为除发送方和接收方之外的其他方均不知道密钥，因此他们不能产生具有正确 MAC 的消息。
- 如果消息中含有序列号（如 HDLC、X.25 和 TCP 中使用的序列号），那么接收方可以相信信息顺序是正确的，因为攻击者无法成功地修改序列号。

（2）基本用法

消息认证码的基本用法有 3 种。

用法一：MAC 直接附加在消息之后，即 $A->B: M \| C_K(M)$。

MAC 基于 A 和 B 共享的密钥 K 生成。若 B 对收到的消息生成的 MAC 与收到的 MAC 相同，则可以确认消息一定来自 A，且未被篡改。这种方法不提供对消息的保密，如图 7-6 所示。

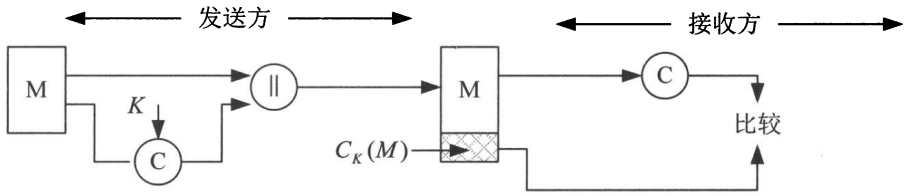

图 7-6　消息认证

用法二：MAC 直接附加在消息之后，并对整体进行加密，即 $A->B: E_{K_2}\left(M \| C_{K_1}(M)\right)$。

这里密钥 K_1 用于生成鉴别码，提供对消息的鉴别，消息的机密性由 A 和 B 共享的密钥 K_2 提供，如图 7-7 所示。

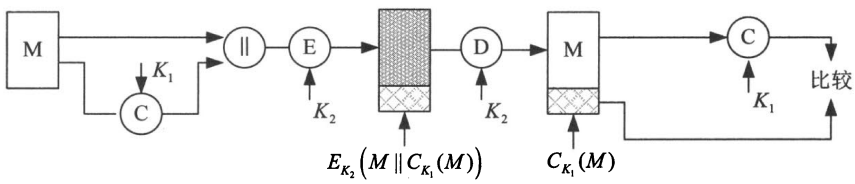

图 7-7　消息的认证及保密

用法三：先对消息加密，再对密文生成鉴别码，即 $A->B: E_{K_2}(M) \| C_{K_1}(E_{K_2}(M))$。

这种方法同时提供保密和鉴别，如图 7-8 所示。

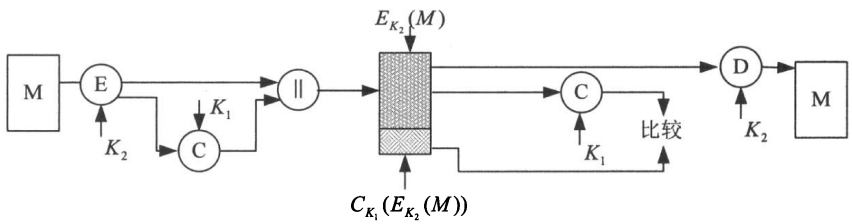

图 7-8　消息先保密后认证

（3）实现算法

生成消息鉴别码的算法有很多，如一种基于对称分组密码的消息鉴别码，称为密码分组链消息鉴别码（CBC-MAC），由国际标准 ISO/IEC 9797-1：1999 描述。它使用分组长度为 b 位的对称分组密码算法的 CBC（Cipher Block Chaining）工作模式对消息进行加密，并取最后一个密文分组最左边的 M 位作为 MAC 值，M 的大小可由通信双方约定。

另外一种是基于哈希函数的 MAC。HMAC 由国际标准 ISO/IEC 9797-2：2002 描述。HMAC 的基本观点是：使用哈希函数 H，K_1 和 K_2（$K_1 \neq K_2$）计算 $\mathrm{MAC}=H(K_1 \| H(K_2 \| m))$，其中 K_1 和 K_2 由同一个密钥 K 导出。

3．数字签名

消息鉴别用来保护通信双方免受第三方的攻击。然而，它无法防止通信双方的互相攻击。通信双方可能存在欺骗和抵赖，一种有效的解决方案是数字签名。数字签名是指附加在数据单元上的一些数据，或是对数据单元所做的密码变换，这种数据或变换能使数据单元的接收者确认数据单元来源和数据单元的完整性，并保护数据，防止被人伪造。数字签名是非对称密钥加密技术与数字摘要技术的应用。

（1）基本特性

数字签名具有以下特证。

① 不可伪造性：不知道签名者私钥前提下，攻击者无法伪造一个合法的数字签名，此性质使签名接收者可确认消息的来源。

② 不可否认性：对普通数字签名，任何人可用签名者公钥验证签名的有效性。由于私钥的私有性，签名者无法否认自己的签名。此性质使签名发送者无法否认是自己发出了消息。

③ 消息完整性：即消息防篡改，利用哈希函数对消息进行完整性鉴别，使得接收者能确保接收到的消息未经篡改。

（2）两种分类

按照对消息的处理方式，数字签名可分为两类：一种是直接对消息签名，它是消息经过密码变换后被签名的消息整体；另一种是对压缩消息的签名，它是附加在被签名消息之后或某一特定位置上的一段签名信息。

若按明文和密文的对应关系划分，以上每一种签名又可以分为两个子类：一类是确定性（Deterministic）数字签名，其明文与密文一一对应，对一个特定消息的签名，签名保持不变，如 RSA、Rabin 签名；另一类是随机化的或概率式数字签名，它对同一消息的签名是随机变化的，取决于签名算法中随机参数的取值。一个明文可能有多个合法数字签名，如 ElGamal 签名。

（3）应用示例

假设用户 A 要与用户 B 进行通信，为了保证传输信息的保密性、真实性、完整性和不可否认性，使用数字签名进行防护。

用户 A 的应用步骤如下。

① 用户 A 对需要发给用户 B 的消息（数据）进行哈希计算，得出传输数据的消息摘要（哈希值）。

② 用户 A 使用自己的私钥对消息摘要进行加密得到签名，并将签名附在数据上。

③ 用户 A 随机生成一个加密密钥对要发送的数据进行加密，得到密文。

④ 用户 A 使用用户 B 的公钥对刚才生成的加密密钥进行加密，将加密密钥与密文一

同发送给用户 B。

用户 B 的应用步骤如下。

① 用户 B 收到用户 A 传送来的密文和加密密钥，先用自己的私钥对加密的密钥进行解密，得到用户 A 随机产生的加密密钥。

② 用户 B 使用随机产生的加密密钥对收到的密文进行解密，得到明文的数字信息，然后将随机密钥抛弃。

③ 用户 B 使用用户 A 的公钥对数字签名进行解密，得到信息摘要。

④ 用户 B 用相同的哈希算法对收到的明文再进行一次哈希运算，得到一个新的信息摘要，将收到的用户 A 发送的消息摘要与由明文运算出来的消息摘要进行比较，如果一致，说明消息完整性没受到破坏。

7.1.5 公钥基础设施

公钥基础设施（Public Key Infrastructure，PKI），也称公开密钥基础设施。按照国际电联（International Telecommunications Union，ITU）制定的 X.509 标准，“PKI 是一个包括硬件、软件、人员、策略和规程的集合，用来实现基于公钥密码体制的密钥和证书的产生、管理、存储、分发和撤销等功能。”简单地说，PKI 是一种遵循标准，利用公钥加密技术提供安全基础平台的技术和规范，是能够为网络应用提供信任、加密以及密码服务的一种基本解决方案。PKI 的本质是实现了大规模网络中的公钥分发问题，为大规模网络中的信任建立基础。

1．PKI 架构

PKI 的组成一般包括证书权威机构（Certificate authority，CA）、证书注册机构（Registration Authority，RA）、证书库和终端实体等部分，如图 7-9 所示。

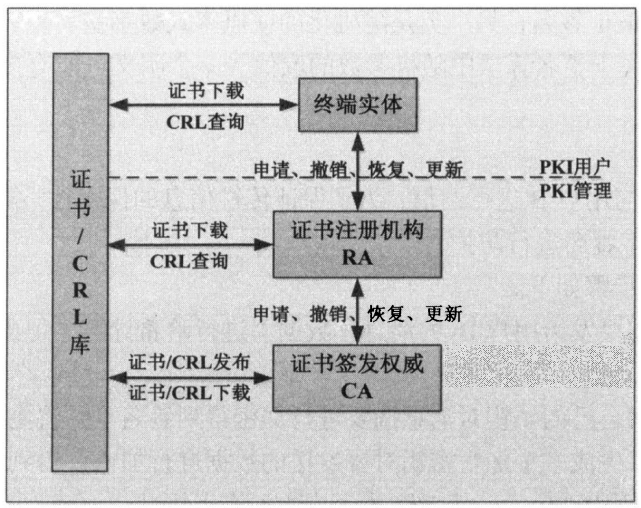

图 7-9 PKI 架构

图 7-9 中主要元素说明如下。

- CA：CA 是证书签发权威，也称数字证书管理中心，它作为 PKI 管理实体和服务的提供者，管理用户数字证书的生成、发放、更新和撤销等工作。
- RA：RA 是证书注册机构，又称数字证书注册中心，是数字证书的申请、审核和注册中心，同时也是 CA 认证机构的延伸。在逻辑上 RA 和 CA 是一个整体，主要负责提供证书注册、审核以及发证功能。
- 证书/CRL 库：证书/CRL 库主要用来发布、存储数字证书和证书撤销列表（Certificate Revocation List，CRL），供用户查询、获取其他用户的数字证书和系统中的证书撤销列表所用。
- 终端实体：指拥有公私密钥对和相应公钥证书的最终用户，可以是人、设备、进程等。

2. 数字证书

数字证书是一段电子数据，是经证书权威机构 CA 签名的、包含拥有者身份信息和公开密钥的数据体。由此，数字证书和一对公私钥相对应，而公钥以明文形式放到数字证书中，私钥则为拥有者所秘密掌握。因为经过了证书权威机构 CA 的签名，确保了数字证书中信息的真实性，数字证书可以作为终端实体的身份证明。在电子商务和网络信息交流中，数字证书常用来解决相互间的信任问题。可以说，数字证书类似于现实生活中的由国家公安部门发放的居民身份证。

（1）数字证书格式

国际标准 X.509 定义一个规范的数字证书格式，是 PKI 技术体系中应用最广泛、也是最基础的一个国际标准。许多与 PKI 相关的协议标准（如 PKIX、S/MIME、SSL、TLS、IPsec 等）都是在 X.509 基础上发展起来的。

在 X.509 标准中，数字证书主要包括 3 部分内容：证书体、签名算法类型以及 CA 签名数据，其中证书体包括以下内容。

- 版本号（Version）：标识证书的版本。
- 序列号（Serial Number）：由证书颁发者分配的本证书的唯一标识符，为一整数。
- 签名算法标识（Signature）：签署证书所用的算法及相应的参数，由对象标识符加上相关参数组成。
- 签发者（Issuer）：指建立和签署证书的 CA 名称。
- 有效期（Validity）：包括证书有效期的起始时间和终止时间。
- 主体名（Subject）：指证书拥有者名称。
- 主体的公钥（Subject Public Key Info）：包括证书拥有者的公钥。
- 发行者唯一识别符（Issuer Unique Identifier）：可选项，标识唯一的 CA。
- 主体唯一识别符（Subject Unique Identifier）：可选项，用来识别唯一的主体。
- 扩展域（Extensions）：其中包括一个或多个扩展的数据项，在第 3 版中开始使用。具体可包括 Authority 密钥标识符、主体密钥标识符、密钥使用用途、主体别名、

颁发者别名等。

（2）数字证书生命周期

数字证书的生命周期分为证书申请、证书生成、证书存储、证书发布、证书废止 5 个阶段。

- 证书申请：用户通过支持 PKI 的应用程序（如 Web 浏览器）向 CA 申请数字证书的过程，该过程从用户生成密钥对（公钥和私钥）时开始。
- 证书生成：一旦用户请求了证书，CA 就根据其建立的认证策略验证用户信息。如果确定信息有效，则 CA 创建该证书。
- 证书存储：CA 在生成用户证书之后，将通过安全的途径把证书发送给用户，或通知用户自行下载。数字证书将保存在用户计算机的安全空间里。为了防止证书的丢失或损坏，证书持有者应将证书导出并保存在安全的存储介质里，如软盘、智能卡。
- 证书发布：CA 在生成用户证书之后，会把用户的公钥发送到指定的任何资源库，如内部目录或公用服务器，以方便人们获得或验证证书持有者的公钥。
- 证书废止：当发出证书时，将根据分发策略为其配置特定的到期日。如果需要在该日期之前取消证书，则可以由 CA 将这一事实发布和分发到证书撤销列表 CRL 中。CRL 是由 CA 签名的一组电子文档，包括被撤销证书的唯一标识（证书序列号），CRL 为应用程序和其他系统提供了一种检验证书有效性的方式。

（3）数字证书分类

按照数字证书的拥有者来分，一般可以将数字证书分为人员证书、设备证书、机构证书等类型。按照数字证书的用途来分，数字证书可分为签名证书和加密证书，其中签名证书主要用于对用户信息进行签名，以保证信息的不可否认性；加密证书主要用于对用户传送信息进行加密，以保证信息的真实性和完整性。

3．CA

数字证书是各实体在网上进行信息交流及商务交易活动时的身份证明，具有唯一性和权威性。为满足这一要求，需要建立一个可信的机构，专门负责数字证书的产生、发放和管理，以保证数字证书的真实可靠，这个机构就是证书权威机构 CA。由此可见，CA 是 PKI 的核心组成部分，PKI 体系也往往称为 PKI/CA 体系。

（1）CA 主要功能

CA 是证书认证服务系统的核心业务节点，主要功能如下。

- 证书的签发和管理：接受终端实体证书申请，验证审查身份，生成数字证书，并负责数字证书的分发、发布、更新和撤销等。
- 证书撤销列表的签发和管理：CA 须发布和维护 CRL，将已作废的证书作为“黑名单”，连同作废原因一起发布到 CRL。
- 证书注册机构的设立、审核及管理：证书注册机构也称证书审核注册中心，是受 CA 委派的、负责和终端实体交互的、接受数字证书申请并进行审核的功能系统，

因此有时也称为用户注册系统。

（2）CA 逻辑结构

为便于 CA 进行数字证书的申请、签发、发布、更新以及撤销等全生命过程的管理，CA 内部各个系统在逻辑上可分为核心层、管理层和服务层三层，如图 7-10 所示。

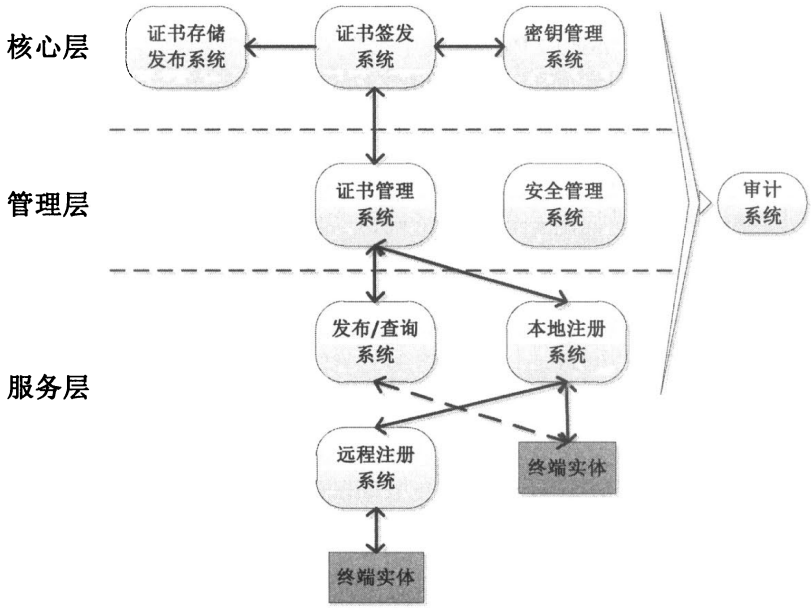

图 7-10　CA 逻辑结构

其中，核心层由密钥管理系统、证书签发系统、证书存储发布系统组成；管理层由证书管理系统和安全管理系统等组成；服务层由本地注册系统、远程注册系统和发布/查询系统等组成。

按照实际建设时的机构设置分，一个完整的证书认证服务系统一般采用层次的结构，即按照根 CA（Root CA，RCA）下设 CA、CA 下设子 CA（Subordinate CA，SCA）、SCA 下设 RA 这样的层次结构建设。为管理方便，且根据行业或地区进行划分，一个 RCA 可以下设多个 CA、一个 CA 可以管理多个 RA 等。通常根据系统建设规模大小，又可以灵活地设计为 RCA-CA-SCA-RA 四层结构、RCA-CA-RA 三层结构或 CA-RA 两层结构。

4．PKI 互操作模型

跨国、跨行业、跨地区间要开展安全电子业务，不同的 PKI 之间需要互联互通和相互信任。信任模型就是一个建立和管理信任关系的框架。信任模型描述了如何建立不同认证机构之间的认证路径以及构建和寻找信任路径的规则。

为描述互操作模型，先介绍和信任相关的基本概念。

- **信任**（Trust）：在 X.509 的 2000 版中对信任的定义为“一般说来，如果一个实体假定另一个实体会严格并准确地像它期望的那样行动，那么就称它信任那个实

体。”其中的实体是指在网络或分布式环境中具有独立决策和行动能力的终端、服务器或智能代理等。信任包含了双方的一种关系以及对该关系的期望。

- **信任域**（Trust Domain）：指一个组织内的实体在一组公共安全策略控制下所能信任的实体集合，简言之即信任的范围。公共安全策略是指系统颁发、管理和验证证书所依据的一系列规定、规则的集合。
- **信任锚**（Trust Anchor）：PKI 体系中信任的起点。
- **信任关系**：在公钥基础设施中，当两个认证机构中的一方给对方的公钥或双方给互相的公钥颁发证书时，两者之间就建立了信任关系。
- **信任路径**（Trust Path）：在一个实体需要确认另一个实体身份时，它先需要确定信任锚，再由信任锚找出一条到达待确认实体的各个证书组成的路径，该路径称为信任路径，通常也称信任链。实体之间的信任通过信任路径传递。

目前，常用的 PKI 互操作模型主要有以下几种结构：严格层次结构模型、网状信任结构模型、桥信任结构模型和混合信任结构模型、Web 模型和以用户为中心的信任模型。

（1）严格层次结构模型

严格层次结构模型是一种集中式的信任模型，又称树模型或层次模型。认证机构的严格层次结构模型是一颗树，它比较适合具有层次结构的机构，如军队、垂直性行业、学校等。在严格层次结构模型中，多级 CA 和最终用户构成一颗倒转的树，如图 7-11 所示表示了一个 4 层的严格层次结构模型。

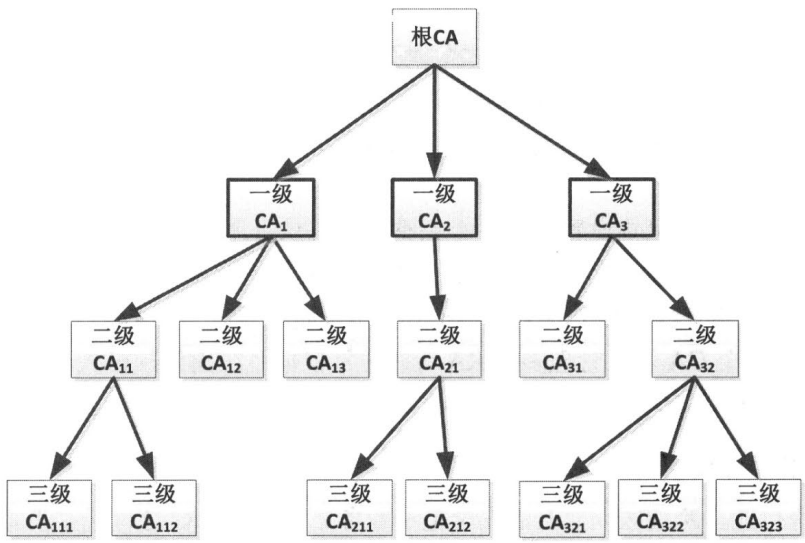

图 7-11　严格层次结构模型

假设实体 A 收到 B 的一个数字证书，而 A 和 B 的数字证书由不同的 CA 签发，则 A 验证 B 的数字证书时，须找到 B 数字证书中签发 CA 的信息，然后沿着层次树往上找，直到可以和 A 数字证书签发 CA 相同或处于 A 的 CA 的垂直上级 CA 时，方可以完成验证。从树的角度看，即 A 和 B 必须找到相同的祖先节点（中间 CA 或根 CA）才可以互相验证。

严格层次结构模型中信任建立在严格的层次机制上，优点是其结构与许多组织或单位的结构相似，容易规划；缺点是在不同单位的 CA 必须在一个共同的根 CA 管理之下，且根 CA 的建设会导致风险集中。

（2）网状信任结构模型

网状信任结构模型，也称分布式信任模型。与严格层次结构相反，网状信任结构把信任分散到两个或更多个 CA 上。在该结构中，每个终端实体都信任其证书签发 CA，而 CA 之间如果信任，则以点对点的方式签发证书来表示。网状信任结构模型的优点是结构灵活，扩展容易，适合动态变化的组织机构，单 CA 安全性的削弱不会影响整个 PKI 域的运行；缺点主要是证书路径的扩展与层次结构比较复杂，选择证书路径比较困难。网状信任结构模型如图 7-12 所示。

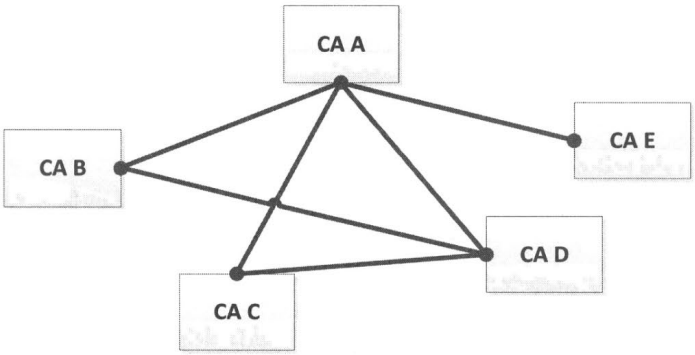

图 7-12　网状信任结构模型

（3）桥信任结构模型

桥信任结构模型也称中心辐射式信任模型。每个根 CA 都与单一的、用作相互连接的、处于中心地位的 CA 进行相互交叉认证，处于中心地位的 CA 称为桥 CA。任何结构类型的 PKI 都可以通过桥 CA 连接在一起，实现相互信任，每个单独的信任域可通过桥 CA 扩展到多个 CA 之间，如图 7-13 所示。

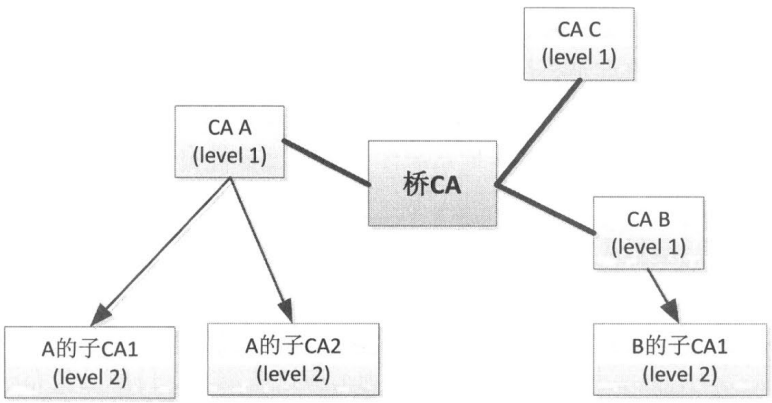

图 7-13　桥信任结构模型

（4）混合信任结构模型

由实际网络结构的复杂性决定了单一的某一类信任模型不能满足现实需要，通常采取混合信任模型来解决。将严格层次结构模型和网状信任结构模型结合起来，就是混合信任结构模型。该模型分为两个部分，一部分是在单一信任域内的信任结构，通常采用严格层次结构信任模型，另一部分是在多个信任域之间的信任模型，通常采用网状信任模型。在大型的域间采用网状信任模型，虽然有着很好的灵活性和可扩展性，但同时也会带来选择证书路径比较困难、证书路径比较复杂及信任度降低的问题。

5．PKI 应用与发展

随着网络应用技术的发展，作为一种基础设施，PKI 的应用范围非常广泛，如应用于虚拟专用网、安全电子邮件、Web 安全、电子商务/电子政务应用等。其中基于 PKI 技术的 IPSec 协议现在已经成为架构 VPN 的基础，它可以为路由器之间、防火墙之间或者路由器和防火墙之间提供经过加密和认证的通信。

通过 Web 进行的网上交易很容易带来网络欺诈、敏感信息泄露、信息篡改和拒绝服务攻击等安全问题。现在的标准浏览器都支持 SSL 协议。利用 PKI 技术，SSL 协议允许在浏览器和服务器之间进行加密通信。此外还可以利用数字证书保证通信安全，服务器端和浏览器端分别由可信的第三方颁发数字证书，这样在交易时，双方可以通过数字证书确认对方的身份。结合 SSL 协议和数字证书，PKI 技术可以保证 Web 交易多方面的安全需求。

随着 PKI 技术应用的不断深入，PKI 技术本身也在不断发展与变化。主要表现在以下几方面。

（1）属性证书

X.509 v4 增加了属性证书的概念，介绍属性证书离不开特权管理基础设施（Privilege Management Infrastructure，PMI）。PMI 技术的核心思想是以资源管理为核心，将对资源的访问控制权统一交由授权机构进行管理，即由资源的所有者来进行访问控制管理。

（2）漫游证书

证书应用的普及产生了证书的便携性需要，一个解决方案是使用漫游证书，它通过第三方软件提供，只需在任何系统中正确地配置，该软件（或者插件）就可以允许用户访问自己的公钥/私钥对。其原理是将用户的证书和私钥放在一个安全的中央服务器上，当用户登录到一个本地系统时，从服务器安全地检索出公钥/私钥对，并将其放在本地系统的内存中以备后用，当用户完成工作并从本地系统注销后，该软件自动删除存放在本地系统中的用户证书和私钥。

（3）无线 PKI（WPKI）

随着无线通信技术的广泛应用，无线通信领域的安全问题也引起了广泛的重视。将 PKI 技术直接应用于无线通信领域存在两方面的问题：其一是无线终端的资源有限（运算能力、存储能力、电源等）；其二是通信模式不同。为适应这些需求，目前已公布了 WPKI 草案，其内容涉及 WPKI 的运作方式、WPKI 如何与现行的 PKI 服务相结合等。

WPKI 中定义了 3 种不同的通信安全模式，在证书编码方面，WPKI 证书格式想尽量减少常规证书所需的存储量。采用的机制有两种：其一是重新定义一种证书格式，以此减少 X.509 证书尺寸；其二是采用 ECC 算法，减少证书的尺寸，因为 ECC 密钥的长度比其他算法的密钥要短得多。同时，互联网工程任务组（Internet Engineering Task Force，IETF）也在 WPKI PKIX 证书中限制了数据区的大小。

7.2 知识子域：身份鉴别

鉴别与访问控制是信息安全领域重要的基础知识之一。信息系统中要想实现安全目标，达到一定的防护水平，必须具备有效的鉴别与访问控制机制。下面在介绍标识、鉴别、访问控制等基本概念和常见的访问控制模型的基础上，描述典型标识与鉴别技术原理，以及典型的访问控制方法。

7.2.1 身份鉴别的概念

1. 标识与鉴别

标识是实体身份的一种计算机表达。信息系统在执行操作时，首先要求用户标识自己的身份，并提供证明自己身份的依据，不同的系统使用不同的方式表示实体的身份，同一个实体可以有多个不同的身份。鉴别是将标识和实体联系在一起的过程。鉴别是信息系统的第一道安全防线，也为其他安全服务提供支撑。访问控制机制的正确执行依赖于对用户身份的正确识别，标识和鉴别作为访问控制的必要支持，以实现对资源机密性、完整性、可用性及合法使用的支持。如果与数据完整性机制结合起来使用，可以作为数据源认证的一种方法。在审计记录中，一般需要提供与某一活动关联的确知身份，因此，标识与鉴别支持安全审计服务。

2. 鉴别的类型

在一个给定的网络中，客户 A 需要访问服务器 S 的服务，客户 A 必须被服务器鉴别，这个鉴别过程称为单向鉴别。如果客户 A 也需要鉴别服务器 S，则称为双向鉴别。还有一些情况要求由双方均信任的第三方进行鉴别，以确认用户和服务器的身份。

（1）单向鉴别

单向鉴别是当用户希望在应用服务器上注册时，用户仅需被应用服务器鉴别。通常是用户发送其用户名和口令给应用服务器，应用服务器对收到的用户名和口令进行验证，确认用户名和口令由合法用户发出。

（2）双向鉴别

双向鉴别是一种相互鉴别，其过程在单向鉴别的基础上还要增加两个步骤：服务器向客户发送服务器名和口令，客户确认服务器身份的合法性。

双向鉴别一般不常使用。假如有 50 个用户（或应用服务器），每个用户若均可与其他用户通信，则每个用户都应有能力鉴别其他用户。在双向鉴别的情况下，还应能被其他用户鉴别，这样每个用户需要保存 49 个口令。一旦用户增加、减少或改变口令，都要调整口令清单，管理烦琐且效率低。

（3）第三方鉴别

更为可靠的鉴别方法是可信第三方鉴别，第三方用于存储、验证标识和鉴别信息。每个用户或应用服务器都向可信第三方发送身份标识和口令，提高了口令存储和使用的安全性，并且具有较高的效率。

3．鉴别的方式

实体身份鉴别一般依据以下 3 种基本情况或这 3 种情况的组合：实体所知、实体所有和实体特征。

- 实体所知，即实体所知道的，如口令等。常常将一个秘密信息发送到系统中，该秘密信息仅为用户和系统已知，据此系统鉴别用户身份。
- 实体所有，即实体所拥有的物品，如钥匙、磁卡等，借助这些物品使系统鉴别用户。在鉴别时，用户手持这些物品，通过外围设备完成鉴别。
- 实体特征，即实体所拥有的可被记录并比较的生理或行为方面的特征，这些特征能被系统观察和记录，通过与系统中存储的特征比较进行鉴别。

多因素鉴别方法，使用多种鉴别机制检查用户身份的真实性。使用两种鉴别方式的组合（双因素鉴别）是常用的多因素鉴别形式。例如，在网上银行的转账验证时，必须同时使用用户名/密码（实体所知）和 USB Key（实体所有）才能完成一次转账验证。使用多因素验证能有效地提高安全性，降低身份滥用的风险。

7.2.2 基于实体所知的鉴别

使用可以记忆的秘密信息作为鉴别依据的方式是“实体所知”的鉴别，目前广泛采用的使用用户名和口令进行登录验证就是一种基于“实体所知”的鉴别方式。口令通常是由字母、数字和特殊字符组成的一串字符串。口令鉴别由于简单易行，并且实现成本低，被广泛地应用在各类商业系统中，为用户提供基础的安全防护。使用实体所知鉴别机制面临的安全问题是信息泄露和信息伪造。

1．口令破解攻击及防御措施

用户使用的鉴别依据（口令）通常由用户默认生成或由用户生成，为了记忆的方便，用户通常不对系统生成的默认口令进行更改或选择与自己相关的信息来设置口令，例如自己和亲人的生日、纪念日、电话号码甚至使用易于记忆的字符串。这种类型的口令虽然便于记忆，但容易猜测，对攻击者而言，使用这样的口令进行保护的系统是非常脆弱的。

表 7-2 所示为 2016 年弱口令 Top 10 排行榜。

表 7-2 2016 年弱口令 Top 10 排行榜

排 名	口 令
1	123456
2	123456789
3	qwerty
4	12345678
5	111111
6	1234567890
7	1234567
8	password
9	123123
10	987654321

穷举攻击是针对口令进行破解的一种方式，它通过穷举所有可能的口令的方法来进行攻击。假设某用户设置的口令是 7 位数字，那么最多存在 10^7 种口令。尽管一次猜对口令的可能性为千万分之一，但在现有网络计算环境中，猜测一个口令的投入很小，攻击者很容易做到利用软件连续测试 10 万、100 万，甚至 1000 万个口令，理论上，只要有足够的时间，所有口令都可以被破解。著名的密码破解软件 John 和 L0phtCrack，就是利用穷举方式对 Linux 和 Windows 系统中存储的口令散列值进行穷举破解。随着技术的发展，口令破解中使用口令字典以提高破解的效率已经成为主流，攻击者预先构建了用户经常会使用的各种口令，通常是英语单词、用户名+生日组合及其他可能的组合的口令字典。在攻击时使用口令破解软件，从口令字典中逐个选择一个口令进行尝试，如果口令错误，则选择下一个口令继续进行尝试，直到猜测成功或字典上所有口令被遍历。由于网络资源的廉价（想一下现在家用宽带每个月的费用），攻击者进行这种类型的攻击成本极低。攻击者只需要部署一台计算机，不停地针对目标账户进行登录尝试即可。

针对口令破解的防护措施：一是提高口令的强度，加大攻击者破解的时间和难度；二是阻止攻击者反复尝试的可能。

（1）提高口令的强度目标是确保密码具有足够的复杂性

在应用系统中设置安全策略，避免用户使用过于简单的口令。

对用户进行安全意识教育，使用户理解弱口令的安全风险并学会如何设置安全的口令。安全的口令通常包括以下两个特征：易于记忆，而且攻击者难以猜测。安全的口令应达到一定的长度，同时包含大写字母、小写字母、数字、特殊字符等，还要避免采用一些规律过于明显的组合。例如，口令 zaq12wsxZAQ!@WSX 看似复杂，但其键盘顺序规律过于明显，已经被很多攻击者列入常用攻击组合。

（2）阻止攻击者反复尝试的可能

在应用系统中设置策略，对于登录尝试达到一定次数的账户锁定一段时间或由管理员

解锁，避免攻击者反复登录尝试。

使用验证码等人工识别的因素以对抗反复的登录尝试，验证码应具有很好的抗机器识别的能力，并且人工识别相对容易。

图 7-14 所示为 12306 为对抗反复尝试登录使用的验证码技术。

图 7-14　12306 登录验证码

2．口令嗅探攻击及防御措施

由于早期采用的网络协议在网络上以明文（如 Telnet、FTP、POP3）或简单的编码（如 HTTP 采用的 BASE64）形式传输口令等，攻击者通过在会话路径中的任何节点部署嗅探器，就可以获得用户的口令。嗅探攻击的防御措施就是使用密码技术对传输数据进行保护，例如对传输中的口令进行加密，使得攻击者即使嗅探到了口令数据也无法获得口令的明文。

注：在实际应用中，存在大量应用系统使用 MD5 对口令明文进行处理，存储和传输的都是处理过的数据（通常称为密码散列），攻击者虽然无法从密码散列中还原出口令明文，但攻击者可以构造出一张对照表，将各种不同的口令的明文和散列建立对应关系，因此只要获得密码散列，就能根据对照表知道对应的口令明文，这样的对照表通常称为彩虹表。

3．重放攻击及防御措施

重放攻击又称重播攻击、回放攻击，是指攻击者发送一个目的主机已接收过的包，特别是在认证的过程中，用于认证用户身份所接收的包，来达到欺骗系统的目的，主要用于身份认证过程，破坏认证的安全性。对于传输的会话凭证（口令或 session 等），如果仅仅采取简单加密措施进行，避免攻击者获得信息，但缺乏有效的验证机制，攻击者可以记录下来，并且在稍后的验证过程中进行重放，系统无法区分这次发送的登录信息是攻击者还是合法用户，会允许攻击者的访问。重放攻击的防御措施包括以下方面。

（1）在会话中引入时间戳，由于时间戳的存在，攻击者的重放攻击会被系统拒绝。

（2）使用一次性口令。一次性口令即一个口令只使用一次，以确保在每次鉴别中所使用的口令不同，对付重放攻击。挑战-应答系统在某些场合使用一次性口令，此时，应答即口令，如果挑战不同，应答也不相同，每次应答都在使用后失效。使用一次性口令鉴别机制，发送方和验证方需要共同拥有一串随机口令，并在该串的某一位置保持同步，两方还要共同使用一个随机序列生成器，在该序列生成器的初态保持同步，同时，应维持两方时钟的同步。

（3）在会话中引入随机数。挑战-应答是一种有效的应对口令嗅探和重放攻击的鉴别方式，在挑战-应答过程中，用户和系统将协商一个秘密函数，鉴别时，系统首先发送一个挑战（随机数）M 给用户，用户使用秘密函数生成应答 N 返回给系统。此时，系统独立计算出一个 P，通过比较 N 和 P 是否一致判断用户的合法性。由于挑战过程中每次给出的 M 是随机生成的，因此可以有效地避免重放攻击和嗅探。

7.2.3　基于实体所有的鉴别

使用用户所持有的东西来验证用户的身份，也是采用较多的一种鉴别方法。用于鉴别的东西通常不容易被复制，具有唯一性。实体所有的鉴别方式是一种被长期使用的身份鉴别方式，古代军队调动时需要出示的虎符就是一种基于实体所有的鉴别，如图 7-15 所示。

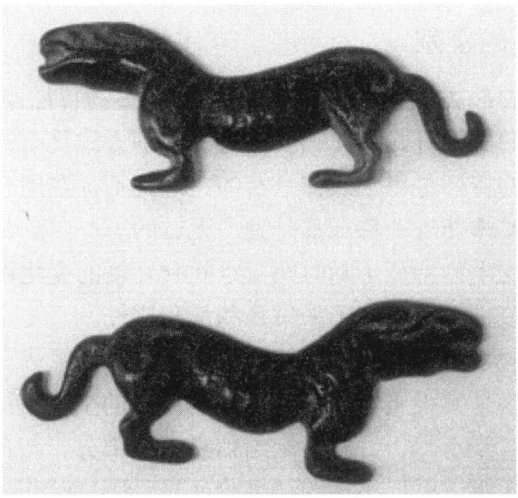

图 7-15　古代用于调兵的虎符

集成电路卡（Integrated Circuit Card，IC Card）是信息化时代广泛使用的“实体所有”鉴别物品。通过将一个专用的集成电路芯片镶嵌于符合 ISO 7816 标准的 PVC（或 ABS 等）塑料基片中，封装成外形与磁卡类似的卡片形式。当然也可以封装成纽扣、钥匙、饰物等特殊形状。IC 卡根据实现方式可以分为内存卡、安全卡、CPU 卡等不同类型。

- 内存卡（Memory Card）内嵌存储器用于存储各种数据，这类卡信息存储方便，使

用简单，价格便宜，很多场合可替代磁卡，但由于其本身不对存储的数据进行加密并且易于被复制，因此通常用于保密性要求不高的应用场合。例如单位门禁卡、企业的会员卡等。

- 安全卡（Security Card）也称逻辑加密卡，内嵌芯片对存储区域增加了控制逻辑，在访问存储区之前要核对密码。如果连续多次密码验证错误，卡片可以自锁，成为死卡。由于具有一定的安全功能，因此安全卡适用于有一定保密需求的场合，例如存储着储值信息的餐饮企业会员卡、电话卡、水电燃气等公共事业收费卡等。
- CPU 卡（CPU Card）也称智能卡（Smart Card），相当于一种特殊类型的单片机，在卡片中封装了微处理单元（CPU）、存储单元（RAM、ROM 等）和输入/输出接口，甚至带有双方单元和操作系统。CPU 卡具有存储容量大、处理能力强、信息存储安全等特点，因此被广泛用于保密性要求较高的场合，例如银行的信用卡等。

对于实体所有的鉴别机制的安全防护主要集中在用于鉴别的物品应不会被复制。IC 卡作为实体所有鉴别的实现方式，其安全防护主要是保证 IC 卡中存储和处理的各种信息不被非法访问、复制、篡改或破坏等。IC 卡的安全防护首先应确保自身的物理的安全，封装应坚固耐用，承受日常使用中各种可能导致卡片损坏的行为。其次是根据应用场景确保相应的逻辑安全措施得到落实，结合 PIN 码甚至其他技术实现对数据的安全防护，避免各类对数据的非法操作。对高安全要求的应用场景，使用高强度的加密算法对数据进行加密。

7.2.4 基于实体特征的鉴别

随着技术的成熟及硬件成本的不断下降，使用实体生物特征作为鉴别方式越来越广泛，与实体所知、实体所有的鉴别方式相比，实体特征鉴别方式具有以下特点。

- 普遍性：鉴别的特征是每个人都具有的，因此不存在遗忘等问题。
- 唯一性：每个实体拥有的特征都是独一无二的。
- 稳定性：实体的生物特征不随时间、空间和环境的变化而改变。
- 可比性：用于鉴别的特征易于采集、测量和比较。

实体特征鉴别系统通常由信息采集和信息识别两个部分组成。信息采集部分通过光学、声学、红外等传感器作为采集设施，采集待鉴别的用户的生物特征（如指纹、虹膜等）和行为特征（声音、笔迹、步态等），然后交给信息识别部分，与预先采集并存储在数据库中的用户生物特征进行比对，根据比对的结果验证是否通过验证。

1. 指纹、掌纹

指纹识别在所有生物特征识别中是最成熟、使用最广泛的技术。指纹是指尖表面的纹路，指纹识别主要利用纹路的起终点、中断处、分叉点、汇合点等的位置、数目和方向的分析比较来鉴别用户身份。指纹识别系统通过特殊的设备采集指纹信息，并将按照用户和姓名等信息存在指纹数据库中的模板指纹调出来，比较用户输入的指纹与模板的指纹是否匹配，以确定这两幅指纹是否出于同一幅指纹，从而判断用户身份的合法性。

掌纹识别技术实现上与指纹识别类似，区别在于使用手掌的纹理作为识别的依据。

2．静脉

静脉识别是最近几年开始出现的生物特征识别方式，通过静脉识别设备提取实体的静脉分布图，采用特定算法从静脉图中提取特征并与预先存储在数据库中的特征进行比对以判断是否通过验证。在实际应用中，使用较多的是指静脉和掌静脉。

3．面部识别

用人脸进行身份鉴别友好、方便，用户接受程度高，但识别的准确率要低于虹膜和指纹识别。人脸识别系统的主要工作是在输入的图像中准确定位人脸，抽取人脸特征，并进行匹配识别。目前，人面部的表情、姿态、妆容等的变化及采集图像时光线、角度、距离、遮挡等问题是影响人脸识别准确性的难题。

4．视网膜、虹膜、巩膜

视网膜是人眼感受光线并产生信息的重要器官，位于眼球壁的内层，是一层透明的薄膜。视网膜由色素上皮层和视网膜感觉层组成，视网膜识别是通过采集视网膜独特的特征用于鉴别的技术。

虹膜是一个位于瞳孔和巩膜间的环状区域，每一个虹膜都包含水晶体、细丝、斑点、结构、凹点、射线、皱纹和条纹等特征。虹膜在出生 6～18 个月成型后终生不再发生变化。虹膜识别系统用摄像机捕获用户眼睛的图像，从中定位虹膜，提取特征，并加以匹配判断。

巩膜识别也称眼纹识别，技术实现上与虹膜识别类似，不同的是使用巩膜（眼白）中的血管分布图作为识别的依据。人的眼球会因为过敏、红眼或者熬夜宿醉等情况发生充血的状况，但这些并不会影响虹膜上的血管排布，所以眼纹识别具有良好的稳定性。

5．语音识别

语音识别是利用发声者的发声频率和幅值来辨识身份的一种特征识别技术，在远程传递中具有明显优势。语音识别可以依赖特定文字识别，也可以不依赖特定文字识别。在依赖特定文字识别的方式中，通过发声者说某个或几个特定词语中的随机特性来识别其身份的真伪。采用这种识别方式的系统设计简单，易于实现，但安全性不高。在不依赖特定文字识别的方式中，允许发声者说任何词语，识别系统找出发声者发音中具有的共性特征，并进行识别。该方式防伪性较高，但系统设计和实现复杂，因为声音的变化范围大，环境、身体状态和情绪等因素均会影响语音识别系统的准确率。

由于生物识别技术的便利性及广泛的应用前景，头骨、耳朵、脑电波等越来越多的生物识别技术被开发出来。实体特征鉴别体系相对实体所知、实体所有的鉴别方式优势在于用于鉴别的特征难以复制，也不会遗失，然而用于识别的生理特征终身不变的特性也成为对应的安全风险，因为人们不可能改变其虹膜等生理特征。

6．实体特征鉴别的有效性判断

基于实体特征鉴别的设备通过扫描一个人的生理属性或行为特征，然后将它与早期特

征记录过程中建立的记录进行比较，这要求系统必须对人的生理或行为特点进行准确而重复性的测量。如某人视网膜中血管的变化或色调，还有声音的音色等，因为大多数人基本类似，生物识别方法通常导致负面的和不正确的认证。基于实体特征的设备通过检查它们产生的不同类型错误来衡量执行情况。

基于实体特征鉴别的设备拒绝一个已获授权的个人，这称为第一类错误，又称为错误拒绝率（False Rejection Rate，FRR）。如用户用他的指纹来认证自己时，系统不正确地拒绝他。

设备接受了一个本应该被拒绝的冒名顶替者，这称为第二类错误，也称为错误接受率（False Acceptance Rate，FAR）。如某黑客没有账户，但他用自己的指纹进行身份认证并且系统承认了他，这就是假正确身份认证。这类错误最为危险，因此必须严格避免。

许多基于实体特征鉴别的设备都能够灵敏地加以调整。当生物识别设备过于灵敏时，错误拒绝会更加常见。当设备不够敏感时，误报会更加常见。

可以通过交叉错误率（Crossover Error Rate，CER）比较设备的整体质量， 图 7-16 显示了当一台设备设置为不同灵敏度水平时，FRR 和 FAR 的百分比。FRR 和 FAR 比例相等的点是 CER，CER 作为标准的评估值来比较不同设备的精度。低 CER 的设备比高 CER 的设备更准确。

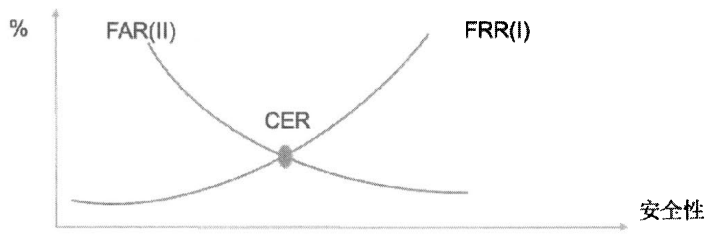

图 7-16　CER 点的 FRR 和 FAR 错误率

7.2.5　Kerberos 体系

1．单点登录

随着信息技术及其应用的不断普及，用户每天需要登录到许多不同的信息系统，如 Web 服务器、邮件服务器、数据库服务器及各种应用服务器等。传统的认证机制采用基于用户名/密码的分散管理，即用户通过网络世界的身份标识来访问各种资源，这些身份标识分别被每个系统保存，无法相互传递。因此，用户必须在每个系统中都有一组用户名和密码，在进入不同系统时都需要进行认证。一方面基于用户名/密码的认证方式安全强度不高，另一方面大量的用户名/密码给用户带来了额外的安全管理问题，为此，人们希望设计一种在网络资源使用过程中更为高效、安全并且简便的认证机制，单点登录技术由此产生。

单点登录就是指用户只需在网络中进行一次身份认证，便可以访问其授权的所有网络资源，而不再需要其他的身份认证过程，实质是安全凭证在多个应用系统之间的传递或共享。这里所指的网络资源可以是各种共享的硬件设备，也可以是各种应用程序和数据等。

单点登录系统把原来分散的用户认证信息集中起来管理，减轻了安全管理员的维护工

作，降低了出现错误的可能。用户不再需要每访问一次资源进行一次身份认证，提高了使用效率，而且单点登录多采用更为可靠的认证方式，增强了系统的整体安全性。

Kerberos 是目前使用广泛的单点登录协议之一，是 1985 年美国麻省理工学院在 Athena 项目中开发的认证协议，用于通信实体间的身份认证。Kerberos 在分布式身份认证领域广泛使用，目前已有 5 个版本，其中，V1～V3 是在实验室环境下开发的；V4 是 1988 年开发的第一个公开版本，并在一些 UNIX 系统中使用；V5 进一步对 V4 中的安全缺陷做了改进，并在 1994 年作为 Internet 标准草案公布。Kerberos 利用集中式认证取代分散认证，减轻服务器负担。它使用对称密码算法实现通过可信第三方的认证服务。

Kerberos 的运行环境由密钥分配中心（Key Distribution Center，KDC）、应用服务器和客户端 3 个部分组成。KDC 是整个系统的核心部分，负责维护所有用户的账户信息。KDC 提供认证服务（Authentication Server，AS）和会话授权服务（Ticket Granting Service，TGS）。AS 对用户的身份进行初始认证，若认证通过便给用户发放票据授权票据（Ticket Granting Ticket，TGT），用户使用该票据可访问 TGS，从而获得访问应用服务器时所需的服务票据（Service Ticket，ST）。应用服务器接受用户的服务访问请求，验证用户身份，并向合法用户提供所请求的服务。客户端在用户登录时发送各种请求信息，并接收从 KDC 返回的信息。

2. Kerberos 基本认证过程

Kerberos 基本认证过程可以分为 3 个阶段，分别由 3 组消息来完成。在介绍协议之前，首先给出相关符号定义。

- C（Client）：客户端。
- S（Server）：服务器。
- K_x：X 与 KDC 的共享密钥。
- $K_{x,y}$：X 和 Y 的会话密钥。
- $T_{x,y}$：X 使用 Y 时的凭据。
- A_x：X 的认证标记。
- N：一次性随机数。
- t：时间标记或序列号。

（1）第一阶段：获得票据许可票据

本阶段，用户登录客户端请求服务，认证服务器（AS）在数据库中验证用户的访问权限，生成票据许可票据和会话密钥，过程如图 7-17 所示。

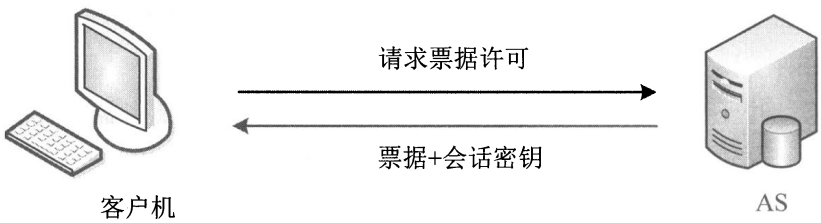

图 7-17　Kerberos 获取票据许可票据

首先，用户从客户端向 AS 发送包含用户名、服务器名和一个随机数 N 的消息 KRB_AS_REQ。

$C->AS:C,TGS,N$

AS 验证 C 的身份和访问权限后，随机生成一个加密密钥 $K_{c,tgs}$ 作为下一阶段客户方与 TGS 通信时使用的会话密钥，生成一个包含客户方、会话密钥以及开始和失效时间等信息的 TGT，用 TGS 的密钥进行加密。AS 将会话密钥和 N 用客户端的密钥 K_c 加密，并与 TGT 一起构成消息 KRB_AS_REP，发送给客户端。客户端通过用户口令变换出 K_c，获得会话密钥 $K_{c,tgs}$，根据 N 验证该消息是新鲜的，从而确信 TGT 是 AS 最新生成的。

$$AS->C:\{K_{c,tgs},N\}K_c,\{T_{c,tgs}\}K_{tgs}$$

（2）第二阶段：获得服务许可票据

客户端对收到的报文解密，然后将票据许可票据以及包含用户名称、网络地址和时间的鉴别符发往票据授权服务器 TGS，票据授权服务器 TGS 对票据和鉴别符进行解密，验证请求，然后生成请求服务许可票据，过程如图 7-18 所示。

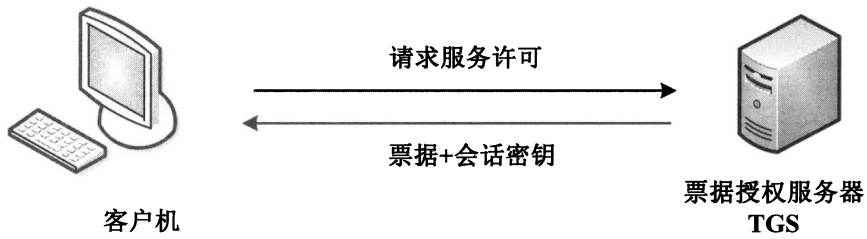

图 7-18　Kerberos 获得服务许可票据

客户端向 TGS 发送 TGT、需要访问的服务器名、保证消息新鲜的 N，以及用会话密钥签名的客户端认证信息，防止数据在传输过程中被篡改。每次客户端要访问某服务时，必须首先生成一个新的认证信息（鉴别符）。该信息由客户端生成，包含客户端名、主机地址，以及当前客户端主机时间，上述信息采用服务许可票据中给出的会话密钥加密，其结构为 $A_c=\{c,addr,timestamp\}K_{s,c}$。

服务许可票据用于在 AS 和应用服务器之间安全地传递凭据使用者的身份，同时也是将 AS 对票据使用者的信任转移给应用服务器。票据包含服务器名、客户端名、客户端地址、时间标记、生命期以及一个随机的会话密钥，这些信息使用接收票据的服务器与 KDC 共享的密钥进行加密，其结构为 $T_{c,s}=\{s,c,addr,timestamp,life,K_{s,c}\}K_s$。票据一旦发放，可以被其中指定的客户端向指定的服务器请求服务时多次使用，直到票据过期为止。

$$C->TGS:\{A_c\}K_{c,tgs},\{T_{c,tgs}\}K_{tgs}$$

TGS 用 K_{tgs} 验证了 TGT 后，获得会话密钥和客户端要访问的服务器名，从数据库中获得服务器密钥 K_s 后，随机生成客户端与服务器之间通信用的会话密钥和服务许可票据。TGS 将客户与服务器之间使用的新的会话密钥和 N 用 $K_{c,tgs}$ 加密后与新的服务许可凭据一

起构成消息 KRB_TGS_REP，发送给客户端。

TGS–>C:$\{K_{c,s},N\}K_{c,tgs},\{T_{c,s}\}K_s$

（3）第三阶段：获得服务

客户机将服务许可票据和认证信息发送给服务器，服务器验证票据和认证信息中的相匹配，允许访问服务。如果需要双向鉴别，服务器返回一个认证信息，过程如图 7-19 所示。

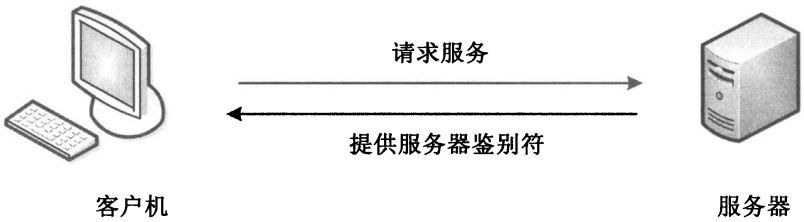

图 7-19　Kerberos 获得服务

经过前两个阶段后，客户端获得了与服务器进行通信所需要的服务许可票据和会话密钥。客户端向服务器发送认证信息，并提交服务许可票据。服务器通过解密获得客户端的时间标记或序列号，同时将这些信息用会话密钥加密后发送回客户端。客户端保留最近接收到的时间标记或者序列号的最大值，以防止重放攻击。

C–>S:$\{A_c\}K_{c,s},\{T_{c,s}\}K_s$

S–>C:$\{t\}K_{c,s}$

Kerberos 认证系统虽然在网络环境中有着广泛的应用，但也存在一定的局限性。首先，协议中的认证信息依赖于时间标记来实现抗重放攻击，这要求使用该协议进行认证的计算机需要实现时间同步，严格的时间同步需要有时间服务器，因此，时间服务器的安全至关重要。其次，协议认证的基础是通信方均无条件信任 KDC，一旦其安全受到影响，将会威胁整个认证系统的安全，同时，随着用户数量的增加，这种第三方集中认证的方式容易形成系统性能的瓶颈。

7.2.6　认证、授权和计费

随着网络的兴起，网络服务提供者多采用认证、授权和计费（Authentication、Authorization、Accounting，AAA）进行远程集中访问控制。其中，认证是指网络服务提供者在用户申请使用网络资源时鉴别该用户的身份；授权是指网络服务提供者允许用户接入，并以特定的方式使用其资源；计费是网络系统收集、记录用户对网络资源的使用情况，向用户收取资源使用费，同时也用于用户行为的审计。AAA 一般采用客户/服务器结构，客户端运行于被管理一方，服务器统一管理用户信息。

1．RADIUS

远程用户拨号认证服务（Remote Authentication Dial In User Service，RADIUS）最初由

Livingston 公司提出，用来为拨号用户进行认证和计费，经多次改进，形成了一项通用的认证协议，可用于多种用户接入方式，如以太网接入、ADSL 接入等。该协议运行于 UDP 之上，1812 为认证端口，1813 为计费端口。

用户登录路由器或接入服务器等网络设备时，首先将用户名和口令发送给网络设备。网络设备中的RADIUS客户端根据获取的用户名和口令,向RADIUS服务器发送认证请求。服务器接收到用户信息后，将该用户信息与用户数据库中的信息进行对比分析。在传输过程中，所有用户密码均加密传送。如果认证成功，则将用户的权限信息以认证响应包发送给 RADIUS 客户端；如果认证失败，则返回拒绝响应包。客户端根据接收到的认证结果接入/拒绝用户。如果可以接入用户，则 RADIUS 客户端向 RADIUS 服务器发送计费开始请求包，服务器返回计费开始响应包。访问结束，RADIUS 客户端向服务器发送计费停止请求包，服务器返回计费结束响应包。

RADIUS 协议实现简单，传输简捷高效，能支持多种认证方式，得到广泛的应用。RADIUS 协议仅对传输过程中的密码本身进行加密，而其他部分都以明文传输，对敏感信息不能进行有效地保护，安全性不高。

2．TACACS+

终端访问控制器访问控制系统（Terminal Access Controller Access-Control System，TACACS）由 RFC1492 定义，标准的 TACACS 协议只认证用户是否可以登录系统，目前已经很少使用。TACACS+协议由 Cisco 公司提出，主要应用于 Cisco 公司的产品中，运行于 TCP 协议之上。TACACS+协议分为认证和授权两个不同的过程。

在认证过程中，客户机发送一个 START 包给服务器，包的内容包括执行的认证类型、用户名等信息。START 包只在一个认证会话开始时使用一次，序列号永远为 1。服务器收到 START 包以后，回送一个 REPLY 包，表示认证继续还是结束。如果认证继续，REPLY 包将指出还需要提交哪些新信息。如果客户机收到认证结束的 REPLY 包，则认证结束；如果收到认证继续的 REPLY 包，则向服务器发送 CONTINUE 包，其中包括服务器要求的信息，如此反复，直到认证结束。

TACACS+授权过程分为两步。首先，客户端向服务器发送一个 REQUEST 包，内容包括请求授权的服务和选项等。服务器回复客户端一个 RESPONSE 包。

由于在传输层上使用 TCP 协议对其数据包进行封装和传输，TACACS+具有较高的传输可靠性。该协议还能对除数据包头外的所有数据包信息加密，保证了通信安全。TACACS+协议采用了重传机制，在大型网络中，实时性较差。

7.3 知识子域：访问控制

在信息系统中，访问控制是重要的安全功能之一。它的任务是在为用户对系统资源提供最大限度共享的基础上，对用户的访问权进行管理，防止对信息的非授权篡改和滥用。

访问控制对经过身份鉴别后的合法用户提供所需要的且经过授权的服务，拒绝合法用户越权的服务请求，拒绝非法用户非授权访问，保证用户在系统安全策略下有序工作。

7.3.1　访问控制模型的基本概念

一个信息系统在进行安全设计和开发时，必须满足某一给定的安全策略，即有关管理、保护和发布敏感信息的法律、规则和实施细则。例如，将系统的用户和信息划分为不同的等级，用户能读信息，当且仅当用户的等级高于或等于信息的等级；用户能写信息，当且仅当用户等级低于或等于信息的等级。

访问控制模型是对安全策略所表达的安全需求的简单、抽象和无歧义的描述，可以是非形式化的，也可以是形式化的，它综合了各种因素，包括系统的使用方式、使用环境、授权的定义、共享的资源和受控思想等。访问控制模型通过对主体的识别来限制对客体的访问权限，具有以下 3 个特点。

- 精确的、无歧义的。
- 简单的、抽象的，容易理解。
- 只涉及安全性质，不过多牵扯系统的功能或其实现细节。

主体是使信息在客体间流动的一种实体。通常，主体是指人、进程或设备等，例如对文件进行操作的用户是一种主体；用户调度并运行的某个进程是一种主体；调度一个例程的设备也是一种主体。在计算机系统中，用户首先在系统中注册，然后启动某一进程并使该进程为用户完成某项工作，该进程继承了启动它的用户的属性，如访问权限等，这时，与用户相对应的进程也是一种主体。

客体是一种信息实体，或者是从其他主体或客体接收信息的实体。通常，数据块、存储页、文件、目录、程序等都属于客体。在系统中，文件是一个处理单位的最小信息集合，每一个文件就是一个客体，如果每个文件还可以分成若干小块，而每个小块又可以单独处理，那么每个小块也是一个客体。

主体接收客体相关信息和数据，也可能改变客体相关信息。一个主体为了完成任务，可以创建另外的主体，这些子主体可以独立运行，并由父主体控制它们。客体始终是提供、驻留信息或数据的实体。主体和客体的关系是相对的，角色可以互换。

访问权限是指主体对客体所执行的操作。文件是系统支持的最基本的保护客体。常见的文件访问模式如下。

- 读：允许主体对客体进行读访问操作。
- 写：允许主体对客体进行修改，包括扩展、收缩及删除。
- 执行：允许主体将客体作为一种可运行文件而运行。
- 拒绝访问：主体对客体不具有任何访问权。

此外，目录也是常见的保护客体。目录常作为结构化文件或结构化段来实现。对目录的访问模式可以分为读和写。

- 读：允许主体看到目录实体，包括目录名、访问控制表以及该目录下的文件与目录的相应信息。
- 写：允许主体在该目录下增加一个新的客体。也就是说，允许主体在该目录下生成与删除文件或子目录。

访问控制的实施一般包括两个步骤：第一步，鉴别主体的合法身份；第二步，根据当前系统的访问控制规则授予用户相应的访问权。访问控制过程如图 7-20 所示。首先主体向访问控制实施部件提交访问请求，收到主体的访问请求后，访问控制实施部件将该请求提交给访问控制决策部件，访问控制决策部件依据请求中的主体、客体和访问权判断是否允许授权。如果依据当前访问控制规则，允许该授权，则将决策结果返回访问控制实施部件，访问控制实施部件向客体提出访问请求，主体执行对客体的授权访问。如果拒绝该授权，则访问控制实施部件拒绝主体提交的访问请求，主体不执行对请求客体的操作。

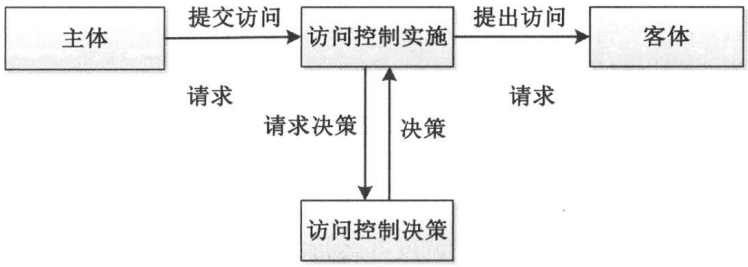

图 7-20　访问控制过程

7.3.2　自主访问控制模型

自主访问控制（Discretionary Access Control，DAC）是应用很广泛的访问控制方法。用这种控制方法，资源的所有者，往往也是创建者，可以规定谁有权访问它们的资源。这样，用户或用户进程就可以有选择地与其他用户共享资源。它是一种对单个用户执行访问控制的过程和措施。

DAC 可为用户提供灵活调整的安全策略，具有较好的易用性和可扩展性，具有某种访问能力的主体能够自主地将访问权的某个子集授予其他主体，常用于多种商业系统中，但安全性相对较低。因为在 DAC 中主体权限较容易被改变，某些资源不能得到充分保护，不能抵御特洛伊木马的攻击。

1．访问控制矩阵

DAC 可以用访问控制矩阵来表示，如图 7-21 所示。矩阵中的行表示主体对所有客体的访问权限，列表示客体允许主体进行的操作权限，矩阵元素规定了主体对客体被准予的访问权。某一主体要对客体进行访问，访问前，访问控制机制要检查访问控制矩阵中主、客体对应的访问权限，以决定主体对客体是否可以进行访问，以及可以进行什么样的访问。访问控制的基本功能就是对用户的访问请求做出“是”或“否”的回答。

目标 / 用户	目标 x	目标 y	目标 z
用户 a	R、W、Own		R、W、Own
用户 b		R、W、Own	
用户 c	R	R、W	
用户 d	R	R、W	

图 7-21　访问控制矩阵

2．访问控制功能

DAC 通常使用访问控制表或能力表来实现访问控制功能。

访问控制矩阵按列读取即形成访问控制表，如图 7-22 所示，ACL 可以决定任何一个特定的主体是否可对某一个客体进行访问。它是利用在客体上附加一个主体明细表的方法来表示访问控制矩阵的。表中的每一项包括主体的身份以及对该客体的访问权。例如对某文件的访问控制表，可以存放在该文件的文件说明中。该表包含此文件的用户身份、文件属主、用户组，以及文件属主或用户组成员对此文件的访问权限。如果采用用户组或通配符的概念，ACL 不会很长。目前，访问控制表是自主访问控制实现中比较好的一种方法。

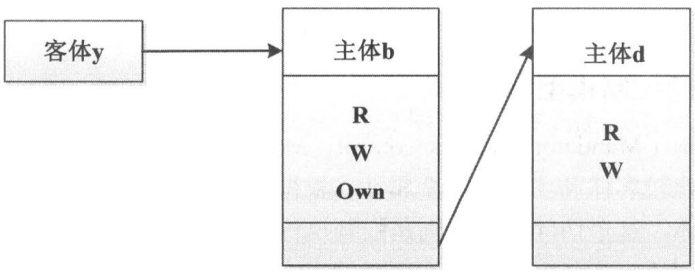

图 7-22　ACL 的结构

能力（Capabilities）决定用户对客体的访问权限（读、写、执行），在这种方式下，系统必须对每个用户维护一份能力表，即按行读取访问控制矩阵，表示每个主体可以访问的客体及权限，如图 7-23 所示。用户可以将自己的部分能力，例如读写某个文件的能力传给其他用户，这样那个用户就获得了读写该文件的能力。在用户较少的系统中，这种方式比较好，但一旦用户数增加，便要花费系统大量的时间和资源来维护系统中每个用户的能力表。

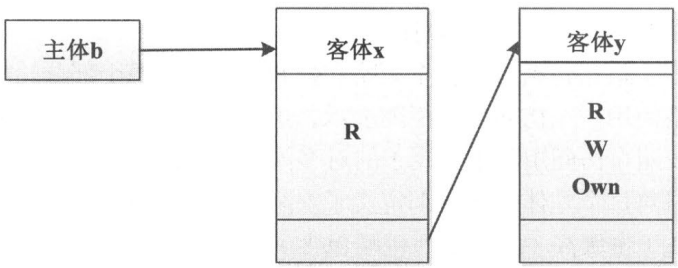

图 7-23　CL 的结构

3．访问许可和访问模式

在访问控制矩阵模型中，访问许可和访问模式描述了主体对客体所具有的访问权与控制权。访问许可定义了改变访问模式的能力或向其他主体传递这种能力的能力，访问模式则指明主体对客体可进行的特定访问操作，如读、写、运行等。这两种能力是对自主访问控制机制的控制方式。

访问许可可以允许主体修改客体的访问控制表，因此利用它可以实现对自主访问控制机制的控制。在自主访问控制机制中，有 3 种基本的控制模式：等级型、有主型和自由型。

在等级型访问许可下，可以将对修改客体访问控制表的能力的控制组织成等级型的，一个简单的例子是将控制关系组织成一个树型的等级结构。等级型结构的优点是可以通过选择值得信任的人担任各级领导，使我们可以用最可信的方式对客体实施控制；缺点是会同时有多个主体有能力修改它的访问控制表。

有主型是对客体设置一个拥有者，它是唯一有权访问客体访问控制表（ACL）的主体。拥有者对其拥有的客体具有全部控制权，但无权将客体的控制权分配给其他主体。目前，这种控制方法已应用于许多系统中，如 UNIX 系统等。

在自由型中，一个客体的生成者可以对任何一个主体分配对它拥有的客体的访问控制表的修改权，并且还可以使其对其他主体具有分配这种权力的能力。

7.3.3 强制访问控制模型

强制访问控制（Mandatory Access Control，MAC）是主体和客体都有一个固定的安全属性，系统通过比较客体和主体的安全属性，根据已经确定的访问控制规则限制来决定主体是否可访问客体。这个访问控制规则是强制执行的，系统中的主体和客体均无权更改。

强制访问控制比自主访问控制具有更高的安全性，能有效防范特洛伊木马，也可以防止在用户无意或不负责任的操作时泄露机密信息，适用于专用或安全性要求较高的系统。但是这种机制也使用户自己受到限制，例如，在用户共享数据方面不灵活。因此，保护敏感信息一般使用 MAC，须对用户提供灵活的保护，更多地考虑共享信息时，使用 DAC。

1．BLP 模型

Bell-LaPadula 模型，简称 BLP 模型，是 D.Elliott Bell 和 Leonard J.LaPadula 于 1973 年提出的一种模拟军事安全策略的计算机访问控制模型，它是最早也是最常用的一种多级访问控制模型，该模型用于保证系统信息的机密性。

BLP 模型的安全策略包括自主安全策略和强制安全策略两个部分。

自主安全策略使用一个访问控制矩阵表示，矩阵中的元素表示主体对客体所有允许的访问模式，主体按照在访问矩阵中被授予的对客体的访问权限对客体进行相应的访问。

强制安全策略对每个主体和客体都定义了安全级，安全级由密级和范畴构成。安全级之间存在支配关系（密级高于或等于、范畴包含）。

BLP 模型基于以下两个规则保障数据的机密性。

- 简单安全规则：当主体的安全级可以支配客体的安全级，且主体对客体有自主型读权限时，主体可以读客体。
- *-规则：当客体的安全级可以支配主体的安全级，且主体对客体有自主型写权限时，主体可以写入客体。

BLP 模型可有效防止低级用户和进程访问安全级别更高的信息资源，同时，安全级别高的用户和进程也不能向安全级别低的用户和进程写入数据，从而有效地保护机密性。

BLP 模型也存在一些局限性。例如，在主体创建客体时，将客体的安全级定义为该主体的安全级，在实际应用中，上级常常要向下级下发文件，这就需要允许系统的安全员对该客体的安全级进行降级定义；又如，内存管理必须允许所有级别进行读和写，解决方法是通过将其抽象化，并且假设内存管理是“可信主体”，但这将导致真实系统信息的泄露。在文件管理方面，假设一个高安全级用户建立了一个名为“代理商”的文件，而低安全级用户也在做同样的事情。如果采用 BLP 模型的操作系统阻止了他，那么，将会泄露系统中有一个具有高密级且名为“代理商”的文件。如果操作系统允许低安全级用户进行此项操作，又将会出现两个同名文件。这种问题经常通过惯例命名来解决，即分别给高安全级用户和低安全级用户分配不同的目录。

2. Biba 模型

1977 年，Biba 对系统的完整性进行了研究，提出了一种与 BLP 模型在数学上对偶的完整性保护模型——Biba 模型。

Biba 模型要求对主、客体按照完整性级别进行划分。完整性级别由完整等级和范畴构成，同样存在支配关系（完整等级高于或等于，范畴包含）。

Biba 模型基于以下两条规则确保数据的完整性。

（1）当且仅当客体的完整性级别支配主体的完整性级别时，主体才具有对客体“读”的权限，即“不下读”。

（2）当且仅当主体的完整性级别支配客体的完整性级别时，主体才具有对客体“写”的权限，即“不上写”。

Biba 模型能很好地满足政府和军事机构关于信息分级的需求，防止非授权用户的修改。

3. Clark-Wilson 模型

Clark-Wilson 模型是一个确保商业数据完整性的访问控制模型，由计算机科学家 David D.Clark 和会计师 David R.Wilson 发表于 1987 年，并于 1989 年进行了修订。如果说 BLP 模型更注重于军事领域的计算机应用的话，Clark-Wilson 模型则偏重于满足商业应用的安全需求。

在商业应用环境中，最关心系统数据的完整性以及对这些数据操作的完整性。数据的完整性是指，如果数据满足给定的条件，则称数据处于一个一致性状态，在每次操作前和操作后，数据都必须满足这个一致性条件。系统的一个事务处理就是一系列操作，使系统从一个一致性状态转移到另一个一致性状态。数据操作的完整性是指，需要有人检查和验

证事务处理是否被正确执行，一个事务需要两个或两个以上的不同的人来执行，如果要使用一个事务处理来破坏数据，必须有两个不同的人员犯错，或者他们合谋担保该事务处理已被正确实现。

（1）Clark-Wilson 模型定义

Clark-Wilson 模型将数据划分为两类：限制数据项（Constrained Data Items ，CDI）和非限制数据项（Unconstrained Data Items，UDI），CDI 是需要进行完整性控制的客体，而 UDI 则不需要进行完整性控制。

Clark-Wilson 模型还定义了两种过程：一个是完整性验证过程（Integrity Verification Procedure，IVP），确认限制数据项处于一种有效状态，如果 IVP 检验 CDI 符合完整性约束，则称系统处于一个有效状态；另一个是转换过程（Transformation Procedure，TP），将数据项从一种有效状态改变至另一种有效状态。

为了达到并保持完整性，Clark-Wilson 模型提出了证明规则和实施规则，证明规则由管理员来执行，实施规则是由系统执行。

① 证明规则 1（CR1）：当任意一个 IVP 在运行时，它必须保证所有的 CDI 都处于有效状态。

② 证明规则 2（CR2）：对于某些相关联的 CDI 集合，TP 必须将那些 CDI 从一个有效状态转换到另一个有效状态。

③ 实施规则 1（ER1）：系统必须维护所有的证明关系，且必须保证只有经过证明可以运行该 CDI 的 TP 才能操作该 CDI。

④ 实施规则 2（ER2）：系统必须将用户与每个 TP 及一组相关的 CDI 关联起来。TP 可以代表相关用户来访问这些 CDI。如果用户没有与特定的 TP 及 CDI 相关联，那么这个 TP 将不能代表那个用户对 CDI 进行访问。

⑤ 证明规则 3（CR3）：被允许的关系必须满足职责分离原则所提出的要求。

⑥ 实施规则 3（ER3）：系统必须对每一个试图执行 TP 的用户进行认证。

⑦ 证明规则 4（CR4）：所有的 TP 必须添加足够多的信息来重构对一个只允许添加的 CDI 的操作。

⑧ 证明规则 5（CR5）：任何以 UDI 为输入的 TP，对于该 UDI 的所有可能值，只能执行有效的转换，或者不进行转换。这种转换要么是拒绝该 UDI，要么是将其转换为一个 CDI。

⑨ 实施规则 4（ER4）：只有 TP 的证明者可以改变与该 TP 相关的一个实体列表。TP 的证明者，或与 TP 相关的实体的证明者都不会有对该实体的执行许可。

（2）Clark-Wilson 模型分析

Clark-Wilson 模型确保完整性的安全属性如下。

① 完整性：确保 CDI 只能由限制的方法来改变并生成另一个有效的 CDI，该属性由规则 CR1、CR2、CR5、ER1 和 ER4 来保证。

② 访问控制：控制访问资源的能力由规则 CR3、ER2 和 ER3 来提供。

③ 审计：确定 CDI 的变化及系统处于有效状态的功能由规则 CR1 和 CR4 来保证。

④ 责任：确保用户及其行为唯一对应由规则 ER3 来保证。

4．Chinese Wall 模型

Chinese Wall 模型由 Brewer 和 Nash 提出，是一种同等考虑保密性和完整性的访问控制模型，主要用于解决商业应用中的利益冲突问题，它在商业领域的应用与 BLP 模型在军事领域的作用相当。

与 BLP 模型不同的是，访问数据不是受限于数据的属性（密级），而是受限于主体已经获得了对哪些数据的访问权限。Chinese Wall 模型的主要设计思想是将一些可能会产生访问冲突的数据分成不同的数据集，并强制所有主体最多只能访问一个数据集，而选择访问哪个数据集并未受强制规则的限制。

在 Chinese Wall 模型中，客体分为无害客体和有害客体两种。其中，无害客体为可以公开的数据，有害客体为会产生利益冲突，需要限制的数据。与某家公司相关的所有客体组成了公司数据集（Company Dataset，CD），若干相互竞争的公司的数据集形成利益冲突类（Conflict of Interest Class，COI）。设 COI（O）表示包含客体 O 的 COI 类，CD（O）表示包含客体 O 的公司数据集，假设每个客体只属于某一个 COI 类。PR（S）表示主体 S 曾经读取过的客体集合。

Chinese Wall 模型也有两种安全特性，分别是 CW-简单安全特性和 CW-*-特性。

CW-简单安全特性：S 能读取 O，当且仅当以下任一条件满足。

（1）存在一个 O’，它是 S 曾经访问过的客体，并且 CD（O’）= CD（O）。

（2）对于所有的客体 O’，O’ ∈ PR（S），则 COI（O’）≠ COI（O）。

（3）O 是无害客体。

假设系统中保存了银行-A、石油公司-A 和石油公司-B 的信息，一个新用户可以自由选择访问 3 个公司数据集之一。在计算机系统中，一个不拥有任何信息的新用户不会存在任何冲突。

假设这个新用户首先访问了石油公司-A 的数据集，则该用户目前拥有了石油公司-A 的信息。稍后，该用户请求访问银行-A 的数据集，由于银行-A 和石油公司-A 分属于不同的利益冲突组，所以不会发生冲突，故被允许访问。但是，如果请求访问石油公司-B 的数据集，将会被拒绝，因为两个石油公司的数据集是冲突的。

需要注意的是，用户访问银行-A 与访问石油公司-A 数据集的顺序无关，而访问石油公司-A 与石油公司-B 数据集的顺序将会导致结果的不同。在该例中，当用户拥有{"石油公司-B"，"银行-A"}时，则访问石油公司-A 的请求将被拒绝，相反地，当用户拥有{"石油公司-A"，"银行-A"}时，则访问石油公司-B 的请求将被拒绝。

在第一次选择时，用户完成了对所喜爱的信息的自由访问，于是，围绕着该用户所拥有信息的 Chinese Wall 已经建成，可以认为在墙外的任何数据集均与墙内的数据集同属于一个利益冲突组。这时，用户仍然可以自由访问那些与墙内信息分属于不同利益冲突组的

信息，但是选择一旦做出，Chinese Wall 会立即针对新的数据集修改形状。可以看出，Chinese Wall 的安全策略是一种自由选择与强制控制的绝妙组合。

综上所述，如果被访问的客体属于以下两种情况，访问将可以进行。

- 与主体曾经访问过的信息属于同一个公司数据集，即在墙内的信息。
- 属于一个完全不同的利益冲突组。

有时，在同一个利益冲突组中的公司数据集之间，会出现间接信息流。例如，有两个用户 User-A 和 User-B，User-A 访问了银行-A 和石油公司-A 的信息，而 User-B 访问了银行-A 和石油公司-B 的信息。如果 User-A 从石油公司-A 中读取数据并写入银行-A 中，则 User-B 便能够读取石油公司-A 的数据。由于石油公司-A 和石油公司-B 同属于一个兴趣冲突组，所以，这种情况是不允许发生的。以上操作的结果已经间接破坏了 Chinese Wall 的安全策略。为了防止以上情况的出现，CW-*-特性对写访问做如下规定。

CW-*-特性：S 能写 O，当且仅当以下任两个条件同时满足。

（1）CW-简单安全特性允许 S 读 O。

（2）对于所有有害客体 O'，S 能读取 O'，则 CD（O'）= CD（O）。

Chinese Wall 模型通常用于证券交易或者投资公司的经济活动等应用中，其目的是为了防止利益冲突的发生，例如，交易员代理两个客户投资，并且这两个客户的利益相互冲突，利用该模型的安全策略，可以防止交易员为了帮助其中一个客户盈利，而导致另一个客户损失。

7.3.4 基于角色的访问控制模型

随着计算机的广泛应用，特别是计算机在商业和民用领域的应用，安全需求变得越来越多样化，自主访问控制和强制访问控制难以适应，基于角色的访问控制（Role-based Access Control，RBAC）成为安全领域的一个研究热点。

在一个基于角色的访问控制中，根据公司或组织的业务要求或管理要求，在系统内设置了若干个“角色”。所谓角色，用一般业务系统中的术语来说，实际上就是业务系统中的岗位、职位或者分工。例如，在一个公司内，财会主管、会计、出纳、核算员等每一种岗位都可以设置多个职员具体从事该岗位的工作，因此它们都可以视作角色。管理员负责掌管对系统和数据的访问权限，将这些权限（不同类别和级别的）分别赋予承担不同工作职责的用户，并随时根据业务的要求或变化对角色的存取权限进行调整，包括对可传递性的限制。

在基于角色的访问控制中，要求明确区分权限（Authority）和职责（Responsibility）。例如，在有数个保密级别的系统内，访问权限为 0 级的某个官员，并不能访问所有保密级别为 0 的资源，0 级是他的权限，而并不是其职责。再如，一个用户或操作员可能有权访问资源的某个集合，但是不能涉及有关授权分配等工作；而一位主管安全的负责人可以修改访问权限，可以分配授权给各个操作员，但是不能同时具备访问/存取任何数据资源的权限。

1．基于角色的访问控制模型的构成

迄今为止，已经讨论和发展了 4 种基于角色的访问控制模型，图 7-24 给出了它们之间的相互关系。RBAC0 是基本模型，规定了所有 RBAC 系统所必需的最小需求。RBAC1 在 RBAC0 的基础上增加了角色等级的概念。RBAC2 则在 RBAC0 的基础上增加了约束。RBAC3 包含了 RBAC1 和 RBAC2，也间接包含了 RBAC0。

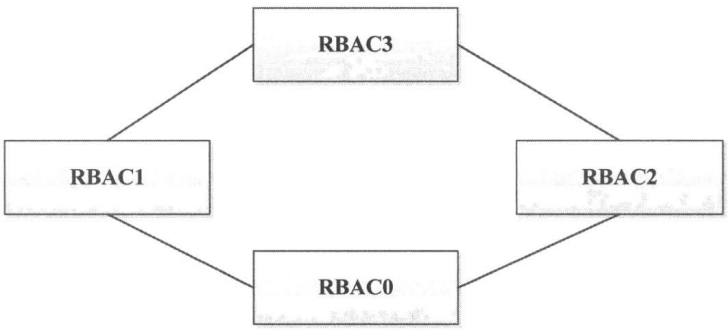

图 7-24　RBAC 家族系列关系示意图

（1）RBAC0

RBAC0 由 4 个基本要素构成，即用户（U）、角色（R）、权限（P）和会话（S）。用户为系统的使用者；角色是根据系统不同工作岗位需求而设置的；权限是系统中所有访问权限的集合；会话是系统对用户一次请求的执行，每个会话由一个用户建立。

在 RBAC0 中，用户与角色、角色与权限均为多对多的关系，用户对权限的执行必须通过角色来关联，以实现对信息资源访问的控制。用户与会话是一对多的关系，会话是一个用户对多个角色的映射，即一个用户激活某个角色子集。此时，用户的权限为激活的多个角色权限的并集。一个用户可以同时拥有多个会话，每个会话又具有不同的许可。

RBAC0 模型定义如下。

① U 表示用户集，R 表示角色集，P 表示权限集，S 表示会话集。

② $PA \subseteq P \times R$，是权限到角色的多对多指派关系。

③ $UA \subseteq U \times R$，是用户到角色的多对多指派关系。

④ $user:S \to U$，是会话到用户的映射函数，$user(s_i)$ 表示创建会话 s_i 的用户。

⑤ $roles:S \to 2^R$，是会话到角色子集的映射函数，$roles(s_i)$ 表示会话 s_i 对应的角色集合 $roles(s_i) \subseteq \{r \mid (user(s_i), r) \in UA\}$。

⑥ 会话 s_i 具有的权限集 $P_{si} = \bigcup_{r \in roles(si)} \{p \mid (p,r) \in PA\}$。

系统初始化时，PA 和 UA 由安全管理员进行配置，配置 PA 意味着系统为每一个角色分配相应的操作权限，配置 UA 表示系统为每一个用户指定相应的角色身份。如果系统安全需求发生变化，安全管理员可修改 PA 和 UA 的配置，以及 U、R 和 P 的值。

$user:S \to U$ 表示每一个会话是由哪个用户创建的，用户创建一个会话，系统就会激活他所拥有的角色集的一个子集，即 $roles(s_i)$。会话 s_i 具有的权限集 P_{si} 是这个子集中所有角

色的权限的集合。

（2）RBAC1

RBAC1 包含 RBAC0 的所有元素，并加入了角色等级的概念。在一个机构中，不同的职务或角色不但具有不同的权力，这些权力之间还存在包含关系，职务越高，权力越大。RBAC1 用偏序关系来描述角色之间的等级关系，高级别角色包含低级别角色的权限。利用角色等级的概念，可以实现多级安全中的访问控制。

在多级安全控制系统内，存取类的保密级别是线性排列的。例如：

公开 < 秘密 < 机密 < 绝密

其中，安全策略的一个要求就是：要想合法地获得信息，提出存取请求的人员的存取类级别要高于信息的存取类级别。RBAC1 中支持的层次关系可以容易地实现多级安全系统所要求的保密级别的线性排列要求。

多级安全系统的另一个要求就是要能够支持范畴，为了获得信息的存取权，提出存取请求的人员必须具备一定的存取类，其存取类的范畴的集合应该包括信息存取类的全部范畴。角色的层次结构 RBAC1 中的角色可以容易地实现所要求的保密存取类的范畴的要求。

（3）RBAC2

RBAC2 包含 RBAC0 的所有元素，并加入了约束的概念。在绝大多数组织中，除了角色的层次关系以外，经常要考虑的问题类似于下列情况：一个公司的采购员和出纳员虽然都不算是高层次的角色，但是，任何一个公司都绝不会允许将这两个角色同时分配给某一个具体人员。因为很显然，这种工作安排必然导致欺诈行为的发生。不论一个具体的系统中是否具备等级角色的机制，约束机制都是很重要的。它是制定高层安全策略的有效机制，特别是在分布式的系统中，安全管理员可将它作为强制要求。通常情形下，约束作用于 PA 和 UA，也可以作用在会话的 user 和 roles 函数上。

最常见的约束条件就是互斥约束，一个用户在两个互斥的角色集中，只能分配给其中一个集合中的角色。与角色互斥相似的是权限的互斥机制。例如，签字权，在任何实际的业务系统中都是非常重要的一个授权过程，而审计权一般都只授予会计主任角色。简言之，对 PA 的约束可以防止系统内的重要特权被失控地分散，从而保证了强制控制的可靠实施。

有时可以对角色附加数量的约束，例如某个岗位只允许安排两个用户。这样系统管理员在执行 UA 时就受到公司规定的有效的约束。

此外，可以对角色施加前提约束，即某个用户被指派为角色 A 的前提条件是已经被指派为角色 B。例如要扮演董事长的角色，必须先要被选入董事会；要成为项目的测试组成员，必须要首先成为项目的成员。实际情况中类似的约束条件一般都是对有一定业务联系或关系的角色起作用。对用户指派的约束机制有一个弱点，即对同一个用户如果给予了两个以上的用户 ID，系统是很难做出逻辑合理的判断的，系统对用户指派所做的约束安排就会失效。

（4）RBAC3

RBAC3 结合了 RBAC1 和 RBAC2，同时具备角色等级和约束，但角色等级和约束之

间存在一些矛盾。例如，测试工程师和程序员角色是互斥的，项目管理角色同时具有测试工程师和程序员角色的权限，违反了角色约束的互斥性。一般情况下，高级角色违反这种约束是可以接受的，而在其他情形下，则需要考虑这种排斥。在角色数量限制中也存在类似问题。例如，一个用户只能指派到最多一个角色中，项目管理的用户指派到他的下级角色就违反了这一约束。因此，在应用 RBAC3 时，需要根据系统的实际安全需求来制定合理的约束。

2．基于角色的访问控制模型分析

在基于角色的访问控制中，将若干特定的用户的集合和某种授权连结在一起，即与某种业务分工，例如岗位、工种等相关联的授权连结在一起。这样的授权管理比对个体的授权来说，可操作性和可管理性都要强得多。因为角色的变动远远低于个体的变动，因此该模型的一个主要优点就是简单。

使用 RBAC 可以较好地支持最小特权原则，使得分配给角色的权限不超过具有该角色身份的用户完成其任务所必需的权限，当用户请求访问某资源时，如果其操作权限不在用户当前被激活角色的授权范围内，访问请求将被拒绝。RBAC 还能实施职责分离原则，即利用互斥角色约束，控制用户的权限，通过激活相互制约的角色共同完成一些敏感任务，以减少完成任务过程中可能发生的欺诈行为。

此外，该模型在不同的系统配置下可以显示不同的安全控制功能，既可以构造具备自主存取控制类型的系统，也可以构造成为强制存取控制类型的系统，甚至可以构造同时兼备这两种存取控制类型的系统。

美国国家标准技术研究所（NIST）对 28 个组织进行的调查结果表明，基于角色的访问控制的功能相当强大，能满足许多类型用户的需求，从政府机构到商业应用。同时，它也非常适用于数据库系统，因为在这类系统中角色的逻辑意义更为明显和直接。

7.3.5　特权管理基础设施

用户在访问应用系统时必须要能控制：访问者是谁，能访问哪些资源。这两项控制检查措施必须在用户进入应用系统时进行检查。其中，前一项——“访问者是谁”对应的是用户的身份认证问题，后一项——“能访问哪些资源”对应的是授权权限问题。为了解决这个问题，特权管理基础设施（Privilege Management Infrastructure，PMI）应运而生，即提供了一种在多应用环境中的权限管理和访问控制机制，将权限管理和访问控制从具体应用系统中分离出来，使得访问控制机制和应用系统之间能灵活而方便地结合。

1．PMI 主要功能

PMI 是与应用相关的授权服务管理基础设施，其主要功能包括以下方面。

（1）对权限管理进行了系统的定义和描述。

（2）系统地建立起对用户身份到应用授权的映射。

（3）支持应用访问控制。

简单地说，PMI 能提供一种相对独立于应用的有效的体系结构，在应用资源和用户身份及访问权限之间建立对应关系，支持应用权限的有效管理和访问控制，以保证用户能获取他们有权获取的信息、做有权限操作。

PMI 建立在 PKI 提供的可信的身份认证服务的基础上，采用基于属性证书（Attribute Certificate，AC）的授权模式，为应用提供用户身份到应用权限的映射功能。PMI 和 PKI 之间的主要区别在于：PMI 主要进行授权管理，证明这个用户有什么权限，能干什么，即“你能做什么”；PKI 主要进行身份鉴别，证明用户身份，即“你是谁”。两者之间的关系，通常使用护照和签证的关系来表述，护照是身份证明，可以用来唯一标识个人信息；而签证具有属性类别，同一个护照可以有多个国家的签证，能在指定时间进入对应的国家。

2．PMI 体系架构

PMI 是属性证书、属性权威、属性证书库等部件的集合体，用来实现权限和属性证书的产生、管理、存储、分发和撤销等功能。其主要组件包括信任源点（SOA）、属性权威机构（AA）、属性注册权威机构（ARA）、用户以及证书库等。

（1）SOA

SOA 是特权管理基础设施的信任源点，是整个授权系统最高管理机构，相当于 PKI 系统中的根 CA，对整个系统特权分发负有最终的责任。SOA 的主要职责是授权策略的管理、应用授权受理、AA 的设立审核及管理等。

（2）AA

特权管理基础设施的核心服务节点，是对应于具体应用系统的授权管理分系统，由各应用部门管理，SOA 授权给它管理一部分或全部属性的权力。AA 中心的职责主要包括应用授权受理。可以有多个层次，上级 AA 可授权给下级 AA，下级可管理的属性的范围不能超过上级。

（3）ARA

ARA 和 RA 的位置类似，ARA 是 AA 的延伸，主要负责提供属性证书注册、审核以及分发功能。

（4）用户

用户指使用属性证书的终端实体，也称特权持有者。

（5）证书/ACRL 库

主要用于发布 PMI 用户的属性证书以及属性证书的撤销列表 ACRL，以供查询使用。在 PMI 和 PKI 一起建设时，也可以直接使用 PKI 的 LDAP 作为 PMI 的证书/CRL 库。

3．属性证书

PMI 使用属性证书表示和容纳权限信息，对权限生命周期的管理是通过管理证书的生命周期实现的。属性证书是一种轻量级的数据体，这种数据体不包含公钥信息，只包含证

书持有人 ID、发行证书 ID 签名算法、有效期、属性等信息。属性证书的申请、签发、注销、验证流程对应着权限的申请、发放、撤销和使用验证的过程。

相比较，公钥证书是将一个标识和公钥绑定，以此表明用户的身份；而属性证书则是将一个标识和一个角色、权限或者属性通过数字签名进行绑定，以此表明用户的角色、权限或者属性。和公钥证书一样，属性证书能被分发和存储或缓存在非安全的分布式环境中，具有不可伪造、防篡改的特性。

4．应用结构

PMI 基于 PKI 建设，在应用中也和 PKI 一起为应用程序提供安全支撑，其中 PKI 可以很好地为应用解决用户身份认证的问题，而 PMI 则可以很好地解决应用访问控制的问题。两者和应用系统结合的逻辑结构如图 7-25 所示。

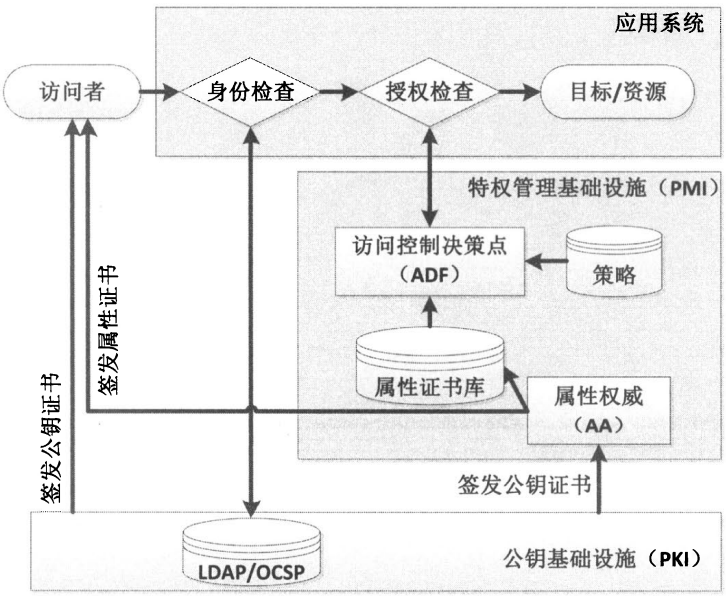

图 7-25　PKI/PMI 应用逻辑结构

图 7-25 中各部分说明如下。

（1）访问者、目标

访问者是一个实体（该实体可能是人，也可能是其他计算机实体），它试图访问应用系统内的其他目标（资源）。

（2）策略

授权策略展示了一个机构在信息安全和授权方面的顶层控制、授权遵循的原则和具体的授权信息。在一个机构的 PMI 应用中，策略应当包括一个机构将如何将它的人员和数据进行分类组织，这种组织方式必须考虑到具体应用的实际运行环境，如数据的敏感性，人员权限的明确划分，以及必须和相应人员层次相匹配的管理层次等因素。所以，策略的制定是需要根据具体的应用量身定做的。

（3）授权检查

授权检查，即访问控制执行点（Access Control Enforcement Function，AEF），在应用系统中，介于访问者和目标（资源）之间，用在这里检查访问者是否具有适当的访问目标（资源）的权限。当访问者申请访问时，授权检查点向访问控制决策点申请授权，并根据授权决策的结果实施决策，即对目标执行访问或者拒绝访问。

（4）访问控制决策点

访问控制决策点（Access Control Decision Function，ADF），接收和评价授权请求，根据具体策略做出不同的决策。它一般并不随具体的应用变化，是一个通用的处理判断逻辑。当接收到一个授权请求时，根据授权的策略、访问者的安全属性以及当前条件进行决策，并将决策结果返回给应用。对于不同应用的支持是通过解析不同的定制策略来完成的。

第 8 章

知识域：物理与网络通信安全

阅读提示 本知识域包括物理安全、OSI 模型、TCP/IP 协议安全、无线通信安全、典型网络攻击及防范和网络安全防护技术 6 个知识子域，通过对这些知识子域的学习，学员了解并掌握信息系统物理及环境安全、OSI 模型架构及安全体系、TCP/IP 协议安全、无线通信安全等方面的知识，并了解针对网络的典型攻击方式、防御措施及常用的网络安全防护技术。

8.1 知识子域：物理安全

物理安全是保护信息稳定、可靠的运行，确保信息系统在对信息进行采集、传输、存储、处理等过程中不会因为自然因素、人为因素等原因导致服务中断、数据丢失、破坏等问题。物理安全需要面对的是环境风险及不可预知的人类活动，是一个非常关键的领域。

8.1.1 环境安全

1．场地选择

选择信息系统部署的场地应考虑组织机构对信息安全的需求并将安全性放在重要的位置，在选择信息系统部署的场地时，应根据相关安全要求对场地的各方面进行详细考虑。信息资产的保护很大程度上取决于场地的安全性，一个部署在高风险场所的信息系统是很难有效地保障信息资产安全性的。

在进行场地选择时应考虑以下因素。

（1）场地区域选择

部署在如地震、龙卷风等自然灾害高发区域很显然对信息系统安全会带来巨大的安全风险，因此在场地选择中这一地区的自然灾害的影响是一个需要关注的重要因素。选择时应考虑该地区是否容易发生地震、火灾、洪水、飓风、龙卷风、降雪、降雨、结冰、潮湿、炎热和极度寒冷等灾害，除此之外还要考虑该地区的地形危害等问题，如泥石流、地底塌陷等。若需要在地震多发的地区部署信息系统，就需要考虑地震的影响。必须做好应对自

然灾害的措施，使设施环境等可以经受得住灾害事件的影响，或者可以容易地进行替换。

对于广域网中重要信息设备的部署点，应尽量避开此类自然灾害发生可能性较高的区域。当然，对于绝大部分的组织机构来说，这通常无法选择。

（2）周边环境

信息系统部署建筑的周边环境对信息系统安全性也是需要考虑的重要因素，如果有可能，尽量选择远离存在的危险因素。

这些因素包括信息系统场所周边的治安环境、人流量等，治安环境不好的区域，盗窃、线路破坏等问题出现的风险就相对要高，而人流量大则会带来大量的管理压力。如果组织机构具备自建或购买独立办公园区的能力，那么在建筑的布局设计上可以针对非法闯入防护进行考虑，同时设置严格的访问控制和监控，这些措施能很好地解决这个问题。绝大部分组织机构可能都不具备这样的经济能力，因此可以考虑其他更经济的方法（例如选择第三方托管）。

另外还需要考虑周边环境中的存在易燃易爆可能的其他经营性设施的风险，包括并不限于加油站、化工厂、餐饮企业等。在大部分情况下，很难对此类周边经营性设施产生的安全风险进行规避，但是如果对此有所了解，那么就可以在信息安全防范中考虑到此类风险并采取相应的应对措施。

（3）其他可能需要考虑因素

除此之外，在为选择信息系统部署区域时，还可考虑的因素包括支持机构的便利，例如与警察局、医疗机构和消防机构的接近程度，交通拥挤情况、与机场、火车站和高速公路的接近程度等。毫无疑问，如果附近就是消防机构并且交通便利，那么对于火灾这类风险的响应就会更及时一些。

2．抗震及承重

机房选择应考虑抗震问题，根据《GB 50223—2008 建筑工程抗震设防分类标准》的定义，对建设工程抗震设防类别由高到低划分为特殊设防类、重点设防类、标准设防类和适度设防类。在标准中对重要信息化设施部署的建筑设防类别进行了相应定义，在进行信息系统场地选择时，先参考相关标准确定信息系统所在建筑的抗震设防类别。

（1）国际出入口局、国际无线电台、国家卫星通信地球站，中央级的电信枢纽（含卫星地球站），抗震设防类别应划为特殊设防类。

（2）省中心及省中心以上的通信枢纽、长途传输一级干线枢纽站、国内卫星通信地球站、本地网通枢纽楼及通信生产楼、应急通信用、抗震设防烈度为 8.9 度的县及县级市的长途电信枢纽楼的主机房和天线支承物应划为重点设防类。

确定的信息系统部署场所抗震设防类别后，参考我国 2016 年修订的《GB 50011—2010 结构抗震设计规范》，选择符合国家标准要求的场地。

（1）特殊设防类建筑，地震作用应高于本地区抗震设防烈度的要求，其值应按批准的地震安全性评价结果确定；抗震措施，当抗震设防烈度为 6～8 度时，应符合本地区抗震设

防烈度提高一度的要求，当为 9 度时，应符合比 9 度抗震设防更高的要求。

（2）重点设防类建筑，地震作用应符合本地区抗震设防烈度的要求；抗震措施，一般情况下，当抗震设防烈度为 6～8 度时，应符合本地区抗震设防烈度提高一度的要求，当为 9 度时，应符合比 9 度抗震设防更高的要求；地基基础的抗震措施，应符合有关规定。对较小的重点设防类建筑，当其结构改用抗震性能较好的结构类型时，应允许仍按本地区抗震设防烈度的要求采取抗震措施。

（3）标准设防类建筑，地震作用和抗震措施均应符合本地区抗震设防烈度的要求。

另外，由于机房是信息系统中电子设备集中运行的场所，这些设备往往部署密集并且重量较高，因此对机房有较高的承重能力要求。如果选择场所在设计时并未设计为机房，其承重可能达不到机房要求。组织机构在选择场所时应对建筑承重能力进行考虑，确保机房在机柜服务器密度较高时能够很好地承受住机柜的压力，对于承重达不到要求的机房应考虑进行承重加固。

3. 火灾防护

火灾是机房日常运营中面临最多的安全威胁之一，火灾防护的工作是通过构建火灾预防、检测和响应系统，保护信息化相关人员和信息系统，将火灾导致的影响降到可接受的程度。

（1）火灾的预防

火灾的预防主要是针对火灾发生的来源，采取针对性的措施进行防护。预防来自机房外部的火灾威胁，最理想的状态是机房为独立建筑，并且在建筑外留有一定宽度的防火带。绝大多数组织机构的机房建设在商业建筑中或同一建筑中还有其他用途的场所，在机房设计时应参考机房设计规范中关于防火的相关要求。将机房单独设置防火区，选址时远离易燃易爆物品存放区域，机房外墙使用非燃烧材料，进出机房区域的门采用防火门或防火卷帘，机房通风管设防火阀。

针对内部的威胁如线路短路、设备高负载自然、UPS 电池燃烧等，应划分防火区域，选择建筑材料非燃烧材料或难燃烧材料等。例如针对较容易起火燃烧的 UPS 电池，在进行机房建设时把 UPS 设备与机房设备分离（很多单位因经费和空间限制而放在了一起），即使不在一个机房，还需要考虑通风管道不可相通，因为管道联通，UPS 电池燃烧时烟渍也会通过通风管道进入机房影响设备。

（2）火灾的检测

火灾的检测是火灾防护的重要工作，越早检测到火灾的发生，就能越快地进行处置，从而使火灾造成的破坏越小。火灾的检测通常采用的是火灾探测器来实现。火灾探测器是一个小型传感器，通过检测防护区域内物理、化学现象以发现火灾的产生。具体实现方式包括烟雾检测、温度检测、火焰检测、可燃气体检测及多种检测复合等。

- **感烟探测器**：由于火灾会产生烟雾，因此通过探测周围空间是否有物质燃烧所形成的烟雾粒子可发现火灾。这是目前使用最广泛的火灾探测器，具有响应速度快

的特点。

- **感温探测器**：火焰会导致周围温度升高，通过探测范围内温度的变化，可以发现是否有火灾出现。相比感烟探测器和感光探测器，感温探测器可靠性较高且对环境条件要求更低，但对初期火灾响应速度要慢一些。
- **感光探测器**：也称为火焰探测器，通过对物质燃烧火焰的光谱特性、光照强度和火焰导致的光感变化进行检测以发现火灾的探测器。感光探测器也具有响应速度快的特点。同时，感光探测器不受环境气流影响，能在户外使用，稳定、可靠。
- **可燃气体探测器**：检测环境中是否存在天然气、煤气、烷、醇、醛、炔等可燃气体，当空气中可燃气体达到或超过报警设定值就触发报警，避免事故发生。

（3）火灾抑制

当机房发生火灾时，火灾检测系统被触发并产生相应的报警。对于报警的产生，火灾抑制系统通常有手动和自动两种响应方式。手动方式下，需要由值班人员对火警进行确认，而自动响应方式下，抑制系统就无须人工干预，直接按预定的程序执行动作。为避免存在误动作导致损失，保护人员和设备安全，使用自动响应方式应考虑同时设立两组独立的火灾探测器，例如采用感烟和感温探测器的组合，只有当两个探测器同时报警，灭火系统才真正进行动作。

在消防领域使用最多的灭火剂就是水，水具有廉价、无污染及可再生等诸多优点，然而由于计算机机房中有大量精密电子设备，不宜采用水作为计算机机房的灭火介质，因此目前广泛在机房中使用气体灭火系统。我国已经加入《蒙特利尔议定书》，从 2010 年起全面停止使用哈龙（卤代烷 1211 和 1301 灭火剂，对臭氧层形成持续破坏）。目前，在机房中使用较多的气体灭火剂有二氧化碳、七氟丙烷、三氟甲烷等。

由于气体灭火系统主要通过降低空气中氧气含量，吸收热量降低温度等方式来灭火，需要在火场形成封闭空间，因此气体灭火系统在工作时，灭火系统应同时停止现场的空调、排风、新风等系统的运行并将火场电源切断，此外，气体灭火系统在释放时应确保范围内人员已经疏散。

注：蒙特利尔议定书全名为“蒙特利尔破坏臭氧层物质管制议定书（Montreal Protocol on Substances that Deplete the Ozone Layer）”，是联合国为了避免工业产品中的氟氯碳化物对地球臭氧层继续造成恶化及损害，承续 1985 年保护臭氧层维也纳公约的大原则，于 1987 年 9 月 16 日邀请所属 26 个会员国在加拿大蒙特利尔所签署的环境保护公约。

4．防水

机房中大量的电子设备在与水的接触中会导致损坏的事故，即使在未运行期间，与水接触也会对计算机系统造成损坏。因此在机房环境安全策略和安全措施中，都需要考虑解决水带来的安全问题。在场地选择一节中提到，应考虑避免水浸这种风险，例如在机房选择时应考虑顶部应该不能有主供水管通过等。我国等级保护中对于三级以上系统的场地选择有机房不能建在地下室和顶层的明确要求。

除了远离水浸的危险源之外，为了降低水浸的风险，也可以在关键系统的地板周围部署水浸探测器。水浸探测器是一种检测是否存在水侵入的报警装置，当检测到水侵入时就会触发警报。水浸探测器分为接触式和非接触式两种类型。

接触式水浸探测器利用液体导电原理进行检测，两个探头在正常时相互之间绝缘，当发生水浸时，由于两个探头之间有水作为导电介质，相互之间形成了通路，就产生报警。

非接触式水浸探测器利用光在不同的介质截面的折射与反射不同的原理进行检测。探头内有 LED 和光电接收器，在正常情况下，绝大部分 LED 产生的光会被接收器收到，而当有水浸发生时，由于对光的折射率与空气不同，光电接收器接受到光量会有变化，从而产生报警。

除了技术措施之外，在应急事件处置中要安排相应的处置流程，如果发生了水浸报警情况下，应该如何处置，相关知识请参考“业务连续性管理”知识子域。

5．供电安全

供电安全是所有电子设备都需要考虑的问题，只有持续平稳的电力供应，才能保障电子设备工作稳定可靠。因此电力供应需要解决两个问题：一是确保电力供应不中断；二是确保电力供应平稳。解决电力供应中断问题的方案有 3 种。

（1）双路供电

机房供电由两路来自不同供电系统的市电接入，这两路市电属于不交叉的供电系统（例如两路电分别来自两个不同的变电站），任何一路出现问题不会影响另外一路供电。平常可使用一路供电，另外一路进行备用，也可使用两路市电并联供电。

（2）发电机

两路供电是一种非常好的应对电力中断的方式，然而并非所有的机房都可以实行双路供电，即使实行了双路供电，对于很多不可中断的业务来说，仍然存在电力中断的风险。因此如果需要确保在外部供电中断的前提下系统能持续工作，则应该考虑一种后备解决方案，现场配备一台发电机，当电力中断时，由现场发电机提供供电。由于现场发电机使用如柴油、汽油等介质进行工作，因此使用现场发电机还需要配备足够的燃料，同时也需要对燃料进行严格管理以避免带来的其他危险。

（3）UPS

UPS（不间断电源供应）是目前电力防护最主要的技术措施，在电力供应正常时，UPS 将电力存储在 UPS 的电池中。当电力中断时，UPS 将存储在电池中的电力输出并供应给与其连接的电子设备。UPS 可提供持续、平稳的电力供应。根据容量的不同及所需要设备的电量差别，UPS 可提供数分钟或数个小时的持续电力。

除了电力中断之外，还需要考虑的问题就是电力稳定性。由于计算机系统内部集成电路、芯片等都对电力波动非常敏感，因此保护计算机机房中精密的电子设备就需要稳定的电力供应。雷击、大型电机设备如电梯、空调、发电机、制冷设备等在运行时都会产生电力波动。这些电力波动也被称为电涌，电涌产生的瞬间高电压可能会导致电子元器件的永

久损坏或使用寿命缩短。因此做好电涌防护也是供电安全的重要环节。电涌防护常用的方式是部署电涌保护器。电涌保护器在电涌出现时（电压升高到预先设定的水平）产生动作，将瞬间的高压导入接地端，从而保护后面的电子设备免受高压的影响。

由于UPS输出的电力稳定可靠，因此也有很多企业使用UPS向计算机设备进行供电，从而确保计算机设备的电力供应是稳定的。由于UPS设备本身也有电子元器件，因此也会受到电涌的影响，使用UPS仍然需要采用电涌防护。

6．空气调节

除了为极端环境设计的如工业控制系统交换机外，绝大部分的计算机设备都对运行环境有较高的要求，包括温度、湿度、清洁度等，因此对于大部分计算机机房应保持在恒温恒湿条件下，这对计算机机房的空调系统提出了较高的要求，普通空调系统无法满足机房运营保障，需要使用机房专用的精密空调。良好的环境是计算机系统稳定可靠工作，减少设备故障，延长使用寿命的基础。表8-1为《GB50174—2008 电子信息系统机房设计规范》中规定的机房环境要求。

表8-1　各级电子信息系统机房环境技术要求

项　　目	技术要求			备　　注
	A级	B级	C级	
主机房温度（开机时）	23±1℃		18～28℃	不得结露
主机房相对湿度（开机时）	40%～55%		35%～75%	
主机房温度（停机时）	5～35℃			
主机房相对湿度（停机时）	40%～70%		20%～80%	
主机房和辅助区温度变化率（开/停机时）	＜5℃/h		＜10℃/h	
辅助区温度/相对湿度（开机时）	18～28℃、35%～75%			
辅助区温度/相对湿度（停机时）	5～35℃、20%～80%			
不间断电源系统电池室温度	15～25℃			

7．电磁防护

电子设备如服务器、网络设备、显示器、打印机等在工作时由于电流通过，不可避免地会产生电磁辐射，通过对这些电磁辐射信号的分析，攻击者可以还原出计算机系统正在处理的数据，因此对于重要信息系统，如果没有采取相应的技术措施进行防护，可能会导致数据泄露。另外，由于磁场变化也会在电路中产生电流，因此外部的磁场变化对计算机系统也会形成干扰，影响系统中传输的数据，从而导致系统运行不稳定或数据完整性破坏。

电磁屏蔽是避免电磁辐射产生的数据泄露和保护设备免受电磁干扰影响的有效方法。电磁屏蔽是采取阻断电磁信息泄露的方式来进行防护，在设备与外部区域之间使用导电的屏蔽材料进行隔离。例如使用屏蔽材料将产生电磁泄露的元器件、电路、电缆甚至整个系统包裹起来，从而防止电磁磁场向外扩散及免受外部磁场的干扰。通常使用的屏蔽材料为

金属，屏蔽材料对电磁波形成能量吸收（涡流损耗）、能量反射和能量抵消作用，从而达到电磁屏蔽作用。在实际应用中，根据不同的防护需求和不同级别的屏蔽效能，电磁屏蔽实现方式有屏蔽机房、屏蔽机柜、屏蔽包、屏蔽线等。例如屏蔽机房将整个机房用金属材料包裹，利用“法拉第笼”原理，抑制和阻挡电磁波在空中传播。屏蔽具有双向屏蔽功能，既能阻止内部的电磁信号泄露出去，也能阻止外部电磁干扰进入屏蔽室。在实际使用中，并非简单地使用金属包裹设备就可以实现电磁屏蔽的作用，屏蔽效果受两个因素的影响，一是需要屏蔽体表面导电并且是连续的，也就是说不能存在不导电的缝隙，另外不能存在直接穿透屏蔽体的导体。

除了电磁屏蔽技术外，用于解决电磁信息泄露的技术措施还有信号干扰和 Tempest 技术。

- **信号干扰技术**是使用电磁发生器产生出电磁波，与计算机电磁辐射出来的电磁波混合后，使得远程攻击者无法从电磁波中还原出有价值的信息。
- **Tempest** 技术是包括了对电磁泄漏信号中所携带的敏感信息进行分析、测试、接收、还原以及防护的一系列技术领域的总称，在 20 世纪 60 年代末 70 年代初由美国国家安全局提出的，用于防止电磁信息设备潜在的安全威胁以及反向的用以收取和还原其他信息发射源的技术。Tempest 技术实现包括屏蔽、红黑设备隔离、布线与元器件选择、滤波、I/O 接口、测试等多种技术。支持 Tempest 技术的设备就是低辐射设备，这些设备在设计和生产时就采取了相应的防辐射措施，把设备的电磁泄露抑制到最低限度，从而达到降低电磁泄露的目的。

8．雷击及静电

雷击是天空云层与地面物体之间的放电现象，雷击的瞬间会产生极高的电压冲击，经过电源线和数据线到达计算机系统，从而对计算机系统进行高压冲击，导致计算机系统损坏。因此在机房环境安全防护中，雷击破坏是必须要采取有效应对措施的一种威胁。雷击产生的威胁可分为直击雷和感应雷。直击雷是雷击直接打到计算机系统的电源线路或者连接计算机系统的信号线路上，导致产生高电压冲击，从而损坏设备。直击雷的防护主要是在建筑上埋设正确合理接地的避雷针，利用避雷针将雷击引入地下从而保护设备。另外，对房屋采用金属网格结构也能较好地避免雷击发生。感应雷是由于带点积雨云接近地面时，在金属导体上两端感应出大量电荷，从而产生极高的静电电压（数万到数十万伏）。建筑物内的各自金属导线、接地效果不良的金属导体和大型金属设备都可能受到感应电的影响。另外，直击雷打到的导电物体由于产生高压和电流，形成突变的强磁场，导致附近的导电物体产生感应电流从而导致设备损坏。对于感应雷较好的防护措施是使用电涌保护器。

除了雷击之外，日常运动中衣服等物体产生的静电也是导致计算机系统损坏的重要原因。由于静电无处不在，因此在日常运营中要注意对设备进行有效接地、机房保持合理湿度（使用机房加湿器）以避免静电在设备、家具及人体上进行集聚。

在对设备进行维护时可穿上防静电服或带上防静电手套，操作前触摸接地点以释放身

上积累的电荷等措施避免静电的危害。

8.1.2 设施安全

1. 安全区域

安全区域是需要被组织保护的业务场所和包含被保护信息处理设施的物理区域，如系统机房、重要办公室等。建立安全区域是设施安全的基础措施，把关键、敏感的业务处理设施放在划定好的安全区域内，并对该安全区域进行保护，建立安全屏蔽及访问控制机制，从而防止未经授权的访问，避免对计算机系统的干扰和破坏。

设立安全区域需要明确并建立物理安全边界，通过建立安全边界可以形成安全区域以保护区域内的信息处理设施。例如独立的建筑、墙、有人管理的接待区等，物理边界内部区域是受控区域，应该采取措施进行防护。对于安全区域的进入通道应采取控制措施，以确保只有授权的人员才允许访问。

出入控制的要求、终端安全及介质安全管理可参考信息安全管理中相关内容。

2. 边界防护

安全区域的出入防护是为了保障设施不被非授权接触，安全区域的边界防护方式如传统防护使用的门锁到目前广泛采用的门禁卡，都是为了对进入安全区域进行控制。门锁是广泛使用的防护措施，特别对一些接入设备，出于技术实现的原因，被部署在建筑竖井里，对这类接入设备无法实施高安全要求的保护，采取锁头是最经济且有效的边界防护措施。而对于大量计算机设备聚集的机房，由于进出人员较多，因此不宜采用锁头的方式。较常用的方式是使用门禁系统，为不同类型的人员配备不同的门禁卡，以便于管理并且限制人员随意进入不合适的区域。

3. 监控与审计

除了对进出安全区域的边界采取访问控制之外，对于安全区域及物理边界，还应采取措施确保非法的闯入可被检测和记录。

（1）闭路电视监控系统

对于重要的安全区域，除了安装上述入侵检测器外，还可以部署闭路电视监控系统（Closed Circuit Television，CCTV）。通过 CCTV 在监控中心可以随时观察到监控区域的动态情况，从而保证监控区域安全。闭路电视监控系统主要由前端数据采集设备以及后端控制设备组成。前端设备包括摄像机，通常布置在机房出入口、设备操作台位置。后端设备由数字式控制录像设备、监视器等中央控制设备组成，根据要求可在需要时对视屏信号进行记录，同时引出监控视频信号在监视器上，供值班人员工作使用。

（2）非法闯入探测器

探测器是针对各自非法闯入最有效的应对方式，相比闭路电视，探测器的成本相对较低且部署灵活。

- **玻璃破碎探测器**：对于安装了玻璃的窗户等可进入安全区域的通道，可以采用玻璃破碎探测器进行防护，玻璃破碎探测器通过检测玻璃破碎时产生的高频信号，以发现是否有攻击者闯入。
- **红外微波双鉴探头**：微波检测的基础是多普勒效应，在充满微波的房间内，当物体移动时，接收到的微波会有变化。使用微波进行检测覆盖区域较大，受环境影响较小，但存在较高的误报现象，因此在微波探头上还添加了红外传感器，检测基于人体发出的不可见的红外线，通过检测红外线便能发现入侵者。红外微波双鉴探头结合了两种检测方式，只有两种检测都通过了，才会产生报警信息，具有很高的准确性。

（3）保安

除了各自电子设备进行检测和防护外，保安仍然是非常有效的监控及访问控制措施。所有电子设备在产生报警后，都必须由保安人员来介入进行处理，保安能针对各自不同的情况进行相应的应对，因此，如果条件许可，可以安排保安进行出入口监视、定期对物理安全区域、安全边界进行巡检等。

8.1.3　传输介质安全

传输线路是信息发送设备和接受设备之间的物理通路，针对传输线路的攻击是攻击者常用的方式，不同传输介质具有不同的安全特性。同轴电缆、双绞线和光纤是广泛使用的有线传输介质。

1．同轴电缆

同轴电缆的结构从里到外分为 4 层：中心铜线（单股的实心线或多股绞合线）、塑料绝缘体、网状导电层和电线外皮。中心铜线和网状导电层形成电流回路用于传输数据。同轴电缆显著的特征是频带较宽，其中高端的频带最大可达到 10GHz，在电视信号及信号馈线的传输过程中具有良好的应用效果，实际的应用较为广泛，在有线传输技术组成中占据着重要的地位。同轴电缆使用总线拓扑结构，在一根电缆上连接多个设备，但是当其中一个地方发生故障时，会串联影响到线缆上的所有设备，可靠性存在不足，并且故障的诊断和修复难度都较大，因此在应用上逐渐被双绞线或光纤取代。

2．双绞线

双绞线由 4 对不同颜色的传输线所组成，是目前局域网使用最广泛的互联技术。虽然相比同轴电缆，双绞线的速率偏低，抗干扰能力较差，但由于性能可靠，成本低廉，因此在网络通信中广泛应用。为了解决双绞线抗干扰能力差的问题，目前使用中还在双绞线外包裹一层金属屏蔽层，减少辐射并阻止外部电磁干扰进入，使得传输更稳定可靠。随着技术不断发展，双绞线传输带宽也在逐步扩大，从最初的仅能用于语音传输的一类线发展到目前达到 10Gbps 带宽的七类线，已经很好地满足信息化发展的需要。

- 一类线线缆最高频率带宽是 750kHz，用于报警系统，或只适用于语音传输（一类标准主要用于 20 世纪 80 年代初之前的电话线缆），不用于数据传输。
- 二类线线缆最高频率带宽是 1MHz，用于语音传输和最高传输速率 4Mbps 的数据传输，常见于使用 4Mbps 规范令牌传递协议的旧的令牌网。
- 三类线的传输频率 16MHz，最高传输速率为 10Mbps（10Mbit/s），目前已淡出市场。
- 四类线的传输频率为 20MHz，最高传输速率 16Mbps，未被广泛采用。
- 五类线增加了绕线密度，外套一种高质量的绝缘材料，线缆最高频率带宽为 100MHz，最高传输率为 100Mbps，这是最常用的以太网电缆。
- 超五类线主要用于千兆位以太网（1000Mbps），超五类线具有衰减小、串扰少以及时延误差小的特性。
- 六类线的传输频率为 1MHz～250MHz，六类布线的传输性能远远高于超五类标准，最适用于传输速率高于 1Gbps 的应用。
- 七类线带宽为 10Gbps，可用于今后的万兆比特以太网。

3．光纤通信

光纤通信技术使用光作为信息传输的媒介，光导纤维被封装在塑料的保护套中，一端有用于发光的二极管产生一个光信号，光纤的另一端是一个光敏元件检测光脉冲信号。由于光在光导纤维中传输损耗非常低，因此光纤可用于长距离的信息传递。相比同轴电缆、双绞线等其他的有线传输技术，光纤通信传输技术有着自身独特的优势，具有高带宽、信号衰减小、无电磁干扰、抗腐蚀材料、重量轻及不易被窃听等特点。但光纤的成本相对较高，并且其安装和维护都需要专业设备。

4．无线传输

无线通信是通过电磁波来进行信息交流的通信方式，最大的特点就是不用连接线来传导信号。近几年，无线通信技术迅猛发展，广泛应用于各个领域。无线通信网络之所以得到广泛应用，是因为无线网络的建设不像有线网络那样受地理环境的限制，无线通信用户也不像有线通信用户受通信电缆的限制，而是可以在移动中通信。无线通信网络的这些优势都来自于它们所采用的无线通信信道，而无线信道是一个开放性信道，它在赋予无线用户通信自由的同时也给无线通信网络带来一些不安全因素，如通信内容容易被窃听、通信内容可以被更改和通信双方身份可能被假冒等。无线通信技术在安全上具体有如下缺点。

（1）在无线通信网络中，所有网络通信内容（如移动用户的通话信息、身份信息、位置信息、数据信息以及移动站与网络控制中心之间信令信息等）都是通过无线信道传送的。而无线信道是一个开放性信道，任何具有适当无线设备的人均可以通过窃听无线信道而获得上述信息。虽然有线通信网络也可能会遭到搭线窃听，但这种搭线窃听要求窃听者能接触到被窃听的通信电缆，而且需要对通信电缆进行专门处理，这样就很容易被发现。而无线窃听相对来说比较容易，只需要适当的无线接收设备即可，而且很难被发现。

（2）对于无线局域网络和无线个人区域网络来说，它们的通信内容更容易被窃听，因

为它们都工作在全球统一公开的工业、科学和医疗（ISM）设备频带（如 2.5GHz 和 5GHz），任何个人和组织都可以利用这个频带进行通信。而且，很多无线局域网和无线个人区域网络采用群通信方式来相互通信，即每个移动站发送的通信信息其他移动站都可以接收，这些使得网络外部人员也可以接收到网络内部通信内容。

（3）无线窃听可以导致信息（如通话信息、身份信息、位置信息、数据信息以及移动站与网络控制中心之间的信令信息等）泄露。移动用户的身份信息和位置信息的泄露可以导致移动用户被无线跟踪。无线窃听除了可以导致信息泄露外，还可以导致其他一些攻击，如传输流分析，即攻击者可能并不知道真正的消息，但他知道这个消息确实存在，并知道这个消息的发送方和接收方地址，从而可以根据消息传输流的这些信息分析通信目的，并可以猜测通信内容。在无线通信网络中，移动站（包括移动用户和移动终端）与网络控制中心以及其他移动站之间不存在任何固定的物理连接（如网络电缆），移动站必须通过无线信道传送其身份信息，以便于网络控制中心以及其他移动站能够正确鉴别它的身份。由于无线信道传送的任何信息都可能被窃听，当攻击者截获到一个合法用户的身份信息时，他就可以利用这个身份信息来假冒该合法用户的身份入网，这就是所谓的身份假冒攻击。

8.2　知识子域：OSI 模型

8.2.1　OSI 模型

开放系统互连模型（Open System Interconnection Reference Model，OSI）是国际标准化组织于 1977 年发布的一个标准参考模型，在 1983 年成为 ISO 7498 国际标准，该模型定义了网络中不同计算机系统进行通信的基本过程和方法。OSI 模型把网络通信工作分为 7 层，从低层到高层依次是物理层（Physical Layer）、数据链路层（Data Link Layer）、网络层（Network Layer）、传输层（Transport Layer）、会话层（Session Layer）、表示层（Presentation Layer）和应用层（Application Layer）。

OSI 模型中，每一层实现特定的功能，按照其功能，一般可以将这 7 层分为低层协议和高层协议两部分，其中，低层协议偏重于处理实际的信息传输，负责创建网络通信连接的链路，包括物理层、数据链路层、网络层和传输层；而高层协议偏重于处理用户服务和各种应用请求，负责端到端的数据通信，包括会话层、表示层和应用层；这七层的主要功能描述如下。

1．物理层

规定通信设备的机械的、电气的、功能的和过程的特性，用以建立、维护和拆除物理链路连接，这些特性包括网络连接时所需接插件的规格尺寸、引脚数量和线序情况、信号电平的大小、阻抗匹配等。OSI 制定了一些标准，也将现有的 RJ-45 标准、EIA/TIA RS-232、EIA/TIA RS-449 等纳入其中。

网络中各种同轴电缆、T 型接头、插头、接收器、发送器、中继器、转发器等都属物

理层的媒体和连接器。

2．数据链路层

负责监督相邻网络节点的信息流动，用检错或纠错技术来确保正确的传输，确保解决该层的流量控制问题。在数据链路层，数据通常被组合成帧（frame）的格式加以传输。常见协议包括 ARP、RARP、SDLC、HDLC、PPP、STP 等。

3．网络层

为数据传送的目的地寻址，再选择出传送数据的最佳路线。网络层管理网络数据传输的路由策略。常见协议包括 IP、IPX 等。

4．传输层

也称为运输层，用于控制数据流量，并且进行错误处理，以确保通信顺利。常见协议包括 TCP、UDP、SPX 等。

5．会话层

允许不同主机上的应用程序进行会话，或建立虚连接。举例来说，某个用户登录到一个远程系统，并与之交换信息。会话层管理这一进程，控制哪一方有权发送信息，哪一方必须接收信息。

6．表示层

以用户可理解的格式为上层用户提供必要的数据，如转换内码、解压等。在表示层可以提供如加解密等数据安全保护措施。

7．应用层

直接与用户和应用程序打交道，以达到展示给用户的目的。应用层为用户提供电子邮件、文件传输、远程登录和资源定位等服务。常见协议包括 HTTP、FTP、Telnet、SNMP、DNS、POP3、SMTP 等。

分层协议的目的在于把各种特定的功能分离开来，并使其实现对其他层次来说是透明的。这种分层结构使各个层次的设计和测试相对独立。例如，数据链路层和物理层分别实现不同的功能。物理层为数据链路层提供服务，数据链路层不必理会服务是如何实现的，物理层实现方式的改变将不会影响数据链路层。这一原理同样适用于其他连续的层次。

8.2.2 OSI 模型通信过程

OSI 模型的每一层只与相邻的上下两层直接通信，当发送进程需要发送信息时，它把数据交给应用层。应用层对数据进行加工处理后，传给表示层。再经过一次加工后，数据被送到会话层。这一过程一直继续到物理层接收数据后进行实际的传输，每一次的加工又称为数据封装。

在另一端，顺序刚好相反，每一层都对数据进行解封装处理。物理层接收比特流后把数据传给数据链路层。后者执行某一特定功能后，把数据送往网络层，这一过程一直继续到应用层最终得到数据，并送给接收进程。这一过程也称为数据分用，如图 8-1 所示。

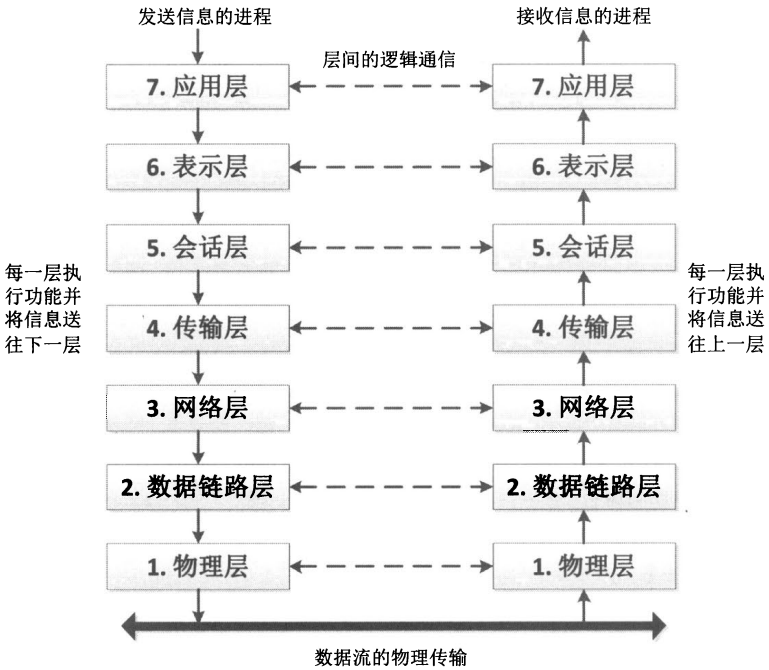

图 8-1　应用 OSI 七层协议通信过程

上面的过程有点像发信。在信封上写好收信人的地址姓名，把信扔进邮筒就行了。信件自然会被送到收信人手里。不管信件如何转发，也不管信件是用卡车、飞机、火车、轮船，还是信鸽传送，收信人都不必关心，要做的只是等待回音而已。

8.2.3　OSI 七层模型安全体系

OSI 安全体系结构的研究开始于 1982 年。国标标准化组织于 1988 年发布了 ISO 7498-2 标准，该标准名称为《信息处理系统开放系统互连基本参考模型第 2 部分：安全结构》（Information processing systems; Open Systems Interconnection; basic reference model; Part 2: Security architecture），描述了开放系统互联安全的体系结构，提出设计安全的信息系统的基础架构中应该包含的安全服务和相关的安全机制。1990 年，ITU 决定采用 ISO 7498-2 作为其 X.800 推荐标准。1995 年，我国颁布国家标准《信息处理系统开放系统互连基本参考模型——第二部分：安全体系结构》（GB/T 9387.2—1995）（等同于 ISO 7498-2）规定了基于 OSI 参考模型七层协议之上的信息安全体系结构。

OSI 安全体系结构的核心内容是：为保证异构计算机进程与进程之间远距离交换信息的安全，定义了系统应当提供的五类安全服务，以及支持这些服务的八类安全机制及相应

的 OSI 安全管理，并根据具体系统适当地配置于 OSI 模型的七层协议中，如图 8-2 所示。

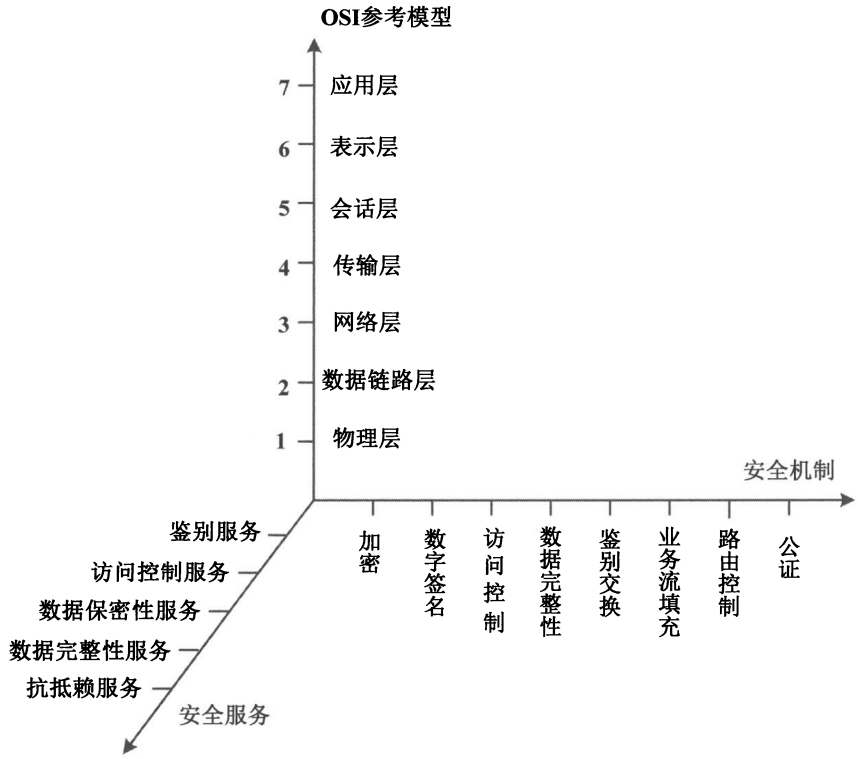

图 8-2　OSI 安全体系结构图

图 8-2 中，安全服务与安全机制的关系为：一种安全服务可以通过某种安全机制单独提供，也可以通过多种安全机制联合提供；一种安全机制可用于提供一种安全服务，也可以用于提供多种安全服务。在 OSI 七层协议中除第五层（会话层）外，每一层均能提供相应的安全服务。

OSI 安全体系结构中的五类安全服务包括鉴别服务、访问控制服务、数据保密性服务、数据完整性服务和抗抵赖服务，这五类安全服务又可以细分为 14 种安全服务，其含义分别解释如下。

（1）鉴别服务：也称认证服务，通过对实体的身份确认和对数据来源的确认，保证两个或多个通信实体的可信以及数据源的可信。鉴别服务可细分为对等实体鉴别服务和数据原发鉴别服务（也可称数据源鉴别）两类。

（2）访问控制服务：用于对 OSI 资源的访问进行保护，防止资源的非授权使用，如读通信资源、写信息资源等。OSI 安全体系中，不对访问控制服务再进行细分。

（3）数据保密性服务：为防止网络各系统之间交换的数据被截获或被非法存取而泄密，提供机密保护。同时，对有可能通过观察信息流就能推导出信息的情况进行防范。数据机密性服务分为连接机密性、无连接机密性、选择字段机密性和通信数据流机密性。

（4）数据完整性服务：用于组织非法实体对交换数据的修改、插入、删除以及在数据交换过程中的数据丢失，保证收到的消息和发出的消息一致。该服务可用于抗击主动攻击。数据完整性服务可以细分为带恢复的连接完整性、不带恢复的连接完整性、选择字段的连接完整性、无连接完整性和选择字段无连接完整性等 5 种安全服务。

（5）抗抵赖服务：用于防止发送方在发送数据后否认发送，接收方在收到数据后否认收到或伪造数据。抗抵赖服务可以细分为有数据原发证明的抗抵赖和有交付证明的抗抵赖两类。

OSI 安全体系结构的 8 种安全机制包括加密、数据签名、访问控制、数据完整性、鉴别交换、业务流填充、路由控制和公正等，其含义分别解释如下。

（1）加密机制：提供对数据或信息流的保密，并可作为其他安全机制的补充。这种机制是确保数据安全性的基本方法。在 OSI 安全体系结构中应根据加密所在的层次及加密对象的不同，而采用不同的加密方法。

（2）数字签名机制：是确保数据真实性的基本方法，利用数字签名技术可以进行用户的身份认证和消息认证，它具有解决收、发双方纠纷的能力。

（3）访问控制机制：使用已鉴别的实体身份、实体的有关信息或实体的能力来确定并实施该实体的访问权限。当实体试图使用非授权资源或以不正确方式使用授权资源时，访问控制功能将拒绝这种企图，并产生事件报警和/或记录，作为安全审计跟踪的一部分。

（4）数据完整性机制：用于保证数据单元或数据流的完整性的各种机制。破坏数据完整性的主要因素有数据在信道中传输时受信道干扰影响而产生错误，数据在传输和存储过程中被非法入侵者篡改，计算机病毒对程序和数据的传染等。纠错编码和差错控制是对付信道干扰的有效方法。

（5）鉴别交换机制：通过实体交换来保证实体身份的各种机制。在计算机网络中认证主要有用户认证、消息认证、站点认证和进程认证等，可用于认证的方法有已知信息（如口令）、共享密钥、数字签名、生物特征（如指纹）等。

（6）业务流填充机制：在数据流空隙中插入若干位以阻止流量分析。攻击者通过分析网络中有一路径上的信息流量和流向来判断某些事件的发生，为了对付这种攻击，一些关键站点间在无正常信息传送时，持续传递一些随机数据，使攻击者不知道哪些数据是有用的，哪些数据是无用的，从而挫败攻击者的信息流分析。

（7）路由控制机制：能够为某些数据动态地或预定地选取路由，确保只使用物理上安全的子网络、中继站或链路。在大型计算机网络中，从源点到目的地址往往存在多条路径，其中有些路径是安全的，有些路径是不安全的，路由控制机制可根据信息发送者的申请选择安全路径，以确保数据安全。

（8）公证机制：利用可信的第三方来保证数据交换的某些性质。这种机制确证两个或多个实体之间数据通信的特征，包括数据的完整性、源点、终点及收发时间等。这种保证由通信实体信赖的第三方——公证员提供。在可检测方式下，公证员掌握用以确证的必要信息。公证机制提供服务还使用到数字签名、加密和完整性服务。

8.3 知识子域：TCP/IP 协议安全

8.3.1 协议结构及安全问题

1. 协议结构

TCP/IP 协议（Transmission Control Protocol/Internet Protocol）是 Internet 最基本的协议，也是 Internet 构成的基础。TCP/IP 协议最早发源于美国国防部的 ARPA 网项目，字面上代表了两个协议：TCP（传输控制协议）和 IP（网际协议）。事实上，TCP/IP 协议是一个协议族，是一组不同层次上的多个协议的组合，定义了电子设备如何连入互联网，以及数据如何在它们之间传输的标准。TCP/IP 通常被认为是一个四层协议系统，每一层都呼叫它的下一层所提供的网络来完成自己的需求，TCP/IP 协议族的每一层负责不同的功能，如图 8-3 所示。

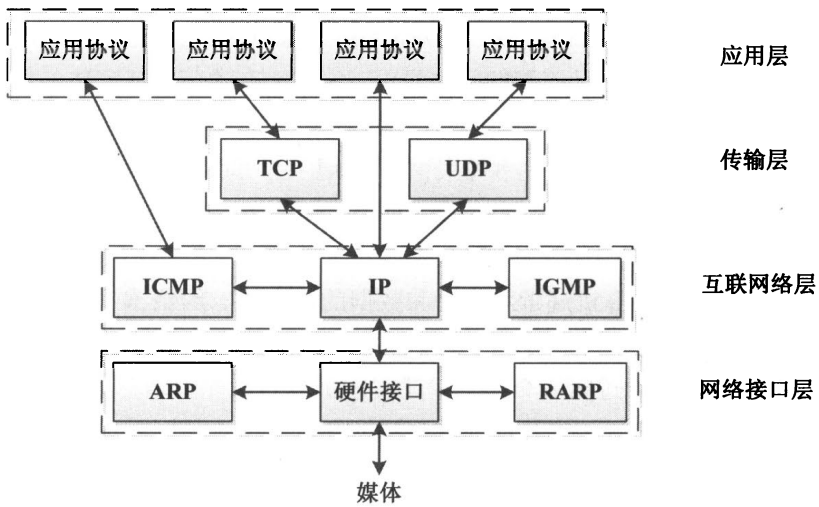

图 8-3 TCP/IP 协议族分层结构

2. 网络接口层安全

网络接口层也称链路层或数据链路层，是 TCP/IP 协议的最底层，它负责接收来自网络层的 IP 数据报，并把数据报发送到指定的网络上，或从网络上接收物理帧，抽出网络层数据报，交给网络层。通常包括操作系统中的设备驱动程序和计算机中对应的网络接口卡，它们一起处理与电缆（或其他任何传输媒介）的物理接口细节。在 TCP/IP 协议族中，网络接口层主要有 3 个目的：（1）为 IP 模块发送和接收 IP 数据报。（2）为 ARP（地址解析协议）模块发送 ARP 请求和接收 ARP 应答。（3）为 RARP（逆地址解析协议）发送 RARP 请求和接收 RARP 应答。

网络接口层使用的 ARP 和 RARP 协议，由于缺乏较好的认证机制，攻击者很容易利用这些协议进行欺骗和拒绝服务攻击，从而假冒主机入侵其他被信任性的主机。另外，电磁

干扰、电磁泄漏、搭线窃听等物理层面的攻击也会引起很大的安全隐患。

3．互联网络层安全

互联网络层也称网络层或网际层，处理分组在网络中的活动，例如分组的选路。在 TCP/IP 协议族中，网络层协议包括 IP 协议（网际协议）、ICMP 协议（Internet 互联网控制报文协议）以及 IGMP 协议（Internet 组管理协议）。

IP 协议是 TCP/IP 协议族的核心协议，是上层协议和应用的基础。IP 协议提供主机到主机的数据传送服务，负责将数据包从源地址（主机）传送到目的地址（主机）。目前广泛使用的是第四版 IP 协议（IPv4）提供无连接不可靠的服务，如图 8-4 所示的包头结构，仅仅有简单的报头校验码，对数据没有差错控制，无法进行重发、流量控制等。攻击者利用 IP 协议的不足，可以实施 IP 欺骗、源路由欺骗及碎片攻击等多种不同类型的攻击。

<table>
<tr><td>版本</td><td>包头长度</td><td>服务类型</td><td colspan="2">数据包长度</td></tr>
<tr><td colspan="3">标识</td><td>标记</td><td>偏移</td></tr>
<tr><td>生存期</td><td colspan="2">协议类型</td><td colspan="2">包头校验和</td></tr>
<tr><td colspan="5">源 IP 地址</td></tr>
<tr><td colspan="5">目的 IP 地址</td></tr>
<tr><td colspan="5">可选项</td></tr>
<tr><td colspan="5">用户数据</td></tr>
</table>

图 8-4　IP 协议包头结构

4．传输层安全

传输层为两台主机上的应用程序提供端到端的通信服务。传输层有 TCP 和 UDP 两个不同的协议。

① TCP 协议提供可靠的、面向连接的数据通信服务。

② UDP 提供不可靠的、无连接的数据包通信服务。

（1）TCP 协议

传输控制协议（Transmission Control Protocol，TCP）由 IETF 的 RFC 793 定义，提供面向连接的、可靠的字节流服务。TCP 协议包头如图 8-5 所示。

<table>
<tr><td colspan="8">16 位源端口号</td><td>16 位目的端口号</td></tr>
<tr><td colspan="9">32 位序号</td></tr>
<tr><td colspan="9">32 位确认序号</td></tr>
<tr><td>偏移量</td><td>保留位</td><td>U</td><td>A</td><td>P</td><td>R</td><td>S</td><td>F</td><td>16 位窗口指针</td></tr>
<tr><td colspan="8">16 位校验和</td><td>16 位紧急指针</td></tr>
<tr><td colspan="9">数据</td></tr>
</table>

图 8-5　TCP 协议包头结构

TCP 协议的连接性和可靠性依赖包头中的 32 位序号和 32 位确认序号，每一个数据包发送时都会给予一个序号，接收端在收到这个数据包时，会返回一个包含确认序号（32 位序号+1）的报文。如果发送端在一个时间段内没有收到确认，就认为数据包丢失，对数据包内容进行重发。除此之外，TCP 和通过 16 位校验和提供数据发送是否错误的检验；通过 16 位窗口指针提供流量控制等功能。

（2）UDP 协议

用户数据报文协议（User Datagram Protocol，UDP）由 IETF RFC 768 定义，提供无连接、不可靠的数据传输服务。UDP 包头结构如图 8-6 所示。

16 位源端口号	16 位目的端口号
16 位 UDP 报文长度	16 位校验和
数据	

图 8-6　UDP 包头结构

相比 TCP 协议，UDP 协议没有标记位、指针、序号等各种控制标记，因此无法提供数据包分组、排序、重发、流量控制等功能，无法保证数据送达。但是由于协议结构简单，因此处理效率高。UDP 设计用于传输对实时性要求较高，但对数据传输可靠性没有严格要求的数据，如网络视频、语音等。由于 UDP 协议的高效，攻击者可利用 UDP 协议产生大量的数据用于实施拒绝服务攻击（UDP Flood）。

5．应用层安全

应用层协议直接面向网络应用提供支持，根据不同的应用实现差异较大。不同的应用根据各自特性都有自身的安全性问题。这些问题包括以下方面。

- 身份认证简单，通常使用用户名和密码进行认证或匿名，面临口令破解、身份伪造等攻击威胁。
- 使用明文传输数据，由于应用层协议在设计时对安全性缺乏考虑，通常使用明文传输数据，由此导致了数据泄露、数据伪造等一系列问题，例如攻击者可能通过嗅探等方式获取传输中的敏感信息。
- 缺乏数据完整性保护，由此带来了数据破坏、篡改等问题，例如攻击者可更改用户提交的数据，从而实施欺诈。

8.3.2　安全解决方案

1．基于 TCP/IP 协议族的安全架构

由于 Internet 的安全性问题日益突出，TCP/IP 协议族也在不断地改善和发展之中。相关组织和专家在协议的不同层次设计了相应的安全通信协议，用来保障网络各层次的安全。

从而形成了由各层次安全通信协议构成的 TCP/IP 协议族的安全架构，如图 8-7 所示。

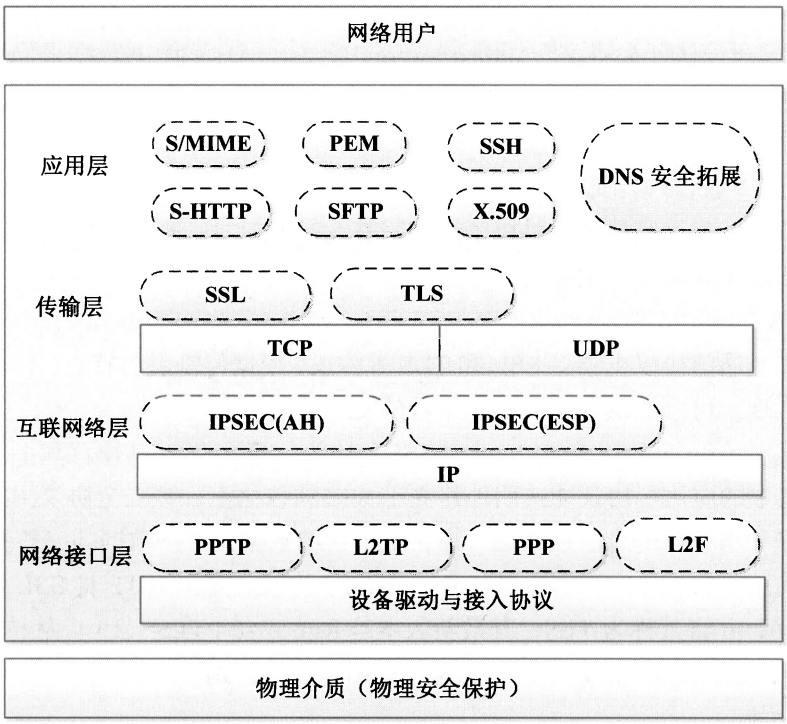

图 8-7　基于 TCP/IP 协议族的安全架构

（1）网络接口层

通过建立专用通信链路，在主机或路由器之间提供安全保证。该层安全通信协议主要有 PPTP、L2TP 等。

点对点隧道协议（Point to Point Tunneling Protocol，PPTP）是在 PPP 协议的基础上开发的一种新的增强型安全协议，支持虚拟专用网（Virtual Private Network，VPN），可以通过密码身份验证协议（Password Authentication Protocol，PAP）、可扩展身份验证协议（Extensible Authentication Protocol，EAP）等方法增强安全性。可以使远程用户通过拨入 ISP、通过直接连接 Internet 或其他网络安全地访问目标网络。

第二层隧道协议（Layer 2 Tunneling Protocol，L2TP 协议）基于 PPTP 和 L2F（Level 2 Forwarding protocol，二层转发协议）设计，在链路层为客户端和服务器端之间建立经过认证的虚拟私有网络，并常通过和加密协议搭配使用来实现数据的加密传输。L2TP 同时支持在两端点间使用多隧道，并可以在 IP、帧中继永久虚拟电路、X.25 虚拟电路或 ATM 网络上使用。

（2）互联网络层

互联网络层安全通信协议主要是解决 IP 协议的安全问题。现阶段，Internet 协议安全性（Internet Protocol Security，IPSec）是主要的互联网络层安全通信协议，有效解决了在互联网络层上存在的安全问题。IPSec 是由 IETF（Internet 工程任务组）于 1998 年制定的

一组基于密码学的安全的开放网络安全协议，它工作在 IP 层，提供访问控制、无连接的完整性、数据源认证、机密性保护、有限的数据流机密性保护以及抗重放攻击等安全服务。

IPSec 协议通过认证头协议（Authentication Header，AH）为 IP 数据报提供无连接完整性与数据源认证，并提供保护以避免重播情况。一旦建立安全连接，AH 尽可能为 IP 头和上层协议数据提供足够多的认证。

IPSec 协议中通过封装安全载荷协议（Encapsulating Security Payload，ESP）加密需要保护的载荷数据，为这些数据提供机密性和完整性保护能力。ESP 协议和 AH 协议可被独立使用，也可以相互结合使用。

（3）传输层

传输层安全通信协议主要有 SSL 和 TLS 等协议。根据传输层的特点，传输层的安全主要在端到端实现，可以提供基于进程到进程的安全通信。

安全套接层（Secure Sockets Layer，SSL）协议，建立在 TCP 协议和上层应用层协议之间，在其之上的应用层协议能透明地建立于 SSL 协议之上。该安全协议主要提供的安全服务有：用户和服务器的合法性认证、加密被传送的数据、维护数据的完整性。

安全传输层（Transport Layer Security，TLS）协议，是由 IETF 将 SSL 做了标准化，形成 RFC2246，并将其称为 TLS，其最新版本是 RFC5246（TLS 1.2）。从技术上讲，TLS 协议与 SSL 协议的差异非常微小，仅仅是一些细节上有区别。

（4）应用层

根据特定应用的安全需要及其特点而设计的安全协议，如电子邮件安全协议（Secure Multipurpose Internet Mail Extensions，S/MIME）、安全超文本传输协议（Secure Hypertext Transfer Protocol，S-HTTP）等。这些应用层的安全措施必须在端系统及主机上实施。其主要优点是可以更紧密地结合具体应用的安全需求和特点，提供针对性更强的安全功能和服务，但主要缺点是要针对每个应用设计有针对性的安全机制。

在实际系统建设时，需要在哪一层采用什么安全通信协议，应综合考虑应用对安全保密的具体要求、每一层实现安全功能的特点以及其他有关因素来确定采用哪个或哪些安全协议。

2．IPv6 协议

IPv6 最初是为解决 IPv4 网络地址数量有限而设计的。IPv4 使用 32 位二进制数字来标识网络中的设备和终端，可使用的地址大约为 43 亿个。随着 Internet 的快速发展，接入网络的终端数量急剧增加，尽管网络地址转换（NAT）在一定程度上缓解了地址不足的问题，但可用的 IPv4 地址仍然无法满足需求。IPv6 重新定义了地址空间，采用 128 位地址长度来提供地址空间。实际可分配的地址数量巨大，整个地球的每平方米面积上可分配 1000 多个地址。

除了网络地址空间的极大扩展，IPv6 还内置了安全性，增加了网络对加密和认证的支持。IPv6 内嵌了对 IPSec 的支持，通过访问控制、数据源的身份验证、数据完整性检查、

机密性保证以及抗重播攻击等机制，有效地在网络层解决端到端数据传输的安全问题。

8.4　知识子域：无线通信安全

8.4.1　蓝牙安全

蓝牙（Bluetooth）是一种全球通用的短距离无线传输技术，使用与微波相同的 2.4GHz-2.4835GHz 无线电波，这是全球免费、免申请的无线电频段。由于使用上的便捷性及低功耗等特点，蓝牙被广泛用于在不同设备之间进行数据传输，例如广泛使用的蓝牙耳机、心脏起搏器等医疗设备等。虽然蓝牙技术在应用上具有优势，但也面临着传输信息的完整性、机密性和可用性等安全威胁，容易受到拒绝服务攻击、窃听、中间人攻击、信息篡改及资源滥用等问题。

1．保密性威胁

蓝牙设备之间的通信安全基于 SAFER+分组密码的定制算法，密钥生成通常基于蓝牙设备配对时的 PIN，这是双方设备都必须输入的。出于配对的便利等原因，部分设备（如蓝牙耳机、音响或用户界面受限的设备）使用固定的 PIN，攻击者可能获得两个蓝牙设备之间会话的密钥，这使得攻击者可能获得会话中的敏感信息（例如蓝牙键盘中输入的密码、蓝牙耳机中传输的音频等）。同时，攻击者也可能未经授权连接到蓝牙设备后从中获取数据或实施其他非法操作。

2．完整性威胁

攻击者通过在两个蓝牙设备之间插入未授权设备实施的中间人攻击，对蓝牙会话双方的数据进行传输控制，攻击者可以修改双方会话的数据，从而使攻击者能实现非常有威胁的攻击，例如在其中插入修改的音频、视频，显示的数据等。

3．非授权连接

攻击者通过未经授权的蓝牙连接将恶意数据（例如恶意代码）推送到蓝牙设备中，或远程操作蓝牙设备，例如重启蓝牙设备等。如果这个蓝牙设备连接着一个系统中的控制设施（例如使用蓝牙进行连接的车辆控制系统），攻击者就有可能因此实现对系统的操纵。

4．拒绝服务攻击

攻击者可能使用硬件地址欺骗及漏洞使得蓝牙设备不可用，这就是针对蓝牙设备的拒绝服务攻击。

蓝牙设备的使用安全是每个蓝牙设备用户都应该考虑的问题，特别是对于重要的系统使用了蓝牙技术，更需要考虑蓝牙安全性。安全地使用蓝牙技术应考虑以下措施。

（1）在选择使用蓝牙设备时，应考虑设备的技术实现及设置是否具备防止上述安全威胁的能力，选择使用功能合适的设备而不是功能尽可能多的设备、尽量关闭不使用的服务

及功能、在企业安全管理体系中建立相应的安全管理要求等。

（2）在使用中减少不必要的风险，包括如果蓝牙设备丢失，把设备从已配对列表中删除、在配对时使用随机生成的密钥、不使用时设置不可被其他蓝牙设备发现等。

8.4.2 无线局域网安全

无线局域网（Wireless Local Area Networks，WLAN）是无线通信技术与网络技术相结合的产物，是通过无线信道来实现网络设备之间的通信，并实现通信的移动化、个性化和宽带化。在 WLAN 中，当前使用最为广泛的为 IEEE 指定的 802.11x 标准族，包括 802.11a、802.11b、802.11g 及 802.11n，加上安全方面的 802.11i。802.11x 标准使用星形拓扑，其中心称为接入点（Access Point，AP），在 MAC 层使用 CSMA/CA 协议。该标准规定 WLAN 的最小构件是基本服务集（Basic Service Set，BSS）。一个 BSS 包括一个基站和若干个移动站，所有的站在本 BSS 以内都可以直接通信，但在和本 BSS 以外的站通信时都必须通过本 BSS 的基站。如图 8-8 所示，分别以 AP1 和 AP2 为基站组成了两个 BSS。一个 BSS 所覆盖的地理范围叫作一个基本服务区（Basic Service Area，BSA）。

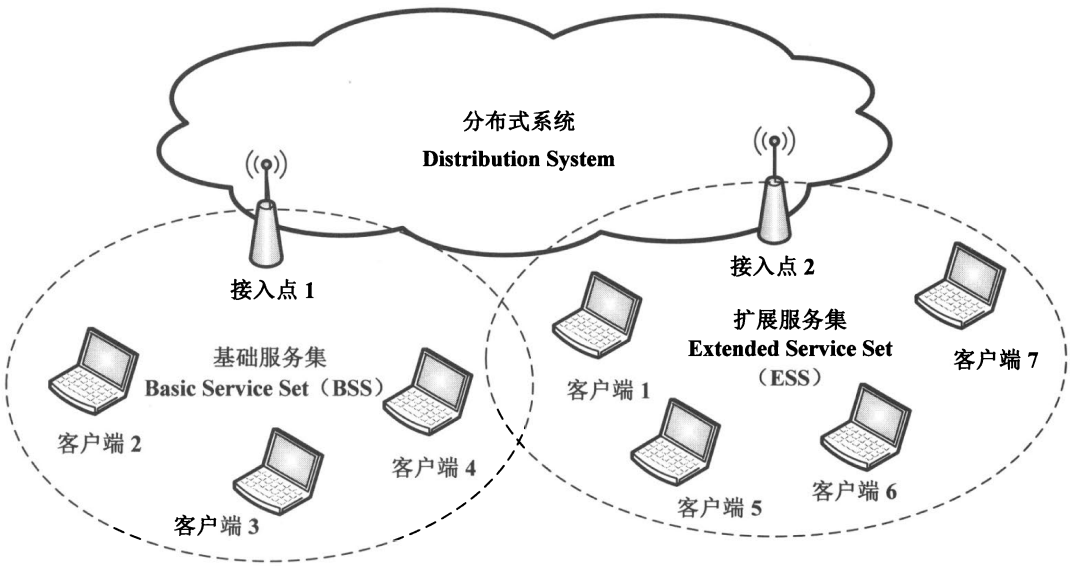

图 8-8 IEEE 802.11 的基本服务集 BSS 和扩展服务集 ESS

1．无线局域网安全协议

（1）WEP（有线等效保密协议）

在 IEEE 802.11i 协议出现以前，有线等效保密协议（Wired Equivalent Privacy，WEP）是无线局域网安全性保护协议。WEP 可提供传输数据加密、接入认证等一系列安全负责。WEP 有两种认证方式，即开放式系统认证（Open System Authentication）和共享密钥认证（Share Key Authentication）。

① 开放式认证即空认证，只要客户端发送一个认证请求消息，AP 即回应一个认证成功消息，采用这种认证方式的任何用户都可以认证成功。

在开放式系统认证的情况下，用户使用服务集标识符（Service Set Identifier，SSID）识别 AP。SSID 并非安全认证机制，仅仅用于标识不同的 AP 网段。伪造 SSID 是针对无线局域网用户的典型攻击方式，攻击者将自己控制的 AP 设置为大量用户所熟知的 SSID（例如中国移动的 CMCC），缺乏警惕性的用户接入这样的 AP 后，通过这个 AP 发送的敏感数据就被攻击者部署的嗅探器获取。出于安全的考虑，AP 可设置为不对外广播 SSID，但这显然不适用于面向公众提供服务的 AP。

MAC 地址过滤是很多厂商为了提高安全性而提供的功能，只有注册了 MAC 的 STA 才能关联至 AP，它要求 AP 在本地或远端服务器上建立 MAC 地址控制列表，MAC 地址不在列表中的 STA 不允许访问网络资源。由于 MAC 地址在帧首部以明文形式传输，非授权用户可以在监听到一个合法用户的 MAC 地址后，通过改变其 MAC 地址获得资源访问权限，所以这种方法也不能真正实现有效的访问控制。

② 共享密钥认证需要 AP 和客户端（Station，STA，也称工作站）预先共享一个密钥。由于设计上存在缺陷，这个密钥很容易被破解。WEP 使用静态的密钥来加密所有通信，通过简单级联初始化向量（Initialization Vector，IV）和密钥形成种子，并以明文方式发送 IV，IV 长度为 24 位，可供使用的 IV 值为 1600 万，因此在网络上很快会出现重复。同时，由于 WEP 使用 RC4 加密算法，这是一个流密码，流密码的原理是将一个短密钥扩展为一个无限的伪随机密钥流。发送者通过将密钥流与明文进行 XOR 操作得到密文，接收者拥有同样的短密钥，使用它可以得到同样的密钥流，将密钥流与密文进行 XOR 操作，即可得到原来的明文。一旦其中一个明文已知，很容易就可以破解并获得其他明文。针对 WEP 的破解工具可以在分析 100 万帧之后破解 RC4 的 40 位或者 104 位密钥，甚至可以在分析 20000 帧之后破解，在 802.11b 正常使用的条件下，最快只需要 11s 就可以破解密钥。

无论开放式系统认证或共享密钥认证均属于单向认证，没有认证 AP 的合法性，且过于简单，不能实现有效地访问控制。

（2）WPA 与 WPA2

由于 WEP 在认证、加密及密钥管理方面的安全问题，无法满足市场对于 WLAN 安全保护的要求。Wi-Fi 联盟在 802.11i 标准草案的基础上制定了 WPA（Wi-Fi Protected Access）标准，在数据加密和访问控制方面上进行了改进。2004 年，IEEE 发布了 802.11i 正式标准（也称为 WPA2），在加密算法上采用了基于 AES 的 CCMP 算法。802.11i 标准定义了强健安全网络（Robust Security Network，RSN）的概念，以增强无线网络的安全性。IEEE 802.11i 使用基于端口访问控制的 802.1X 协议进行身份认证和密钥管理，并定义了临时密钥完整性协议（Temporal Key Integrity Protocol，TKIP）和计数器模式及密码块链消息认证码协议（Counter Mode with CBC-MAC Protocol，CCMP）两种加密机制。为了与 WEP 保持兼容性，TKIP 仍采用 RC4 作为加密算法，通过固件升级和驱动程序更新即可将现有设备升级

到 TKIP 以加强安全性。CCMP 是基于高级加密标准（Advanced EncryptionStandard，AES）和 CCM（Counter-mode/CBC-MAC）模式的全新标准，提高了 WLAN 的安全等级。

802.11i 运行过程主要包括 4 个阶段：发现 AP、802.1X 认证、密钥管理和安全数据传输，如图 8-9 所示。

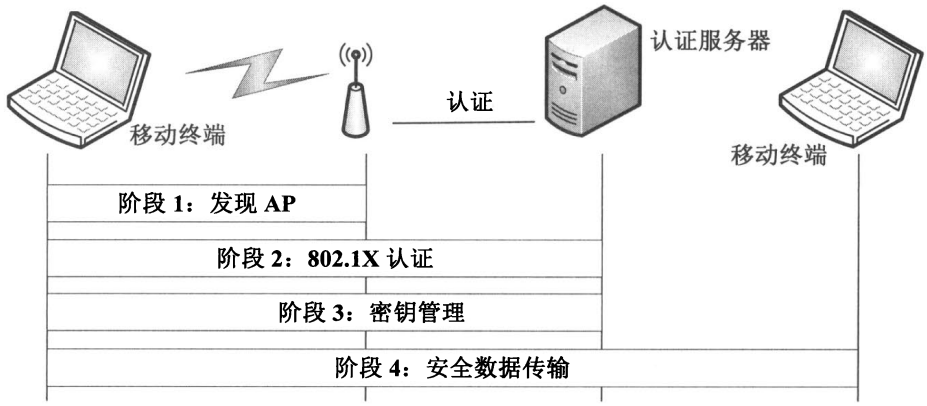

图 8-9　802.11i 的 4 个运行阶段

① 发现 AP 阶段

一个 AP 使用 Beacons、Presponse 等报文信息公布它支持 WPA2。STA 根据收到的信息选择相应的安全配置，并将所选择的安全配置表示在 Association Request 和 Re-Association Request 报文中。WPA 通过这种方式来实现 STA 与 AP 之间的加密算法以及密钥管理方式的协商。该阶段工作在开放系统认证方式上。

② 802.1X 认证阶段

802.11i 使用 802.1X 协议来实现用户认证和密钥管理。802.1X 本身只是一个框架，采用 IETF 制定的可扩展认证协议（Extensible Authentication Protocol，EAP）作为核心协议，EAP 属于一种框架协议，可适用于不同的链路层类型，如 EAP over LAN、EAP over PPP 等，并允许设计人员制定自己的 EAP 认证方式，常用的 EAP 认证方式有 TLS、AKA/SIM、MD5 等，可扩展和灵活性是 EAP 的最大优点。

802.1X 基于端口实现网络访问控制，定义了 3 个组件：申请访问者（supplicant）、认证者（authenticator）和认证服务器（Authentication Server，AS）。申请者是指请求访问网络资源的客户端，网络访问由认证者控制，认证者只负责链路层的认证交互过程，并不维护任何用户信息，任何认证请求均会被转送至认证服务器（如 Radius 服务器）进行处理，整个认证交换过程在逻辑上是通过认证服务器和申请者的交互完成，认证者只是扮演中介的角色。申请者与认证者之间使用 EAP over LAN（简称 EAPoL）协议，认证者与认证服务器之间通过网络协议（如 RADIUS 协议）封包来传递 EAP 协议报文（如 RADIUS 称之为 EAP overRADIUS）。

AS 通常是有线网络中的独立设备，但也可以在 AP 中实现。根据 802.1X 协议框架，

申请访问者（STA）向认证者（AP）发送 EAP 认证请求，AP 通过 RADIUS 消息验证用户合法性。一旦 STA 通过了 802.1X 身份验证之后，AS 会产生一个主会话密钥（MSK），也被称作 AAA key，将它传送给 STA。以后 STA 和 AP 通信的所有加密密钥都由此 MSK 生成。

③ 密钥管理阶段

经过 802.11X 认证之后，RADIUS 服务器向认证者（AP）发送与申请者相同的 PMK，作为 AP 与 STA 之间通信的密钥。AP 和 STA 之间通过四次握手和组密钥握手，重新生成一系列密钥，并将其分别安装在 AP 和 STA 上。

④ 安全数据传输阶段

IEEE 802.11i 定义了两种安全数据传输方式：一种是 TKIP（Temporal Key Integrity Protocol）；另一种是 CCMP（Count Mode-CBC MAC Protocol）。

为兼容 WEP，允许 WEP 设备通过软件升级到 TKIP。TKIP 仍采用 RC4 作为核心加密算法，可以仅仅通过在现有设备上软件升级的办法加以实现，从而提高 WLAN 的安全。

CCMP 机制基于 AES（Advanced Encryption Standard）加密算法和 CCM（Counter-Mode/CBC-MAC）认证方式，使得 WLAN 的安全性大大提高，是实现 RSN 的强制性要求。

（3）WAPI 安全协议

针对无线局域网协议中存在的安全问题，我国在 2003 年提出了 WLAN 国家标准，即无线鉴别和保密基础结构（WLAN Authentication and Privacy Infrastructure，WAPI）。WAPI 采用数字证书和椭圆曲线公开密钥体制，可以实现客户端和接入点的双向认证，对 WLAN 系统提供全面的保护。

WAPI 由无线局域网认证基础设施（WLAN AuthenticationInfrastructure，WAI）和无线局域网保密基础结构（WLAN Privacy Infrastructure，WPI）两部分组成，分别实现对用户身份的鉴别和对传输的数据的加密，其中 WPI 的加密算法由国家密码管理局指定。

WAI 实现对通信双方身份的鉴别，是实现 WAPI 的基础。WAI 采用公开密钥加密体制，利用证书对客户端和接入点进行认证。和 IEEE 802.1X 类似，WAI 也定义了三类实体：鉴别器实体、鉴别请求者实体、鉴别服务器实体，功能也和 IEEE 802.1X 一致。鉴权服务器 AS 即对应鉴别服务器实体，负责公钥证书的颁发、验证与吊销等，无线客户端 STA 和无线接入点 AP 分别对应鉴别请求者实体和鉴别器实体，两者都需要安装 AS 颁发的公钥证书，作为自己的数字身份凭证。当无线客户端登录至无线接入点 AP 时，在访问网络之前必须通过鉴权服务器 AS 对双方进行身份验证。根据验证的结果，持有合法证书的移动终端才能接入持有合法证书的无线接入点 AP。

整个 WAI 过程包括证书鉴别和会话密钥协商，过程如图 8-10 所示。

WPI 负责对 MAC 子层的 MPDU 进行加、解密处理，分别用于 WLAN 设备的数字证书、密钥协商和传输数据的加解密，从而实现设备的身份鉴别、链路验证、访问控制和用户信息在无线传输状态下的加密保护。

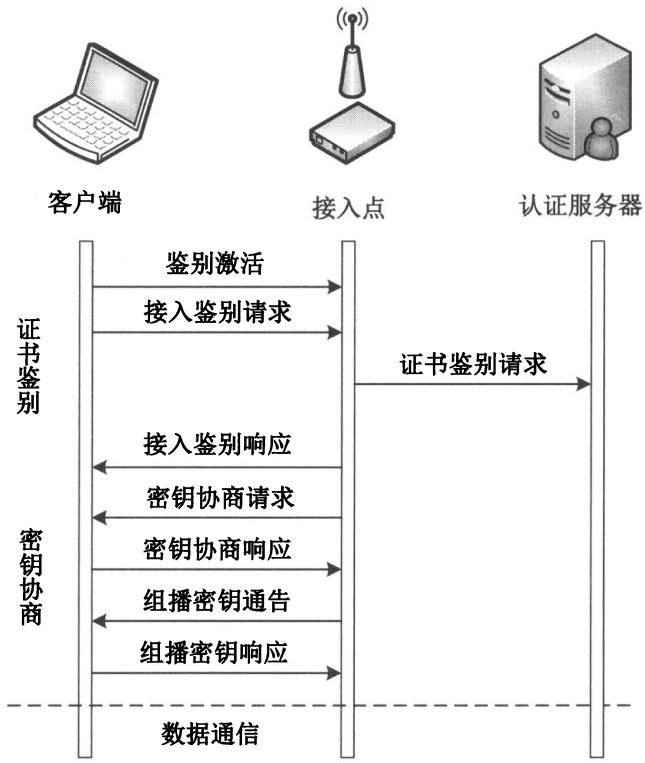

图 8-10　WAPI 证书鉴别和密钥协商流程

WAPI 与 WEP、802.11i 在鉴别和加密方面的安全特性比较如表 8-2 所示。

表 8-2　WEP、IEEE 802.11i、WAPI 三者比较

项　目		WEP	IEEE 802.11i	WAPI
鉴别	鉴别机制	单向鉴别	用户和服务器之间双向认证，但没有认证 AP	用户、接入点和认证服务器之间的相互认证
	鉴别方法	开放式系统鉴别或共享密钥鉴别	支持多种鉴别方式： 预共享密钥 Radius 服务器验证用户名口令 可使用非对称密码算法和数字证书	采用公钥数字证书作为身份凭证；无线用户与无线接入点地位对等，实现无线接入点的接入控制；客户端支持多证书，方便用户多处使用
	鉴别对象	客户机	用户、服务器	用户、接入点、服务器
	密钥管理	无	不同厂商不完全相同	全集中（局域网内统一由 AS 管理）
	算法	4 bit RC4	AES	192 位椭圆曲线算法
加密	密钥	静态	动态	动态
	算法	64 bit RC4	128bit RC4 或 AES	128-bit SMS4

2．无线局域网安全防护

无线局域网由于使用上的灵活和便利，应用日渐普及。很多城市已经将无线局域网建设作为智慧城市建设的重要组成部分。应用越广泛也意味着面临越来越多的安全问题。如何有效地保护无线局域网，为用户提供良好的服务是信息安全工作者无法逃避的挑战。针对无线局域网的安全特点，应从管理、技术方面采取措施才能保障无线局域网。

（1）将无线局域网安全管理纳入公司总体安全策略中

- 结合组织机构业务需求对无线局域网的应用进行评估，制定使用和管理策略。
- 限制无线局域网的使用范围，例如仅用于互联网资料查询和日常办公应用。
- 明确定义并限制无线局域网的使用范围，尽量不在无线网络中传输和处理机密和敏感数据。

（2）应用安全技术保护无线局域网安全

- 为访客设立独立的接入网段，并在无线局域网与业务网之间部署隔离设备。
- 对无线局域网接入使用安全可靠的认证和加密技术，如果有必要，可以使用其他认证机制。
- 部署入侵检测系统以发现可能的攻击并定期对无线局域网安全性进行审查。

8.4.3　RFID 安全

射频识别（Radio Frequency Identification，RFID）是一种应用广泛近场通信技术，通过无线电信号识别特定目标并读写相关数据。RFID 是一种简单的无线通信系统，由读写器和多个应答器构成，应答器也被称为智能标签或标签。读写器通过无线通信可以实现对智能标签识别码和内存数据的读写操作。RFID 技术可识别高速运动物体并可同时识别多个标签，操作快捷方便。

1．针对标签的攻击

- 数据窃取：存储在智能标签中的数据受智能标签计算能力和编程性限制，存在脆弱性，使得攻击者很容易从中获取数据；智能标签中存储数据的安全性通常与标签的成本相关，出于使用成本的考虑，在大量的应用中，使用的标签都不具备很好的数据安全防护能力；攻击者通过射频设备在空中截获标签与阅读器之间的通信，可收集大量用户敏感数据。
- 标签破解及复制：RFID 标签中使用的密钥如果不具备高的安全级别，攻击者可以使用破解设备实现对标签的破解（使用 40 位密钥的 RFID 产品，使用专用的破解设备可以在不到一个小时内完成破解），伪造标签，即使使用了高强度加密算法的标签，攻击者还可能对 RFID 标签进行复制，从而实现非授权操作。

2．针对读写器的攻击

- 拒绝服务：攻击者可以通过一些射频信号装置短时间内向读写器发送大量数据信

号，导致 RFID 系统被大量的信号所淹没，从而使 RFID 系统告警，丧失处理正常数据的能力，陷入停滞状态。

- 恶意代码：如果标签信息中带有病毒或攻击代码，RFID 后台系统若不能提供任何免疫机制和查杀手段，则会导致病毒代码直接进入后端应用系统中。

3．针对无线信道的攻击

由于 RFID 是一种无线通信技术，因此针对无线网络的攻击方式在 RFID 体系中也可以使用，包括干扰、嗅探等。

4．RFID 安全防护

RFID 系统的安全防护需要采取综合性的防护措施，在部署和实施 RFID 之前，应进行充分的业务安全评估和风险分析。

- 对于重要的 RFID 标签，例如用于身份验证的标签，应选择支持 Kill 和休眠的标签。
- 使用高安全加密算法的标签。
- 涉及资金的应用使用在线核查方式。

8.5 知识子域：典型网络攻击及防范

8.5.1 欺骗攻击

欺骗攻击是通过伪造数据从而获得不当优势的一类攻击方式。由于互联网广泛使用的 TCP/IP 协议存在的安全缺陷，攻击者通过伪造源于可信任地址的数据包，可欺骗目标系统获得权限或操作目标系统。欺骗攻击是一种攻击类型的统称，常见的实现方式有 IP 欺骗（IP spoofing）、ARP 欺骗（ARP Spoofing）、DNS 欺骗（DNS Spoofing）以及 TCP 会话劫持（TCP Hijack）等。

1．IP 欺骗

互联网中的两台计算机经过认证后相互信任，当其中一台计算机收到来自另外一台计算机的数据包，如果符合相应的规则，那么这个数据包中的数据就会被接收并处理。IP 欺骗就是利用这一点来实现的，向目标主机发送源地址为已经建立信任关系主机的 IP 报文，冒充其他主机对目标主机进行 IP 欺骗。IP 欺骗攻击能否成功的关键在于数据报文中的会话序号是否正确。

实施 IP 欺骗攻击前需要进行两个前置步骤：一是获得目标主机与被冒充主机之间会话的序号，这是 IP 欺骗攻击能否成功的关键，通常实现方式是通过反复尝试与目标主机建立连接的方式，分析目标主机序数的生成算法，进而猜测出可能的会话序数。二是使被冒充主机无法响应目标主机的数据包，通常采取的方式是对被冒充主机实施拒绝服务攻击，使该主机暂时无法处理连接数据。

针对 IP 欺骗的防御方式是使用抗 IP 欺骗的产品或对网络设备进行配置，拒绝来自外部端口但源地址却是本地地址的数据包。当然，如果某种原因信任了某个外部主机，网络设备不会阻止声明源于这台信任主机的欺骗攻击。

2．ARP 欺骗

地址解析协议（Address Resolution Protocol，ARP）的作用是将网络层的地址（IP 地址）解析成数据链路层的地址（MAC 地址）。ARP 协议是无状态的协议，计算机系统无须收到 ARP 请求就可以发送 ARP 应答，而这个应答会被接收到的计算机系统进行处理。操作系统的 TCP/IP 实现上，系统会根据需要向网络发送 ARP 应答报文，为了提高效率，降低 ARP 数据流量，系统会在缓存中维持一个 IP 地址与 MAC 地址的映射表，默认状态下，这个 ARP 缓存是即时刷新，计算机系统接收到新的应答数据就会覆盖掉之前的数据。

攻击者通过向网络或目标主机发送伪造的 ARP 应答报文，修改目标计算机上 ARP 缓存，形成一个错误的 IP 地址<->MAC 地址映射，这个错误的映射在目标主机需要发送数据时封装错误的 MAC 地址。

例如，著名的利用 ARP 欺骗的中间人攻击过程如图 8-11 所示。

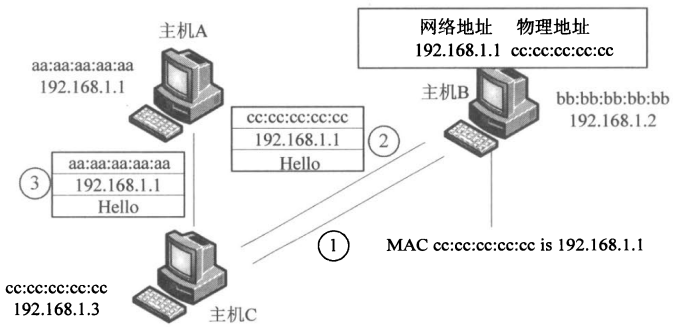

图 8-11　ARP 欺骗攻击过程

首先，攻击者主机 C（IP：192.168.1.3）向主机 B（IP:192.168.1.2）发送伪造的 ARP 应答报文，应答中给出的 IP 地址为 192.168.1.1（主机 A），MAC 地址是 CC:CC:CC:CC:CC（主机 C）。这是一个典型的 ARP 欺骗报文。这个欺骗的 ARP 应答报文被主机 B 收到后，按照协议处理过程，会将接受到的数据添加或更新到 ARP 缓存中，因此，攻击者成功地修改了主机 B 上的 ARP 缓存，形成了一个错误的缓存记录。

当主机 B 希望与主机 A 进行通信，在数据封装时，会根据缓存中的记录进行封装，在网络层封装的地址是主机 A 的 IP 地址（192.168.0.1），但是在链路层封装时，由于缓存中存在错误的数据，因此封装的地址是主机 C 的 MAC 地址（CC:CC:CC:CC:CC）。标准的交换设备使用二层地址进行数据包的分发，因此这个数据包就会被交换机送到主机 C。主机 C 收到这个数据包后，对封装进行修改后再转发给真正的主机 A。这个过程就是著名的中间人攻击。

ARP 欺骗是一种非常有威胁的攻击，攻击者利用 ARP 欺骗可实现中间人欺骗、拒绝服

务等攻击。由于 ARP 缓存有时间限制，为了避免缓存更新，攻击者需要不断向欺骗目标发送伪造的 ARP 应答报文，确保错误的缓存记录被保持。因此对网络中的 ARP 报文进行分析可以有效地检测到 ARP 攻击行为。针对 ARP 欺骗有以下应对措施。

- 使用静态的 ARP 缓存，缓存中的数据不能被 ARP 应答报文刷新，能有效地解决 ARP 欺骗攻击。然而由于使用静态缓存，每次硬件地址变更都需要人工更新，当网络中计算机数量较多的情况下，设备地址的变更会形成较大的工作量。
- 使用三层交换，由于三层交换技术使用 OSI 模型第三层地址（TCP/IP 协议中为 IP 地址）进行数据交换，不会受到错误封装的 MAC 影响。
- 除非设置了 ARP 代理，默认情况下 ARP 协议无法跨越路由设备，因此划分更多的子网能降低 ARP 攻击影响的范围。
- 在系统中部署 ARP 防火墙以阻止攻击者修改 ARP 缓存。

3．DNS 欺骗

域名系统（Domain Name System，DNS）是互联网中大量使用的基础服务。TCP/IP 协议使用网络层地址（IP 地址）定位一台主机，而 IP 地址对于用户是难以记忆的，因此用户经常采用 www.cisp.org.cn 这样的域名访问主机，DNS 的作用就是为用户提供域名与 IP 地址的解析。域名是一个分布的数据库系统，不同的域名分布在全球不同的域名服务器上。在实际应用中，DNS 服务器对于自身无法解析的域名，会向其他 DNS 服务器查询，并且为了提高效率，域名服务器会对已经查询的结果进行缓存。攻击者利用以上特点，通过伪造 DNS 应答在目标 DNS 服务器上生成错误的缓存数据，从而欺骗用户访问错误的服务器。这种攻击就是 DNS 欺骗，也称为 DNS 高速缓存污染。

例如，攻击者对某个 DNS 服务器进行缓存污染，在该 DNS 服务中生成一个 www.cisp.org.cn 错误的缓存记录，即 www.cisp.org.cn 的 IP 地址是 11.11.11.11（攻击者控制的某个服务器）。攻击者进行攻击的过程如下。

攻击者向目标 DNS 服务器发出对 www.cisp.org.cn 的查询请求，如果 DNS 服务器中无此域名的缓存信息，就会向其他 DNS 服务器进行查询。

攻击者立即向目标 DNS 服务器发送伪造的 DNS 应答报文，告诉目标 DNS 服务器，www.cisp.org.cn 域名的 IP 地址是 11.11.11.11，如果这个应答被接受，DNS 服务器会将此应答报文的数据存入缓存中。攻击者就成功地生成了一条错误的 DNS 记录。应答报文是否被接受的关键是 DNS 服务器向外进行查询的一个查询 ID，攻击者伪造的报文必须给出正确的查询 ID 才可被 DNS 服务器接受。

当其他客户机再向该 DNS 服务器查询 www.cisp.org.cn 域名对应的 IP 地址时，DNS 服务器会将缓存中的记录 www.cisp.org.cn<->11.11.11.11 返回给查询的客户机，从而将客户机导向错误的主机。

由于 DNS 缓存存在时间限制，DNS 欺骗存在实效性，一旦超过缓存的有效时间，除非重新构造缓存中的记录，否则 DNS 欺骗会自动失效。此外，与 ARP 欺骗不同，攻击者

不能替换缓存中已经存在的记录。

解决 DNS 欺骗最有效的方法是采用最新版本的 DNS 服务软件，新版本的软件在抵御 DNS 欺骗方面更优于老版本软件，也可以通过配置系统，如限制域名服务器做出响应的地址、限制发出查询请求的客户机地址等，降低攻击者 DNS 欺骗成功的几率。

8.5.2　拒绝服务攻击

拒绝服务（Denial of Service，DoS）攻击是一种让攻击目标瘫痪的攻击手段。攻击者利用协议中的某个弱点，或者系统存在的某些漏洞，甚至合理的服务请求，对目标系统发起大规模的进攻，致使攻击目标无法对合法用户提供正常的服务。拒绝服务攻击的实现方式非常多，包括 SYN Flood、UDP Flood、TearDrop、ARP Flood、Smurf、Land 等。

1．SYN Flood

SYN 是 TCP 协议中的一个标记位，称为同步序号，用于发起 TCP 会话的三次握手过程。三次握手是建立一次 TCP 会话前的协商过程，请求通信的客户机与服务器建立 TCP 会话前，客户机需要向服务器发出一个 SYN 被标记的数据包，这是连接请求。服务器收到后，需要回应一个 ACK 标记的数据包对此请求的确认，同时，为了实现双工的会话，服务器也需要发送自己的连接请求。服务器对客户机请求的应答和建立连接请求通常在一个数据包中（ACK/SYN 都标记）。客户机对服务器的连接请求进行 ACK 确认后，3 次握手过程完成，TCP 会话被建立起来。

SYN Flood 攻击通过伪造带有虚假源地址的 SYN 包，使目标主机发送的 ACK/SYN 包得不到确认。一般情况下，目标主机会等一段时间后才会放弃这个连接，在这个等待的过程中，会占用一个连接。系统所能支持的连接数是有限的，因此当大量的如同洪水一般的虚假 SYN 包同时发送到目标主机时，目标主机上就会有大量的连接请求等待确认，当这些未释放的连接请求数量超过目标主机所支持的并发连接数量时，其他正常的连接请求由于连接耗尽，就不能被目标主机接受，从而形成拒绝服务。

2．UDP Flood

UDP 是一个高效率的传输层协议，攻击者针对使用 UDP 协议的应用，通过产生大量的 UDP 数据报文，占用目标网络的带宽，使得目标网络拥塞，从而导致网络无法访问。例如，目标网络出口带宽为 100M，攻击者通过向目标网络发送 200M 流量的 UDP 数据报文，可形成目标网络出口带宽耗尽，从而形成拥塞，正常的服务流量无法通过。

3．泪滴攻击（TearDrop）

泪滴攻击也被称为分片攻击或碎片攻击，由于首次实现这种攻击的软件名称是 TearDrop，因此这种攻击就被称为泪滴攻击。TCP/IP 协议在数据传输过程中，对过大的数据会进行分包处理，传输到目的主机后再到堆栈中进行重组。为实现重组，IP 包的包头中包含有信息说明该分段是源数据的哪一段。如果发送伪造的含有重叠偏移信息的分段包到

目标主机，当被攻击主机试图将分段包重组时，由于分段数据的错误，重组过程会引起内存错误，导致协议栈的崩溃。

4．分布式拒绝服务攻击

分布式拒绝服务攻击（Distributed Denial of Service，DDoS）是攻击者利用专用程序，实现多个计算机系统协同进行拒绝服务攻击的一种方式。在发动分布式拒绝服务攻击之前，攻击者预先控制了大量的计算机系统，并且安装了攻击程序或控制程序。攻击者通过控制程序下达攻击指令，使得多个安装了攻击程序的计算机系统同时向目标发起拒绝服务攻击，这种攻击方式不仅加大了攻击的威力，也能很好地保护攻击的发起者，如图 8-12 所示。

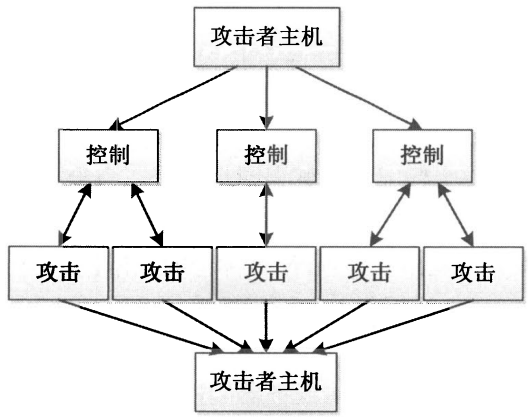

图 8-12　DDoS 攻击示意图

拒绝服务攻击无法依赖单一的技术措施来防御，应建立防护、监测和响应等多种机制结合的防御体系，确保把拒绝服务攻击导致的安全风险降低到可接受的水平。

8.6　知识子域：网络安全防护技术

8.6.1　边界防护

互联网是为了共享资源而创建，但是安全始终是联网系统中无法回避的问题，为了确保网络中信息、资源的安全，就产生了将自身网络与不安全的网络隔离的需求。这些隔离是建立在连接的基础上，通过技术和设备，将存在安全风险的数据、用户隔离在外，从而降低自身网络安全的风险。实施隔离的位置通常是在网络的边界处，边界防御是安全防护的重要环节。

1．防火墙

防火墙是基础的网络安全产品，也是目前应用最广泛、最易于被用户接受的边界防护技术。防火墙用于在两个不同安全要求的安全域之间，根据定义的访问控制策略，检查并控制这两个安全域之间所有流量。

（1）防火墙的主要技术

- 静态包过滤：根据数据包的源地址、目的地址、源端口号、目的端口号、会话协议及数据包头中的各个标记等因素，按照系统预先制定好的规则来决定对数据包的操作（丢弃、通过或转发）。静态包过滤技术逻辑简单、易于实现，处理速度快，但无法实现对应用层信息过滤处理，并且对于网络服务多、结构复杂的网络，包过滤规则配置复杂。
- 应用代理：应用代理技术在内部设备与外部设备通信时进行数据转发，而转发的会话必须符合代理的安全策略。应用代理技术不允许会话双方直接通信，因此具有较高的安全性，同时由于工作在应用层，防火墙可以对应用层数据进行处理，能针对应用层传输的数据进行访问控制，例如可以对 HTTP 协议中的 POST 方法进行拒绝，也可以提供更详细的日志记录。不足之处在于对数据包全部进行转发，系统性能消耗极大，因此处理效率比静态包过滤防火墙低，并且由于需要为每个服务编写相应的代理程序，使得防火墙设备的灵活性不高。
- 状态检测：也称动态包过滤，是对静态包过滤技术的功能扩展。状态检测技术通过维护一个记录着网络连接状态变化的状态表来自动生成或删除安全过滤规则。由于使用了状态表，状态检测防火墙可处理会话当前的状态属性、顺序号、应答标记等信息，能有效地抵御伪造应答报文类型的攻击。状态检测技术的优势在于可根据会话信息决定过滤规则，因此具有较高的安全性，但由于需要检测的内容更多，因此对硬件性能也提出了更高的要求。

（2）防火墙部署

实际工作中，不仅仅要关注防火墙产品技术和防火墙产品，更重要的是要考虑如何根据安全要求和实际环境部署及使用防火墙。不同的组合方式体现了系统不同的安全要求，也决定了系统将采取不同的安全策略和实施方法。

- 单防火墙（无 DMZ）部署：非军事区（Demilitarized Zone，DMZ）是安全网络与非安全网络之间的缓冲区。无 DMZ 区的防火墙部署方式是最简单的防火墙部署架构，通过防火墙设备将需要隔离的网络分开，防止来自外部的安全威胁，从而实现对内部设备的安全防护。无 DMZ 区的单防火墙部署适用于主要需求为内部受控地访问外部资源，并且很少或者没有需要外部来访问的资源。
- 单防火墙（DMZ）部署：防火墙提供一个或多个虚拟非军事区（DMZ），用于部署允许外部网络访问的公开服务系统，如 Web 系统、邮件系统等。DMZ 的数量依赖于使用的防火墙产品所能支持和扩展的 DMZ 端口的数量，可以根据不同的安全要求将各种不同类型的公共服务放在不同的 DMZ 中，并根据需要对外部网络、内部网络、DMZ 网络之间的流量进行控制。
- 双防火墙部署：双防火墙体系结构为穿过防火墙的不同安全区域之间的流量提供了更细粒度的控制能力。在这种系统及结构中，使用两台防火墙分别作为外部防火墙和内部防火墙，在两台防火墙之间形成了一个非军事区网段，与前面支持

DMZ 的单防火墙系统结构相似，外部流量允许进入 DMZ 网段，内部流量允许进入 DMZ 网络并通过 DMZ 网段流出至外部网络，但外部网络的流量不允许直接进入内部网络。双防火墙体系结构的缺点是它的实施复杂性和费用较高。

2．安全隔离与信息交换系统

安全隔离与信息交换系统也称为安全隔离网闸或简称为网闸，是针对物理隔离情况下数据交换问题而发展出来的技术，现在也被用于高安全要求网络上的边界安全防护。通常情况下，安全隔离与信息交换系统由外网处理单元、内网处理单元和中间的隔离部件构成。内网处理单元和外网处理单元分别连接两个不同安全级别的网络，两个网络之间无法建立直接或间接的基于 OSI 或 TCP/IP 链路层以上的网络连接。在需要进行信息交换时，安全隔离与信息交换系统内部隔离安全交换单元模拟形成开关，同一时间只和一个网络进行连接，不会同时连接两个网络。在信息交换时，隔离部件周期性地在两端网络之间切换，需要交换和共享的信息就可以从一个网络传递到另外一个网络。安全隔离与信息交换技术实际上是模拟人工在两个网络之间进行数据复制的方式。

安全隔离与信息交换系统作为一种网络边界安全技术，原理和实现功能与防火墙有明显区别，主要体现在安全隔离与信息交换系统采用专用硬件控制技术保证内外网之间没有物理连接，而防火墙一般存在逻辑连接。

3．其他边界安全防护技术

信息化技术的发展使得边界安全技术也在不断的进步，更多的防护技术被加入边界防护中。针对不同的安全需求，IPS、防病毒网关、上网行为管理、统一威胁管理等各种不同类型的边界安全产品先后诞生。

IPS（Intrusion Prevention System，IPS）是集入侵检测和防火墙于一体的安全设备，部署在网络出口中，不但能检测入侵的发生，而且能针对攻击进行响应，实时地中止入侵行为的发生和发展。

防病毒网关部署在网络出口处，对进出的数据进行分析，发现其中存在的恶意代码并进行拦截。

统一威胁管理（Unified Threat Management，UTM）将防病毒、入侵检测防火墙等多种技术集成一体，形成标准的统一威胁管理平台。

8.6.2 检测与审计

1．入侵检测系统

入侵检测系统（Intrusion Detection System，IDS）是对网络中传输的数据进行实时监测，发现其中存在的攻击行为并进行相应的响应（报警或根据策略采取措施）的网络安全设备。与防火墙是被动防御设备不同，IDS 是一种主动的安全防护技术，是防火墙的良好补充，也是构建完善信息安全防御体系必不可少的设备。

对网络安全管理员来说，IDS 的主要作用是发现并报告系统中未授权或违反安全策略行为，为网络安全策略的制定提供指导。

（1）入侵检测分类

入侵检测系统根据部署方式及数据来源，可以分为网络入侵检测和主机入侵检测。

网络入侵检测通常是硬件形式，部署在需要检测的区域的关键节点上，被动地监听网络上传输的数据报文，通过入侵检测技术（特征匹配或行为分析）来识别可能的攻击。网络入侵检测在应用中以旁路方式接入，不会对网络的传输数据带来干扰，但其检测结果仅依据传输的数据报文，准确度较差，并且无法应对加密数据流量、不能检测主机内部发生的入侵行为、对于交换网络支持不足、处理负荷较重等。

主机入侵检测一般是软件形式，部署在需要防护的主机上，除了可以检测到主机网络接口上传输的数据，还能调用操作系统的审计、日志等数据，并且能分析操作系统的状况。主机入侵检测无须额外硬件，能结合操作系统日志等数据进行分析，准确性相对较高，并且能应用在加密环境，但由于软件运行的形式与平台相关，可移植性差，会占用主机资源，依赖主机操作系统的稳定性和安全性。

在实际环境部署的入侵检测系统一般为分布式结构，关键的主机系统上部署主机入侵检测，关键的网络节点上部署网络入侵检测，采集的数据统一送到管理中心进行分析。

（2）入侵检测技术

- 误用检测：也称为特征检测，根据已知入侵攻击的信息（知识、模式等）来检测可能的入侵行为。误用检测需要对现有的各种攻击手段进行分析，建立能够代表该攻击行为的特征集合，然后将采集到的数据进行处理后与这些特征集合进行匹配，如果匹配成功则说明有攻击发生。
- 异常检测：根据系统或用户的非正常行为或者对于计算机资源的非正常使用来检测可能存在的入侵行为。异常检测需要建立一个系统的正常活动状态或用户正常行为模式的描述模型，然后将用户当前行为模式或系统的当前状态与该正常模型进行比较，如果当前值超出了预设的阈值，则认为存在攻击行为。

（3）入侵检测系统部署

入侵检测的部署应首先明确目标和安全策略，根据目标网络拓扑结构和信息系统类型，选择适合的入侵检测系统类型并进行部署。

主机入侵检测系统则直接安装在需要检测的主机中。网络入侵检测系统采集的数据来自网络中的数据报文，通常部署在网络关键位置的交换机、路由器等网络设备上设置镜像端口来获取数据。例如需要检测目前网络受到的总攻击数量，则入侵检测系统就部署在防火墙外，这样就可以检测到所有进出防火墙外网的数据，从而检测到所有来自外部可能的攻击行为并进行记录。如果想要了解有多少针对 DMZ 区的攻击，那么就将入侵检测系统部署在 DMZ 区的总出口处。

（4）入侵检测系统的局限性

入侵检测系统在实际应用中，由于产生的数据量较大，需要用户具有较好的安全知识

才能针对入侵检测的数据进行分析，因此对用户要求较高。随着信息技术的快速发展，网络设备的性能大幅增加，传输速度快速增长，对入侵检测的性能要求也越来越高，这使得现有的入侵检测很难满足实际处理需要，另外，由于入侵检测提供的报警信息来自网络采集数据，存在高虚警率问题。

2．安全审计系统

安全审计系统是按照一定的安全策略，对系统日志、网络数据、用户活动、环境状况进行检查，以发现系统漏洞、违规操作等行为的安全设备。安全审计系统与入侵检测工作机制类似，也分为网络安全审计和主机安全审计，通过对采集数据进行分析以发现存在的违规行为。

安全审计系统与入侵检测不同之处在于，安全审计系统实际是记录与审查用户操作计算机系统和网络活动，例如用户访问记录、操作记录、使用的资源、时间等。通过对系统记录和行为进行独立审查，安全审计系统能对可能存在的攻击者起威慑和警示作用、发现系统的不安全状态以及时进行调整并对系统安全策略的变更进行评价及反馈等。

8.6.3 接入管理

1．虚拟专用网（VPN）

虚拟专用网（Virtual Private Network，VPN）是在公共网络中，利用隧道技术，建立一个临时的、安全的网络。VPN 提供加密、认证和访问控制等技术来保障通过公共网络传输数据的安全性，具有成本低、安全可靠等特点，因此广泛地被用于安全的远程访问和接入。

（1）关键技术

隧道技术是通过对数据进行封装，在公共网络上建立一条数据通道（隧道），让数据包通过这条隧道传输。在数据链路层进行封装的是二层隧道协议，包括点到点隧道协议（Point to Point Tunneling Protocol，PPTP）和第二层隧道协议（Layer Two Tunneling Protocol，L2TP）。在网络层进行封装的是第三层隧道协议，主要有 IPSec 和通用路由封装协议（General Routing Encapsulation，GRE）。SSL、TSL 等协议工作在传输层之上，对应用层数据进行封装。

密码技术是 VPN 确保网络上未授权的用户无法读取和篡改数据技术方式，在 VPN 实现中，双方大量的通信流量的加密使用对称加密算法，而在管理和分发对称加密的密钥上采用非对称加密技术。

（2）应用领域

远程访问 VPN，适用于企业内部人员流动频繁或远程办公的情况。出差员工或在家办公的员工利用当地 Internet 服务提供商（ISP）就可以和企业的 VPN 网关建立私有的隧道连接。

内联网 VPN，适用于企业内部异地分支机构的互联。内联网 VPN 在异地两个网络的网关之间建立了一个加密的 VPN 隧道，两端的内部网络使用该 VPN 隧道，和使用本地网

络一样通信。

外联网 VPN（Extranet VPN），适用于企业将客户、供应商、合作伙伴或兴趣群体连接到企业内部网。Extranet VPN 其实也是一种网关对网关的 VPN，与 Intranet VPN 不同的是，它需要在不同企业的内部网络之间组建，需要有不同协议和设备之间的配合和不同的安全配置。

2．网络准入控制

当前网络发展迅速，病毒、蠕虫和间谍软件等网络安全威胁始终是造成网络安全问题的重要原因之一。与此同时，移动计算的普及，移动用户通过笔记本、智能手机、PAD 等设备能随时随地连入无线网络，使得病毒、蠕虫等恶意代码的传播更加容易和难以受到控制。移动用户能够从家里或公共热点连接互联网或办公室网，常常在无意中感染病毒，并将其带进企业环境，进而感染网络。

网络准入控制（Network Access Control，NAC）是通过对连入网络的客户端设备进行授权，以阻止非授权用户连接进网络的技术。通过 NAC，可以只允许合法的、值得信任的端点设备（例如 PC、服务器、笔记本、智能手机等）接入网络，而不允许其他设备接入。对于授权的设备，NAC 还能检查设备的“状态”，确保等待接入网络的设备符合一定级别的安全标准。它会检测病毒防护软件的升级版本、当前可用补丁、浏览器设置限定，以及有效的个人防火墙等，是否符合要求，然后决定是否准允其接入网络。

在用户访问网络之前，NAC 能够确保用户的身份可信，同时，也会检测和评价用户所使用的终端设备是否符合安全要求，以防止将恶意代码带入内部网。

第 9 章

知识域：计算环境安全

阅读提示 本知识域主要介绍操作系统安全机制及配置、Web、电子邮件等应用系统安全及数据保护等概念，通过对该知识域的学习，能了解操作系统及应用系统安全机制、针对系统、应用的典型攻击及数据安全相关知识。本知识域由操作系统安全、信息收集与系统攻击、恶意代码防护、应用安全和数据安全 5 个知识子域构成。

9.1 知识子域：操作系统安全

9.1.1 操作系统安全机制

操作系统是管理系统资源、控制程序执行、提供良好人机界面和各种服务的一种系统软件，是连接计算机硬件与上层软件和用户之间的桥梁。操作系统是计算机系统的资源管理者，有序地管理计算机中的硬件、软件资源，并作为用户与计算机硬件之间的接口，帮助用户方便、快捷、安全、可靠地操纵计算机硬件和运行自己的程序。操作系统安全是计算机环境安全的基础和根本，很多应用软件的安全都是构建在操作系统安全的基础上。操作系统安全目标包括以下方面。

（1）标识系统中的用户和进行身份鉴别。

（2）依据系统安全策略对用户的操作进行访问控制。

（3）保证系统自身的安全性和完整性。

（4）监督系统运行的安全性。

为实现安全目标，操作系统需要建立相应的各类安全机制，这些机制主要包括标识与鉴别、访问控制、权限管理、信道保护、安全审计等。

1. 标识与鉴别

标识与鉴别是操作系统基础的安全机制。操作系统利用标识来跟踪用户的操作，用户一旦完成了身份鉴别，就要对基于该标识的所有行为负责。关于标识与鉴别机制的详细内容请参见第 7 章中的 7.2 节有关内容。

（1）Windows 的身份标识与鉴别

Windows 的安全主体类型主要包括用户账户、组账户、计算机和服务，使用安全标识符（Security Identifier，SID）在系统内部进行标记。SID 的创建者和作用范围依赖于账户类型。对于用户账户，就由本地安全授权机构（LSA）生成在该系统内唯一的 SID。而对于域账户则是由域安全授权机构来产生 SID。活动目录把域账户 SID 当作该 SID 所标识的用户或组的一个对象属性来存储，而域账户 SID 在域内是唯一的。当授予用户、组、服务或者其他安全主体访问对象的权限时，操作系统会把安全标识符和权限写入对象的访问控制列表中。

安全标识符是一串字符串，通常在安全主体创建时生成，由计算机名、当前时间、当前用户态线程的 CPU 耗费时间的总和 3 个参数决定以保证它的唯一性。一个完整的 SID（如 S-1-5-21-1534169462-1651380828-111620651-500）包括以下内容。

- 用户和组的安全描述。
- 48-bit 的身份特权（ID authority）。
- 修订版本。
- 可变的验证值。

鉴别是使用户和标识建立联系的过程，Windows 本地登录验证身份鉴别是通过安全通道将用户鉴别信息与预先存储的信息进行对比的过程。Windows 本地用户信息加密存储在注册表中，并且只有 system 账户才有权限进行访问，而 system 作为系统内置账户，不可从交互界面登录，因此确保了用户信息不会被任何一个用户账号获取。用户对鉴别信息的操作，例如更改密码等都通过一个以 system 权限运行的服务“Security Accounts Manager”来实现。

远程登录则较为复杂，在 Windows 发展中经历了 SMB 鉴别协议、LM 鉴别机制、NTLM 鉴别机制、Kerberos 鉴别体系等阶段。

（2）Linux 的身份标识与鉴别

Linux 使用用户标识号（User ID，UID）来标识和区别不同的用户。UID 是 0～65535 之间的一个整数值，在系统内部管理进程和文件保护时使用 UID 字段，在某些特定目的下，系统中可以存在多个拥有不同注册名、但 UID 相同的用户，事实上，这些使用不同注册名的用户是同一个用户。

Linux 的用户信息存储在/etc/passwd 中（早期的 passwd 中包含了用户的密码散列），该文件用于用户登录时校验用户的登录名、加密的口令数据项、用户 ID（UID）、默认的用户分组 ID（GID）、用户信息、用户登录目录以及登录后使用的 shell。这个文件的每一行保存一个用户的资料，而用户资料的每一个数据项采用用户冒号“:”分隔，格式如下所示：

```
注册名:口令:用户标识号:组标识号:用户名:用户主目录:命令解释程序 shell
```

/etc/passwd 文件是全局可读，意味着攻击者是可以看到所有用户的口令散列，包括 root 的口令，虽然使用了不可逆的加密算法（如 DES）来加密口令，但由于算法是公开的，因此攻击者仍然可以使用散列来获取口令。针对这一问题，Linux 系统使用 shadow 文件机制，

将用户口令散列转移到该文件中，shadow 文件只有 root 可读可写，而同时/etc/passwd 文件的密文域显示为一个 x，从而保护用户口令避免泄露。

2．访问控制

访问控制技术是信息安全领域一项传统的技术，其基本任务是防止非法用户进入系统及防止合法用户对系统资源的非法使用。操作系统的访问控制是操作系统安全机制中重要的一环，在身份识别的基础上，根据身份对提出的资源访问请求加以控制。

在访问控制中，对其访问必须进行控制的资源称为客体；必须控制其对客体的访问的活动资源称为主体。主体即访问的发起者，通常为进程、程序或用户。客体包括各种资源，如文件、设备等。访问控制中第三个元素是保护规则，它定义了主体与客体可能的相互作用途径。

访问控制的目的是为了限制访问主体对访问客体的访问权限，从而使计算机系统在合法范围内使用。它决定用户能做什么，也决定代表一定用户身份的进程能做什么，其中主体是某个用户，也可以是用户启动的进程和服务。自主访问控制模型中的 ACL 是操作系统中广泛应用的访问控制模型。例如 Windows 中的访问控制，对每一个客体都保持一个访问控制列表，其中包含有权访问客体对象的用户和组的 SID，系统管理员和所有者有权更改这个控制列表中的信息，如图 9-1 所示。

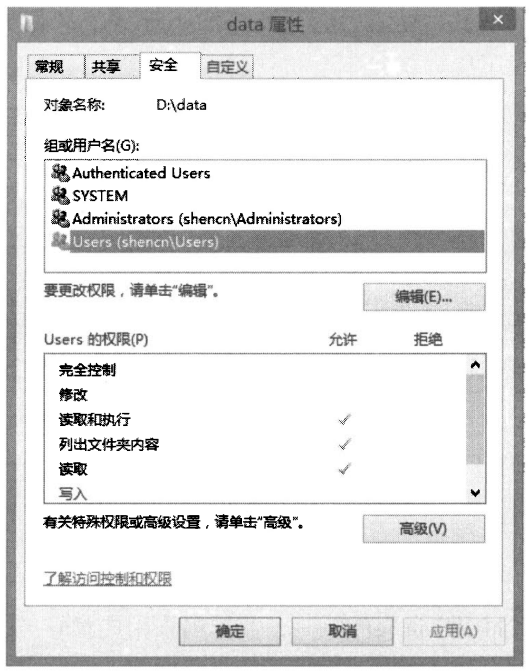

图 9-1　Windows 文件系统访问控制列表

注：Windows 系统的 ACL 信息存储在 NTFS 文件系统的流中，因此必须使用 NTFS 文件系统才能使用访问控制功能。

关于访问控制相关知识，具体参见第 7 章中的 7.3 节中相关内容。

3．权限管理

操作系统中的超级用户具有极高的权限，可执行一些受限的操作或者进行超越安全策略控制的行为。超级用户的口令丢失、账号冒用会对系统带来极大的损失，而超级用户的误操作也是操作系统安全的潜在安全隐患。为了避免这些安全问题，操作系统机制和安全管理中，应遵循最小特权的原则，只给予主体完成所需要的任务或操作的最小特权，这种只给予主体“必不可少”的特权限制了每个主体所能进行的操作，从而减少由于特权被冒用、误操作等引起的安全问题。例如 Windows 使用的标准受限访问令牌及 Linux 下提供的 sudo 命令都是权限管理的具体体现。

Windows 系统使用管理员账号登录时，系统默认给予受限访问令牌，只有当管理员明确要求对某个进程“以管理员身份运行”后，系统才给予该进程完全访问令牌，此时该进程才具备完整的管理员权限，如图 9-2 所示。

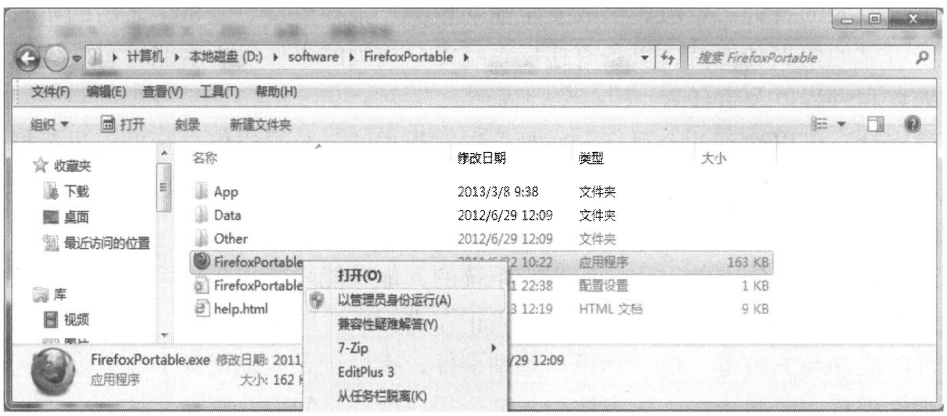

图 9-2　Windows 下的受限访问令牌

Linux 系统提供的 sudo 命令，使管理员平时可以用普通账号登录系统进行操作，在明确需要使用 root 身份时使用 sudo 命令以 root 身份运行进程。

4．信道保护

对信息道路的保护涉及两个方面：一方面对显式信息道路的保护，防止非法或非授权信息经过显式信道；另一方面，要堵住隐蔽的信息通路，防止恶意用户通过隐蔽信道。

（1）正常信道的保护机制

正常信道的保护机制是由可信通路（Trusted Path）机制提供的。可信通路机制一般是以安全键（Secure Attention Key，SAK）为基础实现的。SAK 是由终端驱动程序检测到的一个特殊按键组合。每当系统识别到用户在一个终端上输入的 SAK，便终止对应到该终端的所有用户进程（如果其中存在特洛伊木马，也会被终止），启动可信的会话过程，以保证用户名和口令不被窃走。如 Windows 系统中，安全键是 Ctrl+Alt+Delete，用户同时按下这 3 个键后，Windows 系统会终止所有用户进程，重新激活登录界面，提示用户输入用户

名和口令。

（2）隐蔽信道的发现和处理

隐蔽信道是指系统中利用那些本来不是用于通信的系统资源绕过强制访问控制进行非法通信的一种机制。特洛伊木马攻击的一个关键标志是通过一个合法的信息信道进行非法的通信，这些信道一般是用于交互进程通信的，如文件、交互进程或者是共享内存。虽然强制访问控制机制能够防止利用这些信道进行非法通信，但是用户还可以利用计算机系统中本意不是用作通信的信道进行通信，这些信道就是隐蔽信道。对于隐蔽信道的定义，橘皮书中给出的是“隐蔽信道是允许进程以危害系统安全策略的方式传递信息的信道”。

5．安全审计

安全审计包括审计事件、审计记录和审计日志等，审计事件是系统审计用户的最基本单位。一个系统的安全审计就是对系统中有关安全的活动进行记录、检查及审核。它的主要目的就是检测和阻止非法用户对计算机系统的入侵，并显示合法用户的误操作，并为系统进行事故原因的查询、定位，事故发生前的预测、报警以及事故发生之后的实时处理提供详细、可靠的依据和支持，以备有违反系统安全规则的事件发生后能够有效地追查事件发生的地点和过程以及责任人。

通过审计，可以达到两个目标：一是可以对受损的系统提供信息帮助以进行损失评估和系统恢复；二是可以详细记录与系统安全有关的行为，从而对这些行为进行分析，发现系统中不安全的因素。

审计一般是一个独立的过程，应当与系统的其他功能隔开。操作系统的审计记录一般应包括如下信息：事件的日期和时间、代表正在进行事件的主体的唯一标识符、事件的类型、事件的成功与失败等。对于标识与鉴别事件，审计记录应该记录下事件发生的源地点（如终端标识符）。对于将一个客体引入某个用户地址空间以及删除客体的事件，审计记录应该包括客体名以及客体的安全级。此外，操作系统应该能够监督审计管理员，防止其权利过大。

9.1.2　操作系统安全配置要点

为了应对日益严峻的安全问题，一般操作系统都提供了相应的安全配置接口。安全配置主要有以下几个方面：操作系统安全策略、关闭不必要的服务、关闭不必要的端口、开启审核策略、开启密码策略、开启账户策略、备份敏感文件、不显示上次登录名、禁止建立空连接和下载最新补丁等。

1．安全补丁

操作系统同其他软件一样，不能证明其在任何条件下都是完全正确的，可能在使用过程中会出现这样那样的漏洞，因此系统管理员应该经常关注漏洞情况，及时下载和安装漏洞补丁，以增强操作系统的安全性。一般操作系统厂商都会提供免费的漏洞补丁和安全服务。

2．最小化部署

操作系统中提供的很多服务及功能是为了方便用户和管理员，这些服务和功能可能被设置为默认开启，然而对用户、管理员并非都是必需的。这些服务和功能可能被攻击者利用给系统带来安全风险，因此在系统运行中应考虑最小化部署，关闭不需要的服务和功能。

3．远程访问控制

随着操作系统安全机制的不断完善，防火墙已经被内置在操作系统中，利用防火墙提供的访问控制功能。设置防火墙策略，只开放对外提供服务的端口，将其他端口的访问都进行屏蔽，能对系统安全性带来极大的提升。例如 iptables 很早就内置在 Linux 中并且在大量发行版中都是默认启用的。

注：即使在网络层已经部署了网络防火墙，在操作系统上设置防火墙策略仍然是有必要的，纵深防御是提高系统安全性的基本原则之一。等级保护技术要求中也对操作系统层的访问控制提出要求，无论网络层是否提供访问控制。

4．账户策略及口令策略

使用系统提供的安全策略保护账号口令安全，设置策略避免弱口令，例如设置口令长度不能低于 8 位，不能使用简单的组合等。同时设置账户锁定策略，对于连续登录错误达到一定次数的账户进行锁定，避免攻击者的口令暴力破解攻击。

下面是密码设置的一般性原则。

- 严禁使用空口令和与用户名相同的口令。
- 不要选择可以在任何字典或语言中找到的口令。
- 不要选择简单字母组成的口令。
- 不要选择任何和个人信息有关的口令。
- 不要选择短于 6 个字符或仅包含字母或数字。
- 不要选择作为口令范例公布的口令。
- 采取数字、字母、特殊符号混合并且易于记忆。

5．安全审计

日志是系统安全的最后一道防线，对日志系统的审计能及时发现系统中存在的安全问题并发现安全事件的原因并提供相应的证据。因此对于操作系统的日志安全配置是安全管理的重要工作。通过安全策略配置，确保日志系统能记录下事件的更多信息，并通过权限设置，保护日志不会被攻击者删除、篡改或伪造。如果有可能，可以考虑在网络中部署日志服务器以确保日志的安全性。

6．其他安全策略

针对不同操作系统的特点，还应该考虑有针对性的安全配置，例如 Windows 系统中关闭自动播放功能，关闭管理共享，Linux 设置文件创建时默认权限等。

9.2 知识子域：信息收集与系统攻击

9.2.1 信息收集

1. 信息收集的概念

信息收集是攻击者开始攻击的第一步，通过收集目标网络或目标系统的信息，了解目标系统和网络的基本状况，为下一阶段的攻击提供有价值的信息，甚至可以直接利用收集到的信息进行攻击。信息收集的主要内容包括目标系统的相关资料，如域名、网络拓扑结构、操作系统的类型和版本、应用软件及相关脆弱性等；目标系统的组织相关资料，如组织架构及关联组织、地理位置细节、电话号码、邮件等联系方式、近期重大事件、员工简历等，以及其他令攻击者感兴趣的任何信息。

历史上的“照片泄密”事件可以看出信息收集的重要作用。建国以来，我国一直被认为是贫油国家，而大庆油田的发现彻底改变了这个观点，处于安全考虑，当时大庆油田的信息都作为国家秘密，不允许对外公布。但为了宣传铁人王进喜，1964 年《中国画报》封面刊出一张照片，照片上“铁人”王进喜头戴大狗皮帽，身穿厚棉袄，顶着鹅毛大雪，握着钻机手柄眺望远方，在他身后散布着星星点点的高大井架。日本一家企业根据照片上王进喜的衣着判断，只有在北纬 46 度至 48 度的区域内，冬季才有可能穿这样的衣服，因此，推断大庆油田位于齐齐哈尔与哈尔滨之间。通过照片中王进喜所握手柄的架式，推断出油井的直径，从王进喜所站的钻井与背后油田间的距离和井架密度，推断出油田的大致储量和产量。有了这些分析结果，这家企业迅速设计出适合大庆油田开采用的设备，在我国政府向世界各国征集大庆油田的开采设计方案时一举中标。

2. 信息收集的方法

（1）公开渠道信息收集

公开渠道是攻击者最轻易获取的信息的方式，由于缺乏足够的安全意识，很多信息系统对公开信息没有审核或审核宽松，使得攻击者可以通过公开渠道获得目标系统大量有价值的信息。公开信息收集方式包括搜索引擎、媒体广告等方式。其中，搜索引擎是使用最广泛的公开渠道信息收集方式，攻击者可以利用搜索引擎进行攻击定位和信息定点挖掘，获取并分析目标系统的安全漏洞、配置文件等资料，为攻击的实施创造有利条件。

- 攻击定位：使用搜索引擎能实现对攻击目标的快速定位，攻击者可以查找与目标系统及网络相关的资料和文档，从中发现对攻击有用的信息。例如，大量网站广泛使用的某免费开源论坛系统中某个脚本文件“XXX.jsp”被发现存在安全漏洞，攻击者通过搜索该脚本文件，能很轻松地找到使用了此脚本的 Web 网站，接下来便可以对该 Web 网站针对性地实施攻击。
- 定点挖掘：攻击者可以通过搜索引擎实现对特定目标的信息采集，包括某些特定

目标不对外公开的信息。例如，攻击者在搜索引擎中搜索“.doc+XXX.com”找到 XXX.com 网站上所有的 Word 文档。攻击者甚至可以通过搜索“.mdb”“.ini”+域名，找到该域名下的 mdb 库文件、ini 配置文件等非公开信息。

- 漏洞查询：如何利用搜集到的信息实施攻击是攻击者最关心的问题，而漏洞库及安全论坛是攻击者获得攻击方法及攻击工具的有效手段。获取系统的信息后，攻击者通过漏洞库或安全论坛查询，得到相关版本软件的安全漏洞，并对此实施攻击。

（2）利用网络服务信息收集

使用网络服务、服务旗标（banner）识别、TCP/IP 协议栈检测等技术，也能收集并分析目标系统的网络结构、操作系统和应用系统类型、版本等信息。

① **网络服务：**whois 是一个标准网络服务，用于提供域名相关信息的查询，攻击者通过向 whois 服务提交查询请求，获得目标域名的相关信息，包括联系人、联系电话、域名解析服务器等，这些信息有助于攻击者实施域名攻击。

攻击者还可以使用 ping、tracert 等系统命令或其他工具，获得目标网络的信息。如图 9-3 所示，攻击者利用 tracert，能收集到目标之间经过的路由设备 IP 地址，选择其中存在安全防护相对薄弱的路由设备实施攻击，或者控制路由设备，对目标网络实施嗅探等其他攻击。

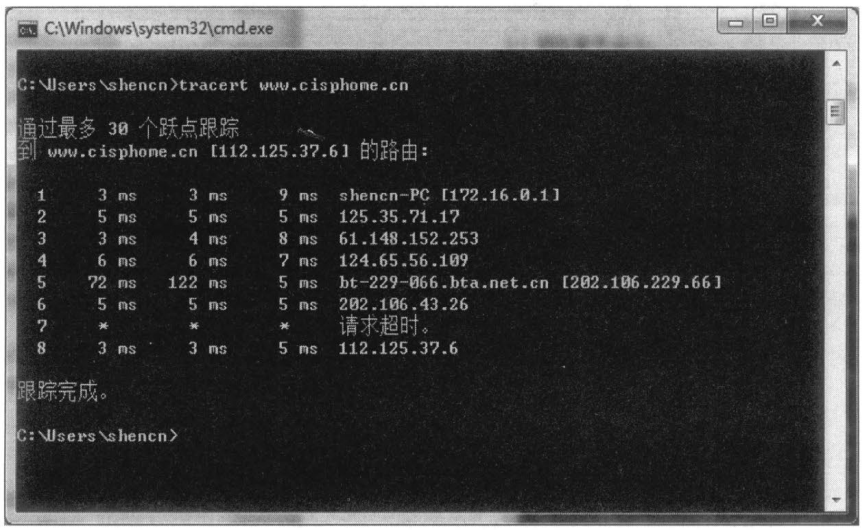

图 9-3　tracert 路由跟踪示意

② **服务旗标识别：**应用服务如 IIS、FTP 等在用户登录时，会在欢迎信息中包含应用的基本信息。例如，FTP 登录时，某些服务器给出的回显信息是“220 Serv_U FTP Server v6.0 For winsock ready……”，说明了 FTP 服务软件名称及版本号等信息。如图 9-4 所示为识别 Web 服务旗标的例子，可以看到，在 Web 服务器的反馈信息中，包含 Web 服务的软件名称、版本号等敏感信息。攻击者在获得了这些信息后，就可以利用该版本服务软件的漏洞进行攻击。

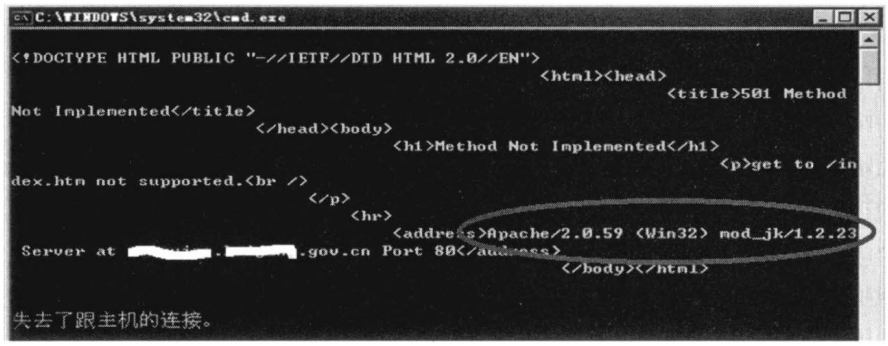

图 9-4　Web 服务信息收集

③ **TCP/IP 协议栈检测**：不同操作系统的 IP 协议栈实现之间存在细微的差别，通过这些差别，可以区分出目标操作系统的类型及版本，这种方法也称为 TCP/IP 协议栈指纹识别法。例如，对远端计算机进行 ping 操作，不同操作系统回应的数据包中初始 TTL 值是不同的，如图 9-5 所示，根据回应的数据包中的 TTL 值，可以大致判断操作系统的类型。

图 9-5　不同系统对 ICMP 协议实现差异

3．信息收集与分析的防范

有效对抗信息收集和分析的原则只有一个，就是“严防死守”。所有不是必须向用户提供的信息，就是需要保护的信息。

首先，应通过信息安全培训，使相关信息发布人员了解信息收集的风险，发布信息应采取最小化原则，所有不是必要的信息都不发布，是防止公开渠道的信息收集的途径。重

点单位应建立信息发布审查机制，对发布的信息进行审核，避免敏感信息的泄露。

其次，通过尽量减少系统中对外服务的端口数量、修改服务旗标等方式，关闭不必要的服务，以及部署防火墙、IDS 等技术措施，也能有效防止信息的收集与分析。同时，系统安全管理员可以使用漏洞扫描软件对系统进行安全审计，及时发现存在的漏洞，采用安装系统补丁或升级等方法进行修补。

9.2.2 缓冲区溢出攻击

1. 缓冲区基本概念

- 缓冲区：缓冲区也称堆栈，是一种抽象的数据结构，物理上就是一段连续分配的内存空间。堆（heap）和栈（stack）是不同的两个概念，堆是由程序申请并释放的内存空间，而栈是由操作系统自动分配的内存空间。堆栈有两个特点：一是数据操作（压栈（push）和出栈（pop））遵循“后进先出”原则，就像往有底的竹筒里面放乒乓球，最后放进去的必须最先取出来；二是堆栈的增长方向与内存地址增长方向相反，也就是堆栈是从内存的高地址向低地址增长的。
- 指针：编程语言中的一个对象，是一个内存地址。
- 寄存器：有限存储容量的高速存储部件，它们可用来暂存指令、数据和地址。以X86 32 位 CPU 为例，其通常包含 8 个通用寄存器和 1 个指令指针寄存器。8 个通用寄存器分别是 EAX、EBX、ECX、EDX、ESI、EDI、ESP、EBP 和指令指针寄存器 EIP。其中，ESP 和 EBP 被称为堆栈指针寄存器，在一个函数中，ESP 和 EBP 共同决定了一个堆栈，其中 ESP 指向栈顶，EBP 指向栈底。而指令指针寄存器（EIP）作为冯·诺依曼计算机体系结构的核心，其指向 CPU 要执行的下一条指令的地址。

在堆栈分配中，是从高地址往低地址分配内存（注意，这和内存从低往高分配的方式截然相反），并且遵循“后进先出”的原则。堆栈涉及压栈（push）和出栈（pop）两种操作，堆栈的栈顶位置由寄存器 ESP 指定，压栈时，ESP=ESP-4，同时在 ESP 处存放需要压入堆栈的数据；出栈时，ESP=ESP+4，原先的栈顶数据将不再属于堆栈范围之内，即相当于数据出栈了。

2. 缓冲区溢出攻击原理

缓冲区溢出是一种非常普遍也非常危险的漏洞，广泛存在于各种操作系统、应用软件中。漏洞的原因是由于程序员对数据没有进行严格的校验，攻击者可以通过向程序的缓冲区写入超过预定长度的数据，从而破坏程序的堆栈，导致程序执行流程的改变，使得攻击者可以操纵被攻击软件并执行攻击者设定的代码。

缓冲区溢出攻击分为栈溢出和堆溢出，下面用一个示例程序来说明缓冲区溢出（栈溢出）攻击，示例程序代码如下：

```
#include <stdio.h>
int main()
```

```
{
char name[8];
printf("Please input your name: ");
gets(name);
printf("you name is: %s!", name);
return 0;
}
```

这段程序的功能是显示输入的用户名称。在程序中，用于存放用户输入名称的变量name长度定义为8位，由于程序缺少必要的输入长度校验，当用户的输入值超过8位时，printf("you name is: %s!", name)执行时会导致一个缓存溢出。例如输入用户姓名为“aaaaaaaaaaaaaaaaaaaaaaa”时，由于输入值超过name定义的长度（程序申请缓冲区），当程序将用户输入值保存到 name 的地址空间时，会继续向内存后续地址空间写入其余输入内容，进而覆盖了程序栈中存储的返回地址（EIP），如图9-6所示。

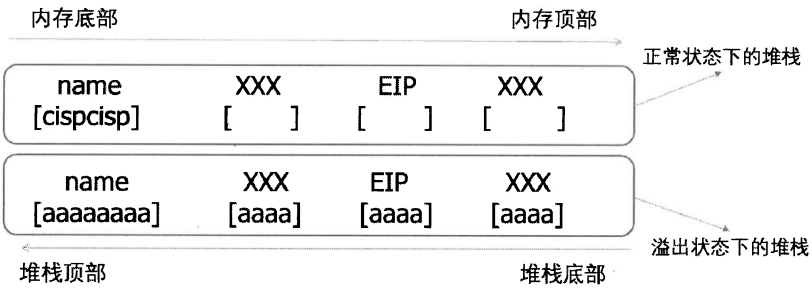

图9-6 缓冲区溢出堆栈状态

程序在需要调用返回地址时，把EIP中存储的“aaaa”的ASCII码0x61616161作为下一条指令地址，CPU 会试图执行 0x61616161 处的指令，而由于该内存并非运行程序所能访问，因此这个操作会被系统拒绝，因此产生错误，如图9-7所示。

图9-7 缓冲区溢出错误

如果攻击者输入的内容是经过精确定义的，覆盖了 EIP 原有的地址，使得程序跳转到

攻击者覆盖进去的地址去执行下一条指令，而该地址处被攻击者预先放置了一段攻击代码，那么攻击者就可以执行这段攻击代码从而获得系统控制权或者执行其他攻击操作。

3．缓冲区溢出的危害

1988 年 11 月，由康奈尔大学学生罗伯特·泰潘·莫里斯编写的“Morris”蠕虫感染了互联网中 6000 多台 UNIX 系统计算机，约占当时互联网上计算机总量的 10%，造成包括美国国家航空和航天局、军事基地和主要大学的计算机停止运行的重大事故。美国的政府审计办公室估算出蠕虫造成的损失为 1000 万～1 亿美元。莫里斯蠕虫之后，利用缓冲区溢出漏洞的蠕虫多次给互联网和计算机系统用户带来了无法估量的损失。

4．缓冲区溢出的防范措施

对用户而言，要防范缓冲区溢出攻击，需要及时安装安全补丁。即使是拥有最好的程序员，经过多年开发完善的软件，也很难彻底消除缓冲区溢出问题。大量用户并非软件的开发者或专业的安全人员，不可能自己解决所有的安全问题，因此，安全补丁或更新程序是解决缓冲区溢出问题的有效方法。而对于软件开发机构来说，应对开发人员进行安全编码培训，了解缓冲区溢出攻击的概念及了解如何避免缓冲区溢出漏洞的产生。提高编写安全代码的能力是降低缓冲区溢出漏洞产生的有效方法。

除此之外，现在操作系统中使用的虚拟化技术对缓冲区溢出攻击有较好的防护作用。

5．其他类型的溢出

溢出攻击是一种非常复杂的攻击，除了缓冲区溢出，还有很多其他类型的溢出。例如整数溢出、格式化字符串漏洞等。

（1）整数溢出：计算机中整数都有一个宽度（例如 Windows 7 下 VC6 编译器中 int 类型为 32 位），当试图保存一个比它可以表示的最大值还大的数时，就会发生整数溢出。整数溢出将导致“不确定性行为”。比如完全忽略该溢出或终止进程。大多数编译器都会忽略这种溢出，这可能会导致不确定或错误的值保存在了整数变量中。

（2）格式化字符串：格式化字符串漏洞同其他许多安全漏洞一样是由于程序员的疏忽大意造成的。例如程序员正在编写代码，他的任务是：打印输出一个字符串或者把这个串复制到某缓冲区内。为了节约时间和提高效率，他可能将代码“printf("%s", str);”省略为“printf(str);”。系统在编译时自动指定格式，而如果攻击者传入的参数包含特殊的格式字符，如"%d"，函数会认为这是一个格式化字符，从而按照这个格式化字符要求来打印输出。这使得攻击者可以查看特定的内存地址数据并利用特定格式化字符向内存中写入任意值，从而控制程序的执行。

9.3　知识子域：恶意代码防护

恶意代码（Malicious Software、Malware、Malicious code）指故意编制或设置的、对网

络或系统会产生威胁或潜在威胁的计算机代码。从更安全、更严格的角度描述，恶意代码也常常被定义为没有有效作用，但会干扰或破坏计算机系统及网络功能的程序、代码或一组指令，在英语中对应使用 Unwanted Code 来表示。恶意代码的存在形式可能包括二进制代码或文件、脚本语言或宏语言等；表现形式包括病毒、蠕虫、后门程序、木马、流氓软件、逻辑炸弹等。恶意代码通过抢占系统资源、破坏数据信息等手段，干扰系统的正常运行。它是信息安全的主要威胁之一，已经成为网络犯罪的主要工具，也是国家、组织之间网络战的主要武器。

恶意代码最初的概念由著名的计算机之父冯·诺依曼（John Von Neumann）于 1949 年在论文《复杂自动装置的理论及组织的行为》提出，他用数学的方法预言了可自我繁殖和实施破坏性功能程序出现的可能性。1977 年夏天，美国作家 Thomas.J.Ryan 在他的科幻小说《P-1 的春天》（*The Adolescence of P-1*）中描写了一种可以在计算机中互相传染的病毒，这个病毒最终控制了 7000 台计算机，造成了一场很大的灾难，由于书中对计算机病毒描写的很细致很逼真，因此这本书成为美国当年的畅销书。至此之后，各种不同类型的恶意代码就被称为计算机病毒。

1994 年 2 月 18 日由国务院颁布的《计算机信息系统安全保护条例》的第二十八条，就明确地阐述：“计算机病毒，是指编制或者在计算机程序中插入的破坏计算机功能或者毁坏数据，影响计算机使用，并能自我复制的一组计算机指令或者程序代码。”这是我们国家法律法规对计算机病毒的一个明确、严谨的定义。

9.3.1 恶意代码预防

传播途径是恶意代码赖以生存的基本条件，只有进入目标系统并被执行起来，恶意代码才能实现代码的相关功能。如果能针对恶意代码的传播方式采取技术措施，掐断恶意代码的传播途径，就能有效地控制恶意代码导致的危害。恶意代码的传播包括文件传播、网络传播、软件部署 3 种方式。

（1）文件传播

恶意代码作为文件的一部分或者自身就是一个独立文件，通过文件复制的方式达到进入目标系统的目的。常见的传播实现如下。

- 感染文件，当文件被复制和执行时传播到目标系统中。例如 CIH 病毒感染可执行文件，当带毒可执行文件被执行时进入目标系统，宏病毒感染 Word 文档等。
- 借助移动存储介质进行传播，利用 Windows 系统默认开启的自动播放功能进入目标系统。

注：自动播放功能是 Windows 为了方便用户的一种机制，当存储介质被接入系统中时，系统会检测存储介质的根目录下是否存在 Autorun.inf 文件，如果存在该文件，Windows 系统就会自动运行 Autorun.inf 中设置的可执行程序。

（2）网络传播

恶意代码利用网络进入目标系统并执行，常见的传播实现方式如下。

- 网页挂马，通过在网页中设置恶意代码，利用浏览器及组件的漏洞将恶意代码传播到目标系统中。
- 垃圾邮件，通过发送携带恶意代码的电子邮件给目标邮箱，采用社会工程学方式或利用邮件客户端漏洞将恶意代码在目标系统中执行。
- 利用即时通讯的关系链或伪装 P2P 下载资源等方式传播到目标系统中。
- 利用系统漏洞直接传播到目标系统中。

（3）软件部署

某些 Rootkit、木马、脚本后门及逻辑炸弹等恶意代码本身不具备自动传播的能力，它们通过文件捆绑或者上传等方式进入用户系统。这类恶意代码常常将自身与其他普通软件进行捆绑，用户在安装该软件后，恶意代码将随之进入系统。常见的实现方式如下。

- 攻击者在获得系统的上传权限后，将恶意代码部署到目标系统。
- 恶意代码自身就是软件的一部分，随软件部署传播，例如逻辑炸弹和预留的后门代码。
- 内嵌在软件中，当文件被执行时进入目标系统，例如流氓软件随着其他软件安装进入系统中。

针对恶意代码的预防包括安全策略、减少漏洞和减轻威胁 3 个方面的措施。

（1）安全策略

组织机构需要针对恶意代码防护制定明确的安全策略并传递给组织的每个成员并确保落实。作为预防性控制的基础，安全策略能有效地降低由于人员错误导致的安全问题的数量。常见的恶意代码预防策略包括并不限于以下内容。

- 制定策略以确保定期对组织机构成员进行安全意识教育，使成员了解恶意代码传播的方式及如何应对，例如不可随意单击未知用户发送的链接、不随意下载并安装软件等。
- 制定策略对组织机构成员的行为进行规范，例如不允许私自安装软件、不允许使用外部存储介质直接接入本地计算机、计算机上必须安装杀毒软件并且确保定期进行更新病毒库等。
- 限制用户对管理员权限的使用，限制计算机终端之间直接连接交换数据等。

（2）减少漏洞

计算机系统中存在的各种安全漏洞是恶意代码得以传播的主要原因之一，通过对信息系统实施良好的补丁管理和系统安全加固是应对恶意代码的有效措施。给系统和应用软件安装最新的安全补丁是解决系统中存在的已知漏洞的主要方法，而通过安全配置及安装安全防护软件对主机进行安全加固能提高信息系统抵抗恶意代码的能力。常用的系统安全加固措施包括并不限于以下内容。

- 对系统连接进行限制，通过软件防火墙等技术实现对系统开放的端口连接进行控制。

- 禁用或删除不需要的服务，降低服务运行权限等措施以提高服务安全性。
- 设置策略避免系统出现弱口令并对口令猜测进行防护。
- 设置并增强系统日志机制以提高审计能力。

（3）减轻威胁

减轻威胁是在系统中部署如防病毒软件、入侵检测/防御系统、防火墙、防病毒网关等安全防护技术措施，检测并发现恶意代码，阻断对系统进行的操作等。

9.3.2 恶意代码检测与分析

1. 恶意代码检测

恶意代码的检测是恶意代码防护中非常重要的技术，通过对软件的特征、行为等进行检测以发现恶意代码。恶意代码的检测技术包括特征码扫描和行为检测两种方式。

（1）特征码扫描

特征码扫描是恶意代码检测中使用的一种基本技术，广泛应用于各类恶意代码清除软件中。当恶意代码的样本被采集到时，恶意代码分析工程师会对恶意代码分析并提取恶意代码中特定的特征数据，这段数据就是该恶意代码的特征码。特征码被加入防病毒软件的特征数据库中，由杀毒引擎调用并对系统中的文件进行匹配，如果在系统某个文件中发现了与某恶意代码特征数据相同的数据，就判断这个文件感染了病毒或者就是某种病毒。因此，病毒扫描的过程就是特征数据匹配的过程。

特征码扫描技术的优势是准确性高、易于管理，是广泛使用的恶意代码检测技术。然而特征码扫描技术也存在着技术上的不足。首先是随着恶意代码数量的增长，特征库规模不断的扩充，扫描效率越来越低。信息系统发展到今天，已经诞生的恶意代码数量在数十万的量级，因此理论上来说，如果需要扫描一个文件是否携带恶意代码，需要与数十万个特征码进行匹配，这样的工作效率是系统不可承受的。因此在实际应用中，防病毒软件仅仅匹配少量的特征数据以实现高效的扫描。其次，由于特征码是从恶意代码中提取的，因此只能用于检测已知恶意代码，不能发现新的恶意代码，具有一定滞后性。

（2）行为检测

行为检测技术是为了解决特征码扫描技术存在滞后性，即只能发现已知恶意代码问题而诞生的解决方案。通过对大量的恶意代码行为分析，构建出一个恶意代码的行为模型。防病毒软件通过对软件的行为检测，将软件行为与恶意代码行为模型进行匹配，以判断是否为恶意代码。行为检测技术根据程序的操作行为分析，判断其恶意性，因此可用于未知病毒的发现，但由于对于恶意代码行为及正常软件行为区分的困难性，行为检测技术存在较大的误报概率。

2. 恶意代码分析

恶意代码分析是指利用多种分析工具掌握恶意代码样本程序的行为特征，了解其运行

方式及安全危害，是准确检测和清除恶意代码的关键环节。为了抵抗安全防护软件，恶意代码使用的隐藏和自我保护技术越来越复杂，以便在系统中长期生存。目前，常用恶意代码的分析方法可以分为静态分析和动态分析两种。这两种方法结合使用，能较为全面地收集恶意代码的相关信息，以达到较好的分析效果。

（1）静态分析

静态分析不需要实际执行恶意代码，它通过对其二进制文件的分析，获得恶意代码的基本结构和特征，了解其工作方式和机制。恶意代码特征分析是静态分析中使用的一种基本方法。它通过查找恶意代码二进制程序中嵌入的可疑字符串，如文件名称、URL 地址、域名、调用函数等，来进行分析判断。反汇编分析使用反汇编工具将恶意代码程序或感染恶意代码的程序本身转换成汇编代码，通过相关分析工具对汇编代码进行词法、语法、控制流等分析，掌握恶意代码的功能结构。由于不需要运行恶意代码，静态分析方法不会影响运行环境的安全。另一方面，静态分析方法可以分析恶意代码的所有执行路径，但是随着程序复杂度的提高，执行路径数量庞大，冗余路径增多，会出现分析效率很低的情况，甚至导致分析无法完成。

（2）动态分析

动态分析是指在虚拟运行环境中，使用测试及监控软件，检测恶意代码行为，分析其执行流程及处理数据的状态，从而判断恶意代码的性质，并掌握其行为特点。动态分析针对性强，并且具有较高的准确性，但由于其分析过程中覆盖的执行路径有限，分析的完整性难以保证。恶意代码一般会对运行环境中的系统文件、注册表、系统服务以及网络访问等造成不同程度的影响，因此动态分析通过监控系统进程、文件和注册表等方面出现的非正常操作和变化，可以对其非法行为进行分析。另一方面，恶意代码为了进入并实现对系统的攻击，会修改操作系统的函数接口，改变函数的执行流程、输入/输出参数等，因此动态地分析检测系统函数的运行状态，数据流转换过程，能判别出恶意代码行为和正常软件操作。

虚拟化技术是动态分析中广泛采用的一种技术，将恶意代码放置在虚拟的计算环境中运行，不仅可以很好地保护真正的分析系统，还能较好地解决变形恶意代码的检测问题。经过加密、混淆或多态变形的恶意代码放入虚拟机后，将自动解码并开始执行恶意操作，由于运行在可控的环境中，通过特征码扫描等方法，可以检测出恶意代码的存在。

9.3.3 恶意代码的清除

恶意代码的清除是根据恶意代码的感染过程或感染方式，将恶意代码从系统中剔除，是将被感染的系统或被感染的文件恢复正常的过程。

1．感染引导区型恶意代码的清除

引导区型恶意代码是一种通过感染系统引导区获得控制权的恶意代码，根据感染的类型分为主引导区和引导区恶意代码两种类型。由于恶意代码寄生在引导区，因此可以在操

作系统前获得系统控制权，其清除方式主要是对引导区进行修复，恢复正常的引导信息，恶意代码随之被清除。

2．文件依附型恶意代码的清除

文件依附型恶意代码是一种通过将自身依附在文件上的方式以获得生存和传播的恶意代码，由于恶意代码将自身附在被感染文件上，只需根据感染过程和方式，将恶意代码对文件的操作进行逆向操作，就可以清除。典型的文件依附型恶意代码通常是将恶意程序追加到正常文件的后面，然后修改程序首指针，使得程序在执行时先执行恶意代码，然后再跳转去执行真正的程序代码，这种感染方式会导致文件的长度增加。清除的过程相对简单，将文件后的恶意代码清除，并修改程序首指针使之恢复正常即可。

部分恶意代码会将自身进行拆分，插入被感染的程序的自由空间内，例如著名的 CIH 病毒，就是将自身代码分拆开，放置在被感染程序中没有使用的部分，这种方式的被感染文件的长度不会增加。这种类型的恶意代码相比前一种感染文件后端的恶意代码的清除要复杂，只有准确了解该类恶意代码的感染方式，才能有效清除。

部分文件依附型恶意代码是覆盖型文件感染恶意代码，这类恶意程序会用自身代码覆盖文件的部分代码，清除会导致正常文件被破坏，无法修复，只能用没有被感染的原始文件覆盖被感染的文件。

3．独立型恶意代码的清除

独立型恶意代码自身是独立的程序或独立的文件，如木马、蠕虫等，是恶意代码的主流类型。独立型恶意代码清除的关键是找到恶意代码程序自身，并将恶意代码从内存中清除，然后就可以删除恶意代码程序文件。

如果恶意代码自身是独立的可执行程序，其运行会形成进程，因此需要对进程进行分析，查找到恶意代码程序的进程，将进程终止后，从系统中删除恶意代码文件，并将恶意代码对系统的修改还原，就可以彻底清除该类恶意代码。

如果恶意代码是独立文件，但并非是一个独立的可执行程序，而是需要依托其他可执行程序运行调用，从而实现加载到内存中。例如利用 DLL 注入技术附着在正常程序中的恶意 DLL 文件（.dll）、利用加载为设备驱动的系统文件（.sys）都是典型的依附型非可执行程序。清除这种类型的恶意代码也需要先将恶意代码终止运行，并从内存中退出。与独立可执行程序这种类型恶意代码不同的是，这种类型的恶意代码是由其他可执行程序加载到内存中的，因此需要将调用的可执行程序从内存中退出，恶意代码才会从内存中退出，相应的恶意代码文件也才能删除。如果调用恶意代码的程序为系统关键程序，无法在系统运行时退出。在这种情况下，需要将恶意代码与可执行程序之间的关联设置删除，重新启动系统后，恶意代码就不会被加载到内存中，文件才能被删除。

4．嵌入型恶意代码的清除

部分恶意代码嵌入在应用软件中，例如，攻击者利用网上存在的大量开源软件，将恶

意代码加入某开源软件的代码中，然后编译相关程序，并发布到网上吸引用户下载，并获得用户敏感信息、重要数据。由于这种类型的恶意代码与目标系统结合紧密，通常需要通过更新软件或系统，甚至重置系统才能清除。

9.3.4　基于互联网的恶意代码防护

互联网的发展极大地促进了各行各业的发展，恶意代码防护也不例外。由于目前恶意代码检测基本还是采用特征码扫描的实现方式，对于防病毒软件厂商来说，恶意代码的样本收集尤为重要。通常的做法是防病毒厂商在互联网上部署大量的蜜罐和蜜网系统，并配合一些网络爬虫程序来进行恶意代码的样本采集，这种方式收集到的样本数量、速度都无法满足恶意代码防护的需要。

随着云技术的出现，每一个防病毒终端软件都被利用起来成为恶意代码的采集器，当防病毒软件检测到可疑文件时（例如使用行为检测发现疑似恶意代码的软件），防病毒软件会在后台将可疑软件及相关资料上报到防病毒厂商的服务器，由防病毒厂商对疑似软件进行检测，如果确认该可疑软件为恶意代码，服务端就会将特征码推送到所有的客户端中从而实现对该恶意代码的检测及查杀。例如，由于某用户访问到了一个挂马网页并被感染了恶意代码，这个恶意代码会被传送到后台进行分析，并将分析结果推送到每个反病毒客户端中，这样其他客户端就可以进行查杀了。

9.4　知识子域：应用安全

在应用层面运行的就是应用系统，或称为应用程序。应用安全是信息安全的一部分，包括应用程序运行安全和应用资源安全两个方面。为了保障应用安全，需要加强应用系统在安全性方面的设计和配置，防止在运行过程中发生应用系统不稳定、不可靠和资源被非法访问、篡改等安全事件。

应用程序运行安全是建立在对应用软件的需求、设计、编码、测试以及废弃等生命周期的每一个阶段加强安全防护的基础上，从而达到降低应用软件的安全漏洞问题的目的。而对应用资源安全防护而言，需要保证合法用户能够通过安全策略合法的访问资源，同时也阻止攻击者访问、篡改任何受保护的资源。因此，应用安全不仅仅强调开发安全的应用系统，同时也应该强调应用系统的安全部署和安全运维。

9.4.1　Web 应用安全

Web 是一种基于浏览器/服务器（Browser/Server，B/S）架构的体系，是目前互联网使用最广泛的应用方式，基于 Web 的业务系统在不同领域得到大量应用。由于技术的发展，Web 的功能和交互性也在不断增强，承载的业务也越来越多，大量的数据存储在各种 Web

系统中，这使得 Web 应用成为攻击者针对的主要目标，对个人隐私、企业安全和社会安全造成了严重威胁。Web 应用安全已成为最严重、最广泛、危害性最大的安全问题，如何保证 Web 应用的安全是信息安全界广泛关注的重点问题。

1．Web 体系架构

Web 体系架构包括传输协议（http、https）、服务端软件（Apache、IIS 等）、数据库、应用程序（使用 ASP、PHP、JSP、Perl 等语言开发）、客户端（Internet Explorer、Firefox、Opera、Chrome 等）。数据库安全与应用程序安全问题内容可参考相关章节，此处不做介绍。

（1）Web 传输协议

超文本传输协议（Hypertext Transfer Protocol，HTTP）是 Web 架构主要使用的协议，HTTP 协议定义了客户端和服务器端请求和应答的标准过程，客户端只要遵循这个标准，就能从服务器端获取资源。目前最常用的 HTTP 协议是 HTTP/1.1，这个协议在 RFC2616 中被完整定义。一次标准的 HTTP 会话过程如下：客户端向服务器指定端口（默认 Web 服务使用 80 端口）建立 TCP 会话，会话建立后，客户端向服务器发送 HTTP 请求，请求中包含方法、统一资源标识符（Uniform Resource Identifiers，URL）、协议/版本及请求的实体内容。例如下面所列的请求：

```
POST /servlet/default.JSP HTTP/1.1
Accept: text/plain; text/HTML
Accept-Language: en-gb
Connection: Keep-Alive
Host: localhost
Referer: http://localhost/ch0/SendDetails.htm
User-Agent: Mozilla/4.0 （compatible; MSIE 6.0; Windows NT 5.1）
Content-Length: 33
Content-Type: application/x-www-form-urlencoded
Accept-Encoding: gzip, deflate
LastName=Franks&FirstName=Michael
```

这个请求送到服务器端后，服务器端根据 HTTP 协议给予响应，响应也包含 3 个部分：协议状态代码描述、响应包头、实体包，如下所示：

```
HTTP/1.1 200 OK
Server: Microsoft-IIS/6.0
Date: Mon, 3 Jan 2010 13:13:33 GMT
Content-Type: text/HTML
Last-Modified: Mon, 11 Jan 2010 13:23:42 GMT
Content-Length: 112

XXXX    响应实体内容
```

从以上会话过程可以看到，HTTP 协议在设计时仅仅考虑了实现相应功能，缺乏安全相关的机制，因此导致了大量的安全问题，包括拒绝服务、电子欺骗、嗅探等。

HTTP 协议存在以下安全问题。

① 明文传输数据

HTTP 协议使用简单的请求、响应模式进行数据传输，整个会话的过程中所有的数据都是明文进行传输，这些传输的信息中可能包含敏感信息，如用户进行 Web 登录验证的用户名和口令、向服务器提交的数据等。攻击者在 Web 会话的路径上对传输的数据进行嗅探，就可能获取这些数据。如图 9-8 所示，在嗅探到的 HTTP 会话数据中，可以看到用户向服务器提交的用户名和密码。

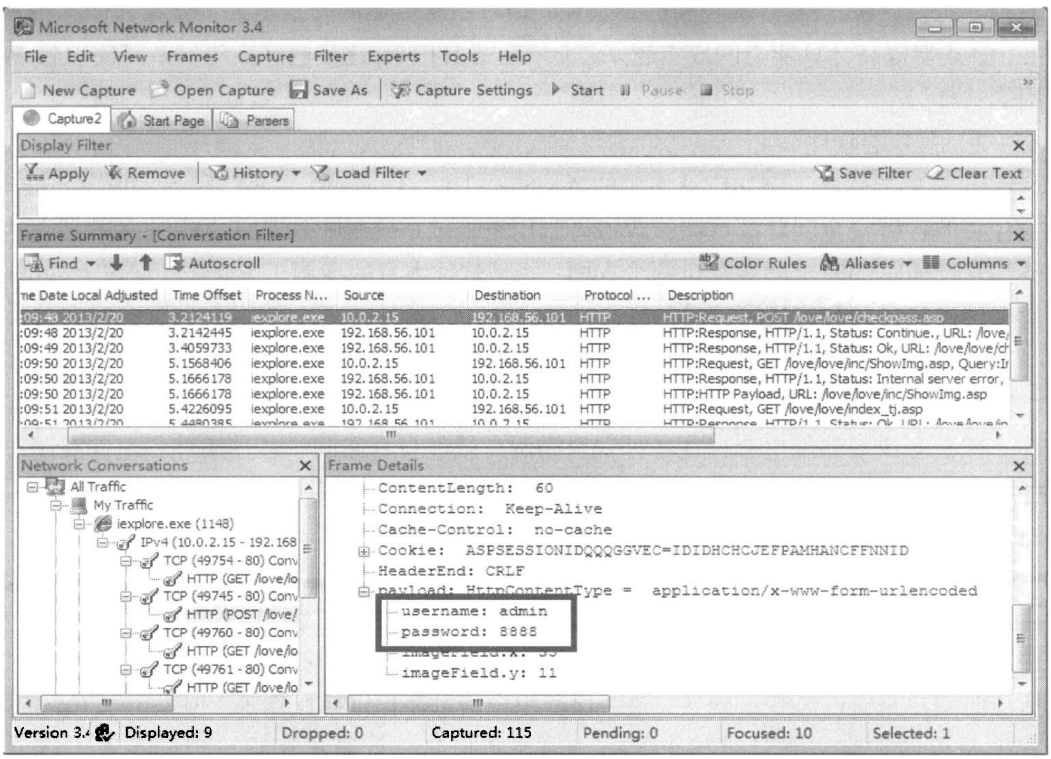

图 9-8　用户向服务器提交的用户名和密码

② 弱验证

HTTP 协议设计的初衷是基于开放的互联网平台，因此对会话双方没有严格的认证机制。HTTP1.0 仅仅提供简单的认证机制，HTTP1.1 虽然提供了摘要访问认证（digest access authentication，DAA）机制，采用 MD5 将用户名、密码、请求包头等进行封装，由于不提供对实体信息的保护，因此也无法有效解决信息泄露、数据篡改、重放攻击等安全问题。

③ 缺乏状态跟踪

HTTP 协议采取的请求、响应模式决定了它是一个无状态的协议。客户端在需要与服务器连接时才建立 TCP 连接，获取完连接数据后，TCP 连接就被断开，再次交换数据需要建立新的连接，因此 HTTP 协议不会维持一个持续的会话。这一机制在 Web 1.0 时代不会产生问题，而在 Web 2.0 时代，由于交互性的要求，需要提供状态机制。Session 是用于解

决 HTTP 协议缺乏状态跟踪机制的方法，但是也带来了相应的安全问题。对于已经验证过的用户，只需 Session ID 就可以成为身份验证，攻击者如果能获取用户的有效会话 Session ID（服务器没有释放这个 Session ID），无须用户名和密码，就能以此用户的身份去操纵 Web 应用，这种攻击方式被称为 Session 欺骗。

针对 HTTP 协议存在的安全问题，解决措施是在 HTTP 的基础上加入了 SSL 协议，这就是安全套接字层超文本传输协议（Hyper Text Transfer Protocol over Secure Socket Layer，HTTPS）。SSL 依靠证书来验证服务器的身份，并为浏览器和服务器之间的通信加密。相比 HTTP 协议，HTTPS 具有较高的安全性，但对系统性能的开销更大，随着云计算技术的发展，服务端提高计算能力的成本越来越低，全站 HTTPS 逐步已经成为一些高安全性 Web 应用的选择。

（2）服务端软件

Web 服务端软件（例如广泛使用的 Apache、IIS、Tomcat、WebSphere、WebLogic 等）自身存在的各种安全问题都可能被攻击者利用来入侵系统影响到 Web 应用的安全性。Web 服务端软件面临的安全问题来自两个方面：一是软件本身的漏洞；一是软件配置上的缺陷。即使软件本身设计和实现了完善的安全功能，也可能因为配置和使用不当而受到攻击。

（3）客户端软件

Web 应用的客户端主要是各种浏览器，是 Web 应用的用户操作界面，与 Web 服务端软件一样，客户端软件也会存在各种安全漏洞（软件自身漏洞、各种插件和组件漏洞），这些漏洞可被攻击者利用，对 Web 用户实施攻击，例如消耗用户系统资源、非法读取用户本地文件、非法写入文件、在用户计算机上执行代码等操作。

在 Web 客户端缺陷中，基于 Cookie 技术的缺陷广受抨击。Cookie 是为了辨别用户身份、进行 Session 跟踪而储存在用户本地终端上的数据，用于解决 HTTP 协议无状态的应用问题，是 HTTP 协议的补充。Web 服务器利用 Cookie 中的信息来判断 HTTP 传输中的状态，包括注册用户是否已经登录网站，是否保留用户信息简化以后操作等。但是由于 Cookie 在实现上是存储在客户端计算机上的一小段文本信息，计算机用户可以随意查看存储在 Cookie 中的数据，并且 Cookie 中的内容在发送到服务器之前能够被用户进行更改。因此，Cookie 机制实际上严重影响到用户的隐私及安全，网站可以利用 Cookie 收集用户的访问记录，从而获得用户的包括身份、银行卡号等隐私数据。而通过伪造 Cookie，可以欺骗网站以其他用户的身份进行操作。

2．Web 应用的安全问题

（1）SQL 注入

Web 应用程序开发使用的 SQL、Perl 和 PHP 等语言，属于解释型语言，即在运行时，有一个运行时组件解释语言代码并执行其中包含的指令。这类解释型语言易于产生代码注入攻击。攻击者可以提交一段预先构造的恶意代码作为输入，输入的信息被解释成程序的指令执行，向应用程序实施攻击。代码注入攻击中，SQL 注入是危害最严重的攻击方式之一。

SQL 注入攻击产生的原因是由于程序员水平缺乏安全开发经验，在编写代码时，没有对用户输入数据的合法性进行判断，使得攻击者可将 SQL 语句提交到数据库中，从而绕过安全机制操纵数据库。由于 Web 应用程序开发门槛比较低，所以 SQL 注入漏洞普遍存在。

SQL 注入可能发生在任何需要将参数提交到数据库中的地方，例如某网站的新闻 URL 是 http://www.target.com.cn/showdetail.asp?id=20000101，新闻的实际内容是保持在数据库中，当用户请求这个链接时，链接中包含参数“20000101”就是需要传递给数据库进行检索的关键信息，然而，由于程序员缺乏足够的安全意识和安全编码开发知识，对传递到数据库中的参数没有进行严格的过滤，那么攻击者就可以通过构造特定的语句对数据库进行查询甚至修改、删除数据等操作。攻击者可以构造如下的请求 URL：

```
http://www.target.com.cn/showdetail.asp?id=20000101'And (select * from user);--
```

showdetail.asp 脚本会将“20000101' And (select * from user);--”作为参数传递到数据库进行查询，从而导致提交的非法 SQL 语句“select * from user”被执行，结果是攻击者可以查看到 user 表中的所有记录。

由于 SQL 语句可以通过未严格过滤的参数传递到数据库中执行，攻击者可以窃取到数据库中的私有信息如用户表中的数据，包括用户名、密码等关键信息，甚至可以删除、篡改数据库中的数据。此外，由于数据库服务器内置的存储过程能实现丰富的功能，攻击者甚至通过调用内置存储过程控制操作系统，实施更大的破坏或攻击。

SQL 注入攻击的防范可以从程序设计、代码编写、安全部署和使用 3 个方面采取措施。

① **程序设计**：可以考虑通过严谨的程序结构设计，降低注入攻击的风险。如在程序结构设计时，应遵循最小特权原则，即给予用户完成某项工作所需的最小权限，这样即使某个模块的程序存在注入问题，也不会对系统整体的安全造成太大影响。

② **代码编写**：对用户的输入数据进行严格控制是解决 SQL 注入的主要方法。开发人员在编写代码时，可以采用格式化输入数据、过滤危险字符等方式，对所有外部输入的数据包括 URL、cookie 等进行验证。如上例中的 URL http://www.target.com.cn/showdetail.asp?id=20000101，“20000101”是向数据库中传输的参数，应审查输入是否为数字，长度是否为 8 位，不符合要求的输入参数，将被拒绝传递到数据库中。格式化数据技术是 SQL 注入攻击防御的有效方法，但在某些情况下，无法格式化用户输入数据，例如留言板、搜索框等。在这种情况下，可以采取过滤危险字符的方式，对输入数据中存在的 SQL 语句这类危险字符进行过滤，包括 select、delete、update 等常用 SQL 命令，单引号、双引号、斜杠、反斜杠、冒号、空字符等。

③ **安全部署和使用**：当访问数据库时，大多数情况下应用程序只需要读取并写入数据，并不需要数据库管理员权限，因此，应用程序应尽量配置使用最低权限账户。许多企业级数据库默认开启了大量功能，其中部分可以被利用执行 SQL 注入攻击，应该尽可能禁用不必要的功能。同时，还要定期评估 Web 应用程序的安全状况，及时安装产品供应商发布的安全补丁。

（2）跨站脚本

跨站脚本（Cross Site Script，XSS）是由于网页支持脚本的执行，而程序员又没有对用户输入的数据进行严格的控制，使得攻击者可以向 Web 页面插入恶意 HTML 代码，当用户浏览该页面时，嵌入其中的 HTML 代码会被执行，从而实现攻击者的特殊目的。跨站脚本的危害包括将用户引导到其他的地址（可能是恶意的）、窃取用户的敏感信息、屏蔽页面特定信息、伪造页面信息、拒绝服务攻击、突破外网内网不同安全设置等，或与其他漏洞结合，形成更大的影响。

跨站脚本问题与 SQL 注入漏洞类似，都是利用程序员编写脚本或页面过滤不足所导致，相对 SQL 注入而言，跨站脚本安全问题和特点更复杂，这使得对跨站脚本漏洞的防范难度更大。跨站脚本的防御措施主要是针对提交的信息进行严格过滤。

（3）失效的验证和会话管理

失效的验证和会话管理（Broken Authentication and Session Management）指 Web 应用程序中与身份认证和会话管理相关的代码功能往往没有正确实现，导致攻击者破坏口令、密钥、会话令牌或攻击其他的漏洞去冒充其他用户的身份。

Web 应用通常使用用户 ID 和口令来进行用户认证，并使用会话来保存每个用户的请求流。因为 HTTP 协议本身并不提供这样的功能，所以 Web 应用程序和环境须自己提供会话能力，妥善保护开发人员自己创建的会话 token 以免攻击者劫持活跃会话。但如果编写这些代码时存在安全缺陷，则可能导致出现 session 或 cookies 内所存的数据泄漏。

（4）不安全的对象直接引用

不安全的对象直接引用（Insecure Direct Object References，IDOR）指当 Web 开发人员未妥善保护内部实现对象，而在暴露出某些内部对象的引用时，如内部某个文件、目录或者数据库口令，攻击者可能利用这个不安全的直接对象引用去访问未授权资源，尤其是在其他访问控制或保护措施不到位时，更可能导致读取系统上任意文件或重要资料。

对于 Web 系统中，通常有的用户只具有部分访问权限。但是在生成 Web 页面时，应用程序经常使用对象的实名或关键字，而不是对象的间接引用数字。此时攻击者可以通过代码分析和尝试来直接访问这些对象，从而可能访问未授权资源。

（5）跨站请求伪造

跨站请求伪造（Cross Site Request Forgery，CSRF）是一种允许攻击者通过受害者发送任意 HTTP 请求的一类攻击方法，尤其是攻击者迫使已登录 Web 应用程序的合法使用者执行恶意的 HTTP 指令，而 Web 应用程序却当成合法请求处理，使得攻击者的恶意指令被正常执行。

在跨站请求伪造中，受害者通常是一个不知情的同谋，所有的伪造请求都由他发起，而不是攻击者。这样，Web 应用就很难确定哪些请求是属于跨站请求伪造攻击。利用跨站伪造请求，攻击者能让受害用户修改该受害用户允许修改的任何数据，或者是执行该受害用户被授权使用的任何功能。

（6）不安全的配置管理

不安全的配置管理，指由于没有对 Web 应用程序及部署环境进行安全的配置，导致攻击者通过默认账户、测试网页、系统漏洞、未被保护的文件和目录及不必要的服务等，以获得对系统未授权的访问或了解。

不安全的配置管理可以发生在一个 Web 应用系统的任何层面，包括操作系统、Web 服务器、应用服务器、框架和自定义代码等方面，这些层面的不正确配置和部署，则可能导致攻击者的恶意攻击，使得攻击者能访问一些未授权的系统数据或功能，甚至会导致系统完全被控制。

（7）不安全的密码存储

不安全的密码存储，指 Web 应用程序没有使用加密算法，或使用较弱的加密算法对敏感性资料加密存储，或简单地将密钥储存于容易被获取之处。

许多 Web 应用程序存在大量敏感数据，包括信用卡、社保卡号码、身份认证证书等，Web 应用这些敏感信息存储到数据库或者文件系统中，并使用适当的加密措施或 Hash 算法来保护。通常的漏洞是应该加密的数据不进行加密；在使用加密的情况下，常见的问题是不安全的密钥生成和储存、不轮换密钥、使用弱算法、使用弱的或者不加盐的哈希算法等。攻击者可能利用这种弱点来实施身份盗窃、信用卡诈骗或其他犯罪行为。

（8）错误的访问控制

错误的访问控制是指某些网页没有做好权限控制，使得攻击者可通过网址直接访问。这种漏洞允许攻击者访问未经授权的功能。

通常，Web 应用在显示受保护的页面之前会检查用户的访问权限，但是，当 Web 应用在给不同用户授予对各页面的不同的访问权限，可能存在设置方面的问题，从而导致攻击者可以不需要权限直接访问。Web 中的某些隐藏的、未正确设置权限的页面也可能被攻击者直接访问。

（9）传输保护不足

薄弱的传输保护是指 Web 应用在需要传输敏感信息时没有使用安全的传输通道，从而导致敏感信息泄漏，或被恶意篡改。

Web 应用程序在编写时，由于没有进行仔细安全设计，结果没有提供保护网络数据流的措施，如身份认证、数据加密、完整性保护等，或在保护时采用了弱算法、使用过期或无效的数字证书等。如有的 Web 应用在身份验证过程中使用 SSL/TLS 协议进行保护，但是传输数据时没有使用，因此会暴露传输的敏感数据和会话 ID 等信息。

（10）未经验证的网址重定向

未经验证的网址重定向指某些 Web 程序提供网页重定向功能，让使用者可通过该程序连接到其他网站，攻击者可利用这种特性，将恶意网站隐藏在网页重定向的参数中发送给使用者。

应用程序经常将用户重定向到其他网页，或以类似的方式进行内部转发。攻击者设计出一些钓鱼软件或恶意网站，将其链接到未验证的重定向并诱使受害者去单击。由于看起

来是链接到有效的网站，受害者很有可能去单击。这种重定向可能试图安装恶意软件或者诱使受害者泄露密码或其他敏感信息。

（11）不恰当的异常处理

不恰当的异常处理，是指 Web 应用在处理内部异常、错误时处理不当，导致会给攻击者透露出过多的 Web 应用架构信息和安全配置信息。

在 Web 正常运行，或当攻击者控制 Web 的输入时，经常能导致 Web 应用产生错误情况，如内存不够、空指针、系统调用失败、数据库不存在、网络不通等。正确地处理这些错误异常，给用户提供详细有意义的错误信息、给网站维护者提供诊断信息但不能给攻击者提供任何信息。不恰当的异常处理会将详细的内部错误信息比如堆栈追溯、数据库清空及错误的代码等提供给攻击者，从而给网站带来很多安全问题

（12）拒绝服务攻击

一般地，Web 应用根据其硬件和软件配置，有一定的用户并发访问能力，如能同时处理两百个用户的访问情况。但是，由于 Web 应用的开放性，难以分辨出攻击和普通的访问，所以更容易受到拒绝服务式攻击。

一个攻击者可以从一台主机产生足够多的流量来耗尽 Web 应用提供的有限资源，阻止合法的用户使用系统。这些资源包括带宽、数据库链接、磁盘存储、CPU、内存、线程或应用程序的特定资源。例如，一个网站允许未授权的用户来请求信息，攻击者可以利用这点使用一个 HTTP 请求发出很多数据库的查询，并很容易地发送许多类似请求，这样数据库连接资源池很快就会被耗光，合法的用户将不能使用服务。

3．Web 安全防护技术

针对 Web 应用安全，除了确保应用本身安全性外，也可以采取相应的技术进行防护。特别是对于一些老的应用，由于应用的兼容性及厂商问题，已经无法对现有的安全问题进行修复，只能采取其他安全防护技术进行防护。

（1）Web 应用防火墙

Web 应用防火墙（Web Application Firewall，WAF），也称 Web 防火墙，是指通过执行一系列针对 HTTP/HTTPS 的安全策略来专门为 Web 应用提供保护的一类产品，用以解决 Web 应用层出现的安全问题，保护 Web 应用通信流和所有相关的应用资源免受利用应用程序漏洞发动的攻击。目前，Web 应用防火墙尚无标准定义。由于 Web 应用的复杂性和特殊性，很多 Web 应用防火墙产品是集 Web 防护、网页保护、负载均衡等功能于一体的 Web 整体安全防护设备。常见的功能包括以下几种。

- 审计功能：用来截获所有 HTTP 数据或者仅仅满足某些规则的会话。
- 访问控制设备：用来控制对 Web 应用的访问，既包括主动安全模式也包括被动安全模式。
- Web 应用加固工具：用来增强被保护 Web 应用的安全性，它不仅能够屏蔽 Web 应用固有弱点，而且能够保护 Web 应用编程错误导致的安全隐患。

这些功能可能全部或部分地包含到当前的一些 Web 应用防火墙中。Web 应用防火墙一

般部署在 Web 服务器和接入网之间，且为串行接入。如网络中还存在防火墙，则 Web 应用防火墙一般部署在防火墙之后、Web 服务器之前。目前，部分 WAF 产品能够参与到安全事件发生的全过程，具备事前防范、事中防护、事后补救的能力。

- 事前防范是指在事件发生之前通过主动扫描检测 Web 系统来发现漏洞，并通过修复漏洞或在前端的防护设备上添加防护规则等积极主动手段来预防事件发生。
- 事中防护是指防护 Web 应用的各种威胁，能有效解决网页挂马、敏感信息泄露等安全问题，充分保障 Web 应用的可用性、可靠性。
- 事后补救则是指即使 Web 服务器被攻陷了，也具备网页防篡改的能力，让攻击者不能破坏重要数据。

此外，还出现了新的发展趋势，如采用白名单方式，即根据实际情况（如数据流向、应用的业务逻辑、用户访问习惯等）建立安全规则，只有符合安全规则的输入，Web 应用防火墙才予以放行。有的 Web 应用防火墙还可以和其他安全产品进行互动，如与 Web 安全扫描产品的结合，Web 扫描工具的扫描结果可以形成 Web 应用防火墙的防护规则。

（2）网页防篡改

网页防篡改产品出现在 Web 技术早期，并随着 Web 技术的发展逐渐发展。网页防篡改技术的基本原理是对 Web 服务器上的页面文件（目录下文件）进行监控，发现有恶意更改及时恢复原状，防止来自外部或内部的非授权人员对页面和内容进行篡改和非法添加。网页防篡改的实现方式有两种类型：一种是对需要保护的文件进行备份，使用轮询的方式进行比较，如果发现 Web 服务器上的文件与备份的不一致，就使用备份覆盖网站文件。这种实现方式随着文件数量的增多效率也在降低，并且扫描比对也会占用大量的资源；第二种实现类型是事件触发，由守护进程监控对受保护文件的操作行为，如果发现了改变、删除等非法行为，就对操作进行阻断。

网页防篡改系统可以用于 Web 服务器，也可以用于中间件服务器，其目的都是保障网页文件的完整性。其部署方式为，建立一台单独的管理服务器，然后在每台 Web 服务器上安装一个 Agent 程序，负责该服务器中站点文件的看护。其中管理服务器主要是管理这些 Agent 程序的看护策略。网页防篡改产品的技术原理主要包括如下几种。

- 定时循环技术：把 Web 服务器主目录下的文件做一个备份，用一个定时循环进程，把备份的文件与服务使用的文件逐个进行比较，不一样的就用备份去覆盖。网站更新发布的同时更新主目录的备份。这种方法不适用于大型站点，因为大型站点页面数量巨大，备份时扫描时间过长，并会占用大量的 Web 服务器性能资源。
- 摘要循环技术：采用了 Hash 算法，对 Web 服务器主目录下的每个文件做 Hash，生成该文件的哈希值。定时循环进程直接计算文件的哈希值并与原哈希值进行核对。该技术便于使用，仅占用较小的附加空间，而且哈希值具有不可逆的特点，不容易假冒。
- 事件触发防范技术：在权衡文件访问量、读取和修改操作的危险程度之后，开启一个看守进程，对 Web 服务器的主目录文件删改操作进行监控。发现有此操作行

为，判断用户是否具有合法身份并被授权进行维护操作，否则阻断其执行，文件不被改写，也就起到了网页防篡改的目的。由于只有文件被改变时才做检查，因此该技术大大降低了对服务器资源的占用。

- 底层过滤技术：防篡改产品直接调用 Windows 系统中所提供的系统级的目录文件修改看护进程，或者利用操作系统自身的文件安全保护功能，对主目录文件进行锁定，只允许站点发布系统（页面更新）才可以修改文件，其他系统进程也不允许删改。

网页防篡改虽然可以很好地保护静态页面，但无法对动态页面实施保护，因为动态页面是用户访问时生成的，内容与数据库相关。很多 SQL 注入攻击就是利用这个漏洞来入侵 Web 服务器的。有些网页防篡改产品也在其内部提供了一个 IPS 软件模块，用来阻止针对 Web 服务的 SQL 注入、XML 注入等攻击。

9.4.2 电子邮件安全

电子邮件是最古老的互联网应用之一，自从 1971 年诞生以来，已经作为一种有效的在不同计算机之间传送数据的方法，并很快得到了广泛的应用。尽管随着互联网的发展，其他的传送数据的方式如 QQ、微信等 IM 软件、微博、论坛等社交平台在一定程度上承担了数据传输的功能，但电子邮件应用并没有因此退出市场，反而承担了重要的职能，很多应用把电子邮箱作为安全性验证的手段，也正是这个原因，针对电子邮件的攻击数量和案例一直居高不下。

1．电子邮件工作机制

电子邮件的工作过程如图 9-9 所示。

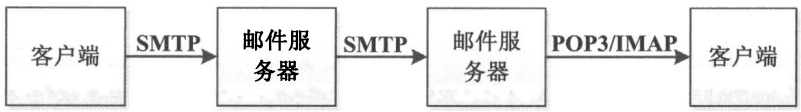

图 9-9　电子邮件工作过程

电子邮件客户端向邮件服务器特定端口发起连接（默认为 25），建立 TCP 会话后，按照协议规则向邮件服务器传递邮件相关信息，包括发件人、收件人、邮件主题、邮件正文等。邮件服务器收到电子邮件后，根据邮件要求的收件人地址，将邮件传递到下一个邮件服务器中，通过这种接力传递的方式，最终到达收件人邮件服务器上，收件人使用客户端从邮件服务器上接收邮件。目前广泛使用的电子邮件协议包括以下方面。

- 简单邮件传输协议（Simple Mail Transfer Protocol，SMTP）：由 RFC2821 定义，用于将邮件推送到收件人邮件服务器。
- 邮局协议-版本 3（Post Office Protocol-Version3，POP3）：由 RFC1939 定义，主要用于支持使用客户端远程管理在服务器上的电子邮件。
- Internet 邮件访问协议（Internet Mail Access Protocol，IMAP）：由 RFC3501 定义，

邮件客户端通过这种协议从邮件服务器上获取邮件的信息，下载邮件等，与 POP3 相比，IMAP 无须下载邮件全部内容，可以直接在客户端上对邮件进行操作。

2．电子邮件安全问题

电子邮件协议 SMTP、POP3 及 IMAP 都是基于纯 ASCII 文本的格式的应用层协议，机制简单易于实现，但也带来了安全上的诸多问题。

（1）信息泄露：会话过程使用明文，这使得会话过程毫无秘密可言，用户验证的用户名、密码、传输的邮件的内容都存在泄露的可能。攻击者只要在会话路径上进行嗅探，就能获得这些敏感信息。

（2）邮件伪造：早期的 SMTP 协议对发送方是没有任何认证的，这使得发件人可以随意标记自己的邮件地址，攻击者在发邮件中如果将发件人写成 admin@qq.com，这封邮件也不会被拒绝，接收邮件的人会认为自己收到了 QQ 管理员的邮件。这一问题导致了大量的社会工程学欺骗攻击和垃圾邮件泛滥。为了解决这一问题，SMTP 协议进行了升级，提供了身份验证的功能，用户在发送邮件时需要证明自己是发件人（使用用户名、密码验证），这在一定程度上带来了安全性的提升，但仍然没有从本质上解决这一问题，因为对于接收方来说，电子邮件系统没有任何来源验证机制，攻击者可以自建无须身份验证的 SMTP 服务器或对电子邮件本身进行篡改（电子邮件本身也缺乏完整性保护机制）。

（3）垃圾邮件：由于电子邮件得到了广泛的应用，而发送电子邮件的成本又是如此低廉，营销组织及攻击者是不会放过对此进行利用的，垃圾邮件就因此诞生了。垃圾邮件是电子邮件的副产品，对互联网安全带来了极大的挑战。

- 占用网络流量及带宽、服务器资源等，甚至被用于实施拒绝服务攻击。
- 消耗收件人邮箱空间、时间、精力。
- 传播恶意代码和谣言等非法信息。
- 影响企业及个人声誉。

3．电子邮件安全解决方案

已经在运行的电子邮件基础设施数量如此庞大，想进行全面的修改几乎是不可能的。目前，电子邮件安全解决方案大都是在基于对目前电子邮件的基础设施不做大的调整前提下。

（1）S/MIME

安全/多用途互联网邮件扩展（Secure/Multi—purpose Intemet Mail Extensions，S/MIME）协议由 RFC 2311 定义，对 MIME 对象（MIME 也称复合数据，允许用户把图像、音频、Word 文件等不同类型数据嵌入邮件主体中）进行了扩展，把 MIME 实体封装成安全对象。S/MIME 增加了新的 MIME 数据类型，用于提供数据保密、完整性保护、认证和鉴别服务等功能。为了确保邮件在传统邮件体系中进行传递，S/MIME 保护的对象是邮件的主体。目前绝大多数的服务器端和客户端产品都已经支持 S/MIME。

（2）PGP

PGP（Pretty Good Privacy）是一个基于公钥加密体系的开源软件，利用密码技术为邮

件提供保密性、完整性、抗抵赖性等一系列服务。PGP 由于开源和免费的特性，在邮件安全中得到了广泛的应用。使用 PGP 可以减少或消除目前电子邮件应用中的安全问题。

（3）使用 SSL 对会话进行保护

尽管很多邮件服务器处于安全的需要限制使用 POP3 进行邮件收取，但不可否认 POP3 仍然拥有大量的用户，为了避免对用户使用造成困扰，大量的电子邮件服务机构使用 SSL 对 SMTP 和 POP3 进行保护。

9.4.3 其他互联网应用

1．远程接入安全

随着组织机构的业务扩展和跨地域发展，使用远程接入技术对远程计算机、服务器进行访问和管理已经成为业务发展的必需。由于缺乏足够的安全机制等问题，传统的远程访问技术如 Telnet 由于明文传输信息、缺乏完整性检查等问题，已经逐步从实际应用中被淘汰，取而代之的是一些更安全的远程管理技术。例如用于取代 Telnet 的 SSH，把所有传输的数据进行了加密，并提供基于证书的身份验证、完整性保护等服务。

2．域名系统安全

域名系统（Domain Name System，DNS）是互联网的基础，Web 服务、电子邮件服务等互联网应用都需要 DNS 作为支撑，因此 DNS 的安全关系到整个互联网能否正常使用。DNS 是一个非常庞大、复杂的分布式数据库系统，由于设计初期对安全性考虑不足，DNS 系统存在很多安全缺陷。例如著名的 DNS 欺骗攻击，也称 DNS 高速缓存污染。另外由于 DNS 对于互联网体系的重要性，使得 DNS 也很容易成为拒绝服务攻击的对象。对于 DNS 的安全问题，IETF 组织提出了 DNS 安全扩展（Domain Name System Security Extensions，DNSSEC），它提供了一种来源鉴定和数据完整性的扩展，但不去保障可用性、加密性和证实域名不存在。

3．即时通讯安全

即时通讯（Instant Messaging，IM）是互联网和移动互联网的一项重要应用，几乎每个互联网用户都拥有一个或多个即时通讯账号。随着即时通讯服务商不断将语音、视频、文件分享等功能加入，即时通讯已经被广泛地应用在商业领域。例如，大量的组织机构使用如微信、QQ 这样的即时通讯软件建立群用于内部沟通和文件分享。尽管即时通讯应用能够帮助我们通过互联网进行交流，但如果不采取恰当的防护措施，即时通讯可能被攻击者利用给个人和组织机构带来新的安全风险。

- 即时通讯功能越来越多，这些功能中可能存在安全缺陷被攻击者利用或被蠕虫利用进行传播。
- 即时通讯账号被攻击者窃取后进行诈骗或窃取信息。
- 即时通讯普遍支持文件共享等功能，这可能使得个人隐私和组织机构敏感信息无

意中被泄露。

即时通讯安全是移动互联网时代每个用户和组织机构都应该认真考虑的问题，特别对于使用即时通讯进行内部工作交流和协作的组织机构。安全使用即时通讯应考虑以下措施。

- 选择在设计上已经为商业应用提供安全防护的即时通讯软件，例如提供传输安全性保护措施的即时通讯软件。
- 如果经费许可，可以使用自建服务器的即时通讯系统。
- 在组织机构安全管理体系中制定相应安全要求，例如禁止在即时通讯中传输敏感及以上级别的文档；建立管理流程及时将离职员工移除等。
- 涉及重要操作包括转账等必须电话或其他可靠方式确认。

9.5　知识子域：数据安全

9.5.1　数据库安全

数据库是一种长期储存在计算机系统中的一组相关数据的集合，它可以供各种用户共享，具有最小冗余度和较高的数据独立性。这种数据集合具有如下特点：尽可能不重复、以最优方式为某个特定组织的多种应用服务、数据结构独立于使用它的应用程序等。对数据库进行查询、增加、删除、修改均通过数据库管理系统（Database Management System，DBMS）进行。DBMS 在数据库建立、运行和维护时对数据库进行统一控制，以保证数据库的完整性和安全性，并在多用户同时使用数据库时进行并发控制，在发生故障后对数据库进行恢复。

1．数据库安全要求

数据库作为应用系统数据存储的系统，是信息系统的核心和运行支撑，毫无疑问会成为信息安全的重点防护对象。数据库安全涉及数据资产的安全存储和安全访问，对数据库安全要求包括以下方面。

- 向合法用户提供可靠的信息服务。
- 拒绝执行不正确的数据操作。
- 拒绝非法用户对数据库的访问。
- 能跟踪记录，以便为合规性检查、安全责任审查等提供证据和迹象等。

2．数据库安全防护

随着网络技术的发展和普及，分布式数据库和 Web 应用已经被越来越多的人所接受。数据库服务器已经不再是像以前那样仅仅安装在一台主机上，企业有更多的数据库服务器作为网络上的一个节点为与其连接的各种信息系统提供数据服务。因此针对现代计算机网

络环境下的数据库系统安全防护问题，不能仅仅考虑数据库本身，数据库运行环境安全、人员管理、实时监控、审计等方面都是需要考虑的问题。

数据库安全防护是指保护数据库运行安全以防止不合法的使用造成的数据泄漏、更改或破坏，包括安全防护体系构建、安全运行监控和安全审计。

在数据库系统投入生产运行之前，需要对数据库系统进行安全检测，检测分为以下两个方面。

（1）数据库系统运行环境的检测。

（2）数据库系统自身缺陷的安全检测。

通过安全检测尽早发现数据库存在的安全缺陷（包括软件漏洞及配置缺陷），然后通过安装补丁、调整安全设置、制定安全策略等方法进行弥补。同时，根据数据库业务需要，构建完善的防护技术体系。

在数据库系统运行过程中，通过数据库活动监控（Database Activity Monitoring，DAM）实时地监控数据库用户活动（应用程序对于数据库的访问行为）和数据库的运行状态，及时发现影响数据库运行稳定的问题，并对可疑的用户行为进行报警，从而能及时地采取适当的措施，确保数据库运行安全性。

安全审计主要是针对数据库运行期间产生的各种日志，通过多个不同维度进行综合分析，从而发现影响数据库运行安全的因素并采取相应的应对措施。

9.5.2 数据泄漏防护

数据是信息系统中的关键资产，对于一个采用了防火墙、入侵检测系统、防病毒软件等各种安全设备严密保护的信息系统，可能仍然无法保护数据的数据流失。组织机构积极拥抱数字化带来了新的安全风险，不断增长的数据威胁对组织机构而言是一个无法回避的问题。

> 数据：2016 年，26%的受访者表示遭遇了数据泄露，2017 年的占比上升至 36%，而到 2018 年这一比例明显上升至 67%。
>
> ——《2018 泰雷兹数据威胁报告》

数据泄露防护（Data Leakage（Loss）Prevention，DLP）是建立在内容识别基础上，防止组织机构指定数据或信息资产违反安全策略流出组织机构的解决方案。

《网络安全法》的颁布，对数据保护提出了明确的要求，这些要求包括“未经被收集者同意，不得向他人提供个人信息”“采取技术措施和其他必要措施，确保其收集的个人信息安全，防止信息泄露、毁损、丢失。”等。在金融等其他行业，也有相应的规定。

组织机构的数据泄露防护体系构建，必须覆盖可能的数据外泄渠道。因此在构建数据泄露防护体系时，应确定组织机构的业务流程中的每个环节是否已经制定了数据安全策略，

这些策略是否得到实施，组织机构的员工是否了解这些策略。对于业务流程中的每个环节，都应该关注以下问题。

- 什么敏感数据需要发出。
- 谁会发出敏感数据。
- 这些数据要发往哪里？
- 使用什么协议、端口等。
- 违反了哪些安全策略。
- 违规程度如何。

第 10 章

知识域：软件安全开发

阅读提示 本知识域主要介绍软件安全开发管理相关知识，包括软件安全开发生命周期管理概念、软件安全开发需求及设计、软件安全实现、软件安全审计、软件安全交付等重要过程。通过学习，学员理解软件安全开发生命周期管理的重要性，并了解如何确定软件安全需求、软件安全设计、安全代码编写及软件安全交付工作内容。本知识域包括软件安全开发生命周期、软件安全需求及设计、软件安全实现、软件安全测试和软件安全交付 5 个知识子域。

10.1 知识子域：软件安全开发生命周期

10.1.1 软件生命周期模型

软件包括与计算机系统操作相关的计算机程序、规程、规则，以及开发和使用过程中可能产生的文件、文档及数据等。

软件开发生命周期（Software Development Life Cycle，SDLC）又称为软件生存周期或软件生命周期，是软件从产生直到报废的生命周期，生命周期包括有问题定义、可行性研究、系统概述、系统设计、编码、调试和测试、验收与运行、维护升级以及废弃等阶段，这种按时间分程的思想方法是软件工程中的一种思想方法，即每个阶段都要有定义、工作、审查，并形成过程文档，按部就班、逐步推进，以提高软件的质量。

随着新的面向对象的设计方法和技术的成熟，软件生命周期模型方法的指导意义正在逐渐减弱。生命周期的每一个阶段都有确定的任务，并产生一定规格的文档，提交给下一个阶段作为继续工作的依据。按照软件生命周期思想，软件开发不再单单强调“编码”，而是概括了软件开发的全过程。软件工程要求每一阶段工作的开始只能而且必须是建立在前一个阶段结果“正确”的前提下进行，因此，每一阶段都是按“工作-结果-审核-再工作-直至结果正确”循环往复进展的。

从概念提出的那一刻开始，软件产品就进入了软件生命周期。在经历需求、分析、设计、实现、部署后，软件将被使用并进入维护阶段，直到最后由于缺少维护费用而逐渐消亡。这样的一个过程，称为“生命周期模型”（Life Cycle Model）。

典型的几种生命周期模型包括瀑布模型、快速原型模型、迭代模型等。

1．瀑布模型

瀑布模型（Waterfall Model）是最早出现的软件开发模型，在软件工程中占有重要的地位，它提供了软件开发的基本框架。在 20 世纪 80 年代之前，瀑布模型一直是唯一被广泛采用的生命周期模型，现在它仍然是软件工程中应用最广泛的过程模型。传统的软件工程方法学的软件过程，基本上可以用瀑布模型来描述。核心思想是按工序将问题简化，将功能的实现与设计分开，便于分工协作，即采用结构化的分析和设计方法将逻辑实现与物理实现分开。将软件生命周期划分为系统需求、软件需求、初步设计、详细设计、编码及调试和测试和运行维护等 7 个基本活动，并且规定了它们自上而下、相互衔接的固定测序，形如瀑布流水，逐级下落，如图 10-1 所示。

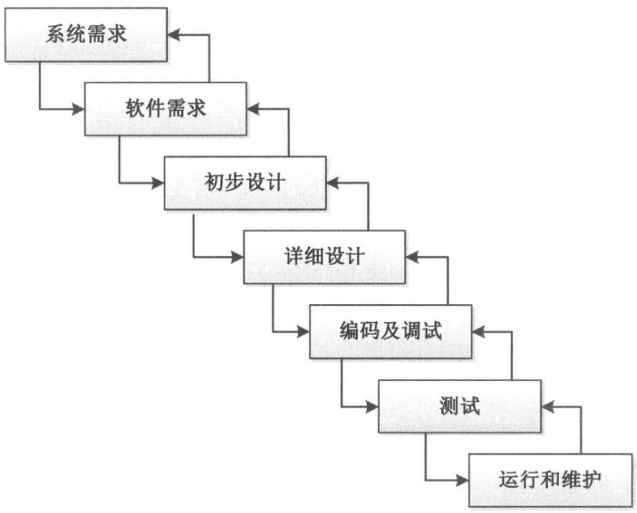

图 10-1　瀑布模型

瀑布模型是在考虑返回先前阶段纠正系统错误的必要性的情况下，建立软件开发过程的模型的第一次全面的尝试。由于瀑布模型并没有对开发周期后期发现错误做出相应的规定，只允许开发人员后退一个阶段，这使得它在实际应用中存在一些不足。针对瀑布模型的改进是为每个阶段添加确认和验证步骤，针对规范评估产品，从而确认评估产品满足实际需求的程度。

2．迭代模型

迭代模型是统一软件开发过程（Rational Unified Process，RUP）推荐的周期模型。迭代被定义为：迭代包括产生产品发布（稳定、可执行的产品版本）的全部开发活动和要使用该发布必需的所有其他外围元素。所以在某种程度上，开发迭代是一次完整地经过所有工作流程的过程，至少包括需求工作流程、分析设计工作流程、实施工作流程和测试工作流程。

迭代模型可以理解为多个小型的瀑布模型的组合，所有的阶段都可以细分为迭代，每一次迭代都会产生一个可以发布的产品，这个产生是最终产品的一个子集。迭代的思想如图 10-2 所示。

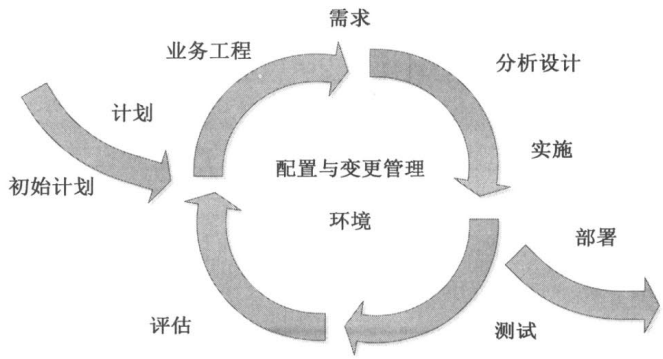

图 10-2　迭代模型

3．增量模型

增量模型融合了瀑布模型和迭代模型的特征，该模型采用随着日程时间的进展而交错的线性序列，每一个线性序列产生软件的一个可发布的“增量”。当使用增量模型时，第一个增量往往是核心的产品，即第一个增量实现了基本的需求，但很多补充的特征还没有发布。客户对每一个增量的使用和评估都作为下一个增量发布的新特征和功能，这个过程在每一个增量发布后不断重复，直到产生了最终的完善产品。

增量模型与原型实现模型和其他演化方法一样，本质上是迭代的，但是与原型实现不一样的是其强调每一个增量均发布一个可操作产品。早期的增量是最终产品的“可拆卸”版本，但提供了为用户服务的功能，并且为用户提供了评估的平台，如图 10-3 所示。

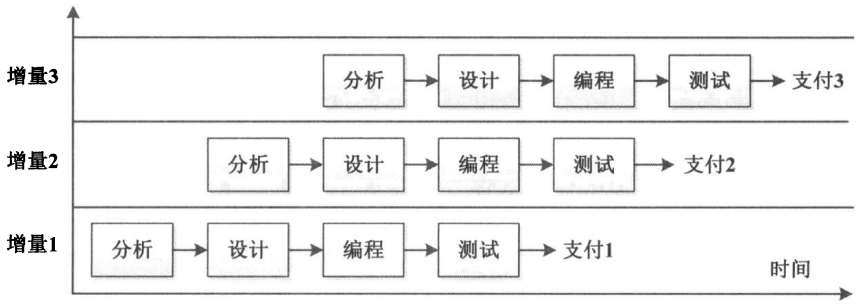

图 10-3　增量模型

4．快速原型模型

快速原型模型又称原型模型，它是增量模型的另一种形式；它是在开发真实系统之前，构造一个原型，在该原型的基础上，逐渐完成整个系统的开发工作。例如，客户需要一个 ATM 机软件，可以先设计一个仅包含刷卡、密码检测、数据输入和账单打印的原型软件提

供给客户，此时还不包括网络处理与数据库存取以及数据应急、故障处理等服务。快速原型模型的第一步是建造一个快速原型，实现客户或未来用户与系统的交互，用户或客户对原型进行评价，进一步细化待开发软件的需求。通过逐步调整原型使其满足客户的要求，开发人员可以确定客户的真正需求是什么；第二步则在第一步的基础上开发客户满意的软件产品。

快速原型是利用原型辅助软件开发的一种思想。经过简单快速分析，快速实现一个原型，用户与开发者在使用原型过程中加强通信与反馈，通过反复评价和改进原型，减少误解，弥补漏洞，适应变化，最终提高软件质量。

5．螺旋模型

螺旋模型是一种演化软件开发过程模型，它兼顾了快速原型的迭代以及瀑布模型的系统化与严格监控的特征。螺旋模型最大的特点在于引入了其他模型不具备的风险分析，使软件在无法排除重大风险时有机会停止，以减小损失。同时，在每个迭代阶段构建原型是螺旋模型用以减小风险的途径，如图 10-4 所示。

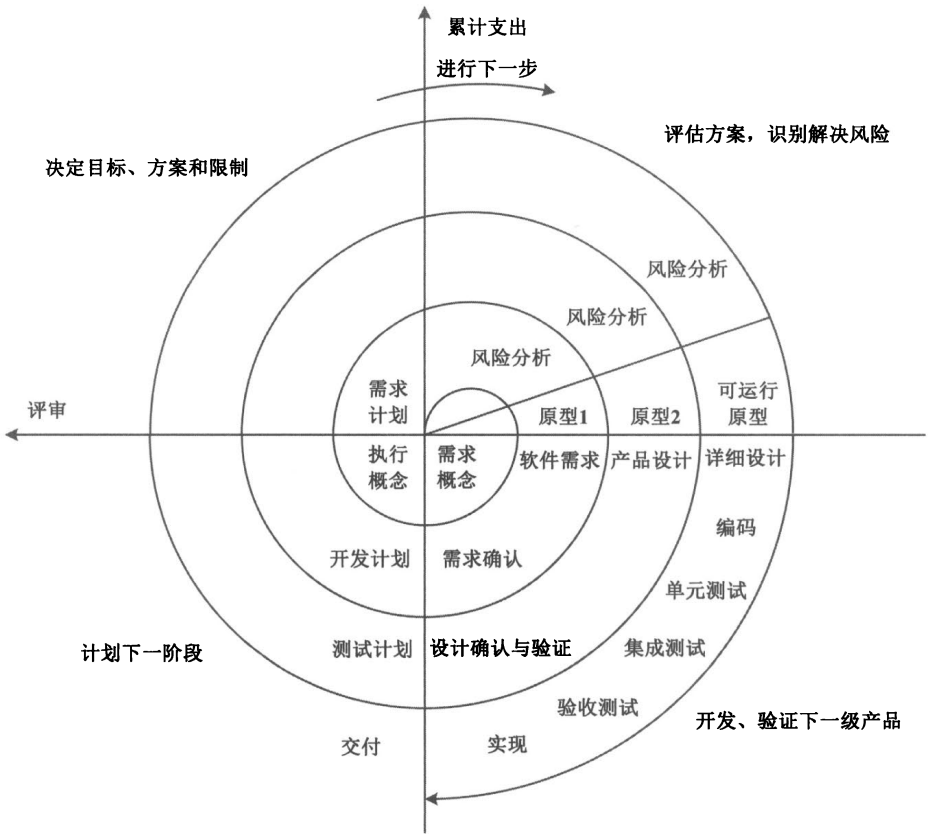

图 10-4　螺旋模型

螺旋模型更适合大型的、昂贵的系统级软件应用。

6．净室模型

净室是一种应用数学与统计学理论以经济的方式生产高质量软件的工程技术。力图通过严格的工程化的软件过程达到开发中的零缺陷或接近零缺陷。“净室”一词源自半导体工业中硬件生产车间，通过严格、洁净的生产过程预防了缺陷的产生，而不是在事后再去排除故障。借用这个词，充分显示了净室技术“防患于未然”的主导思想。

7．各软件过程模型的特点

各软件过程模型的主要特点如表 10-1 所示。

表 10-1　各个软件过程模型的特点

模 型 名 称	技 术 特 点	使 用 范 围
瀑布模型	简单，分阶段，阶段间存在因果关系，各个阶段完成后都有评审，允许反馈，不支持用户参与，要求预先确定需求	需求易于完善定义且不易变更的软件系统
迭代模型	不要求一次性地开发出完整的软件系统，将软件开发视为一个逐步获取用户需求、完善软件产品的过程	需求难以确定、不断变更的软件系统
增量模型	软件产品是被增量式地一块块开发的，允许开发活动并行和重叠	技术风险较大，用户需求较为稳定的软件系统
快速原型模型	不要求需求预先完备定义，支持用户参与，支持需求的渐进式完善和确认，能够适应用户需求的变化	需求复杂、难以确定、动态变化的软件系统
螺旋模型	结合瀑布模型、快速原型模型和迭代模型的思想，并引进了风险分析活动	需求难以获取和确定、软件开发风险较大的软件系统
净室模型	净室技术是一种开发高质量和高可靠性软件的方法，由三大关键技术来刻画：统计过程控制下的增量开发，基于函数的规范、设计和验证，以及统计测试和认证	质量要求非常高的项目；软件开发团队需要具备丰富的数学知识以及编程语言和开发环境相关的知识和经验

10.1.2　软件危机与安全问题

1．软件危机

软件危机是指在计算机软件的开发和维护过程中所遇到的一系列严重问题。计算机系统经过了数十年的快速发展，仍然没有彻底摆脱“软件危机”的困扰，软件已经成为限制计算机系统发展的瓶颈。

为了更有效地开发和维护软件，软件工作者在 20 世纪 60 年代后期开始认真研究消除软件危机的途径，从而逐渐形成了一门新兴的工程学科——计算机软件工程学（通常简称

为软件工程）。

（1）第一次软件危机

20 世纪 60 年代以前，计算机刚刚投入实际使用，这个时期主要的软件开发方式是使用机器语言或者汇编语言在特定的机器上进行软件的设计与编写。此时软件规模较小，文档资料通常也不存在，也不需要使用系统化的软件开发方法，基本上是个人设计编码、个人操作使用的私人化的软件生产模式。这个时代的程序一个典型的特征就是依赖特定的机器，程序员必须根据所使用的计算机的硬件特性编写特定的程序。

随着 20 世纪 60 年代中期大容量、高速度计算机问世，使计算机的应用范围迅速扩大。软件系统的规模越来越大，复杂程度越来越高，程序设计的复杂度也随之增长，软件开发量急剧增长，软件可靠性问题也越来越突出。原来的个人设计、个人开发的方式不再能满足要求，迫切需要改变软件的生产方式，提高软件的生产率，第一次软件危机开始爆发。

第一次软件危机的现象：

- 软件开发费用和进度失控。费用超支、进度拖延的情况屡屡发生。有时为了赶进度或者压成本不得不采取一些权宜之计，这样又往往严重损害了软件产品的质量。
- 软件的可靠性差。尽管耗费了大量的人力、物力，而系统的正确性却越来越难以保证，出错率大大增加，由于软件错误而造成的损失十分惊人。
- 生产出来的软件难以维护。很多程序缺乏相应的文档资料，程序中的错误难以定位，难以改正，有时改正了已有的错误又引入了新的错误。随着软件的社会拥有量越来越大，维护占用了大量人力、物力和财力。

1968 年，北大西洋公约组织的计算机科学家在联邦德国召开国际会议，第一次提出了“软件危机”的概念并针对软件危机问题进行讨论。在这次会议上，“软件工程”被正式提出，“软件工程学”这门为研究和克服软件危机的新兴的工程学科就诞生了。

（2）第二次软件危机

尽管软件工程研究取得了可喜的成就，软件技术水平有了长足的进展，但是软件生产水平依然远远落后于硬件生产水平的发展速度。随着软件应用的不断发展，软件复杂性的进一步增长，大规模软件常常由数百万行代码组成，数以百计的程序员参与开发。如何高效、可靠地构造和维护这样规模的软件成为了一个新的难题。著名的《人月神话》中提及，IBM 公司开发的 OS/360 系统共有 4000 多个模块，约 100 万条指令，每年投入 5000 人，耗资数亿美元，结果还是延期交付。在交付使用后的系统中仍发现大量（2000 个以上）的错误。当软件规模不断扩大到需要大量的开发人员共同协作时，第二次软件危机就诞生了。

第二次软件危机的现象：

- 软件成本在总成本中所占的比例不断升高。由于微电子学技术的进步和硬件生产自动化程度不断提高，硬件成本逐年下降，性能和产量迅速提高。然而软件开发需要大量人力，软件成本随着软件规模和数量的剧增而持续上升。
- 软件开发生产率提高的速度远跟不上硬件的发展速度，使得人类不能充分利用现代计算机硬件所能提供的巨大潜力。

英特尔创始人之一戈登·摩尔（Gordon Moore）提出来的摩尔定律：当价格不变时，集成电路上可容纳的元器件的数目，约每隔 18～24 个月便会增加一倍，性能也将提升一倍。由于计算机硬件的快速发展，程序的性能已经不是需要关注的问题，因为计算机硬件的计算能力远超过软件的发展速度。

第二次软件危机是由于软件的规模庞大带来的开发成本、维护成本与用户对软件“可组合性”“可延展性”“可维护性”之间的矛盾。

为了解决这次危机，面向对象的编程语言（C++、C#、Java 等）诞生了，更好的软件工程方法（设计模式、重构、测试、需求分析等）诞生了，而程序员也越来越不知道硬件是怎么工作的了。软件和硬件的界限越来越牢固，Java 编写的代码能在任何 JVM 支持的平台上运行，程序员也乐于享受这样的便利。

（3）第三次软件危机

现代软件功能越来越强，功能组件越来越多，软件也变得越来越复杂。研究显示，软件漏洞的增长同软件复杂性、代码行数的增长呈现正相关的关系，即“代码行越多，缺陷也就越多”。互联网的发展在拓展了软件功能和范围，为软件应用带来极大发展的同时，也为攻击者提供了更多的机会。由于软件被应用于各种环境，会面对不同层次的使用者，使得软件开发需要考虑更多的安全问题。同时，恶意攻击者可以比以往获得更多的时间和机会来访问软件系统并尝试发现软件中存在的安全漏洞。而软件存在漏洞和缺陷不可避免，这使得应用系统面临极大的安全风险，从而导致了第三次软件危机。

第三次软件危机的现象：

- 由于软件安全问题导致的损失越来越多，软件安全性已经成为不得不认真考虑的问题。
- 软件开发需求中被加入安全相关的需求，安全性测试成为软件验收的依据之一。

为了更好地应对第三次软件危机，在软件开发的生命周期中开始引入安全相关工作，软件安全开发生命周期诞生了。

2. 软件安全问题

软件安全（即设计、构造和测试安全的软件的方法）通过确定和解决软件本身的问题而触及计算机安全的核心，软件安全试图基于这种方法构建能够主动抵御攻击的软件。软件安全问题不仅仅是编码问题，数据显示，有超过 50%的问题实际上属于软件设计方面的问题。开发安全的软件就像建设一栋安全的房屋，正确的编码就如同使用了坚固的砖头，能确保房子的坚固。虽然使用的砖头很重要，但如果在房子的设计中，没有考虑到更多的安全要求，设计的房屋窗口没有加上防护，使得小偷很容易就进入房屋中，那么再坚固的砖块也无法确保这件房屋的安全。软件也是一样，使用了哪些系统调用、哪些库文件以及如何使用都是非常重要的。软件的安全也遵循信息安全的木桶原理，需要关注软件开发的各个方面问题。软件安全问题的根本原因在于两个方面：一是内因，软件本身存在安全漏洞；二是外因，软件应用存在外部威胁。

软件安全问题产生根源的内因是由于现代信息系统（特别是软件系统）的规模大而且复杂性高，使得软件漏洞不可避免。图 10-5 列出了早期不同版本的 Windows 操作系统的代码量。Windows Vista 操作系统本身包括了 5000 万行代码，如此大规模的系统，缺陷是不可避免的。实际上，软件的缺陷的增长速度趋向于与代码行数的平方而变化。显著影响软件复杂性的其他因素还包括代码集成的紧密程度、补丁与其他部署后所做的修改之间的重叠率，以及严重的体系结构问题。

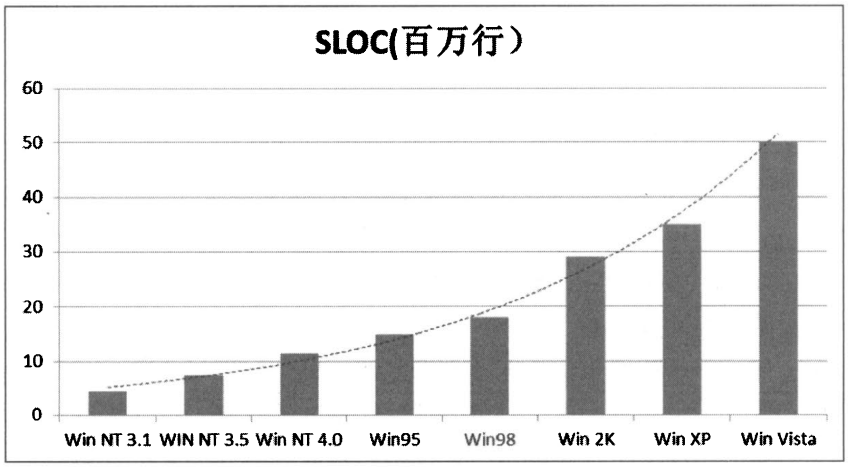

图 10-5　Windows 系统源代码行数增长情况

软件安全问题产生根源的外因是在目前的软件开发管理中，更多地重视软件功能而不关注对安全风险的管理。如果用户方没有提出明确、细致的软件安全要求，软件公司将实现软件功能作为首要目标，因此更多地去考虑尽快实现软件的各项功能，加快进度以抢占市场份额。由于“劣币驱除良币”效应的存在，使得更多的软件厂商对软件安全开发缺乏动力，企业管理层和软件开发人员都缺乏相应的知识，不知道如何才能更好地实现安全的软件。公司管理层缺乏对软件安全开发的管理流程、方法和技巧，缺少正确的安全经验积累和培训教材；软件开发人员则大多数仅仅从学校学会编程技巧，不了解如何将软件安全需求、安全特性和编程方法进行结合，更无法以“坏人”的角度来思考软件安全问题。

> 在市场竞争中，注重软件安全开发的企业，由于软件安全开发方面的投入，使得软件的研发周期、研发成本都有所提高，因此在市场竞争中会败给不考虑软件安全开发的企业，这就是软件安全开发中的“劣币驱除良币”。

互联网的发展使得越来越多的设备都接入进来，这些设备中的软件面临着更多的攻击者和更简单的攻击实施，也使得软件面临的安全风险也越来越高。

3．软件安全保障

信息化社会，软件无处不在。它使汽车开动，控制手机，使洗碗机运行，它控制高速列车的运行，城市交通系统的运转。它是银行和国家权力机构保持活力的源泉。由于商业

和社会活动越来越依赖于软件，软件安全不仅仅是一种奢侈，而且是一种必需品。

理想中安全的软件，是不存在任何安全漏洞、能抵御各种攻击威胁的软件。现实中这样的软件是不可能存在的，由于安全威胁无处不在，软件在需求、设计和开发等过程，如果对安全考虑稍有不慎，都有可能将安全漏洞带入软件中。

软件安全保障是对“软件可以规避安全漏洞而按照预期的方式执行其功能”的信心。软件安全保障是指确保软件能够按照开发者预期、正常地执行任务，提供与威胁相适应的安全能力，从而避免存在可以被利用的安全漏洞，并且能从被入侵和失败的状态中恢复。由于信息系统以及系统所承载业务的风险很大程度上与软件安全息息相关，软件安全保障已经成为当前信息安全需要解决的关键问题。

软件安全保障的目标是在软件开发生命周期中提升软件的安全性，主要目的如下。

（1）可信赖性：无论是恶意而为还是无意疏忽，软件都没有可利用的漏洞存在。

（2）可预见性：对软件执行时其功能符合开发者的意图的信心。

（3）遵循性：将（软件开发）跨学科的活动计划并系统化，以确保软件过程和软件产品满足需求、遵循相关标准。

在软件安全保障中，需要贯彻风险管理的思想。由于软件自身存在漏洞，而客观上又存在外部威胁，而且一旦条件满足，则势必造成安全问题，对软件的执行后果造成影响。软件用户需要树立对软件安全控制的信心，该信心是通过保障活动来获取的。安全保障的作用不是直接使软件系统增加抗拒安全威胁的能力，而是试图证明软件系统已满足了其安全目标，使用户对降低预期的风险抱有信心，这种信心来源于对安全控制正确性和充分性的评估。如果控制风险的安全控制是正确的和足够充分的，那么软件系统完成预定任务时可能面临的风险就会是用户可接受的，用户就会对软件有信心。

软件安全保障的思路是通过在软件开发生命周期各阶段采取必要的安全考虑和相适应的安全措施，尽管不能完全杜绝所有的安全漏洞，也可以做到避免和减少大部分安全漏洞。

10.1.3 软件安全开发生命周期模型

要想减少软件自身的安全漏洞或者缓解软件自身安全漏洞的危害，则必须从软件开发的过程开始着手，改进软件的开发过程，使之从需求分析阶段就开始考虑软件的安全需求，在设计阶段就设计符合安全准则的功能，并设计保障安全的安全功能与安全策略，在编码阶段保证开发的代码符合安全编码规范，并通过安全测试和运行维护，确保安全需求、安全设计、安全编码各个环节得以正确有效的实施。

软件安全开发过程即对传统软件开发过程进行改造，在其各个阶段添加安全措施和安全手段，防止因设计、开发、提交、升级或维护中的缺陷而产生不该有的软件漏洞和脆弱性。软件安全开发的目标是开发安全的软件，即软件能够按照开发者的意图执行，并且在受到恶意攻击的情形下依然能够继续正确运行。

可以看出，软件安全开发涵盖了软件的整个生命周期。软件生命周期是软件从产生直

到报废的生命周期，周期内一般包括需求分析、系统设计、代码编制、软件测试、运行维护等阶段。基于此概念，安全软件开发生命周期（Secure Software Development Lifecycle，SSDL）是一种强调具有安全设计和安全措施的软件生命周期，即通过软件开发的各个步骤来确保软件的安全性，其目标是最大限度地确保软件的安全。

根据 NIST 的研究显示，如果软件开发商能够在软件开发过程中给予软件安全问题更多的重视，并尽可能在软件开发生命周期的早期就发现软件中存在的安全漏洞的话，能够节约大量的成本。在软件系统发布以后才进行漏洞修复代价是最高的，而其也会给软件系统的使用者带来无法估量的损失。研究数据表明，在软件发布后对安全漏洞的修复所需的成本至少是在软件设计和编码阶段就进行修复的 30 倍。因此，要使软件的安全性达到较高的水平，不仅仅要在整个软件开发生命周期来考虑安全性，而且更要注重在软件开发的需求分析和系统设计阶段就开始考虑安全性。

1．SDL（安全开发生命周期）

SDL 基于 3 个核心概念：教育、持续过程改进和责任。对软件开发小组中的技术工作角色进行持续不断的教育，这一点至关重要。因为安全风险不是静止不变的，所以 SDL 非常重视了解安全漏洞的原因和后果，要求定期评估 SDL 过程并随着新技术的发展和新威胁引入应对措施。

SDL 将软件开发生命周期划分为 7 个阶段，并提出了 17 项重要的安全活动，如图 10-6 所示。

图 10-6　微软 SDL 阶段定义

这 7 个阶段的主要含义和目的如下。

（1）培训

针对开发团队和高层进行安全意识与能力的培训，以确保 SDL 能有效实施，同时能针对新的安全问题与形式持续提升团队的能力。

（2）需求

通过安全需求分析，确定软件安全需要的安全标准和相关要求。

（3）设计

通过分析攻击面，设计相应的功能和策略，降低和减少不必要的安全风险。同时通过威胁建模，分析软件或系统的安全威胁，提出缓解措施。

（4）实现

按设计要求，实现对应功能和策略，以及缓解措施涉及的安全功能和安全策略。同时通过安全编码和禁用不安全 API，减少实现时导致的安全问题，不引入编码级安全漏洞，并通过代码审计等措施来确保安全编码规范的实行。

（5）验证

通过安全测试的手段，检测软件的安全漏洞，并全面核查攻击面，各个关键因素上的威胁缓解措施是否正确得以实现。

（6）发布

建立相应的响应计划，进行最终安全核查，并完善相应的安全指导文档以提交给用户使用。

（7）响应

响应安全事件与漏洞报告，实施漏洞修复和应急响应。同时发现新的问题与安全问题模式，学习到新的知识，将它们用于 SDL 的持续改进过程中。

在这 7 个阶段中，SDL 要求前 6 个阶段的 16 项安全活动，为开发团队必须成功完成的必需安全活动，这些必需活动由安全和隐私专家确认有效，并且会作为严格的年度评估过程的一部分，不断进行有效性评析。同时，SDL 认为开发团队应保持灵活性，以便根据需要，选择可选安全活动，如人工代码评析、渗透测试、相似应用程序的漏洞分析，以确保对某些软件组件进行更高级别的安全分析。关于这些安全活动的详细说明和最新资料可以从 SDL 的公开文档得到，SDL 的官方网址为 http://www.microsoft.com/sdl。

微软在内部开发中使用了大量自己开发的辅助安全开发过程的工具，并且将其中的一部分发布出来。

2．CLASP（综合的轻量级应用安全过程）

综合的轻量级应用安全过程（Comprehensive Lightweight Application Security Process，CLASP）最初由安全软件公司（Secure Software，Inc.）提出，后来由开放 Web 应用安全项目（The Open Web Application Security Project，OWASP）完善、维护并推广。

CLASP 是一个用于构建安全软件的轻量级过程，包括由 30 个特定的活动和辅助资源构成的集合，用于提升整个开发团队的安全意识，并针对这些活动给出了相应的指南、导则和检查列表。

CLASP 的一个很大特点是其安全活动基于角色安排，强调安全开发过程中的角色和职责。软件开发不同阶段的安全活动需要指派不同的角色负责和参与。这些角色分别包括项目经理、需求专家、软件架构师、设计者、实施人员、集成和编译人员、测试者和测试分析师、安全审计员。对于每一项基于角色的安全活动，CLASP 都对以下问题进行了描述。

（1）安全活动应该在什么时间如何实施？

（2）如果不进行这项安全活动，将会带来多大的风险？

（3）如果实施这项安全活动，估计需要多少成本？

CLASP 所采用的流程和其他软件安全开发流程相比是属于轻量级的。它使企业能够使

用并不烦琐而且仍然系统的流程开发出安全的软件产品，并且也能够和多种软件开发模型相结合。

CLASP 的主要目标是支持构建安全处于中心地位的软件，其安全活动大都从安全理论的角度定义和构思，因此，安全活动的覆盖面相当广泛。同时，CLASP 通过一些安全最佳实践将安全属性以一种结构化、可重复和可测量的方式整合进软件开发组织的现有或者将要展开的软件开发生命周期中。其相互独立的安全活动以结构化组织的方式集成到开发过程和运行环境中。为了灵活性，要执行的安全活动及其执行顺序的选择是开放的，不同开发者可以自行裁剪以适应待开发产品的实际情况。

3．CMMI（软件能力成熟度集成模型）

CMMI 是在美国国防部资助下，由卡内基梅隆大学软件工程所建立，用于评价软件开发组织过程能力成熟度的模型，后来该模型被用于软件开发组织内部的软件过程改进。

CMMI 里面的所有要求都来自于成功企业的最佳实践，涉及产品的开发和维护活动、覆盖产品从概念提出到交付和维护的整个生存周期。

CMMI 的 5 个级别如下。

（1）CMMI Level 1，初始级。软件过程是无序的，有时甚至是混乱的，对过程几乎没有定义，成功取决于努力。管理是反应式的。

（2）CMMI Level 2，可管理级。建立了基本的项目管理过程来跟踪费用、进度和功能特性。制定了必要的过程纪律，能重复早先类似应用项目取得的成功经验。

（3）CMMI Level 3，已定义级。已将软件管理和工程两方面的过程文档化、标准化，并综合成该组织的标准软件过程。所有项目均使用经批准、剪裁的标准软件过程来开发和维护软件，软件产品的生产在整个软件过程是可见的。

（4）CMMI Level 4，量化管理级。分析对软件过程和产品质量的详细度量数据，对软件过程和产品都有定量的理解与控制。管理有一个做出结论的客观依据，管理能够在定量的范围内预测性能。

（5）CMMI Level 5，优化管理级。过程的量化反馈和先进的新思想、新技术促使过程持续不断地改进。

CMMI 的每个等级都由几个过程域组成，这几个过程域共同形成一种软件过程能力。每个过程域都有一些特殊目标和通用目标，通过相应的特殊实践和通用实践来实现这些目标。当一个过程域的所有特殊实践和通用实践都按要求得到实施，就能实现该过程域的目标。

CMMI 为企业带来的价值主要体现在以下几个方面。

（1）能保证软件开发的质量与进度，能对“杂乱无章、无序管理”的项目开发过程进行规范。

（2）有利于成本控制。因为质量有所保证，浪费在修改、解决客户的抱怨方面的成本会降低很多。绝大多数情况是缺少规范制度，只是求快。项目完成后，要浪费很多时间修修补补，费用很难控制。

（3）有助于提高软件开发者的职业素养。每一个具体参与其中的员工，无论是项目经

理，还是工程师，甚至一些高层管理人员的做事方法逐渐变得标准化、规范化。

（4）能够解决人员流动所带来的问题。公司通过过程改进，建立知识库以共享经验，而不是单纯依靠某些人员。

（5）有利于提升公司和员工绩效管理水平，以持续改进效益。通过度量和分析开发过程和产品，建立公司的效率指标。

4．SAMM（软件保证成熟度模型）

软件保证成熟度模型（Software Assurance Maturity Mode，SAMM）最初是由独立软件安全顾问 Pravir Chandra 创建，并由 Fortify 软件公司资助。SAMM 于 2009 年正式发布 1.0 版本，目前由 OWASP 组织作为一个开放的项目来维护。

SAMM 提供了一个开放的框架，用以帮助软件公司制定并实施所面临来自软件安全的特定风险的策略，SAMM 提供的资源可用于以下方面。

- 评估一个组织已有的软件安全实践。
- 建立一个迭代的权衡的软件安全保证计划。
- 证明安全保证计划带来的实质性改善。
- 定义并衡量组织中与安全相关的措施。

SAMM 规定了 4 个软件开发过程中的核心业务功能，包括治理、构造、验证以及部署，这 4 个业务功能各包括了 3 个安全实践。

（1）**治理**：专注软件开发企业组织管理其软件安全开发相关的过程、活动和措施，主要包括策略与指标、教育与指导、政策与遵守等三项安全实践。

（2）**构造**：关注与软件安全开发中需求、目标和架构方面的过程、活动和措施，主要包括安全需求、威胁评估和安全架构 3 个方面的安全实践。

（3）**验证**：注重软件检查和测试中的过程、活动和措施，主要包括设计审核、安全测试和代码审核三项安全实践。

（4）**部署**：强调了软件发布和部署配置时相关的过程、活动和措施，主要包括环境强化、漏洞管理和操作启用 3 项安全实践。

SAMM 的总体框架如图 10-7 所示。

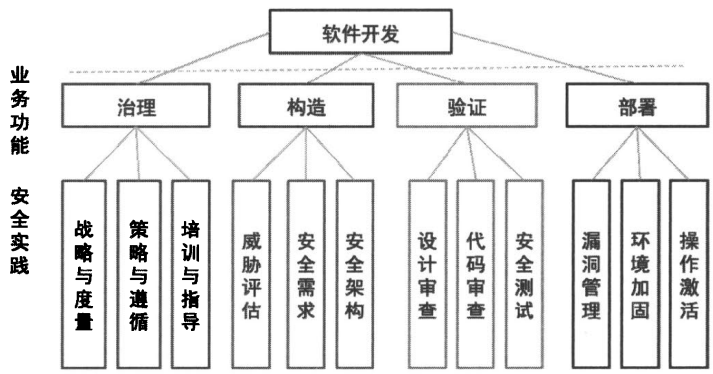

图 10-7　SAMM 总体结构

SAMM 的每个安全实践是一个与安全相关的措施，以便保证相关业务功能的实现。所以，从总体来说，这 12 个安全实践都是改进软件开发业务功能的独立部分。

对于每一个安全实践，SAMM 设置了 3 个成熟度等级和一个隐含的零起点。每个等级的细节对不同实践有所不同，但它们普遍代表的含义如下。

- 0：隐含的 0 起点代表实际没有实现该安全实践。
- 1：对安全实践有了初步了解并有专门的设计和使用。
- 2：进一步提高了安全实践的效率和有效性。
- 3：在一定规模上综合、有效地掌握了安全实践。

对于某个特定的软件开发项目或软件开发企业，使用 SAMM 对其进行评估，有以下两种推荐的评估方法。

- 简单方法：对每项安全实践进行评估，并为得到的评估结果评定分数。
- 详细方法：对每项安全实践评估后，再执行额外的审计工作，以确保每个安全实践中规定的每一项措施都已执行，且已达到成功指标。

软件企业可以参考 SAMM 作为基准来衡量其软件安全保证计划。通过使用评估和记分卡，软件开发企业能够证明其软件安全性得到循序渐进的改善，软件开发企业还可以参考 SAMM 路线图模板，以指导建立或改善一个软件安全保证计划。

5．BSIMM（BSI 成熟度模型）

BSI 成熟度模型（Building Security In Maturity Model，BSIMM）是一个针对多个软件公司的软件安全项目进行研究的模型，该模型对不同软件安全项目所采取的措施和实践进行量化，描述其共性和各自的特点。

很多软件公司一方面希望能构建功能强大而又安全的软件，另一方面却不知道该如何构建，没有其他公司的最佳实践作为参考。针对此问题，BSIMM 分析了多个真实的软件安全项目的实践数据，提炼出这些软件公司和软件项目中的共同特点，其目的是帮助更大范围的软件安全公司对其各自的项目进行安全规划、实现和评测。因为 BSIMM 中分析的原始数据来自于当前国际上很多著名的大型公司，包括美国银行、美国第一资本银行、微软、谷歌、英特尔以及赛门铁克等，所以其分析结果体现了当今业界软件安全技术的领先水平。而对软件安全感兴趣的公司，可以参考这个结果来指导自己的实际软件安全开发　实践。

BSIMM 研究开始于 2009 年，出版了 BSIMM 1，当时对来自软件厂商、技术公司和金融服务业界的 9 个顶尖软件安全项目进行了数据收集和分析；2010 年，BSIMM 2 公布，该版本对 30 个软件公司的软件安全项目进行了数据收集和分析；2011 年，BSIMM 3 发布，该版本对每个软件安全项目所研究的内容全面更新考察要求，并将被研究的公司数量增加到 42 个。

6．各软件安全开发模型的特点

事实上，SDL、BSI 系列、CLASP 以及 SAMM 都提供了一个广泛的活动集合，覆盖了软件开发生命周期的多个方面。这些模型大都经过相关公司或安全组织的实践验证，如微

软在内部强制使用 SDL、加入 OWASP 的多家顶级安全公司使用 CLASP 进行软件安全开发管理等。与传统的软件开发模型相比，应用这些模型有助于提高软件产品的安全性。软件企业可以根据自身实际，依据模型对现有的软件开发过程制订改进计划，持续不断地提升管理和开发水平，以保障软件产品的安全性。

从这些模型包含的内容看，它们之间既有很多相同的特点，也有很多不同，这几种模型各自的特点可以概括如下。

（1）SDL

SDL 由微软提出，其相关文档较为丰富。在投入大量的人力、物力进行研究和实践后，微软不断更新升级 SDL 版本，并通过专门网站和开发者社区对 SDL 进行推广。同时，SDL 还具有一个鲜明的特点，就是具有较多的自动化工具支持。SDL 重视各种工具的使用，支持从需求阶段到测试阶段的各种工具，如威胁建模、静态源代码分析等工具，这些工具既有免费的，也有商业化的。

由于 SDL 体系较为完善，和其他安全开发流程相比，SDL 被认为实施要求严格，适于大型机构使用。

（2）CLASP

CLASP 是一个用于构建安全软件的轻量级过程，应用该方法可以比较好地处理那些可能导致安全服务出现漏洞的软件脆弱性。CLASP 强调安全开发过程中的角色和职责，其安全活动基于角色安排。CLASP 既可能用于启动一个新的软件开发项目，也容易和已有的软件开发项目进行集成，它使企业能够使用并不烦琐且系统的流程开发出安全的软件产品。在实践中，CLASP 容易存在的一个问题是，其定义的有些角色可能无法和某些企业中的现有人员安排进行对应。

与 SDL 相比，CLASP 所采用的流程属于轻量级，也能够和多种软件开发模型相结合，因此，对小型软件企业更具有吸引力。

（3）CMMI

CMMI 的中心思想是：只要集中精力持续努力去建立有效的软件工程过程的基础结构，不断进行管理的实践和过程的改进，就可以克服软件开发中的困难。CMMI 为改进一个组织的各种过程提供了一个单一的集成化框架，新的集成模型框架消除了各个模型的不一致性，减少了模型间的重复，增加了透明度和理解，建立了一个自动的、可扩展的框架。

（4）SAMM

SAMM 为软件安全开发提供了一个开放的框架，软件企业可以参考 SAMM 来衡量其软件安全保证计划，制定软件开发安全策略，创建明确定义和可衡量的目标，并循序渐进地改善软件开发过程。

与其他几个模型相比，SAMM 的目标在于制定简单、有良好定义，且可测量的软件安全开发模型，其对安全知识的要求更低，更适用于非安全专家使用。

为便于理解和使用 SAMM，它提供了一个安全活动级别的映射表，可以将 BSIMM 的

109 个安全活动映射到 SAMM 中的 72 个安全活动。

（5）BSI 系列

BSI 认为软件安全有 3 根支柱：风险管理、软件安全接触点和安全知识，其强调了在软件的整个生命周期中风险管理的重要性，并要求风险管理框架贯穿整个开发过程。BSI 明确了安全知识在软件安全中的重要性，但是没有强调要把安全培训作为软件安全开发的先决条件。

软件安全接触点针对软件安全开发中可能出现的问题，通过从“白帽子”和“黑帽子”两个角度出发，提出了 7 个工作接触点（实践方法），以在软件开发生命周期的每一个阶段尽可能地避免和消除漏洞。同时，软件安全接触点具有较好的通用性，能够和不同的软件开发模型相结合。软件安全接触点从顶层给出安全实践要求，但是对于执行安全实践的具体细节描述不多。

BSIMM 收集了很多软件企业在软件安全开发方面的措施和方法，并按照软件安全开发框架进行描述，找出这些软件企业的共同点和不同点，从而给其他企业提供实践参考。因此，尽管 BSIMM 本身不提出任何建议，软件企业还是可以根据 BSIMM 的数据了解常用的软件安全开发措施，同时可以用来和自己的开发方法进行比较。

10.2　知识子域：软件安全需求及设计

在软件的生命周期中，需求分析和软件设计都是应该在软件编码之前开始的工作，而所有的软件安全开发模型，也都为安全需求分析和软件安全设计的有关活动预留了位置。需求分析和软件设计阶段一旦出现失误，在软件生命周期的后期再挽回，其代价将是非常昂贵的。因此软件开发企业一定要重视软件安全需求分析和软件安全设计过程。这两项工作做得好，可以为开发出安全的软件奠定良好的基础。

安全需求分析应当以风险管理为基础，建立“危险”分析计划，建立软件安全需求定义，以确保软件安全需求定义的正确性，并完成相关文档的撰写。对于软件系统的每一项需求，都应该在软件安全设计阶段认真考虑。

软件设计阶段要明确软件安全目标以及采取的有效措施，相关的安全设计内容一般包括系统安全框架、访问控制机制、主体权利和权限、加密方法和算法、数据完整性机制、敏感数据处理机制、内部通信机制等。

10.2.1　威胁建模

1．威胁建模作用

威胁建模是一种工程技术，威胁建模是以结构化的方式，识别、评估应用系统面临的威胁，其目的是在设计阶段充分了解各种可能的安全威胁，对可能的风险进行管理，并指

导选择适当的应对措施，根据设计和测试情况对安全架构和设计进行验证，从而有助于降低软件的攻击面。威胁建模在软件生命周期的需求、设计阶段就介入进行全面的威胁分析，使得安全防护成本更低，避免在软件开发后期进行成本高昂的补救。威胁建模活动可帮助识别安全目标、相关威胁、相关漏洞和对策。

一个开发团队首先需要明确项目需要保护的目标，了解有哪些威胁和漏洞能够影响保护目标，找到缓解这些威胁和漏洞的具体措施，才有可能开发出安全的软件。因此，威胁建模也是一种风险管理模型，可以适用于所有的软件产品和系统的开发。

由于应用环境的复杂，软件可能存在很多漏洞和威胁，但在实际应用中，这些漏洞和威胁不太可能都会导致软件安全问题，组织也不可能需要解决所有的问题。通过威胁建模，组织可识别出软件应用中所需要针对的威胁，从而合理地投入资源。威胁建模的作用如下。

- 形成组织的应用设计，满足安全目标。
- 帮助制定衡量安全目标的工程决策与其他设计目标。
- 通过消除常见漏洞，解决和提高工程质量。
- 通过实施必要和有效的对策，提高服务质量。
- 降低开发和运营过程中出现的安全问题的风险。

威胁建模从应用程序生命周期的架构和设计阶段开始，它是以组织的安全目标进行的。组织的安全目标是业务目标的关键部分，它们用于确定威胁建模活动的程度以及花费努力的多少。

2．威胁建模流程

威胁建模主要流程包括四步：确定建模对象、识别威胁、评估威胁和消减威胁。

（1）确定建模对象

确定要保护和评估的对象，了解软件应用的可信任边界之内的所有功能组件。威胁建模中常用“资产”来描述对象，这里资产可能指软件系统本身、信息的可用性或者信息内容本身，例如客户数据。

（2）识别威胁

发现组件或进程存在的威胁。威胁是一种不希望发生、对资产目标有害的事件。从本质上看，威胁是潜在事件，它可能是恶意的，也可能不是恶意的。因此，威胁并不等于漏洞。

（3）评估威胁

对威胁进行分析，评估被利用和攻击发生的概率，了解被攻击后资产的受损后果，并计算风险。

（4）消减威胁

根据威胁的评估结果，确定是否要消除该威胁以及消减的技术措施。在设计阶段，可以通过重新设计，以直接消除威胁，或设计采用技术手段来消减威胁。在本阶段，应在确定消减威胁手段后继续评估是否可以接受残余的安全风险。

在威胁建模实施过程中，可供参考的一些建议如下。

- 确保所有的威胁模型符合起码的威胁模型质量要求。所有的威胁模型必须包含数据流程图、资产描述、威胁与漏洞描述、缓解措施。威胁建模可以使用各种不同的方式和工具、文档来定义和创建。
- 确保威胁模型输出的数据和文件（功能/设计规范要求等）都已经被文档控制系统存储并正确地被软件开发人员所使用。
- 针对威胁上的每个漏洞形式和缓解措施，建立一个独立的工作小组进行检查和验证，这样可以让质量管理组织确保每个缓解措施都得以真正地实施。
- 针对所有的威胁模型以及提出的缓解措施，应该由至少一个开发人员、一个测试人员、一个项目经理参与审查并批准。咨询软件架构师、开发人员、测试人员、项目经理、用户或者其他软件相关的人员有助于威胁模型和缓解措施尽可能全面。

3. STRIDE 模型

微软提出使用 STRIDE 模型来进行威胁建模的实践，STRIDE 由 Spoofing（假冒）、Tampering（篡改）、Repudiation（否认）、Information Disclosure（信息泄漏）、Denial of Service（拒绝服务）和 Elevation of Privilege（提升权限）的第一个字母组合而成，如表 10-2 所示。

表 10-2　STRIDE 六类主要威胁说明

威　胁	威胁（中文）	定　义	举　例
Spoofing	哄骗	模仿其他人或实体	伪装成 microsoft.com 或 ntdll.dll
Tampering	篡改	修改数据或代码	修改硬盘、DVD 或网络数据包中的 DLL
Repudiation	抵赖	声称没有执行某个动作	“我没有发送过那封电子邮件”“我没有修改过那个文件”“亲爱的，我确实没有访问过那个网站！”
Information Disclosure	信息泄露	把信息披露给那些无权知道的人	允许某人阅读 Windows 源代码；公布某个 Web 网站的用户清单
Denial of Service	拒绝服务	拒绝为用户提供服务	使得 Windows 或 Web 网站崩溃，发送数据包并耗尽 CPU 时间，将数据包路由到某黑洞中
Elevation of Privilege	权限提升	获得非授权访问权	允许远程互联网用户执行命令，让受限用户获得管理员权限

这 6 种威胁与系统安全属性是密切相关的，理解威胁也就是理解软件系统的安全目标，威胁对应影响的安全属性及其说明如表 10-3 所示。

表 10-3　威胁与安全属性对应表

威　　胁	受影响的安全属性	说　　明
假冒（Spoofing）	可鉴别性	鉴别用户身份是否合法和正确
篡改（Tampering）	完整性	数据和系统资源只限适当的人员以适当的方式进行更改
抵赖（Repudiation）	不可抵赖性	系统在需要时一切就绪，可以正常执行操作
信息泄露（Information disclosure）	机密性	资源只限应具有权限的人员访问
拒绝服务攻击（Dos）	可用性	系统在需要时一切就绪，可以正常执行操作
特权提升（Eop）	授权	明确允许或拒绝用户访问资源

使用 STRIDE 模型进行威胁建模，应按照确定建模对象、识别威胁、评估威胁以及消减威胁 4 个步骤反复循环进行，直到所有的威胁所带来的风险都在可接受范围之内。

10.2.2　软件安全需求分析

软件安全需求是为保障实现业务功能而对相关信息的机密性、完整性和可用性提出的要求。开发一个安全的新的信息系统，需要解决的问题常常是极为复杂的。系统的安全目标是什么，系统应该提供什么样的安全服务，工作将受到什么条件约束等，这些都是安全系统的开发人员必须研究的问题，而这些问题往往是通过安全需求分析而得以解决的。

安全需求分析就是为了在软件的开发人员和提出需求的人员之间建立一种理解和沟通的机制，以确定软件的安全系统“做什么”而非“怎么做”（即如何实现）的问题。安全需求以一种清晰、简洁、一致且无二义性的方式，对一个待开发的软件中各个有意义的方面进行了陈述，它必须包含有足够多的信息，以使开发人员编制一个能使用户满意的软件系统。

信息系统安全需求的分析过程，由于具体实现存在区别，但是总的来说主要有以下几个基本的步骤。

1．系统调查

了解信息系统所处的安全环境（存在于系统边界之外并对系统的安全具有潜在的或直接影响的所有因素）及其他与安全相关的信息，例如用户、组成部件、运行机制及与其他系统的连接情况等。在此基础上确定需要保护的资产，其中可能包括硬件、软件、数据、文档和计算机服务等，并评价各个资产的相对价值。

2．定性分析系统的脆弱点和可能遭受的安全威胁

这一步骤比第一步更加困难，因为它需要一定程度的想象，以预测资产可能受到的损害及损害来自何方。系统脆弱点和安全威胁是两个互相依存的概念：没有威胁，就无所谓脆弱点；没有脆弱点，威胁也就不称其为“威胁”。所以当系统的脆弱点被确定后，就需

要针对每个脆弱点分析由此可能引发的安全威胁及其对资产可能造成损害的程度。

3．脆弱点和安全威胁的定量分析

这一步骤的目标是确定系统暴露各种脆弱点及面临安全威胁的可能性。这种可能性与当前采用的安全措施和所处的安全环境有关。对脆弱点和安全威胁的可能性进行估算是非常困难的，主要采用的是概率统计的方法，分析凭借的数据主要是操作日志、局部犯罪的统计和用户的投诉等，由此得到的结果可以进一步计算出系统承受的安全风险值。

4．需求的确定

需求分析的最后一个阶段将定性分析和定量分析的结果结合起来以定义信息系统的安全需求，然后开发人员由此确定相应的安全措施，以达到为信息系统提供有效且合理的安全保障的目的。

安全需求分析的过程并不是一蹴而就的。由于数据的不确定性和环境的不断变化，安全需求的内容需要不断地进行修正，因此安全需求的管理工作也将一直进行下去，以最终指导信息系统安全保障措施的实施。

由于安全需求对后续开发工作所起的指导性作用以及对安全系统的最终交付使用所起的评价、审定、鉴定性作用，其分析过程在整个安全系统开发过程中的地位日益突出，并受到越来越多的重视。进行充分的安全需求分析能够保证开发出的安全系统为信息系统提供充足、有效的安全保障，从而使开发人员的工作价值得以完全体现，所以可以说准确、完备的安全需求分析是安全系统得以正确、高效实现的前提。

10.2.3　软件安全设计

在软件设计阶段，需要根据安全需求方案确定的安全目标，对初步风险评估确定的控制措施的具体技术实现而进行安全设计，包括概要设计和详细设计两个阶段。

1．工作内容与活动

概要设计阶段确定应用系统的安全整体架构，安全概要设计阶段，包括但不限于：安全体系结构设计、各功能块间的处理流程、与其他功能的关系、安全协议设计、安全接口设计等；详细设计阶段作为安全功能的程序设计阶段，应当直接指导安全功能的编码工作。包括但不限于：模块设计、内部处理流程、数据结构、输入/输出项、算法、逻辑流程图等。

软件安全设计的活动包括以下方面。

（1）详细风险评估：从确定需要保护的信息资产出发，分析系统面临的安全威胁、系统自身存在的脆弱点，威胁利用弱点的影响，从而确定系统风险。

（2）控制措施选择：根据安全目标及详细风险评估的结果，从应用设计的角度选择必要的安全控制措施，并从成本、安全性、用户体验等方面综合选择最佳的控制措施。

（3）安全技术实现：完成安全控制措施技术实现的设计工作，技术实现分为三步：结构设计、模块设计及详细设计。

（4）设计审查：检查安全设计是否符合安全需求。

一旦完成功能需求定义和安全需求定义，系统设计人员就可以开始展开工作。设计人员要正确地确定系统的各个模块交互操作的方法，和如何对系统结构进行模块化划分的工作。此外，在这个阶段期间，设计管理团队通常会为不同的团队安排具体的任务，并且布置开发编码里程碑的初步完成时间。

当设计团队完成正式的设计文档后，会和项目相关人召开一个评审会议，确保每个人都同意按部就班地按照此过程进行，在朝着成功开发满足期望功能的系统的方向迈进。

2．安全设计原则

软件的安全设计应该尽量遵循一些安全设计原则，这些原则是软件开发和软件测试中有关安全经验的高度总结，用于指导安全开发人员（特别是软件架构师和设计师）开发更为安全的软件。下面是一些基本的安全设计原则。

（1）最小特权原则

对于请求存储资源的主体，只应该分配最少的必要权限，而且应该保证赋予权限分配的必要时间最短。如果授予一个用户或进程、组件超过其行为必要的权限范围的许可，该用户或进程、组件就有可能获得或修改其没有权限处理的信息。

（2）权限分离原则

尽量把软件划分为不同独立的组件，把权限分离成不同的权限许可和认证条件，把用户分离成不同的权限角色。不要将权限一次性授予给一个用户，而是根据需要提供多重的认证与检查机制再进行授予。

（3）最少共享机制原则

避免多个主体共享同一个资源，因为敏感的信息可能通过相同的机制在这些主体之间共享导致被其他用户获取。每个主体应该有不同的机制或不同的机制实例，在保证多用户存取访问的灵活性的同时，防止由单一的共享机制导致潜在违背安全性的行为。

（4）完全中立原则

每次主体对资源的请求，系统都应该实行认证和执行检查，特别是和安全相关的内容。以避免错误地赋予主体过高的权限或者在第一次授予权限之后，主体被攻击之后攻击者滥用相关权限。为了提高性能，一些系统会缓存主体的权限，这种做法易使系统具有较高的安全风险。

（5）心理可接受度原则

安全机制应该尽可能对用户透明，只引入少量的资源使用障碍，对用户友好，才能在使用时方便用户的理解和使用，真正起到安全防护的作用。如果安全机制妨碍了资源的可用性或使得资源难以获取，那么用户很可能会选择关闭这些安全机制或功能。

（6）默认故障处理保护原则

当系统失效或产生故障时，必须是以安全的方式来处理系统信息，系统故障处理默认应该是安全的设置。例如，即使丧失了可用性，也应该保障系统的机密性和完整性；故障

发生时必须阻止未授权的用户获得访问权限；发生故障后，应该不向远程未授权的用户暴露敏感信息，如错误号和错误信息、服务器信息之类。

（7）经济机制原则

复杂性是评估一个系统安全性的重要因素之一。如果设计、实现的功能是非常复杂的，那么系统存在安全漏洞的可能性则大大增加，一些问题在复杂的系统中很难被及时发现。系统的设计和实现应该尽量简单，以降低因复杂性带来的安全问题。

（8）不信任原则

开发者应该假定系统环境是不安全的。减少对用户、外部系统、其他组件的信任，对外部实体所有的输入都需要进行检查，即使对于可信的外部用户输入。另外也不应该信任每次对函数或系统的调用操作都必然会成功，如内存的分配，因此必须对每次函数或系统的调用的返回值进行检查，并进行正确的处理。

（9）纵深防御原则

软件应该设置多重安全措施，并充分利用操作系统提供的安全防护机制，形成纵深防御体系，以降低攻击者成功攻击的机率和危害。结合多重安全措施使攻击者要绕过每一个机制才能达到目的，提高了攻击者的攻击成本和要求，降低了安全危害。

（10）保障最弱环节原则

攻击者一般从系统最薄弱的环节发起攻击，而不是针对已经加固的组件。相对于破解一个数学上已经证明了比较安全的算法，攻击者更喜欢利用软件的安全漏洞。因此软件开发者必须了解自己软件的薄弱点，针对这些弱点实施更强的安全保护措施。

（11）公开设计原则

应该假定攻击者有能力获取系统足够的信息来发起攻击，而不是依赖于攻击者不知道系统设计信息来保护系统的安全。如果设计的加密算法存在弱密钥，或者系统设有万能口令，等等，攻击者通过反汇编分析能够获取这些信息，攻击者还可能是内部被辞退的员工，因此，依赖于攻击者无法掌握某些特定信息来保护自己的安全是不可靠的。

（12）隐私保护原则

系统收集到的用户信息都必须实施妥善和安全的保护。攻击者获得了用户的隐私数据之后，可以发起进一步针对用户的各种攻击，如欺骗等，不应该向其他用户泄露用户的隐私信息。

（13）攻击面最小化原则

攻击面（Attack Surface），通常也称受攻击面，是指对一个软件系统可以采取的攻击方法集合。因为攻击者对软件的攻击是从其暴露在外部的接口、功能、服务和协议等资源来实施的，通过对每种资源计算其被攻击成功的可能性，并将这些可能性综合归纳，即可衡量软件的攻击面大小。可以看出，一个软件的攻击面越大，其安全风险也就越大。

减少攻击面是安全设计中的一个重要步骤，软件设计人员需要仔细评估软件中所有的功能模块和接口的特性，分析其可能存在的安全风险，并设定相应的限制措施。如果一个功能/数据接口不是必要的，则应该取消或禁止，或者默认不开启。如果一个功能/数据接口

的配置没有特殊的理由，默认则应该按安全的方式进行设置。表 10-4 是一个可以参照的关闭或限制一些接口访问方式，增加一些安全的保障措施或技术的方式。

表 10-4　一些可降低攻击面的例子

较高受攻击面	较低受攻击面
默认执行	默认关闭
打开网络连接	关闭网络连接
同时侦听 UDP 和 TCP 流量	仅侦听 TCP 流量
匿名访问	鉴别用户访问
弱 ACLs	强 ACLs
管理员访问	普通用户访问
统一默认配置	用户可选的配置
ActiveX 控件	.NET 代码

10.3　知识子域：软件安全实现

此阶段将软件的设计转换成计算机可运行的程序代码，因此在软件设计阶段进行了良好的设计后，紧接着在编码阶段也应该继续提高和执行安全开发的意识，以确保最终得到安全的软件。

10.3.1　安全编码原则

通常在编码阶段，人们会使用一些开发工具来提高代码的编写效率，也会使用多种编程语言，如 C、C++、Java 等，对于不同类型的软件开发，选择合适的编程语言也是很重要的。另外，在程序编码中必须要制定统一、符合标准的编写规范，以保证程序的可读性、易维护性，提高程序的运行效率。

就软件安全编码而言，一些安全组织和企业已经公开了一些编码标准和规范，可以供软件开发团队参考，如 CERT 发布的有关 C、C++、Java 等语言的著名安全编码标准，OWASP 也发布了《OWASP 安全编码规范快速参考指南》提供了一种综合的清单模式。同时，一些企业和安全专家撰写的一些安全编码书籍，也提出了不少有益的安全编码原则和规范参考。

根据每个项目开发语言和应用环境特性不同，每个软件开发企业可以根据自己的特定需求，结合标准的安全编码规范来制定适合自己项目的安全编码规范。本节介绍一些通用的安全编码准则，作为原则性的安全编码要求，适用于不同的编程语言和开发环境。

1．验证输入

安全软件的第一道防线是检查每一个不可信的输入。如果能不让恶意的数据进入软件，

或者至少不在软件中处理它，那么该软件程序在面对攻击时将更加健壮。验证输入和网络安全防护中的防火墙保护原理很类似，是对外部输入进行过滤控制。

在输入数据第一次进入软件中时，需要对其进行验证是显而易见的，这也是验证输入的必要的一环。事实上，有经验的软件开发人员还会在第一次使用输入数据时对其进行检查和验证，以保障软件接收到符合要求的输入数据，并成功执行。一般地，有些软件开发人员会使用公共模块接收外部输入数据，此时可采用公用验证模块对数据进行安全检查和验证。因此，在输入数据真正使用时，再次有针对性地进行合法检查就显得非常有必要了。

对输入数据的验证，可以采用“黑名单”的方式，也可以采用“白名单”的方式，这两种方式效率不同，对输入数据的开放性要求也不一样，因此适合在不同的场合使用。

常见的输入源如下。

（1）命令行参数：有些软件程序启动时能接收来自命令行的参数输入，对这些参数需要进行严格的检查，包括参数的数量、格式和长度等。

（2）环境变量：软件程序中可能读取、使用环境变量，由于常会误认为环境变量是操作系统的变量，软件开发人员容易认为其可信，从而忽视对其的验证。环境变量作为输入有可能存在的危险包括长度过长、内容篡改、格式不符等。

（3）文件及文件名：考虑到外部文件更容易被攻击者篡改，因此软件程序中读入外部文件时，需要对文件进行验证，检查的内容同样包括长度、格式和内容等各个方面。此外，对文件名也需要加强输入检查，不同的操作系统可能采用不同的文件命名要求，甚至对文件名的路径保护、链接使用等措施也不一样，软件程序如果不对输入的文件名进行检查，可能被攻击者利用以篡改或删除某些系统文件。

（4）网络数据：网络数据是高度不可信的。只要是通过网络传递过来的数据，不管是数据内容本身，还是组成网络包的数据头（如表示来源 IP 地址区域），都是极容易被攻击者篡改和伪造。因此，对网络数据更需要进行严格的验证检查。

（5）其他来源：软件程序还存在很多其他的输入，如信号、内存映射、系统管道等，安全的程序不应当忘记对这些输入来的数据进行验证检查。

对输入的验证检查，具体到不同的软件程序中有不同的要求。一般地，对字符串、数字、文件名、邮件地址、URL 等不同的数据串有不同的通用性规则，如数字主要检查整数溢出、合法范围等；对邮件地址主要检查格式、特殊字符等；对文件名主要检查长度、特殊字符等。

2．避免缓存溢出

缓冲区溢出是指当计算机向缓冲区内填充数据时超过了缓冲区本身的容量，溢出的数据覆盖了合法数据。当软件程序对输入数据长度检查不够，并且允许超过长度的数据存储到缓冲区中，则会导致缓冲区溢出发生。缓冲区溢出是一种非常普遍、非常危险的漏洞，在各种操作系统、应用软件中广泛存在。利用缓冲区溢出攻击，可以导致程序运行失败、系统崩溃、系统被恶意控制等后果。

C 和 C++的语言允许程序员随意处置指针和数组，并且将对缓冲区（如数组）的边界检查工作交给程序员来处理。如果在程序将输入数据读入或复制到缓冲区中时，安全经验不足，或者轻易相信输入数据，程序员不会主动编写代码来检查目标空间是否足够，就容易产生缓冲区溢出。

同时，C 和 C++附带了大量基础库，这些库中存在容易导致缓冲区溢出的危险函数，即基础库中的大量函数在复制数据时也缺乏对目标缓冲区空间的检查。因此，在软件程序中，使用这些函数时需要非常慎重。

尽管除了 C 和 C++外的其他高级编程语言加强了对缓冲区溢出的防护，增加了一些保护机制，如主动对缓存边界进行控制，但是并不能说使用其他语言就不存在缓冲区溢出的危险。一方面由于 C 语言具有使用广泛、功能强大且高效灵活等特性，许多其他高级编程语言依赖于使用 C 语言库，另一方面有些高级编程语言出于高效运行的考虑，允许程序员关闭该缓存溢出保护特性的机制，因此，不管使用哪种语言，开发人员需要提高安全意识而避免出现缓冲区问题。

对于避免缓冲区溢出，可以使用很多安全防御措施。

（1）精心编程避免缓冲区溢出。编写程序时，应当严格检查缓冲区长度，避免出现将过长的数据复制到长度较小的缓冲区空间，程序员一方面要预估并控制输入数据的长度，并且根据需要动态地申请/分配内存以便灵活处理具有不定长度的输入数据，甚至在处理更长输入数据时采用分段复制、分段处理的程序流程。

（2）使用替代的安全函数或函数库。不使用 C 或 C++语言中那些存在缓冲区溢出问题的函数，而改用一些更安全的函数，如使用 strncpy()代替 strcpy()；此外，可以使用一些知名的底层库来代替使用 C/C++语言提供的基础库，如采用 Libmib、libsafe 等，这些库提供了一些更为安全的基础函数。

（3）基于探测方法防御，使用更新、更具安全性的编译环境，打开一些具有安全防御机制的选项。有些高级编程环境会在复制用户数据之前主动探测目标空间，将一个“探测”值插入返回地址的前面，以保证不会出现缓冲区溢出，如 Immunix 提供的 StackGuard、OpenBSD 提供的 ProPolice、Microsoft 提供的/GS 选项等。

（4）非执行的堆栈防御。这种方法要求不允许执行堆栈上的代码，从而防止攻击者利用缓冲区溢出后执行堆栈上的代码。这包括为 OpenWall 所使用 non-exec 补丁和为 Red Hat/Fedora 所使用 exec shield。

3．程序内部安全

软件程序在编码完成实际部署后，在实际运行过程中，会碰到各种情况，如每次运行时操作系统内存分配情况不同、系统资源分配情况不同、不同用户的输入不同、同时存在的其他进程不同、网络连接情况不同等。这些不同情况不可能在软件测试过程中模拟得到，只有靠良好的软件设计和编码来保证软件的正确运行，因此，软件在代码执行过程中，动态地检查自身运行情况，确保软件按照预期正确处理各种情况。

（1）程序内部接口安全：软件程序内部也存在多个组件、多个函数之间的互相调用，因此，组件或函数的调用过程也需要检查能否调用成功，参数传递是否合理和安全。一个简单的例子是，某个软件内部需要将用户的中文姓名由一个函数传递给另外一个函数，如果被调用函数想当然地只分配了 8 个字节的空间来接收该中文姓名，那么在碰到有 5 个汉字的中文姓名时就会出现问题。

（2）异常安全处理：软件程序在运行过程中可能会出现某种错误而导致中断正常的控制流，这就是异常现象。对于异常，软件程序应当提供异常安全处理代码，使其能检测出各种异常，并安全处理各种可能的运行路径，保证程序总能“正确”地运行。不提供异常处理代码的软件程序可能会在异常发生时停止运行，严重的甚至可能引发安全问题。如某个银行转账程序，如果在用户试图转账时发生运行时错误（比如要调用的某个动态库加载不成功），没有安全处理程序，则该软件程序可能会导致用户的资金已经转出，同时接收方账号尚未收到资金的情况。

（3）最小化反馈：最小化反馈是指在程序内部处理时，尽量将少的信息反馈到运行界面，即避免给予不可靠用户过多的信息，防止不可靠用户据此猜测软件程序的运行处理机制。最小化反馈可以用在成功的流程，也可以用在发生错误的流程中。典型的例子如用户名和口令认证程序，不管用户是用户名输入错误还是口令输入错误，认证端都只反馈统一的“用户名/口令错误”，而不是分别告知“用户名错误”和“口令错误”，这样可以避免让攻击者猜测已经存在的用户名，并根据用户名来猜测口令。当然，作为软件程序的跟踪检查日志，可以记录较为详细的程序运行信息，而这些信息只允许有权限的人员查看。

（4）避免竞争条件：竞争条件一般涉及一个或多个进程访问某个共享资源（如某个文件或变量），这些进程在访问共享资源时没有适当地控制，如果软件程序受困于互相等待对方释放资源时，死锁就发生了。例如，如果进程 1 锁定了资源 A 并等待资源 B，而进程 2 锁定了资源 B 并等待资源 A，死锁就发生了。一种简单的死锁解决方案是要求所有进程按相同顺序锁定资源。

（5）安全使用临时文件：很多安全漏洞发生在访问已知文件名或可猜测的临时文件时。常见的情况是，程序在一个临时目录中打开一个文件，然后就将数据写到文件中，然而，如果攻击者预先创建一个符号链接，将这个临时文件指向其他文件，就有可能将数据写到那些文件中。安全使用临时文件办法包括：不在/tmp 建立临时文件，使用随机名建立临时文件，在往文件中写入数据之前检查文件是否已经存在，使用系统接口来建立临时文件等。

4．安全调用组件

软件程序几乎都不会是自包含的，它们通常都会调用其他组件，包括底层的操作系统、数据库系统、可重用的库、Internet 服务（例如 DNS）、Web 服务等。这种组件调用极大地促进了软件的发展，能让软件开发者集中精力开发自己的功能模块，并借用其他方为用户提供更为强大的功能服务。但是，这种组件在调用的同时存在很大的安全问题，即攻击者可能更为方便地利用组件发起攻击。为避免调用组件带来安全问题，建议在组件安全、

返回值安全以及传递数据安全等几个方面加强安全防护。

（1）组件安全：尽量使用自己或可信的组件，对第三方组件，应当能在具有更为详细的安全说明、获得更安全的信心，甚至是只有经过安全认证后才可以调用。在选用可用组件时，应当广泛地了解该组件是否存在安全问题，或搜索获得更广泛应用、被公众检验过不存在问题的公共组件。在正式调用任何组件之前，即使只可能调用很小的一个函数，应当先对其进行考察，获取有关使用文档，了解其中是否提及了安全性警告。

（2）返回值安全：当调用的组件函数返回时，应当对返回值进行检查，确保所调用的函数“正确”处理、结果“正确”地返回。这里正确是指被调用的组件函数按照规定的流程和路径运行完成，其中包括成功的执行路径，也可能包括错误的处理路径。当组件函数调用成功时应当检查返回值，确保组件按照期望值处理，并且返回结果符合期望，如执行read(2)时，所读取的字节数可能少于所请求的字节数；当组件函数调用错误时应当检查返回值和错误码，以得到更多的错误信息。

（3）传递数据安全：毕竟软件程序和被调用组件之间是通过系统或网络调用，在两者之间传递数据时，攻击者可能可以读到或篡改这些传递的数据，尤其当这些数据通过网络进行传递时。因此，需要采取安全措施，确保攻击者不会读取或篡改软件程序和被调用组件之间传递的数据。通常可供参考使用的安全措施包括数据加密和采用安全协议，常见的数据加密算法包括 DES、AES、RSA 等，安全协议包括 TLS、IPSec 和 OpenSSH 等。

5．禁止使用不安全函数

很多安全漏洞是与使用一些不安全的函数有关。历史上有大量的安全漏洞都是由于使用了这些不安全函数触发的，表 10-5 列举了几个早期微软高危级安全漏洞和触发的不安全的函数。

表 10-5　安全漏洞与不安全函数

微软补丁号	受影响产品/组件	危 险 函 数
MS02-039	Microsoft SQL Server 2000	sprintf
MS05-010	License Server	lstrcpy
MS04-011	Microsoft Windows（DCPromo）	wvsprintf
MS04-011	Windows（MSGina）	lstrcpy
MS04-031	Windows（NetDDE）	wcscat
MS03-045	Windows（USER）	wcscpy

因此应该禁用这类不安全的函数，而改用一些更为安全的替代函数。

项目团队应分析将与软件开发项目结合使用的所有函数，并禁用确定为不安全的函数。确定禁用列表之后，项目团队明确告知编码人员，并应使用头文件（如 banned.h 和 strsafe.h）、较新的编译器或代码扫描工具来检查代码（在适当情况下还包括旧代码）中是否存在禁用函数，并且通过源代码审查手段来保证其执行的效果。

10.3.2　软件安全编译

编写安全的代码是程序员应该养成的良好习惯。除了符合良好的安全开发规范外，仅仅是代码的编写规范不足以保障软件的安全性。在软件代码编写阶段不可避免地会存在一些潜在的安全威胁，因为编码人员也可能因为经验不足而犯下安全错误。除了要求编码人员提高程序质量之外，还应该使用安全编译技术来提高编码的安全水平，即采用最新的集成编译环境，通过这些编译环境提供的安全编译选项和安全编译机制来保护软件代码的安全性。

另外一方面，考察软件的目标运行环境，如果可能，尽量只使用最新版本的操作系统环境。如 Windows 操作系统从 Vista 开始提供了系统底层的一些防御机制，以帮助上层应用降低这些安全漏洞的危害。

10.3.3　代码安全审核

1．源代码审核的概念和原理

为了保障安全编程规范的执行，以及在开发阶段由开发小组发现安全问题，需要采用源代码审核的技术手段来予以保障。

源代码审核是指无须运行被测代码，仅通过分析或检查源程序的语法、结构、过程、接口等来检查程序的正确性，报告源代码中的可能导致安全弱点的薄弱之处，找出代码隐藏的错误和缺陷，如高风险的资源管理、组件间的不安全交互、防御渗透等。统计证明，在整个软件开发生命周期中，30%～70%的编码缺陷是可以通过源代码审核来发现的。

源代码审核可以采用人工审核和工具审核两种方式进行，可以看出，源代码审核往往要求大量的时间消耗和相关知识的积累，采用人工审核的方式不仅费时费力，还极容易产生遗漏。因此，对于软件开发团队来说，使用源代码审核工具自动化执行代码检查和分析，能够极大地提高软件可靠性并节省软件开发和测试成本。

源代码审核工具的优势如下。

- 帮助程序开发人员自动执行静态代码分析，快速定位代码隐藏错误和缺陷。
- 明显地减少了在代码逐行检查上花费的时间，提高软件可靠性并节省软件开发成本。
- 支持知识库的升级，也支持用户添加自定义的安全规则。

源代码审核工具的劣势如下。

- 存在大量的误报。由源代码审核工具的设计理念决定的，在“尽可能找出代码中可能导致弱点的薄弱之处”思想的指导下，误报大量产生。
- 存在漏报。源代码审核工具能够发现几乎所有实现层面的安全缺陷，但是对于设计层面和业务流程层面的安全瑕疵能力薄弱。

因此，在软件编码完成后，理想的做法是使用源代码审核工具审核和人工审核结合的方式对代码进行审核，能极大地减少软件中的安全问题被带入随后的软件生命周期阶段的可能性。

2．源代码审核工具

目前已经有很多源代码审核工具可供软件开发团队使用，这些工具分为开源工具和商业工具两类，开源工具中比较有名的包括 BOON、Cqual、Xg++和 FindBugs 等，商业工具中影响力较大的包括 Fortify、Coverity、CheckMax、Ounce Labs 和 SecureSoftware 等。

优秀的源代码审核工具应该具有如下一些特点。

（1）安全性

源代码审核工具应当以审核源代码的安全性为主要功能，而不是检查源代码的功能是否完整、是否执行正确。

（2）多平台性

源代码审核工具应考虑支持多种编程语言平台，支持不同的操作系统平台，以便适应现代大型软件的代码审核需要。

（3）可扩展性

安全威胁和安全漏洞总是层出不穷，新的安全规则和知识库也随着不断增加，源代码审核工具应能支持知识库升级，支持添加新的安全分析技术。

（4）知识性

源代码审核工具能为分析人员和程序员指出编码中的安全缺陷，也能同时告诉编码人员正确的安全编码方式，即提供知识的教学和传递。

（5）集成性

源代码审核工具应考虑和编程集成开发环境整合，或支持 make、ant 等编译命令，便于程序员能在编码编译时随时发现代码中存在的安全性问题。

10.4 知识子域：软件安全测试

10.4.1 软件测试

IEEE 软件测试定义为：使用人工和自动化的手段来运行或测试某个系统的过程，其目的在于检验它是否满足规定的需求或是弄清预期结果与实际结果之间的差异。以上定义明确提出了软件测试是以检验是否满足需求为目标。软件测试的目的在于发现错误，测试是为发现错误而执行程序的过程。

1．软件测试基本概念

（1）测试用例

测试用例是为某个特殊目的而编制的一组测试输入、执行条件以及预期结果，以便测

试某个程序路径或核实是否满足某个特定需求。比较通俗的说法是：指对一项特定的软件产品进行测试任务的描述，体现测试方案、方法、技术和策略。内容包括测试目标、测试环境、输入数据、测试步骤、预期结果、测试脚本等，并形成文档。

（2）测试覆盖率度量指标

测试覆盖率度量指标是测试完整性的一个手段，是测试有效性的一个度量。测试覆盖是由测试需求和测试用例的覆盖或已执行代码的覆盖表示的。最常见的覆盖评测是基于需求的测试覆盖和基于代码的测试覆盖。

- 语句覆盖：语句覆盖是最基础的覆盖要求，语句覆盖要求设计足够多的测试用例，使得程序中每条语句至少被执行一次。
- 判定覆盖：判定覆盖又称分支覆盖，它要求设计足够多的测试用例，使得程序中每个判定至少有一次为真值，有一次为假值，即程序中的每个分支至少执行一次。每个判断的取真、取假至少执行一次。
- 条件覆盖：条件覆盖要求设计足够多的测试用例，使得判定中的每个条件获得各种可能的结果，即每个条件至少有一次为真值，有一次为假值。
- 判定-条件覆盖：设计足够多的测试用例，使得被测试程序中的每个判断本身的判定结果（真假）至少满足一次，同时，每个逻辑条件的可能值也至少被满足一次。即同时满足 100%判定覆盖和 100%条件覆盖的标准。
- 条件组合覆盖：设计足够多的测试用例，使得被测试程序中的每个判断的所有可能条件取值的组合至少被满足一次。
- 路径覆盖：设计足够多的测试用例，使得被测试程序中的每条路径至少被覆盖一次。

（3）测试的信条

- 预期测试的测试结果是预先确定的。
- 好的测试用例发现错误的概率高。
- 成功的测试就是发现了错误的测试。
- 测试独立于编码。
- 需要具备应用（用户）及软件（编程）两方面的专业知识。
- 测试人员使用不同于开发人员的工具。
- 只检查常见的测试用例是不够的。
- 测试文档要能够再利用。

2. 软件测试方法

根据软件测试工作的测试策略，一般将软件测试过程分为单元测试、集成测试、系统测试和验收测试 4 个大阶段；根据对软件内部工作过程了解的程度又分为黑盒测试、白盒测试和灰盒测试；从测试过程中是否执行软件又可以将软件测试方法分为静态测试和动态测试。

（1）单元测试、集成测试、系统测试

单元测试是对软件中的基本组成单位进行的测试，如一个模块、一个过程等。它是软件动态测试最基本的部分，也是最重要的部分之一，其目的是检验软件基本组成单位的正确性。一个软件单元的正确性是相对于该单元的规约（详细设计）而言的。因此，单元测试以被测试单位的规约为基准。单元测试的主要方法有控制流测试、数据流测试、排错测试等。一般由开发这段代码的程序员自己开展该类测试。

集成测试是在软件系统集成过程中所进行的测试，其主要目的是检查软件单位时间之间的接口是否正确。它根据集成测试计划，一边将模块或其他软件单位组合成越来越大的系统，一边运行该系统，以分析所组成的系统是否正确，各组成部分是否合拍。集成测试的策略主要有自顶向下和自底向上两种。

系统测试是对已经集成好的软件系统进行彻底的测试，以验证软件系统的正确性和性能等满足其规约所指定的要求，检查软件的行为和输出是否正确并非一项简单的任务，它被称为测试的“先知者问题”。因此，系统测试应该按照测试计划进行，其输入、输出和其他动态运行行为应该与软件规约进行对比。

（2）黑盒测试、白盒测试、灰盒测试

黑盒测试意味着测试要在软件的接口处进行。是把测试对象看作一个黑盒子，测试人员完全不考虑程序内部的逻辑结构和内部特性，只依据程序的需求规格说明书，检查程序的功能是否符合它的功能说明。因此黑盒测试又称功能性测试或数据驱动测试。

白盒测试也称结构测试、透明盒测试、逻辑驱动测试或基于代码的测试，是对软件的过程细节做细致的检查。是把测试对象看作一个打开的盒子，它允许测试人员利用程序内部的逻辑结构及有关信息，设计或选择测试用例，对程序所有逻辑路径进行测试。通过在不同点检查程序状态，确定实际状态是否与预期的状态一致。

灰盒测试是一种介于白盒测试和黑盒测试之间的一种测试方法。灰盒测试关注输出对于输入的正确性，同时也关注内部表现，但这种关注不像白盒测试那样详细、完整，只是通过一些表征性的现象、事件、标志来判断内部的运行状态，有时候输出是正确的，但内部其实已经错误，这种情况非常常见，如果每次都采用白盒测试来操作的话，会造成效率低下的问题，因此需要采用灰盒测试的方式来开展测试工作。

（3）静态测试、动态测试

静态方法是指不运行被测程序本身，仅通过分析或检查源程序的语法、结构、过程、接口等来检查程序的正确性。对需求规格说明书、软件设计说明书、源程序做结构分析、流程图分析、符号执行来找错。静态方法通过程序静态特性的分析，找出欠缺或可疑之处，例如不匹配的参数、不适当的循环嵌套和分支嵌套、不允许的递归、未使用过的变量、空指针的引用和可疑的计算等。静态测试结果可用于进一步的查错，并为测试用例选取提供指导。静态测试又可分为代码走查、代码审查和代码评审。

① 代码走查

开发组内部进行的，采用讲解、讨论和模拟运行的方式进行的查找错误的活动。代码走查的目的是交换有关代码书写的思路，并建立一个对代码的标准集体阐述。在代码走查

的过程中，开发人员都应该有机会向其他人来阐述他们的代码。通常地，即便是简单的代码阐述也会帮助开发人员识别出错误并预想出对以前麻烦问题的新的解决办法。

② 代码审查

开发组内部进行的，采用讲解、提问并使用编码模板进行的查找错误的活动。一般有正式的计划、流程和结果报告。代码审查是代码评审的一种严格形式。

③ 代码评审

开发组、测试组合相关人员（QA、产品经理等）联合进行的，采用讲解、提问并使用编码模板进行的查找错误的活动。一般有正式的计划、流程和结果报告。代码审查是软件开发过程的一个阶段，在这个阶段中，代码创造者和审查人员，可能还有质量保证测试人员，一起进行代码评审。能在该阶段中就找出并更正存在的错误，相对来说比较合理，因为如果在开发软件后面的阶段或者软件交付给用户后才来处理、查找和修改程序缺陷的话，会要花费更多成本。

审查人员需要很仔细地检查代码，包括以下方面。

- 缺陷或者潜在的缺陷。
- 和整个程序设计的一致性。
- 评论的质量。
- 遵守编码标准。

代码评审通常能很好地检测出安全漏洞问题。有一些专门的应用程序可以帮助进行代码审查。自动代码评审系统可以有效地、系统化地检测源代码的潜在问题，如缓冲区溢出、竞态条件、内存泄露、代码块大小问题和重复语句等。另外，代码评审也常用于检测补丁质量。

代码审查是一种正式的评审活动，而代码走查的讨论过程是非正式的。代码审查同代码评审一样，都是对代码进行静态、人工审查的过程。在实际工作中，完全没有必要被概念所束缚，根据项目的实际情况来决定采取什么样的静态测试形式，不用严格去区分到底是代码走查、代码审查还是代码评审。

动态方法是指通过运行被测程序，检查运行结果与预期结果的差异，并分析运行效率和健壮性等，这种方法由 3 部分组成：构造测试用例、执行程序、分析程序的输出结果。所谓的软件动态测试，就是通过运行软件来检查软件的动态行为和运行结果的正确性。动态测试也是各个公司测试工作的主要方式。

（4）回归测试

回归测试是指在发生修改之后重新测试先前的测试以保证修改的正确性。理论上，软件产生新版本，都需要进行回归测试，验证以前发现和修复的错误是否在新软件版本上再次出现。

根据修复好了的缺陷再重新进行测试。回归测试的目的在于验证以前出现过但已经修复好的缺陷不再重新出现，同时不会因为修改代码而带来新的缺陷。因此，在验证修复的缺陷时不仅要验证此处，还要测试所有可能受影响的功能。

（5）验收测试

验收测试旨在向购买者展示该软件系统满足其用户的需求。它的测试数据通常是系统测试的测试数据的子集。所不同的是，验收测试常常有软件系统的购买者代表在现场，甚至是在软件安装使用的现场开展。这是软件在投入使用之前的最后测试。

验收测试需要开发方提供软件包之外，还需要提供软件开发的整个过程文档，包括但不限于系统的源代码、需求分析文档、详细设计文档、系统流程图、单元测试报告、集成测试报告和系统测试报告。

10.4.2 软件安全测试

1. 软件安全测试基本概念

一般来说，对安全性要求不高的软件，其安全性测试可以混在单元测试、集成测试、系统测试之中一起做。但是对于安全性要较高要求的软件，则必须做专门的安全性测试，以便在部署之前预防并识别软件的安全问题。

显然，传统的软件测试重点在于功能测试，其强调软件的肯定需求，强调软件应当做什么。但是，在工程项目中，这种软件测试并不能用来发现软件中的安全缺陷，不能用来验证软件安全性。因此，需要考虑采用专门的安全测试来保证软件安全性。事实上，软件安全性测试技术有着与其他传统测试类型不同的关注重点。相比传统软件测试，软件安全测试的重点在于软件的否定需求，安全性测试不但强调软件应当做什么，而且更加强调软件不应该做什么。例如，未授权用户不能访问系统数据。

随着软件技术的发展，安全性作为软件系统的质量属性受到越来越多的重视。软件安全测试是确定软件的安全特性实现是否与预期设计一致的过程，是验证软件安全等级和识别潜在安全缺陷的过程，检查软件系统是否具有一定程度的保护机制和防止受到非法侵入的能力。

安全性测试应该以攻击者所有可能的方式探测系统，寻找软件中可以被利用的弱点。安全性测试在由风险分析阶段发现的系统风险指导时最有效。这意味着安全性测试是一种创造性的测试形式，它受限于已识别的风险和测试人员的安全专业知识。

实践证明，代码覆盖范围是理解一组测试能发现多少系统缺陷的度量标准。对于安全性测试，代码覆盖范围扮演了更关键的角色。简而言之，如果程序的某个模块没有被测试，则其安全性就应该受到怀疑。一个明显的风险是未经测试的代码可能会包含特洛伊木马，表面上无害的代码会由此进行攻击。更为普遍的风险是未经验证的代码含有严重的错误，这些错误可能被攻击者利用。

2. 软件安全测试方法

尽管传统软件测试方法重点在软件功能测试，但是通过组织合适的测试步骤和适当的测试用例，也能对软件的安全质量进行测试，可以采用的测试方法包括常见的白盒测试、黑盒测试以及灰盒测试等方法。在传统测试之外，模糊测试和渗透测试是常用的软件安全

性测试方法。

（1）模糊测试

模糊测试，也称 Fuzz 测试，由 Baron Miller、Lars Fredriksen、Bryan So 首次提出，是一种通过提供非预期的输入并监视异常结果来发现软件故障的方法。

模糊测试本质上属于黑盒测试，它不关心被测试目标的内部实现，而是利用构造畸形的输入数据引发被测试目标产生异常，从而发现相应的安全漏洞。据资料分析，模糊测试是目前最有效的漏洞挖掘技术，已知漏洞大部分都是通过这种技术发现的。

模糊测试的主要步骤如下。

① 生成大量的畸形数据作为测试用例。

② 将这些测试用例作为输入应用于被测对象。

③ 监测和记录由输入导致的任何崩溃或异常现象。

④ 查看测试日志，深入分析产生崩溃或异常的原因。

模糊测试是在软件测试中强制软件程序使用畸形数据，并观察软件运行情况的一种测试方法。不够强壮的代码在处理这些畸形数据时会运行不稳定，或导致崩溃，而经过良好编码并具有足够安全性的程序则不会崩溃。

影响模糊测试效果的一些关键因素如下。

- **测试点**：由于模糊测试是通过数据通道的，所以测试点一般会选择数据通道的入口点或者可信边界点，如网络端口和协议，外部传入文件和文件类型，RPC 请求端口。
- **样本选择**：模糊测试的效果与覆盖能力，与样本选择的好坏极其相关，实施模糊测试必须依据上面的测试流程，分析和选择覆盖面广，便于测试的多个样本来保证测试的效果。
- **数据关联性**：由于模糊测试对数据的变异依赖于安全经验，对数据含义并不了解，所以如果一个样本是数据关联的，模糊测试由于无法同步这种关联，导致生成的样本都成为无效样本，在程序预处理之前就判断为不合格不再继续，这样就达不到测试的效果。数据存在关联性的软件和程序并不适合采用模糊测试，现在有一些替代的技术，如智能模糊测试，允许用户描述数据结构的关联性，以辅助生成符合关联规则的测试样本。
- **自动化框架**：实现无人值守自动化测试和记录，是提高黑盒安全测试能力的关键。黑盒安全测试依靠大量的异常样本来进行测试，靠机器替代部分人力来发现安全问题，实现无人值守自动化测试和记录就是必须的组件。几乎所有的黑盒安全测试都支持自动化框架，以及行为录入回放的功能，以便更好地实施自动化测试。
- **异常监控与异常恢复**：发现异常的能力是发现漏洞的前提。目前大多数黑盒安全测试工具只支持对程序崩溃异常的发现，其实这是远远不够的，很多异常并不直接表现为程序的崩溃，如 VISTA/WIN7 下的堆溢出，受 GS 保护的堆栈溢出，资源消耗型拒绝服务等。好的黑盒模糊测试工具需要对更多的异常进行监控。此外，

为保障安全测试的效果和自动化过程，除了对于发现的异常进行现场保护记录外，还需要恢复异常状态以进行后续的测试，并保证准确性。

- **分析评估**：通过异常样本重现异常，人工分析异常原因，判断是否为潜在的安全漏洞，如果是安全漏洞，就需要进一步分析其危害性、影响范围、修复建议，以及临时防范措施。由于可能产生大量的异常报告，通过一些辅助分析工具，如同源异常归并等，可以有效地节省人工分析的成本。

（2）渗透测试

渗透测试是一种模拟攻击者进行攻击的测试方法，从攻击的角度来测试软件系统，并评估系统安全性的一种测试方法。与一般软件测试不同，渗透测试采用攻击者思想，从“逆向”的角度出发，测试软件系统的安全性，其价值在于可以测试软件在实际系统中运行时的安全状况。

与“正向”的安全测试方法相比，渗透测试的优点是发掘出来的安全问题都是真实的，也是较为严重的，能够被攻击者真实利用的。它的主要缺点是渗透测试和测试人员的知识、经验、素质等因素密切相关，渗透测试受测试方法和路径所限，只能到达有限的测试点，对软件系统安全关键点的覆盖率较低。

近年来，渗透测试被广泛使用，也经常被软件开发企业用来测试其软件系统的安全性，通过在实际网络环境中利用各种测试软件和脚本对目标系统发起模拟攻击，以验证是否可以找到危害目标系统安全性的途径。

由于渗透测试具有模拟攻击者行为这样一特性，而攻击者的行为没有一成不变的固定模式，所以渗透测试对不同用户的需求，切入的角度、方法各不相同，没有统一的测试步骤和操作流程，测试过程中漏洞的发现和利用尝试取决于测试者的个人知识、经验和爱好，图 10-8 给出了一个渗透测试的基本流程。渗透测试应当经过方案制订、信息收集、（高级/低级）漏洞利用、完成渗透测试报告等步骤。

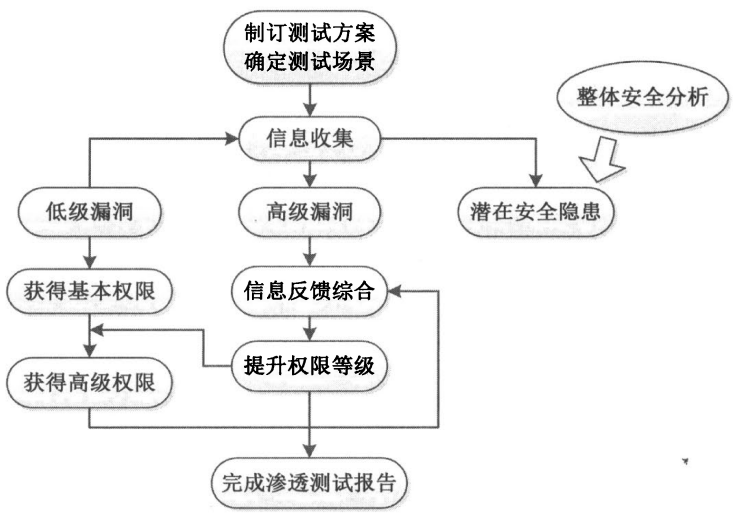

图 10-8　渗透测试框架流程

渗透测试的价值在于其能检测到系统在最终真实环境中的运行情况，发现实际环境和配置给目标系统运行带来的安全问题，以及目标系统的安全隐患是否能真正被入侵者成功利用。

渗透测试会使用多种网络安全工具，自动化的渗透测试平台也逐渐出现，比较著名的包括 IMPACT、CANVAS 和 Metasploit。其中，Metasploit 为开放源代码、可自由获取的开发框架，它集成了各平台上常见的溢出漏洞和流行的 Shellcode，并且不断更新。利用这些自动化测试平台，能实现系统漏洞的自动化探测，提高测试的效果。

值得注意的是，开展渗透测试还必须注意以下两点。

① 它是非破坏性测试

与真正的攻击不同，渗透测试的目的在于对目标系统进行安全性评估，而不是摧毁或破坏目标系统，因此渗透测试应当采用可控制、非破坏性的方法。由于在实际的渗透测试过程中，存在不可预知的风险，所以在渗透测试前要提醒用户进行系统和数据备份，以便在出现问题时，可以及时恢复系统和数据。

② 需要进行测试风险控制

在正式开始渗透测试之前，测试人员应当了解在测试中可能发生的风险，并针对风险制定有效的控制措施。如渗透测试的扫描不采用带有拒绝服务的策略，渗透测试安排在业务低峰期进行等。

利用渗透测试，除了可以较为全面地进行系统安全评估之外，还可以针对某些安全专项进行测试，比如对软件系统访问控制模块的测试、弱口令测试等。这些安全专项测试使用一般的软件功能测试、模糊测试，甚至包括逆向分析等手段很难有效完成。

与逆向分析和模糊测试相比较，渗透测试可以挖掘一些这两种方法无法发现的漏洞。例如，访问控制缺陷。目前几乎所有的网络安全设备都使用了基于角色的访问控制策略。通过逆向分析和模糊测试很难发现这种访问控制策略存在的漏洞，或者即使在模糊测试过程中发生了这种未授权的访问，但对于模糊测试工具而言，它并不理解这样的逻辑是否正确。类似的情况还有密码被猜测漏洞、配置漏洞、多因素漏洞等。

渗透测试考虑的是以入侵者方法和思路，从单点上找到利用途径，证明是否存在问题，帮助客户提高认识，能够解决一些急迫的问题，但无法针对系统做完备性的安全测试。

（3）静态代码安全测试

主要通过对源代码进行安全扫描，根据程序中数据流、控制流、语义等信息与其特有软件安全规则库进行匹对，从中找出代码中潜在的安全漏洞。静态的源代码安全测试是非常有用的方法，它可以在编码阶段找出所有可能存在安全风险的代码，这样开发人员可以在早期解决潜在的安全问题。而正因为如此，静态代码测试比较适用于早期的代码开发阶段，而不是测试阶段。

3．安全测试思路

许多软件安全测试经验告诉我们，做好软件安全性测试的必要条件是：一是充分了解

软件安全漏洞；二是评估软件安全风险；三是拥有高效的软件安全测试技术和工具。

（1）充分了解软件安全漏洞

评估一个软件系统的安全程度，需要从设计、实现和部署 3 个环节同时着手。例如 CC 标准对软件安全性的评估方式，首先确定软件产品对应的保护策略（Protection Profile，PP）。一个 PP 定义了一类软件产品的安全特性模板，例如数据库的 PP、防火墙的 PP 等。然后根据 PP 再提出具体的安全功能需求，如用户的身份认证实现。最后，确定安全对象以及是如何满足对应的安全功能需求的。因此，一个安全软件的 3 个环节，哪个出问题都不行。我们要对这 3 个环节可能产生的安全漏洞有深刻的认识。

（2）评估软件安全风险

当做完安全性测试后，软件是否能够达到预期的安全程度呢？这是安全性测试人员最关心的问题，因此需要建立对测试后的安全性评估机制。一般从以下两个方面进行评估。

① 安全性缺陷数据评估。如果发现软件的安全性缺陷和漏洞越多，可能遗留的缺陷也越多。进行这类评估时，必须建立基线数据作为参照，否则评估起来没有依据就无法得到正确的结论。

② 采用漏洞植入法来进行评估。采用漏洞植入法时，先让不参加安全测试的特定人员在软件中预先植入一定数量的漏洞，最后测试完后看有多少植入的漏洞被发现，以此来评估软件的安全性测试做得是否充分。

（3）采用安全测试技术和工具

可使用专业的具有特定功能的安全扫描软件来寻找潜在的漏洞，将已经发现的缺陷纳入缺陷库，然后通过自动化测试方法来使用自动化缺陷库进行测试。

安全测试是用来验证集成在软件内的保护机制是否能够在实际中保护系统免受非法的侵入。一句通俗的话说：软件系统的安全当然必须能够经受住正面的攻击，但是也必须能够经受住侧面的和背后的攻击。

10.5 知识子域：软件安全交付

10.5.1 软件供应链安全

1. 软件供应链安全的概念

供应链安全是目前软件安全开发生命周期中新的威胁，不同于自身的安全漏洞，供应链安全问题来自外部的恶意代码对软件代码的污染。这些安全问题涉及软件的代码编写、代码编译、软件分发、软件更新等各个环节。

（1）代码编写

随着软件开发模块化和代码复用的日益平凡，大量的共享库被程序员使用以提高开发的效率，这些共享库来自各类的开源软件，甚至成为软件开发的基础设施。针对这些共享

库进行攻击，攻击者能将恶意代码植入这些共享库中，从而随着软件的发布进入最终的用户计算环境中。

（2）代码编译

软件的编译是发布前的重要工作，而实施编译的软件如果被攻击者植入了恶意代码，那么在编译的过程中，这些恶意代码就会进入软件中，随软件的发布进入最终用户的计算机中。

（3）软件分发及更新

攻击者入侵了软件开发商的系统，在发布/更新的软件中嵌入恶意代码，利用用户对软件开发商的信任进入用户的系统中，从而给用户带来安全风险。

软件供应链安全是一种值得警惕的安全问题，攻击者找到缺乏安全管理的软件公司，利用它们攻击其客户群，最终影响到的是该软件用户对软件的信任程度。

2．软件供应链安全应对措施

软件供应链安全问题的频繁出现，使得企业在软件安全交付时应考虑如何避免这些问题以保护自己的用户。针对供应链安全问题的根源采取措施才是有效解决之道。

（1）代码编写安全

在软件安全实现阶段，应建立对引用的源代码（包括内部复用的源代码及第三方源代码）进行审核的机制，将代码安全审核覆盖到使用的第三方源代码及复用的其他软件代码中。

在进行攻击面分析及威胁建模时，应考虑第三方源代码和库的安全性问题，谨慎选择使用的第三方源代码及共享库。在软件中使用第三方源代码和共享库之前进行安全检测，并建立可使用的第三方源代码库和共享库清单，确保软件开发人员使用的源代码和库文件是安全可靠的。

（2）代码编译安全

在进行代码编译时，应确保编译环境的安全性，包括编译的操作系统安全性、编译软件自身的安全性。特别是编译软件自身，应确保从可靠的地方、采取可靠的方式获取编译软件，以避免类似 XcodeGhost 事件再次发生。

注：XcodeGhost 是针对苹果应用开发工具 Xcode 的病毒，通过非官方下载的 Xcode 进行传播。当应用开发者使用带病毒的 Xcode 进行软件编译时，APP 都会被注入恶意代码。XcodeGhost 导致了数百款 APP 被感染，其中包括银行应用 APP。

（3）软件发布及更新安全

对软件开发商，特别是面向公众发布软件的应用厂商，应更多考虑发布及更新的软件安全。建立官方的发布渠道（官方网站）或合作发布渠道，并对发布的软件提供校验码，以帮助从第三方渠道获取软件的用户检验软件是否与官方发布完全一致，从而避免攻击者通过打包重新发布的方式将恶意代码引入用户的系统中。

10.5.2 软件安全验收

在软件交付给用户并部署到生产环境之前，验收是必不可少的环节。验收是确保开发或采购的软件符合需求、质量、功能和安全保障要求的重要工作。一个正式而规范的验收过程能避免由于缺少文档导致无法有效地在用户的计算环境中运行，或权限不足、兼容性问题等影响。在目前的信息安全环境下，验收软件时，不仅需要考虑功能需求，还需要考虑安全需求。从安全角度来看，软件验收时只核查和验证业务功能，本身就是缺乏安全考虑的做法，应确保软件安全在得到认可前不应该被部署或者发布。软件安全验收应确保应用软件的功能、性能、安全、隐私都符合用户的要求，并且软件无须特定的专业人员就能进行部署和管理。软件安全验收应考虑的内容包括以下方面。

- 确保针对安全需求进行了相应的安全设计，所有安全需求都得到了满足。
- 确保软件默认培训是安全的，不会导致由于部署产生的安全问题。
- 确保软件在多样的计算环境中是安全的。
- 确保软件采取措施满足隐私保护的相关要求。
- 确保软件满足相关标准和要求，例如等级保护要求、行业信息安全保护相关要求。

在软件的交付过程中，规范的验收是发现遗漏和不可预见的安全问题的最后一个检测点，有助于保持安全的计算环境，避免不符合安全要求的软件被应用到生产环境中。

10.5.3 软件安全部署

软件安全部署是软件安全生命周期的一个重要环节，也是软件安全交付中的一项重要内容，软件开发商应提供软件部署所需要的文档和工具，指导用户如何安全地部署并使用软件。

在软件安全问题中，由于软件安全加固和配置上的错误导致的安全问题在软件安全问题中占比非常高，大量的安全事件来自这两个方面的问题。因此软件安全部署主要是通过安全加固和安全配置为用户提供良好的软件环境以应对各类安全问题。

1．软件安全部署的重要性

软件安全部署是软件安全开发生命周期中的一个重要环节，对于软件本身以及软件部署时的运行环境安全起着关键作用，同时，保障着软件后续活动的顺利进行。

软件安全部署影响着整个软件过程的运行效率和投入成本，软件系统部署的管理代价占到整个软件管理开销的绝大部分。软件安全配置过程极大影响着软件安全部署结果的正确性，应用系统的安全配置是整个安全部署过程中的主要问题。

将规划和执行作为软件部署过程的基本划分阶段，软件部署的一般过程可以归纳为“根据运行环境和应用系统信息进行部署方案的规划，然后用部署方案指导各个部署活动的具体执行，与此同时，整个过程还需要保障正确性，并满足用户的需求”。

2．软件安全加固

软件安全部署首先要确保软件本身的安全，软件安全加固和软件安全安装是确保软件安全的重要条件。软件与应用系统加固和优化服务是实现客户信息系统安全的关键环节。

安全加固是对信息系统的脆弱性进行分析并修补。安全加固包含对主机系统的身份鉴别与认证、访问控制和审计跟踪策略的增强等方面。

软件安全加固应遵循两个原则：一是风险最大化原则，不要忽视扫描报告和检查结果中的任何一个细节，将任何潜在的隐患以最大化的方式展现；二是威胁最小化原则，由于威胁是动态的，所以很难被彻底消除，故只能将其降低至可接受的程度。

3．软件安全配置

软件安全部署另一方面内容是要保证软件应用部署时的环境安全，为此，引入软件安全配置，为开发高质量、可靠的软件提供保证。安全配置错误经常会导致整个系统的一些数据或者功能可以在未授权的情况下被访问。偶尔也可能导致整个系统被攻击者控制，系统的所有数据都会被偷窃或者修改，而且，修复的代价可能会很高。因此，在产品的开发、部署和维护的过程中，需要时刻关注可能产生问题的配置，及时更新配置，将风险降到最低。

英文缩略语

A

ASME	American Society of Mechanical Engineers	美国机械工程师协会
AES	Advanced Encryption Standard	高级加密标准
AS	Authentication Server	认证服务
AAA	Authentication、Authorization、Accounting	认证、授权和计费
AC	Attribute Certificate	属性证书
ADF	Access Control Decision Function	访问控制决策点
AEF	Access Control Enforcement Function	访问控制执行点
AH	Authentication Header	认证头协议
AP	Access Point	接入点
APT	Advanced Persistent Threat	高级持续性威胁
ARP	Address Resolution Protocol	地址解析协议
ALE	Annualized Loss Expectancy	年度损失期望
AICPA	American Institute of Certified Public Accountants	美国注册会计师协会
ANSI	American National Standards Institute	美国国家标准协会
ASTAP	Asia-Pacific Telecommunity Standardization Program	亚太地区电信标准化机构

B

BYOD	Bring Your Own Device	携带你自己的设备
BLP 模型	Bell-LaPadula 模型	
BSS	Basic Service Set	基本服务集
BSA	Basic Service Area	基本服务区
BCP	Business Continuity Project	业务连续性计划
BCMS	Business Continuity Manager System	业务连续性管理系统
BCM	Business Continuity Manager	业务连续性管理

BIA	Business Impact Analysis	业务影响分析
BRP	Business Recovery Plan	业务恢复计划
BRA	Baseline Risk Assessment	基线评估
BSIMM	Building Security In Maturity Model	BSI 成熟度模型

C

CNCI	Comprehensive National Cybersecurity Initiative	国家网络安全综合计划
CPM	Critical Path Method	关键路径法
CMM	Capability Maturity Model	能力成熟度模型
CM	Capability Maturity	能力成熟度
CIA	Confidentiality、Intergrity and Availability	保密性、完整性和可用性
CCTA	Central Computing and Telecommunications Agency	英国政府部门
CBC	Cipher Block Chaining	密码块链接
CA	Certificate Authority	证书权威机构
CRL	Certificate Revocation List	证书撤销列表
CDI	Constrained Data Items	限制数据项
CD	Company Dataset	公司数据集
COI	Conflict of Interest Class	利益冲突类
CCTV	Closed Circuit Television	闭路电视监控系统
CCMP	Count Mode-CBC MAC Protocol	计数模式 - CBC MAC 协议
CHAP	Challenge Handshake Authentication Protocol	询问握手认证协议
CSRF	Cross Site Request Forgery	跨站请求伪造
COOP	Continuity of Operations Plan	运行连续性计划
CCP	Crisis Communication Plan	危机通信计划
通用标准或 CC	Common Criteria for Information Technology Security Evaluation	信息技术安全评估通用标准
CEM	Common Evaluation Method	通用评估方法
CLASP	Comprehensive Lightweight Application Security Process	综合的轻量级应用安全过程
CSBTS	China National Bureau of Technical Supervision	中国国家技术监督局

D

DES	Data Encryption Standard	数据加密标准
DSS	Digital Signature Standard	数字签名标准

DSA	Digital Signature Algorithm	数字签名算法
DAC	Discretionary Access Control	自主访问控制
DNS	Domain Name System	域名系统
DoS	Denial of Service	拒绝服务
DDoS	Distributed Denial of Service	分布式拒绝服务攻击
DMZ	Demilitarized Zone	非军事区
DAA	Digest Access Authentication	摘要访问认证
DBMS	Database Management System	数据库管理系统
DAM	Database Activity Monitoring	数据库活动监控
DRM	Digital Rights Management	数字版权管理
DOI	Digital Object Identifier	数字对象标识符
DCI	Digital Copyright Identifier	数字版权唯一标识符
DOO	Degraded Operations Objective	降级操作目标
DRP	Disaster Recovery Plan	灾难恢复计划
DoD	Department of Defense	政府国防部
DLP	Data Leakage Protection	数据防泄漏

E

ENIAC	Electronic Numerical Integrator And Computer	计算机 ENIAC
ECML	Engineering Capability Maturity Level	安全工程能力成熟度级
EV	Earned Value	挣值
ESP	Encapsulating Security Payload	封装安全载荷协议
EAP	Extensible Authentication Protocol	可扩展认证协议
EF	Exposure Factor	暴露因子
EAC	Estimated Annual Cost	年度损失期望
EAL	Evaluation Assurance Level	评估保证级
ETR	Evaluate Technical Reports	评估技术报告
ESR	Evaluation summary report	评估总结报告
ECMA	European Computer Manufacturers Association	欧洲计算机制造联合会
ETSI	European Telecommunications Standards Institute	欧洲电信标准协会
EAL	Evaluation Assurance Level	评估保证级别

F

FC	Federal（minimum safety requirements）Assessment Criteria	联邦（最低安全要求）评估准则

G

GP	Generic Practices	通用实施
GRE	General Routing Encapsulation	通用路由封装协议

H

Http	Hypertext Transfer Protocol	超文本传输协议
Https	Hyper Text Transfer Protocol over Secure Socket Layer	安全套接字层超文本传输协议
HIPAA	Health Insurance Portability and Accountability Act	健康保险便携性和责任法案

I

InfoSec	Information Security	信息安全
ICS	Industrial Control System	工业控制系统
IEC	International Electrotechnical Commission	国际电工委员会
IATF	Information Assurance Technical Framework	信息安全保障技术框架
IA	Information Assurance	信息安全保障
IS	Information System	信息系统
ISPP	Information System Protect Profile	信息系统保护轮廓
ISST	Information System Security Target	信息系统安全目标
ISAL	Information Systems Assurance Level	信息系统安全保障级
IDS	Intrusion Detectiom System	入侵检测系统
IPS	Intrusion Prevention System	入侵防御系统
ISSE	Information System Security Engineering	信息系统安全工程
ITIL	Information Technology Infrastructure Library	信息技术基础架构库
ITSM	IT Service Management	IT 服务管理
IDEA	International Data Encryption Algorithm	国际数据加密算法
ITU	International Telecommunications Union	国际电联
IETF	Internet Engineering Task Force	互联网工程任务组
IC Card	Integrated CircuitCard	集成电路卡
IVP	Integrity Verification Procedure	完整性验证过程
IP	Internet Protocol	网际协议
IPSec	Internet Protocol Security	Internet 协议安全性
IV	Initialization Vector	初始化向量

IMAP	Internet Mail Access Protocol	Internet 邮件访问协议
IM	InstantMessaging	即时通讯
IDF	International DOI Foundation	国际 DOI 基金会
IRP	Incident Response Plan	事件响应计划
ISMS	Information Security Management System	信息安全管理体系
ITSEC	Information Technology Security Evaluation Criteria	信息技术安全评估准则
IEEE	Institute of Electrical and Electronics Engineers	美国电气和电子工程师协会
ISO	International Organization for Standardization	国际标准化组织
IDOR	Insecure Direct Object References	不安全的对象直接引用
ICS	Insecure Cryptographic Storage	不安全的密码存储

K

KMI and PKI	Key Management Infrastructure and Public Key Infrastructure	密钥管理和公钥基础设施
KDC	Key Distribution Center	密钥分配中心
KPI	Key Performance Indicators	关键绩效指标
KRIS	Key Risk Indicators	主要风险指标

L

L2TP	Layer 2 Tunneling Protocol	第二层隧道协议

M

MCML	Security Management Capability Maturity Level	安全管理能力成熟度级
MAC	Message Authentication Code	消息认证码也称消息鉴别码
MS	Management System	管理体系

N

NSA	National Security Agency	国家安全局
NIST	National Institute Of Standards And Technology	国家标准和技术委员会
NIPP	National Infrastructure Protection Program	国家基础设施保护计划
NAT	Network Address Translation	网络地址转换
NRO	Network Recovery Objective	网络恢复目标
NSA	National Security Agency	国家安全局
NCSC	National Computer Security Center	国家计算机安全中心

O

OMB	Office of Management and Budget	管理和预算办公室
OGC	Office of Government Commerce	英国商务部
OSI	Open System Interconnection Reference Model	开放系统互连模型
OEP	Occupant Emergency Plan	场所紧急计划
OWASP	The Open Web Application Security Project	开放 Web 应用安全项目

P

PDR	Protection-Detection-Response	保护-检测-响应
PPDR	Policy-Protection-Detection-Response	策略-保护-检测-响应
PM	Project Management	项目管理
PDA	Personal Digital Assistant	掌上电脑
PERT	Program Evaluation and Review Technique	计划评审技术
PKI	Public Key Infrastructure	公钥基础设施
PMI	Privilege Management Infrastructure	特权管理基础设施
PPTP	Point to Point Tunneling Protocol	点对点隧道协议
PGP	Pretty Good Privacy	
PAP	Password Authentication Protocol	口令认证协议
POP3	Post Office Protocol-Version3	邮局协议-版本 3
PA 计划	Protection Analysis Project	PA 计划
PP	Protection Profile	保护轮廓
PCI-DSS	Payment Card Industry Data Security Standards	支付卡行业数据安全标准

Q

QC	Quality Control	质量控制
QM	Quality Management	质量管理
QoS	Quality of Service	服务质量保证

R

RA	Registration Authority	证书注册机构
RADIUS	Remote Authentication Dial In User Service	远程用户拨号认证服务
RBAC	Role-based Access Control	基于角色的访问控制
RB-ERBAC	Rule-based Enterprise RBAC	基于规则的访问控制模型
RFID	Radio Frequency Identification	射频识别

RISOS	Research in Secured Operating Systems	安全操作系统研究
RPO	Recovery Point Objective	恢复点目标
RTO	Recovery Time Object	恢复时间目标
RUP	Rational Unified Process	统一软件开发过程
RI	Rights Issuer	授权中心

S

SA	Situational Awareness	态势感知
SCM	Security Consultative Meeting	安全协商会议
SOC	Security Operations Center	安全管理平台
SSE-CMM	Systems Security Engineering Capability Maturity Model	系统安全工程能力成熟模型
SABSA	Sherwood Applied Business Security Architecture	舍伍德的商业应用安全架构
SE	Systems Engineering	系统工程
SSAM	SSE-CMM Appraisal Method	系统安全工程能力成熟度模型评估方法
SHA	Secure Hash Algorithm	安全 Hash 算法
ST	Service Ticket	服务票据
SSL	Secure Sockets Layer	安全套接层
S/MIME	Secure Multipurpose Internet Mail Extensions	电子邮件安全协议
SNMP	Simple Network Management Protocol	简单网络管理协议
SET	Secure Electronic Transaction	安全电子交易协议
S-HTTP	Secure Hypertext Transfer Protocol	安全超文本传输协议
SSID	Service Set Identifier	服务集标识符
STA	Station	客户端
SID	Security Identifier	安全标识符
SAK	Secure Attention Key	安全键
SMTP	Simple Mail Transfer Protocol	简单邮件传输协议
SoA	Statement of Applicability	适用性声明
SLE	Single Loss Expectance	单一损失期望
SOC	Single Occurrence Costs	单一损失期望
ST	Security Target	安全目标
SDLC	Software Development Life Cycle	软件生命周期
SAMM	Software Assurance Maturity Mode	软件保证成熟度模型
SM	Security Misconfiguration	不安全的配置管理

T

TCSEC	Trustworthy Computer System Assessment Criteria	可信计算机系统评估准则
TCML	Technique Capability Maturity Level	安全技术能力成熟度级
TGS	Ticket Granting Service	会话授权服务
TGT	Ticket Granting Ticket	票据授权票据
TACACS	Terminal Access Controller Access-Control System	终端访问控制器访问控制系统
TP	Transformation Procedure	转换过程
TCP	Transmission Control Protocol	传输控制协议
TLS	Transport Layer Security	安全传输层
TKIP	Temporal Key Integrity Protocol	
TCPEC	Trusted Computer Product Evaluation Criteria	可信计算机产品评估准则
TOE	Target of Evaluation	评估对象

U

UTM	Unified Threat Management	统一威胁管理
UDI	Unconstrained Data Items	非限制数据项
UDP	User Datagram Protocol	用户数据报文协议
UID	User ID	用户标识号
URL	Uniform Resource Identifiers	统一资源标识符

V

VLAN	Virtual Local Area Network	虚拟局域网
VPN	Virtual Private Network	虚拟专用网

W

WAN	Wide Area Network	广域网
WBS	Work Breakdown Structure	工作分解结构
WLAN	Wireless Local Area Networks	无线局域网
WEP	Wired Equivalent Privacy	有线等效保密协议
WAPI	WLAN Authentication and Privacy Infrastructure	无线鉴别和保密基础结构
WAI	WLAN Authentication Infrastructure	无线局域网认证基础设施
WPI	WLAN Privacy Infrastructure	无线局域网保密基础结构
WAF	Web Application Firewall	Web 应用防火墙